

DATA BESKYTTELSESRET

HENRIK UDSEN

Version 0.1

Henrik Udsen
Databeskyttelsesret

Version 0.1, 26. november 2022

Tilgængeliggjort på www.databeskyttelsesret.dk

Bogen kan frit anvendes til egen brug, både kommercielt og ikke-kommercielt. Det er ikke tilladt helt eller delvist at foretage direkte eller indirekte videresalg af bogens indhold.

Kapiteloversigt

	Databeskyttelsesretlige begreber og forkortelser	13
1	Introduktion til databeskyttelsesret	30
2	Forordningens og databeskyttelseslovens anvendelsesområde	61
3	Databeskyttelsesrettens aktører	89
4	De grundlæggende behandlingsprincipper	125
5	Behandlingsgrundlag	147
6	Den registreredes rettigheder	217
7	Behandlingssikkerhed	265
8	Ansvarlighed	287
9	Overførsel til tredjelande	328
10	Tilsyn	378
11	Straf og erstatning	397
	Vejledninger mv.	422
	Litteraturfortegnelse	434

Indholdsfortegnelse

Forord	10
Databeskyttelsesretlige begreber og forkortelser	13
1 Introduktion til databeskyttelsesret	30
1. Indledning	30
2. Databeskyttelsesretten som en del af personlighedsretten	33
3. De bagvedliggende hensyn	34
4. Databeskyttelsesrettens udvikling	35
5. Retskilderne	40
5.1. Grundrettigheder	40
5.2. Databeskyttelsesforordningen	42
5.3. Databeskyttelsesloven	43
5.4. Sektorspecifikke regler og danske særregler	46
5.4.1. E-databeskyttelsesdirektivet	46
5.4.2. Direktiv og lov om retshåndhævende myndigheders behandling af personoplysninger	46
5.4.3. Danske særregler	47
5.5. Retspraksis	48
5.6. Afgørelser og udtalelser fra tilsynsmyndighederne og EDPB	50
5.6.1. EDPB	51
5.6.2. De nationale tilsynsmyndigheder	53
6. Databeskyttelsesrettens grundstruktur	57
2 Forordningens og databeskyttelseslovens anvendelsesområde	61
1. Materielt anvendelsesområde	61
1.1. "Personoplysning"	62
1.2. "Behandling"	69
1.3. Automatisk databehandlingen	69
1.4. Manuelle registre	70
2. Undtagne behandlinger	70
2.1.1. I strid med ytringsfriheden	71
2.1.2. Private handlinger	73
2.1.3. Journalistisk øjemed	77
3. Territorialt anvendelsesområde	79

3.1.1.	Dataansvarlig etableret i EU	79
3.1.2.	Dataansvarlig ikke etableret i EU	83
3.1.3.	Den territoriale afgrænsning i national ret. Databeskyttelsesloven	84
3.1.4.	Beskyttelsens tidsmæssige udstrækning	86
3	Databeskyttelsesrettens aktører	89
1.	Den registrerede	89
2.	Den dataansvarlige	90
3.	Databehandleren	99
4.	Ansatte	102
5.	Forpligtelser og ansvar ved brug af databehandler	104
5.1.	Den dataansvarliges pligt til at bruge en databehandler, der overholder forordningen	105
5.2.	Databehandleraftalen	106
5.3.	Databehandlerens forpligtelser	109
5.4.	Databehandlerens brug af underdatabehandlere	112
5.5.	Den dataansvarliges kontrol med databehandleren	115
5.6.	Databehandlerens misligholdelse af sine forpligtelser	118
6.	Forpligtelser og ansvar for fælles dataansvarlige	121
4	De grundlæggende behandlingsprincipper	125
1.	Lovlighed, rimelighed og gennemsigtighed	127
2.	Formålsbegrænsning	128
3.	Dataminimering	134
4.	Rigtighed	135
5.	Opbevaringsbegrænsning	142
6.	Integritet og fortrolighed	146
5	Behandlingsgrundlag	147
1.	Generelt om art. 6	148
2.	Samtykke – art. 6, stk. 1, litra a	151
2.1.	Frivilligt	152
2.2.	Specifikt og informeret	155
2.3.	Utvetydigt	156
2.4.	Tilbagekaldelse af samtykke	159
2.5.	Børns samtykke	163
2.5.1.	Samtykke til informationssamfundstjenester udbudt direkte til børn	163
2.5.2.	Samtykke i øvrigt	165
2.6.	Konkurrence mellem samtykke og andre behandlingsgrundlag	166
3.	Specifikke former for behandling – art. 6, stk. 1, litra b-e	170
3.1.	Opfyldelse af en kontrakt – art. 6, stk. 1, litra b	170
3.2.	Overholdelse af retlig forpligtelse – art. 6, stk. 1, litra c	176
3.3.	Fysiske personers vitale interesser – art. 6, stk. 1, litra d	178
3.4.	Samfundsinteresser og offentlig myndighedsudøvelse,	

art. 6, stk. 1, litra e	180
4. Interesseafvejningsreglen – art. 6, stk. 1, litra f	186
4.1. Den dataansvarlige eller tredjemands legitime interesser	187
4.2. Nødvendighedskravet	188
4.3. Den registreredes interesser og rettigheder	189
4.4. Interesseafvejningen	190
4.5. Offentlige myndigheder	194
5. Valg og skift af behandlingsgrundlag (konkurrerende behandlingsgrundlag) – uden for samtykke	195
6. Følsomme personoplysninger	199
6.1. Forbud mod behandling af følsomme oplysninger – art. 9, stk. 1	199
6.2. Undtagelser – adgang til behandling af følsomme oplysninger efter art. 9, stk. 2	205
6.2.1. Samtykke	205
6.2.2. Arbejds-, sundheds- og socialretlige forpligtelser	206
6.2.3. Fysiske personers vitale interesser	206
6.2.4. Visse typer af organisationer	206
6.2.5. Oplysninger offentliggjort af den registrerede selv	207
6.2.6. Retskrav	207
6.2.7. Øvrige undtagelser	208
6.3. Forholdet mellem art. 6 og 9	208
7. Danske særregler	212
7.1. Videregivelse af personoplysninger i markedsføringsøjemed – DBL § 13	213
7.2. Oplysninger om straffbare forhold	215
7.3. Personnummer (CPR-nummer)	216

6 Den registreredes rettigheder 217

1. Generelt om reglerne om registreredes rettigheder	217
2. Processuelle krav – art. 12	218
3. Den registreredes ret til oplysning om indsamling (den dataansvarliges oplysningspligt)	223
3.1. Indsamling fra den registrerede	223
3.2. Indsamling fra andre kilder	229
4. Den registreredes indsigtsret	232
5. Den registreredes ret til berigtigelse	241
6. Retten til sletning (“retten til at blive glemt”)	242
6.1. Google Spain-dommen	243
6.2. Forordningens art. 17	245
7. Ret til begrænsning af behandling	251
8. Ret til dataportabilitet	255
9. Ret til indsigelse	257
10. Ret til ikke at være genstand for automatiserede individuelle afgørelser	259

7 Behandlingssikkerhed 265

1. Behandlingssikkerhed (krav om sikkerhedsforanstaltninger) – art. 32	266
--	-----

1.1.	Indledning	266
1.2.	Risikovurderingen	267
1.2.1.	Sandsynlighedsvurderingen	267
1.2.2.	Konsekvensvurderingen	268
1.3.	Valg af sikkerhedsforanstaltninger	273
1.4.	Krav om løbende vurdering	275
1.5.	Risikovurderingen i praksis	276
1.6.	Ansaret efter art. 32	277
2.	Oplysning om brud på persondatasikkerheden – art. 33 og 34	278
2.1.	Anmeldelsespligt til tilsynsmyndigheden – art. 33	278
2.2.	Pligt til at underrette den registrerede – art. 34	282

8 Ansvarlighed 287

1.	Generelt om ansvarlighed	287
2.	Den dataansvarliges pligt til at gennemføre risikobaserede lovlighedsvurderinger og etablere tekniske og organisatoriske foranstaltninger for at sikre behandlingens lovlighed	289
2.1.	Indledning	289
2.2.	Generalklausulen – art. 24	290
2.3.	Databeskyttelse gennem design og standardindstillinger – art. 25	294
2.3.1.	Databeskyttelse gennem design	294
2.3.2.	Databeskyttelse gennem standardindstillinger	302
2.4.	Konsekvensanalyse – art. 35 og 36	304
2.4.1.	Pligt til at gennemføre en konsekvensanalyse	305
2.4.2.	Indholdet af konsekvensanalysen	309
2.4.3.	Krav til form og proces	312
2.4.4.	Fornyet konsekvensanalyse	314
2.4.5.	Retsvirkning af manglende overholdelse af art. 35	314
2.4.6.	Mulighed for at foretage behandling, når der er høj risiko for de registrerede	315
2.5.	Forholdet mellem art. 24, 25, stk. 1, 32 og 35	318
3.	Den dataansvarligs pligt til at kunne påvise behandlingens lovlighed	321
4.	Fortegnelse over behandlingsaktiviteter – art. 30	321
5.	Pligten til brug af en databeskyttelsesrådgiver – art. 37-39	323
5.1.	Pligten til udpegning – art. 37	324
5.2.	Databeskyttelsesrådgiverens rolle, stilling og opgaver – art. 38 og 39	326

9 Overførsel til tredjelande 328

1.	Begreberne "overførsel" og "tredjeland"	331
1.1.	Overførsel	331
1.2.	Tredjelande	341
2.	Tilstrækkeligt beskyttelsesniveau – art. 45 (overførsel til sikre tredjelande)	342
3.	Overførsler omfattet af fornødne garantier – art. 46 (overførsel til usikre tredjelande)	347
3.1.	Standardkontraktbestemmelser	349
3.1.1.	Gennemførelsesafgørelsen	350

3.1.2.	Standardkontraktbestemmelserne	351
3.1.2.1.	Generelt om standardkontraktbestemmelserne	351
3.1.2.2.	Dataimportørens forpligtelser	351
3.1.2.3.	Lovgivningen i tredjelandet	352
3.1.2.4.	Ansvar og håndhævelse	355
3.2.	Bindende virksomhedsregler	357
3.3.	Kravene til lovgivningen i tredjelandet	359
3.3.1.	Vurderingen af tredjelandslovgivningen	361
3.3.2.	Supplerende foranstaltninger	365
3.3.3.	En risikobaseret tilgang?	366
3.3.4.	Fortsatte udfordringer	368
4.	Undtagelser i særlige situationer – art. 49	369
4.1.	Generelt om anvendelsesområdet	370
4.2.	De enkelte undtagelser	371
5.	Det nationale lokationskrav – DBL § 3, stk. 9	373
6.	Forpligtelse til at udlevere oplysninger efter lovgivningen i tredjelande	375
10	Tilsyn	377
1.	Den nationale tilsynsmyndighed - Datatilsynet	378
2.	Koordination og harmonisering af tilsynsmyndighedernes arbejde	382
2.1.	Det Europæiske Databeskyttelsesråd (EDPB)	382
2.2.	Gensidig bistand og fælles aktiviteter	383
2.3.	Sammenhængsmekanismen	384
3.	One-stop-shop ordningen	386
11	Straf og erstatning	395
1.	Erstatning	395
2.	Godtgørelse	401
3.	Bøder	407
3.1.	Administrative bøder efter art. 83	407
3.2.	Bøder efter DBL § 41	409
3.3.	Bødemodeller	411
3.4.	Praksis	413
4.	Fængsel	414
5.	Koordination og harmonisering af tilsynsmyndighedernes arbejde	415
5.1.	Det Europæiske Databeskyttelsesråd (EDPB)	415
5.2.	Gensidig bistand og fælles aktiviteter	416
5.3.	Sammenhængsmekanismen	417
	Vejledninger mv.	421
	Vejledninger knyttet til forordningens enkelte bestemmelser	421
	Tematiske vejledninger	430
	Litteraturfortegnelse	433

Forord

Denne bog udgør en samlet fremstilling af databeskyttelsesretten. Udarbejdelsen har taget udgangspunkt i kapitlerne om databeskyttelsesret i min bog *It-ret*, 5. udgave. Der er der dog tale om en omfattende udbygning og gennemskrivning af kapitlerne, og bogen ligger således langt fra det oprindelige forlæg.

Databeskyttelsesretten udvikler sig i disse år med stor hastighed og mange også mere grundlæggende spørgsmål er fortsat under afklaring. Frekvensen af afgørelser fra tilsynsmyndigheder, domstole og EU-Domstolen er høj, og vejledninger fra både de nationale tilsynsmyndigheder og i særdeleshed EDPB tilfører hele tiden nye bidrag til forståelsen og fortolkningen af reglerne.

Dette gør på den ene side databeskyttelsesretten til et spændende og dynamisk arbejdsområde men rummer på den anden side også udfordringer, når hensigten er at give en fremstilling af gældende ret. Det er ambitionen at håndtere denne udfordring ved løbende at udbygge og opdatere bogen. Opdateringsfrekvensen vil variere og bl.a. afhænge af andre arbejdsforpligtelser. Den nyeste version af bogen vil være tilgængelig fra <www.databeskyttelsesret.dk>, hvor der også ligger en oversigt over de løbende ændringer. I sin første version publiceres bogen udelukkende i digitalt format. I dette format indeholder bogen aktive links til vejledninger, afgørelser mv. Links er markeret med en stiplede linje i teksten. Da den trykte bog rummer kvaliteter, som det digitale format ikke har, vil bogen også senere udkomme som fysisk bog, således at kvaliteterne ved de to formater kan supplere hinanden.

Det digitale format har bl.a. den fordel, at rettelser og ændringer hurtigt kan indføres og publiceres. Jeg vil derfor være taknemmelig for at få besked på henrik.udsen@jur.ku.dk, hvis læserne falder over fejl eller i øvrigt har forbedringsforslag.

Fredensborg og København, november 2022

Henrik Udsen

Databeskyttelsesretlige begreber og forkortelser

Accountability	Den engelsksproget betegnelse for <i>ansvarlighed</i> .
Almindelige personoplysninger	Residualbetegnelse for <i>personoplysninger</i> , der ikke har karakter af <i>følsomme personoplysninger</i> . Synonymt med begrebet anvendes “ikke-følsomme personoplysninger”.
Ansvarlighed	Betegnelse for et grundlæggende princip om, at den <i>dataansvarlige</i> er ansvarlig for at sikre og kunne dokumentere overholdelse af de databeskyttelsesretlige regler. Begrebet er anvendt i <i>databeskyttelsesforordningens</i> art. 5, stk. 2, hvorefter den dataansvarlige er ansvarlig for og skal kunne påvise overholdelse af de generelle <i>behandlingsprincipper</i> i art. 5, stk. 1. En række af reglerne i databeskyttelsesforordningens kap. IV hviler også på princippet om ansvarlighed, herunder art. 24 om den dataansvarliges ansvar.
Art. 29-gruppen	En sammenslutning af ledelsesrepræsentanter for de nationale tilsynsmyndigheder samt repræsentanter fra EU-institutionerne nedsat i henhold til art. 29 i det tidligere <i>persondatadirektiv</i> . Art. 29-gruppen blev afløst af <i>Det Europæiske Databeskyttelsesråd</i> i forbindelse med overgangen fra persondatadirektivet til <i>databeskyttelses-</i>

forordningen. Art. 29-gruppen har udgivet en række vejledninger og udtalelser, der fortsat kan have værdi for forståelsen af forordningen. Nogle af disse er tiltrådt af Det Europæiske Databeskyttelsesråd.

BCR

Forkortelse for “Binding Corporate Rules” (dansk: *bindende virksomhedsregler*).

Behandling

Defineret i forordningens art. 4, nr. 2, som “enhver aktivitet eller række af aktiviteter – med eller uden brug af automatisk behandling – som personoplysninger eller en samling af personoplysninger gøres til genstand for, f.eks. indsamling, registrering, organisering, systematisering, opbevaring, tilpasning eller ændring, genfindning, søgning, brug, videregivelse ved transmission, formidling eller enhver anden form for overladelse, sammenstilling eller samkøring, begrænsning, sletning eller tilintetgørelse”.

Kernen i afgrænsningen af databeskyttelsesforordningens anvendelsesområde er “behandling” af “*personoplysninger*”. Behandlingsbegrebet er således et af databeskyttelsesrettens centrale begreber. Som følge af begrebets brede, giver det dog sjældent anledning til fortolkningstvivl.

Behandlingsgrundlag

I sin generelle form betegnelse for kravet om, at en *behandling* af *personoplysninger*, skal være omfattet af et konkret behandlingsgrundlag for at være lovlig (som f.eks. i dette udsagn: “lovlig behandling af personoplysninger kræver et behandlingsgrundlag”).

I sin konkrete form en henvisning til et eller flere af de seks behandlingsgrundlag, der følger af forordningens art. 6, stk. 1.

Synonymt med begrebet anvendes “hjemmelsgrundlag”. Om de seks behandlingsgrundlag i art. 6, stk. 1, anvendes også begrebet “behandlingsregler”.

Behandlingsprincipper

Betegnelse for de grundlæggende principper for *behandling* af *personoplysninger*, der følger af *databeskyt-*

telsesforordningens art. 5, stk. 1.

Behandlingsregler Betegnelse for de seks *behandlingsgrundlag* i art. 6, stk. 1.

**Berørt
tilsynsmyndighed** Defineret i forordningens art. 4, nr. 22, som “en *tilsynsmyndighed*, der er berørt af en *behandling* af *personoplysninger*, fordi: a) den *dataansvarlige* eller *databehandleren* er etableret på denne tilsynsmyndigheds medlemsstats område b) de *registrerede*, der har bopæl i denne tilsynsmyndigheds medlemsstat, i væsentlig grad er påvirket af eller sandsynligvis i væsentlig grad vil kunne blive påvirket af behandlingen, eller c) en klage er blevet indgivet til denne tilsynsmyndighed”.

Som led i *one-stop-shop ordningen* er en dataansvarlig som udgangspunkt kun underlagt tilsynsmyndigheden i det land, hvor den dataansvarlige er etableret eller har sit hovedkontor. I sager om grænseoverskridende behandling af personoplysninger vil denne tilsynsmyndighed (benævnt den *ledende tilsynsmyndighed*) ofte samarbejde med tilsynsmyndigheder fra andre berørte lande. Disse øvrige tilsynsmyndigheder benævnes i denne type sager for “berørte tilsynsmyndigheder”.

**Betænkning
1565/2017** Betænkning nr. 1565 om databeskyttelsesforordningen (2016/679) og de retlige rammer for dansk lovgivning udgivet af Justitsministeriet i 2017.

Betænkningen beskriver de dagældende databeskyttelsesregler i *persondataloven* og *persondatadirektivet*, de nye regler i *databeskyttelsesforordningen*, mulighederne for nationale særregler under forordningen og behovet for ændringer af gældende ret.

**Bindende
virksomhedsregler** Defineret i forordningens art. 4, nr. 20, som “regler om beskyttelse af *personoplysninger*, som en *dataansvarlig* eller *databehandler*, der er etableret på en medlemsstats område, overholder i forbindelse med *overførsel* eller en række overførsler af personoplysninger til en *dataansvarlig* eller *databehandler* i et eller flere *trejdelande* inden for en koncern eller gruppe af foretagender, der

udøver en fælles økonomisk aktivitet”.

Bindende virksomhedsregler kan anvendes til koncerninterne overførsler af personoplysninger til *usikre tredjelande* efter *databeskyttelsesforordningens* art. 46, stk. 2, litra b. Forordningens art. 47 indeholder nærmere regler om bindende virksomhedsregler.

Binding Corporate Rules Den engelsksproget betegnelse for *bindende virksomhedsregler*.

CNIL Forkortelse for “Commission Nationale de l’Informatique et des Libertés”. *Tilsynsmyndighed* for Frankrig.

CSA Forkortelse for “Conserved Supervisor Authority” (dansk: “*berørt tilsynsmyndighed*”).

Data Privacy Framework Ordning, der skal etablere et grundlag for *overførsel* af *personoplysninger* fra EU til amerikanske virksomheder efter *databeskyttelsesforordningens* art. 45. Ordningen skal afløse *Privacy Shield-ordningen*, der blev statueret ugyldig af EU-Domstolen i *Schrems II-dommen*.

Data Protection Impact Assessment Den engelsksproget betegnelse for *konsekvensanalyse*.

Data Protection Officer Den engelsksproget betegnelse for *databeskyttelsesrådgiver*.

Dataansvarlig Defineret i forordningens art. 4, nr. 7, som “den fysiske eller juridiske person, en offentlig myndighed, en institution eller et andet organ, der alene eller sammen med andre afgør, til hvilke formål og med hvilke hjælpemidler der må foretages *behandling* af *personoplysninger*”.

Den dataansvarlige er forordningens primært pligtsubjekt.

Databehandler Defineret i forordningens art. 4, nr. 8, som “en fysisk eller juridisk person, en offentlige myndighed, en institution eller andet organ, der *behandler oplysninger* på den *dataansvarliges* vegne”.

Databehandleren handler på vegne af og efter instruks

	fra den dataansvarlige og er derfor ikke <i>databeskyttelsesforordningens</i> primære pligtssubjekt. En række af forordningens bestemmelser pålægger dog databehandleren selvstændige pligter, ligesom databehandleren kan blive pålagt erstatningsansvar og bødestraf efter forordningens art. 82 og 83.
Databehandler-aftale	Aftale mellem den <i>dataansvarlige</i> og en <i>databehandler</i> om sidstnævntes <i>behandling af personoplysninger</i> på vegne af den dataansvarlige. Det er efter forordningens art. 28, stk. 3, et krav, at der indgås en aftale mellem parterne, når den dataansvarlige overlader behandlingen til en databehandler. Bestemmelsen fastsætter også krav til indholdet af aftalen.
Databeskyttelsesforordningen	Forordning 2016/679 om beskyttelse af fysiske personer i forbindelse med behandling af personoplysninger og om fri udveksling af sådanne oplysninger og om ophævelse af direktiv 95/46/EF (generel forordning om databeskyttelse). Ofte blot benævnt "GDPR" (forkortelse for General Data Protection Regulation). Forordningen afløste det tidligere <i>persondatadirektiv</i> med virkning fra 25. maj 2018.
Databeskyttelsesloven	Lov nr. 502 af 23. maj 2018 om supplerende bestemmelser til forordning om beskyttelse af fysiske personer i forbindelse med behandling af personoplysninger om fri udveksling af sådanne oplysninger (databeskyttelsesloven). Som titlen angiver, indeholder databeskyttelsesloven bestemmelser, der supplerer <i>databeskyttelsesforordningen</i>.
Databeskyttelsesrådet	Synonym for <i>Det Europæiske Databeskyttelsesråd</i>.
Databeskyttelsesrådgiver	Person der har til formål at sikre en organisations overholdelse af de databeskyttelsesretlige regler. Of-

fentlige myndigheder og visse private virksomheder har pligt til at udpege en databeskyttelsesrådgiver i henhold til *databeskyttelsesforordningens* art. 37. Databeskyttelsesrådgiveren kan være ansat i organisationen eller tilknyttet som ekstern rådgiver. Databeskyttelsesrådgiveren skal under alle omstændigheder leve op til de krav, der følger af art. 38 og varetage de opgaver, der er angivet i art. 39.

Dataeksportør Betegnelse for en *dataansvarlig* eller *databehandler*, der *overfører personoplysninger* til en *dataimportør*.

Dataimportør Betegnelse for en fysisk eller juridisk person i et *tredjeland*, som en *dataeksportør* *overfører personoplysninger* til.

Datarådet Datarådet udgør sammen med et sekretariat *Datatilsynet*. Rådet er nedsat i henhold til databeskyttelseslovens § 27, stk. 3, og består af otte medlemmer. Formanden skal være landsdommer eller højesteretsdommer.

Datarådets primære opgave er at træffe afgørelse i principielle sager. Hovedparten af Datatilsynets arbejde varetages således af sekretariatet under ledelse af tilsynets direktør.

Datatilsynet Uafhængig tilsynsmyndighed i Danmark, der fører tilsyn med overholdelse af *databeskyttelsesforordningen*, *databeskyttelsesloven* og særregler om behandling af personoplysninger, der ligger inden for forordningens rammer. Nedsat med hjemmel i forordningens art. 51 og databeskyttelseslovens § 27.

Datatilsynet udgøres af *Datarådet* og et sekretariat, der ledes af en direktør. Hovedparten af Datatilsynets arbejde varetages af sekretariatet.

Datasubjekt Synonym for *den registrerede*.

Den Europæiske Tilsynsførende for Databeskyttelse Uafhængigt EU-instans, der fører tilsyn med EU-institutionernes overholdelse af de regler for *behandling af personoplysninger*, som institutionerne er underlagt efter *forordning 2018/1725* (der i det væsentlige svarer til reglerne i *databeskyttelsesforordningen*). Etableret i henhold

til forordning 2018/1725 art. 52.

Ofte anvendes “EDPS” (forkortelse for “European Data Protection Supervisor”) som betegnelse for Den Europæiske Tilsynsførende for Databeskyttelse.

Den registrerede

I forordningens terminologi betegnelse for den person, hvis *personoplysninger* bliver *behandlet*. Den registrerede er forordningens beskyttelsessubjekt og den, som tildeles en række rettigheder.

Begrebet “datasubjekt” anvendes synonymt med “den registrerede”.

Det Europæiske Databeskyttelsesråd

Et EU-organ bestående af cheferne for de 27 nationale tilsynsmyndigheder og *Den Europæiske Tilsynsførende for Databeskyttelse* oprettet i henhold til *databeskyttelsesforordningens* art. 68.

Det Europæiske Databeskyttelsesråd afløste *art. 29-gruppen* da *persondatadirektivet* blev afløst af forordningen. Rådet skal navnlig sikre en ensartet anvendelse af forordningen på tværs af medlemsstaterne og de nationale tilsynsmyndigheder. Den nærmere regulering af rådet og dets arbejdsopgaver følger af forordningens art. 68 ff.

Ofte anvendes “EDPB” (European Data Protection Board) eller “Databeskyttelsesrådet” som synonym for Det Europæiske Databeskyttelsesråd.

Det nationale råderum

Betegnelse for det “rum” medlemsstaterne har til at vedtage nationale særregler om databeskyttelse, der supplerer *databeskyttelsesforordningen*.

Direktiv 95/46

Direktiv 95/46 om beskyttelse af fysiske personer i forbindelse med behandling af personoplysninger og om fri udveksling af sådanne oplysninger.

Direktivet, der i Danmark var implementeret ved *persondataloven*, blev erstattet af *databeskyttelsesforordningen*

den 25. maj 2018.

Direktivet benævnes ofte “persondatadirektivet”.

DPA	Kan både være en forkortelse for “Data Protection Authority” (dansk: <i>tilsynsmyndighed</i>) og for “Data Processor Agreement” (dansk: <i>databehandleraftale</i>).
DPC	Forkortelse for “the Data Protection Commission”. <i>Til- synsmyndighed</i> for Irland.
DPF	Forkortelse for <i>Data Privacy Framework</i> .
DPIA	Forkortelse for “Data Protection Impact Assessment” (dansk: <i>konsekvensanalyse</i>).
DPO	Forkortelse for “Data Protection Officer” (dansk: <i>data- beskyttelsesrådgiver</i>).
EDPB	Forkortelse for “European Data Protection Board” (dansk: <i>Det Europæiske Databeskyttelsesråd</i>).
EDPS	Forkortelse for “European Data Protection Supervisor” (dansk: <i>Den Europæiske Tilsynsførende for Databeskyttelse</i>).
EEG	Forkortelse for “European Essential Guarantees” (dansk: <i>europæiske væsentlige garantier</i>).
Europæiske væsentlige garantier	Fire garantier, der er oplistet af <i>Det Europæiske Databeskyttelsesråd</i> i anbefalinger 02/2020 på baggrund af <i>Schrems-dommene</i> og anden praksis fra EU-Domstolen og Den Europæiske Menneskerettighedsdomstol. Garantierne har følgende indhold:

1. Behandling skal være baseret på klare, præcise og tilgængelige regler.
2. Nødvendighed og proportionalitet hvad angår de legitime mål, der forfølges, skal godtgøres.
3. Der skal findes en uafhængig tilsynsmekanisme.
4. Der skal være effektive retsmidler til rådighed for de enkelte personer.

Garantierne udgør krav, som skal være opfyldt, før lov-
givningen i et *tredjeland* yder en beskyttelse af *person-
oplysninger*, der lever op til de grundlæggende rettighe-
der efter EU’s charter om grundlæggende rettigheder.

**Forordning
2016/679**

Forordning 2016/679 om beskyttelse af fysiske personer i forbindelse med behandling af personoplysninger og om fri udveksling af sådanne oplysninger og om ophævelse af direktiv 95/46/EF (generel forordning om databeskyttelse).

Ofte blot benævnt “GDPR” (forkortelse for General Data Protection Regulation) eller “databeskyttelsesforordningen”.

Forordningen afløste det tidligere *persondatadirektiv* med virkning fra 25. maj 2018.

**Forordning
2018/1725**

Forordning 2018/1725 af 23. oktober 2018 om beskyttelse af fysiske personer i forbindelse med behandling af personoplysninger i Unionens institutioner, organer, kontorer og agenturer og om fri udveksling af sådanne oplysninger og om ophævelse af forordning (EF) nr. 45/2001 og afgørelse nr. 1247/2002/EF.

Forordning 2018/1725 regulerer EU-institutionernes behandling af personoplysninger, idet denne behandling ikke er omfattet af den generelle *databeskyttelsesforordning*. Forordningen er i vidt omfang identisk med den generelle databeskyttelsesforordning.

**Fortrolige
personoplysninger**

Betegnelse for en særlig kategori af *personoplysninger*, der ikke nævnes udtrykkeligt i databeskyttelsesreglerne, men som anvendes i *Datatilsynets* praksis. Der er således tale om et særligt nationalt begreb.

En personoplysning anses for fortrolig, hvis den efter den almindelige samfundsopfattelse bør kunne forlanges unddraget offentlighedskendskab.

Følsomme personoplysninger vil altid have karakter af fortrolige personoplysninger, men det omvendt ikke nødvendigvis vil være tilfældet.

	<i>Ikke-følsomme personoplysninger</i> kan i visse situationer have karakter af følsomme personoplysninger. Det gælder efter omstændighederne oplysninger om indtægts- og formueforhold, arbejds-, uddannelses- og ansættelsesmæssige forhold. Det samme gælder oplysninger om interne familieforhold, herunder for oplysninger om for eksempel selvmordsforsøg og ulykkestilfælde.
Følsomme personoplysninger	Betegnelse for den særlige kategori af <i>personoplysninger</i> , der er oplistet i <i>databeskyttelsesforordningens</i> art. 9, stk. 1.
	Begrebet anvendes ikke i nogen af forordningens bestemmelser men er anvendt i præambelbetragtning 10 og anvendes også i <i>databeskyttelsesloven</i> , jf. dennes § 7.
GDPR	Forkortelse for “General Data Protection Regulation” (dansk: <i>databeskyttelsesforordningen</i>).
Hjemmelsgrundlag	Synonym for <i>behandlingsgrundlag</i> .
ICO	Forkortelse for “Information Commissioner’s Office”. <i>Tilsynsmyndighed</i> for Storbritannien.
Ikke-følsomme personoplysninger	Residualbetegnelse for <i>personoplysninger</i> , der ikke har karakter af <i>følsomme personoplysninger</i> . Synonymt med begrebet anvendes “almindelige personoplysninger”.
Konsekvensanalyse	Betegnelse for den forudgående analyse af mulige konsekvenser for beskyttelsen af <i>personoplysninger</i> , som en <i>dataansvarlig</i> skal foretage efter forordningens art. 35, når <i>behandlingen</i> indebærer en høj risiko for fysiske personers rettigheder og frihedsrettigheder.
Konvention 108	Europarådets konvention af 28. januar 1981 om beskyttelse af det enkelte menneske i forbindelse med elektronisk databehandling af personoplysninger.
Konvention 108+	Opdateret version af <i>konvention 108</i> fra 2018. Opdateringen har bl.a. til formål at skabe en større ensartethed med <i>databeskyttelsesforordningen</i> .
Ledende tilsynsmyndighed	Den <i>tilsynsmyndighed</i> der i henhold til proceduren i <i>databeskyttelsesforordningens</i> art. 60 leder en sag om grænseoverskridende behandling af <i>personoplysninger</i> . Den

ledende tilsynsmyndighed er som regel tilsynsmyndigheden i det land, hvor den *dataansvarlige* har sit hovedsæde. I sager om grænseoverskridende behandling af personoplysninger samarbejder den ledende tilsynsmyndighed med tilsynsmyndigheder i de andre lande, hvis borgere også får behandlet deres personoplysninger. Disse andre tilsynsmyndigheder benævnes *berørte tilsynsmyndigheder*.

LIA Forkortelse for “Legitimate Interest Assessment”, der er en engelsksproget betegnelse for den interesseafvejning, der skal foretages efter *databeskyttelsesforordningens* art. 6, stk. 1, litra f.

LSA Forkortelse for “Lead Supervisor Authority” (dansk: *ledende tilsynsmyndighed*).

One-stop-shop ordningen Betegnelse for den ordning, hvorefter en *dataansvarlig* kun er underlagt én *tilsynsmyndighed*, typisk der hvor den dataansvarlige har hovedsæde, også selvom den dataansvarlige foretager grænseoverskridende behandling af *personoplysninger*, som også omfatter *registrerede* i andre medlemsstater.

Oplysning Anvendes ofte synonymt med *personoplysning*.

Overførsel Betegnelse for den situation, hvor en *dataeksportør* overfører personoplysninger fra et EØS-land til en *dataimportør* i et *tredjeland*.

Begrebet er centralt i reguleringen af overførsler til tredjeland i *databeskyttelsesforordningens* kap. V men er ikke defineret i forordningen.

Synonymt med *tredjelandsoverførsel*.

Persondata direktivet Betegnelse for direktiv 95/46 om beskyttelse af fysiske personer i forbindelse med *behandling* af *personoplysninger* og om fri udveksling af sådanne oplysninger.

Direktivet, der i Danmark var implementeret ved *persondataloven*, blev erstattet af *databeskyttelsesforordningen* den 25. maj 2018.

Persondataloven	Lov nr. 429 af 31. maj 2000 om <i>behandling af personoplysninger</i>. Persondataloven implementerede <i>persondatadirektivet</i> og blev ophævet med virkning fra 25. maj 2018, hvor <i>databeskyttelsesforordningen</i> fik virkning og <i>databeskyttelsesloven</i> trådte i kraft.
Personfølsomme oplysninger	Begreb der mest bruges i den offentlige debat om databeskyttelsesretlige spørgsmål. Det er ikke et begreb, der normalt anvendes i databeskyttelsesretten, og når begrebet bruges, er det som regel uklart, om det sigter til <i>personoplysninger</i> i generel forstand, til <i>følsomme personoplysninger</i> eller til noget tredje. Af samme grund bør begrebet undgås.
Personoplysning	Begrebet er defineret i <i>databeskyttelsesforordningens</i> art. 4, nr. 1, som “enhver form for information om en identificeret eller identificerbar fysisk person (<i>‘den registrerede’</i>); ved identificerbar fysisk person forstås en fysisk person, der direkte eller indirekte kan identificeres, navnlig ved en identifikator som f.eks. et navn, et identifikationsnummer, lokaliseringsdata, en onlineidentifikator eller et eller flere elementer, der er særlige for denne fysiske persons fysiske, fysiologiske, genetiske, psykiske, økonomiske, kulturelle eller sociale identitet”. Kernen i afgrænsningen af databeskyttelsesforordningens anvendelsesområde er “<i>behandling</i>” af “personoplysninger”. Personoplysningsbegrebet er således et af databeskyttelsesrettens mest centrale begreber.
Privacy Shield-ordningen	Ordning, der etablerede et grundlag for at <i>overføre personoplysninger</i> fra EU til amerikanske virksomheder efter <i>databeskyttelsesforordningens</i> art. 45. Ordningen blev statueret ugyldig af EU-Domstolen i <i>Schrems II-dommen</i>.
Registeransvarlig	Ældre udtryk for <i>dataansvarlig</i>, der blev anvendt i <i>direktiv 95/46</i>.

Registrerede	Se <i>den registrerede</i> .
SA	Forkortelse for "Supervisor Authority" (dansk: <i>tilsynsmyndighed</i>).
Safe Harbor-ordningen	Ordning, der etablerede et grundlag for at <i>overføre personoplysninger</i> fra EU til amerikanske virksomheder efter <i>persondatadirektivets</i> art. 26. Ordningen blev statueret ugyldig af EU-Domstolen i <i>Schrems I-dommen</i> .
SCC	Forkortelse for "Standard Contractual Clauses" (dansk: <i>standardkontraktbestemmelser</i>).
Schrems I-dommen	EU-Domstolens dom af 6. oktober 2015 i sag C-362/14 (Maximillian Schrems mod Data Protection Commissioner). Dommen fastslog, at <i>Safe Harbor-ordningen</i> ikke ydede et tilstrækkeligt beskyttelsesniveau efter <i>persondatadirektivets</i> art. 26, når <i>personoplysninger</i> blev overført til USA. Dommen fastslog, at det kan være i strid med EU's charter om grundlæggende rettigheder, hvis lovgivningen i et <i>tredjeland</i> gør det muligt for offentlige myndigheder på generel vis at få adgang til indholdet af elektronisk kommunikation, herunder personoplysninger, eller hvis lovgivningen ikke indeholder retsmidler, der gør det muligt at få adgang til egne oplysninger eller få oplysninger berigtiget eller slettet.
Schrems II-dommen	EU-Domstolens dom af 16. juli 2020 i sag C-311/18 (Data Protection Commissioner mod Facebook Ireland Ltd og Maximillian Schrems). Dommen fastslog, at <i>Privacy Shield-ordningen</i> ikke ydede et tilstrækkeligt beskyttelsesniveau efter <i>databeskyttelsesforordningens</i> art. 45, når <i>personoplysninger</i> blev overført til USA. Dommen fastslog endvidere, at der kun kan overføres personoplysninger efter forordningens art. 46, hvis lovgivningen i <i>tredjelandet</i> sikrer et beskyttelsesniveau for de grundlæggende rettigheder, som i det væsentlige svarer til det niveau, der er sikret i EU i medfør af forordningen sammenholdt med charteret.

	EU-Domstolen fandt ikke, at den amerikanske lovgivning levede op til disse krav. Dommen har medført betydelig usikkerhed om muligheden for lovligt at overføre oplysninger til USA og andre <i>usikre tredjelande</i>.
Sikkert tredjeland	Betegnelse for <i>tredjelande</i>, som Kommissionen har fastslået har et tilstrækkeligt beskyttelsesniveau efter <i>databeskyttelsesforordningens</i> art. 45.
Standard Contractual Clauses	Den engelsksproget betegnelse for <i>standardkontraktbestemmelser</i>.
Standard bestemmelser	Efter <i>databeskyttelsesforordningens</i> art. 46, stk. 2, litra c og d, kan Kommissionen henholdsvis <i>tilsynsmyndighederne</i> udstede standardbestemmelser, der regulerer forholdet mellem en <i>dataeksportør</i> og en <i>dataimportør</i> ved en <i>overførsel af personoplysninger</i> til et <i>usikkert tredjeland</i>. Som regel anvendes begrebet <i>standardkontraktbestemmelser</i> frem for "standardbestemmelser". I forordningens art. 64, stk. 1, litra d, anvendes begrebet også om de standardkontraktbestemmelser, en <i>tilsynsmyndighed</i> kan udstedes efter art. 28, stk. 8. Forordningen indeholder således en ikke-konsekvent brug af de to synonyme begreber "standardbestemmelser" og "standardkontraktbestemmelser".
Standardkontraktbestemmelser	<i>Databeskyttelsesforordningen</i> giver Kommissionen og <i>tilsynsmyndighederne</i> hjemmel til at udstede to typer af standardkontraktbestemmelser. Efter art. 28, stk. 7 og 8, kan Kommissionen henholdsvis <i>tilsynsmyndighederne</i> udstede standardkontraktbestemmelser, der regulerer forholdet mellem en <i>dataansvarlig</i> og en <i>databehandler</i>. I denne situation er der med andre ord tale om en standard <i>databehandlersaftale</i>. Efter art. 46, stk. 2, litra c og d, kan Kommissionen henholdsvis <i>tilsynsmyndighederne</i> udstede standardbestemmelser, der regulerer forholdet mellem en <i>data-</i>

eksportør og en *dataimportør* ved en *overførsel* af *personoplysninger* til et *usikkert tredjeland*. Bestemmelsen anvender begrebet “standardbestemmelser” og ikke “standardkontraktbestemmelser”. I forordningens art. 57, stk. 1, litra j, anvendes begrebet “standardkontraktbestemmelser” imidlertid også om standardbestemmelserne efter art. 46. Kommissionen har med gennemførelsesafgørelse 2021/914 af 4. juni 2021, vedtaget standardkontraktbestemmelser efter art. 46, hvor Kommissionen også anvender betegnelsen “standardkontraktbestemmelser”.

Når begrebet anvendes, vil det oftest være om standardkontraktbestemmelser for tredjelandsoverførsler efter art. 46.

Ofte anvendes betegnelsen SCC (“standard contractual clauses”) om standardkontraktbestemmelser.

Supplerende foranstaltninger

Betegnelse for foranstaltninger, der eventuelt kan lovgøre en *overførsel* af *personoplysninger* til et *usikkert tredjeland*, hvis lovgivningen i det pågældende tredjeland ikke sikrer de *registeredes* grundlæggende rettigheder. Begrebet er introduceret af EU-Domstolen i *Schrems II-dommen*.

Særlige kategorier af personoplysninger

Betegnelse for den særlige kategori af personoplysninger, der er oplyst i *databeskyttelsesforordningens* art. 9, stk. 1.

Ofte anvendes betegnelsen *følsomme personoplysninger* om denne type af oplysninger.

TIA

Forkortelse for *Transfer Impact Assessment*.

Tilsynsmyndighed

I *databeskyttelsesforordningens* art. 4, nr. 21, defineret som “en uafhængig offentlig myndighed, der er etableret i en medlemsstat i henhold til artikel 51”.

Tilsynsmyndigheden er således en nationale offentlige myndighed, der fører tilsyn med overholdelse af databeskyttelsesreglerne. I Danmark varetages funktionen

af *Datatilsynet*.

Medlemsstaternes pligt til at udpege en tilsynsmyndighed og de nærmere regler for tilsynsmyndigheden følger af forordningens art. 51 ff.

**Tilstrækkeligheds-
afgørelse** Afgørelse truffet af Kommissionen efter *databeskyttelsesforordningens* art. 45 om, at et *tredjeland* har et tilstrækkeligt beskyttelsesniveau. Tredjelandet får hermed status som *sikkert tredjeland*.

**Transfer Impact
Assessment** En vurdering af, om en *overførsel* af *personoplysninger* til et *tredjeland* vil være lovlig.

I *Schrems II-dommen* fastslog EU-Domstolen, at *dataeksportøren* i hvert enkelt tilfælde skal foretage en konkret vurdering af, om lovgivningen i tredjelandet sikrer den fornødne beskyttelse, før en overførsel foretages.

Tredjeland Betegnelse for lande, der ikke er medlem af EU eller deltager i EØS-samarbejdet. EØS-landene er udover EU-medlemsstaterne Norge, Island og Liechtenstein.

**Tredjlands-
overførsel** Betegnelse for den situation, hvor en *dataeksportør* overfører personoplysninger fra et EØS-land til en *dataimportør* i et *tredjeland*.

Begrebet er centralt i reguleringen af overførsler til tredjelande i *databeskyttelsesforordningens* kap. V men er ikke defineret i forordningen.

Synonymt med *overførsel*.

Tredjemand I *databeskyttelsesforordningens* art. 4, nr. 10, defineret som “en anden fysisk eller juridisk person, offentlig myndighed eller institution eller ethvert andet organ end den *registrerede*, den *dataansvarlige*, *databehandleren* og de personer under den dataansvarliges eller databehandlerens direkte myndighed, der er beføjet til at *behandle personoplysninger*”.

**Underdata
behandler** Fysisk eller juridisk person der behandler *personoplysninger* på vegne af en *databehandler*. Begrebet anvendes

des ikke i *databeskyttelsesforordningen*, der i art. 28, stk. 4, i stedet anvender betegnelserne “oprindelig databehandler” om databehandleren og “anden databehandler” om underdatabehandleren.

**Underdata
behandler
aftaler**

Aftale mellem en *databehandler* og en *underdatabehandler* om sidstnævntes behandling af *personoplysninger* på vegne af databehandleren. Det er efter *databeskyttelsesforordningens* art. 28, stk. 4, et krav, at der indgås en aftale mellem parterne, når databehandleren overlader behandlingen til en underdatabehandler. Bestemmelsen fastsætter også krav til indholdet af aftalen.

Usikkert tredjeland

Betegnelse for *tredjelande*, som Kommissionen ikke har fastslået har et tilstrækkeligt beskyttelsesniveau efter *databeskyttelsesforordningens* art. 45.

Videreoverførsel

Betegnelse for en *dataimportørs* videregivelse af personoplysninger til en tredjepart fra et land uden for EØS.

Begrebet er ikke anvendt i forordningen men anvendt i Kommissionens *standardkontraktbestemmelser* for overførsel af personoplysninger til tredjelande.

Kapitel 1

Introduktion til databeskyttelsesret

1. Indledning

De fleste mennesker har et grundlæggende behov for at kunne opretholde en privatsfære, hvor de kan være sig selv. Dette omfatter både et behov for en fysisk privatsfære, hvor man kan “lukke døren og være i fred”, og en informatorisk privatsfære, der giver mulighed for, at oplysninger om én selv holdes inden for den private sfære og i nogle tilfælde slet ikke deles med andre.

Dette behov har været kendt tilbage i tiden, men har fået en øget betydning i nyere tid i takt med den stigende fokus på individets rettigheder.

I en retlig kontekst blev retten til et privatliv tidligt fremhævet i en berømt amerikansk artikel af *Warren & Brandeis* fra 1890, “The Right to Privacy” trykt i *Harvard Law Review*. Under begrebet “right to privacy” fremhævede artiklen, at der efter common law-regler gjaldt en grundlæggende “right to be let alone”. Artiklen fik stor indflydelse på udviklingen af en retlig beskyttelse af privatlivet og førte til en række efterfølgende artikler, der søgte at udvikle begrebet og dermed definere, hvilken beskyttelse der nærmere lå i “the right to privacy”.

De retspolitiske drøftelser om behovet for en beskyttelse af individets privatliv og retten til egne oplysninger intensiveredes i løbet af 1960’erne og 1970’erne i takt med, at offentlige myndigheder og private

virksomheder begyndte at foretage databehandling via computere, som gav mulighed for en langt hurtigere, mere omfattende og dermed mere effektiv behandling af data, herunder også personoplysninger. Dette indebar bl.a. langt bedre muligheder for at samkøre registre og dermed kontrollere den enkelte borgers adfærd på tværs af forskellige myndigheder mv. Informationsteknologiens øgede mulighed for kontrol og overvågning af det enkelte menneske kunne dermed udgøre et angreb på den enkeltes ret til et privatliv. Disse risici var ikke mindst blevet tydeliggjort i den offentlige bevidsthed gennem George Orwells berømte roman “1984”, hvor et regime anført af *Big Brother* overvåger alle sine borgere gennem teleskærme. Udviklingen indebar, at der i Danmark i 1970 blev nedsat et udvalg, som skulle overveje behovet for lovgivning om brug af offentlige og private registre. Dette arbejde førte til to love om offentlige og private registre, der i 2000 blev afløst af persondataloven, som fra maj 2018 er afløst af databeskyttelsesforordningen og databeskyttelsesloven, jf. nærmere om regelgrundlaget straks nedenfor.

I dag har internettet, sociale medier, registrering af brugeradfærd med henblik på markedsføring mv. medført, at der sker en massiv udveksling og brug af personoplysninger, og at sådanne oplysninger får en stadigt større kommerciel værdi. Af samme grund har databeskyttelsesretten i dag en stor praktisk betydning og et retsområde, der ikke mindst med databeskyttelsesforordningen er vokset eksplosivt.

Tidligere anvendtes navnlig betegnelsen “persondataret” for disciplinen, ligesom den tidligere lov blev benævnt “persondataloven” (selvom den retteligt hed “lov om behandling af personoplysninger”). Betegnelsen “persondataret” er fortsat udbredt, men i denne fremstilling anvendes betegnelsen “databeskyttelsesret” i overensstemmelse med betegnelserne for de to centrale retsakter, forordningen (“generel forordning om databeskyttelse”) og den danske suppleringslov (“databeskyttelsesloven”).

2. Databeskyttelsesretten som en del af personlighedsretten

Begrebet “personlighedsret” er ikke fast indarbejdet i dansk ret, men kan overordnet siges at omfatte regler, der beskytter individets integritet og personlighed. Heri ligger, at også personlighedsretten yder en beskyttelse mod behandling af personoplysninger. Med denne begrebsforståelse udgør databeskyttelsesretten en del af personlighedsretten.

Se nærmere om begrebet *Udsen*, De informationsretlige grundsætninger, s. 64 ff. med yderligere henvisninger.

Personlighedsretten omfatter imidlertid også andre regelsæt, der i større eller mindre omfang er beslægtet med de databeskyttelsesretlige regler. Nogle handlinger vil derfor både være omfattet af databeskyttelsesretlige regler og af andre personlighedsretlige regler.

Som eksempler på andre personlighedsretlige regelsæt kan nævnes straffelovens bestemmelser om personværn i §§ 264 a-d og om ærekrænkelser i §§ 267 ff., beskyttelsen af retten til eget billede efter mfl. § 3 og almindelige retsgrundsætninger og beskyttelsen af privatlivets fred efter EMRK art. 8. Disse bestemmelser har alle overlappende anvendelsesområder med de databeskyttelsesretlige regler, og når man skal vurdere retsstridigheden af en konkret behandling af personoplysninger, kan det derfor være nødvendigt at overveje flere regelsæt. Brug af et personbillede i en kommerciel reklame vil eksempelvis både kunne være en overtrædelse af reglerne om retten til eget billede og af de databeskyttelsesretlige regler. Tilsvarende vil fotografering af en person på et privat område kunne være i strid med både strfl. § 264 a og databeskyttelsesretten.

I det følgende fokuseres der kun på de databeskyttelsesretlige regler.

Se for en generel introduktion til personlighedsretten *Borberg* i *Udsen* (red.), Lærebog i informationsret, kap. 7. Om forholdet mellem straffelovens regler om freds- og ærekrænkelser og de databeskyttelsesretlige regler, se min artikel i *Udsen m.fl. (red.)*, Festskrift til Mads Bryde Andersen, s. 121 ff.

3. De bagvedliggende hensyn

Enhver lovregel er baseret på nogle modsatrettede hensyn og en afvejning heraf. Dette gælder også de databeskyttelsesretlige regler, og bevidstheden om disse hensyn er vigtig for at forstå databeskyttelsesretten. Det er imidlertid ikke let at beskrive hensynene bag persondatabeskyttelsen med større præcision. I modsætning til eksempelvis immaterialretten, der overvejende er baseret på økonomiske hensyn, antager persondatabeskyttelsen en mere moralsk-filosofisk karakter baseret på ideelle hensyn til individet. Af samme grund indeholder den databeskyttelsesretlige litteratur også righoldige (og forskellige) bud på disciplinens nærmere afgrænsning og formål.

Se hertil *Blume*, Databeskyttelsesret, s. 25 ff. med henvisninger.

Det ligger uden for rammerne af fremstillingen at bevæge sig længere ind i disse overvejelser. På dette sted er det tilstrækkeligt at fastslå, at databeskyttelsesretten overordnet bygger på et privatlivshensyn, det vil sige en forudsætning om, at individet har et behov for og et krav på at kunne bevare oplysninger om sig selv inden for en egen sfære, fordi det vil kunne opleves som integritetskrænkende, såfremt selv intime oplysninger om den enkelte kunne deles af offentligheden.

Privatlivshensyn

I tilknytning hertil har individet et krav på selv at vælge, hvordan den pågældende vil fremtræde i offentligheden, hvilket bl.a. indebærer en beskyttelse mod, at der tegnes et falsk eller forvrænget personlighedsbillede af den pågældende. Dette hensyn, der kan betegnes personlighedshensynet, adskiller sig fra privatlivshensynet. Hvor privatlivshensynet skal sikre individet retten til at være i fred (det vil sige retten til ikke at optræde i offentligheden), skal personlighedshensynet sikre individet retten til selv at bestemme, hvordan den pågældende vil optræde i offentligheden.

Personlighedshensyn

Se også om personlighedshensynet, *Udsen*, De informationsretlige grundsætninger, s. 117 ff.

Personlighedshensynet kan bl.a. medvirke til at forklare databeskyttelsesrettens krav om, at oplysninger skal være korrekte og løbende opdateres, men det er privatlivshensynet, som har den største betydning i databeskyttelsesretten.

Såfremt databeskyttelsesretten alene skulle varetage de nævnte privatlivs- og personlighedshensyn, det vil sige hensynene til individet, kunne databeskyttelsesforordningen lidt forenklet udtrykt bestå af én bestemmelse, der forbød enhver form for behandling af personoplysninger.

Det er imidlertid en afgørende forudsætning for, at vores samfund kan fungere, at offentlige myndigheder og virksomheder har mulighed for at behandle personoplysninger i forskellige sammenhænge. Inddrivelse af skat, fakturering til kunder, undervisningsinstitutioners registrering af eksamenskarakterer og en lang række andre samfundsnyttige handlinger forudsætter behandling af personoplysninger.

Der er med andre ord en række væsentlige hensyn, der isoleret set strider mod de hensyn, der tilsiger en beskyttelse af personoplysninger. Overordnet gælder det de informations- og ytringsfrihedshensyn, der indebærer, at information frit skal kunne spredes.

Informations- og ytringsfrihedshensyn

Herudover taler en række mere konkrete hensyn for indskrænkninger i persondatabeskyttelsen, herunder hensyn til en effektiv forvaltning, muligheden for at drive virksomhed og kriminalitetsbekæmpelse.

Andre modsatrettede hensyn

Det er således tungtvejende modsatrettede hensyn, som databeskyttelsesretten skal afveje, og som reglerne skal balancere. Henset til den stigende betydning af personoplysninger er det ikke overraskende, at dette giver anledning til intense retspolitiske diskussioner.

4. Databeskyttelsesrettens udvikling

I 1950 trådte Den Europæiske Menneskerettighedskonvention (EMRK) i kraft. I en databeskyttelsesretlig sammenhæng er dette relevant, fordi konventionen i art. 8 indeholder en bestemmelse om ret til privatlivets fred, der i stk. 1 angiver, at "enhver har ret til respekt for sit privatliv og familieliv, sit hjem og sin korrespondance".

EMRK art. 8

Beskyttelsen af personoplysninger havde ikke samme fokus i 1950 som i dag, og det var ikke denne form for privatlivsbeskyttelse, der var det primære mål for beskyttelsen. At bestemmelsen også omfatter retten til egen korrespondance, illustrerer imidlertid, at også den informatoriske privatlivsbeskyttelse var indtænkt i bestemmelsen. Med den foreliggende praksis fra Den Europæiske Menneskerettighedsdomstol

er der i dag heller ikke tvivl om, at krænkelsen af retten til egne personoplysninger kan udgøre en krænkelse af EMRK art. 8.

Se f.eks. allerede Menneskerettighedsdomstolens dom i *Leander mod Sverige* (sag 9248/81), hvor domstolen dog ikke fandt, at registreringen af en svensk statsborger i et statsligt svensk sikkerhedsregister var i strid med art. 8.

Selvom beskyttelsen af personoplysninger ikke var i fokus ved konventionens tilblivelse, udgør art. 8 i dag således et vigtigt bidrag til databeskyttelsesretten, og EMD har gennem de senere år afsagt en række domme om behandling af personoplysninger. På sin hjemmeside har domstolen offentliggjort en større oversigt over denne praksis.

Behovet for en retlig beskyttelse af personoplysninger blev aktualiseret med fremkomsten af computeren. De første computere blev udviklet i 1940'erne, men først i 1960'erne og 1970'erne var udviklingen nået så langt, at computerne begyndte at blive udbredt blandt myndigheder og virksomheder. Hermed opstod muligheden for at behandle personoplysninger langt mere intensivt end tidligere. Dette gjaldt ikke mindst muligheden for at samkøre registre og dermed skaffe sig oplysninger om de registrerede, som ikke kunne udledes af de enkelte registre. Dette kan betragtes som en ældre variant af den form for brug af big data og profilering, der i dag er centrale temaer i databeskyttelsesretten.

Computernes
fremkomst

Som en konsekvens af denne udvikling nedsatte Justitsministeriet i 1970 et registerudvalg, der fik til opgave "at overveje de problemer vedrørende privates retsbeskyttelse, som er forbundet med oprettelse og brug af offentlige og private registre, navnlig under hensyn til den tekniske udvikling på området". Registerudvalget afgav to delbetænkninger om henholdsvis private registre (bet. 687/1973) og offentlige myndigheders registre (bet. 767/1973). På baggrund af disse betænkninger blev der vedtaget en lov om private registre og en lov om offentlige myndigheders registre, der trådte i kraft i 1978 (registerlovene). Lovene, der var blandt de første af sin art i verden, regulerede adgangen til at indsamle personoplysninger i registre og til den efterfølgende behandling, herunder samkøring af registre. Registerlovene var gældende frem til persondatalovens ikrafttræden i 2000.

Registerlovene

Også på internationalt plan medførte den teknologiske udvikling og de nye muligheder for behandling af personoplysninger reguleringstiltag.

I 1980 vedtog OECD et sæt "Guidelines on the Protection of Privacy and Transborder Flows of Personal Data", som var det første internationale dokument, der regulerede behandlingen af personoplysninger. Disse guidelines er ikke bindende, men har ikke desto mindre fået stor betydning for udviklingen af databeskyttelsesretten. Grundprincipperne heri har således været med til at forme det tidligere persondatadirektiv og den nuværende databeskyttelsesforordning og dermed de gældende regler i databeskyttelsesretten.

OECD's
guidelines

Året efter, i 1981, vedtog Europarådet en konvention om Beskyttelse af det enkelte menneske i forbindelse med elektronisk databehandling af personoplysninger, der i det væsentlige bygger på samme grundprincipper som OECD's guidelines. I 2018 blev konventionen opdateret, bl.a. for at skabe en større grad af ensartethed med databeskyttelsesforordningen. Den opdaterede version af konventionen benævnes også for "konvention 108".

Europarådets
konvention 108

I takt med, at behandlingen af personoplysninger fik stadigt større praktisk betydning, der skete en øget spredning på tværs af landegrænser, og medlemslandene begyndte at indføre national regulering, fandt Kommissionen det nødvendigt at indføre fælles EU-regler på området. På baggrund heraf blev persondatadirektivet (dir. 95/46 om beskyttelse af fysiske personer i forbindelse med behandling af personoplysninger og om fri udveksling af sådanne oplysninger) udstedt i 1995. Direktivet bygger på Europarådets konvention fra 1981 og dermed også de grundprincipper, der følger af OECD's guidelines. Hovedformålet med direktivet var at sikre et ensartet højt beskyttelsesniveau i EU og hermed også muliggøre overførsel af personoplysninger mellem medlemslandene uden nationale barrierer (at skabe et indre marked for persondataoverførsler).

Persondata-
direktivet

Direktivet skulle være implementeret senest i 1998, men i Danmark skete det først i 2000 med persondataloven. Den lange implementeringsperiode var bl.a. udtryk for (rets)politiske uenigheder om indholdet af loven. Med persondatalovens ikrafttræden blev de to registerlove samtidig ophævet.

Persondataloven

Som nærmere beskrevet nedenfor bygger databeskyttelsesforordningen på de samme grundstrukturer som persondatadirektivet, og med direktivet og persondataloven blev fundamentet således skabt for den databeskyttelsesret, vi kender i dag.

I direktivets første år levede databeskyttelsesretten et forholdsvis stille liv uden stor opmærksomhed. Der skulle således også gå otte år fra direktivets ikrafttræden, til EU-Domstolen afsagde den første dom om fortolkning af direktivet i den såkaldte *Lindqvist*-sag omtalt nedenfor. Dette begyndte at ændre sig i takt med den teknologiske udvikling. Da persondatadirektivet blev forhandlet i starten af 1990'erne, var internettet endnu ikke blevet udbredt, men dette skete med stor hast i slutningen af årtiet og videre ind i 00'erne, hvor bl.a. Google og Facebook blev etableret. Disse udviklinger medførte en markant forøget og mere intensiv behandling af personoplysninger. Store mængder af oplysninger kunne nu indsamles fra mange kilder, deles næsten uden tekniske begrænsninger og offentliggøres for det meste af verden af både private, virksomheder og myndigheder. Sammenholdt med, at personoplysninger fik selvstændig økonomisk værdi og blev et væsentligt element i internetøkonomien, blev der sat stadigt større fokus på den retlige beskyttelse af personoplysninger. Der var således en stigende erkendelse af, at reglerne ikke fungerede optimalt i praksis. Det blev bl.a. anført som et problem, at reglerne i direktivet og persondataloven blev til før internetudviklingen og derfor ikke tog højde for de særlige juridiske problemstillinger, som denne udvikling førte med sig. Dette var dog ikke helt retvisende. I hovedsagen var direktivets regler så bredt formuleret, at de kunne anvendes også på den efterfølgende teknologiske udvikling. Sammenligner man direktivet og forordningen, er det således også kun få steder, man med forordningen har forsøgt at gøre op med en uhensigtsmæssig retstilstand forårsaget af direktivets manglende evne til at rumme den teknologiske udvikling.

Internettet

Et af disse steder er ændringen af reglernes geografiske anvendelsesområde, hvor direktivet ikke tog højde for, at det med internettet og hjemmesider er muligt at rette aktiviteter mod EU, uanset om hjemmesiden fysisk befinder sig uden for EU. Se nærmere herom kapitel 2.3 nedenfor.

Når reglerne i praksis ikke fungerede optimalt skyldtes det nok først og fremmest, at der ikke var en tilstrækkelig opmærksomhed på dem og vilje til at efterleve dem. Forhold, der navnlig kan henføres til de beskedne konsekvenser, der var knyttet til en manglende overholdelse af reglerne.

Den stadig mere omfattende brug og misbrug af personoplysninger forårsaget af den teknologiske udvikling førte til overvejelser om behovet for at erstatte direktivet med nye regler, der kunne sikre en mere effektiv beskyttelse og i øvrigt tage højde for nogle af de kritikpunkter, der gennem årene var rejst mod de eksisterende regler. Overvejelserne førte til, at Kommissionen i januar 2012 fremlagde et forslag til en databeskyttelsesforordning til afløsning af direktivet.

Forordnings-
udkast

I juni 2013, mens forhandlingerne om databeskyttelsesforordningen pågik, lækkede Edward Snowden oplysninger om den amerikanske efterretningstjeneste NSA's hemmelige masseovervågning. Overvågningen havde et omfang og inkluderede en personkreds, herunder europæiske politikere, der gav anledning til betydelig kritik fra såvel amerikanske som europæiske politikere, interesseorganisationer og samfundsaktører i bred forstand. Snowdens afsløringer viste, at overvågningen havde et omfang, som de færreste havde forestillet sig, og ikke var underlagt den demokratiske kontrol, man må forvente af så massive overvågningstiltag.

Snowden-
afsløringerne

I perioden efter Snowden-afsløringerne afsagde EU-Domstolen flere meget principielle domme på det databeskyttelsesretlige område, hvor påvirkningen af disse afsløringer synes mærkbar. I april 2014 fastslog EU-Domstolen i *Digital Rights Ireland*-sagen (forenede sager C-293/12 og C-594/12), at det såkaldte lognings-direktiv, der pålagde medlemsstaterne at indføre en pligt for teleselskaber til at logge (registrere) trafikoplysninger om telefonopkald, mailkorrespondance mv., var i strid med chartret om grundlæggende rettigheder. Månedet efter i maj 2014 fastslog EU-Domstolen i *Google Spain*-sagen (C-131/12), at der gjaldt en ret til at blive glemt og kræve sletning fra Googles søgemaskine, se nærmere om dommen kap. 6.6.1. Året efter afgjorde EU-Domstolen i *Schrems I*-sagen (C-362/14), at Safe Harbor-ordningen, der tillod overførsel af personoplysninger til virksomheder i USA, ikke overholdt kravene i persondatadirektivet og chartret om grundlæggende rettigheder. Snowden-afsløringerne var et centralt element i den-

Principielle
afgørelser fra EU-
Domstolen

ne sag, og dommen blev i 2021 fulgt op af endnu en afgørelse fra EU-Domstolen, *Schrems II* (C-311/18), der har skabt betydelig usikkerhed om lovligheden af overførsler af oplysninger til USA og andre usikre tredjelande. Se nærmere om sagerne kap. 9 nedenfor.

Efter fire års forhandlinger blev databeskyttelsesforordningen vedtaget i april 2016 med virkning fra 25. maj 2018. Erkendelsen af, at de tidligere regler i praksis ikke virkede optimalt, reflekteres ikke mindst i de markant højere bøderammer, der er indført med forordningen. Særligt dette element af forordningen har medført en betydeligt større fokus på de databeskyttelsesretlige regler end tidligere. Med samme virkningstidspunkt som forordningen trådte databeskyttelsesloven i kraft samtidig med, at persondataloven blev ophævet.

Databeskyttelsesforordningen og databeskyttelsesloven

Med databeskyttelsesforordningen og databeskyttelsesloven har den danske og europæiske databeskyttelsesret fået et regelsæt, som nok er nyt, men som dog i sin grundstruktur hviler på det hidtidige system. Det må forventes, at disse regler vil være gældende databeskyttelsesret i mange år fremover. Som det vil fremgå af det følgende, er det imidlertid regler, der hviler på brede formuleringer, og som dermed skal udfyldes. Med databeskyttelsesforordningen har skabt et fundament for fremtidens databeskyttelsesret, men rammerne skal i vidt omfang udfyldes i de kommende år.

5. Retskilderne

5.1. Grundrettigheder

Som beskrevet ovenfor omfatter privatlivsbeskyttelsen i EMRK art. 8 også en beskyttelse af personoplysninger, og Menneskerettighedsdomstolen har i de senere år sagt en række afgørelser om behandling af personoplysninger.

EMRK art. 8

På sin hjemmeside har domstolen offentliggjort en større oversigt over denne praksis.

EMRK er fra 2000 blevet suppleret af EU's charter om grundlæggende rettigheder. Chartret indeholder en bestemmelse om beskyttelse af privatlivets fred (art. 7), der er identisk med bestemmelsen i EMRK

EU's charter om grundlæggende rettigheder

art. 8, men herudover også en bestemmelse (art. 8), der specifikt handler om beskyttelse af personoplysninger. Bestemmelsen har følgende indhold:

1. Enhver har ret til beskyttelse af personoplysninger, der vedrører ham/hende.
2. Disse oplysninger skal behandles rimeligt, til udtrykkeligt angivne formål og på grundlag af de berørte personers samtykke eller på et andet berettiget ved lov fastsat grundlag. Enhver har ret til adgang til indsamlede oplysninger, der vedrører ham/hende, og til berigtigelse heraf.
3. Overholdelsen af disse regler er underlagt en uafhængig myndigheds kontrol.

Chartret blev juridisk bindende for medlemsstaterne med vedtagelsen af Lissabon-traktaten i 2009 gennem en henvisning i EU-traktatens art. 6.

Selvom beskyttelsen af personoplysninger allerede er omfattet af privatlivsbeskyttelsen, har det ikke kun symbolsk betydning, at databeskyttelsesretten nu udtrykkeligt har fået karakter af en grundlæggende rettighed på linje med andre grundlæggende rettigheder. For det første indeholder chartrets art. 8 en præcisering af beskyttelsen på grundrettighedsniveau, f.eks. ved udtrykkeligt at angive samtykke som et muligt behandlingsgrundlag og indeholde et krav om en uafhængig tilsynsmyndighed. For det andet har det en væsentlig signalværdi, at persondatabeskyttelsen har fået sin egen bestemmelse i chartret. Mange af de databeskyttelsesretlige regler er som nævnt formuleret bredt og efterlader dermed meget rum for fortolkning. Ved denne fortolkning vil det kunne få betydning, at persondatabeskyttelsen nu har karakter af en grundlæggende rettighed. Det lod, der lægges i den vægtskål, som taler for beskyttelse, bliver med andre ord tungere. Dette understreges af, at EU-Domstolen i sin nyere praksis om fortolkning af persondatadirektiv og nu forordningen ofte henviser til chartret.

Se eksempelvis *Digital Rights Ireland* (forenede sager [C-293/12](#) og [C-594/12](#) om tilsidesættelse af logningsdirektivet med direkte henvisning til chartrets art. 8), *Google Spain* ([C-131/12](#) om retten til at blive glemt), *Rynes* ([C-212/13](#) om privat overvågningskamera, der filmede på

offentlig vej) og *Schrems I og II* (C-362/14 og C-311/18 om tredjelands-overførsler).

I det daglige arbejde med databeskyttelsesret vil grundrettighederne sjældent spille en rolle. Ikke desto mindre må databeskyttelsesjurister have blik for, at disse rettigheder kan påvirke fortolkningen af reglerne, og at databeskyttelsesretlige regler potentielt kan stride mod de grundlæggende rettigheder.

5.2. Databeskyttelsesforordningen

Databeskyttelsesforordningen (ofte blot benævnt GDPR) afløste med virkning fra 25. maj 2018 det hidtidige persondatadirektiv og er udgangspunktet for gældende databeskyttelsesret i EU. Forordningen har umiddelbar virkning i medlemsstaterne og skal således ikke implementeres i national ret, som et direktiv skal. Overgangen fra direktiv til forordning var et udtryk for et ønske om en større grad af harmonisering mellem medlemsstaterne.

Fra Kommissionen fremlagde det første udkast til forordningen i januar 2012, gik mere end fire år med intensive forhandlinger og lobbyisme, før den endelige tekst blev vedtaget i april 2016. Forordningen hviler på samme fundament og struktur som det tidligere persondatadirektiv og er heller ikke i sit juridiske indhold en revolution af europæisk databeskyttelsesret, selvom den enorme opmærksomhed og omtale af forordningen nogle gange kan efterlade det indtryk.

Dette er dog ikke ensbetydende med, at alt er status quo. Forordningen indeholder således en række nyskabelser, som på væsentlig måde påvirker udviklingen af databeskyttelsesretten. Dette gælder de markant højere bøderammer, der er indført med forordningen. Ikke mindst dette element af forordningen har medført en betydeligt større fokus på de databeskyttelsesretlige regler end tidligere (herunder også de regler, der også gjaldt under direktivet). Herudover indeholder forordningen en række "ansvarligheds"-bestemmelser, der på forskellige vis skal understøtte efterlevelsen af forordningen. Som en yderligere nyskabelse er virksomheder med aktiviteter i flere medlemsstater nu kun underlagt én national tilsynsmyndighed (den såkaldte one-stop-shop ordning). Der er indført et tættere samarbejde mellem tilsyns-

Nyskabelser

myndighederne og etableret et europæisk databeskyttelsesråd med flere kompetencer end den tidligere art. 29-gruppe. Andre nyskabelser omfatter bl.a. krav om databeskyttelsesrådgivere for offentlige myndigheder og visse virksomheder, pligt til at informere om sikkerhedsbrud og skærpet ansvar for databehandlere. Nyskabelserne omtales nærmere i de følgende kapitler.

5.3. Databeskyttelsesloven

Databeskyttelsesloven trådte i kraft, samme dag som databeskyttelsesforordningen fik virkning, den 25. maj 2018. Samtidig hermed ophævedes den hidtil gældende persondatalov.

Lovens fulde, men ikke særligt mundrette, navn er “Lov om supplerende bestemmelser til forordning om beskyttelse af fysiske personer i forbindelse med behandling af personoplysninger og om fri udveksling af sådanne oplysninger (databeskyttelsesloven)”. Som titlen siger, er databeskyttelsesloven et supplement til databeskyttelsesforordningen. Umiddelbart kan det virke overraskende, at en forordning suppleres af en national lov, da hensigten med at vælge en forordning frem for et direktiv netop er at undgå nationale implementeringslove. Dette var formentlig heller ikke Kommissionens oprindelige intention, men under forhandlingerne om forordningen ønskede en række medlemsstater, herunder Danmark, et vist nationalt råderum bl.a. med henblik på at kunne opretholde eksisterende særregler. Forordningen giver derfor på forskellig vis medlemsstaterne mulighed for at opretholde eller indføre egne regler. Disse muligheder kan opdeles i fire kategorier.

Der er for det første regler, som giver medlemsstaterne mulighed for at supplere forordningen med egne behandlingsregler. Det gælder forordningens art. 6, stk. 2, der har følgende ordlyd:

Medlemsstaterne kan opretholde eller indføre mere specifikke bestemmelser for at tilpasse anvendelsen af denne forordnings bestemmelser om behandling med henblik på overholdelse af stk. 1, litra c) og e), ved at fastsætte mere præcist specifikke krav til behandling og andre foranstaltninger for at sikre lovlig og rimelig behandling, herunder for andre specifikke databehandlingssituationer som omhandlet i kapitel IX.

Nationalt råderum efter forordningen

1. suppling af forordningen med egne behandlingsregler

Et andet eksempel er art. 9, stk. 2, litra a, hvorefter der kan ske behandling af følsomme oplysninger med den registreredes samtykke, “medmindre det i EU-retten eller medlemsstaternes nationale ret er fastsat, at det i stk. 1 omhandlede forbud ikke kan hæves ved den registreredes samtykke”. Medlemsstaterne kan således indføre nationale regler, der begrænser muligheden for at anvende samtykke som behandlingsgrundlag for følsomme oplysninger.

Til disse bestemmelser knytter sig præambelbetragtning 10, der bl.a. anfører:

[...] Denne forordning indeholder også en manøvremargin, så medlemsstaterne kan præcisere reglerne heri, herunder for behandling af særlige kategorier af personoplysninger (“følsomme oplysninger”). Denne forordning udelukker således ikke, at medlemsstaternes nationale ret fastlægger omstændighederne i forbindelse med specifikke databehandlingssituationer, herunder mere præcis fastlæggelse af de forhold, hvorunder behandling af personoplysninger er lovlig.

Hermed understreges, at forordningen indeholder et råderum for medlemsstaterne til at fastsætte nationale behandlingsregler. Det er dog værd at bemærke, at medlemsstaternes mulighed for national regulering af behandlingsgrundlagene efter art. 6 kun gælder for stk. 1 litra c (retlig forpligtelse) og litra e (offentlig myndighedsudøvelse og behandling i samfundets interesse). Dette betyder bl.a., at art. 6, stk. 2, ikke giver mulighed for at afskære interesseafvejningsreglen i litra f. National lovgivning kan således eksempelvis ikke kræve, at behandlingen kun kan finde sted, hvis der er opnået samtykke fra den registrerede, såfremt behandlingen kan hjemles i art. 6, stk. 1, litra f.

På den baggrund vil eksempelvis bestemmelsen i DBL § 13, stk. 1, der kræver samtykke for at en dataansvarlig må videregive personoplysninger med henblik på markedsføring, næppe kunne opretholdes, jf. om bestemmelsen kap. 5.7.1.

Forordningen indeholder endvidere regler, der eksplicit giver medlemsstaterne mulighed for at vælge national regulering på et specifikt område. Et eksempel på dette er art. 8, stk. 1, hvorefter børn under 16 år ikke kan give samtykke til udbydere af informationssamfundstjenester. Det følger imidlertid af bestemmelsen, at medlemsstaterne kan

2. eksplicite valgmuligheder på konkrete områder

fastsætte en aldersgrænse ned til 13 år i deres nationale lovgivning. Et andet eksempel er art. 83, stk. 7, hvorefter medlemsstaterne kan fastsætte regler om, hvorvidt offentlige myndigheder kan pålægges administrative bøder.

Forordningen giver også medlemsstaterne mulighed for at fastsætte regler om begrænsninger og undtagelser til en række forpligtelser og rettigheder. Dette gælder særligt art. 23, som giver medlemsstaterne mulighed for at begrænse rækkevidden af de rettigheder, forordningen giver de registrerede, når begrænsningerne respekterer det væsentligste indhold af de grundlæggende rettigheder og er en nødvendig og forholdsmæssig foranstaltning i et demokratisk samfund af hensyn til en række nærmere angivne omstændigheder.

Endelig indeholder forordningen enkelte bestemmelser, der forpligter medlemsstaterne til at indføre national regulering. Efter art. 51, skal medlemsstaterne således sikre etableringen af en uafhængig tilsynsmyndighed.

I Danmark er mulighederne for nationale særregler udnyttet gennem databeskyttelsesloven og opretholdelsen af en række særlovsregler. Databeskyttelsesloven indeholder bl.a. regler om CPR-nummer, om behandling på grundlag af kollektive overenskomster, om kreditoplysningsbureauer, om pligt til at opbevare visse oplysninger i Danmark (lokationsreglen – tidligere krigsreglen), om Datatilsynet og om bøder (herunder bøder til offentlige myndigheder).

Betænkning 1565/2017 indeholder en omfattende analyse af det nationale råderum, se særligt s. 141 ff.

Grænserne for det nationale råderum er langt fra klare, og forordningsteksten bærer (også) på dette punkt præg af at have været genstand for intense forhandlinger. Der er derfor også en risiko for, at en medlemsstats fortolkning, der måtte bevæge sig på grænsen af råderummet, kan blive tilsidesat af EU-Domstolen. Konsekvensen heraf er, at den nationale særregel ikke er gyldig. På samme måde som forordningen (og lovgivningen i øvrigt) potentielt kan være i strid med chartret, kan national lovgivning potentielt være i strid med forordningen.

Beskrivelsen af gældende ret i de følgende kapitler inddrager databeskyttelsesloven, når den supplerer reglerne i forordningen.

3. begrænsninger i de registreredes rettigheder

4. pligt til national regulering

Udnyttelsen af det nationale råderum

Forholdet mellem databeskyttelsesloven og forordningen

5.4. Sektorspecifikke regler og danske særregler

5.4.1. E-databeskyttelsesdirektivet

I 1997 blev udstedt dir. 1997/66 om behandling af personoplysninger og beskyttelse af privatlivets fred inden for telesektoren, der i 2002 blev afløst af dir. 2002/58 om databeskyttelse inden for elektronisk kommunikation (e-databeskyttelsesdirektivet), som blev ændret i 2009 ved dir. 2009/136.

E-databeskyttelsesdirektivet retter sig mod udbydere af elektroniske kommunikationstjenester, der stilles til rådighed over åbne net (det vil navnlig sige internettet). En kommunikationstjeneste i direktivets forstand er en tjeneste, som udelukkende eller overvejende består i overføring af signaler via elektroniske kommunikationsnet. Det er med andre ord kun teleudbydere og andre internetoperatører, der varetager selve transmissionen af indhold på nettet, som er omfattet af direktivet.

Direktivet omhandler primært den type personoplysninger, der knytter sig til at levere transmissionsydelser, herunder trafikdata, lokaliseringsdata og abonnementsfortegnelser. Reglerne herom er implementeret i dansk ret gennem teleloven.

I det omfang udbydere af elektroniske kommunikationstjenester behandler andre typer af personoplysninger, f.eks. oplysninger om egne ansatte, eller foretager andre former for behandling end reguleret i e-databeskyttelsesdirektivet, gælder de generelle databeskyttelsesretlige regler i forordningen og databeskyttelsesloven.

E-databeskyttelsesdirektivet forventes afløst af en ny e-databeskyttelsesforordning. Det var oprindeligt planen, at denne forordning skulle have fået virkning samtidig med databeskyttelsesforordningen, men der forhandles fortsat om indholdet af forordningen.

5.4.2. Direktiv og lov om retshåndhævende myndigheders behandling af personoplysninger

Samtidig med fremlæggelse af forslaget til en databeskyttelsesforordning i januar 2012 fremlagde Kommissionen forslag til direktiv om retshåndhævende myndigheders behandling af personoplysninger. Forslaget indebar, at de retshåndhævende myndigheders (det vil navnlig sige politi, anklagemyndighed og domstolene) behandling af perso-

noplysninger ikke var omfattet af databeskyttelsesforordningen, men selvstændigt reguleret i et direktiv. Formålet hermed var at give medlemsstaterne større frihed til at fastsætte egne regler på håndhævelsesområdet.

Direktivet var genstand for langt mindre opmærksomhed end forordningen under forhandlingerne og blev vedtaget samtidig med forordningen den 27. april 2016 (dir. 2016/680). Fordi der er tale om et direktiv, forudsættes en national implementeringslov. I Danmark blev direktivet implementeret med retshåndhævelsesloven (lov nr. 410/2017), der trådte i kraft den 29. april 2017.

Direktivet og loven hviler på samme fundament som databeskyttelsesforordningen og databeskyttelsesloven og indeholder bl.a. krav til behandlingsgrundlag og opstiller velkendte basale behandlingsprincipper. På en række punkter er beskyttelsen dog ikke så stærk som efter forordningen. Der er bl.a. videre adgang til at behandle oplysninger og flere begrænsninger i de registreredes rettigheder. Dette er et udtryk for, at muligheden for at kunne foretage strafferetlig efterforskning og retsforfølgelse kan rykke på balancen mellem privatlivshensyn og de hensyn, der tilsiger behandling af personoplysninger.

Reglerne om retshåndhævende myndigheders behandling af personoplysninger behandles ikke i bogen.

5.4.3. Danske særregler

Der findes i dansk ret en lang række særregler om behandling af personoplysninger på forskellige områder. Som beskrevet ovenfor indeholder forordningen et ganske stort nationalt råderum, hvilket i Danmark er blevet brugt til i det væsentlige at opretholde de særregler, der var gældende forud for forordningen.

Pressens brug af personoplysninger er undergivet en særregulering, der navnlig er begrundet i pressens særlige status som “public watchdog”. Efter lov om massemediers databaser gælder således nogle særlige regler om massemediers behandling af personoplysninger i deres databaser, der fraviger en række af reglerne i forordningen og databeskyttelsesloven. Herudover gælder generelt, at brug af personoplysninger i journalistisk øjemed i vidt omfang er undtaget fra forordningen og databeskyttelsesloven og i stedet reguleres af de presseretlige regler, jf. også kap. 2.2.3 nedenfor.

Lov om
massemediers
databaser

På sundhedsområdet gælder også særlige regler om behandling af personoplysninger, jf. sundhedslovens kap. 9 om indhentning og videregivelse af helbredsoplysninger, der på nogle områder yder en stærkere beskyttelse end de almindelige databeskyttelsesretlige regler.

Sundhedsloven

Lov om massemediers databaser og reglerne i sundhedsloven er blot eksempler på nogle af de særregler, der gælder inden for forskellige sektorer. Disse regler behandles ikke i det følgende, men jurister der arbejde med databeskyttelsesret, må være opmærksomme på, om der gælder særregler ved siden af de generelle regelsæt på deres område.

Andre særregler

Sammen med databeskyttelsesloven blev vedtaget lov om ændring af lov om retshåndhævende myndigheders behandling af personoplysninger, lov om massemediers informationsdatabaser og forskellige andre love (lov nr. 503/2018). Der er tale om en retsteknisk lov, der gennemfører konsekvensændringer i andre love som følge af forordningen og databeskyttelsesloven. I denne lov kan man således få et overblik over de nationale love, der omtaler behandling af personoplysninger og eventuelt fraviger reglerne i forordningen og databeskyttelsesloven.

5.5. Retspraksis

Antallet af databeskyttelsesretlige domme har historisk set været begrænset. I takt med databeskyttelsesrettens voksende betydning finder stadigt flere sager imidlertid vej til både nationale domstole og EU-Domstolen.

EU-Domstolen har i de senere år afsagt en række domme, der har haft stor betydning for den databeskyttelsesretlige udvikling. Mest markant er EU-Domstolens to afgørelser i *Schrems*-sagerne (C-362/14 og C-311/18), der har medført betydelig usikkerhed om muligheden for lovligt at overføre personoplysninger til USA og andre tredjelande. Domstolen har dog også afsagt mange andre vigtige afgørelser om forståelsen af de databeskyttelsesretlige regler. Disse domme omtales løbende i fremstillingen. Forordningen giver anledning til mange fortolkningsspørgsmål også af mere grundlæggende karakter og antallet af verserende sager for EU-Domstolen er betydeligt. Det kan derfor også forventes, at Domstolen i de kommende år vil afsige mange vigtige afgørelser.

EU-Domstolen

Med overgangen fra persondatadirektivet til databeskyttelsesforordningen opstår spørgsmålet om retskildeværdien af de domme, der fortolker direktivet og den tidligere persondatalov. Svaret herpå afhænger af, hvilke regler dommene fortolker. Mange af direktivets regler er videreført i forordningen, eventuelt med mindre sproglige justeringer, men uden indholdsmæssige ændringer. Domme, der fortolker sådanne regler, vil fortsat have retskildeværdi. Er en regel indholdsmæssigt ændret med forordningen, vil det bero på en konkret vurdering, i hvilket omfang en dom, der fortolker den tidligere direktivregel, fortsat kan tillægges retskildeværdi. En regeljustering indebærer ikke nødvendigvis, at den nye regel hviler på helt andre hensyn, og EU-Domstolens besvarelse af præjudicielle spørgsmål kan stadig have relevans for vurderingen af forordningsreglen. I det følgende inddrages domme under de tidligere regler, i det omfang de vurderes fortsat at have relevans for fortolkningen af de gældende regler. Generelt må det forventes at gælde for de fleste afsagte domme. I overensstemmelse hermed, men også meget kategorisk, har EU-Domstolen i *Mircom*-dommen, C-597/19, (præmis 107) fastslået, at “da de relevante bestemmelser i forordningen i det væsentlige har samme indhold som de relevante bestemmelser i direktivet, finder Domstolens praksis vedrørende direktivet principielt ligeledes anvendelse på forordningen”.

Det stigende antal præjudicielle forelæggelser for EU-Domstolen afspejler, at også antallet af sager for de nationale domstole er stigende. Denne udvikling er drevet af et generelt større fokus på de databeskyttelsesretlige regler og mere konkret på en større fokus på håndhævelsen af reglerne. Som allerede nævnt indførtes med forordningen meget høje bøderammer og en kompetence for tilsynsmyndighederne til at pålægge administrative bøder. Dette har indebåret en betydelig stigning i antallet af bødesager og en betydelig stigning i bødestørrelserne. I mange tilfælde anfægter de dataansvarlige tilsynsmyndighedernes bødeafgørelse og indbringer den for domstolene. I nogle tilfælde vil uenigheden ikke kun omhandle bødespørgsmålet men også det underliggende spørgsmål om den dataansvarliges overtrædelse af de materielle regler, hvorved domstolene må forholde sig til fortolkningen af forordningens materielle bestemmelser. Forordningens bestemmelse om tilsynsmyndighedernes kompetence til at udstede administrative bøder gælder ikke i Danmark, og Datatilsynet har således ikke

Domme fra danske og andre nationale domstole

mulighed for at pålægge administrative bøder. Det er dog et krav efter forordningen, at det danske bødesystem er ligeså effektivt som det, der gælder for de øvrige lande. Vurderer Datatilsynet, at der foreligger en overtrædelse af forordningen, som vil udløse en administrativ bøde efter forordningens art. 83, foretager tilsynet en politianmeldelse med indstilling til, at der pålægges den dataansvarlige en bøde. Også i Danmark er antallet af databeskyttelsesretlige straffesager ved domstolene derfor stigende. Også civile krav giver anledning til et stigende antal sager for domstolene. Erstatningsbestemmelsen i forordningens art. 82 har allerede givet anledning til adskillige domstolsafgørelser i flere medlemsstater, og der verserer flere sager for EU-Domstolen om forståelsen af art. 82.

Der vil gælde det samme om præjudikatsværdien af afgørelser fra danske domstole på det databeskyttelsesretlige område, som gælder om domme på andre områder. Herom kan henvises til den almindelige retskildelære. Eftersom en stor del af det databeskyttelsesretlige område dækkes af en forordning, vil fortolkningstvivil imidlertid ofte medføre en præjudiciel forelæggelse for EU-Domstolen. I praksis får danske domstolsafgørelser derfor nok en begrænset præjudikateffekt på det databeskyttelsesretlige område.

Da der med forordningen er skabt et identisk regelsæt på tværs af medlemsstaterne, kan man overveje, om afgørelser fra andre medlemsstaters domstole kan tillægges retskildeværdi. Formelt set har udenlandske domme ingen retskildeværdi i Danmark. I praksis kan det ikke udelukkes, at udenlandske domme vil blive fremhævet af parterne i danske sager, og at danske domstole vil finde inspiration i dem. På samme måde som det gælder for brug af juridisk litteratur, kan domstolene selvsagt lægge vægt på de argumenter, der er anvendt i udenlandske domme, hvis domstolene finder dem overbevisende.

5.6. Afgørelser og udtalelser fra tilsynsmyndighederne og EDPB

Som nærmere omtalt i kapitel 10 skal medlemsstaterne efter forordningens art. 51 etablere en national tilsynsmyndighed med en række opgaver og beføjelser. Dette gjaldt tilsvarende efter direktivet (reguleringen er dog langt mere detaljeret under forordningen), og medlemsstaterne

har således i mange år haft nationale tilsynsmyndigheder. I Danmark varetages tilsynsopgaven af Datatilsynet. Tilsynsmyndighederne har kompetence til at træffe afgørelser og afgive udtalelser, herunder udarbejde vejledninger om overholdelse af reglerne. Med forordningen blev EDPB etableret. Rådet afløser den tidligere art. 29-gruppe og har som beskrevet nærmere i kapitel 10.2, ligesom tilsynsmyndighederne, kompetence til at afgive udtalelser og i nogle situationer træffe bindende afgørelser.

Afgørelser og vejledninger fra EDPB og tilsynsmyndighederne er ikke autoritative retskilder, der binder domstolene. Ved læsningen af dem skal man derfor også have sig for øje, at det "blot" er rådets og tilsynsmyndighedernes bud på, hvordan reglerne skal fortolkes. Ikke desto mindre har vejledningerne i praksis en betydelig vægt, fordi de dataansvarlige ofte indretter sig efter dem. Det kan også med stor sikkerhed forventes, at en afgørelse fra tilsynsmyndighederne vil blive truffet i overensstemmelse med vejledningerne, og at en anfægtelse i denne situation derfor vil kræve, at sagen indbringes for domstolene. Afgørelser og vejledninger mv. fra EDPB og tilsynsmyndighederne er derfor i praksis meget vigtigt retskilder i databeskyttelsesretten.

Se også *Blume*, der betegner databeskyttelsesretten som en "tilsynsret", fordi afgørelser og vejledninger fra tilsynsmyndighederne i realiteten fastlægger, hvad der er gældende ret på det databeskyttelsesretlige område, Persondatarettens kilder og metode, s. 51 og 64.

I det følgende omtales de forskellige typer af retskilder, der hidrører fra EDPB og tilsynsmyndighederne. Som det fremgår, er der tale om et ganske komplekst retskildebillede.

5.6.1. EDPB

EDPB består af chefen for hver af de 27 nationale tilsynsmyndigheder og Den Europæiske Tilsynsførende for Databeskyttelse (der fører tilsyn med EU-institutionerne). I praksis varetages arbejdet dog ikke kun af den nationale chef men også af medarbejdere fra de forskellige tilsynsmyndigheder i en lang række arbejdsgrupper og udvalg, ligesom EDPB har sit eget sekretariat. Det er derfor også et omfattende arbejde, der udføres i EDPB, primært med sigte på at skabe harmonisering og sikre en ensartet anvendelse af forordningen på tværs af med-

lemsstaterne og de nationale tilsynsmyndigheder. Som led heri udarbejder EDPB en betydelig mængde vejledninger, hvorimod EDPB kun i begrænset omfang træffer afgørelser.

EDPB kan i enkelte tilfælde træffe bindende afgørelser efter forordningens art. 65, særligt når flere involverede tilsynsmyndigheder ikke kan nå til enighed om en afgørelse. EDPB har indtil videre truffet et mindre antal afgørelser efter art. 65 (se om sagerne kap. 10.2.1). Afgørelsen binder de involverede tilsynsmyndigheder i den konkrete sag. Den ledende tilsynsmyndighed vil eksempelvis være forpligtet til at ændre sit udkast til afgørelse, så den afspejler afgørelsen fra EDPB. Udover denne direkte retskildeværdi i den konkrete sag, kan afgørelser fra EDPB efter art. 65 indeholde fortolkninger af forordningens bestemmelser, som kan tillægges vægt i andre sager. Det øger retskildeværdien af disse afgørelser, at de er truffet af EDPB, og at samtlige tilsynsmyndigheder derfor står bag afgørelsen.

Bindende
afgørelser

Det følger af forordningens art. 72, stk. 1, at EDPB træffer afgørelse med simpelt flertal, og i praksis vil der ikke nødvendigvis være enighed blandt alle tilsynsmyndighederne. Det ligger i sagens natur, at der som minimum vil være uenighed blandt nogle af de tilsynsmyndigheder, der er involveret i den konkrete sag. Det er denne uenighed, der fører til, at EDPB afsiger en bindende afgørelse efter art. 65. Da EDPB's afgørelser ikke indeholder dissenser, vil de uanset dette fremstå som afgørelser, der er konsensus om blandt tilsynsmyndighederne.

EDPB kan ikke kun træffe bindende afgørelser men også afgive udtalelser efter forordningens art. 64. Dette giver bl.a. tilsynsmyndigheder mulighed for at anmode EDPB udtale sig om fortolkning af forordningen, til brug for tilsynsmyndighedens afgørelse af en konkret sag. Denne type af udtalelser, som tilsynsmyndighederne kun sjældent anmoder om, har ligeledes karakter af harmoniserede fortolkningsbidrag, som alle tilsynsmyndighederne står bag.

Udtalelser efter
art. 64

Mens det er relativt sjældent, at EDPB træffer bindende afgørelser efter art. 65 og afgiver udtalelser om forståelsen af forordningen efter art. 64, har EDPB udarbejdet en stor mængde retningslinjer, der ofte er ganske omfangsrige. Disse retningslinjer indeholder mange bidrag til fortolkningen af forordningen. Efter art. 70 hører det til blandt EDPB's (centrale) arbejdsopgaver at udarbejde sådanne retningslinjer

Retningslinjer

med henblik på at sikre en ensartet anvendelse af forordningen. At opgaven er lovfæstnet bidrager til retningslinjernes autoritet. Det samme gør den omstændighed, at de gennem EDPB er udstedt af alle tilsynsmyndighederne.

De fortolkninger af forordningen, som EDPB udtrykker i sine afgørelser, udtalelser og retningslinjer, binder i praksis tilsynsmyndighederne. Man kan vanskeligt forestille sig, at en tilsynsmyndighed vil træffe en afgørelse, der tilsidesætter en fortolkning af forordningen, som er udtrykt af EDPB. I praksis har vejledningerne derfor stor retskildeværdi, selvom de som anført ikke er bindende for domstolene.

5.6.2. De nationale tilsynsmyndigheder

Forordningens art. 58 udstyrer de nationale tilsynsmyndigheder med en række beføjelser, herunder til at udstede advarsler, give kritik og udstede påbud om at lovliggøre eller standse en behandling. De dataansvarlige vil være forpligtet til at følge en afgørelse herom fra tilsynsmyndigheden. I Danmark følger det af DBL § 41, stk. 2, nr. 4-8, at en manglende efterlevelse af Datatilsynets afgørelser kan strafforfølges. Tilsynsmyndighedernes afgørelse kan dog altid indbringes for domstolene, jf. forordningens art. 78 og for Datatilsynets vedkommende DBL § 39, stk. 2.

Afgørelser

På samme måde, som det gælder domme fra domstolene, kan afgørelser fra tilsynsmyndighederne indeholde mere generelle bidrag til fortolkning af databeskyttelsesreglerne. Mens antallet af databeskyttelsesretlige domme (endnu) er begrænset, er antallet af tilsynsafgørelser omfattende. Datatilsynet har gennem årene truffet mange afgørelser, hvoraf en del indeholder mere generelle fortolkningsbidrag.

Datatilsynet har samlet afgørelserne i en database på sin hjemmeside.

Disse afgørelser tillægges normalt stor vægt, både fordi Datatilsynet som specialmyndighed har en betydelig ekspertise på området, og fordi det kun er et fåtal af afgørelserne, der indbringes for domstolene. Som anført ovenfor bliver Datatilsynets afgørelser derfor i de fleste tilfælde de facto udtryk for gældende ret.

Det forekommer, at tilsynet korrigerer sin praksis. Det sker sjældent men vil bl.a. kunne forekomme, hvis EU-Domstolen eller EDPB læg-

- korrektion af
praksis

ger en forståelse af reglerne til grund, der strider mod tilsynets hidtidige praksis.

Et eksempel herpå er Datatilsynets meddelelse fra november 2019 om, at behandling af følsomme oplysninger både skal have hjemmel i art. 6 og 9. Indtil dette tidspunkt, havde det været tilsynets faste praksis, at behandling af følsomme oplysninger kun skulle have hjemmel i art. 9. Denne opfattelse blev imidlertid ikke delt af hovedparten af tilsynsmyndighederne, hvorfor det også var EDPB's opfattelse, at behandlingen af følsomme oplysninger skal have hjemmel i begge bestemmelser. I sin meddelelse henviste Datatilsynet endvidere til praksis fra EU-Domstolen (selvom denne dog næppe forholder sig entydigt til spørgsmålet). Se også om dette spørgsmål om "dobbelt" hjemmel kap. 5.6.3.

Også den teknologiske udvikling og samfundsudviklingen mere generelt kan bevirke, at tilsynet korrigerer sin fortolkning af reglerne.

Et eksempel herpå er Datatilsynets meddelelse fra september 2019 om praksisændring i forhold til offentliggørelse af billeder på internettet. Hvor det hidtidig havde været tilsynets praksis, at der skulle sondres mellem situations- og portrætbilleder, meddelte tilsynet, at man fremadrettet ville foretage en helhedsvurdering. Som begrundelse for sin praksisændring anførte tilsynet bl.a., at den "teknologiske og samfundsmæssige udvikling, der har været siden 2002, har endvidere medført et markant skift i anvendelsen af internettet. Billeder af identificerbare personer offentliggøres således i dag i vidt omfang på hjemmesider og sociale medier som f.eks. Facebook og Instagram. Mange mennesker opfatter dette som værende ganske uproblematisk, så længe der er tale om, at der sker offentliggørelse af helt harmløse billeder af dem på internettet".

En sådan praksisændring vil kun have virkning fremadrettet, og det er ikke tænkeligt, at Datatilsynet vil sanktionere dataansvarlige for behandlinger foretaget før ændringen, når behandlingen er i overensstemmelse med den hidtidige praksis. Derimod vil tilsynet kunne sanktionere dataansvarlige, der ikke efterfølgende indretter sig efter den nye praksis og give påbud om, at behandlingen indrettes i overensstemmelse hermed.

Domstolene er som anført ikke bundet af tilsynsmyndighedernes praksis og fortolkninger. Potentielt kan derfor opstå den situation, at

en dataansvarlig, der har indrettet sin behandling i overensstemmelse med tilsynspraksis, dømmes for overtrædelse af reglerne i en retssag. Indirekte kan tilsynsmyndighedernes praksis og fortolkninger dog stadig få betydning. Man kan således vanskeligt forestille sig, at en dataansvarlig ifalder et bødeansvar, når den dataansvarlige har indrettet sig i tillid til praksis eller vejledninger fra tilsynsmyndighederne.

Den nationale tilsynsmyndighed vil ikke være bundet af en afgørelse truffet af en tilsynsmyndighed i en anden medlemsstat. Det er selvsagt ikke hensigtsmæssigt, hvis tilsynsmyndighederne anvender forskellige fortolkninger af forordningen, men harmoniseringshensyn afskærer ikke en tilsynsmyndighed fra at anlægge en anden fortolkning end den, der allerede måtte være udtrykt af en anden tilsynsmyndighed.

Afgørelser fra
andre tilsyns-
myndigheder

Se også Datatilsynets afgørelser [2018-7320-0166](#) (Pandora), hvor den dataansvarlige påberåbte sig en afgørelse fra den engelske tilsynsmyndighed (ICO), der var materielt identisk med den konkrete sag. Datatilsynet nåede et andet resultat end ICO og anførte bl.a.: “Datatilsynet bemærker, at tilsynet i forbindelse med sin behandling af klagesager altid vil foretage en konkret vurdering af forholdene. En henvisning til en afgørelse truffet i et andet europæisk land kan efter Datatilsynets opfattelse ikke nødvendigvis føre til, at tilsynet træffer en tilsvarende afgørelse”.

I praksis må harmoniseringen sikres gennem tilsynsmyndighedernes samarbejde i EDPB. Uenigheder om fortolkning af reglerne kan både afklares gennem udtalelser i henhold til forordningens art. 64 og EDPB's generelle vejledninger. Harmoniseringen kan dog også ske mere uformelt ved, at arbejdsgrupper i EDPB behandler et spørgsmål, hvorved der opnås en vis konsensus om regelforståelsen, som tilsynsmyndighederne anvender i deres egen nationale praksis. I denne situation vil en tilsynsmyndighed nok være mere tilbøjelig til at tillægge afgørelser fra andre tilsynsmyndigheder vægt. Den øgede retskildeværdi vil dog først og fremmest være udtryk for, at den nationale afgørelse udtrykker en forståelse, der i et eller andet omfang er koordineret i EDPB.

Se som et eksempel herpå en [udtalelse](#) fra Datatilsynet fra 21. september 2022, hvor tilsynet omtaler afgørelser om brug af Google Analytics fra

andre tilsynsmyndigheder og anførte, at tilsynet ville afgøre sager på tilsvarende måde, og at “[S]elvom de enkelte sager er blevet afgjort individuelt af de respektive tilsynsmyndigheder, som har modtaget den oprindelige klage, er afgørelserne udtryk for en fælleseuropæisk holdning blandt tilsynsmyndighederne”.

I sager med grænseoverskridende karakter, vil afgørelser ofte involvere flere tilsynsmyndigheder og blive afgjort efter samarbejdsmekanismen i art. 60 (se nærmere herom kap. 10.2.3). Hermed vil afgørelsen være tiltrådt af flere tilsynsmyndigheder, hvilket kan siges at øge afgørelsens retskildeværdi. Heller ikke disse afgørelser vil dog være bindende for øvrige tilsynsmyndigheder, omend andre tilsynsmyndigheder muligvis vil tillægge afgørelsen større vægt, hvis den er tiltrådt af en række af de øvrige tilsyn.

EDPB har på sin hjemmeside en database med afgørelser truffet efter sammenhængsmekanismen. Databasen rummer over 250 afgørelser.

De nationale tilsynsmyndigheder kan udarbejde vejledninger om forståelsen af reglerne på samme måde, som EDPB kan. Retstildeværdien af disse vejledninger svarer til de generelle fortolkningsbidrag, der kan udledes af konkrete afgørelser, jf. ovenfor. Hverken domstole eller andre tilsynsmyndigheder er således bundet af vejledningerne, mens det kan lægges til grund, at tilsynsmyndigheden vil afgøre konkrete sager i overensstemmelse med sine vejledninger. Vejledninger fra de nationale tilsynsmyndigheder supplerer de mange vejledninger fra EDPB. Nationale vejledninger bør ikke udtrykke en forståelse af reglerne, der er i strid med vejledninger fra EDPB, og det vil normalt heller ikke være tilfældet men kan dog forekomme, f.eks. hvis den nationale vejledning er udarbejdet før EDPB-vejledningen og før EDPB's holdning til det behandlede spørgsmål var klarlagt. I så fald må det antages, at den nationale vejledning er blevet afløst af EDPB-vejledningen (som den nationale tilsynsmyndighed også står som afsender af). I realiteten vil det derfor svare til en praksisændring fra tilsynsmyndigheden, som tilsynsmyndigheden bør informere om, medmindre der kun er tale om uvæsentlige ændringer.

Vejledninger

Datatilsynet har udarbejdet en lang række vejledninger, der er tilgængelig fra tilsynets hjemmeside. En samlet oversigt over vejledningerne fra EDPB og Datatilsynet kan findes sidst i bogen.

6. Databeskyttelsesrettens grundstruktur

Databeskyttelsesretten er en kompleks retsdisciplin, der med en omfattende og mange steder svært tilgængelig regulering i forordningen, databeskyttelsesloven, sektorlovgivning mv. med en vis berettigelse af mange opfattes som vanskelig at overskue og arbejde med.

Et første skridt i retning af at reducere kompleksiteten og skabe sig et overblik over disciplinen er at forstå dens grundstruktur. Databeskyttelsesretten består således (som andre retsdiscipliner) af en række centrale reguleringstemaer, der tilsammen udgør disciplinens grundlæggende struktur. Disse temaer omfatter følgende:

— Reglernes anvendelsesområde

Dette omfatter spørgsmålet om, hvornår de databeskyttelsesretlige regler *materielt* finder anvendelse; eller med andre ord, hvilke typer af (informations)handling der omfattes af reglerne. Anvendelsesområdet omfatter endvidere spørgsmålet om, hvordan de databeskyttelsesretlige regler *geografisk* afgrænses. Dette rummer både et regionalt jurisdiktionsspørgsmål om, hvornår forordningen finder anvendelse, og et nationalt jurisdiktionsspørgsmål om, hvornår databeskyttelsesloven finder anvendelse. Som det gælder for andre typer af informationsretlige regler, må databeskyttelsesretten forholde sig til *beskyttelsesperioden*, dvs. hvor længe beskyttelsen skal gælde. Det er klart, at beskyttelsen skal gælde i levende live, men det er mindre åbenbart, om beskyttelsen også skal gælde for afdøde og i givet fald hvor længe.

— Rettigheds- og pligtsubjekter

Det er et centralt aspekt i databeskyttelsesretten at definere de personer, som nyder beskyttelse og tildeles rettigheder under reglerne (de registrerede), henholdsvis de personer, der pålægges forpligtelser og potentielt sanktioner under reglerne (dataansvarlige og databehandlere).

— **Krav til behandlingen – de grundlæggende behandlingsprincipper (hvordan skal personoplysninger behandles?)**

Et centralt element i databeskyttelsesretten er de grundlæggende principper for behandlingen af personoplysninger, som altid skal overholdes. Dette omfatter princippet om lovlighed, rimelighed og gennemsigtighed, om formålsbegrænsning, om data-minimering, om rigtighed, om opbevaringsbegrænsning og om integritet og fortrolighed.

— **Krav om behandlingshjemmel (hvornår må personoplysninger behandles?)**

Det er et grundlæggende krav i databeskyttelsesretten, at en behandling af personoplysninger kræver hjemmel. De såkaldte behandlingsbetingelser, der fastlægger, hvornår der er hjemmel til en behandling, er derfor en central del af databeskyttelsesrettens grundstruktur. Tilsammen besvarer reglerne om behandlingsbetingelser og behandlingsprincipper de grundlæggende spørgsmål om, *hvornår* og *hvordan* personoplysninger må behandles.

— **Den registreredes rettigheder**

Databeskyttelsesretten udstyrer den registrerede med en række rettigheder, som dataansvarlige og databehandlere skal iagttage. Dette gælder eksempelvis en ret for den registrerede til at blive informeret, når oplysninger indsamles, og en ret til indsigt i, hvordan oplysningerne behandles. I de situationer, hvor en behandling kun kan foretages med den registreredes samtykke, får den registrerede hermed en ret til at sige ja eller nej til behandlingen. Denne ret rubriceres dog ikke som en del af “den registreredes rettigheder”, men som et spørgsmål om behandlingshjemmel. Reguleringen af den registreredes rettigheder omhandler således de rettigheder, den registrerede udstyres med i relation til en behandling, som der er hjemmel til.

— **Sikkerhedskrav**

Da personoplysninger oftest opbevares og behandles i it-systemer (og da databeskyttelsesretten primært regulerer digital behandling af personoplysninger), rummer databeskyttelsesretten

en række krav til it-sikkerhed, der skal forhindre misbrug af oplysninger.

- **Yderligere forpligtelser for den dataansvarlige – ansvarlighed**
Det er et grundlæggende princip i databeskyttelsesretten, at den dataansvarlige skal udvise ansvarlighed for efterlevelse af reglerne. Dette krav om “ansvarlighed”, eller på engelsk “accountability”, kommer til udtryk i en række forpligtelser, den dataansvarlige er underlagt efter forordningen, f.eks. en pligt til at indtænke databeskyttelse allerede i designet af løsninger og i nogle situationer foretage konsekvensanalyser, inden en behandlingsaktivitet iværksættes.
- **Overførsel til tredjelande**
Databeskyttelsesretten indeholder særlige regler om, hvornår personoplysninger må overføres til lande uden for EU. Formålet er at hindre en fri overførsel til lande, som ikke giver samme beskyttelse som de europæiske regler.
- **Tilsyn og kontrol**
Som allerede beskrevet er eksistensen af uafhængige tilsynsmyndigheder et centralt element i databeskyttelsesretten. Med overgangen fra direktivet til forordningen fik tilsynsmyndighederne flere kompetencer og blev i øvrigt genstand for en langt mere detaljeret regulering.
- **Erstatning og straf**
Spørgsmålet om konsekvenserne ved et regelbrud er på dette som andre områder centralt og har ikke mindst fået betydning med forordningens høje bøderammer.

Bogens gennemgang af den materielle databeskyttelsesret er opdelt efter den netop skitserede grundstruktur.

Databeskyttelsesretten er en af de informationsretlige discipliner, som er karakteriseret ved, at en person gives retten til at forbyde andre at behandle en bestemt type information. På overordnet niveau har de informationsretlige discipliner alle samme grundstruktur: (1) beskyttelsens objekt (hvilken type information reguleres?), (2) beskyttelsens

indhold (hvad er indholdet af informationsrettighederne?), (3) beskyttelsens subjekt (hvem tildeles informationsrettighederne?), (4) indskrænkninger i informationsrettighederne (hvornår må informationen behandles uden beskyttelsessubjektets samtykke?), (5) beskyttelsens varighed (hvor længe gælder beskyttelsen?), (6) sanktioner. Se nærmere hertil *Udsen, De informationsretlige grundsætninger* og *Udsen (red.), Lærebog i informationsret*, s. 369 ff.

Kapitel 2

Forordningens og databeskyttelseslovens anvendelsesområde

1. Materielt anvendelsesområde

Hovedanvendelsesområdet for forordningen fremgår af art. 2, stk. 1, der har følgende ordlyd:

Denne forordning finder anvendelse på behandling af personoplysninger, der helt eller delvis foretages ved hjælp af automatisk databehandling, og på anden ikke-automatisk behandling af personoplysninger, der er eller vil blive indeholdt i et register.

Databeskyttelsesloven indeholder en tilsvarende formulering i § 1, stk. 2.

Bestemmelsen afgrænser de aktiviteter, der omfattes af forordningen (også benævnt den funktionelle afgrænsning). Afgørende er således, at der sker 1) “behandling” af 2) “personoplysninger”, der enten 3a) “helt eller delvis foretages ved hjælp af automatisk databehandling” eller 3b) “er eller vil blive indeholdt i et register”. Disse krav gennemgås nærmere i det følgende med vægten på de to centrale begreber “behandling” og “personoplysninger”.

Forordningens anvendelsesområde er ikke afgrænset til en nærmere bestemt kreds af fysiske eller juridiske personer (også benævnt den or-

Omfattede aktiviteter (funktionel afgrænsning)

Omfattede personer (organisatorisk afgrænsning)

ganisatoriske afgrænsning). Som udgangspunkt gælder forordningen og loven således for alle offentlige myndigheder, private virksomheder, foreninger og privatpersoner, der behandler personoplysninger.

Forordningen og loven indeholder en række undtagelser, hvor en behandling omfattet af art. 2, stk. 1, hhv. § 1, stk. 2 (dvs. en behandling af personoplysninger ved hjælp af automatisk databehandling eller indeholdt i et register), alligevel falder uden for forordningens eller lovens anvendelsesområde. Disse omtales nærmere i afsnit 2.

1.1. “Personoplysning”

Personoplysningsbegrebet er defineret i forordningens art. 4, nr. 1, som:

Definition

Enhver form for information om en identificeret eller identificerbar fysisk person (“den registrerede”); ved identificerbar fysisk person forstås en fysisk person, der direkte eller indirekte kan identificeres, navnlig ved en identifikator som f.eks. et navn, et identifikationsnummer, lokaliseringsdata, en onlineidentifikator eller et eller flere elementer, der er særlige for denne fysiske persons fysiske, fysiologiske, genetiske, psykiske, økonomiske, kulturelle eller sociale identitet.

Definitionen omfatter alle oplysninger, der kan henføres til en bestemt fysisk person fra “uskyldige” oplysninger om navn, alder, yndlingsfarve mv., herunder offentligt tilgængelige oplysninger, og til stærkt personlige oplysninger om sygdom, seksualitet mv.

Begrebet omfatter ikke kun objektive oplysninger, men også subjektive vurderinger af en person, f.eks. om kreditværdighed eller evner inden for et område. Også objektivt forkerte oplysninger er omfattet.

Objektiv og subjektiv

I mange tilfælde vil oplysninger umiddelbart kunne knyttes til en bestemt fysisk person (eksempelvis en liste med navne, adresser og telefonnumre på personer). I disse tilfælde er der tale om en identificeret fysisk person.

Identificerede personer

Ofte vil det imidlertid forudsætte en nærmere bearbejdning af oplysninger, kendskab til yderligere oplysninger og/eller et forudgående kendskab til den person, oplysningerne vedrører, før det er muligt at henhøre oplysningerne til en bestemt fysisk person. Som udgangspunkt omfatter personoplysningsbegrebet også oplysninger, som først

Identificerbare personer

skal bearbejdes eller sammenkædes med andre oplysninger for at kunne henføres til en bestemt fysisk person. Det følger således af den ovennævnte definition, at begrebet ikke kun omfatter identificerede personer, men også "identificerbare" personer, der direkte eller indirekte kan identificeres ud fra oplysningerne. Om begrebet "identificerbar" anføres følgende i præambelbetragtning 26:

[...] For at afgøre, om en fysisk person er identificerbar, bør alle midler tages i betragtning, der med rimelighed kan tænkes bragt i anvendelse af den dataansvarlige eller en anden person til direkte eller indirekte at identificere, herunder udpege, den pågældende. For at fastslå, om midler med rimelighed kan tænkes bragt i anvendelse til at identificere en fysisk person, bør alle objektive forhold tages i betragtning, såsom omkostninger ved og tid der er nødvendig til identifikation, under hensyntagen til den tilgængelige teknologi på behandlingstidspunktet og den teknologiske udvikling [...]

Det beror på en konkret vurdering, om det inden for rimelige grænser er muligt at identificere en fysisk person ved hjælp af oplysninger, hvorved der bl.a. skal tages hensyn til de teknologiske muligheder og ressourceforbruget i tid og penge knyttet til identifikationen. Også den indirekte identifikation indebærer hermed, at der foreligger en personoplysning, også i relation til personer, som ikke selv umiddelbart har mulighed for at henføre oplysningerne til en bestemt fysisk person.

– identifikation gennem oplysninger fra tredjeparter

Det er et vanskeligt og praktisk væsentligt spørgsmål, hvornår der foreligger en personoplysning, hvis oplysningen kun kan henføres til en bestemt fysisk person, når den kobles med oplysninger, som en tredjepart er i besiddelse af. Spørgsmålet opstår bl.a., når internettjenesteudbydere udstyrer internetbrugere med en form for identifikator, der kun kan kobles til en bestemt fysisk person ved hjælp af yderligere information fra udbyderen. Sådanne identifikatorer kan eksempelvis være ip-adresser, anonyme e-mailadresser og anonyme brugerprofiler på sociale medier.

Se også forordningens præambelbetragtning 30, der omtaler sådanne identifikatorer uden dog at tage stilling til, hvornår de udgør personoplysninger: "Fysiske personer kan tilknyttes onlineidentifikatorer, som tilvejebringes af deres enheder, applikationer, værktøjer og protokoller,

såsom IP-adresser og cookieidentifikatorer, eller andre identifikatorer, såsom radiofrekvensidentifikationsmærker. Dette kan efterlade spor, der, navnlig når de kombineres med unikke identifikatorer og andre oplysninger, som serverne modtager, kan bruges til at oprette profiler om fysiske personer og identificere dem”.

Spørgsmålet om indirekte identifikation gennem adgang til oplysninger fra tredjeparter er behandlet af EU-Domstolen i *Breyer-dommen* (C-582/14). I sagen klagede en tysk statsborger over, at en række tyske forbundsinstitutioners hjemmesider lagrede hans dynamiske ip-adresse og opbevarede den, efter hans besøg på siden var afsluttet. Den tyske stat gjorde gældende, at lagringen og opbevaringen af ip-adresserne bl.a. skulle forebygge og opklare cyberangreb. Det var i sagen omtvistet, om en dynamisk ip-adresse udgjorde en personoplysning i persondatadirektivets forstand, og der blev stillet præjudicielt spørgsmål herom til EU-Domstolen. De tyske forbundsinstitutioner, som ejede hjemmesiderne, kunne ikke selv henvise ip-adressen til en bestemt fysisk person. Dette kunne kun den internetudbyder, som havde tildelt sine kunder de midlertidige ip-adresser. Spørgsmålet var, om dette var tilstrækkeligt til, at ip-adresserne var personoplysninger i relation til forbundsinstitutionernes lagring og opbevaring. EU-Domstolen fastslog først, at det ikke var påkrævet, at alle de oplysninger, som gjorde det muligt at identificere den registrerede, befandt sig hos samme person (præmis 43). Spørgsmålet var herefter, om muligheden for at kombinere en dynamisk ip-adresse med internetudbyderens viden om den bagvedliggende kundeidentitet, udgjorde et hjælpemiddel, som med rimelighed kunne bringes i anvendelse for at identificere den registrerede. Dette ville ifølge EU-Domstolen ikke være tilfældet, hvis identificeringen af den registrerede var forbudt ved lov eller praktisk uigennemførlig, “f.eks. på grund af det forhold, at den vil indebære en større indsats i tid, omkostninger og arbejde, således at risikoen for en identificering i virkeligheden synes ubetydelig” (præmis 46). Det var i sagen blevet anført, at internetudbyderen i henhold til tysk lov ikke kunne overgive oplysninger om kundens identitet til hjemmesideudbyderne. EU-Domstolen lagde imidlertid vægt på, at hjemmesideindehaveren kunne rette henvendelse til politiet, der som led i en strafferetlig efterforskning kunne kræve kundens identitet oplyst. EU-Domstolen fandt herefter, at hjemmesideudbyderne rådede “over hjælpemidler,

– Breyer-dommen

der med rimelighed kan tænkes bragt i anvendelse for ved hjælp af andre personer, dvs. den kompetente myndighed og internetudbyderen, at få identificeret den registrerede på grundlag af de opbevarede ip-adresser” (præmis 48), og at de dynamiske ip-adresser derfor udgjorde personoplysninger i forhold til hjemmesideindehaverne. Det følger også heraf, at EU-Domstolen ikke fandt, at det krævede en urimeligt stor indsats i tid, omkostninger og arbejde for hjemmesideindehaverne at skaffe sig kendskabet til identitet gennem en politianmeldelse.

Med dommen ligger det fast, at dynamiske ip-adresser har karakter af personoplysninger, når de indsamles med henblik på forebyggelse og efterforskning af (it-)kriminalitet, da den til ip-adressen hørende identitet kan skaffes gennem politiet. Det samme må gælde andre typer af oplysninger, der indsamles med kriminalitetsbekæmpende formål. Dommen forholder sig ikke til den situation, hvor indsamleren af oplysningerne ikke kan få oplyst den bagvedliggende identitet direkte eller gennem politiet (som led i en strafferetlig efterforskning).

Dommen fastslår, at der ikke vil foreligge en personoplysning, hvis identifikationen (videregivelsen af de yderligere oplysninger fra tredje-part) strider mod loven. Tilbage står de situationer, hvor tredje-part er berettiget, men ikke forpligtet, til at videregive de yderligere oplysninger. I disse situationer må svaret formentlig bero på en konkret vurdering af muligheden for at få udleveret oplysningerne. Det vil dog under alle omstændigheder gælde, at ip-adressen ikke vil have karakter af en personoplysning fra det tidspunkt, da internetudbyderen har slettet oplysningerne om abonnentens brug af ip-adressen. Fra dette tidspunkt vil det ikke længere være muligt at koble ip-adressen til en fysisk person.

Dette spørgsmål har EU-Domstolen efterfølgende forholdt sig til i *Mircom*-dommen, C-579/19. I sagen foretog et selskab rettighedshåndhævelse på vegne af en rettighedshaver. Som led heri havde selskabet ved hjælp af software registreret dynamiske ip-adresser på flere tusinde brugere, der angiveligt havde delt piratkopierede film via et BitTorrent-netværk. Rettighedshaveren krævede, at brugernes teleselskab oplyste navn og adresse på de personer, der var knyttet til de pågældende ip-adresser, hvilket teleselskabet afviste. I den præjudicielle forelæggelse skulle EU-Domstolen bl.a. forholde sig til, om en sådan udlevering ville være i strid med forordningen. Som led heri vurderede EU-

– *Mircom*-
dommen

Domstolen, om ip-adresserne havde karakter af personoplysninger. Herom udtalte Domstolen, at dynamiske ip-adresser “som en udbyder af onlinemedietjenester registrerer i forbindelse med en søgning foretaget af en person på en internetside, som denne udbyder gør tilgængelig for offentligheden, i forhold til den nævnte udbyder udgør en personoplysning som omhandlet i artikel 4, nr. 1), i forordning 2016/679, når udbyderen råder over lovlige hjælpemidler, der gør det muligt for denne at få identificeret den registrerede gennem den yderligere viden, som denne persons internetudbyder råder over” (præmis 102). Domstolen fastslog herefter, at selskabet, der indsamlede ip-adresserne med henblik på senere søgsmål, foretog en behandling af personoplysninger i forordningens forstand. Det gjaldt tilsvarende for rettighedshaveren, på hvis vegne oplysningerne blev indsamlet, og som med hjemmel i direktiv 2004/48 om håndhævelses af intellektuelle rettigheder, rådede over lovlige midler til at identificere indehaverne af internetforbindelserne.

På baggrund af dommen må det formentlig gælde, at den der indsamler en dynamisk ip-adresse eller en anden tredjepartsidentifikator med det formål senere at kunne identificere personen bag ip-adressen, foretager en behandling af personoplysninger, hvis lovgivningen giver tredjeparten (teleselskabet, hvis der er tale om en ip-adresse) mulighed for at udlevere identifikationsoplysningerne.

De to domme forholder sig ikke til den situation, hvor en ip-adresse eller en anden tredjepartsidentifikator indsamles med et andet formål end senere identifikation af personen. Dette vil eksempelvis være tilfældet, når virksomheder indsamler internetbrugeres ip-adresser for at kunne følge deres adfærd og eksponere dem for målrettet annoncering. I denne situation vil virksomheden og dens annoncører normalt ikke have interesse i, hvilken fysisk person, der er knyttet til ip-adressen. På den ene side, havde det været nærliggende for EU-Domstolen blot at fastslå, at dynamiske ip-adresser generelt udgør personoplysninger, uanset formålet med deres indsamling, hvis det var Domstolens opfattelse. Det gjorde EU-Domstolen imidlertid ikke. På den anden side er det i mange tilfælde muligt at finde frem til identiteten på en fysisk person ved at koble en ip-adresse med andre oplysninger, der indsamles om brugeren, som også omtalt i præambelbetragtning 30. I praksis er der derfor en risiko for, at brugerne ikke ydes tilstrækkelig beskyt-

telse, hvis indsamling og brug af ip-adresser ikke omfattes af forordningen, når blot de ikke indsamles med det formål at identificere personen bag adressen. I overensstemmelse med den sidstnævnte betragtning har Datatilsynet også lagt til grund, at dynamiske ip-adresser generelt udgør personoplysninger, se eksempelvis DMI-afgørelsen (j.nr. 2018-32-0357).

På den baggrund må udgangspunktet formentlig være, at dynamiske ip-adresser skal betragtes som personoplysninger.

Tilsvarende *Korfits Nielsen & Lotterup*, Databeskyttelsesforordningen og databeskyttelsesloven, s. 246

Det må dog under alle omstændigheder gælde, at ip-adressen ikke vil have karakter af en personoplysning fra det tidspunkt, da internetudbyderen har slettet oplysningerne om abonnentens brug af ip-adressen. Fra dette tidspunkt vil det ikke længere være muligt at koble ip-adressen til en fysisk person.

Efter retsplejelovens § 786, stk. 4, skal udbyderen opbevare loggede oplysninger i et år. Dette vil derfor i praksis ofte være den periode, hvor det er muligt at knytte ip-adressen til en bestemt fysisk person.

Det må bero på en konkret vurdering, om andre identifikatorer har karakter af en personoplysning, når de ikke indsamles med det formål at identificere den fysiske person bag identifikatoren.

Det kan være forbundet med sådanne praktiske vanskeligheder at henhøre oplysninger til en bestemt fysisk person, at oplysningerne ikke har karakter af personoplysninger, jf. hermed også den ovenstående præambelbetragtningens ord om brug af de hjælpemidler, "der med rimelighed kan tænkes bragt i anvendelse". Et fingeraftryk eller en blodplet vil rumme dna, der kan henføres til en bestemt fysisk person, men i mange tilfælde vil materialet indgå i en sammenhæng, der bringer det uden for definitionen af en personoplysning. Et fingeraftryk afsat på et glas i en restaurant har ikke karakter af en personoplysning, og restauranten skal selvsagt ikke iagttage forordningens regler i sin omgang med glasset (hvilket også ville gælde, selvom der var tale om en personoplysning, da behandlingen ikke er automatisk). Men tager politiet et aftryk af fingeraftrykket i efterforskningssammenhæng, vil dette aftryk have karakter af en personoplysning.

– oplysninger der kun med et uforholdsmæssigt ressourceforbrug kan henføres til en bestemt person

En dataansvarlig kan vælge at pseudonymisere eller anonymisere en personoplysning. En pseudonymisering er i forordningens art. 4, nr. 5, defineret som “behandling af personoplysninger på en sådan måde, at personoplysningerne ikke længere kan henføres til en bestemt registreret uden brug af supplerende oplysninger, forudsat at sådanne supplerende oplysninger opbevares separat og er underlagt tekniske og organisatoriske foranstaltninger for at sikre, at personoplysningerne ikke henføres til en identificeret eller identificerbar fysisk person”. Et eksempel kan være, at navnene på de registrerede udskiftes med et unikt nummer, således at oplysningerne om de registrerede umiddelbart kun er knyttet til et nummer, der ikke i sig selv angiver de registreredes identitet. Den dataansvarlige må så føre en liste, hvoraf det fremgår, hvilken identitet der er knyttet til hvert nummer. Da de pseudonymiserede oplysninger fortsat ved brug af denne liste kan henføres til en bestemt fysisk person, har de karakter af personoplysninger. Det er således også forudsat i præambelbetragtning 26, at pseudonymiserede oplysninger, der kan henføres til en bestemt fysisk person ved brug af supplerende oplysninger, bør anses for oplysninger om en identificerbar fysisk person. Pseudonymisering kan bidrage til at beskytte personoplysninger mod kompromittering og misbrug og kan være en af de sikkerhedsforanstaltninger, som den dataansvarlige skal iagttage for at overholde kravene til behandlingssikkerhed, jf. herved forordningens art. 32 og kap. 7.1 nedenfor.

Pseudonymisering
og anonymisering

Kryptering af tekst kan også udgøre pseudonymisering. Kryptering bruges bl.a. i blockchainteknologien. I det omfang blokkene i en blockchain indeholder personoplysninger, behandles derfor personoplysninger i den pågældende blockchain, uanset om disse oplysninger er krypteret. Se nærmere hertil Michéle Finck, Blockchains and Data Protection in the European Union, European Data Protection Law, 2018, s. 17 ff.

– blockchain

Anonymisering anvendes ikke som et defineret begreb i forordningen, men det følger af præambelbetragtning 26, at forordningen ikke bør gælde for oplysninger, der er gjort anonyme på en sådan måde, at den registrerede ikke længere kan identificeres. En dataansvarlig kan således undgå at blive omfattet af forordningens krav ved at anonymisere personoplysninger. Dette forudsætter dog, at den dataansvarlige

ikke har mulighed for gennem en revers behandling af oplysningerne at retablere koblingen mellem oplysningerne og en bestemt fysisk person. Tages udgangspunkt i det ovenstående pseudonymiserings-eksempel, ville det kræve, at den dataansvarlige ikke førte en liste over koblingen mellem det unikke nummer og identiteten af den registrerede.

Af kravet om, at oplysningerne skal kunne henføres til en bestemt fysisk person følger, at oplysninger om virksomheder ikke har karakter af personoplysninger, jf. herved også forordningens præambelbetragtning 14. Dog vil oplysninger om enkeltmandsejede virksomheder være omfattet, da disse oplysninger kan henføres til ejeren.

Virksomheds-
oplysninger

1.2. "Behandling"

Behandlingsbegrebet er i forordningens art. 4, nr. 2, defineret som:

Enhver aktivitet eller række af aktiviteter – med eller uden brug af automatisk behandling – som personoplysninger eller en samling af personoplysninger gøres til genstand for, f.eks. indsamling, registrering, organisering, systematisering, opbevaring, tilpasning eller ændring, genfindning, søgning, brug, videregivelse ved transmission, formidling eller enhver anden form for overladelse, sammenstilling eller samkøring, begrænsning, sletning eller tilintetgørelse.

Behandlingsbegrebet er så bredt, at man i udgangspunktet ikke kan forestille sig en behandling i et it-system (en automatisk behandling), der falder uden for definitionen. Dog må man nok indfortolke en bagatelgrænse i behandlingsbegrebet, således at sporadiske og atypiske behandlinger i et it-system kan falde udenfor. Når personoplysninger transmitteres over internettet, kan internetudbyderen således næppe siges at behandle oplysningerne, selvom de midlertidigt kopieres på internetudbyderens servere.

1.3. Automatisk databehandlingen

Efter det tidligere persondatadirektiv var kriteriet, at behandlingen skulle være foretaget "ved hjælp af edb". Forordningens forudsætning om en automatisk behandling svarer indholdsmæssigt til direktivets krav om behandling ved hjælp af edb, jf. også betænkning 1565/2017,

s. 31. Højesteret har fundet, at en manuel videregivelse af en personoplysning, der var lagret elektronisk, udgjorde en elektronisk behandling efter den tilsvarende regel i persondataloven, jf. *U.2011.2343H*. Hermed er begrebet blevet strakt langt.

1.4. Manuelle registre

Reglerne gælder endvidere for personoplysninger i manuelle registre. Det følger af præambelbetragtning 15, at sagsmapper, der ikke er struktureret efter bestemte kriterier, ikke er omfattet af forordningens anvendelsesområde. For at være omfattet af reglerne kræves således, at oplysningerne i det manuelle register er struktureret efter bestemte kriterier. EU-Domstolen fortolkede i sag *C-25/17, Jehovas Vidner*, registerbegrebet i det tidligere persondatadirektiv og slog fast, at kravet om strukturering efter bestemte kriterier alene indebærer, at personoplysningerne let skal kunne hentes frem, jf. dommens præmis 57. Denne meget brede fortolkning af registerbegrebet vil også gælde under forordningen, da registerbegrebet må antages at være identisk under de to regelsæt. Selvom en del manuelle behandlinger hermed omfattes af forordningen, er det dog den digitale behandling af personoplysninger, der har langt den største praktiske betydning.

2. Undtagne behandlinger

Forordningen og databeskyttelsesloven rummer en række undtagelser, hvor behandling af personoplysninger ikke omfattes af de to regelsæt.

Efter forordningens art. 2, stk. 2, gælder den ikke for behandling af personoplysninger

- under udøvelse af aktiviteter, der falder uden for EU-retten
- som foretages af medlemsstaterne i forbindelse med fælles sikkerheds- og udenrigspolitiske aktiviteter under traktatens afsnit V, kap. 2
- som foretages af en fysisk person som led i rent personlige eller familiemæssige aktiviteter
- som led i kompetente myndigheders forebyggelse, efterforskning og retsforfølgelse af strafbare handlinger og fuldbyrdelse af

strafferetlige sanktioner (som anført ovenfor er de retshåndhævende myndigheders behandlinger på det strafferetlige område reguleret i et særskilt direktiv).

Databeskyttelsesloven undtager i § 3 på tilsvarende vis en række behandlinger fra lovens anvendelsesområde. Dette gælder

- hvis det ville stride mod informations- og ytringsfriheden at lade behandlingen være underlagt lovens krav (stk. 1)
- behandlinger der foretages af forswarets og politiets efterretningstjenester (stk. 2). Disse behandlinger er reguleret i særskilte love for efterretningstjenesterne
- behandlinger der foretages som led i Folketingets parlamentariske arbejde (stk. 3)
- behandlinger der er omfattet af lov om massemediers informationsdatabaser (stk. 4)
- informationsdatabaser omfattet af medieansvarsloven (med visse undtagelser) (stk. 5-6)
- manuelle arkiver med trykte offentliggjorte artikler som udelukkende behandles i journalistisk øjemed (med visse undtagelser) (stk. 7)
- behandlinger i journalistisk øjemed i øvrigt (stk. 8).

I det følgende gennemgås undtagelserne vedrørende ytringsfrihed, private aktiviteter og journalistisk virksomhed.

2.1.1. I strid med ytringsfriheden

Databeskyttelsesloven fastlægger i § 3, stk. 1, at loven og forordningen ikke finder anvendelse, hvis dette vil være i strid med ytringsfriheden:

Loven og databeskyttelsesforordningen finder ikke anvendelse, hvis det vil være i strid med artikel 10 i Den Europæiske Menneskerettighedskonventions eller artikel 11 i Den Europæiske Unions charter om grundlæggende rettigheder.

Forordningen indeholder ikke en tilsvarende bestemmelse, men fastslår i art. 85, at de to grundlæggende rettigheder skal "forenes":

Medlemsstaterne forener ved lov retten til beskyttelse af personoplysninger i henhold til denne forordning med retten til ytrings- og informationsfrihed, herunder behandling i journalistisk øjemed og med henblik på akademisk, kunstnerisk eller litterær virksomhed.

Det kan forekomme overraskende, at loven anfører ikke at finde anvendelse, når det strider mod ytrings- og informationsfriheden, når forordningen taler om at forene de to rettigheder, og når beskyttelsen af personoplysninger er gjort til en selvstændig grundrettighed efter chartret. Formuleringen kan give indtryk af, at hensynet til ytrings- og informationsfriheden skal veje tungere end hensynet til persondatabeskyttelsen, når disse rettigheder kolliderer. Dette er dog ikke tilfældet. Praksis fra Den Europæiske Menneskerettighedsdomstol viser, at rettighederne er ligestillede, og at der derfor ikke kan opstilles et udgangspunkt om, at eksempelvis ytringsfriheden vejer tungere end privatlivsbeskyttelsen under EMRK. Det tilsvarende må antages at gælde under forordningen.

Afvejning af
rettighederne

Der er heller ikke noget i forarbejderne til databeskyttelsesloven eller andre kilder, der kan tages til indtægt for, at ytrings- og informationsfriheden skal tillægges mere vægt end persondatabeskyttelsen. Forklaringen på formuleringen af § 3, stk. 1, er formentlig alene, at man har ønsket at videreføre ordlyden fra den tilsvarende tidligere bestemmelse i persondataloven.

Afvejningen af disse grundlæggende hensyn er vanskelig, og det kan forekomme vidtgående helt at undtage en behandling fra lovens område ud fra bredere ytringsfrihedsbetragtninger. Ytringsfrihedsreglerne anvendes også sjældent som en selvstændig undtagelse til persondatabeskyttelsen, men oftere som et element, der tillægges vægt ved fortolkningen af persondatareglerne, se som eksempel herpå to ældre afgørelser fra Datatilsynet under persondataloven:

Ytringsfrihedshensyn som
fortolkningsfaktor

I sag nr. 2001-215-0050 (omtalt i Datatilsynets Årsberetning 2001, s. 38 ff.) havde en forening lagt oplysninger om lokalpolitikere ud på foreningens hjemmeside, herunder billede og oplysning om oppebårne vederlag, rejseaktiviteter og udgifter forbundet hermed. Formålet var at stille kritisk lys på, om politikerne belønnes efter deres indsats eller mangel på samme. Datatilsynet fandt tilgængeliggørelsen af oplysningerne lovlig efter afvejningsreglen i pdl. § 6, stk.1, nr. 7, og tog herved bl.a. hensynet til ytringsfriheden i betragtning.

I sag nr. 2001-2221-0019 (omtalt i Datatilsynets Årsberetning 2002, s. 56 ff.), havde miljøorganisationen Nepenthes på sin hjemmeside udarbejdet en sortliste over forhandlere, der solgte havemøbler, der ikke bar FSC-miljømærket. Datatilsynet havde i første omgang fundet, at dette udgjorde et advarselsregister efter pdl. § 50, stk. 1, nr. 2. Efter en klage fra Nepenthes blev sagen genoptaget, og Datatilsynet mente nu, at der ikke var tale om et advarselsregister. Tilsynet udtalte bl.a., at der må "gives vide rammer for den politiske/ideologiske debat vedrørende emner af almen samfundsmæssig interesse. Hensynet til ytringsfriheden taler således med betydelig vægt imod at anse denne del af videregivelsen på hjemmesiden for et advarselsregister".

2.1.2. Private handlinger

Efter forordningens art. 2, stk. 2, litra c, gælder den ikke for behandlinger af personoplysninger, "som foretages af en fysisk person som led i rent personlige eller familiemæssige aktiviteter".

Bestemmelsen sikrer, at privatpersoners rent private handlinger kan ske uden iagttagelse af alle forordningens regler. Uden bestemmelsen skulle en privatperson eksempelvis iagttage forordningens krav, når vedkommende noterede telefonnumre, adresser mv. på familie og venner i en elektronisk kontaktoversigt.

Bestemmelsen er omtalt i præambelbetragtning 18, der har følgende ordlyd:

Denne forordning gælder ikke for en fysisk persons behandling af oplysninger under en rent personlig eller familiemæssig aktivitet og således uden forbindelse med en erhvervmæssig eller kommerciel aktivitet. Personlige eller familiemæssige aktiviteter kan omfatte korrespondance og føring af en adressefortegnelse eller sociale netværksaktiviteter og onlineaktiviteter, der udøves som led i sådanne aktiviteter. Denne forordning gælder dog for dataansvarlige eller databehandlere, som tilvejebringer midlerne til behandling af personoplysninger til sådanne personlige eller familiemæssige aktiviteter.

Privatbrugsreglen i art. 2, stk. 2, litra c, rummer to kriterier, som begge skal være opfyldt, for at reglen finder anvendelse. For det første gælder reglen kun for "fysiske personer", og for det andet skal der foreligge en rent "personlig eller familiemæssig aktivitet".

Begrænsningen til fysiske personer medfører, at selskaber og andre juridiske personer ikke kan påberåbe sig reglen, uanset om deres behandling af personoplysninger i øvrigt ville være omfattet. Dette medfører endvidere, at den databehandling, som f.eks. politiske partier, velgørende organisationer og andre foreninger foretager, ikke vil være omfattet af privatbrugsreglen. Der vil i nogle tilfælde være en glidende overgang mellem de situationer, hvor databehandlingen udføres af en organisation, og de situationer, hvor behandlingen udføres af de enkelte medlemmer. Der foreligger ingen retspraksis, som angiver nærmere kriterier for, hvordan denne afgrænsning skal foretages.

“Fysiske personer”

Som eksempler på, hvad der kan omfattes af begrebet “rent personlig eller familiemæssig aktivitet”, angiver præambelbetragtning 18 “korrespondance og føring af en adressefortegnelse eller sociale netværksaktiviteter og onlineaktiviteter, der udøves som led i sådanne aktiviteter”. Denne opstilling er ikke udtømmende, men generelt kan det lægges til grund, at den databeskyttelsesretlige privatbrugsregel har et snævert anvendelsesområde.

“personlig eller familiemæssig aktivitet”

Dette er også fastslået af EU-Domstolen i sag C-212/13, *Ryneš*, der både anfører, at undtagelser fra beskyttelsen af personoplysninger i henhold til domstolens faste praksis skal holdes inden for det strengt nødvendige (præmis 28), og at privatbrugsreglen skal undergives en streng fortolkning med henvisning til EU’s charter om grundlæggende rettigheder og dets beskyttelse af personoplysninger (præmis 29). Sagen angik en privatperson, som med et overvågningskamera filmede indgangen til sit eget hus, offentlig vej foran huset og indgangen til genboens hus. EU-Domstolen konkluderede – ikke overraskende – at privatbrugsreglen ikke fandt anvendelse.

Ved den nærmere afgrænsning af begrebet må der bl.a. lægges vægt på formålet med behandlingen og på antallet af modtagere, som personoplysningerne gøres tilgængelige for, jf. også Udsen, *De informationsretlige grundsætninger*, s. 201 ff.

– afgrænsningskriterier

I overensstemmelse hermed har det traditionelt været opfattelsen, at offentliggørelse af oplysninger via internettet for et ubegrænset antal brugere ikke omfattes af privatbrugsreglen.

– oplysninger på internettet

Se således EU-Domstolens dom i sag C-101/01, *Lindqvist*, hvor en borger havde udlagt personoplysninger om et antal kolleger på en privat hjem-

meside og bl.a. gjorde gældende, at dette udgjorde en handling af rent privat karakter. Herom udtalte EU-Domstolen (præmis 47): “Denne undtagelse [privatbrugsreglen] skal derfor fortolkes således, at den udelukkende vedrører de aktiviteter, der indgår i den enkelte borgers privatliv eller familieliv, hvilket åbenbart ikke er tilfældet med hensyn til behandling af personoplysninger, som består i, at de offentliggøres på internettet, hvorved disse oplysninger bliver tilgængelige for et ubestemt antal personer”.

I nyere praksis har Datatilsynet imidlertid lagt til grund, at offentliggørelse af personoplysninger på en hjemmeside ud fra en helhedsvurdering kan være omfattet af privatbrugsreglen. Den omstændighed, at oplysningerne gøres tilgængelige for et ubegrænset antal personer udelukker med andre ord ikke anvendelsen af privatbrugsreglen. Se herved Datatilsynets afgørelse i j.nr. 2019-31-2538, hvor tilsynet anfører følgende: “Det er således ikke i sig selv afgørende for anvendelsen af databeskyttelsesforordningens artikel 2, stk. 2, litra c, om der er sket offentliggørelse på internettet, idet der skal foretages en konkret helhedsvurdering af offentliggørelsen, herunder formålet med offentliggørelsen, karakteren af de offentliggjorte oplysninger, og den kontekst, som oplysningerne indgår i”. Afgørelsen er udtryk for en ændring af tilsynets praksis og er endvidere ikke forenelig med EU-Domstolens afgørelse i Lindqvist-sagen. Normalt vil tilsynsmyndighederne ikke træffe afgørelser, der strider mod EU-Domstolens fortolkning af reglerne. Når Datatilsynet alligevel har fraveget Lindqvist-afgørelsen kan det nok ses som udtryk for, at den digitale virkelighed er en anden i dag, end den var, da Lindqvist-afgørelsen blev truffet, og – måske væsentligst - at der med overgangen fra persondatadirektivet til forordningen muligvis er sket en justering af privatbrugsreglen. Ordlyden af bestemmelsen er ganske vist uændret, hvilket normalt vil indebære, at praksis under direktivet fortsat har retskildeværdi for fortolkningen af forordningen, jf. kap. 1.5.1. Den ovenfor citerede præambelbetragtning 18 fra forordningen angiver imidlertid, at privatbrugsreglen også kan omfatte sociale netværksaktiviteter og onlineaktiviteter. Direktivets præambelbetragtninger indeholdt ikke en tilsvarende ordlyd (da direktivet er fra 1995), hvilket muligvis kan tages som udtryk for, at forordningen giver et større rum for offentliggørelse på hjemmesider og sociale medier end de tidligere regler. I overensstemmelse hermed anføres i Data-

tilsynets afgørelse, at det “[i] lyset af det, som er anført i præambelbetragtningen om “sociale netværksaktiviteter og onlineaktiviteter” er [...] Datatilsynet opfattelse – efter at spørgsmålet har været forelagt Datarådet – at en fysisk persons behandling af personoplysninger kan anses for at være foretaget som led i rent personlige eller familiemæssige aktiviteter, selv om behandlingen omfatter offentliggørelse af oplysninger på internettet” (fremhævet her).

Sagen omhandlede offentliggørelse af en e-mailkorrespondance om et forfatterskab på en hjemmeside mellem hjemmesideindehaveren og en bruger af hjemmesiden. Hjemmesiden, der blev drevet non-profit af en privatperson, drøftede forskellige emner. Klageren ønskede, at hjemmesideindehaveren fjernede e-mailkorrespondancen fra hjemmesiden, idet han ikke havde forventet, at den ville blive offentliggjort. Datatilsynet fandt, at offentliggørelsen af korrespondancen var omfattet af privatbrugsreglen. I afgørelsen lagde tilsynet vægt på, at der alene var tale om offentliggørelse af harmløse oplysninger, som ikke havde negativ indvirkning på klagerens privatliv, at offentliggørelsen ikke havde et økonomisk sigte, og at dele af korrespondancen indeholdt meningstilkendegivelser, der udtrykte indklagedes begrundelse for at offentliggøre korrespondancen. I relation til sidstnævnte lagde tilsynet vægt på hensynet til informations- og ytringsfriheden.

Afgørelsen omhandler offentliggørelse på en dataansvarligs egen hjemmeside, men de samme principper vil gælde for offentliggørelse via sociale medier. Den omstændighed, at en profil på et sociale medie er åben og oplysningerne dermed tilgængelige for alle, indebærer derfor ikke i sig selv, at offentliggørelsen ikke kan være omfattet af privatbrugsreglen. Se således også Datatilsynets afgørelse i j.nr. 2019-31-2536, hvor tilsynet fandt, at offentliggørelse på en Facebook-profil ikke var omfattet af privatbrugsreglen, idet opslagene havde nær tilknytning til en enkeltmandsvirksomhed. Forudsætningsvis synes afgørelsen dog at lægge til grund, at opslagene havde været omfattet af privatbrugsreglen, hvis ikke det havde været tilfældet.

EU-Domstolen har ikke haft lejlighed til at udtale sig om privatbrugsreglens anvendelse i forbindelse med offentliggørelse af oplysninger på internettet siden *Lindqvist*-sagen. Om domstolen vil justere sin linje og lade privatbrugsreglen omfatte visse behandlinger på sociale medier og internettet i øvrigt, selvom oplysninger hermed gøres til-

gængelige for en stor eller ubegrænset personkreds, er vanskeligt at spå om. Ønsket om ikke lade alle private brugere af sociale medier skulle iagttage forordningens mange krav, taler for en lempelse. Som nævnt er dette nok også en væsentlig årsag til Datatilsynets praksisændring. Forordningens præambelbetragtning 18 vil endvidere kunne begrunde en justering, selvom betragtningen blot anfører, at sociale netværksaktiviteter og andre online aktiviteter *kan* have privat karakter. Betragtningen siger således ikke noget om, hvorvidt dette kun gælder, når oplysningerne gøres tilgængelige for en begrænset persons kreds, eller om det også gælder, når oplysningerne gøres tilgængelige for alle.

Indtil EU-Domstolen, dansk retspraksis eller EDPB måtte fastslå andet, vil danske brugere kunne offentliggøre oplysninger på internettet i overensstemmelse med den helhedsvurdering, der er fastlagt ved Datatilsynets praksis.

2.1.3. Journalistisk øjemed

Det følger af DBL § 3, stk. 8, 1. pkt, at behandlinger af personoplysninger i journalistisk øjemed i det væsentlige er undtaget fra forordningen og loven:

Loven og databeskyttelsesforordningens kapitel II-VII og kapitel IX finder ikke anvendelse ved behandling af oplysninger, som i øvrigt udelukkende finder sted i journalistisk øjemed.

Hjemlen til at fastsætte denne undtagelse følger af forordningens art. 85. Som anført er det pressens særlige rolle som “public watchdog” og dermed informationsfrihedshensyn, der begrunder undtagelsen. Databeskyttelsesretten skal ikke bruges til at hindre pressen i at bringe vigtige samfundsrelevante oplysninger frem til offentligheden. Undtagelsen skal ses i lyset af, at de presseretlige regler, herunder reglen om god presseskik, indeholder begrænsninger i, hvilke oplysninger pressen må viderebringe.

Med internettets udvikling er det blevet muligt for alle at publicere information til offentligheden, og der er mange eksempler på, at private hjemmesider, blogs, indlæg på sociale medier mv. har givet væsentlige input til en samfundsdebat og afdækket forhold af væsentlig samfundsmæssig betydning.

Hermed rejses spørgsmålet, om begrebet “journalistisk øjemed” kun dækker de traditionelle massemediers aktiviteter, eller om privatpersoners aktiviteter også kan være journalistisk virksomhed og dermed undtaget fra forordningen. EU-Domstolen har forholdt sig til spørgsmålet i sag C-73/07, *Satamedia*, hvor en privat virksomhed udgav en avis, der bragte skatte- og indkomstoplysninger om 1,2 mio. finiske statsborgere, og som ligeledes via en mobiltjeneste gav adgang til oplysningerne via sms (disse oplysninger er offentligt tilgængelige hos skattemyndighederne i Finland). EU-Domstolen blev bl.a. spurgt, om disse aktiviteter kunne siges udelukkende at have et journalistisk øjemed i direktivets forstand. Domstolen fastslog i sin afgørelse, at undtagelsen ikke kun gjaldt for medieselskaber, men for enhver person, der udøver journalistisk virksomhed, uanset hvilket medie der anvendes (trykte medier, internettet mv.). Domstolen fastslog endvidere, at det afgørende var, om formålet var at udbrede oplysninger, synspunkter eller ideer til offentligheden, jf. præmis 61. Dommen fortolker det tilsvarende begreb i det tidligere persondatadirektiv, men må antages også at have retskildeværdi under forordningen.

Kan privatpersoner bedrive journalistisk virksomhed?

Hermed ligger det fast, at vurderingen skal tage udgangspunkt i indholdet og ikke karakteren af den, der udøver aktiviteterne, eller det medie, der anvendes til formidlingen, selvom disse forhold dog også kan have en betydning i den samlede vurdering. En privatpersons skriverier på internettet kan således godt være journalistik i databeskyttelsesretlig forstand og dermed undtaget fra forordningens regler.

På trods af EU-Domstolens temmelig brede formulering (udbredelse af oplysninger, synspunkter eller ideer til offentligheden) må det antages, at aktiviteten skal have journalistisk karakter og angå et forhold, der har en vis offentlig interesse. I modsat fald ville stort set enhver formidling af personoplysninger på internettet kunne falde uden for forordningens område, hvilket ikke har været formålet med bestemmelsen. Der ligger endvidere den begrænsning i undtagelsens anvendelsesområde, at en behandling i journalistisk øjemed kun undtages, hvis det er nødvendigt for at forene retten til beskyttelse af personoplysninger med ytringsfriheds- og informationsfriheden, jf. forordnings art. 85, stk. 2, (ordlyden er ikke medtaget i DBL § 3, stk. 8).

Efter EU-Domstolens dom nåede den forelæggende ret, finske Högsta förvaltningsdomstolen, måske lidt overraskende, frem til, at indsamlingen og distributionen af skatteoplysninger ikke var omfattet af undtagelsen om behandling udelukkende i journalistisk øjemed. Retten lagde herved vægt på omfanget af skatteoplysninger, der blev videreformidlet. Herefter blev virksomheden pålagt ikke at distribuere skatteoplysninger i så massivt omfang som hidtil sket. Virksomheden indbragte denne afgørelse for Den Europæiske Menneskerettighedsdomstol (sag 931/13) bl.a. med påstand om en krænkelse af EMRK artikel 10 om ytringsfrihed. Dette fik virksomheden dog ikke medhold i.

Datatilsynet har endnu ikke truffet afgørelser, der nærmere fastlægger, hvornår privatpersoners aktiviteter på internettet har karakter af journalistisk virksomhed.

Se også til emnet Udsen, De informationsretlige grundsætninger, s. 386 f., Bagger Tranberg, Lov&Data 2011, nr. 105, s. 10 ff., Blume, Juristen, 2012, s. 8 ff., Sandfeld & Schaumburg-Müller, Juristen, 2017, s. 53 ff., Ullits, Journalistbegrebet i retlig belysning, s. 59 ff. og Ullits & Schaumburg-Müller, s. 321 ff. i Gram Mortensen (red.), Dansk Persondataret.

3. Territorialt anvendelsesområde

Det følger af forordningens art. 3, hvilke handlinger der omfattes af forordningens territoriale anvendelsesområde. Reglen gælder både for dataansvarlige og databehandlere. I det følgende refereres for enkelheds skyld kun til dataansvarlige, men det tilsvarende gælder altså for databehandlere. Ved fastlæggelsen af det territoriale anvendelsesområde sondres der mellem handlinger foretaget af dataansvarlige, der er etableret i EU (art. 3, stk. 1), og dataansvarlige, som ikke er etableret i EU (art. 3, stk. 2). Det territoriale anvendelsesområde af de særlige danske regler i databeskyttelsesloven reguleres særskilt i denne lov.

3.1.1. Dataansvarlig etableret i EU

Forordningens territoriale anvendelsesområde for dataansvarlige etableret i EU følger af art. 3, stk. 1:

Denne forordning finder anvendelse på behandling af personoplysninger, som foretages som led i aktiviteter, der udføres for en dataansvarlig eller en databehandler, som er etableret i Unionen, uanset om behandlingen finder sted i Unionen eller ej.

Når en virksomhed, der er etableret i EU, behandler personoplysninger, er behandlingen således omfattet af forordningen, uanset hvor de registrerede er bosat og uanset, om behandlingen foretages uden for EU (f.eks. fordi behandlingen foretages på computere, der er placeret uden for EU). Hvis en dansk virksomhed som dataansvarlig eksempelvis til markedsføringsbrug behandler oplysninger om amerikanske borgere i USA, vil behandlingen være omfattet af forordningen. Har den danske virksomhed et amerikansk datterselskab, som på egne vegne behandler oplysningerne (f.eks. fordi markedsføringen udelukkende skal ske fra det amerikanske datterselskab), vil denne behandling derimod ikke være omfattet af art. 3, stk. 1, da det amerikanske selskab er dataansvarlig og ikke er etableret i EU.

Art. 3, stk. 1, finder anvendelse, når behandlingen af personoplysninger sker “som led i aktiviteter, der udføres for en dataansvarlig”, der er “etableret” i EU. Disse krav er en videreførelse af territorialitetsbestemmelsen i det tidligere direktiv.

Efter forordningens præambelbetragtning 22 indebærer etablering “effektiv og faktisk udøvelse af aktivitet gennem en mere permanent struktur”. Derimod er den retlige form for etableringen ikke afgørende. Et datterselskab eller en filial af en virksomhed i et land uden for EU kan således indebære, at virksomheden anses for etableret i EU, hvis der sker databehandling af eller for virksomheden gennem filialen eller datterselskabet. Etableringsbegrebet skal formentlig forstås i overensstemmelse med det samme begreb i det tidligere persondatadirektiv.

“Etablering”

I sag C-230/14, *Weltimmo*, fastslog EU-Domstolen, at etableringskravet er opfyldt, når den dataansvarlige har en permanent struktur i landet, hvorfra der udøves en minimal, faktisk og reel aktivitet, og behandlingen af personoplysninger sker som led i denne aktivitet. Det betød i den konkrete sag, at en virksomhed ansås for etableret i Ungarn, selvom den var registreret i Tjekkiet. Virksomheden, der var drevet af én eller to personer, havde oprettet hjemmesider på ungarsk med ejendomsannoncer for ungarske boliger, og virksomheden havde en repræsentant med

bopæl i Ungarn, der bl.a. varetog inddrivelseskra­v mod brugere af hjemmesiderne i Ungarn.

I *Google Spain-dommen* (C-131/12), omtalt nærmere nedenfor i kapitel 6.6.1, fastslog EU-Domstolen, at Googles søgemaskines indsamling, indeksering og tilrådighedsstillelse af oplysninger, herunder personoplysninger, fra hjemmesider, var en behandling omfattet af den spanske persondatalov. Dette uagtet søgemaskinetjenesten blev drevet af Googles amerikanske moderselskab, Google Inc., og selvom Googles servere, der foretog indeksering og lagring af oplysningerne, ikke befandt sig i Spanien.

“Som led i den dataansvarliges aktiviteter”

Google nægtede under sagen af konkurrencemæssige grunde at oplyse, hvor serverne var placeret. Det kunne således ikke i sagen lægges til grund, at serverne var placeret i Spanien. EU-Domstolen kunne vel have tillagt den manglende oplysning processuel skadevirkning for Google, men gjorde det ikke. Dommen er således ikke baseret på, at serverne var placeret i Spanien.

Baggrunden herfor var, at Google havde etableret et spansk datterselskab (Google Spain), der på det spanske marked solgte annoncer og reklameplads knyttet til Googles søgemaskine (navnlig AdWords). Google Spain deltog ikke i Google Inc.'s indeksering og lagring af personoplysninger i forbindelse med søgemaskinetjenesten. EU-Domstolen fandt imidlertid, at der var en uløselig forbindelse mellem søgemaskineaktiviteterne og salget af annoncer, eftersom annoncesalget var det, der gjorde søgemaskinen økonomisk rentabel, og søgemaskinen omvendt var det, der gjorde annoncesalget muligt. På denne baggrund måtte aktiviteterne ses under ét, og etableringen af et datterselskab i Spanien, der stod for annoncesalg på det spanske marked, var tilstrækkelig til, at den behandling af personoplysninger, der isoleret set blev varetaget af Googles amerikanske moderselskab uden for Spanien, blev omfattet af den spanske persondatalov. Annonceaktiviteterne udgjorde med andre ord et “led i aktiviteter” i art. 4's forstand.

Den samme tankegang lagde EU-Domstolen til grund i C-210/16, *Wirtschaftsakademie Schleswig-Holstein*, hvor spørgsmålet bl.a. var, om Facebooks tyske datterselskab (Facebook Germany) var omfattet af den daværende tyske persondatalov. Facebook Germany varetog rekla-

me og salg af annonceplads i Tyskland, men Facebooks behandling af personoplysninger på europæisk plan blev varetaget af Facebook Ireland. Med henvisning til den uløselige forbindelse mellem annoncesalg og behandlingen af personoplysninger som opstillet i Google Spain-sagen nåede EU-Domstolen frem til, at Facebook Germanys salg af annoncer skete som led i behandlingen af personoplysninger. Dette indebar, at Facebooks behandling af personoplysninger var omfattet af den tyske persondatalov, uanset at behandlingen blev varetaget i Irland, og at det tyske datatilsyn derfor havde kompetence til at håndhæve eventuelle overtrædelser af den tyske persondatalov over for Facebook Germany.

Dommene er en vidtgående fortolkning af det tidligere direktivs territorialitetsregler. *Google Spain*-afgørelsen udtrykker utvivlsomt en modvilje mod, at internationale internettjenester med omfattende aktiviteter i Europa skulle kunne undgå de europæiske regler ved at placere den tekniske behandling af personoplysninger uden for Europa.

EU-Domstolen anfører, at territorialitetsbestemmelsen i direktivets art. 4, stk. 1, litra a, ikke kan fortolkes indskrænkende, da formålet med direktivet er at sikre en effektiv og fuldstændig beskyttelse af fysiske personers grundlæggende rettigheder og frihedsrettigheder, især retten til privatlivets fred, jf. dommens præmis 53.

Resultatet blev dog som beskrevet det samme i *Wirtschaftsakademie Schleswig-Holstein*-afgørelsen, hvor de europæiske databeskyttelsesregler under alle omstændigheder ville finde anvendelse. Her var det alene spørgsmålet, om kun den irske persondatalov eller også den tyske lov fandt anvendelse.

Som omtalt straks nedenfor er reguleringen af det territoriale anvendelsesområde ændret i forordningen, således at der bedre tages højde for internettets grænseoverskridende karakter, ligesom kompetenceforholdene mellem de nationale datatilsyn er mere detaljeret reguleret i forordningen. Dommene må læses i dette lys, men må dog stadig tillægges retskildeværdi i fortolkningen af forordningens art. 3.

Se også om forordningens art. 3, direktivets tilsvarende art. 4 og de ovennævnte domme, Svantesson, *International Data Privacy Law*, 2016, s. 210 ff.

3.1.2. Dataansvarlig ikke etableret i EU

Under direktivet var det meget omdiskuteret, hvorvidt internettjenesteudbydere etableret uden for EU bliver omfattet af de europæiske databeskyttelsesregler, når de behandler oplysninger om europæiske brugere af deres tjenester. Spørgsmålet gav anledning til særlig tvivl, fordi direktivet, som blev udarbejdet i starten af 1990'erne, ikke tog højde for internettets grænseoverskridende karakter. Når den, der behandlede oplysninger, var etableret uden for EU, fandt direktivet kun anvendelse, hvis behandlingen skete ved hjælp af midler, der fysisk befandt sig inden for EU. En amerikansk virksomhed, der behandlede personoplysninger på en computer, der fysisk var placeret i et EU-land, ville således blive omfattet af direktivet. En virksomhed, der rettede sine aktiviteter mod europæiske borgere, f.eks. gennem hjemmesider og andre internettjenester, kunne derimod undgå at blive omfattet af de europæiske regler, hvis behandlingen skete på computere mv., der fysisk befandt sig uden for Europa. Denne retstilstand var selvsagt u hensigtsmæssig i en digital tidsalder, hvor den fysiske placering af computere mv. ikke afspejler aktiviteterernes reelle territoriale tilknytning, og den gjorde det i udgangspunktet nemt at undgå at blive omfattet af de europæiske regler. Der blev løbende søgt rettet op på dette gennem udvidede fortolkninger af direktivets territorialitetsbestemmelse, som ikke mindst *Google Spain*-dommen er et udtryk for.

Med forordningen fik man imidlertid "repareret" denne u hensigtsmæssighed og indført en bestemmelse, art. 3, stk. 2, der tager højde for problemstillingen:

Denne forordning finder anvendelse på behandling af personoplysninger om registrerede, der er i Unionen, og som foretages af en dataansvarlig eller databehandler, der ikke er etableret i Unionen, hvis behandlingsaktiviteterne vedrører:

- a) udbud af varer eller tjenester til sådanne registrerede i Unionen, uanset om betaling fra den registrerede er påkrævet, eller
- b) overvågning af sådanne registreredes adfærd, for så vidt deres adfærd finder sted i Unionen.

Litra a indebærer, at alle, der udbyder varer og/eller tjenesteydelser til borgere i EU og som led heri behandler deres personoplysninger,

Udbud af varer eller tjenester i EU

omfattes af forordningen. Det vil bero på en konkret vurdering, hvornår varer eller tjenesteydelser kan siges at være udbudt til borgere i EU. Kravet er selvsagt ikke opfyldt, blot fordi EU-borgere har adgang til en hjemmeside, jf. forordningens præambelbetragtning 23. I den konkrete vurdering kan lægges vægt på en række af de faktorer, der også på andre retsområder afgør, om en aktivitet kan siges at være rettet mod et land eller en jurisdiktion og dermed lovgivningen på det pågældende retsområde. Af præambelbetragtning 23 følger således, at der bl.a. kan lægges vægt på anvendelse af et sprog eller en valuta, der almindeligvis anvendes i en eller flere medlemsstater og muligheden for at bestille varer og tjenesteydelser på det pågældende sprog. Af andre forhold kan nævnes muligheden for at få sendt varer til adresser inden for EU og omtale/anmeldelser fra EU-borgere. At bestemmelsen også finder anvendelse, selvom der ikke betales for tjenesten, indebærer, at også sociale medier og andre internettjenester, der stilles gratis til rådighed for brugerne (som i stedet ofte "betaler" med deres personoplysninger), kan være omfattet.

Litra b indebærer, at registrering af brugeradfærd, eksempelvis gennem cookies, omfattes af de europæiske regler, også selv om den, der foretager overvågningen, ikke udbyder varer eller tjenester i EU (litra a) og heller ikke er etableret i EU (stk. 1). Ved vurderingen af, om der sker overvågning i bestemmelsens forstand, skal der lægges vægt på, om der sker profilering af en fysisk person, navnlig med det formål at træffe beslutninger om den pågældende eller analysere eller forudsige præferencer, adfærd og holdninger, jf. forordningens præambelbetragtning 24. Med forordningen har det generelt været ønsket at skabe en styrket retsbeskyttelse, når der sker profilering af internetbrugere, og med litra b er det sikret, at virksomheder uden for EU, som foretager profilering, bl.a. med henblik på markedsføring, også omfattes af de europæiske regler.

Overvågning af adfærd

3.1.3. Den territoriale afgrænsning i national ret. Databeskyttelsesloven

Den ovennævnte art. 3 i forordningen forholder sig til, hvornår en behandling af personoplysninger territorielt er omfattet af selve forordningen. Derimod forholder bestemmelsen sig ikke til territorialitetsspørgsmålet på nationalt niveau og angiver ikke, hvilken af EU-landenes lovgivning en given behandling af personoplysninger er omfattet

Forordningens manglende regulering af den nationale territorialitet

af. Art. 3, stk. 1, anfører således ikke, at lovgivningen i en medlemsstat (herunder forordningen) finder anvendelse, når en virksomhed etableret i medlemsstaten behandler personoplysninger, men kun at “forordningen” finder anvendelse, når virksomheden er etableret i “Unionen”. Forklaringen på dette er nok, at en forordning har direkte virkning i medlemsstaterne, hvorfor det i udgangspunktet burde være helt samme regler, der gælder i alle medlemsstater. Som beskrevet efterlader forordningen imidlertid et ganske stort nationalt råderum, og der vil derfor fortsat bestå nationale særregler og forskelle i medlemsstaternes databeskyttelsesretlige regulering.

I mangel af regulering i forordningen må de supplerende nationale databeskyttelseslove selv fastlægge deres territoriale anvendelsesområde. Den danske databeskyttelseslov har valgt en regulering, der svarer til forordningens art. 3. Det følger således af § 4, stk. 1, at loven gælder for “behandling af personoplysninger, som foretages som led i aktiviteter, der udføres for en dataansvarlig eller en databehandler, som er etableret i Danmark, uanset om behandlingen finder sted i EU”. Efter § 4, stk. 3, gælder loven også for dataansvarlige, der ikke er etableret i EU, hvis behandlingsaktiviteterne vedrører “udbud af varer eller tjenester til sådanne registrerede, der befinder sig i Danmark, uanset om betaling fra den registrerede er påkrævet” eller “overvågning af sådanne registreredes adfærd, for så vidt deres adfærd finder sted i Danmark”. Bestemmelserne anvender samme ordlyd som art. 3, stk. 1 og 2, og skal i henhold til forarbejderne til § 4 også fortolkes i overensstemmelse med disse bestemmelser, jf. herom ovenfor. Det er værd at bemærke, at § 4, stk. 3, ikke finder anvendelse, hvis den dataansvarlige er etableret i et andet medlemsland. En virksomhed etableret i Grækenland, som udbyder en internettjeneste til personer bosiddende i Danmark, omfattes ikke af den danske databeskyttelseslov.

Forordningens manglende regulering af det nationale territorialitetsspørgsmål vil kunne rejse vanskelige problemstillinger, hvis databeskyttelseslovgivningen varierer i medlemslande, der regulerer territorialitetsafgrænsningen forskelligt. I Danmark kan unge f.eks. gyldigt give sociale medier samtykke til behandling af deres personoplysninger fra de er 13 år, jf. DBL § 6, stk. 2, og nærmere kap. 5.2.5 nedenfor, mens aldersgrænsen i andre lande er 16 år. Forordningens manglende harmonisering af territorialitetsspørgsmålet indebærer, at der potenti-

Databeskyttelses-
loven

Regelkonflikter

elt kan opstå en situation, hvor en internetjeneste omfattes af den danske databeskyttelseslov efter dennes territorialitetsbestemmelse (§ 4) og ligeledes omfattes af loven i en medlemsstat, der har en aldersgrænse på 16 år, efter territorialitetsbestemmelsen i dette land. I disse situationer må den dataansvarlige iagttage reglerne i begge lande for så vidt angår den del af behandlingen, som omfattes af lovgivningen i det pågældende land. Endnu mere komplekst kan det blive, hvis den dataansvarlige omfattes af forskellige nationale love, som kræver handlinger, der udelukker hinanden, f.eks. således at den ene lov kræver opbevaring af oplysninger, mens den anden lov kræver sletning af de samme oplysninger.

Se også om denne problemstilling, Chen, International Data Privacy Law, 2016, s. 310 ff.

3.1.4. Beskyttelsens tidsmæssige udstrækning

Det er åbenbart, at beskyttelsen efter forordningen og databeskyttelsesloven gælder i hele den registreredes levetid. Det har tidligere været mindre klart, i hvilket omfang beskyttelsen også gjaldt for afdøde, idet den tidligere persondatalov ikke indeholdt en eksplicit bestemmelse herom.

Det følger af forordningens præambelbetragtning 27, at forordningen ikke finder anvendelse på afdøde personer, men at medlemsstaterne kan fastsætte regler for behandling af personoplysninger om afdøde personer i national ret. Udnytter medlemsstaterne ikke denne mulighed, nyder afdødes oplysninger ingen beskyttelse.

Muligheden er udnyttet i databeskyttelsesloven, som i § 2, stk. 5, fastslår, at beskyttelsen efter loven og forordningen gælder i 10 år efter den registreredes død. Dette indebærer bl.a., at allerede behandlede personoplysninger i denne periode fortsat vil være omfattet af loven og forordningen, og at indsamling og efterfølgende behandling om afdøde personer skal overholde kravene i loven og forordningen. I nogle situationer vil den registreredes død medføre, at det ikke længere er relevant at opbevare og behandle oplysningerne, og i så fald er den dataansvarlige forpligtet til at slette oplysningerne.

Det er uklart, om nærtstående kan indtræde i den afdødes rettigheder, men forarbejderne synes at lægge til grund, at dette ikke er tilfæl-

det. Det anføres således i bemærkningerne til bestemmelsen, at en række af lovens regler "i sagens natur" ikke kan finde anvendelse, herunder reglerne om samtykke og oplysningspligt (art. 13 og 14). Forarbejderne nævner dog ikke andre af bestemmelserne om registreredes rettigheder.

Kapitel 3

Databeskyttelsesrettens aktører

Forud for gennemgangen af forordningens materielle regler kan det være nyttigt at indlede med et kort overblik over de tre centrale aktører i forordningen, der tildeles rettigheder (den registrerede) og forpligtelser (den dataansvarlige og databehandleren).

Andre af forordningens centrale aktører, tilsynsmyndighederne, Databeskyttelsesrådet og databeskyttelsesrådgivere, der bidrager til overholdelse og håndhævelse af forordningens regler, omtales nærmere i kapitel 8.7 og 10.

1. Den registrerede

Forordningen regulerer behandlingen af oplysninger om fysiske personer. I forordningens terminologi benævnes den person, som oplysningen vedrører, den “registrerede”. Den registrerede er således forordningens beskyttelsessubjekt og den, som tildeles en række rettigheder. Begrebet volder sjældent afgrænsningsvanskeligheder, da det er nogenlunde klart, hvad der forstås ved en fysisk person.

Begrebet “den registrerede” kan forekomme lidt gammeldags og lå mere naturligt for, da registre var omdrejningspunktet for databeskyttelsesretten, som tilfældet var i de ovenfor omtalte registerlove fra 1970’erne. Det engelsksprogede begreb “data subject” er mere tidløst og derfor også i en vis forstand bedre egnet til i nutidens databeskyttelsesret. Begrebet “datasubjekt” falder dog ikke lige så naturligt på dansk, og da for-

ordningen anvender begrebet “den registrerede”, fastholdes begrebet også her.

2. Den dataansvarlige

Ansaret for at overholde forordningens regler ved behandling af personoplysninger påhviler den, der vælger, hvorvidt og hvordan oplysningerne skal behandles. I forordningens terminologi betegnes vedkommende “den dataansvarlige”, hvilket begreb er defineret på følgende måde i art. 4, nr. 7:

Definition

en fysisk eller juridisk person, en offentlig myndighed, en institution eller et andet organ, der alene eller sammen med andre afgør, til hvilke formål og med hvilke hjælpemidler der må foretages behandling af personoplysninger; hvis formålene og hjælpemidlerne til en sådan behandling er fastlagt i EU-retten eller medlemsstaternes nationale ret, kan den dataansvarlige eller de specifikke kriterier for udpegelse af denne fastsættes i EU-retten eller medlemsstaternes nationale ret

Det er åbenbart, at den, der beslutter at behandle oplysninger om andre og også selv gennemfører behandlingen, har ansvaret for at overholde forordningen og dermed også er den, som kan underkastes forordningens sanktioner, hvis dette ikke sker. Konsekvensen af, at den dataansvarlige er forordningens primære pligtssubjekt, er imidlertid også, at den dataansvarlige fortsat har et ansvar i situationer, hvor databehandlingen foretages af en tredjemand på vegne af den dataansvarlige, en såkaldt databehandler, jf. herom nedenfor.

Den engelsksproget betegnelsen for den dataansvarlige er “data controller”, hvilket på sin vis er mere retvisende. Det centrale er således, at den dataansvarlige har kontrol over behandlingen. Den dataansvarliges ansvar er en konsekvens af denne kontrol.

Det følger af definitionen i art. 4, nr. 7, at både fysiske og juridiske personer kan være dataansvarlige. Når virksomheder, myndigheder og andre juridiske personer behandler personoplysninger, foretages handlingerne normalt af medarbejdere i organisationen. Som i de fleste andre sammenhænge identificeres medarbejderen med organisationen, og det er derfor også organisationen og ikke medarbejderen, der er da-

Både fysiske og juridiske personer

taansvarlig. Medarbejderen kan undtagelsesvist blive selvstændig dataansvarlig, hvis den pågældende behandler oplysningerne i egen interesse og helt uden for arbejdsgiverens instruks, jf. forordningens art. 29 og afsnit 4 nedenfor. Den registrerede kan ikke være dataansvarlig. Behandler man oplysninger om sig selv, f.eks. ved at videregive dem til andre, underlægges man ikke forordningens krav.

Selvom der vel heller ikke er tvivl herom, er det udtrykkeligt fastslået af EDPB i guidelines 05/2021 on the interplay between the application of Article 3 and the provisions on international transfers as per Chapter V of the GDPR, pkt. 12, note 10. Det har bl.a. den betydning, at der ikke foreligger en tredjelandsoverførsel efter forordningens kap. V, når den registrerede selv overfører oplysninger til et tredjeland, jf. herom kap. 9.1 nedenfor.

Det er den juridiske enhed, f.eks. et aktieselskab, som er dataansvarlig. Interne afdelinger i aktieselskabet er derfor ikke dataansvarlige, heller ikke selvom afdelingen har ansvaret for virksomhedens overholdelse af databeskyttelsesreglerne. Omvendt vil koncernforbundne virksomheder være selvstændigt dataansvarlige. Et moderselskab bliver således ikke dataansvarlig for de behandlinger, som et datterselskab foretager for at forfølge egne formål. På tilsvarende vis vil offentlige myndigheder være selvstændigt dataansvarlige. Det kan dog være tvivlsomt, hvornår en enhed har karakter af en selvstændig offentlig myndighed, og hvornår den kun indgår som organisatorisk enhed i en – større - offentlig myndighed. Ved den konkrete vurdering kan bl.a. lægges vægt på, om enhedens opgaver er klart afgrænset og har selvstændig karakter, om enheden er undergivet andre enheders instruktionsbeføjelse og enhedens generelle selvstændighed i sin opgaveudførelse, jf. *Korfits Nielsen & Lotterup*, Databeskyttelsesforordningen og databeskyttelsesloven, s. 272.

Det centrale element i definitionen af en dataansvarlig er, at denne afgør formålet og hjælpemidlerne med behandlingen. Som anført af EDPB i Retningslinjer 07/2020 om begreberne dataansvarlig og databehandler i den generelle forordning om databeskyttelse (v. 2.0), pkt. 35, kan dette også formuleres som de to spørgsmål om, *hvorfor* der skal ske en behandling (formålet), og *hvordan* behandlingen skal ske (hjælpemidler). Overordnet er den dataansvarlige altså den, der bestemmer

Den dataansvarlige afgør formål og hjælpemidler

hvorfor, der skal behandles personoplysninger, og hvordan det skal ske.

Når det skal vurderes, hvem der afgør formålet med behandlingen, kan der tages udgangspunkt i den formålsfastlæggelse, der altid skal foretages, før behandlingen indledes. Det følger således af art. 30, at den dataansvarlige skal føre en fortegnelse over behandlingsaktiviteter, der bl.a. skal angive formålet med behandlingen. Det følger videre af art. 13 og 14, at den dataansvarlige som led i sin oplysningspligt bl.a. skal informere den registrerede om formålet med behandlingen i forbindelse med indsamling af oplysninger. På tilsvarende vis skal dataansvarlige oplyse om formålet, når den registrerede begærer indsigt i behandlingen efter art. 15. Endelig følger det af art. 5, stk. 1, litra b, at oplysninger skal indsamles til udtrykkeligt angivne formål og ikke må viderebehandles på en måde, der er uforenelig med formålet.

– formål

Den formelle fastlæggelse af formålet kan dog ikke i alle tilfælde afgøre, hvem der er dataansvarlig. Som påpeget af EDPB er begrebet “dataansvarlig” et funktionelt begreb, hvor der skal lægges vægt på de faktiske forhold og ikke formelle angivelser, jf. EDPB’s Retningslinjer 07/2020 om begreberne dataansvarlig og databehandler i den generelle forordning om databeskyttelse (v. 2.0), pkt. 12. Dette indebærer bl.a., at parterne, der er involveret i en behandling af personoplysninger, ikke kan afgøre mellem sig, hvem der skal være dataansvarlig gennem en ukorrekt formålsangivelse, hvis realiteten er en anden, ligesom en part ikke kan smyge et dataansvar af sig ved at undlade at fastsætte et eget selvstændigt formål med behandlingen og blot henvise til, at den pågældende alene bistår en anden dataansvarlig med at opfylde dennes formål, hvis realiteten er, at parten behandler oplysningerne til eget formål. De formålsangivelser, der er knyttet til behandlingsaktiviteter, kan derfor være udgangspunkt for vurderingen af, hvem der er dataansvarlig, men heller ikke mere end det. I sidste ende vil det bero på en konkret vurdering, hvad der er formålet med en behandling, herunder om en kæde af behandlingsaktiviteter udgør én eller flere behandlinger og dermed er underlagt samme eller forskellige formål. Se også nedenfor om eksempler på disse grænseflader.

Begrebet “hjælpemidler” kan give indtryk af, at der navnlig sigtes til de tekniske hjælpemidler, som anvendes i behandlingen. Begrebet skal dog forstås bredere (i den engelsksproget version af forordningen

– hjælpemidler

anvendes ordet “means”). EDPB har introduceret en sondring mellem “væsentlige” og “ikke-væsentlige” hjælpemidler og definerer væsentlige hjælpemidler på følgende måde: “hjælpemidler, der er tæt forbundet med formålet og omfanget af behandlingen, såsom den type personoplysninger, der behandles (“hvilke oplysninger behandles?”), varigheden af behandlingen (“hvor længe skal de behandles?”), kategorierne af modtagere (“hvem skal have adgang til dem?”) og kategorierne af registrerede (“hvilke personers oplysninger behandles?”), Retningslinjer 07/2020, pkt. 40. “Ikke-væsentlige” hjælpemidler vedrører ifølge retningslinjerne mere praktiske aspekter af gennemførelsen, f.eks. valg af en bestemt type udstyr, software eller nærmere sikkerhedsforanstaltninger. Mens de væsentlige hjælpemidler afgøres af den dataansvarlige, kan de ikke-væsentlige hjælpemidler afgøres af en databehandler, f.eks. en cloudleverandør. Det er sprogligt ikke helt oplagt, at begrebet “hjælpemidler” omfatter forhold som typen af personoplysninger eller varigheden af behandlingen. Ikke desto mindre forekommer det hensigtsmæssigt, at det ikke bliver en for rigid ordlydsfortolkning, men en helhedsvurdering, der afgør, hvem der er dataansvarlig, således at dette ansvar tildeles den, der reelt har den bestemmende indflydelse over behandlingen.

I Datatilsynets og Justitsministeriets Vejledning om dataansvarlige og databehandlere, s. 9, anvendes begrebet “væsentligste behandlingsskridt”, hvilket sprogligt er mere dækkende, men omvendt ikke fremgår af definitionen i art. 4, nr. 7.

Det fremgår heller ikke af definitionen i art. 4, nr. 7, at visse hjælpemidler kan afgøres af andre end den dataansvarlige. Det forekommer dog også hensigtsmæssigt, at den dataansvarlige ikke nødvendigvis skal afgøre alle tekniske aspekter af behandlingen, eftersom den teknologiske udvikling, ikke mindst cloududviklingen, indebærer, at den dataansvarlige i mange tilfælde har stadig mindre indsigt i og indflydelse på opsætningen af de systemer, hvor oplysningerne behandles.

I mange situationer, vil der ikke være tvivl om, hvem der er dataansvarlig. Det vil særligt gælde, når en fysisk eller juridisk person foretager en behandling af personoplysninger til eget formål og selv står for alle dele af behandlingen. Også når flere aktører er involveret i behandlingen kan det være klart, hvem der er dataansvarlig. Har en virk-

De klare tilfælde

somhed eksempelvis truffet beslutning om at behandle personoplysninger for at forfølge et formål i egen interesse (f.eks. gennemførelse af en markedsføringskampagne) og truffet beslutning om de væsentlige dele af hjælpemidlerne som angivet ovenfor, vil virksomheden være dataansvarlig, selvom den tekniske gennemførelse af kampagnen overlades til en ekstern samarbejdspartner. Når flere aktører er involveret, vil det imidlertid nogle gange være tvivlsomt, om der er et eller flere formål med behandlingen, hvis interesser behandlingen varetager m.m., og dermed også tvivl om, hvem der er dataansvarlig.

Tvivlen kan særligt opstå i de situationer, hvor én part skal varetage en opgave på vegne af en anden part som indebærer behandling af personoplysninger. I disse situationer, kan det være tvivlsomt, om den part, der udfører opgaven, alene agerer som databehandler, eller om parten selv har fastsat formål og hjælpemidler på en sådan måde, at den pågældende bliver dataansvarlig.

Grænsetilfælde – særligt om sondringen mellem dataansvarlig og databehandler

Et illustrativt eksempel herpå er advokaters behandling af personoplysninger som led i sagsbehandling på vegne af klienter. Man kan betragte det sådan, at formålet med behandlingen udelukkende er at varetage klientens interesser og sker på vegne af klienten, og at advokaten derfor ikke har noget selvstændigt formål med behandlingen. Man kan også betragte det sådan, at formålet med behandlingen er at kunne levere en advokatydelse, og at advokaten derfor behandler oplysningerne til eget formål. EDPB antager (Retningslinjer 07/2020, pkt. 27), at et advokatfirma, der bistår en virksomhed i en retssag, bliver dataansvarlig for sin behandling af personoplysninger, fordi virksomhedens mandat til advokatfirmaet ikke er rettet specifikt mod behandlingen af personoplysninger, og fordi advokatfirmaet handler med en betydelig grad af uafhængighed, f.eks. ved at beslutte, hvilke oplysninger der skal bruges, og hvordan de skal bruges. Hvis virksomheden omvendt vælger, hvilke personoplysninger, der skal overgives til advokatfirmaet, og hvordan de må bruges, kan advokatfirmaet ikke antages at blive dataansvarlig.

I Datatilsynets og Justitsministeriets Vejledning om dataansvarlige og databehandlere lægges der vægt på, om den ydelse, som skal udføres, i sig selv består i behandling af personoplysninger, se vejledningens pkt. 3.1.1. I så fald vil udgangspunktet være, at den part, der udfører ydelsen, alene er databehandler, mens opgavestilleren er data-

ansvarlig. Er behandlingen af personoplysninger omvendt ikke en del af selve ydelsen, vil den part, der udfører opgaven, som udgangspunkt være dataansvarlig. I vejledningen gives som et eksempel herpå et tilfælde, hvor en kommune bestiller en tømrer til at opsætte dørgreb hos en handicappet borger og oplyser tømreren om borgerens navn og adresse. Tømrerens behandling af disse personoplysninger er nødvendig for at kunne udføre opgaven, men behandlingen er ikke en del af selve ydelsen. Tømreren er derfor ikke databehandler men dataansvarlig for sin behandling af oplysningerne.

I de situationer, hvor formåls- og hjælpemiddelkriterierne ikke umiddelbart kan give svaret på, om en person er dataansvarlig, vil det nok bero på en bredere helhedsvurdering, om den pågældende har en sådan bestemmende indflydelse på behandlingen, at personen bliver dataansvarlig. Hvis interesser varetager behandlingen? Hvem vurderer, om behandlingen skal foretages? Hvor stort selvstændigt råderum for at træffe afgørelser om behandlingen har den pågældende person?

Der etableres kun et databehandlerforhold, hvis en overladelse af personoplysninger fra den dataansvarlige til databehandleren i et eller andet omfang sker med henblik på behandling af oplysningerne. Hvis en aftale mellem to parter først og fremmest drejer sig om levering af en anden ydelse end behandling af personoplysninger, og hvor der derfor ikke er behov for at give instruks om behandling af de personoplysninger, der måtte blive givet adgang til som led i aftaleforholdet, foreligger ikke et databehandlerforhold, jf. Datatilsynets vejledning om dataansvarlige og databehandlere fra november 2017, s. 7.

Vejledningen giver som et eksempel herpå, at en reparatør af kopimaskiner som led i sit arbejde får adgang til personoplysninger i en virksomhed, der skal have repareret sin kopimaskine. Reparatøren har i denne situation ikke karakter af databehandler, fordi parternes aftale hverken helt eller delvist (og hverken eksplicit eller forudsætningsvist) går ud på, at reparatøren skal behandle personoplysninger på vegne af virksomheden.

Det kan i nogle tilfælde være vanskeligt at afgøre, om den, som personoplysningerne overlades til, har karakter af en databehandler eller en selvstændig dataansvarlig. En revisor, der skal udarbejde en selvangivelse for en virksomhed, hvilket forudsætter brug af personoplysning-

ger, vil eksempelvis kunne blive betragtet som selvstændig dataansvarlig, hvis virksomheden blot har givet revisoren en bred instruks om at udarbejde selvangivelsen. I denne situation afgør revisoren selv, hvordan og på hvilken måde personoplysningerne skal behandles som led i udarbejdelsen af selvangivelsen, jf. Datatilsynets vejledning om dataansvarlige og databehandlere, s. 9.

I nogle situationer involverer behandlingsaktiviteter flere dataansvarlige. Dette vil være tilfældet, når aktiviteterne omfatter flere selvstændige behandlinger med forskellige dataansvarlige. Gennemfører en analysevirksomhed eksempelvis en arbejdspladsvurdering hos en kunde, der har givet nærmere instrukser om, hvilke medarbejdropslysninger, der skal indsamles, og hvordan de skal indgå i undersøgelsen, vil kunden være dataansvarlig og analysevirksomheden databehandler. Vælger analysevirksomheden at anvende oplysningerne til andre formål, f.eks. udarbejde generelle statistikker til brug for sin rådgivning af andre kunder, vil analysevirksomheden blive dataansvarlig for denne brug af oplysningerne.

Flere selvstændige dataansvarlige

Situationen kan dog også være den, at der er flere dataansvarlige for den samme behandling. Definitionen i art. 4, nr. 7, forudsætter således, at flere organisationer mv. sammen kan afgøre formål og hjælpemidler, (jf. ordene “[...] der alene eller sammen med andre afgør [...]”). I så fald vil begge parter blive dataansvarlige. EU-Domstolen har forholdt sig til spørgsmålet om fælles dataansvar i tre afgørelser, der alle nåede frem til, at der forelå et fælles dataansvar.

Fælles dataansvarlige

I C-210/16 (Wirtschaftsakademie) fastslog domstolen, at en virksomhed, der havde en fanside på Facebook, var fælles dataansvarlig med Facebook, når Facebook via cookies indsamlede oplysninger om brugerne af fansiden til brug for statistik. Facebook gav administratorer af fansider gratis adgang til statistikoplysninger om brugerne. EU-Domstolen fastslog først (præmis 30), at Facebook skulle anses for den, der primært afgjorde formål og hjælpemidler. Domstolen lagde imidlertid vægt på (præmis 36 og 37), at administratoren af fansiden kunne definere de kriterier, som statistikkerne skulle udarbejdes på grundlag af og angive de kategorier af personer, som Facebook skulle indsamle oplysningerne om. På den baggrund fastslog domstolen, at virksomheden (administratoren af fansiden) og Facebook tilsammen afgjorde formål og hjælpemidler og derfor var fælles dataansvarlige.

Afgørelsen viser, at en part (i det konkrete tilfælde virksomheden, der administrerede fansiden) kan blive dataansvarlig, selvom en anden (i det konkrete tilfælde Facebook) primært fastlægger formål og hjælpemidler, hvis parten kan siges at bidrage til fastlæggelsen.

I C-40/17 (Fashion ID) havde en virksomhed integreret Facebooks "like"-knap på sin hjemmeside. Knappen er i realiteten et lille computerprogram, der kan registrere og synliggøre på Facebook, når en bruger af en hjemmeside "liker" siden. Knappen har imidlertid også den funktion, at den indsamler oplysninger om brugerne og videregiver disse oplysninger til Facebook, uanset om brugeren har trykket på knappen, og uanset om brugeren var medlem af Facebook. EU-Domstolen fastslog, at hjemmesideindehaveren og Facebook sammen bestemte de formål og hjælpemidler, der var knyttet til indsamlingen af oplysningerne via hjemmesiden og videregivelsen heraf til Facebook. Hjemmesideindehaveren bidrog til afgørelsen om hjælpemiddel ved at træffe beslutningen om at integrere "like knap"-modulet på sin hjemmeside. EU-Domstolen fandt endvidere, at hjemmesideindehaveren bidrog til at fastlægge formålet med behandlingen, idet "like"-knappen bidrog til at gøre hjemmesideindehaverens varer mere synlige på Facebook, når brugerne klikkede på knappen. På den baggrund fastslog domstolen, at hjemmesideindehaveren og Facebook var fælles dataansvarlige for indsamlingen og videregivelsen af oplysningerne. Derimod var hjemmesideindehaveren ikke dataansvarlig for Facebooks videre behandling af oplysningerne.

I C-25/17 (Jehovas Vidner) tog medlemmer af Jehovas Vidner noter om besøgene, som de kontaktede ved at gå fra dør til dør. Dette kunne omfatte oplysninger om navn, adresse, religiøs overbevisning og familiemæssige status. Noterne, der blev anvendt af de forkyndende medlemmer ved eventuelt senere besøg hos de samme personer, blev udarbejdet på de forkyndende medlemmers egen initiativ, og selve trossamfundet Jehovas Vidner og dets menigheder instruerede ikke medlemmerne herom og fik heller ikke videregivet oplysninger fra de forkyndende medlemmer. Jehovas Vidner bestred på denne baggrund af være dataansvarlig for de forkyndende medlemmers behandling af personoplysninger. EU-Domstolen fastslog mere generelt, at en fysisk eller juridiske person, der til eget formål udøver indflydelse på behandlingen af personoplysninger og som følge heraf deltager i fastlæg-

gelsen af formål med og hjælpemidler ved behandlingen, vil være dataansvarlig. EU-Domstolen fandt, at de forkyndende medlemmer og Jehovas Vidner var fælles dataansvarlige, selvom det alene var medlemmerne, der besluttede, om de ville indsamle oplysninger, hvilke oplysninger de ville indsamle, og selvom Jehovas Vidner ikke fik adgang til oplysningerne. Domstolen lagde vægt på, at forkyndelsen og indsamlingen af oplysningerne fandt sted med henblik på udbredelse af Jehovas Vidners overbevisning, og at trossamfundet organiserede og koordinerede medlemmernes forkyndelsesaktiviteter og dermed opmuntrede medlemmerne til at behandle personoplysninger.

Særligt Facebook-afgørelserne viser, at en person kan blive (fælles) dataansvarlig, når den pågældende har en selvstændig interesse i behandlingen og bidrager til dens gennemførelse, også selvom personen kun i et mere begrænset omfang medvirker til at fastlægge formål og hjælpemidler, der i øvrigt primært afgøres af en anden dataansvarlig. Afgørelserne viser endvidere, at en person godt kan have karakter af dataansvarlig, selvom den pågældende ikke har adgang til de behandlede personoplysninger.

Art. 26 indeholder en regulering af parternes forpligtelser og ansvar i tilfælde af fælles dataansvar, jf. herom afsnit 6.

Det følger af art. 4, nr. 7, at når formålet med en behandling er fastlagt i lovgivning, kan den pågældende lovgivning også eksplicit angive, hvem der er dataansvarlig. Denne mulighed udnyttes dog sjældent.

Lovregulering af
hvem der er
dataansvarlig

Se som et eksempel herpå bekendtgørelse nr. 302 af 8. marts 2022 om det fælles it-baserede datagrundlag og det statistiske datavarehus på beskæftigelsesområdet, der i § 11 fastslår, at it-leverandøren er dataansvarlig for anvendelse af oplysninger i specifikke testmiljøer og i § 153 fastslår, at de enkelte kommuner er dataansvarlig for egen brug af nærmere angivne systemer.

Når lovgivning pålægger en myndighed eller anden organisation at behandle personoplysninger, vil formålet med behandlingen i realiteten være bestemt af lovgiver, og den organisation der er påført den lovbundne opgave, vil som konsekvens heraf være dataansvarlig. Det samme gælder de situationer, hvor lovgivningen ikke eksplicit pålægger en myndighed eller anden organisation at behandle personoplysninger men pålægger organisationen at udføre en opgave, som forudsætter

Dataansvarlig for
lovbundne
behandlinger

behandling af personoplysninger. Også i denne situation er formålet – om end indirekte – fastlagt af lovgiver, og den organisation, der er pålagt den lovbundne opgave, vil være dataansvarlig, jf. EDPB's Retningslinjer 07/2020, pkt. 24.

Det følger af definitionen i art. 4, nr. 7, at den dataansvarlige både skal fastsætte formålet og hjælpemidlerne med behandlingen. Definitivt bliver en person således ikke dataansvarlig, hvis den pågældende fastsætter formålet med en behandling men overlader selve behandlingen og alle beslutninger om hjælpemidler forbundet hermed til en anden. Omvendt bliver denne anden person heller ikke dataansvarlig, fordi den pågældende ikke har fastsat formålet med behandlingen. Teoretisk set kan derfor opstå den uhensigtsmæssige situation, at ingen er dataansvarlig for den pågældende behandling. I praksis vil dette dog ikke ske. Man kan ikke forestille sig, at domstole eller tilsynsmyndigheder vil nå et resultat, hvor forordningen skulle føre til, at ingen var ansvarlig for en behandling af personoplysninger, der i øvrigt var omfattet af forordningens regler. Spørgsmålet bliver derfor kun, hvem der samlet set har den primære interesse i og kontrol over behandlingen.

Behandlinger
uden en
dataansvarlig?

3. Databehandleren

I nogle situationer vil en dataansvarlig vælge at lade en tredjepart varetage behandlingen af personoplysninger på sine vegne. En sådan tredjepart har i forordningens terminologi karakter af en databehandler, hvilket i art. 4, nr. 8, defineres som "en fysisk eller juridisk person, en offentlig myndighed, en institution eller andet organ, der behandler oplysninger på den dataansvarliges vegne".

Tidligere rummede databehandlerbegrebet navnlig de virksomheder, der varetog driften af deres kunders it-systemer, og sådanne it-driftsleverandører, herunder cloududbydere, udgør også fortsat en praktisk vigtig gruppe af databehandlere, men databehandlerforholdet kan opstå i mange forskellige typer af relationer. Udbydere af sociale netværkstjenester, der giver brugerne mulighed for at lagre og dele information via udbyderens server og tilhørende tjenester, har eksempelvis karakter af databehandlere. Dette gælder dog kun i relation til de personoplysninger, som brugerne lægger ind på tjenesten og deler

Eksempler på
databehandlere

med hinanden. I relation til de oplysninger om brugerne, som tjenesteudbyderen selv behandler, vil udbyderen være dataansvarlig, jf. også ovenfor EU-Domstolens praksis om fælles dataansvar for Facebook og deres brugere. Se også eksemplerne fra EDPB nedenfor.

Det følger af definitionen i art. 4, nr. 8, at en person kun kan blive databehandler, hvis den pågældende (1) behandler personoplysninger og (2) dette sker på vegne af den dataansvarlige.

Foretager en person, der bistår en anden, ingen behandling af personoplysninger, kan personen ikke være databehandler.

Databehandleren skal behandle personoplysninger

Derimod er det muligt at være dataansvarlig, selvom man ikke selv behandler personoplysninger. Dette kan både være tilfældet, hvis al databehandlingen er overladt til databehandleren, og hvis databehandlingen foretages af en anden fælles dataansvarlig, jf. herved den ovenfor beskrevne praksis fra EU-Domstolen om fælles dataansvar, hvorefter en person potentielt godt kan være (fælles) dataansvarlig, selvom den pågældende ikke selv behandler oplysninger og heller ikke nødvendigvis har adgang til dem.

Om den potentielle databehandler foretager en behandling af personoplysninger skal afgøres på samme måde, som når det i øvrigt skal afgøres om en person foretager "behandling" af "personoplysninger", jf. om disse begreber kap. 2.1.1 og 2.1.2. Som dér anført kan en behandling helt undtagelsesvist have en så bagatelagtig karakter, at den ikke skal rubriceres som en "behandling" i forordningens forstand, selvom den formelt omfattes af begrebet (f.eks. når oplysningerne lagres på en internettrasmittørs routere i forbindelse med forsendelse af oplysninger over internettet). På samme måde vil en person, der bistår en anden, og som i den forbindelse får en helt tilfældig og flygtig adgang til personoplysninger, formentlig undtagelsesvist kunne siges ikke at foretage behandling af oplysningerne og dermed ikke være databehandler.

Dette synes også lagt til grund af EDPB i Retningslinjer 07/2020, som under pkt. 83 angiver et eksempel, hvor en virksomhed hyrer en ekstern it-konsulent til at rette softwarefejl. Konsulenten er ikke hyret til at behandle personoplysninger, og enhver adgang til personoplysninger vil være rent tilfældig og i praksis derfor meget begrænset. På den baggrund lægges i eksemplet til grund, at konsulenten ikke bliver databe-

handler. Virksomheden skal til gengæld træffe passende foranstaltninger efter art. 32 for at forhindre konsulenten i at behandle personoplysninger på en uautoriserede måde.

Det karakteristiske for databehandlerforholdet er, at den dataansvarlige har en instruktionsbeføjelse over for databehandleren og gennem denne beføjelse i sidste ende er den, som afgør formålet med behandlingen, hvilke oplysninger der behandles, og hvordan behandlingen skal foretages (hjælpe midlerne). Databehandleren behandler med andre ord og med formuleringen fra definitionen i art. 4, nr. 8 oplysningerne på vegne af den dataansvarlige.

Databehandlingen skal ske på vegne af den dataansvarlige - instruktionsbeføjelsen

Som beskrevet i afsnit 2 ovenfor kan det i nogle tilfælde være vanskeligt at afgøre, om en person, der bistår en anden, behandler oplysninger på egne vegne (og dermed bliver dataansvarlig) eller på vegne af den anden person (og dermed bliver databehandler). Se nærmere om afgrænsningen heraf i det anførte afsnit.

Som anført ovenfor vil en dataansvarlig være en selvstændig juridisk enhed, f.eks. et aktieselskab. Derimod kan en intern afdeling i aktieselskabet ikke have karakter af dataansvarlig. Dette gælder tilsvarende for databehandlere og indebærer, at en afdeling i en virksomhed ikke kan være databehandler for den behandling af personoplysninger, der foretages af virksomheden generelt eller i andre af virksomhedens afdelinger. Virksomheden (den selvstændige juridiske enhed vil være dataansvarlig for alle behandlinger, der foretages af virksomhedens afdelinger, og der kan derfor ikke opstå en "intern" databehandlerkonstruktion. Derimod er koncernforbundne selvstændige juridiske enheder selvstændige personer i databeskyttelsesretlig forstand. Et koncernselskab, der behandler personoplysninger på vegne af andre selskaber i koncernen, kan derfor have karakter af databehandler for disse behandlinger.

Databehandleren skal være selvstændig juridisk enhed

Når der foreligger et databehandlerforhold, indebærer det en række forpligtelser for den dataansvarlige og databehandleren, herunder en pligt til at indgå en skriftlig databehandleraftale. Disse krav er angivet i forordningens art. 28, der beskrives i afsnit 5 nedenfor. der skal overholde de indholdsmæssige krav, som følger af forordningens art. 28, stk. 3, herunder fastsætte, at databehandleren kun må behandle personoplysninger efter dokumenteret instruks fra den data-

Krav om databehandleraftale og andre pligter knyttet til databehandlerforholdet

ansvarlige, sikre at de personer, som behandler oplysningerne, er underlagt fortrolighed, at databehandleren skal iagttage de fornødne sikkerhedskrav mm.

Udover de forpligtelser, der følger af art. 28, er databehandleren underlagt selvstændige forpligtelser og ansvar efter en række af forordningens øvrige regler. Som nærmere omtalt i de følgende kapitler gælder mange af forordningens forpligtelser således direkte for både dataansvarlige og databehandlere. Det følger endvidere af art. 82 og 83, at databehandlere kan ifalde erstatningsansvar direkte over for den registrerede og kan blive pålagt administrative bøder, jf. nærmere herom kapitel 11.

Databehandlers ansvar

Se generelt om databeskyttelsesrettens aktører, *Blume*, Den nye persondatarets aktører, og om begreberne “dataansvarlig” og “databehandler”, Artikel 29-gruppens Opinion 1/2010 on the concepts of “controller” and “processor” (efter det tidligere persondatadirektiv).

4. Ansatte

Som anført vil en dataansvarlig enten være en fysisk person eller en selvstændig juridisk person. Langt de fleste behandlinger af personoplysninger foretages af virksomheder, myndigheder og andre juridiske personer. Endvidere vil mange behandlinger foretaget af fysiske personer være undtaget forordningen efter art. 2, stk. 2, litra c, fordi den foretages som led i rent personlige eller familiemæssige aktiviteter. I praksis indebærer det, at den dataansvarlige oftest er en juridisk person. Som det gælder i andre forhold, foretages juridiske personers handlinger af de fysiske personer, der repræsenterer den juridiske person, primært dens ansatte. Ansatte, der behandler personoplysninger på vegne af den dataansvarlige, er ikke selvstændige pligts subjekter under forordningen men identificeres med den dataansvarlige. Man kan også udtrykke det således, at ansatte ikke udgør en retlig aktør i forordningen men dog en praktisk aktør, da det ofte er dem, som foretager den faktiske behandling af personoplysninger.

Det følger af forordningens art. 29, at enhver, der udfører arbejde for den dataansvarlige eller databehandleren, og som led i dette arbejde har adgang til personoplysninger, kun må behandle oplysninger-

ne efter instruks fra den dataansvarlige. Handler den ansatte uden for arbejdsgiverens instruks for behandling af personoplysninger, vil den ansatte potentielt kunne blive selvstændig dataansvarlig for den pågældende behandling, på samme måde som det gælder for databehandlere. I mange tilfælde vil en overtrædelse af de databeskyttelsesretlige regler være forårsaget af en fejl fra en ansat. Dette indebærer ikke i sig selv, at den ansatte kan siges at have handlet i strid med instruksen og bliver selvstændig dataansvarlig, eller at arbejdsgiveren (den dataansvarlige) ikke har ansvaret for overtrædelsen. I så fald ville virksomheder og myndigheder i realiteten være fritaget fra ansvar for de fleste overtrædelser. Udgangspunktet vil være det modsatte: at arbejdsgiveren identificeres med den ansatte i relation til dennes handlinger i strid med reglerne, også selvom det formelt set normalt vil ligge eksplicit eller implicit i instruksen, at behandlingen skal ske inden for lovgivningens rammer.

Handler den ansatte med fuldt overlæg helt uden for instruksen, vil den ansatte imidlertid kunne blive selvstændig dataansvarlig og arbejdsgiveren omvendt blive uden ansvar. Situationen er herved beslægtet med den situation, hvor en arbejdsgiver ikke bliver erstatningsansvarlig for den ansattes abnorme handlinger. Hvor meget der skal til, før arbejdsgiveren i databeskyttelsesretlig henseende ikke identificeres med den ansatte, er vanskeligt at sige, men det må tillægges vægt, hvorvidt og i hvilket omfang behandlingen har tilknytning til den ansattes varetægelse af sin stilling, og om der er tale om en forsætlig overtrædelse af instruksen. Jo grovere en overtrædelse, jo mere taler for, at det er den ansatte og ikke arbejdsgiveren, der er dataansvarlig for behandlingen. Arbejdsgiveren kan dog blive ansvarlig for en overtrædelse af art. 32, hvis der ikke er truffet fornødne sikkerhedsforanstaltninger mod det sikkerhedsbrud, som den ansattes ulovlige handling udgør.

I Datatilsynets afgørelse i sag [2020-441-4652](#) havde en ansat vagt hos Salling lukket en tidligere ansat vagt ind ad en personaleadgang og ind i et aflukket lokale og givet den tidligere ansatte adgang til se og optage videoovervågningsoptagelser fra en forretning med billeder af den tidligere ansattes ekskæreste, der var ude at shoppe. Salling oplyste bl.a., det kun var betroede medarbejdere, der havde adgang til lokalet. Det fremgik af Sallings ansættelseskontrakter og medarbejderhåndbog, at

oplysninger som medarbejdere fik kendskab til under ansættelsesforholdet skulle behandles fortroligt og ikke måtte videregives til uvedkommende. Salling havde også udsendt en mail til alle partnere og vagter om, at videomateriale kun måtte udleveres til politiet og ikke til andre. På denne baggrund fandt Datatilsynet, at Salling havde efterlevet sikkerhedskravene i art. 32. Datatilsynet anførte bl.a., at “Saling ikke kan anses for være ansvarlig for, at en medarbejder bevidst og mod bedre vidende på flere måder, herunder ved at give en tidligere ansat adgang til bygningen, har brudt virksomhedens retningslinjer. Datatilsynet finder, at medarbejderen har foretaget indtil flere handlinger, som ligger udover, hvad der med rimelighed kunne forventes, at Salling skulle have været forberedt på eller truffet foranstaltninger med henblik på at undgå. Datatilsynet har videre lagt vægt på, at hændelsen fremstår som en afgrænset og enkeltstående hændelse, der er sket som følge af en abnorm handling, og at både afsender og modtageren af optagelserne har bekræftet at have slettet oplysningerne”. Afgørelsen retter sig mod art. 32, men det ligger forudsætningsvist i den, at Salling ikke var dataansvarlig for den ulovlige videregivelse.

Et andet eksempel på en ekstrem handling fra en ansat, der fritog arbejdsgiveren for ansvar, er en meget omtalt sag afgjort af den engelsk højesteret i 2020 ([2020] UKSC 12 - WM Morrisson Supermarkets). En ansat i en supermarkeds kædes regnskabsafdeling kopierede og offentliggjorde oplysninger om ca. 100.000 af kædens medarbejdere angiveligt som hævn for at have fået en advarsel i forbindelse med sit arbejde. Højesteret fandt ikke, at supermarkeds kæden havde noget ansvar for medarbejderens ulovlige handlinger under den daværende engelske databeskyttelseslov.

5. Forpligtelser og ansvar ved brug af databehandler

Når en dataansvarlig vælger at bruge en databehandler, udløser det en række forpligtelser for både den dataansvarlige og databehandleren, ligesom det rejser spørgsmål om, hvilket ansvar parterne hver især har overfor hinanden og overfor de registrerede. I det følgende behandles det, der kan betegnes som databehandlerkonstruktionens hovedspørgsmål:

- Den dataansvarliges pligt til at bruge en databehandler, der overholder forordningen

- Krav om databehandleraftale
- Databehandlerens forpligtelser
- Den dataansvarliges kontrol med databehandleren
- Databehandlerens brug af underdatabehandlere
- Ansvar for databehandlerens ulovlige behandling af oplysninger

En række af disse spørgsmål er reguleret i forordningens art. 28, der er en ganske omfattende bestemmelse med 10 stykker. Bestemmelsen omtales løbende under behandlingen af de enkelte spørgsmål.

5.1. Den dataansvarliges pligt til at bruge en databehandler, der overholder forordningen

Den dataansvarliges pligt til at bruge en databehandler, der overholder forordningen, fremgår af art. 28, stk. 1, der har følgende ordlyd:

Hvis en behandling skal foretages på vegne af en dataansvarlig, benytter den dataansvarlige udelukkende databehandlere, der kan stille de fornødne garantier for, at de vil gennemføre de passende tekniske og organisatoriske foranstaltninger på en sådan måde, at behandling opfylder kravene i denne forordning og sikrer beskyttelse af den registreredes rettigheder.

Bestemmelsen indebærer, at den dataansvarlige allerede i forbindelse med sit valg af databehandler skal overveje, om databehandleren vil være i stand til og agter at overholde forordningens krav. Vurderer den dataansvarlige, at dette ikke er tilfældet, må den dataansvarlige vælge en anden databehandler. Den dataansvarlige kan med andre ord ikke "lukke øjnene" og håbe på, at databehandleren vil efterleve forordningen. Forordningen angiver ikke noget om, hvor indgående en vurdering af databehandlerens evne til at overholde forordningen, den dataansvarlige skal foretage. Dette vil bero på en konkret vurdering, hvor der bl.a. kan tages hensyn til, hvilke typer af oplysninger, der skal behandles, omfanget af oplysningerne og mere generelt, hvilken risiko for de registreredes, der er knyttet til behandlingen. Det må forventes, at store og professionelle databehandlere, vil kunne fremvise en mere omfattende beskrivelse af, hvordan de behandler oplysninger og efter-

lever forordningen, mens mindre databehandlere, der kun lejlighedsvis behandler personoplysninger, næppe vil være i besiddelse af en tilsvarende omfattende dokumentation. Foreligger der en konkret tvivl om databehandlerens evne eller vilje til at efterleve forordningen, må denne afklares af den dataansvarlige.

Et praktisk vigtigt eksempel herpå er den situation, hvor databehandleren er en europæisk virksomhed, f.eks. en cloudtjeneste, der er ejet af et amerikansk moderselskab. Som følge af forordningens særlige krav til tredjelandsoverførsler, jf. herom kap. 9, vil det ikke altid være lovligt at overføre oplysninger til det amerikanske moderselskab. Efter den amerikanske CLOUD ACT, kan det amerikanske moderselskab imidlertid under amerikansk ret blive pålagt at udlevere oplysningerne. Situationen kan således være den, at det amerikanske moderselskab bryder amerikansk lov, hvis ikke oplysningerne overføres fra det europæiske datterselskab, mens dette selskab omvendt vil overtræde databeskyttelsesforordningen, hvis oplysningerne overføres. Er der en reel mulighed for, at denne situation kan opstå, indebærer art. 28, stk. 1, nok en forpligtelse for den dataansvarlige til at få afklaret, om databehandleren (det europæiske datterselskab) vil respektere overførelsesforbuddet efter forordningen, særligt hvis databehandlerens egne vilkår kan efterlade tvivl om dette.

5.2. Databehandleraftalen

Når den dataansvarlige anvender en databehandler, skal parterne indgå en databehandleraftale, der nærmere angiver behandlingens omfang, formål mv. og databehandlerens forpligtelser. Kravet om at indgå en databehandleraftale følger af forordningens art. 28, stk. 3, 1. afsnit, 1. pkt.:

Krav om databehandleraftale og indholdet heraf

En databehandlers behandling skal være reguleret af en kontrakt eller et andet retligt dokument i henhold til EU-retten eller medlemsstaternes nationale ret, der er bindende for databehandleren med hensyn til den dataansvarlige, og der fastsætter genstanden for og varigheden af behandlingen, behandlingens karakter og formål, typen af personoplysninger og kategorierne af registrerede samt den dataansvarliges forpligtelser og rettigheder.

Databehandleraftalen skal således fastlægge

- Genstanden for og varigheden af behandlingen
- Behandlingens karakter og formål
- Typen af personoplysninger
- Kategorien af registrerede
- Den dataansvarliges forpligtelser og rettigheder

Disse krav suppleres i art. 28, stk. 3, 1. afsnit, 2. pkt., af en række forpligtelser for databehandleren, som ligeledes skal fremgå af databehandleraftalen. Efter denne del af bestemmelse skal databehandleraftalen foreskrive, at databehandleren

Angivelse af databehandlerens forpligtelser

- kun må behandle personoplysninger efter dokumenteret *instruks* fra den dataansvarlige (herunder overføre oplysningerne til et tredjeland). Dette gælder dog ikke, hvis den dataansvarlige er forpligtet til at foretage behandlingen efter EU-retten eller national ret. I så fald skal databehandleren orientere den dataansvarlige om, at behandlingen finder sted.
- sikrer, at de personer, der er autoriseret til at behandle personoplysninger, har forpligtet sig til *fortrolighed* eller er underlagt en passende lovbestemt tavshedspligt.
- iværksætter alle *sikkerhedsforanstaltninger*, som kræves i henhold til art. 32 (se herom kap. 7.1)
- opfylder de betingelser for at bruge underdatabehandlere, som følger af art. 28, stk. 2 og 4 (se herom straks nedenfor)
- under hensyntagen til behandlingens karakter, så vidt muligt *bistår den dataansvarlige* ved hjælp af passende tekniske og organisatoriske foranstaltninger, med opfyldelse af den dataansvarliges forpligtelse til at besvare anmodninger om udøvelse af *de registreredes rettigheder* som fastlagt i forordningens kapitel III (se herom kap. 6)
- *bistår den dataansvarlige* med at sikre overholdelse af *forpligtelserne i medfør af artikel 32-36* under hensyntagen til behandlingens karakter og de oplysninger, der er tilgængelige for databehandleren. Dette indebærer, at databehandleren i rimeligt omfang skal bistå den dataansvarlige med dennes overholdelse af pligten til (i) at iværksættelse sikkerhedsforanstaltninger efter art. 32, (ii) oplyse om brud på persondatasikkerheden efter art. 34 og 35 (se

herom kap. 7.2) og (iii) gennemføre konsekvensanalyser efter art. 35 og 36 (se herom kap. 8.6).

- efter den dataansvarliges valg *sletter eller tilbageleverer alle personoplysninger* til den dataansvarlige, efter at tjenesterne vedrørende behandling er ophørt, og sletter eksisterende kopier, medmindre EU-retten eller medlemsstaternes nationale ret foreskriver opbevaring af personoplysningerne
- stiller alle *oplysninger, der er nødvendige for at påvise overholdelse af kravene i art. 28*, til rådighed for den dataansvarlige
- giver mulighed for og bidrager til *revisioner (audits)*, herunder inspektioner, der foretages af den dataansvarlige eller en anden revisor, som er bemyndiget af den dataansvarlige

Det følger af art. 28, stk. 7 og 8, at Kommissionen og de nationale tilsynsmyndigheder kan udarbejde standardkontraktbestemmelser til opfyldelse af art. 28, stk. 3 – eller med andre ord en “standarddatabehandlersaftale”.

Standarddatabehandlersaftale

Begrebet “standardkontraktbestemmelser” anvendes i forordningen både om de her omhandlede bestemmelser, der regulerer forholdet mellem en dataansvarlig og en databehandler, og om de bestemmelser, der regulerer forholdet mellem en dataeksportør og en dataimportør ved overførsel af personoplysninger til tredjelande.

Fordelen ved at anvende denne type af standardaftaler er, at dataansvarlige og databehandlere kan forlade sig på, at aftalen opfylder forordningens krav, og man i øvrigt slipper for arbejdet med selv at skulle udforme en aftale. Parterne skal dog under alle omstændigheder indføre de individuelle oplysninger i aftalen om formålet med den konkrete behandling, typer af personoplysninger der behandles mv.

Datatilsynet har udarbejdet en skabelon til databehandlersaftale, der både foreligger på dansk og engelsk. Skabelonen er godkendt af ED-PB (som krævet efter art. 28, stk. 8), hvilket skaber en forventning om, at den ligeledes vil blive accepteret af tilsynsmyndigheder i andre lande.

De svenske og norske tilsynsmyndigheder har meddelt, at den danske standardaftale også kan anvendes af svenske og norske virksomheder.

Kommissionen har imidlertid også (efterfølgende) udarbejdet en standarddatabehandleraftale i henhold til art. 28, stk. 7, ved gennemførelsesafgørelse 2021/915, og det vil derfor være nærliggende at anvende denne ved grænseoverskridende aftaler, da Kommissionens aftale må forventes at få større udbredelse på europæisk plan. Indebærer brugen af en databehandler overførsel af oplysninger til tredjelande, kan det også være hensigtsmæssigt at bruge Kommissionens standardaftale, da denne også kan dække kravene til en databehandleraftale efter art. 28. Er der derimod tale om en rent dansk aftale mellem en dansk dataansvarlig og en dansk databehandler, kan det være nærliggende at bruge standardaftalen fra Datatilsynet, der har vundet udbredelse i Danmark. Begge aftaler kan imidlertid bruges og opfylder kravene efter art. 28.

Det er ikke et krav, at dataansvarlige og databehandlere anvender de standardaftaler, der er udarbejdet af Kommissionen og tilsynsmyndighederne. Parterne kan således udarbejde deres egne individuelle databehandleraftaler, når blot disse lever op til kravene i art. 28. Der er også muligt at tilpasse standardaftalerne fra Kommissionen og Datatilsynet, hvis den tilpassede version fortsat overholder kravene i art. 28. I så fald vil Datatilsynet dog nok i forbindelse med et eventuelt tilsyn efterprøve databehandleraftalen, mens dette ikke vil være tilfældet, når standardaftalen anvendes uden tilpasninger.

Det følger af art. 28, stk. 9, at databehandleraftalen skal være skriftlig, og at skriftlighedskravet kan opfyldes af et digitalt dokument.

Krav om
skriftlighed

5.3. Databehandlerens forpligtelser

På et overordnet plan kan databehandlerens forpligtelser inddeles i tre kategorier: (1) pligten til at behandle personoplysningerne i overensstemmelse med den dataansvarliges instruks, (2) pligten til at overholde databehandleraftalens øvrige krav og (3) pligten til at overholde de særskilte krav til databehandlere, der følger af direkte af forordningen (og som potentielt også kan følge af databehandleraftalen, hvis de er skrevet ind i denne, men som databehandleren under alle omstændigheder vil være underlagt).

Som beskrevet ovenfor skal det fremgå af databehandleraftalen, at databehandleren alene må behandle personoplysninger efter doku-

Pligten til at
handle inden for
instruksen

menteret instruks fra den dataansvarlige. Instruksen udgør med andre rammen for, hvordan databehandleren kan og må behandle personoplysningerne. At instruksen skal være "dokumenteret" indebærer, at det skal være muligt at påvise dens indhold uden at der er knyttet mere specifikke formkrav til, hvordan dette skal ske. I praksis opfyldes kravet oftest ved, at instruktionen foreligger på skrift. Såfremt databehandleren vurderer, at instruksen er i strid med forordningen eller lovgivning i øvrigt, skal databehandleren gøre den dataansvarlige opmærksom på det, jf. art. 28, stk. 3, 2. afsnit.

Mens instruksen forholder sig til, hvordan databehandleren skal behandle personoplysningerne, regulerer databehandleraftalen også en række andre forhold og forpligtelser for databehandleren som nærmere beskrevet ovenfor. Databehandleren skal selvsagt også iagttage disse forpligtelser. Det følger således også eksplicit af art. 28, stk. 3, at databehandleraftalen skal være bindende for databehandleren over for den dataansvarlige.

Mens der ikke er tvivl om, at databehandleren skal iagttage de forpligtelser, der følger af databehandleraftalen, kan det overvejes, om det også gælder de forpligtelser, som burde fremgå af databehandleraftalen, men som ikke gør det. Art. 28, stk. 3, angiver en række forpligtelser, der skal fremgå af databehandleraftalen. Et væsentligt eksempel herpå er databehandlerens pligt til at bistå den dataansvarlige med dennes opfyldelse af sine forpligtelser, herunder forpligtelsen til at iagttage de registreredes rettigheder og pligten til at oplyse om sikkerhedsbrud. De registrerede kan ikke gå direkte til en databehandler og f.eks. kræve indsigt (efter art. 15) eller sletning (efter art. 17) men må henvende sig til den dataansvarlige. Databehandleren er heller ikke forpligtet til at oplyse tilsynsmyndighederne eller de registrerede om et sikkerhedsbrud. Oplysningerne om et sådant brud skal efter art. 33 og 34 gives af den dataansvarlige. Når den dataansvarlige anvender en databehandler, vil overholdelsen af disse forpligtelser ofte forudsætte bistand fra databehandleren.

Det vil normalt og bør også fremgå af databehandleraftalen, at databehandleren har pligt til at bistå den dataansvarlige med opfyldelsen af dennes forpligtelser. Som anført ovenfor er det således et krav efter art. 28, stk. 3, litra e og f, at databehandleraftalen forpligter databehandleren til at bistå den dataansvarlige med disse opgaver. Såfremt

Pligten til at overholde databehandleraftalens øvrige krav

- pligter der burde have fremgået af databehandleraftalen

parterne (i strid med forordningen) ikke har indgået en databehandler-aftale eller forsømmer at skrive ind i aftalen, at databehandleren skal bistå kunden i opfyldelsen af den registreredes rettigheder, rejser det spørgsmålet, hvorvidt de databeskyttelsesretlige regler alligevel pålægger databehandleren en bistandspligt. På den ene side kan en sådan pligt siges at ligge forudsætningsvist i forordningen, når den kræver, at pligten fremgår af databehandleraftalen. Det kan forekomme formalistisk, om retstilstanden skulle afhænge af, om bistandspligten er skrevet direkte ind som en pligt i forordningen eller skrevet indirekte ind som en pligt, der skal fremgå af databehandleraftalen, eftersom hensigten under alle omstændigheder må være at sikre, at den registrerede kan iagttage sine rettigheder, uanset om den dataansvarlige gør brug af en databehandler. På den anden side havde det været mest nærliggende at skrive pligten ind som en direkte pligt under forordningen for databehandleren, hvis det var meningen, at databehandleren skulle være selvstændigt pligtsubjekt. Det er endvidere tvivlsomt, om forordningen giver hjemmel til at sanktionere databehandleren for en manglende overholdelse af en bistandspligt, der ikke er skrevet ind i databehandleraftalen.

Efter forordningens art. 82 kan databehandleren kun ifalde erstatningsansvar, hvis databehandleren ikke har overholdt forpligtelser i forordningen, der er rettet specifikt mod databehandlere, eller hvis den pågældende har undladt at følge eller handlet i strid med den dataansvarliges lovlige instrukser.

Uagtet de sidstnævnte betragtninger må det antages, at databehandleren vil være forpligtet til at yde den bistand, der fremgår af art. 28, stk. 3, uanset om databehandleraftalen ikke måtte angive dette. Det har næppe været intentionen med forordningen at etablere en situation, hvor den registrerede ikke kan udøve sine rettigheder, fordi den dataansvarlige er afhængig af databehandlerens bistand, og databehandleren ikke er forpligtet til at yde denne bistand. Det må derfor antages, at databehandleren efter de databeskyttelsesretlige regler er forpligtet til at yde den bistand, der følger af art. 28, stk. 3, uanset om dette ikke måtte fremgå af databehandleraftalen.

Kan den dataansvarlige afgive en efterfølgende instruks om bistand? I så fald opstår problemstillingen ikke, og afsnittet skal udgå

Den dataansvarlige er forordningens primære pligtsubjekt og underlagt alle de forpligtelser, der følger af forordningen, uanset om behandlingen varetages af den dataansvarlige selv eller gennem en databehandler. Det samme gælder ikke for databehandleren. Det er således eksempelvis ikke databehandlerens ansvar, om behandlingen overholder de grundlæggende principper i art. 5, eller om der eksisterer et behandlingsgrundlag efter art. 6. Det er den dataansvarlige som gennem sin instruks til databehandleren må sikre, at behandlingen er lovlig, og databehandleren kan som udgangspunkt forudsætte, at behandlingen vil være lovlig, hvis databehandleren følger instruksen. Databehandleren er imidlertid gjort til selvstændigt pligtsubjekt i nogle af forordningens bestemmelser. Dette gælder eksempelvis pligten til at iagttage sikkerhedsforanstaltninger efter art. 32 og formentlig også pligten til at overholde kravene til tredjelandsoverførsler efter forordningens kap. V.

Pligten til at overholde krav, der følger direkte af forordningen

Det følger af art. 44, at tredjelandsoverførsler kun må finde sted, hvis betingelserne i kap. V opfyldes af den dataansvarlige og databehandleren.

Konsekvensen af, at databehandleren er selvstændigt pligtsubjekt, er, at databehandleren er forpligtet til selv at vurdere og sikre, at behandlingen opfylder kravene i den pågældende regel. Databehandleren må således selv sikre at iværksætte de fornødne sikkerhedsforanstaltninger efter art. 32 og kan ikke blot forlade sig på den dataansvarliges eventuelle instrukser om sikkerhedsforanstaltninger. Overholder databehandleren ikke kravene efter art. 32 (eller en anden bestemmelse hvor databehandleren er selvstændigt pligtsubjekt), kan databehandleren potentielt både ifalde erstatningsansvar efter art. 82 og bødeansvar efter art. 83/DBL § 41 for den selvstændige overtrædelse af bestemmelsen, jf. afsnit 5.6 nedenfor.

5.4. Databehandlerens brug af underdatabehandlere

Ligesom den dataansvarlige kan ønske at lade sin behandling af personoplysninger varetage af en databehandler, kan databehandleren ønske at en del af dennes behandling på vegne af den dataansvarlige varetages af en anden databehandler (en underdatabehandler) på vegne

af den oprindelige databehandler. Et eksempel herpå er en it-driftsleverandør, der anvender en af de store cloudtjenester (AWS, Azure m.fl.) som underleverandør og dermed underdatabehandler.

Begrebet “underdatabehandler” er fast indarbejdet men anvendes ikke i forordningen, der i stedet anvender betegnelserne “oprindelig databehandler” og “anden databehandler” (hvor sidstnævnte er underdatabehandleren).

Det følger af art. 28, stk. 2, at en databehandler kun må anvende en underdatabehandler med tilladelse fra den dataansvarlige. Bestemmelsen har følgende ordlyd:

Krav om tilladelse fra den dataansvarlige

Databehandleren må ikke gøre brug af en anden databehandler uden forudgående specifik eller generel skriftligt godkendelse fra den dataansvarlige. I tilfælde af generel skriftlig godkendelse skal databehandleren underrette den dataansvarlige om eventuelle planlagte ændringer vedrørende tilføjelse eller erstatning af andre databehandlere og derved give den dataansvarlige mulighed for at gøre indsigelse mod sådanne ændringer.

Kravet om godkendelse fra den dataansvarlige afspejler, at den dataansvarlige har det overordnede ansvar for, at alle behandlinger er lovlige. Som led heri skal den dataansvarlige bl.a. sikre kun at bruge databehandlere, der overholder forordningen, jf. om dette krav ovenfor. Det passer dårligt med princippet om den dataansvarliges overordnede ansvar, som bl.a. også kommer til udtryk i art. 5, stk. 2, og hele tanken om “ansvarlighed”, hvis en databehandler kunne vælge en hvilken som helst underdatabehandler, uden at den dataansvarlige havde nogen kontrol hermed.

Som det fremgår af bestemmelsen, kan den dataansvarlige enten kræve at skulle godkende hver enkelte underdatabehandler eller give databehandleren en generel skriftlig godkendelse til at bruge underdatabehandlere. For at sikre, at den dataansvarlige fortsat har en overordnet kontrol med behandlingen, skal databehandleren i sidstnævnte tilfælde orientere den dataansvarlige om eventuelle tilføjelser eller udskiftninger af underdatabehandlere. Heri ligger også, at databehandleren indledningsvist skal oplyse den dataansvarlige om de underdatabehandlere, der forventes anvendt. Det fremgår af bestemmelsen, at den

dataansvarlige kan gøre indsigelse mod en planlagt underdatabehandler. Bestemmelsen angiver ikke, hvad retsvirkningen af en sådan indsigelse er, men meningen må være, at databehandleren i så fald må undlade at anvende den pågældende underdatabehandler. Det kan ikke udelukkes, at parterne kontraktuelt kan aftale, at den dataansvarlige i denne situation skal kompensere databehandleren for eventuelle omkostninger forbundet med afvisningen af underdatabehandleren. Det vil dog formentlig være i strid med art. 28, hvis den dataansvarlige skal betale et prohibitivt stort beløb, da dette i praksis kan indebære, at den dataansvarliges indsigelsesret bliver illusorisk.

Mens art. 28, stk. 2, fastslår, at brugen af underdatabehandlere skal godkendes af den dataansvarlige, følger det af art. 28, stk. 4, at der skal indgås en underdatabehandleraftale mellem databehandleren og underdatabehandleren. Bestemmelsen har følgende ordlyd:

Krav om underdatabehandleraftale

Gør en databehandler brug af en anden databehandler i forbindelse med udførelse af specifikke behandlingsaktiviteter på vegne af den dataansvarlige, pålægges denne anden databehandler de samme databeskyttelsesforpligtelser som dem, der er fastsat i kontrakten eller et andet retligt dokument mellem den dataansvarlige og databehandleren som omhandlet i stk. 3, gennem en kontrakt eller et andet retligt dokument i henhold til EU-retten eller medlemsstaternes nationale ret, hvorved der navnlig stilles de fornødne garantier for, at de vil gennemføre de passende tekniske og organisatoriske foranstaltninger på en sådan måde, at behandlingen opfylder kravene i denne forordning. Hvis denne anden databehandler ikke opfylder sine databeskyttelsesforpligtelser, forbliver den oprindelige databehandler fuldt ansvarlig over for den dataansvarlige for opfyldelsen af denne anden databehandlers forpligtelser.

Det følger af bestemmelsen, at databehandleren skal indgå en aftale med underdatabehandleren, der pålægger denne de samme forpligtelser, som databehandleren er pålagt overfor den dataansvarlige efter databehandleraftalen mellem disse to parter. Kravene til indholdet af en underdatabehandleraftale er i det hele identiske med de krav til databehandleraftalen, der følger af art. 28, stk. 3, jf. herom ovenfor.

Udover kravet om en underdatabehandleraftale, regulerer art. 28, stk. 4, også databehandlerens ansvar for underdatabehandleren. Det følger således af bestemmelsens sidste punktum, at den dataansvarlige er "fuldt ansvarlig" over for den dataansvarlige for opfyldelsen af un-

Databehandlerens ansvar for underdatabehandleren

derdatabehandlerens forpligtelser. Databehandleren identificeres således med underdatabehandleren og underlægges samme ansvar for underdatabehandlerens manglende overholdelse af sine forpligtelser, som databehandleren er underlagt over for den dataansvarlige, når databehandleren misligholder sine egne forpligtelser, jf. nærmere om dette ansvar straks nedenfor.

Underdatabehandleren vil i nogle tilfælde gøre brug af yderligere underdatabehandlere, således at der opstår en hel kæde af databehandlere. I forholdet mellem underdatabehandleren og underunderdatabehandleren gælder samme krav, som mellem databehandleren og underdatabehandleren. Underdatabehandleren skal således indgå en (under)underdatabehandleraftale med sin underdatabehandler og i det hele taget iagttage de krav, der følger af art. 28, stk. 2 og 4. Dette gælder for alle led i databehandlerkæden.

Kæde af databehandlere

5.5. Den dataansvarliges kontrol med databehandleren

Som nærmere beskrevet i kap. 8 hviler forordningen på et ansvarlighedsprincip, der bl.a., indebærer, at den dataansvarlige både forudgående og løbende skal vurdere og kontrollere, at behandlingen af personoplysninger opfylder forordningens krav. Det er tilsvarende i god tråd med ansvarlighedsprincippet, at den dataansvarlige i sit valg af databehandler skal sikre, at den pågældende er i stand til at overholde forordningen og løbende kontrollerer, at dette også sker.

Pligten til forudgående kontrol af databehandleren følger direkte af art. 28, stk. 2, jf. ovenfor, hvorimod hverken art. 28 eller andre bestemmelser i forordningen indeholder en eksplicit pligt for den dataansvarlige til løbende at kontrollere databehandlerens overholdelse af forordningen. Det følger af art. 28, stk. 2, litra h, databehandleraftalen skal forpligte databehandleren til at give den dataansvarlige mulighed for at foretage revisioner (audits), herunder inspektioner, hos databehandleren og bidrage til sådanne revisioner. Bestemmelsen kan muligvis tages til indtægt for en implicit forudsætning om, at den dataansvarlige kontrollerer databehandleren, men den indeholder ikke et eksplicit krav herom. Ikke desto mindre er det fast antaget, at dataansvarlige har en pligt til at føre en passende kontrol med sine databehandlere, bl.a. under hensyntagen til det generelle princip om ansvarlighed i art.

Pligten til løbende kontrol

5, stk. 2, der indebærer, at den dataansvarlige er ansvarlig for og (løbende) skal kunne påvise, at de generelle principper i art. 5, stk. 1 – og dermed lovligheden af behandlingen – overholdes. Dette er også lagt til grund i Datatilsynets praksis og vejledninger, se eksempelvis tilsynets vejledning om tilsyn med databehandlere, s. 3. Af vejledningen følger imidlertid også, at der kan være situationer, hvor den dataansvarlige ikke behøver føre kontrol med databehandleren, fordi behandlingen har en sådan karakter, at risikoen for de registreredes rettigheder er meget begrænset. Det gælder ifølge vejledningen, når behandlingen højst vedrører 10.000 registrerede, der ikke behandles følsomme eller fortrolige personoplysninger, og der ikke foretages mere indgribende former for behandling (som eksempelvis systematisk overvågning, profilering og afgørelser alene baseret på automatisk behandling).

Den dataansvarlige skal først og fremmest føre tilsyn med, om databehandleren overholder sine forpligtelser efter databehandleraftalen, men kontrollen skal overordnet give den dataansvarlige tilstrækkelig sikkerhed for, at behandlingen af personoplysninger hos databehandleren sker inden for forordningens rammer. Dette vil dog normalt også være tilfældet, hvis databehandleren overholder sine forpligtelser efter databehandleraftalen, som bl.a. kræver, at databehandleren alene behandler oplysningerne efter den dataansvarliges instruks.

Kontrollen med databehandleren kan antage mange forskellige former. I den ene af spektret modtager den dataansvarlige blot en bekræftelse på, at databehandleren efterlever databehandleren. I den anden ende gennemfører den dataansvarlige en omfattende kontrol af databehandlerens systemer, eventuelt baseret på fysisk fremmøde hos databehandleren. Da forordningen som nævnt ikke indeholder nogen eksPLICIT regulering af den dataansvarliges kontrolpligt, kan det være vanskeligt for dataansvarlige at vide mere præcist, hvor intensiv en kontrol, der skal gennemføres for at overholde forordningen. For at bidrage til en større afklaring, har Datatilsynet opstillet en vejledende model for tilsyn (kontrol) med databehandlere i den ovenfor nævnte vejledning om tilsyn med databehandlere. I modellen tildeles databehandlerens behandling af personoplysninger et samlet pointtal fra 1-10. Pointtallet afgøres af antallet af registrerede, typen af personoplysninger (almindelige, følsomme, fortrolige) og om der foretages mere indgribende

Kontrollens
indhold og form

– Datatilsynets
kontrolmodel

former for behandling (f.eks. systematisk overvågning eller profilering). Modellen opererer med seks tilsynskoncepter afhængigt af, hvilket pointtal behandlingen opnår. Efter koncept 1 skal den dataansvarlige kun reagerer ved kendskab til, at der er noget galt hos databehandleren. I denne situation består med andre ord ikke en kontrolpligt (det er den ovenfor beskrevne situation, hvor der ikke er mere end 10.000 registrerede, ingen følsomme eller fortrolige oplysninger og ingen behandling af mere indgribende karakter). Efter koncept 2 skal databehandleren bekræfter overfor den dataansvarlige, at alle krav i databehandleraftalen fortsat efterleves. Efter koncept 3 giver databehandleren en årlig skriftlig status på forhold, der er omfattet af databehandleraftalen, og andre relevante områder (f.eks. organisatoriske eller produktmæssige ændringer). Efter koncept 4 har databehandleren en relevant og opdateret certificering eller følger et adfærdskodeks, som er relevant for behandlingsaktiviteterne. Efter koncept 5 har en uafhængig tredjepart ført et dokumenteret tilsyn med databehandleren på et område, der dækker de konkrete behandlingsaktiviteter. Efter koncept 6 fører den dataansvarlige selv, eller sammen med andre, et dokumenteret tilsyn med databehandleren. Selv i de situationer, hvor behandlingen opnår det højeste pointtal (10), kan den dataansvarlige vælge mellem koncept 5 og 6. Dette indebærer, at den dataansvarlige ikke behøver føre sit eget tilsyn, hvis databehandleren har fået en uafhængig tredjepart til at føre en dokumenteret tilsyn, der dækker behandlingen. Dette har bl.a. stor praktisk betydning, når den dataansvarlige bruger en cloududbyder, hvor det i praksis kan være meget vanskeligt for den dataansvarlige at gennemføre sin egen kontrol.

For en nærmere gennemgang af pointmodellen og koncepterne henvises til vejledningen, der også rummer en række eksempler på anvendelsen af de enkelte koncepter.

Det vil bero på en konkret vurdering, hvor ofte den dataansvarlige skal føre kontrol med databehandleren. I Datatilsynets vejledning om tilsyn med databehandlere angives (s. 22), at det i nogle tilfælde kan være nødvendigt med et årligt tilsyn, mens det i andre tilfælde kan være tilstrækkeligt med en lavere frekvens af tilsyn. Afgørende er, hvor stor risiko der er forbundet med behandlingen. I vejledningen angives som eksempler på begivenheder, der taler for en høj tilsynsfrekvens, at

Hvor ofte skal der føres kontrol?

databehandleren har haft problemer med at overholde aftaler, at databehandleren har oplevet flere alvorlige sikkerhedsbrud, at der ofte skiftes underdatabehandler(e) og, at der ofte sker ejerskifte, opkøb, fusion eller gennemgribende ændringer i strategien hos databehandleren.

5.6. Databehandlerens misligholdelse af sine forpligtelser

Som beskrevet ovenfor kan databehandlerens forpligtelser inddeles i 1) pligten til at behandle personoplysningerne i overensstemmelse med den dataansvarliges instruks, 2) pligten til at overholde databehandleraftalens øvrige krav og 3) pligten til at overholde de særskilte krav til databehandlere, der følger af direkte af forordningen.

Databehandlerens overtrædelse af disse forpligtelser kan medføre forskellige typer af sanktioner.

Efter art. 82, stk. 2, bliver databehandleren erstatningsansvarlig for registreredes tab, når databehandleren handler i strid med den dataansvarliges instruks eller overtræder de bestemmelser i forordningen, hvor databehandleren er særskilt pligtssubjekt. Såfremt de registrerede rejser kravet mod den dataansvarlige, kan denne søge regres hos databehandleren, jf. art. 82, stk. 4. Selvom art. 82, stk. 1, indledes med ordene “[E]nhver, som har lidt materiel eller immateriel skade ...” (fremhævet her), kan det ikke antages, at art. 82 regulerer den dataansvarliges krav på erstatning for egne tab forvoldt ved databehandlerens misligholdelse af sine forpligtelser. Sådanne krav må i stedet afgøres af parternes aftale og nationale regler om kontraktuelt erstatningsansvar.

Databehandlerens
erstatningsansvar

Se nærmere om erstatningsansvaret efter art. 82 og den dataansvarliges hæftelsesansvar for databehandleren kap. 11.1

Databehandleren kan ifalde et bødeansvar efter art. 83 for en overtrædelse af de bestemmelser i forordningen, hvor databehandleren er selvstændigt pligtssubjekt. Som nærmere beskrevet i kap. 11.3, finder art. 83 ikke anvendelse i Danmark. I stedet udgøres hjemmelen til at pålægge bøde af DBL § 41. Det gælder tilsvarende efter § 41, at databehandleren kan idømmes en bøde for en overtrædelse af de selvstændige forpligtelser, forordningen pålægger databehandlere. Som beskrevet ovenfor er art. 28 konstrueret sådan, at den pålægger den dataansvarlige at indgå en databehandleraftale, som pålægger databehand-

Databehandlerens
strafansvar

leren forskellige forpligtelser, herunder eksempelvis at bistå den dataansvarlige i dennes opfyldelse af de registrerede rettigheder. Da disse forpligtelser ikke følger direkte af art. 28 men forudsættes indført i databehandleraftalen, vil databehandleren næppe kunne ifalde strafansvar for ikke at overholde forpligtelserne. DBL § 41 foreskriver, at databehandleren kan ifalde bødestraf for at overtræde (bl.a.) art. 28, hvorimod § 41 ikke angiver manglende overholdelse af databehandleraftalen som en bødeudløsende begivenhed.

Hvis databehandleren behandler personoplysningerne i egen interesse og således ikke længere varetager den dataansvarliges interesser, kan databehandleren potentielt blive selvstændig dataansvarlig for den pågældende behandling. Dette følger af art. 28, stk. 10, der har følgende ordlyd:

Databehandlerens ansvar som selvstændig dataansvarlig

Hvis en databehandler overtræder denne forordning ved at fastlægge formålene med og hjælpemidlerne til behandling, anses databehandleren for at være en dataansvarlig for så vidt angår den pågældende behandling, uden at dette berører artikel 82, 83 og 84

Det afgørende er således, om databehandleren selv fastlægger formålene med og hjælpemidlerne til behandlingen. Er dette tilfældet ændrer databehandleren status til dataansvarlig for den pågældende behandling. Konsekvensen af dette er, at databehandleren (der altså nu er dataansvarlig) skal iagttage alle forordningens krav og bliver selvstændigt pligtsubjekt. Har den pågældende behandling eksempelvis ikke hjemmel i art. 6, vil databehandleren ifalde et selvstændigt ansvar for en overtrædelse af bestemmelsen. Spørgsmålet om, hvorvidt databehandleren har overskredet sine grænser som databehandler og som følge heraf skal ifalde et selvstændigt ansvar som dataansvarlig, har en naturlig sammenhæng med de grænser for behandlingen, der fastsættes med den dataansvarliges instruks. I praksis vil databehandleren altid have handlet i strid med instruks fra den dataansvarlige, når databehandleren selv fastsætter formål og hjælpemidler. Det modsatte gør sig imidlertid ikke ubetinget gældende. Den omstændighed, at databehandleren har handlet i strid med instruks, indebærer ikke nødvendigvis, at databehandleren kan siges at have fastlagt formål og hjælpemidler med behandlingen og dermed bliver dataansvarlig efter art. 28, stk. 10. Datatilsynets praksis kan dog muligvis tages til indtægt

for det modsatte synspunkt, således at databehandleren næsten pr. automatik bliver dataansvarlig ved en overskridelse af instruks.

I sag nr. 2022-431-0167 afviste en underdatabehandler at udlevere personoplysninger til den dataansvarlige under henvisning til, at underdatabehandleren alene havde en kontrakt med databehandleren og alene var forpligtet til at følge instrukser fra denne. Datatilsynet fastslog, at også en underdatabehandler skulle følge instruksen fra den dataansvarlige, og at underdatabehandleren derfor ikke havde været berettiget til at nægte udleveringen til den dataansvarlige. Datatilsynet anførte videre, at det var tilsynets opfattelse, "at en databehandler der handler uden for den dataansvarliges instruks, bliver selvstændigt dataansvarlig for behandlingen. Datatilsynet finder således, at databehandler b som underdatabehandler – ved ikke at imødekomme den dataansvarliges anmodning om at tilbagelevere X's kundedata – selv har fastlagt formålet med behandlingen og derved også er selvstændig dataansvarlig for den fortsatte opbevaring af X's kundeoplysninger."

I sag nr. 2019-442-3996 havde en underdatabehandler som led i udvikling, vedligehold og drift af et it-system anvendt en underunderdatabehandler, der leveres en softwarekomponent til løsningen som en cloudydelse. Underdatabehandlerens brug af andre underdatabehandlere skulle godkendes af databehandleren, hvilket ikke var sket, idet underunderdatabehandleren ikke var opført på listen over de underunderdatabehandlere, som underdatabehandleren anvendte. Underdatabehandleren gjorde gældende, at dette var en ren forglemmelse, idet det fremgik af tilbudsmaterialet, at den pågældende underunderdatabehandler ville blive anvendt. Datatilsynet lagde til grund, at underunderdatabehandleren ikke var godkendt, sådan som databehandleraftalen krævede, og at underdatabehandleren derfor havde handlet uden for instruks ved at videregive personoplysninger til underunderdatabehandleren. Datatilsynet anførte herefter, at det "således [er] Datatilsynets vurdering, at EG [underdatabehandleren] ved selv at fastlægge formålet med behandlingen er dataansvarlig for videregivelsen af personoplysningerne, jf. databeskyttelsesforordningens artikel 28, stk. 10.

Det kan dog ikke antages at have været hensigten med art. 28, stk. 10, at enhver overskridelse af instruksen skal indebære, at databehandleren bliver dataansvarlig. En instruks kan være detaljeret, og det forekommer uproportionalt, hvis selv små og uforsætlige overtrædelser af den altid skulle indebære, at databehandleren skal pålægges ansvar

som selvstændig dataansvarlig. Havde det været tanken, må det forventes, at art. 28, stk. 10, simpelthen havde anført, at en overtrædelse af instruksen havde denne konsekvens. Kravet synes at være skærpet, når bestemmelsen forudsætter, at databehandleren skal have fastlagt eget formål med og hjælpemidler for behandlingen. At en overtrædelse af instruksen ikke nødvendigvis indebærer, at databehandleren bliver dataansvarlig, følger også af erstatningsbestemmelsen i art. 82. Som beskrevet ovenfor angiver art. 82, stk. 2, at databehandleren kan ifalde erstatningsansvar (som databehandler), hvis databehandleren handler i strid med instruksen. Hvis databehandleren automatisk blev dataansvarlig ved overskridelse af instruksen, ville det savne mening at indsætte en særlig bestemmelse om *databehandlerens* erstatningsansvar i denne situation. Ikke desto mindre viser de to afgørelser, at en databehandler – i hvert fald efter tilsynspraksis – ganske ofte vil blive selvstændig dataansvarlig ved en manglende overholdelse af instruksen. Det er dog muligt, at denne praksis går for langt. Der foreligger ingen domstolsafgørelser om spørgsmålet.

6. Forpligtelser og ansvar for fælles dataansvarlige

Som nærmere beskrevet i afsnit 2 kan flere parter i nogle tilfælde blive fælles dataansvarlige, når de sammen bestemmer formålet med behandlingen og fastlægger hjælpemidlerne. Forordningen indeholder i art. 26 en regulering af fælles dataansvarliges forpligtelser. Bestemmelsen har følgende ordlyd:

1. Hvis to eller flere dataansvarlige i fællesskab fastlægger formålene med og hjælpemidlerne til behandling, er de fælles dataansvarlige. De fastlægger på en gennemsigtig måde deres respektive ansvar for overholdelse af forpligtelserne i henhold til denne forordning, navnlig hvad angår udøvelse af den registreredes rettigheder og deres respektive forpligtelser til at fremlægge de oplysninger, der er omhandlet i artikel 13 og 14, ved hjælp af en ordning mellem dem, medmindre og i det omfang de dataansvarliges respektive ansvar er fastlagt i EU-ret eller medlemsstaternes nationale ret, som de dataansvarlige er underlagt. I ordningen kan der udpeges et kontaktpunkt for registrerede.

2. Ordningen, der er omhandlet i stk. 1, skal på behørig vis afspejle de fælles dataansvarliges respektive roller og forhold til de registrerede. Det væsentligste indhold af ordningen skal gøres tilgængeligt for de registrerede.

3. Uanset udformningen af den ordning, der er omhandlet i stk. 1, kan den registrerede udøve sine rettigheder i medfør af denne forordning med hensyn til og over for den enkelte dataansvarlige.

Konsekvensen af et fælles dataansvar er navnlig, at de dataansvarlige er forpligtet til at etablere en ordning, der på en gennemsigelig måde fastlægger deres respektive forpligtelser, således at det sikres, at de dataansvarlige tilsammen sikrer overholdelsen af alle forordningens krav, herunder oplysningspligten og de registreredes øvrige rettigheder. Der må med andre ord ikke "falde noget mellem stolene". Omvendt indebærer det fælles dataansvar ikke, at begge de dataansvarlige nødvendigvis hver især skal iagttage alle forpligtelserne, når blot de sikrer, at én af dem gør det. Der er selvsagt ikke grund til, at begge de dataansvarlige giver den registrerede de samme oplysninger med henblik på at opfylde oplysningsforpligtelsen efter art. 13 eller 14. I praksis vil kravet om etablering af en ordning oftest opfyldes ved udarbejdelse af en aftale om fælles dataansvar, der nærmere fastlægger den indbyrdes fordeling af forpligtelser og opgaver mellem parterne.

De dataansvarliges fordeling af forpligtelser – ordning (aftale) om fælles dataansvar

Datatilsynet har udarbejdet en skabelon til en aftale om fælles dataansvar.

Det følger af art. 26, stk. 2, at det væsentligste indhold af ordningen skal gøres tilgængeligt for de registrerede. Der er ingen formkrav til tilgængeliggørelsen, men i praksis betyder det, at ordningen normalt må udformes skriftligt og hensigtsmæssigt kan gøres tilgængelig via en hjemmeside.

Tilgængeliggørelse for de registrerede

Uanset at de dataansvarlige kan aftale mellem sig, hvordan de sikrer overholdelse af forordningens krav, følger det af art. 26, stk. 3, at den registrerede kan udøve sine rettigheder over for begge (alle) de fælles dataansvarlige. En dataansvarlig kan således ikke afvise at give indsigt i oplysninger efter art. 13 eller 14 med henvisning til, at det er den anden fælles dataansvarlige, der ligger inde med oplysningerne.

Ansvar for overholdelse af de registreredes rettigheder

På tilsvarende vis som de dataansvarlige begge er forpligtet til at sikre overholdelse af den registreredes rettigheder, vil de begge være erstatningsansvarlige overfor den registrerede. Det må således antages, at fælles dataansvarlige hæfter objektivt og solidarisk for hinandens ansvarspådragende adfærd efter forordningens art. 82, jf. nærmere herom kap. 11.1. Derimod vil en dataansvarlig som udgangspunkt ikke kunne ifalde bødeansvar for en anden dataansvarligs overtrædelse af forordningen, da der ikke gælder et objektivt hæftelsesansvar i straffetretten, jf. nærmere kap. 11.3.

Erstatnings- og
strafansvar

Kapitel 4

De grundlæggende behandlingsprincipper

Forordningens art. 5, indeholder i stk. 1, litra a-f, en række grundlæggende principper for behandlingen af personoplysninger. Bestemmelsen har følgende ordlyd (forordningstekstens betegnelser for de enkelte principper er fremhævet her):

1. Personoplysninger skal:

- a) behandles lovligt, rimeligt og på en gennemsigtig måde i forhold til den registrerede (*»lovlighed, rimelighed og gennemsigtighed«*)
- b) indsamles til udtrykkeligt angivne og legitime formål og må ikke viderebehandles på en måde, der er uforenelig med disse formål; viderebehandling til arkivformål i samfundets interesse, til videnskabelige eller historiske forskningsformål eller til statistiske formål i overensstemmelse med artikel 89, stk. 1, skal ikke anses for at være uforenelig med de oprindelige formål (*»formålsbegrænsning«*)
- c) være tilstrækkelige, relevante og begrænset til, hvad der er nødvendigt i forhold til de formål, hvortil de behandles (*»dataminimering«*)
- d) være korrekte og om nødvendigt ajourførte; der skal tages ethvert rimeligt skridt for at sikre, at personoplysninger, der er urigtige i forhold til de formål, hvortil de behandles, straks slettes eller berigtiges (*»rigtighed«*)

- e) opbevares på en sådan måde, at det ikke er muligt at identificere de registrerede i et længere tidsrum end det, der er nødvendigt til de formål, hvortil de pågældende personoplysninger behandles; personoplysninger kan opbevares i længere tidsrum, hvis personoplysningerne alene behandles til arkivformål i samfundets interesse, til videnskabelige eller historiske forskningsformål eller til statistiske formål i overensstemmelse med artikel 89, stk. 1, under forudsætning af, at der implementeres passende tekniske og organisatoriske foranstaltninger, som denne forordning kræver for at sikre den registreredes rettigheder og frihedsrettigheder (*»opbevaringsbegrænsning«*)
- f) behandles på en måde, der sikrer tilstrækkelig sikkerhed for de pågældende personoplysninger, herunder beskyttelse mod uautoriseret eller ulovlig behandling og mod hændeligt tab, tilintetgørelse eller beskadigelse, under anvendelse af passende tekniske eller organisatoriske foranstaltninger (*»integritet og fortrolighed«*).

2. Den dataansvarlige er ansvarlig for og skal kunne påvise, at stk. 1 overholdes (*»ansvarlighed«*).

Disse principper udgør en hjørnesten i databeskyttelsesretten og vil ofte være centrale for vurderingen af en behandlings lovlighed. Hovedparten af principperne var allerede en del af 108-konventionen fra 1981 og er i det væsentlige en videreførelse fra persondatadirektivet. I betænkning 1565/2017 antages således også, at reglerne ikke indebærer en ændring af retstilstanden fra før forordningen (dog nok med en pligt til hurtigere sletning, jf. nærmere nedenfor), s. 101. Praksis efter de tidligere regler vil derfor også fortsat have relevans.

Principperne er bredt formuleret, hvilket på den ene side gør dem rummelige og fleksible, men på den anden side også gør det vanskeligt at fastlægge deres præcise indhold. Dette er ikke helt uproblematisk i lyset af, at en overtrædelse af art. 5 er bødebelagt efter DBL § 41, stk. 1, nr. 4.

Principperne i art. 5 skal altid iagttages og gælder ved siden af kravene til behandlingsgrundlag efter art. 6 ff. (se nærmere om disse krav kapitel 5 nedenfor). Principperne kan ikke fraviges ved aftale, og det er således ikke muligt at indhente et gyldigt samtykke fra den registre-

rede til en fravigelse (med en enkelt undtagelse vedrørende princippet om formålsbestemthed, der omtales nedenfor).

1. Lovlighed, rimelighed og gennemsigtighed

Efter art. 5, stk. 1, litra a, skal oplysninger behandles “lovligt, rimeligt og på en gennemsigtig måde i forhold til den registrerede”. Med bestemmelsen indføres en bred retlig standard, der ikke har noget stort selvstændigt anvendelsesområde, men som i enkeltstående tilfælde gør det muligt at fastlægge krav til behandlingen, som ikke umiddelbart følger af forordningens mere specifikke krav.

Art. 5, stk. 1, litra a

Den tilsvarende bestemmelse i persondatadirektivet var i persondataloven implementeret ved en bestemmelse om “god databehandlings-skik”. Denne bestemmelse er ikke længere gældende, men man støder stadig på begrebet “god databehandlings-skik” som udtryk for de krav, der følger af art. 5, stk. 1, litra a.

Datatilsynet har truffet en række afgørelser, der pålægger den data-ansvarlige en pligt efter bestemmelsen, herunder bl.a. en pligt til at informere om sikkerhedsbrud efter de tidligere regler, der ikke indeholdt en eksplicit bestemmelse herom (informationspligten følger nu af forordningens art. 33 og 34). Se også om tilsynets praksis Korfits Nielsen & Lotterup, Databeskyttelsesforordningen og databeskyttelsesloven, 2020, s. 314 ff. EU-Domstolen har i sag C-201/14 (Bara) fastslået, at princippet om rimeligheden indebærer, at offentlige myndigheder skal informere den registrerede, når personoplysninger videregives til en anden offentlig myndighed.

Det var tidligere antaget, at princippet om rimelighed også indeholdt et princip om gennemsigtighed, jf. de Terwagne i Kuner m.fl. (red.), GDPR com, s. 314 med henvisninger. Med forordningen er gennemsigtighedsprincippet eksplicit angivet. Det bør være gennemsigtigt for de pågældende fysiske personer, at personoplysninger, der vedrører dem, indsamles, anvendes, tilgås eller på anden vis behandles, og i hvilket omfang personoplysningerne behandles eller vil blive behandlet. Princippet skal give den registrerede en reel mulighed for at gennemskue, hvilken behandling, der finder sted og er hermed beslægtet

Gennemsigtighed

med reglerne om oplysningspligt og indsigtsret og princippet om ansvarlighed, der nærmere gennemgås nedenfor. Princippet om gennemsigtighed er omtalt i præambelbetragtning 39:

[...] Princippet om gennemsigtighed tilsiger, at enhver information og kommunikation vedrørende behandling af disse personoplysninger er lettilgængelig og letforståelig, og at der benyttes et klart og enkelt sprog. Dette princip vedrører navnlig oplysningen til de registrerede om den dataansvarliges identitet og formålene med den pågældende behandling samt yderligere oplysninger for at sikre en rimelig og gennemsigtig behandling for de berørte fysiske personer og deres ret til at få bekræftelse og meddelelse om de personoplysninger vedrørende dem, der behandles [...]

2. Formålsbegrænsning

Det følger af art. 5, stk. 1, litra b, at personoplysninger skal “indsamles til udtrykkeligt angivne og legitime formål og ikke må viderebehandles på en måde, der er uforenelig med disse formål”. Dette benævnes også princippet om formålsbestemthed eller finalité-princippet.

Art. 5, stk. 1,
litra b

Bestemmelsen består af to led, der dels fokuserer på selve indsamlingen af oplysningerne, dels fokuserer på viderebehandlingen af oplysningerne.

Når bestemmelsen bruger begrebet “viderebehandling” frem for blot “behandling” skyldes det, at selve indsamlingen også udgør en behandling i forordningens forstand.

Bestemmelsen indebærer, at den dataansvarlige i forbindelse med indsamlingen af oplysningerne skal gøre sig klart, hvad formålet med indsamlingen er. Dette formål fastlægger herefter rammerne for, hvordan oplysningerne må behandles. Ønsker den dataansvarlige at foretage en behandling af oplysningerne uden for disse rammer, vil det være nødvendigt enten at foretage en ny indsamling af de samme oplysninger til dette nye formål, eller at indhente den registreredes samtykke til, at oplysningerne behandles med et nyt formål. Den dataansvarlige kan således heller ikke indsamle oplysninger med henblik på en fremtidig men endnu ikke fastlagt brug, der ikke fremgår af formålet.

Indsamling

Kravet om, at formålene skal være “udtrykkeligt” angivne, indebærer, at formålet skal angives med en vis præcision. Kortfits Nielsen & Lotterup anfører med eksempler hentet fra forarbejderne til den tidligere persondatalov, at eksempelvis “til administrative formål” eller “til brug for kommercielle formål” ikke vil være tilstrækkeligt, hvorimod “til brug for udbud af finansielle ydelser” må anses for tilstrækkeligt præcist og dermed “udtrykkeligt”, Databeskyttelsesloven og databeskyttelsesforordningen, s. 318. I i WP29 203, Opinion 03/2013 on purpose limitation, s. 16, angives som eksempler på formålsbeskrivelser, der ikke er tilstrækkeligt tydelige “improving users’ experience”, “marketing purposes”, “IT security purposes” og “future research”.

– udtrykkeligt

Udtrykkelighedskravet indebærer ikke, at formålet skal nedfældes skriftligt eller i øvrigt er undergivet formkrav. Da den dataansvarlige skal oplyse den registrerede om formålet med behandlingen, vil det dog i praksis ofte forudsætte, at formålet formuleres skriftligt. Dette kan også være hensigtsmæssigt, fordi den dataansvarlige skal kunne dokumentere at overholde de generelle principper efter art. 5, jf. art. 5, stk. 2.

Det er endvidere et krav, at formålet er “legitimt” (i den engelsksprogede version “legitimate”). Dette indebærer, det ret åbenbare, at der ikke kan ske indsamling med henblik på en behandling, der vil være ulovlig efter forordningen eller anden lovgivning. Kravet om et legitimt formål går dog formentlig videre end dette. I Danmark blev den tilsvarende bestemmelse i persondatadirektivet implementeret i den tidligere persondatalov gennem et krav om, at formålet skulle være “sagligt”, og dette synes også at være opfattelsen under forordningen, hvilket også kan udtrykkes således, at formålet skal være sagligt.

– legitimt

Se således Kortfits Nielsen og Lotterup, Databeskyttelsesloven og databeskyttelsesforordningen, s. 319 og Blume, Den nye persondataret, s. 86.

Kortfits Nielsen & Lotterup anfører som afgørende, om indsamlingen sigter mod at løse opgaver, som falder inden for myndighedens eller virksomhedens kompetenceområde eller (lovlige) virksomhedsområde, Databeskyttelsesloven og databeskyttelsesforordningen, s. 319. Som nævnt kan registrerede ikke gyldigt give samtykke til en fravigelse af de grundlæggende behandlingsprincipper. Selvom der så-

ledes måtte foreligge et behandlingsgrundlag efter art. 6 i form af den registreredes samtykke, vil behandlingen ikke være lovlig, hvis den ikke tjener et sagligt formål.

Princippet om formålsbestemthed indebærer både, at selve indsamlingen af oplysningerne skal ske til det udtrykkelige og saglige formål, og at den efterfølgende behandling af oplysningerne også skal ske inden for rammerne af dette formål. Når den dataansvarlige lovligt har indsamlet oplysningerne til ét formål, kan den dataansvarlige ikke herefter bruge oplysningerne til et helt andet formål, heller ikke selv om der findes et behandlingsgrundlag til den efterfølgende behandling i art. 6.

Viderebehandling
til andre men
forenelige formål

I sin rene form ville princippet om formålsbestemthed indebære, at den dataansvarlige måtte indhente oplysningerne på ny eller indhente samtykke fra den registrerede til enhver efterfølgende behandling, der blot marginalt afveg fra det oprindelige formål. Dette kan være byrdefuldt og ressourcekrævende for den dataansvarlige og i øvrigt også anspore til at formulere bredere (og dermed mindre informative) formål. Det er heller ikke altid i den registreredes interesse at blive ulejliget med mange forespørgsler om oplysninger, fordi der ikke kan ske genbrug af oplysningerne (mange kan sikkert genkende irritationen over at blive bedt om at indtaste eller i øvrigt afgive oplysninger, som man allerede har givet til spørgeren). Bestemmelsen om formålsbegrænsning i art. 5, giver derfor også adgang til at viderebehandle oplysninger til et andet formål, når dette formål ikke er “uforenligt” med det oprindelige formål.

Det kan overvejes, om det skal tillægges nogen betydning, at bestemmelsen anvender formuleringen “ikke uforenelig” frem for blot “forenelig”. Dette kunne indikere, at bestemmelsen er tiltænkt et bredere anvendelsesområde, jf. i denne retning WP29/203, Opinion 03/2013 on purpose limitation (om den tilsvarende bestemmelse i direktivet). Omvendt anvender art. 6, stk. 4, terminologien “forenelig” i stedet for “ikke uforenelig” i beskrivelsen af, hvilke kriterier, som skal tillægges vægt ved bedømmelsen. På den baggrund kan brugen af dobbeltnegationen “ikke uforenelig” næppe tillægges nogen betydning.

Det kan være vanskeligt at afgøre, hvornår et formål er uforenligt med det oprindelige. Dette var allerede en udfordring under den tilsva-

rende bestemmelse i persondatadirektivet og med forordningen blev i art. 6, stk. 4, indført en bestemmelse, som opregner kriterier, der skal tillægges betydning ved denne vurdering.

Retssystematisk er det uheldigt, at bestemmelsen er placeret i art. 6, der regulerer behandlingsbetingelserne, frem for at være gjort til en del af art. 5. Det kan foranledige til at tro, at den relaterer sig til behandlingsbetingelserne, hvilket ikke er tilfældet.

Den relevante del af bestemmelsen har følgende ordlyd:

“[...] tager den dataansvarlige, for at afgøre, om behandling til et andet formål er forenelig med det formål, som personoplysningerne oprindeligt blev indsamlet til, bl.a. hensyn til følgende:

- a) enhver forbindelse mellem det formål, som personoplysningerne er indsamlet til, og formålet med den påtænkte viderebehandling
- b) den sammenhæng, hvori personoplysningerne er blevet indsamlet, navnlig med hensyn til forholdet mellem den registrerede og den dataansvarlige
- c) personoplysningernes art, navnlig om særlige kategorier af personoplysninger behandles, jf. artikel 9, eller om personoplysninger vedrørende straffedomme og lovovertrædelser behandles, jf. artikel 10
- d) den påtænkte viderebehandlings mulige konsekvenser for de registrerede
- e) tilstedeværelse af fornødne garantier, som kan omfatte kryptering eller pseudonymisering.”

Litra a omhandler det helt centrale kriterie, nemlig sammenhængen mellem de to formål (men giver ikke nærmere bidrag til, hvordan denne sammenhæng skal vurderes). Litra b lægger vægt på forholdet mellem den registrerede og den dataansvarlige, hvilket bl.a. kan have betydning for, hvad den registrerede kunne forvente af den videre behandling. Litra c-e omhandler ikke selve formålene men har i højere grad karakter af en slags risikoanalyse, hvor konsekvenser og risici ved viderebehandlingen skal inddrages. Bestemmelsen gøre det klart, at der skal foretages en samlet helhedsvurdering ved “forenelighedstesten”, men den efterlader stadig et meget stort rum for den konkrete fortolkning.

Kriterierne i art. 6, stk. 4, hidrører fra WP29 203, Opinion 03/2013 on purpose limitation, hvor artikel 29-gruppen identificerede dem på baggrund af national praksis. Dokumentet indeholder på s 23 ff. en nærmere beskrivelse af kriterierne og i annex 4 en række eksempler på deres anvendelse.

Det fremgår af art. 6, stk. 4, at den dataansvarlige “bl.a.” skal tage hensyn til de opregnede kriterier. Opregningen er således ikke udtømmende men omfatter dog de (overordnede) kriterier, der som regel vil være afgørende for vurderingen.

Bestemmelsen er ordret gengivet i DBL § 5, stk. 2 (som ikke har nogen selvstændig betydning).

Det databeskyttelsesretlige udgangspunkt er som angivet, at der ikke kan ske viderebehandling til uforenelige formål. I enkelte situationer er dette udgangspunkt dog fraveget.

Viderebehandling til uforenelige formål

Art. 6, stk. 4, 1. pkt., giver for det første den dataansvarlige mulighed herfor, når den registrerede giver sit samtykke. Dette er den eneste situation, hvor et af behandlingsprincipperne i art. 5 kan fraviges ved samtykke. I realiteten svarer situationen dog til en fornyet indsamling hos den registrerede, og det ville være unødigt formalistisk, hvis den registrerede skulle genfremsende oplysninger, som den dataansvarlige allerede var i besiddelse af, frem for blot at give sit samtykke til viderebehandlingen.

– samtykke fra den registrerede

Art. 6, stk. 4, 1. pkt., giver for det andet medlemsstaterne mulighed for inden for rammerne af art. 23 at vedtage nationale særregler, der fraviger kravet om, at en viderebehandling kun må ske, når den ikke er uforenlig med det oprindelige formål. Denne mulighed er udnyttet i DBL § 5 stk. 3, hvorefter en minister efter forhandling med justitsministeren i en bekendtgørelse kan fastsætte nærmere regler om, at offentlige myndigheder må viderebehandle personoplysninger til formål, der er uforenelige med det oprindelige formål. I forarbejderne til bestemmelsen nævnes som et eksempel på dens anvendelse udarbejdelsen af oversigter, der kan udsøge borgere, som modtager ydelser på tværs af flere forvaltninger. Det må antages, at bestemmelsen ikke mindst har haft potentialet ved digital forvaltning for øje, og for de gevinster, der kan opnås ved datadeling mellem offentlige myndigheder. Bestem-

– nationale særregler – DBL § 5, stk. 3

melsen gælder ikke helbredsoplysninger indsamlet med henblik på sundhedsbehandling mv. efter art. 7, stk. 3.

DBL § 5, stk. 3, var genstand for stor politisk debat i forbindelse med lovens vedtagelse. Dette skyldes, at bestemmelsen giver mulighed for at indføre omfattende adgang til datadeling mellem myndigheder, bl.a. med henblik på at kontrollere borgerne, uden at disse tiltag skal vedtages af Folketinget. For at imødegå denne kritik, er det i Folketingets Retsudvalgs betænkning af 9. maj 2018 vedrørende lovforslaget til databeskyttelsesloven forudsat af de daværende regeringspartier og Socialdemokratiet, at Datatilsynet forudgående skal udtale sig om alle betænkninger, der udstedes efter bestemmelsen. Det er endvidere anført, at partierne ønsker, at udkast til disse betænkninger skal sendes til relevante udvalg i Folketinget og Retsudvalget med henblik på en politisk drøftelse af udkastet.

Det følger af art. 5, stk. 1, litra b, at viderebehandling til arkivformål i samfundets interesse, til videnskabelige eller historiske forskningsformål eller til statistiske formål i overensstemmelse med artikel 89, stk. 1, ikke skal anses for at være uforenelig med de oprindelige formål. Det er således altid tilladt at viderebehandle til disse formål, uanset hvad det oprindelige formål var. Lovgiver kunne også have udformet dette som undtagelse til forbuddet mod viderebehandling til et uforeneligt formål men har altså i stedet valgt at fastslå, at disse formål altid vil være forenelige. Det har bl.a. den retstekniske fordel, at den dataansvarlige ikke behøver vurdere, om formålet er foreneligt (for at fastslå om behandlingen ville være omfattet af kravet om formålsbestemthed eller af undtagelsesreglen).

Viderebehandling med henblik på arkivering, forskning og statistik

Det følger af forordningens art. 13, stk. 1, litra c, og art. 14, stk. 1, litra c, at den dataansvarlige skal oplyse den registrerede om formålet med behandlingen i forbindelse med indsamlingen. Såfremt den dataansvarlige viderebehandler oplysningerne til et andet men foreneligt formål, skal dette nye formål også oplyses til den registrerede i forbindelse med viderebehandlingen, jf. art. 13, stk. 2, og art. 14, stk. 2. Hvis en offentlig myndighed har fået hjemmel til at foretage viderebehandling med et formål, der er uforeneligt med det oprindelige, efter DBL § 5, stk. 3, skal denne viderebehandling derimod ikke oplyses til borgeren, medmindre formålet er sammenstilling eller samkøring i kon-

Oplysningspligt

troløjemed, jf. DBL § 23. Se også nærmere om oplysningspligten kap. 6.1 nedenfor.

3. Dataminimering

Efter art. 5, stk. 1, litra c, skal personoplysninger være “tilstrækkelige, relevante og begrænset til, hvad der er nødvendigt i forhold til de formål, hvortil de behandles”. Dette benævnes også princippet om dataminimering. Princippet om dataminimering skal bidrage til at undgå unødigt dataophobning med deraf følgende øget risiko for kompromitering og anden form for misbrug af oplysningerne.

Art. 5, stk. 1, litra c

Selvom princippet således har fokus på at begrænse omfanget af personoplysninger, tilsiger det indledende krav om, at personoplysningerne skal være tilstrækkelige, at der ikke indsamles og behandles for få personoplysninger. Kravet har nær tilknytning til princippet om rigtighed i litra d og skal sikre, at der ikke bliver truffet forkerte afgørelser som følge af et utilstrækkeligt oplysningsgrundlag.

Tilstrækkelige

Kravet om, at personoplysninger skal være relevante, kan ligeledes siges at have et slægtskab med princippet om rigtighed, da inddragelse af irrelevante oplysninger kan bidrage til, at der træffes en forkert afgørelse. Kravet udtrykker dog i endnu højere grad princippet om dataminimering og ønsket om at begrænse omfanget af indsamling og behandling af personoplysninger. Uanset om en irrelevant oplysninger ikke inddrages i sagsbehandling eller i øvrigt ikke medfører et forkert resultat, bør den ikke indhentes og opbevares, når den ikke er relevant for behandlingsformålet.

Relevante

Som det tredje led i bestemmelsen kræves, at oplysningerne skal være nødvendige for at opfylde de formål, der legitimerer behandlingen. Kan formålet opnås uden behandling af den pågældende type oplysninger, må behandlingen ikke ske. Bestemmelsen om dataminimering har herved nær tilknytning til bestemmelsen i litra b om formålsbestemthed. Princippet har endvidere tilknytning til princippet om opbevaringsbegrænsning i litra e, da oplysningerne skal slettes, hvis de oprindeligt var nødvendige for at opfylde formålet men ikke længere er det. Kraven om relevans og nødvendighed for at opfylde formålet vil ofte være overlappende. Hvis en oplysning ikke er relevant, vil den heller ikke være nødvendig for at opfylde formålet. Om-

Nødvendige for at opfylde formålet

vendt kan en oplysning i princippet godt være relevant uden at være nødvendig. Dette er tilfældet, hvis den dataansvarlige opbevarer samme oplysning flere steder.

Bestemmelsen rummer et proportionalitetskrav, der både har en kvantitativ og en kvalitativ side, jf. de Terwagna i Kuner m.fl. (red.), *The EU General Data Protection Regulation (GDPR)*, s. 317. I vurderingen af, om oplysningerne er nødvendige for at opfylde formålet, kan det således både være relevant at vurdere omfanget og karakteren af de behandlede oplysninger. Skal man ansætte en ny medarbejder, vil det eksempelvis ikke være i overensstemmelse med dataminimeringsprincippet at bede om ansøgernes fulde sundhedsjournaler, men det vil også kunne være i strid med princippet at bede om enkeltstående men meget følsomme oplysninger (ligesom det kan være i strid med andre af de grundlæggende principper og ansættelsesretlige regler).

Se som et eksempel på manglende overholdelse af dataminimeringsprincippet i litra c Datatilsynets afgørelse i j.nr. 2018-41-0016. Et taxaselskab opbevarede kundernes telefonnumre i fem år. Nummeret var nøglen til systemets database, der blev anvendt til virksomhedens produkt- og forretningsudvikling. Under sagen blev oplyst, at nummeret i princippet kunne udskiftes med en anden unik kode, men at dette ikke var systemunderstøttet. På den baggrund fandt Datatilsynet ikke, at det havde været nødvendigt at opbevare telefonnumrene i fem år. Formålet kunne med andre ord opnås uden brug af kunders telefonnumre.

En række yderligere afgørelser fra Datatilsynet er omtalt hos Korfits Nielsen og Lotterup, *Databeskyttelsesforordningen og databeskyttelsesloven*, s. 329 ff.

4. Rigtighed

Efter art. 5, stk. 1, litra d, skal personoplysninger være “korrekte og om nødvendigt ajourførte” og “der skal tages ethvert rimeligt skridt for at sikre, at personoplysninger, der er urigtige i forhold til de formål, hvortil de behandles, straks slettes eller berigtiges”.

Bestemmelsen har en nær sammenhæng med den registreredes ret til berigtigelse efter art. 16 og til sletning efter art. 17. Da den registreredes *ret* til at kræve henholdsvis berigtigelse og sletning afspejler den

Art. 5, stk. 1,
litra d

Forholdet til art.
16 og 17

dataansvarliges *pligt* til at berigtige og slette, er der et væsentligt overlap mellem bestemmelserne.

Kravet om rigtighed afspejler, at myndigheder og virksomheder ofte træffer afgørelser af betydning for den registrerede på baggrund af personoplysninger. Ukorrekte personoplysninger kan derfor føre til ukorrekte afgørelser. Herudover kan bestemmelsen ses som en beskyttelse af personlighedshensynet: den registrerede har krav på, at der bliver præsenteret et retvisende billede af den pågældendes personlighed, hvilket forudsætter, at behandlede personoplysninger er korrekte og retvisende.

Første del af bestemmelsen kræver, at oplysningerne er "korrekte", mens anden del bruger begrebet "urigtige" oplysninger. Der ligger ingen indholdsmæssig forskel heri (i den engelsksprogede version anvendes begreberne "accuracy" og "inaccuracy"). Det vil i de fleste tilfælde ikke volde problemer at afgøre, om en objektivt konstaterbar oplysning, som f.eks. en persons alder eller adresse, er rigtig. Det vil være vanskeligere, hvis oplysningerne har karakter af skønsbaserede vurderinger, f.eks. om den registreredes evner, karaktertræk mv. Denne type oplysninger vil derfor også sjældnere være "urigtige" i bestemmelsens forstand, medmindre vurderingen er baseret på objektivt forkerte oplysninger.

Begreberne
"korrekte" og
"urigtige"
personoplysninger

Det følger af bestemmelsen, at vurderingen af, om oplysningen er urigtig, skal tage udgangspunkt i formålet med behandlingen. Om oplysningen kan betegnes som "urigtig" vil dog i mange tilfælde (nok de fleste) være uafhængig af, hvad formålet med behandlingen er. Begrebet "urigtig" dækker imidlertid ikke kun over objektivt forkerte oplysninger, men også over oplysninger, der er vildledende eller ufuldstændige og dermed giver et forkert grundlag for en eventuel afgørelse.

Se således også Korfits Nielsen og Lotterup, Databeskyttelsesforordningen og databeskyttelsesloven, s. 332.

Formålet med behandlingen vil kunne påvirke vurderingen af, om en oplysning er vildledende eller ufuldstændig. Oplysninger, der er vildledende eller ufuldstændige, vil i mange tilfælde også være utilstrækkelige eller irrelevante og dermed i strid med art. 5, stk. 1, litra c, om dataminimering.

Bestemmelsen pålægger den dataansvarlige en pligt til at slette eller berigtige urigtige oplysninger. Det er således klart, at den dataansvarlige skal reagere, når det konstateres, at oplysningerne er urigtige. Derimod følger det ikke eksplicit af bestemmelsen, at den dataansvarlige løbende skal kontrollere, om oplysningerne er rigtige. En sådan kontrolpligt må dog antages at følge af princippet om accountability (ansvarlighed), som det kommer til udtryk i art. 5, stk. 2, og art. 24 (se også nærmere om ansvarlighedsprincippet kap. 8). Efter art. 5, stk. 2, er den dataansvarlige ansvarlig for og skal kunne påvise, at de grundlæggende behandlingsprincipper overholdes. Efter art. 24 skal den dataansvarlige gennemføre passende tekniske og organisatoriske foranstaltninger for at sikre og for at kunne påvise, at behandling er i overensstemmelse med forordningen, og altså herunder art. 5. For at sikre, at oplysningerne vedblivende er rigtige, vil den dataansvarlige være nødt til at føre løbende kontrol med oplysningerne. De nærmere krav til kontrollen kan ikke udledes af bestemmelsen men vil afhænge af de konkrete omstændigheder, herunder karakteren af oplysningerne og behandlingen, og må i øvrigt mest naturligt fastsættes som led i kravene til passende og tekniske foranstaltninger efter art. 24, jf. herom kapitel 8.2.

Den registrerede har også mulighed for selv at gøre den dataansvarlige opmærksom på, at oplysningerne er urigtige. Den registrerede kan blive opmærksom herpå, når den dataansvarlige som led i sin oplysningspligt efter art. 13 og 14 bl.a. orienterer den registrerede om, hvilke oplysninger, der behandles, eller når den registrerede udnytter sin indsigtsret efter art. 15. I nogle tilfælde vil den registrerede blive opmærksomme på de urigtige oplysninger, fordi der træffes en forkert afgørelse. Som netop beskrevet er den dataansvarlige forpligtet til at føre løbende kontrol med rigtigheden, og den registreredes egen kontrol er derfor ikke en forudsætning for princippet om rigtighed efter art. 5, stk. 1, litra d.

Når den dataansvarlige konstaterer, at oplysningerne er urigtige, har den dataansvarlige pligt til enten at slette eller berigtige oplysningerne. Forordningen inderholder ingen definition af eller nærmere fortolkningsbidrag til, hvordan begreberne "sletning" og "berigtigelse" skal forstås.

I sin tekst “Sletning af personoplysninger” (publiceret på tilsynets hjemmeside den 28. januar 2019) har Datatilsynet defineret sletning som “en handling, der sikrer, at oplysningerne ikke længere er tilgængelige”. Utilgængeligheden sikres i de fleste tilfælde ved, at oplysningerne fjernes fra det fysiske medie, de er lagret på.

Sletning

I den nævnte tekst anfører Datatilsynet, at der er sket sletning, når oplysningerne er slettet via et operativsystem, selvom disken endnu ikke er overskrevet med andre data, da oplysningerne ikke længere er tilgængelige “med rimelige midler”.

Begrebet må også omfatte tilintetgørelse af det fysiske medium (selvom “sletning” og “tilintetgørelse” i definitionen af “behandling” i art. 4, nr. 2, anføres som to forskellige handlinger). Derimod indebærer bortskaffelse af det fysiske medium ikke i sig selv, at oplysningerne er slettet. Oplysningerne på en computer anses ikke for slettet, fordi computeren smides i en container. Ved bortskaffelse af lagringsmedier, har den dataansvarlige pligt til forudgående at slette oplysningerne.

En berigtigelse forudsætter, at de urigtige oplysninger korrigeres. Det kan i praksis gøres ved, at oplysningerne slettes og erstattes af nye og rigtige oplysninger, og der er ingen tvivl om, at dette vil udgøre en berigtigelse i bestemmelsens forstand.

Berigtigelse

Derimod er det mindre klart, i hvilket omfang begrebet “berigtigelse” også dækker den situation, hvor de urigtige oplysninger bevarer, men hvor der tilføjes information om, at oplysningerne er urigtige suppleret med de rigtige oplysninger. Denne form for korrektion kan være nødvendig i situationer, hvor der fortsat er behov for at kunne dokumentere de urigtige oplysninger. Har de urigtige oplysninger eksempelvis indgået i en myndigheds afgørelse, skal dette kunne dokumenteres, idet offentlige myndigheder som udgangspunkt skal kunne dokumentere det grundlag, en afgørelse blev truffet på. Tilsvarende kan private virksomheder have behov for at kunne dokumentere, hvilke oplysninger, der har været registreret, til brug for en eventuel klage eller retssag. Reale grunde taler derfor for, at en tilføjelse om oplysningerne urigtighed også kan udgøre en berigtigelse, når der er tilstrækkeligt tungtvejende grunde til, at de urigtige oplysninger ikke slettes.

– berigtigelse
uden sletning af
de urigtige
oplysninger?

I overensstemmelse hermed er det fast antaget, at offentlige myndigheder kan foretage en berigtigelse ved at tilføje de rigtige oplysninger.

ger på sagen uden at slette de urigtige. Dette var praksis under den tidligere persondatalov, og Datatilsynet har i sin vejledning om de registreredes rettigheder fastslået, at det fortsat er gældende under forordningen, jf. vejledningens s. 31. Samme opfattelse lægges til grund i betænkning 1565/2017, s. 327.

Se kritisk til denne retstilstand og den udbredte forvaltningspraksis, hvorefter urigtige oplysninger ikke slettes, Blume, Databeskyttelsesret, s. 122, der betegner den generelle fravigelse af princippet om, at den dataansvarlige konkret skal vurdere situationen og de enkelte oplysninger, som uheldig, og anfører, at dette næppe er i overensstemmelse med forordningen.

I sin vejledning anfører Datatilsynet imidlertid også, at private virksomheder “blot skal berigtige de urigtige oplysninger”, hvilket i den konkrete kontekst må forstås således, at private virksomheder skal slette de urigtige oplysninger og erstatte dem af de rigtige. I denne sammenhæng synes begrebet “berigtigelse” ikke at dække tilføjelse af rigtige oplysninger uden samtidig sletning af de urigtige.

Denne opfattelse synes at have en vis støtte i Datatilsynets afgørelse i sag 2018-31-0147, hvor tilsynet lagde til grund, at Rejsekort A/S ikke kunne foretage en berigtigelse ved at tilføje supplerende information om, at oplysningerne var urigtige. Sagen omhandlede Rejsekort A/S’ registrering af klagerens brug af sit rejsekort til bustransport. Som led heri blev klagerens start- og slutdestination registreret. Disse lokationsoplysninger var i tre tilfælde forkerte, fordi buschaufføren havde foretaget en fejlregistrering i systemet. Klageren anmodede herefter Rejsekort A/S om at rette de urigtige oplysninger, hvilket selskabet afviste, da dette ikke var teknisk muligt. I stedet tilføjede selskabet information om, at de pågældende lokationsoplysninger var urigtige. Datatilsynet afviste, at dette levede op til kravet om berigtigelse i art. 16: “Databeskyttelsesforordningens artikel 16 medfører således ikke efter sin ordlyd en ret til for den dataansvarlige at vælge at *undlade* berigtigelse ved *i stedet* at tilføje supplerende oplysninger efter bestemmelsens 2. pkt.” (fremhævet her). Denne formulering synes nærmest at indebære, at en tilføjelse af korrigerende oplysninger definatorisk ikke kan udgøre en berigtigelse i art. 16’s forstand.

– Rejsekortsagen

Det ligger dog klart, at afgørelsen ikke afskærer offentlige myndigheder fra at kunne foretage en berigtigelse gennem korrigerende tilføjelser til de urigtige oplysninger. Rejsekort A/S (der er et offentligt ejet selskab) havde således henvist til offentlighedslovens regler om notat- og journaliseringspligt og offentlige myndigheders heraf følgende praksis med at foretage berigtigelse ved at tilføje information om oplysningernes urigtighed. Datatilsynet afviste dette synspunkt med den begrundelse, at “de hensyn, der ligger bag offentlighedslovens bestemmelser om journaliserings- og notatpligt ikke kan sidestilles med den tekniske indretning af rejsekortsystemet, der ikke kan fastlægge korrekte oplysninger, og som ikke tillader berigtigelse af urigtige personoplysninger”.

Datatilsynets vejledning og Rejsekort A/S-afgørelsen peger i retning af, at begrebet “berigtigelse” kan omfatte offentlige myndigheders tilføjelse af korrigerende oplysninger uden sletning af de urigtige oplysninger, mens begrebet ikke omfatter en tilsvarende korrektion foretaget af private virksomheder.

Som anført ovenfor kan også private virksomheder dog have behov for at kunne bevare urigtige oplysningerne. På den baggrund må det antages, at også private virksomheder i visse situationer kan foretage en berigtigelse gennem tilføjelse af korrigerende oplysninger, og at begrebet “berigtigelse” definatorisk omfatter denne form for korrektion. Det ville også være u hensigtsmæssigt, hvis definitionen gjordes relativ og afhængig af den dataansvarliges status.

– konklusion

Korfits Nielsen og Lotterup antager tilsvarende, at private virksomheder kan foretage berigtigelse gennem tilføjelse af korrigerende oplysninger, Databeskyttelseforordningen og databeskyttelsesloven, s. 334. På s. 538 f. anfører forfatterne dog med henvisning til Datatilsynets vejledning og Rejsekort-sagen, at private virksomheder blot skal berigtige (slette) oplysningerne, mens offentlige myndigheder typisk skal berigtige ved at bevare de urigtige oplysninger og supplere med de rigtige.

At begrebet “berigtigelse” må antages også at omfatte den situation, hvor urigtige oplysninger suppleres med rigtige, men ikke slettes, indebærer ikke, at den dataansvarlige i enhver situation kan vælge denne form for berigtigelse. En sådan korrigerende foranstaltning vil sikre mod, at der fremadrettet træffes forkerte afgørelser på grundlag af de urigtige personoplysninger. Den vil derimod ikke hindre, at en

– i hvilke situationer kan der berigtiges uden sletning af de urigtige oplysninger?

registreret fortsat kan føle ubehag ved, at der er anført forkerte oplysninger om den pågældende i en sagsjournal eller lignende, navnlig hvis der er tale om oplysninger af følsom karakter. Det må derfor også være udgangspunktet, at en berigtigelse sker ved en sletning af de urigtige oplysninger og en tilføjelse af de rigtige. Kun hvis der er saglige grunde til at bevare de urigtige oplysninger, kan den dataansvarlige foretage berigtigelse ved at tilføje supplerende korrigerende oplysninger. Det er nærliggende at fortage vurderingen heraf med udgangspunkt i de undtagelser til slettepligten, som følger af art. 17, stk. 3. Hvis den dataansvarlige kan undlade at slette oplysningerne efter denne bestemmelse, har det formodningen mod sig, at der skulle følge en slettepligt efter princippet om rigtighed i art. 5, stk. 1, litra d, og den registreredes ret til berigtigelse efter art. 16. Omvendt har dog også formodningen mod sig, at den registrerede helt kan undlade at foretage en berigtigelse i denne situation, og i praksis er derfor kun tilbage at foretage berigtigelsen gennem tilføjelse af korrigerende oplysninger.

Når en berigtigelse foretages gennem tilføjelse af korrigerende oplysninger skal det ske på en måde, så berigtigelsen får en reel effekt. Det fremgår således af Datatilsynets vejledning om de registrerede rettigheder, at tilføjelsen skal ske i så nær tilknytning til de urigtige personoplysninger som muligt, så det er nemt for fremtidige sagsbehandlere mv. at se, at oplysningerne er blevet berigtiget. For den registrerede vil det nok være mere tilfredsstillende, at den urigtig oplysning udskiftes i databasen, så "stamdata" er rigtige, og at der herefter laves en tilføjelse om rettelsen, frem for at stamdata forbliver urigtige med en tilføjelse om dette i form af et notat e.lign. Om den registrerede kan kræve dette er dog usikkert. En sådan pligt følger ikke af Datatilsynets praksis eller vejledningen. Er der tale om offentligt tilgængelige oplysninger eller oplysninger, som andre dataansvarlige bruger i deres sagsbehandling, kan der være særlig grund til at rette i databasen og lade oplysninger herom fremgå af et notat mv.

– hvordan skal berigtigelse uden sletning foretages?

Se i samme retning Korfits Nielsen og Lotterup, Databeskyttelsesforordningen og databeskyttelsesloven, s. 334: "En egentlig sletning vil oftere kunne kræves, hvis der er tale om oplysninger, som indgår i et register eller andet informationssystem, hvorfra oplysningerne tilgår andre dataansvarlige, eventuelt via et on-line-system. Men også her må det dog efter omstændighederne accepteres, at det gennem en fortsat opbe-

varing af en kopi af registreret i dets tidligere version eller på en anden måde kan dokumenteres, hvilke faktuelle oplysninger der tidligere måtte være blevet videregivet”.

Det må antages, at den dataansvarlige i øvrigt har valgfrihed mellem at foretage sletning og berigtigelse. Denne valgfrihed begrænses dog, hvis den registrerede vælger at gøre brug af sine rettigheder til at kræve berigtigelse eller sletning efter art. 16 og 17, jf. nærmere herom kap. 6.5 og 6.6.

Sletningen eller berigtigelsen skal efter art. 5, stk. 1, litra d, foretages “straks”. Har den dataansvarlige etableret en løbende procedure for “rensning” af data og opdatering af databaser, kan sletningen eller berigtigelsen ikke afvente denne procedure. At den dataansvarliges system er indrettet således, at en sletning ikke umiddelbart er mulig, vil normalt heller ikke være diskulperende. Kravet gælder først fra det tidspunkt, hvor den dataansvarlige indser, at oplysningerne er urigtige. Henvender den registrerede sig og gør opmærksom på, at den dataansvarlige behandler urigtige oplysninger, har den dataansvarlige mulighed for at bruge tid på at vurdere indsigelsen. Dette følger af art. 16 og 17, hvorefter den dataansvarlige skal berigtige henholdsvis slette de urigtige oplysninger “uden unødigt forsinkelse”, efter den registrerede har anmodet om det. Hermed er den dataansvarlige givet en vis tid til at vurdere indsigelsen (se også herom kap 6.5 og 6.6). Når den dataansvarlige har vurderet, at indsigelsen er berettiget, skal berigtigelsen foretages “straks” herefter.

Valgfrihed mellem sletning og berigtigelse

Sletning eller berigtigelse skal ske straks

5. Opbevaringsbegrænsning

Efter art. 5, stk. 1, litra e, skal personoplysninger “opbevares på en sådan måde, at det ikke er muligt at identificere de registrerede i et længere tidsrum end det, der er nødvendigt til de formål, hvortil de pågældende personoplysninger behandles”.

Art. 5, stk. 1, litra e

Bestemmelsen om den registreredes ret til sletning, skal modvirke en dataophobning, hvor myndigheder og virksomheder over tid kommer til at opbevare store mængder data, som ikke længere er relevante. Hvor art. 5, stk. 1, litra b og c, forbyder indsamling og behandling af oplysninger, der ikke har relevans for det angivne formål med be-

Modvirkning af dataophobning

handlingen, forpligter litra e den dataansvarlige til at slette sådanne oplysninger. Baggrunden er, at store dataophobninger indebærer en øget risiko for misbrug, utilsigtet videregivelse mv.

Kravet om, at det ikke længere er muligt at identificere den registrerede, kan enten opfyldes ved sletning eller anonymisering. Om begrebet "sletning" henvises til afsnit 4 ovenfor. Om begrebet "anonymisering" henvises til kapitel 2.1.1 (under gennemgangen af begrebet "personoplysning").

"Sletning" og
"anonymisering"

Også denne bestemmelse tager sit udgangspunkt i det behandlingsformål, som den dataansvarlige har opstillet. Det vil bero på en konkret vurdering, hvor længe opbevaring vil være nødvendig for at opfylde formålet. Da personoplysninger ofte vil danne baggrund for afgørelser og retsdispositioner, kan det være nødvendigt at opbevare oplysningerne i en årrække af hensyn til efterfølgende dokumentation. Bogføringsloven kræver eksempelvis, at bogføringsmateriale opbevares i 5 år. Også forældelseslovens frister på hhv. 3 og 5 år kan være relevante, når personoplysninger eksempelvis indgår i dokumentation for et retskrav.

Opbevarings-
periode

Med inspiration i bogføringsloven havde Datatilsynet under den tidligere persondatalov fastsat en vejledende frist på 5 år for opbevaring af personoplysninger. Forordningen efterlader næppe rum for en sådan vejledende frist, og det gælder under alle omstændigheder, at fristen kan være både længere og kortere. Blume antager, at den vejledende frist fortsat kan lægges til grund, Den nye persondataret, s. 94.

Den dataansvarlige har ansvaret for, at der løbende sker sletning (eller anonymisering) af oplysninger, som ikke længere er nødvendige for at opfylde behandlingsformålet. En sådan pligt følger af art. 5, stk. 2, hvorefter den dataansvarlige er ansvarlig for og skal påvise at overholde bestemmelserne i stk. 1. Den dataansvarlige kan med andre ord ikke vente på, at registrerede eller andre protesterer over den fortsatte opbevaring af oplysningerne men skal mere proaktivt forholde sig til, om oplysningerne fortsat er relevante. I praksis sker det typisk ved at fastsætte nærmere slettefrister og sletteprocedurer for forskellige typer af oplysninger.

Fastsættelse af
slettefrister og
sletteprocedurer

I sin tekst om "sletning af personoplysninger" (publiceret på tilsynets hjemmeside den 28. januar 2019) har Datatilsynet givet et eksempel på

fastsættelse af slettefrister for en webshop, hvor en kunde opretter en profil i virksomhedens system: “Kunden giver samtykke til at modtage nyhedsbreve, som er personliggjort på baggrund af kundens tilkendegivne interesser i bestemte produkter. Når kunden foretager et køb i webshoppens gemmes en kopi af faktura til regnskabsformål. Virksomheden fastsætter på baggrund af bogføringsloven en slettefrist på 5 år for fakturaer. Desuden fastsætter virksomheden – med baggrund i forældelsesfristen for sager efter markedsføringslovens § 10 – en slettefrist på 2 år for det samtykke, som kunden har afgivet i forhold til modtagelse af nyhedsbrevet. Hvis kunden sletter sin profil i systemet slettes de øvrige oplysninger om vedkommende efter 6 måneder. På baggrund af behandlingerne og slettefristerne indretter virksomheden sine systemer på en måde, hvor fakturaer kun indeholder de fornødne oplysninger jf. bogføringsloven. På samme måde gemmes samtykker til modtagelse af nyhedsbrev separat med de fornødne personoplysninger, der kræves til dokumentation heraf. De øvrige oplysninger om kunden gemmes i kundens profil, som alle kan slettes på samme tid, når slettefristen er mødt. På den måde letter virksomheden sit arbejde med at overholde sine fastsatte slettefrister, idet fristerne og behandlingerne kan knyttes op på bestemte dele af systemet.”

I teksten anfører Datatilsynet følgende om sletningsprocedurer: “En sletteprocedure bør inkorporere både tekniske og organisatoriske overvejelser, da der i forbindelse med sletning løbende udføres både tekniske og organisatoriske handlinger. Organisatoriske overvejelser kan indebære stillingtagen til: hvordan systemerne løbende undersøges for oplysninger, der har nået sin slettefrist; hvem der er ansvarlig for, at sletningen igangsættes; hvordan der følges op på, at sletningen er foretaget; hvordan det dokumenteres at sletningen er fuldført. Tekniske overvejelser kan indebære, at den dataansvarlige forholder sig til om sletningen skal foretages automatisk eller manuelt, samt hvilke konkrete datafelter i et system der vil blive påvirket af sletningen og på hvilken måde. Det kan fx være, at en kunde hos en virksomhed får hele sit datablad slettet i systemet, eller at kun de personhenførbare oplysninger slettes eller anonymiseres.”

Der tages sædvanligvis løbende backup af data i it-systemer. Når personoplysninger skal slettes, vil det som udgangspunkt også omfatte backup-kopier af oplysningerne. Den dataansvarliges sletteprocedurer skal således også tage højde for eventuelle backup-kopier. Datatilsynet

Backup-kopier

har dog i den omtalte tekst “sletning af personoplysninger” anført, at backup-kopier ikke er omfattet af slettepligten, hvis det teknisk ikke er muligt at slette disse kopier.

Udover pligten til at fastsætte slettefrister og procedurer for sletning følger det Datatilsynets praksis, at den dataansvarlige efter art. 5, stk. 2, også er forpligtet til at fastsætte procedurer for opfølgning på sletning. Den dataansvarlige skal med andre også kontrollere, at de fastlagte procedurer for sletning rent faktisk bliver efterlevet.

Opfølgning

Som et markant eksempel på manglende overholdelse af slettepligten efter art. 5, stk. 1, litra e, kan nævnes Datatilsynets afgørelse i sag 2018-41-0015, hvor tilsynet politianmeldte virksomheden IDdesign og indstillede den til en bøde på 1,5 mio. kr. for manglende sletning af oplysninger om 385.000 kunder. Kundeoplysningerne, der indbefattede navn, adresse, telefonnummer, e-mailadresse og købshistorik, var ikke slettet efter udløbet af den 5-årige opbevaringsperiode efter bogføringsloven. Virksomheden havde endvidere ikke fastlagt frister for sletning af oplysninger i systemet (og havde heller aldrig foretaget en sletning). Tilsynet fandt, at den manglende fastsættelse af slettefrister var en overtrædelse af art. 5, stk. 2 om ansvarlighed. Dette samme gjaldt manglende procedurer for opfølgning på sletning.

Praksis fra
Datatilsynet

Yderligere afgørelser fra Datatilsynet er omtalt hos Korfits Nielsen og Lotterup, Databeskyttelsesforordningen og databeskyttelsesloven, s. 336 ff.

Det følger af art. 5, stk. 1, litra e, at personoplysninger kan opbevares i længere tidsrum, hvis oplysningerne alene behandles til arkivformål i samfundets interesse, til videnskabelige eller historiske forskningsformål eller til statistiske formål i overensstemmelse med artikel 89, stk. 1. Efter DBL § 14 kan personoplysninger arkiveres efter reglerne i arkivloven. Det er således arkivloven, som afgør, i hvilket omfang der kan ske arkivering af personoplysninger inden for denne lovs område.

Arkivering,
forskning og
statistik

Når den dataansvarlige sletter personoplysninger, kan den registrerede ikke længere få indsigt i, hvilke oplysninger den dataansvarlige behandlede om den pågældende. Slettepligten gælder imidlertid også, selvom om sletningen kan medføre, at den registrerede ikke kan gøre sine rettigheder gældende (herunder indsigtsretten). Det følger således

Manglende
adgang til indsigt

af artikel 11, stk. 1, at den dataansvarlige ikke forpligtet til at beholde oplysninger for at kunne identificere den registrerede alene med det formål at overholde forordningen, når formålene med behandlingen ikke længere kræver, at den registrerede kan identificeres af den dataansvarlige.

Bestemmelsen i art. 5, stk. 1, litra e, har en vis sammenhæng med art. 17 om den registreredes ret til at kræve sletning. Se om denne bestemmelse kap. 6.6.

Art. 17

6. Integritet og fortrolighed

Efter art. 5, stk. 1, litra f, skal personoplysninger “behandles på en måde, der sikrer tilstrækkelig sikkerhed for de pågældende personoplysninger, herunder beskyttelse mod uautoriseret eller ulovlig behandling og mod hændeligt tab, tilintetgørelse eller beskadigelse, under anvendelse af passende tekniske eller organisatoriske foranstaltninger”. Bestemmelsen stiller således krav til behandlingssikkerheden, altså hvilke sikkerhedsforanstaltninger den dataansvarlige skal iværksætte for at beskytte de opbevarede personoplysninger mod misbrug og anden form for ulovlig behandling.

Kravet om behandlingssikkerhed fremgår også og mere detaljeret af art. 32. Det vil først og fremmest være denne bestemmelse, der afgør, hvilke sikkerhedskrav, som kan stilles til den dataansvarliges behandling af personoplysninger. Hermed får art. 5, stk. 1, litra f, formentlig begrænset praktisk betydning. Der ligger dog en signalværdi i, at behandlingssikkerhed er gjort til et grundlæggende behandlingsprincip (hvilket er en nyskabelse i forordningen). Hermed understreges, at behandlingssikkerhed er centralt for at opnå en effektiv databeskyttelse. Det kan muligvis også bidrage til at skærpe sanktioneringen, når den dataansvarlige ikke overholde sikkerhedskravene.

Kapitel 5

Behandlingsgrundlag

Et af de helt centrale reguleringsspørgsmål i databeskyttelsesretten er spørgsmålet om, hvornår en personoplysning må behandles. Ved denne regulering må lovgiver foretage nogle grundlæggende retssystematiske valg.

Retssystematiske valg

Det kan for det første overvejes, om alle former for behandling som udgangspunkt skal kræve et hjemmelsgrundlag, eller behandlingen omvendt skal være tilladt, medmindre den er omfattet af et forbud. Dette har bl.a. betydning for, hvem der har bevisbyrden for, at en behandling er lovlig, og har ligeledes en signalværdi. Som det fremgår af det følgende, er forordningen baseret på det udgangspunkt, at behandlingen af personoplysninger kun må finde sted, hvis der eksisterer en hjemmel til behandlingen i forordningen.

– krav om hjemmelsgrundlag for alle behandlinger?

Dernæst kan det overvejes, om der skal gælde samme regler for alle typer af oplysninger, eller om reglerne skal differentieres i erkendelse af, at nogle typer oplysninger vil opleves som mere følsomme end andre og dermed potentielt også kan indebære større integritetskrænkelser. Forordningen har valgt den sidstnævnte model og indeholder en bestemmelse om adgangen til at behandle en række særligt følsomme oplysninger. Ofte benævnes disse oplysninger “følsomme oplysninger”, mens øvrige personoplysninger benævnes “almindelige personoplysninger”.

– sondring mellem forskellige typer af personoplysninger

Endelig kan det overvejes, om der skal indføres en række konkrete regler, der specifikt angiver særlige situationer, hvor behandlingen kan finde sted, eller om hjemmelsreglerne skal baseres på brede standarder.

– konkrete hjemmelsgrundlag eller brede standarder?

Som det fremgår af det følgende, er forordningen baseret på en kombination heraf.

Forordningens bestemmelser om hjemmelsgrundlag følger af art. 6-10. Den centrale bestemmelse er art. 6, som opregner de i alt seks hjemmelsgrundlag, der kan gøre en behandling af personoplysninger lovlig. Art. 7 og 8 fastlægger nærmere regler for samtykket, der udgør et af de seks hjemmelsgrundlag. Art. 9 stiller krav til, hvornår følsomme oplysninger på behandles. Art. 10 fastlægger, hvornår der må ske behandling af personoplysninger vedrørende straffedomme og lovovertrædelser. I det følgende beskrives de seks behandlingsgrundlag, der følger af art. 6 og de særlige regler, der gælder for behandling af følsomme oplysninger og oplysninger om straffedomme og lovovertrædelser. Indledningsvist gennemgås forholdet mellem art. 6 og 9, da dette har betydning for den resterende del af kapitlet.

1. Generelt om art. 6

Forordningen indeholder i art. 6, stk. 1, seks forskellige hjemmelsgrundlag til behandling af almindelige personoplysninger. Bestemmelsen har følgende indhold (fremhævelser fortaget her):

De seks behandlingsgrundlag

Behandling er kun lovlig, hvis og i det omfang mindst ét af følgende forhold gør sig gældende:

- a) Den registrerede har givet *samtykke* til behandling af sine personoplysninger til et eller flere specifikke formål.
- b) Behandling er nødvendig af hensyn til *opfyldelse af en kontrakt*, som den registrerede er part i, eller af hensyn til gennemførelse af foranstaltninger, der træffes på den registreredes anmodning forud for indgåelse af en kontrakt.
- c) Behandling er nødvendig for at overholde en *retlig forpligtelse*, som påhviler den dataansvarlige.
- d) Behandling er nødvendig for at beskytte den registreredes eller en anden fysisk persons *vitale interesser*.
- e) Behandling er nødvendig af hensyn til udførelse af en *opgave i samfundets interesse* eller som henhører under *offentlig myndighedsudøvelse*, som den dataansvarlige har fået pålagt.
- f) Behandling er nødvendig for, at den dataansvarlige eller en tredjemand kan forfølge en *legitim interesse*, medmindre den re-

gistreredes interesser, eller grundlæggende rettigheder og frihedsrettigheder, der kræver beskyttelse af personoplysninger, går forud herfor, navnlig hvis den registrerede er et barn.

Det retstekniske udgangspunkt efter art. 6 er, at en behandling er forbudt, medmindre der kan identificeres et hjemmelsgrundlag for behandlingen (også benævnt "behandlingsgrundlag"), jf. bestemmelsens indledende ord om, at behandlingen "kun er lovlig", når en af de efterfølgende betingelser er opfyldt.

De seks behandlingsgrundlag har forskellige karakter og kan overordnet inddeles i tre kategorier.

Den første kategori udgøres af litra a om samtykke. Samtykket adskiller sig fra de fem øvrige behandlingsgrundlag ved, at det er den registrerede selv, der vælger, om grundlaget skal aktiveres, og om behandlingen kan iværksættes. Tilsvarende er det det eneste grundlag, som den registrerede selv kan bringe til ophør ved at trække samtykket tilbage. Herudover adskiller samtykkereglen sig sammen med interesseafvejningsreglen i litra f fra de øvrige fire behandlingsgrundlag ved at gå på tværs af behandlingssituationer og dermed potentielt kunne finde anvendelse på alle typer af behandlinger. I situationer, hvor der er flere potentielle behandlingsgrundlag, vil samtykket derfor ofte også være ét af dem. I praksis er det disse situationer, der har givet anledning til flest spørgsmål om valg og skift af behandlingsgrundlag.

Den anden kategori udgøres af de fire behandlingsgrundlag i litra b-e. Fælles for disse behandlingsgrundlag er, at de omhandler specifikke behandlingssituationer og kun finder anvendelse, når den pågældende behandlingssituation nødvendiggør en behandling. Selvom der er tale om specifikke behandlingssituationer, er bestemmelserne relativt brede og udgør i praksis hjemmel for en meget stor del af de behandlinger, der foretages.

Det tredje kategori udgøres af interesseafvejningsreglen i litra f. Dette behandlingsgrundlag har karakter af en slags "opsamlingsbestemmelse", som omfatter situationer, hvor det er rimeligt, at den dataansvarlige kan foretage en behandling, også selvom ingen af de specifikke behandlingsgrundlag i litra b-e finder anvendelse, og det heller ikke er muligt at indhente samtykke fra den registrerede (enten fordi det ikke er praktisk muligt, eller fordi den registrerede ikke ønsker at

Tre typer af
behandlings-
grundlag
- samtykke, litra a

- specifikke
behandlings-
situationer,
litra b-e

- interesseafvej-
ning, litra f

give samtykke). Bestemmelsen går på samme måde som samtykkereglen på tværs af konkrete behandlingssituationer og er en nødvendighed, når det retstekniske udgangspunkt er et forbud mod behandling af personoplysninger, hvis der ikke kan findes et behandlingsgrundlag. Det vil ikke være muligt at opfange alle de situationer, hvor der kan være et behov for at behandle personoplysninger, gennem regulering af specifikke behandlingssituationer. Bestemmelsen finder ikke anvendelse på offentlige myndigheders behandling foretaget som led i deres opgaveudførelse.

Som udgangspunkt opnår den dataansvarlige samme retstilling, uanset hvilket af de seks behandlingsgrundlag, der anvendes. Der er således ingen forskel på, hvordan oplysningerne må behandles, ligesom forordningens øvrige regler som udgangspunkt heller ikke skaber forskelle mellem de forskellige behandlingsgrundlag i reguleringen af den dataansvarliges forpligtelser. Ved anvendelsen af samtykkereglen må den dataansvarlige dog som anført acceptere, at den registrerede til enhver tid kan bringe behandlingen til ophør. Endvidere gælder for behandlingsgrundlagene i litra e og f, at den registrerede har ret til at gøre indsigelse mod behandlingen efter forordningens art. 21, stk. 1. Dette giver dog ikke den registrerede en ubetinget ret til at kræve behandlingen afsluttet på samme måde, som en tilbagetrækning af samtykke gør. Indsigelsesretten gælder således kun i særlige situationer og har af denne grund et relativt snævert anvendelsesområde, jf. nærmere herom kap. 6.9.

Betingelserne i art. 6 er ikke kumulative, og det er således tilstrækkeligt, at betingelserne i én af bestemmelserne i litra a-f er opfyldt.

I nogle situationer vil en behandling kunne dækkes af flere behandlingsgrundlag. Dette rejser spørgsmålet, om den dataansvarlige frit kan vælge mellem behandlingsgrundlagene, eller om ét behandlingsgrundlag kan være mere passende end et andet og derfor skal foretrækkes. I tilknytning hertil opstår spørgsmålet, om den dataansvarlige kan skifte behandlingsgrundlag. Disse spørgsmål drøftes specifikt i relation til samtykke nedenfor i afsnit 2.4 og 2.6 og generelt i afsnit 5.

Som beskrevet nedenfor i afsnit 6 indeholder forordningen i art. 9 en særskilt regulering af behandlingen af følsomme oplysninger. Det har tidligere været den udbredte opfattelse i Danmark, at art. 9 afgør, hvornår der må behandles følsomme oplysninger, mens art. 6 afgør,

Samme retsvirkning

Ikke kumulative

Valg og skift af behandlingsgrundlag

Følsomme personoplysninger

hvornår der må behandles oplysninger, der ikke er følsomme (“almindelige personoplysninger”). I november 2019 meddelte Datatilsynet imidlertid, at det fremover ville være tilsynets opfattelse, at også behandlingen af følsomme oplysninger skal have hjemmel i art. 6, hvilket også er opfattelsen hos EDPB. Det må på den baggrund lægges til grund, at art. 6 omfatter alle personoplysninger, også de følsomme. Spørgsmålet er mere indgående behandlet nedenfor i afsnit 6.

2. Samtykke – art. 6, stk. 1, litra a

Det er et bærende princip i databeskyttelsesretten, at den registrerede kan give et samtykke til behandlingen, hvilket illustreres af, at også behandlingen af følsomme oplysninger kan hjemles ved et samtykke, jf. herom nedenfor.

Databeskyttelsesretten skal beskytte individet mod integritetskrænkende behandlinger af den pågældendes personoplysninger. Denne beskyttelse kan blive illusorisk, hvis virksomheder og myndigheder kan basere behandlingen på et samtykke i situationer, hvor den registrerede ikke kan gennemskue konsekvenserne af sit samtykke eller måske føler sig presset til at afgive et samtykke til behandlingen. Forordningen stiller derfor nogle krav til samtykket, for at det tillægges retsvirkning. Disse krav fremgår af definitionen af samtykkebegrebet i art. 4, nr. 11:

Enhver frivillig, specifik, informeret og utvetydig viljestilkendegivelse fra den registrerede, hvorved den registrerede ved erklæring eller klar bekræftelse indvilliger i, at personoplysninger, der vedrører den pågældende, gøres til genstand for behandling.

Et samtykke skal således være *frivilligt, specifikt, informeret og utvetydigt* for at give hjemmel til behandlingen af personoplysninger.

Selv i situationer, hvor disse gyldighedsbetingelser er opfyldt, kan den dataansvarlige være forpligtet til anvende et af de andre behandlingsgrundlag, når behandlingen både kan dækkes af et samtykke og et (eller flere) af de øvrige behandlingsgrundlag. Men kan i disse situationer tale om, at samtykket bliver et *sekundært* behandlingsgrundlag.

I det følgende gennemgås først i afsnit 2.1-2.4 de fire gyldighedsbetingelser, herefter omtales de særlige regler om børns samtykke i afsnit

2.5 og afslutningsvist drøftes valget mellem samtykke og andre behandlingsgrundlag i afsnit 2.6.

2.1. Frivilligt

Kravet om, at samtykket skal være frivilligt, indebærer det helt åbenbare, at et samtykke, der er fremkaldt ved fysisk tvang eller trusler om vold, ikke er gyldigt. Databeskyttelsesretten går dog noget videre i kravene til frivillighed, og forordningens præambelbetragtning 42 fastslår, at samtykke ikke bør anses for frivilligt, hvis den registrerede ikke har et reelt eller frit valg eller ikke kan afvise eller tilbagetrække sit samtykke, uden at det er til skade for den pågældende. I praksis begrænser forordningen på en række væsentlige områder muligheden for at bruge samtykke som behandlingsgrundlag.

Det har været et omdiskuteret spørgsmål i databeskyttelsesretten, om et samtykke er frivilligt, hvis det er afgivet som en betingelse for at opnå en modydelse, f.eks. for at opnå en offentlig ydelse, adgang til indhold på en hjemmeside, mulighed for at tegne forsikringer mv. Spørgsmålet er i særlig grad blevet aktuelt i takt med, at sociale medier og andre internettjenester stiller ydelser til rådighed uden betaling (i penge) mod at få adgang til brugernes personoplysninger. Det har tidligere været den herskende opfattelse i dansk ret, at frivillighedskravet er opfyldt i disse situationer, da den registrerede selv vælger, om den pågældende ønsker modydelsen mod at acceptere behandlingen af personoplysninger. Denne opfattelse kan ikke opretholdes fuldt ud med forordningen. I art. 7, stk. 4, og præambelbetragtning 43 opstilles således en formodning for, at et samtykke ikke er frivilligt, hvis levering af en ydelse er gjort betinget af, at modtageren accepterer behandling af den pågældendes personoplysninger, når denne behandling ikke er nødvendig for levering af ydelsen. Art. 7, stk. 4, har følgende ordlyd:

Modydelse

Ved vurdering af, om samtykke er givet frit, tages der størst muligt hensyn til, bl.a. om opfyldelse af en kontrakt, herunder om en tjenesteydelse, er gjort betinget af samtykke til behandling af personoplysninger, som ikke er nødvendig for opfyldelse af denne kontrakt.

I præambelbetragtning 43 anføres, at der er formodning for, at samtykket ikke er frivilligt i denne situation. Reglen vil kunne ramme sociale medier og andre tjenester, der stiller ydelser gratis til rådighed mod at få adgang til brugernes personoplysninger. Sådanne tjenester kan være nødsaget til at finde andre hjemmelsgrundlag end samtykke.

Kravet om frivillighed kan også give anledning til tvivl, når der består en form for afhængighedsforhold mellem den registrerede og den dataansvarlige, eller i øvrigt en ubalance i forholdet, der kan gøre det tvivlsomt, om den registrerede føler at have et reelt frit valg. Er den registrerede alvorligt syg, er det ikke sikkert, at den pågældende føler at have et reelt valg, hvis sundhedsmyndighederne beder om samtykke til behandling af oplysninger. Behandling af sundhedsoplysninger reguleres primært i sundhedsloven.

Ubalanceret
forhold

Ud fra sådanne betragtninger opstiller forordningens præambelbetragtning 43 en formodning for, at et samtykke ikke er frivilligt, når det gives til en offentlig myndighed, jf. betragtningens første punktum:

– offentlige
myndigheder

Med henblik på at sikre, at der frivilligt er givet samtykke, bør samtykke ikke udgøre et gyldigt retsgrundlag for behandling af personoplysninger i et specifikt tilfælde, hvis der er en klar skævhed mellem den registrerede og den dataansvarlige, navnlig hvis den dataansvarlige er en offentlig myndighed, og det derfor er usandsynligt, at samtykket er givet frivilligt under hensyntagen til alle de omstændigheder, der kendetegner den specifikke situation.

I praksis er dette dog nok også uproblematisk, idet forordningens art. 6, stk. 1, litra e, indeholder en bred hjemmel til behandling for offentlige myndigheder, jf. nedenfor.

I ansættelsesforhold består en form for afhængighed (fordi den ansattes økonomiske situation typisk i væsentlig grad afhænger af lønindkomsten), der også kan rejse tvivl om, hvorvidt den ansattes samtykke til arbejdsgiverens behandling af personoplysninger kan siges at være frivilligt. Forordningen forholder sig ikke til spørgsmålet i præambelbetragtningerne, men det er EDPB's opfattelse, at et samtykke i ansættelsesforhold, herunder i ansættelsessamtaler, kun helt undtagelsesvist vil være frivilligt, rådets retningslinjer 5/2020 vedrørende samtykke i henhold til forordning 2016/679, pkt. 22: "I lyset af magtu-

– ansættelses-
forhold

balancen mellem arbejdsgivere og deres medarbejdere kan arbejdstagerne kun frivilligt give samtykke under særlige omstændigheder, når det ikke har nogen som helst negative konsekvenser, om de giver samtykke eller ej”. EU-Domstolen har endnu ikke forholdt sig til spørgsmålet. I Danmark har brugen af samtykke i ansættelsesforhold været mere udbredt, end hvad der lægges op til i EDPB’s vejledning. I DBL § 12, stk. 3, er eksplicit angivet “at behandling af personoplysninger i ansættelsesforhold kan finde sted på baggrund af den registreredes samtykke i overensstemmelse med artikel 7 i databeskyttelsesforordningen”. Bestemmelsen giver ikke et større råderum for samtykke i ansættelsesforhold, end hvad der følger af forordningen, og har dermed heller ikke nogen selvstændig retsvirkning. Bestemmelsen sender dog et retspolitisk signal om, at lovgiver i Danmark fortsat har ønsket, at samtykke i et vist omfang skal kunne bruges som behandlingsgrundlag i ansættelsesforhold.

Hvis den dataansvarlige ønsker at foretage forskellige behandlinger af den registreredes personoplysninger (f.eks. både intern brug af oplysninger og videregivelse af oplysningerne til tredjeparter), skal der indhentes samtykke til hver af disse behandlinger (medmindre et andet behandlingsgrundlag anvendes), jf. forordningens præambelbetragtning 32. Forordningens præambelbetragtning 43 opstiller en formodning for, at et samtykke ikke er frivilligt, hvis det dækker flere forskellige behandlinger. Den dataansvarlige kan med andre ord ikke “bundle” flere behandlinger i én samtykkeerklæring, men skal give den registrerede mulighed for at tage stilling til hver enkelt af behandlingerne gennem separate samtykkeerklæringer.

Separate
samtykker til flere
behandlinger

Kravet om separate samtykkeerklæringer kan illustreres med følgende eksempel fra EDPB’s retningslinjer 5/2020, pkt. 45: “En detailhandler anmoder i en og samme anmodning om samtykke sine kunder om samtykke til, at deres oplysninger anvendes til at sende dem markedsføringsmateriale pr. e-mail, og til, at deres oplysninger deles med andre virksomheder inden for koncernen. Dette samtykke er ikke granulært, da der ikke er noget særskilt samtykke til de to særskilte formål, og derfor er samtykket ikke gyldigt. I dette tilfælde bør der indhentes specifikt samtykke til, at kontaktoplysningerne sendes til virksomhedens handelspartnere. Et sådant specifikt samtykke anses for at være gyldigt for hver enkelt partner [...], hvis identitet den registrerede blev oplyst om

på tidspunktet for indhentningen af samtykke, i det omfang det sendes til dem med henblik på det samme formål (her til markedsføringsformål)”.

Skade

Som nævnt anfører forordningens præambelbetragtning 42, at et samtykke ikke bør anses for frivilligt, hvis det vil komme den registrerede til skade ikke at afgive samtykket. Kravet om, at et samtykke ikke må være en betingelse for at få stillet en ydelse til rådighed, jf. ovenfor, kan ses som et udtryk for dette mere generelle princip.

2.2. Specifikt og informeret

Kravet om at samtykket skal være specifikt, er tæt knyttet til kravet om formålsbestemthed, jf. herom nedenfor. Behandlingen af personoplysninger skal ske til et bestemt og udtrykkeligt formål, og dette formål skal oplyses den registrerede i forbindelse med afgivelsen af samtykket. Er der ikke fastsat et klart formål med behandlingen, eller er formålet ikke oplyst den registrerede, er samtykket ikke “specifikt” og dermed ikke gyldigt.

Specifikt

Såfremt personoplysningerne skal anvendes til flere behandlinger med forskellige formål, skal der indhentes separat samtykke til hver af disse behandlinger. Derimod kan et samtykke dække flere behandlinger, hvis disse forfølger samme formål.

EU-Domstolen har i sag C-673/17 (*Planet49*) fastslået, at kravet om et specifikt samtykke indebærer, at den registreredes viljestilkendegivelse skal vedrøre præcis den pågældende behandling af oplysninger og ikke kan udledes af en viljeseerklæring, der har en anden genstand. Hjemmesidebesøgendes tryk på en knap for at deltage i en salgsmende konkurrence kunne derfor ikke udgøre et gyldigt samtykke til behandling af personoplysninger i form af placering af cookies (se dommens præmis 58 og 59).

Kravet om, at samtykket skal være informeret, indebærer en pligt for den dataansvarlige til at give den registrerede en række oplysninger i forbindelse med indhentningen af samtykket. Det følger således af forordningens præambelbetragtning 42, at den registrerede som minimum bør gøres bekendt med den dataansvarliges identitet og formålene med behandlingen (formålsangivelse er som nævnt ovenfor også en betingelse for, at samtykket er “specifikt”). Det er også et krav, at den

Informeret

registrerede oplyses, hvilke typer af oplysninger der behandles, jf. EU-Domstolens dom i C-61/19 (*Orange Romania*), præmis 40 og EDPB's retningslinjer 5/2020, pkt. 64. Efter art. 7, stk. 3, skal den registrerede endvidere oplyses om muligheden for at tilbagekalde samtykket, inden det indhentes.

Som nærmere beskrevet i afsnit 2.4 og 5 nedenfor, vil det være i strid med art. 5, stk. 1, litra a, at anvende samtykke som behandlingsgrundlag, hvis den dataansvarlige har tænkt sig at fortsætte behandlingen med hjemmel i et andet behandlingsgrundlag, såfremt den registrerede tilbagekalder samtykket. Det vil ikke være rimeligt, at den dataansvarlige stiller den registrerede i udsigt, at denne kan bringe behandlingen til ophør, hvis realiteten er, at den dataansvarlige vil fortsætte behandlingen, uanset om den registrerede tilbagekalder sit samtykke. Når den dataansvarlige ikke oplyser den registrerede herom, vil det endvidere kunne gøre samtykket ugyldigt, da der kan argumenteres for, at dette er en relevant oplysning, som den dataansvarlige bør have, når der indhentes samtykke.

Såfremt der i den konkrete situation er behov for at afgive yderligere oplysninger, for at den registrerede kan vurdere konsekvenserne af at give et samtykke, skal sådanne yderligere oplysninger også gives.

Kravene om, at samtykket skal være specifikt og informeret, skal sikre, at de registrerede ikke (gyldigt) giver samtykke til behandlinger af deres oplysninger, som de ikke kan overskue konsekvensen og rækkevidden af. Dette kan ses som et udtryk for forordningens grundlæggende princip om gennemsigtighed (transparens), jf. herved art. 5, stk. 1, litra a.

Gennemsigtighed

2.3. Utvetydigt

At samtykket skal være utvetydigt og i øvrigt efter samtykkedefinitionen have karakter af en viljestilkendegivelse, indebærer, at en stiltiende eller passiv accept af en behandling ikke kan danne grundlag for en behandling. Den dataansvarlige kan således ikke gøre den registrerede opmærksom på, at der vil ske en behandling af personoplysninger, medmindre den registrerede protesterer og herefter tage den registreredes tavshed som udtryk for et samtykke. Samtykket kræver en aktiv handling fra den registrerede. En "jeg accepterer"-boks på en hjem-

Forbud mod stiltiende og passivt samtykke

meside, der i standardopsætningen er markeret med et flueben, som den registrerede skal fjerne, vil eksempelvis ikke opfylde kravet om udtrykkeligt samtykke.

Se også forordningens præambelbetragtning 32: “Dette [afgivelse af samtykke] kan f.eks. foregå ved at sætte kryds i et felt ved besøg på et websted, ved valg af tekniske indstillinger til informationssamfundstjenester eller en anden erklæring eller handling, der tydeligt i denne forbindelse tilkendegiver den registreredes accept af den foreslåede behandling af vedkommendes personoplysninger. Tavshed, forudafkrydsede felter eller inaktivitet bør derfor ikke udgøre samtykke”. At et forudafkrydset felt ikke kan udgøre et gyldigt samtykke er også fastslået af EU-Domstolen i sagerne C-673/17 (*Planet49*) og C-61/19 (*Orange Romania*).

Det vil bero på en konkret vurdering, om den registreredes aktive handling har en sådan karakter, at der foreligger et utvetydigt samtykke. Er processen for afgivelsen af samtykket etableret på en måde, der skaber en klar sammenhæng mellem handlingen og viljen til at acceptere behandlingen af personoplysningerne, er kravet om utvetydighed opfyldt. Dette vil f.eks. være tilfældet, hvis det udtrykkeligt angives, at et tryk på en “jeg accepterer”-boks, indebærer et samtykke til behandlingen. Derimod er det mere tvivlsomt, om en handling, som ikke kun og eksplicit udtrykker vilje til at acceptere behandlingen af personoplysninger, men også har et andet formål, kan opfylde kravet om utvetydighed. Spørgsmålet har særlig betydning i de situationer, hvor den dataansvarlige udtrykkeligt gør opmærksom på, at brug af en ydelse vil udgøre et samtykke til behandling af personoplysninger.

Samtykke gennem brug af en ydelse

I en afgørelse fra 2008 (sag nr. 2007-212-0042) godkendte Datatilsynet en ordning, hvor deltagerne i en dagligvarekoncerns medlemsprogram ved at ibrugtage deres medlemskort accepterede, at koncernen behandlede oplysninger om deres køb. Medlemmerne var forudgående udtrykkeligt blevet informeret om, at brug af kortet blev anset for samtykke til persondatabehandlingen. Afgørelsen er afsagt under den tidligere persondatalov og har næppe præjudikatsværdi for forståelsen af forordningens krav om “utvetydighed”, men den er illustrativ for problemstillingen.

Forordningen tager ikke udtrykkeligt stilling til dette. Præambelbetragtning 32 anfører, at hvis den registreredes samtykke skal gives efter en elektronisk anmodning, skal anmodningen ikke “unødigt forstyrre brugen af den tjeneste, som samtykke gives til”. Betragtningen anfører endvidere, at tavshed og inaktivitet ikke bør udgøre samtykke. Hermed synes forordningen ikke at udelukke, at en aktiv handling, der indbærer brug af en ydelse, kan udgøre et samtykke, hvis den registrerede tilstrækkelig tydeligt er gjort opmærksom på dette. Som anført ovenfor har EU-Domstolen imidlertid i *Planet49-sagen* (C-673/17) fastslået, at den registreredes viljestilkendegivelse skal vedrøre præcis den pågældende behandling af personoplysninger og ikke kan udledes af en viljeserklæring, der har en anden genstand. Dette peger i retning af, at det ikke vil være muligt at give et gyldigt samtykke gennem brug af en ydelse.

Ved den konkrete vurdering vil det muligvis spille ind, hvor vanskeligt det havde været at indhente et samtykke gennem en erklæring, der alene udtrykte accepten af en persondatabehandling (f.eks. klik på en “jeg accepterer”-boks).

I retningslinjer 5/2020, pkt. 84, anfører EDPB, at den dataansvarlige skal sikre, at “[...] den handling, hvorved samtykke gives, kan skelnes fra andre handlinger. Derfor er en registrerets fortsatte normale anvendelse af et websted ikke en adfærd, hvoraf der kan udledes en viljestilkendegivelse, som viser, at den registrerede indvilger i en foreslået behandling.”

Der er gennem tiden set mange eksempler på, at en erklæring om samtykke til behandling af personoplysninger er blevet “begravet” i et sæt omfattende brugervilkår. Dette opfylder ikke kravet om “utvetydighed”. Forordningen forbyder ikke, at et samtykke kan indeholdes i en erklæring, der også vedrører andre forhold, men stiller krav til, at samtykkeerklæringen let skal kunne adskilles fra de øvrige forhold, jf. art. 7, stk. 2:

Hvis den registreredes samtykke gives i en skriftlig erklæring, der også vedrører andre forhold, skal en anmodning om samtykke forelægges på en måde, som klart kan skelnes fra de andre forhold, i en letforståelig og lettilgængelig form og i et klart og enkelt sprog. Enhver del af en så-

Samtykke i
brugervilkår

dan erklæring, som udgør en overtrædelse af denne forordning, er ikke bindende.

Kravet om, at samtykket skal være utvetydigt, indeholder ikke et krav til formen af samtykket, jf. art. 7, stk. 1. Et mundtligt samtykke vil have samme gyldighed som en skriftlig eller digital erklæring, men da det er den dataansvarlige, som har bevisbyrden for, at der er indhentet det fornødne samtykke, er det i praksis uhensigtsmæssigt at lade behandlingen bero på mundtlige samtykker.

Ingen formkrav

2.4. Tilbagekaldelse af samtykke

Det følger af art. 7, stk. 3, at et samtykke til enhver tid kan tilbagekaldes. Bestemmelsen har følgende ordlyd:

Den registrerede har til enhver tid ret til at trække sit samtykke tilbage. Tilbagetrækning af samtykke berører ikke lovligheden af den behandling, der er baseret på samtykke inden tilbagetrækningen. Inden der gives samtykke, skal den registrerede oplyses om, at samtykket kan trækkes tilbage. Det skal være lige så let at trække sit samtykke tilbage som at give det.

Tilbagekaldelsen indebærer det åbenbare, at der ikke længere er hjemmel i art. 6, stk. 1, litra a, til behandlingen (hvorimod de behandling, der hidtil har fundet sted, selvsagt ikke bliver ulovlige).

Potentielt vil behandlingen kunne være omfattet af et af de andre behandlingsgrundlag i art. 6, hvis den registrerede tilbagekalder samtykket. I så fald opstår spørgsmålet, om den dataansvarlige kan fortsætte behandlingen med hjemmel i et af disse øvrige behandlingsgrundlag. Som nærmere beskrevet nedenfor i afsnit 2.6 er samtykke ikke det korrekte behandlingsgrundlag, når den dataansvarlige ikke ønsker at afslutte behandlingen, selvom den registrerede trækker sit samtykke tilbage. Spørgsmålet er derfor, om den dataansvarlige kan skifte behandlingsgrundlag og fortsætte behandlingen med hjemmel i det behandlingsgrundlag, som den dataansvarlige burde have anvendt fra start af i stedet for samtykket.

Mulighed for fortsat behandling efter andet behandlingsgrundlag?

Det følgende er i forkortet form baseret på dele af min artikel "Konkurrerende behandlingsgrundlag – valg og skift af behandlingsgrundlag i

databeskyttelsesretten med særlig fokus på samtykke” trykt i Juristen, 2022, s. 83 ff. For en mere uddybende drøftelse henvises til artiklen.

I Rejsekortafgørelsen (sag nr. 2019-32-0709) udtalte Datatilsynet, at en dataansvarlig som udgangspunkt ikke kan skifte behandlingsgrundlag, efter behandlingen af personoplysninger er påbegyndt, og at et skifte af behandlingsgrundlag må anses som særlig problematisk, når behandlingen sker på baggrund af et samtykke, da dette er et udtryk for, at den registrerede gives et reelt valg og kontrol over behandlingen af dennes personoplysninger. Dette udgangspunkt er også fastslået i Datatilsynets samtykkevejledning, s. 16, og i EDPB's retningslinjer 5/2020 om samtykke, pkt. 122 og 123. Datatilsynet opstillet dog ikke et ubetinget forbud mod skift af behandlingsgrundlag i sin vejledning men anfører, at det i nogle tilfælde vil være muligt at fortsætte en behandling, selvom den registrerede har tilbagekaldt sit samtykke, hvis behandlingen er rimelig i forhold til den registrerede. I overensstemmelse hermed nåede Datatilsynet i Rejsekortsagen med henvisning til rimelighedskriteriet frem til, at Rejsekort efter art. 6, stk. 1, litra c, fortsatte kunne behandle klagerens oplysninger, efter samtykket var trukket tilbage, i det omfang dette var nødvendigt for at overholde bogføringsloven. Med anvendelsen af rimelighedskriteriet må det antages, at Datatilsynet også i spørgsmålet om skift af behandlingsgrundlag tager udgangspunkt i art. 5, stk. 1, litra a. Datatilsynet, og formentlig også EDPB, synes med andre ord at opstille det udgangspunkt, at det vil være i strid med art. 5, stk. 1, litra a, at skifte behandlingsgrundlag, når der startes i det forkerte behandlingsgrundlag, men at skiftet i nogle situationer vil kunne være rimeligt overfor den registrerede og dermed ikke i strid med art. 5, stk. 1, litra a.

Med denne tilgang opnås en høj grad af fleksibilitet men også en høj grad af usikkerhed i vurderingen af, om et skift af behandlingsgrundlag kan finde sted. Meget taler for, at man i stedet kan lade spørgsmålet besvare med udgangspunkt i art. 17 om sletning.

Ved behandling af spørgsmålet om skift af behandlingsgrundlag, er det således en vigtig pointe, at et forbud mod skift af behandlingsgrundlag er ikke det samme som et forbud mod generelt at behandle de omhandlede personoplysninger. Den dataansvarlige kan vælge at indsamle oplysningerne igen og starte en ny behandling. Et eventuelt

– Datatilsynet og EDPB

Art. 17

forbud mod skift af behandlingsgrundlag retter sig med andre ord mod den eller de *konkrete kopier* af oplysningerne, som den dataansvarlige har indsamlet og opbevarer med hjemmel i den registreredes (nu tilbagetrukne) samtykke. Det er således spørgsmålet, om behandlingen må fortsætte på baggrund af disse kopier. Hermed bliver der en tæt sammenhæng mellem spørgsmålet om skift af behandlingsgrundlag og den registreredes ret til at kræve sletning af oplysninger: Hvis den registrerede kan kræve (kopierne af) oplysningerne slettet, når et samtykke trækkes tilbage, vil den dataansvarlige allerede af den grund være afskåret fra at fortsætte behandlingen på baggrund af et andet behandlingsgrundlag. Og hvis den registrerede ikke kan kræve sletning af oplysninger, vil det typisk være fordi, den dataansvarlige har et anerkendt behov for fortsat behandling af oplysningerne.

Dermed samler interessen sig om, hvornår der kan kræves sletning af oplysninger efter art. 17: når dette er tilfældet, har lovgiver ikke ønsket, at det skulle være muligt at fortsætte behandlingen. Og når art. 17 omvendt tillader fortsat opbevaring, selvom den registrerede har trukket sit samtykke tilbage, taler meget for, at lovgiver har ønsket, at der fortsat skulle kunne ske behandling, når der eksisterer et andet behandlingsgrundlag.

Art. 17, stk. 1, litra b, fastslår, at den dataansvarlige er forpligtet til at slette oplysninger om den registrerede, når denne trækker et samtykke tilbage, *“og der ikke er et andet retsgrundlag for behandlingen”*. Umiddelbart kunne det fremhævede give indtryk af, at den registrerede ikke kan kræve sletning, når der er et andet behandlingsgrundlag, som den dataansvarlige kan vælge i stedet for, og at den dataansvarlige derfor altid kan fortsætte behandlingen i denne situation. Sådan skal bestemmelsen dog næppe forstås. Bestemmelsen kan ikke antages at tage stilling, om den dataansvarlige kan fortsætte en behandling, når samtykket trækkes tilbage, men blot at *hvis* det er muligt at fortsætte behandlingen (efter forordningens øvrige regler), er der ikke pligt til at slette oplysningerne.

Mens art. 17, stk. 1, litra b, således ikke kan antages at give svaret på, om en dataansvarlig kan fortsætte behandlingen, efter samtykket er trukket tilbage, kan svaret formentlig udledes af art. 17, stk. 3. Bestemmelsen fastslår, at art. 17, stk. 1 og 2 (om den dataansvarliges pligt til at slette oplysninger) ikke finder anvendelse, i det omfang behand-

lingen er nødvendig i nærmere angivne situationer. Dette omfatter efter art. 17, stk. 3, litra b, overholdelse af en retlig forpligtelse eller udførelse af en opgave i samfundets interesse eller som henhører under offentlig myndighedsudøvelse, hvilket svarer til behandlingsgrundlagene i art. 6, stk. 1, litra c og e. Sletning skal endvidere efter art. 17, stk. 3, litra e, ikke ske, hvis behandlingen er nødvendig for at et retskrav kan fastlægges, gøres gældende eller forsvares.

Udover de anførte situationer, omfatter art. 17, stk. 3, også behandlinger, der er nødvendige for at udøve retten til ytrings- og informationsfrihed, af hensyn til samfundsinteresser på folkesundhedsområdet, til arkivformål i samfundets interesse, til videnskabelige og historiske forskningsformål og til statistiske formål i overensstemmelse med art. 89.

Den direkte virkning af art. 17, stk. 3, er, at den dataansvarlige i de angivne situationer er berettiget til fortsat at *opbevare* oplysningerne, selvom den registrerede trækker sit samtykke tilbage. Som anført må det imidlertid antages, at bestemmelsen også indebærer, at den dataansvarlige derudover kan foretage den behandling af oplysningerne, der er nødvendig for at forfølge de angivne formål (overholdelse af retlig forpligtelse, varetagelse af myndighedsopgave eller varetagelse af retskrav). Derimod kan det ikke antages, at den dataansvarlig kan fortsætte behandlingen af oplysningerne i situationer, der ikke er omfattet af art. 17, stk. 3.

Samlet set fører disse betragtninger til, at den dataansvarlige kan skifte behandlingsgrundlag og fortsætte behandlingen, når den registrerede trækker et samtykke tilbage, hvis behandlingen er nødvendig for at overholde en retlig forpligtelse (litra c) eller varetage offentlig myndighedsudøvelse eller en opgave i samfundets interesse (litra e). Den dataansvarlige er omvendt afskåret fra at skifte behandlingsgrundlag, hvis den fortsatte behandling kun kan hjemles i litra b (kontrakt) eller litra f (interesseafvejning), medmindre behandlingen er nødvendig for at fastlægge, forfølge eller forsvare et aktuelt eller sandsynligt retskrav.

Konklusion

2.5. Børns samtykke

Børn har brug for en særlig beskyttelse af deres personoplysninger, bl.a. fordi de ikke er i stand til at gennemskue konsekvenserne af en behandling på samme måde, som voksne er. Det særlige beskyttelsesbehov er udtrykt i forordningens præambelbetragtning 38:

Børn bør nyde særlig beskyttelse af deres personoplysninger, eftersom de ofte er mindre bevidste om de pågældende risici, konsekvenser og garantier og deres rettigheder for så vidt angår behandling af personoplysninger. En sådan særlig beskyttelse bør navnlig gælde for brug af børns personoplysninger med henblik på markedsføring eller til at oprette personligheds- eller brugerprofiler og indsamling af personoplysninger vedrørende børn, når de anvender tjenester, der tilbydes direkte til et barn. Samtykke fra indehaveren af forældremyndigheden er ikke nødvendigt, når det drejer sig om forebyggende eller rådgivende tjenester, der tilbydes direkte til et barn.

Det særlige beskyttelsesbehov og børns begrænsede evne til at gennemskue konsekvenserne af en persondatabehandling har ikke mindst betydning i relation til afgivelsen af samtykke.

2.5.1. Samtykke til informationssamfundstjenester udbudt direkte til børn

Forordningen indeholder i art. 8 en særbestemmelse om børns samtykke i forbindelse med informationssamfundstjenester. Bestemmelsen har følgende ordlyd:

1. Hvis artikel 6, stk. 1, litra a), finder anvendelse i forbindelse med udbud af informationssamfundstjenester direkte til børn, er behandling af personoplysninger om et barn lovlig, hvis barnet er mindst 16 år. Er barnet under 16 år, er sådan behandling kun lovlig, hvis og i det omfang samtykke gives eller godkendes af indehaveren af forældremyndigheden over barnet.

Medlemsstaterne kan ved lov fastsætte en lavere aldersgrænse til disse formål, forudsat at en sådan aldersgrænse ikke er under 13 år.

2. Under hensyntagen til den tilgængelige teknologi skal den dataansvarlige gøre sig rimelige bestræbelser på i sådanne tilfælde at kon-

trollere, at indehaveren af forældremyndigheden over barnet har givet eller godkendt samtykket.

3. Stk. 1 berører ikke medlemsstaternes generelle aftaleret, som f.eks. bestemmelser om gyldighed, indgåelse eller virkning af en kontrakt, når der er tale om et barn.

I Danmark er muligheden for at fastsætte en lavere aldersgrænse udnyttet, således at et gyldigt samtykke i henhold til art. 8 kan afgives af børn, der er fyldt 13 år, jf. DBL § 6, stk. 2. De almindelige betingelser for samtykkets gyldighed skal fortsat være opfyldt, jf. den indledende henvisning til art. 6, stk. 1, litra a.

Bestemmelsen gælder i forbindelse med “udbud af informations-samfundstjenester direkte til børn”. Det følger af forordningens art. 4, nr. 25, at begrebet “informations-samfundstjeneste” skal forstås i overensstemmelse med definitionen i direktiv 2015/1535, dvs. en tjeneste, der normalt ydes mod betaling og leveres via elektronisk databehandlingsudstyr via individuel anmodning, uden at parterne er til stede samtidig. Det er ikke et ubetinget krav, at der skal betales for tjenesten, og sociale medier og andre internettjenester, der stilles til rådighed uden betaling, vil også kunne udgøre en informations-samfundstjeneste. Det er i høj grad denne type tjenester, som art. 8 tager sigte på.

Informations-
samfundstjeneste

Kravet om, at tjenesten skal være udbudt direkte til børn, må antages at være opfyldt, hvis det eksplicit fremgår, at personer under 18 år kan bruge tjenesten, f.eks. ved at sætte en aldersgrænse for brugere på under 18 år. Tilsvarende hvis tjenesten efter sit indhold retter sig mod børn (eksempelvis et spilleunivers for børn). Det må endvidere kunne tillægges vægt, hvis et stort antal af tjenestens brugere er børn, uanset at tjenesten ikke direkte angiver aldersgrænser og også har voksne brugere.

Udbudt direkte
til børn

I retningslinjer 5/2020, pkt. 130, anfører EDPB, at en tjeneste ikke anses for udbudt direkte til børn, hvis det fremgår klart, at tjenesten kun udbydes til brugere over 18 år. Dette resultat er åbenbart, men det kan ikke omvendt antages, at tjenester altid er rettet direkte mod børn, hvis ikke de indeholder en eksplicit aldersgrænse på 18 år.

Det følger af de indledende ord til art. 8, stk. 1, at bestemmelsen gælder, “hvis art. 6, stk. 1, litra a, finder anvendelse”. Som nævnt ovenfor har det tidligere været opfattelsen i Danmark, at art. 6 alene udgjorde hjemmelsgrundlaget for behandling af almindelige oplysninger, mens art. 9 udgjorde grundlaget for behandling af følsomme oplysninger. Med en sådan forståelse af forholdet mellem art. 6 og 9 ville konsekvensen være, at art. 8 med sin henvisning til art. 6, stk. 1, litra a, alene omhandlede almindelige oplysninger. Eftersom det nu må lægges til grund, at art. 6 omfatter både almindelige og følsomme oplysninger, må det imidlertid antages, at art. 8 både omfatter børns samtykke til almindelige og følsomme oplysninger.

Følsomme
oplysninger

Er tjenesten omfattet af art. 8, skal tjenesteudbyderen indhente samtykke fra barnets forælder, hvis ikke barnet har den angivne minimumsalder.

Det kan i praksis være vanskeligt for tjenesteudbyderen at kontrollere barnets alder og også, om den angivne forælder rent faktisk har forældremyndigheden. I art. 8, stk. 2, er anført, at tjenesteudbyderen under hensyn til den tilgængelige teknologi skal gøre sig rimelige bestræbelser på at kontrollere, at indehaveren af forældremyndigheden har givet samtykke. Det samme princip må antages at gælde for kontrollen af barnets alder, jf. nærmere retningslinjer 5/2020, pkt. 132.

Kontrol af alder
og forældremyn-
dighed

2.5.2. Samtykke i øvrigt

Forordningens art. 8 vil dække mange af de praktisk vigtige samtykkesituationer for børn, men i alle de situationer, hvor barnet giver samtykke til en databehandler, som ikke udbyder en informationsamfundstjeneste direkte til børn, afgøres samtykkets gyldighed ikke af art. 8.

I disse situationer vil spørgsmålet om gyldigheden af barnets samtykke skulle behandles efter forordningens almindelige samtykkeregler. Forordningen indeholder således ingen generelle regler om børns samtykke. Kravene til de almindelige samtykkebetingelser som gennemgået ovenfor påvirkes imidlertid af, at samtykket afgives af et barn. Informationskravet forudsætter således, at informationen gives på en måde, så den kan forstås af et barn, jf. herved forordningens præambelbetragtning 58 (“eftersom børn bør nyde særlig beskyttelse, bør alle oplysninger og meddelelser, hvis behandling er rettet mod et barn, væ-

re i et så klart og enkelt sprog, at et barn let kan forstå dem”). Uanset informationens tydelighed kan barnet have en så lav alder, at barnet ikke kan forventes at overskue konsekvenserne af samtykket. I så fald må det lægges til grund, at barnet ikke kan give et gyldigt samtykke. Ved denne vurdering vil den aldersgrænse, som er fastsat i henhold til art. 8, nok kunne spille en rolle. Såfremt barnet ikke gyldigt kan give et samtykke, forudsætter lovlig behandling efter art. 6, stk. 1, litra a, at samtykke afgives af barnets forælder på samme måde som efter art. 8.

2.6. Konkurrence mellem samtykke og andre behandlingsgrundlag

Da samtykkebestemmelsen i art. 6, stk. 1, litra a, ikke er afgrænset til bestemte typer af behandling, kan den dataansvarlige potentielt indhente samtykke til alle former for behandling, herunder også behandlinger, der er omfattet af de øvrige behandlingsgrundlag i art. 6. Der opstår hermed en form for “konkurrence” mellem samtykket og andre behandlingsgrundlag, og spørgsmålet bliver da, om den dataansvarlige frit kan vælge mellem samtykket og andre mulige behandlingsgrundlag, eller om der består en form for forrang, således at den dataansvarlige enten skal anvende samtykke frem for det andet mulige behandlingsgrundlag eller omvendt, at det andet behandlingsgrundlag skal anvendes frem for samtykket.

Den følgende drøftelse af disse spørgsmål er baseret på min [artikel](#) “Konkurrerende behandlingsgrundlag – valg og skift af behandlingsgrundlag i databeskyttelsesretten med særlig fokus på samtykke” trykt i Juristen, 2022, s. 83 ff.

I en række lande har det, i hvert fald under det tidligere persondatadirektiv, været opfattelsen, at samtykket var et primært grundlag, og at den dataansvarlige skulle starte med at forsøge at opnå samtykke fra den registrerede, inden andre behandlingsgrundlag eventuelt blev anvendt. Denne opfattelse er imidlertid ikke korrekt og er formentlig heller ikke opretholdt i nogen medlemsstater længere.

Tværtimod viser praksis fra Datatilsynet og vejledninger fra både tilsynet og EDPB, at dataansvarlige i de fleste tilfælde skal vælge et af

Samtykke ikke et primært behandlingsgrundlag

EDPB og Datatilsynet: samtykke ofte et sekundært behandlingsgrundlag

de andre behandlingsgrundlag, når dette kan hjemle behandlingen, og dermed undlade at indhente samtykke fra den registrerede.

I sine retningslinjer 5/2020 om samtykke anfører EDPB således (pkt. 122), at “hvis en dataansvarlig vælger at basere en bestemt del af behandlingen på samtykke, skal den dataansvarlige, hvis den registrerede trækker sit samtykke tilbage, være klar til at respektere dette valg og indstille behandlingen. Det ville være urimeligt over for de registrerede at udsende en meddelelse om, at deres oplysninger vil blive behandlet på grundlag af samtykke, hvis de rent faktisk behandles ud fra et andet retsgrundlag”. Når EDPB anfører, at det vil være “urimeligt” overfor den registrerede at vælge samtykke som behandlingsgrundlag, kobler EDPB hermed valget til forordningens art. 5, stk. 1, litra a, om lovlighed, rimelighed og gennemsigtighed.

Tilsvarende anføres det i Datatilsynets samtykkevejledning (s. 16), at et samtykke efter databeskyttelsesforordningen er udtryk for, at de registrerede gives et reelt valg og kontrol over, hvordan deres personoplysninger behandles, og at den dataansvarlige derfor som udgangspunkt ikke kan skifte behandlingsgrundlag, hvis den registrerede trækker sit samtykke tilbage (jf. herom i afsnit 2.5 nedenfor).

Synspunktet ligger også til grund for Datatilsynets afgørelse i Rejsekortsagen (sag nr. 2019-32-0709), hvor tilsynet som begrundelse for, at andre behandlingsgrundlag var klart mere passende end samtykke anførte følgende: “Datatilsynet har ved sin vurdering tillagt det væsentlig betydning, at en dataansvarlig som altovervejende udgangspunkt ikke bør skifte behandlingsgrundlag, efter behandlingen af personoplysninger er påbegyndt. I den henseende må et skift af behandlingsgrundlag anses som særlig problematisk, når behandlingen sker på baggrund af et samtykke, da et samtykke efter databeskyttelsesforordningen er et udtryk for, at de registrerede gives et reelt valg og kontrol over, hvordan deres oplysninger behandles. Rejsekort har således ved anvendelse af samtykke som behandlingsgrundlag givet klager en forventning om, at klager havde kontrol over behandlingen af personoplysninger om hende”. Datatilsynet fastslog på denne baggrund, at Rejsekort havde overtrådt forordningens art. 5, stk. 1, litra a, om lovlighed, rimelighed og gennemsigtighed, idet samtykke ikke kunne anses for det mest passende behandlingsgrundlag. Datatilsynet udleder

med andre ord af denne bestemmelse en pligt til at anvende det mest passende blandt flere mulige behandlingsgrundlag.

Med Rejsekortsagen og de anførte vejledninger ligger det fast, at Datatilsynet og EDPB finder det i strid med forordningens art. 5, stk. 1, litra a, hvis den dataansvarlige vælger samtykke som behandlingsgrundlag, når den dataansvarlig agter at fortsætte behandlingen, efter den registrerede har tilbagekaldt sit samtykke. Det forekommer rigtigt, at den dataansvarlige i denne situation ikke bør vælge samtykke men i stedet det alternative behandlingsgrundlag. Som fremhævet af både Datatilsynet og EDPB, vil det ikke være rimeligt overfor den registrerede at foregive, at denne selv vælger, hvor lang tid behandlingen skal fortsætte, hvis dette i realiteten ikke er tilfældet.

Når en dataansvarlig inden en behandling overvejer sit behandlingsgrundlag, herunder samtykke, må den dataansvarlige derfor spørge sig selv, om den pågældende vil ophøre med behandlingen, hvis den registrerede anmoder om det. Kan den dataansvarlige ikke svare ja til dette spørgsmål, må der vælges et andet behandlingsgrundlag end samtykke. I mange situationer, vil den dataansvarlige være nødsaget til at fortsætte behandlingen, selvom samtykket tilbagekaldes, hvorfor den dataansvarlige ikke bør anvende samtykke som behandlingsgrundlag.

Det vil for det første gælde den situation, hvor den dataansvarlige efter lovgivningen er underlagt en pligt til at foretage behandlingen. I denne situation har hverken den dataansvarlige eller den registrerede kompetence til at beslutte, at behandlingen skal ophøre. Dette omfatter *litra c* om behandlinger, der er nødvendige for at overholde en retlig forpligtelse, som påhviler den dataansvarlige. Det vil som regel også være tilfældet, når behandlingen efter *litra e* er nødvendig af hensyn til udførelsen af en opgave i samfundets interesse eller som henhører under offentlig myndighedsudøvelse, som den dataansvarlige har fået pålagt. Er en offentlig myndighed nødt til at behandle personoplysninger for at kunne varetage sine myndighedsopgaver, vil myndigheden normalt ikke kunne vælge at undlade behandlingen og dermed ikke varetage den pågældende opgave.

Det vil også gælde i den situation, hvor behandlingen er nødvendig, for at den dataansvarlige kan opfylde en aftale med den registrerede efter *litra b*. Medmindre den registreredes tilbagekaldelse af sit

Afgørende om den dataansvarlige agter at fortsætte behandlingen efter tilbagetrækning af samtykke

I hvilke situationer vil den dataansvarlige fortsætte behandlingen?

samtykke bringer aftalen til ophør, hvad der ikke afgøres af databeskyttelsesretten men af aftaleretten, vil det fortsat være nødvendigt for den dataansvarlige at behandle oplysninger for at kunne opfylde sine aftaleforpligtelser. I denne situation bør den dataansvarlige derfor heller ikke bruge samtykke som behandlingsgrundlag. Selv i situationer, hvor en tilbagekaldelse af samtykke vil bringe aftalen til ophør efter aftaleretten, og den dataansvarlige derfor ikke vil have behov for at behandle oplysningerne efter samtykkets tilbagekaldelse, vil samtykke ikke være det bedst egnede behandlingsgrundlag. Et samtykke skal kunne tilbagekaldes, uden det har negative konsekvenser for den registrerede. Dette krav kan vanskeligt siges at være opfyldt, hvis konsekvensen af en tilbagekaldelse er, at aftalen ophører. Dette kan også formuleres sådan, at den dataansvarlige ikke bør kunne anvende samtykke og oplyse om, at samtykket til enhver tid kan trækkes tilbage, men i realiteten betinge aftalen af, at den registrerede ikke tilbagekalder sit samtykke. Det vil være mere retvisende og dermed også mere gennemsigtigt, at den dataansvarlige oplyser om, at behandlingen vil fortsætte, så længe det er nødvendigt for at opfylde forpligtelserne under aftalen og regulere spørgsmålet om aftalens varighed uafhængigt af spørgsmålet om behandlingen af personoplysninger. EDPB har tilsvarende anført, at når “en dataansvarlig forsøger at behandle personoplysninger, der rent faktisk er nødvendig af hensyn til opfyldelsen af en kontrakt, så er samtykke ikke det passende retsgrundlag” (retningslinjer 2/2019, pkt. 19). Det må på den baggrund antages, at samtykke ikke er det bedst egnede behandlingsgrundlag, når behandlingen kan hjemles i litra b.

Hvis det konkurrerende behandlingsgrundlag udgøres af interesseafvejningsreglen i *litra f*, vil den dataansvarlige ikke være forpligtet, hverken efter lovgivning eller aftale, til at behandle oplysningerne. Hvis den dataansvarlige i denne situation ikke har til hensigt at standse behandlingen, selvom den registrerede anmoder om det, bør den dataansvarlige ikke give den registrerede indtryk heraf og bør i stedet anvende interesseafvejningsreglen, jf. således også Datatilsynets samtykkevejledning, s. 16. Vil den dataansvarlige indstille behandlingen, når den registrerede trækker sit samtykke tilbage, vil samtykket kunne anvendes, og vil ofte også være det bedst egnede behandlingsgrundlag, da muligheden for at bringe behandlingen til ophør gøres

tydelig for den registrerede. Praktiske vanskeligheder ved at indhente samtykket eller andre omstændigheder kan dog gøre, at interesseafvejningsreglen vil være et mere egnet behandlingsgrundlag i den konkrete situation.

Samlet set fører disse betragtninger til, at samtykke ikke vil være det korrekte behandlingsgrundlag, når behandlingen er omfattet af et af de specifikke behandlingsgrundlag i litra b, c eller e. Kan behandlingen hjemles i interesseafvejningsreglen, vil samtykke kun være et korrekt behandlingsgrundlag, hvis den dataansvarlig vil standse behandlingen ved den registreredes tilbagetrækning af samtykket. Dette kan også udtrykkes således, at den dataansvarlige kun bør anvende samtykke som behandlingsgrundlag i de situationer, hvor samtykket enten er det eneste mulige behandlingsgrundlag eller, hvor behandlingen også kan hjemles i interesseafvejningsreglen, men hvor den dataansvarlige vil lade den registrerede til enhver tid have mulighed for at bringe behandlingen til ophør. Hermed bliver samtykket i realiteten et sekundært behandlingsgrundlag i de situationer, hvor der består konkurrerende behandlingsgrundlag.

Samlet konklusion

3. Specifikke former for behandling – art. 6, stk. 1, litra b-e

3.1. Opfyldelse af en kontrakt – art. 6, stk. 1, litra b

Efter litra b kan behandlingen ske, når den er nødvendig af hensyn til opfyldelsen af en kontrakt, som den registrerede er part i, eller for at gennemføre foranstaltninger forud for en sådan aftale (f.eks. afsendelse af tilbud forud for aftalen). Bestemmelsen indebærer, at en virksomhed kan behandle de oplysninger om sine kunder, som er nødvendige for at kunne gennemføre aftaleforholdet. Ved forsendelse af varer skal den erhvervsdrivende kende kundens adresse, og ved køb over nettet skal der sendes en e-mail med en ordrebekræftelse og faktura. Bestemmelsen medfører, at den erhvervsdrivende ikke behøver anmode om samtykke i disse situationer, men kan opbevare og behandle oplysningerne med hjemmel i art. 6, stk. 1, litra b.

Bestemmelsen omfatter også aftaleforholdet mellem en ansat og arbejdsgiver, og udstyrer således arbejdsgiveren med ret til at behandle de oplysninger om den ansatte, som ansættelsesforholdet betinger, herunder kontooplysninger med henblik på lønudbetalinger, ferieperioder mv.

Se nærmere herom Korfits Nielsen & Lotterup, Databeskyttelsesforordningen og databeskyttelsesloven med kommentarer, s. 354 ff.

En første forudsætning for at anvende litra b som behandlingsgrundlag er, at der foreligger en "kontrakt" mellem den dataansvarlig og den registrerede. Oftest er det åbenbart, at der foreligger en kontrakt mellem parterne, som når der f.eks. indgås en købsaftale, en ansættelsesaftale eller en forsikringsaftale. I enkelte situationer kan det dog være tvivlsomt, om relationen mellem den dataansvarlig og den registrerede har karakter af en "kontrakt" i bestemmelsens forstand.

"Kontrakt"

Datatilsynets afgørelse i sag 2018-31-0118 er et eksempel herpå. I sagen havde klageren optrådt som model for indklagede, der var professionel fotograf. Klageren havde ikke modtaget betaling for billederne, hvoraf nogle var af en mere intim karakter. Der var mellem parterne indgået en skriftlig aftale, der gav fotografen ret til at bruge og offentliggøre billederne. Nogle af de intime billeder var efterfølgende blevet brugt af tredjeparter bl.a. i forbindelse med escort-annoncer. Fotografen afviste at slette billederne og undlade fortsat tilgængeliggørelse af dem, medmindre klageren betalte 5.000 kr. for at ophæve kontrakten. Klageren gjorde gældende, at behandlingen ikke havde hjemmel i litra b men i litra a om samtykke, og at fotografen derfor var forpligtet til at slette billederne, da klageren trak samtykket tilbage. Datatilsynet fandt, at der var indgået en kontrakt mellem parterne i litra b's forstand og lagde herved vægt på, det fremgik af aftalen, at der var tale om en "Universal Adult Model Release for all Agencies", at aftalen "Shall be binding upon me my heirs, legal representatives and assigns", og at klageren ved at skrive under på aftalen havde bekræftet, at "I hereby affirm that I am over the age of majority and have the right to contract in my own name".

sag 2018-31-0118
– model-
kontrakten

Datatilsynets afgørelse viser, at der godt kan foreligge en kontrakt mellem den dataansvarlige og den registrerede, selvom der ikke sker en udveksling af ydelser. Det fremgår af sagen, at klageren ikke fik be-

– ikke krav om
modydelse

taling for modelarbejdet, og det anføres heller ikke, at klageren fik andre ydelser, f.eks. gratis billeder, som modydelse for arbejdet. Datatilsynet lagde heller ikke vægt på dette forhold i sin afgørelse. På tilsvarende vis vil der også kunne foreligge en kontrakt, når den dataansvarlige stiller en ydelse til rådighed for den registrerede, uden at denne skal præstere en betaling eller anden form for modydelse.

I sin afgørelse lagde Datatilsynet vægt på, at aftalen angav at være bindende for den registrerede, og at denne bekræftede at være myndig og have ret til at indgå aftale i eget navn. Dette er nok udtryk for, at der foretages en samlet vurdering af, om forholdet har karakter af et kontraktforhold, og hvilke forventninger parterne med rimelighed kunne have ud fra alt foreliggende. I denne vurdering tilægges det vægt, hvis den registrerede har tiltrådt et dokument, hvis indhold er formuleret som en kontrakt mere end eksempelvis som en samtykkeerklæring.

– helheds-
vurdering

At der foreligger et skriftligt dokument mellem parterne, der nærmere angiver, hvad den registrerede accepterer, indebærer ikke i sig selv, at der foreligger en kontrakt i litra b's forstand. Indhentelse af samtykke efter litra a vil oftest også ske ved den registreredes accept af et skriftligt samtykkedokument. Datatilsynet begrundes således heller ikke sin afgørelse alene med det faktum, at der foreligger en skriftlig aftale mellem parterne men på indholdet af denne.

Det er endvidere en forudsætning for anvendelsen af litra b, at behandlingen er "nødvendig" for at opfylde kontrakten. Udgangspunktet for vurderingen heraf er den ydelse, som den dataansvarlige skal levere under kontrakten. En webshop må behandle oplysninger om kunders kreditkort og forsendelsesadresse men må ikke foretage en profilering af kundens købsinteresser med hjemmel i litra b. Denne profilering er ikke nødvendig for at kunne opfylde den købsaftaler, der indgås med kunden. Den dataansvarlige vil i et vist omfang kunne påvirke rummet for behandling efter litra b gennem sin beskrivelse af ydelsen. Hvis webshoppen slår sig op på at give særligt gode og individualiserede tilbud til kunderne baseret på deres specifikke præferencer, kan man med nogen ret anføre, at profileringen er nødvendig for at kunne levere denne ydelse.

"Nødvendig"

Den dataansvarlige kan dog ikke udvide rummet for behandlingen blot ved at angive en specifik behandling i kontrakten eller udvide ydelsesbeskrivelsen alene med det formål at opnå hjemmel til en behandling, der ikke er nødvendig for opfyldelse af aftalens reelle ydelse. Eller som formuleret i EDPB's retningslinjer 2/2019, pkt. 31: "En kontrakt kan ikke kunstigt udvide kategorierne for personoplysninger eller typer af behandlingsaktiviteter, som den dataansvarlige har brug for for at opfylde kontrakten, som omhandlet i artikel 6, stk. 1, litra b)."

EDPB afviser ret kategorisk, at litra b kan anvendes til behandling som led i profilering og adfærdsbaseret markedsføring, se retningslinjer 2/2019, pkt. 51-56.

I vurderingen af, om en behandling er nødvendig for at opfylde kontrakten, skal der ifølge retningslinjer 2/2019 tages udgangspunkt i kontraktens grundlæggende natur og formål og ydelsens kerneindhold. Vejledningen opregner en række spørgsmål, der kan inddrages i vurderingen (pkt. 33):

– kriterier

- Hvilken art tjeneste leveres til den registrerede? Hvad er dens karakteristiske egenskaber?
- Hvad er den præcise begrundelse for kontrakten (dvs. dens indhold og grundlæggende målsætning)?
- Hvad er de væsentlige aspekter af kontrakten?
- Hvilke gensidige perspektiver og forventninger har kontraktparterne? Hvordan promoveres eller annonceres tjenesten for den registrerede? I betragtning af tjenestens art, ville en almindelig bruger af tjenesten med rimelighed forvente, at den påtænkte behandling finder sted med henblik på opfyldelse af kontrakten, som brugeren er part i?

Vanskelighederne ved at fastlægge, hvad der udgør ydelsen, og dermed hvilke behandlinger, der opfylder nødvendighedskravet under litra b, illustreres af en sag mellem Max Schrems og Facebook/Meta, der verserer for EU-Domstolen. I sagen har Facebook/Meta gjort gældende at kunne behandle brugernes personoplysninger med henblik på profilering og adfærdsbaseret annoncering med hjemmel i litra b, idet det fremgår af Facebooks/Metas brugerbetingelser, at brugerne vil modtage

målrettet annoncering. Schrems har gjort gældende, at dette blev indsat i brugerbetingelserne samtidig med, at forordningen fik virkning, alene med det formål, at Facebook/Meta kunne omgå forordningens samtykkekrav. Det forekommer sandsynligt, at Domstolen vil afvise Facebooks forsøg på at konstruere en kontraktuel forpligtelse til at levere adfærdsbaseret annoncering.

Bestemmelsen gælder for “opfyldelse” af kontrakten. Heri ligger, at bestemmelsen som udgangspunkt ikke kan anvendes som hjemmelsgrundlag for behandlinger, der foretages efter kontrakten er opfyldt og dermed ophørt. Hvis den dataansvarlige eksempelvis er forpligtet til at opbevare oplysninger om salg i fem år efter bogføringsloven, kan denne opbevaring ikke hjemles i litra b (men i litra c om behandling, der er nødvendig for at overholde en retlig forpligtelse). Nogle kontraktuelle forpligtelser kan bestå efter ydelserne er udvekslet og kontrakten dermed opfyldt. Er ydelsen mangelfuld, vil køberen potentielt kunne gøre mangelsindsigelser gældende i en periode efter købet. Periodens længde afhænger af de obligationsretlige reklamationsregler, forældelsesregler og parternes aftale, herunder om der er afgivet garanti af sælgeren. Den dataansvarlige må efter litra b kunne opbevare oplysninger, der er nødvendige for at behandle en mangelsindsigelse fra køberen, jf. således også retningslinjer 2/2019, pkt. 38 og 39, der nævner fejlrettelse og garantiforpligtelser.

Behandling efter
kontrakts
ophør

I sag nr. 2019-32-0709 (Rejsekort) afviste Datatilsynet, at Rejsekort A/S kunne fortsætte behandlingen af oplysninger om en kunde med hjemmel i litra b, efter kunden have opsagt aftaleforholdet. Rejsekort havde anført, at den fortsatte opbevaring var nødvendig bl.a. for at kunne dokumentere foretagne rejsetransaktioner ved en eventuel efterfølgende indsigelse fra kunden. I sin afgørelse lagde Datatilsynet imidlertid vægt på, at Rejsekort uberettiget havde skiftet behandlingsgrundlag fra samtykke (litra a) til kontrakt (litra b) og anførte, at “[I] hvert fald under de konkrete omstændigheder, hvor Rejsekort fejlagtigt har anvendt samtykke som behandlingsgrundlag, finder Datatilsynet, at hensynet til den registrerede går forud for Rejsekorts interesse i at opbevare oplysninger med henblik på håndtering af et eventuelt retskrav”. Afgørelsen kan derfor ikke tages til indtægt for, at det generelt ikke er muligt efter kontraktens ophør at opbevare oplysninger med hjemmel i litra b for at kunne håndtere en eventuelt kontraktindsigelse fra den registrerede.

Ikke enhver teoretisk pligt til at foretage mangelsafhjælpning kan dog begrunde fortsat opbevaring under litra b. Sælgeren, der giver livstidsgaranti på sine støbejernsgryder, kan ikke af den grund opbevare oplysninger om sine kunder i al evighed. I vurderingen af, om der kan ske fortsat opbevaring kan bl.a. lægges vægt på længden af afhjælpningsperioden, sandsynligheden for at sælgeren mødes med mangelsindsigelser, de potentielle økonomiske konsekvenser heraf og oplysningernes karakter. Almindelige kunde- og købsoplysninger må kunne opbevares inden for den frist, der gælder efter baggrundsretten, som er to år efter købeloven og tre år efter forældelsesloven. Om oplysningerne kan opbevares i en længere periode, hvis der er afgivet en længerevarende garanti, må bero på en konkret vurdering.

I ILVA-sagen (sag 13-3662/2020) fandt byretten i Aarhus ikke, at art. 6 kunne hjemle en opbevaring af oplysninger efter udløbet af 5-årsfristen i bogføringsloven, selvom enkelte produkter var undergivet en længere garanti. Retten anførte, at en længere garantiperiode ikke nødvendigvis gjorde en længere opbevaringsfrist, da det i første række var op til kunderne selv at dokumentere deres ret. Det synes dog rimeligt, at sælgeren også har mulighed for selv at kontrollere de oplysninger, som køberen måtte komme med. Det er jo ikke sikkert, at køberen oplyser sagen fuldt ud (og f.eks. medsender eventuelle begrænsninger i garantien). Afgørelsen skal nok læses i lyset af, at der var afgivet nogle meget lange garantier (op til 25 år) på nogle relativt ukomplicerede produkter (møbler), og at sandsynligheden for, at sælgeren ville få brug for de gemte personoplysninger var beskeden. Den dataansvarlige havde således også selv sat slettefristen til 2,5 år i sit nye system (sagen omhandlede manglende sletning i et udfaset system) og dermed også erkendt, at der ikke var behov for opbevaring i hele garantiperioden.

Det væsentligste anvendelsesområde for art. 6, stk. 1, litra b, er den dataansvarliges behandling af oplysninger i forbindelse med opfyldelse af en kontrakt. Som anført indledningsvist omfatter bestemmelsen imidlertid også behandlinger, der er nødvendige for “gennemførelse af foranstaltninger, der træffes på den registreredes anmodning forud for indgåelse af en kontrakt”. Formuleringen dækker over behandlinger, der er nødvendige for at kunne forberede en kontrakt eller undersøge muligheden for at indgå en kontrakt. Behandlingen skal så-

Behandling forud
for kontraktens
indgåelse

ledes ske som led i en aktivitet, der potentielt kan føre frem til en kontrakt. Heri ligger også, at det ikke er et krav, at der rent faktisk indgår en kontrakt mellem den dataansvarlige og den registrerede. Retningslinjer 2/2019 giver som eksempel på anvendelsesområdet, at den registrerede indtaster sit postnummer for at se, om den dataansvarlige leverer i dette område. Det er et krav, at forberedelsesforanstaltningerne træffes på den registreredes foranledning. Den dataansvarlige kan derfor ikke af egen drift behandle oplysninger med henblik på markedsføring eller afgivelse af tilbud, hvis ikke den registrerede har taget initiativet hertil.

3.2. Overholdelse af retlig forpligtelse – art. 6, stk. 1, litra c

Efter art. 6, stk. 1, litra c, kan behandlingen ske, hvis den er nødvendig, for at den dataansvarlige kan overholde en retlig forpligtelse.

Bestemmelsen omfatter retlige forpligtelser, der følger af lovgivning eller administrative forskrifter udstedt i henhold til lovgivning. Den omfatter endvidere forpligtelser, der følger af domstolsafgørelser eller bindende afgørelser fra administrative myndigheder, idet bindende afgørelser for så vidt blot udtrykker det, der følger af lovgivningen eller administrative forskrifter. Eksempler på bestemmelsens anvendelsesområde er virksomheders pligt til at indberette lønoplysninger til skattemyndighederne, bankers pligt til at indsamle oplysninger som led i hvidvaskkontrol og bogføringslovens regler om pligt til opbevaring af oplysninger i fem år.

Lovgivning

Bestemmelsen kan ikke antages at gælde for retlige forpligtelser, der følger af en kontrakt. Disse situationer omfattes af litra b.

Kontrakt

Se nærmere herom Korfits Nielsen & Lotterup, Databeskyttelsesforordningen og databeskyttelsesloven med kommentarer, s. 359 og Kotschy i Kuner m.fl. (red.), The EU General Data Protection Regulation (GDPR), s. 332.

Det er ikke klart, om bestemmelsen også omfatter retlige forpligtelser, der følger af kollektive overenskomster, der på den ene side ikke har karakter af lovgivning, men på den anden side har en anden status end private kontrakter indgået mellem individuelle parter. Datatilsynet har i afgørelse 2011-313-0474 afvist, at den tilsvarende regel i den tidli-

Kollektive
overenskomster

gere persondatalov omfattede kollektive overenskomster. I betænkning 1565/2017, s. 130, anføres, at det ikke på forhånd kan udelukkes, at litra c omfatter forpligtelser, der følger af kollektive overenskomster. Betænkningen henviser herved til forordningens betragtning 41, der fastslår, at når forordningen henviser til et retsgrundlag eller en lovgivningsmæssig foranstaltning, kræver det ikke nødvendigvis en lov, der er vedtaget af parlamentet. Det synes mest nærliggende, at denne betragtning blot præciserer, at bestemmelsen også omfatter dommerskabte (ikke-kodificerede) retsregler. I så fald taler mest for at opretholde vurderingen fra Datatilsynets tidligere afgørelse og afvise, at bestemmelsen omfatter kollektive overenskomster. Spørgsmålet har dog begrænset praktisk betydning, idet databeskyttelsesloven i § 12 indeholder en bestemmelse, der eksplicit giver hjemmel til behandling, som er nødvendig for at overholde en arbejdsretlig forpligtelse fastlagt i kollektive overenskomster.

Bestemmelsen kan ikke antages at omfatte retlige forpligtelser, der følger af lovgivning fra andre lande, herunder andre medlemsstater. En dansk dataansvarlig vil således kun kunne foretage en behandling med hjemmel i bestemmelse, hvis den retlige forpligtelse følger af dansk lovgivning eller EU-retten. Bliver den dataansvarlige eksempelvis mødt med lovkrav om behandling af personoplysninger på et eksportmarked, må den dataansvarlige finde et andet behandlingsgrundlag, f.eks. afvejningsreglen i litra f.

Lovgivning i andre lande

Se tilsvarende hos Korfits Nielsen & Lotterup, Databeskyttelsesforordningen og databeskyttelsesloven med kommentarer, s. 359, hvor det dog anføres, at forordningen ikke tager stilling til spørgsmålet.

En stor del af de behandlinger, som foretages af offentlige myndigheder, vil udspringe af en retlig forpligtelse, da offentlige myndigheder udøver deres aktiviteter på grundlag af lovhjemmel. Da behandlinger nødvendiggjort af offentlig myndighedsudøvelse har sit eget behandlingsgrundlag i litra d (omtalt straks nedenfor), er det omdiskuteret, om litra c også gælder for offentlige myndigheder, se således Kotschy i Kuner m.fl. (red.), The EU General Data Protection Regulation (GDPR), s. 333, der lader spørgsmålet stå åbent. Korfits Nielsen & Lotterup, Databeskyttelsesforordningen og databeskyttelsesloven med kommentarer, s. 359, antager, at bestemmelsen gælder for offentlige

Offentlige myndigheder

myndigheder. Dette resultat kan tiltrædes, og skulle bestemmelsen have været forbeholdt private dataansvarlige, burde dette have fremgået af bestemmelsen eller præambelbetragtningerne.

3.3. Fysiske personers vitale interesser – art. 6, stk. 1, litra d

Efter art. 6, stk. 1, litra d, kan behandling ske, når det er nødvendigt for at beskytte den registreredes eller en anden fysisk persons vitale interesser. Bestemmelsen finder navnlig anvendelse i situationer, hvor den registrerede ikke har mulighed for selv at varetage sine interesser, f.eks. pga. sygdom eller bortrejse.

Begrebet “vitale interesser” indebærer, at bestemmelsen kun kan anvendes, hvis det vil påføre den registrerede eller en anden fysisk person væsentlig skade, såfremt der ikke sker en behandling af personoplysninger. Efter betragtning 46 beskytter bestemmelsen hensyn af “fundamental” betydning for den registrerede eller en anden fysisk person. Bestemmelsen tager primært sigte på forhold, der kan true liv og helbred, men det kan ikke udelukkes, at bestemmelsen også kan anvendes, hvis en manglende behandling af oplysningerne vil have alvorlige økonomiske konsekvenser for den registrerede eller en anden fysisk person, jf. således også Korfits Nielsen & Lotterup, Databeskyttelsesforordningen og databeskyttelsesloven med kommentarer, s. 360.

Det er tvivlsomt, om bestemmelsen kan anvendes, hvis det er muligt at indhente samtykke fra den registrerede. Der må her sondres mellem de situationer, hvor behandlingen sker for at varetage den registreredes egne interesser og de situationer, hvor behandlingen sker for at varetage en anden fysisk persons interesser.

Bestemmelsens kerneområde er de situationer, hvor den registrerede ikke er i stand til at varetage sine interesser, hvilket skaber en formodning for, at bestemmelsen ikke kan anvendes, når det er muligt at indhente samtykke fra den registrerede. Hvorvidt, der kan opstilles et krav om, at det ikke er muligt at indhente samtykke fra den registrerede, bliver imidlertid tvivlsomt, når bestemmelsen læses i sammenhæng med art. 9, stk. 2, litra c. Denne bestemmelse fastslår, at forbudet mod behandling af følsomme oplysninger i art. 9, stk. 1, ikke gælder, når behandlingen er nødvendig for at beskytte den registreredes eller en anden fysisk persons vitale interesser “i tilfælde, hvor den regi-

Vitale interesser

Betydningen af potentielt samtykke

– beskyttelse af den registreredes interesser

strerede fysisk eller juridisk ikke er i stand til at give samtykke”. I denne bestemmelse er det således angivet eksplicit, at den kun gælder, når den registrerede ikke har mulighed for at give samtykke. Dette peger i sig selv i retning af, at et tilsvarende krav ikke gælder efter art. 6, stk. 1, litra d. Ikke desto mindre forekommer der ikke reale hensyn, som tilsi-ger, at der skal kunne finde en behandling sted for at beskytte den re-gistreredes interesser, hvis denne ikke ønsker behandlingen, og dette kan afklares ved en forespørgsel til den registrerede. Det må derfor an-tages, at litra d ikke kan anvendes, hvis det er muligt at indhente samtykke fra den registrerede.

Såfremt behandlingen sker for at varetage en anden fysisk persons interesser er forholdet et andet. Den registrerede bør ikke kunne hin-dre behandlingen af sine personoplysninger, hvis dette er nødvendigt for at beskytte en andens vitale interesser. Hvis den registrerede afviser at give samtykke, og behandlingen undtagelsesvist ikke har hjemmel i et af de andre behandlingsgrundlag, kan behandlingen derfor ske med hjemmel i litra d. Den registrerede bør derfor heller ikke anmodes om samtykke, hvis behandlingen under alle omstændigheder vil blive fore-taget med hjemmel i litra d, jf. også afsnit 2.6 om konkurrence mellem samtykke og øvrige behandlingsgrundlag. Det er med andre ord uden betydning, om det er muligt at indhente samtykke fra den registrerede, og den dataansvarlige bør ikke forsøge at indhente et samtykke.

Anderledes Kotschy i Kuner m.fl. (red.), The EU General Data Pro-tection Regulation (GDPR), s. 334, der med henvisning til den forskelli-ge ordlyd i art. 6, stk. 1, litra d og art. 9, stk. 2, litra c, og princippet om rimelighed (“fair processing”) antager, at den dataansvarlige muligvis er forpligtet til at konsultere den registrerede.

Det følger af betragtning 46, at en behandling på grundlag af en an-den fysisk persons vitale interesser i princippet kun bør finde sted, hvis behandlingen tydeligvis ikke kan baseres på et andet retsgrund-lag. Afvejningsreglen i art. 6, stk. 1, litra f, vil stort set altid kunne anvendes af private dataansvarlige i de situationer, der er omfattet af li-tra d. Hensynet til den person, hvis vitale interesser er truet, må såle-des antages at veje tungere, end hensynet til den registrerede.

Såfremt vurderingen efter litra f undtagelsesvist fører til, at hensynet til den registrerede vejer tungere end hensynet til den anden fysiske perso-

– beskyttelse af en anden fysisk persons interesser

Krav om eneste behandlingsgrundlag

– beskyttelse af andre fysiske persons interesser

ner, hvis vitale interesser er truet, rejser det spørgsmålet, om behandlingen i denne situation kan gennemføres med hjemmel i litra d. På den ene side indeholder litra d efter sin ordlyd ikke en afvejning overfor den registreredes interesser. På den anden side virker det besynderligt, hvis hensynet til den registrerede findes at veje tungest efter litra f, og det så alligevel skulle være muligt at foretage behandlingen efter litra d. En afvisning af at anvende litra d som behandlingsgrundlag i denne situation, kan begrundes med, at der ikke foreligger tilstrækkeligt tungtvejende (vitale) hensyn til den anden person efter litra d. Hermed flyder vurderingen efter litra d og litra f sammen.

Afvejningsreglen i litra f gælder ikke for offentlige myndigheders behandling som led i udførelsen af deres opgaver. Behandling som led i myndighedsudøvelse er imidlertid omfattet af litra e, og realiteten er derfor nok, at litra d har et meget begrænset anvendelsesområde for behandlinger, der skal beskytte en anden person end den registrerede.

Betragtning 46 nævner ikke den situation, hvor der foreligger andre behandlingsgrundlag, når behandlingen skal varetage den registreredes interesser. Der kan derfor heller ikke i denne situation opstilles en tilsvarende generel formodning for, at litra d kun kan anvendes, hvis behandlingen ikke kan baseres på andre behandlingsgrundlag. Se i øvrigt om valg af behandlingsgrundlag afsnit 3.5 nedenfor.

- beskyttelse af den registreredes interesser

3.4. Samfundsinteresser og offentlig myndighedsudøvelse, art. 6, stk. 1, litra e

Efter art. 6, stk. 1, litra e, kan behandling ske, "når den er nødvendig af hensyn til udførelsen af en opgave i samfundets interesse eller som henhører under offentlig myndighedsudøvelse, som den dataansvarlige har fået pålagt".

Begrebet "offentlig myndighedsudøvelse" dækker den offentlige myndigheds afgørelsesvirksomhed. Når en behandling af personoplysninger er nødvendig for at en myndighed kan træffe afgørelse i en sag, er behandlingsgrundlaget således litra e, andet led.

"Offentlig myndighedsudøvelse"

Bestemmelsen første led hjemler som anført behandlinger, der er nødvendige for udførelsen af en opgave i "samfundets interesse". Dette begreb er ikke defineret i forordningen, hvilket gør bestemmelsens grænser noget uklare. Overordnet vil begrebet dække behandlinger,

"Samfundets interesse"

der foretages til gavn for befolkningen som helhed eller for bredere og generelt afgrænsede befolkningsgrupper snarere end en snævre og mere specifik kreds af personer, virksomheder mv.

I forordningens betragtning 46 angives overvågning af epidemier og humanitære nødsituationer, herunder naturkatastrofer og menneskeskabte katastrofer, som eksempler på behandling, der både kan tjene samfundsinteresser og den registreredes vitale interesser. Det er dog klart, at begrebet “samfundsmæssige interesser” dækker langt bredere end dette.

Bestemmelsens væsentligste anvendelsesområde er de behandlinger, der foretages af offentlige myndigheder, som ikke har karakter af offentlig myndighedsudøvelse, og som derfor ikke omfattes af litra e, andet led. Dette vil omfatte myndigheders faktiske forvaltningsvirksomhed, som f.eks. drift af biblioteker, skoler, svømmehaller mv.

I betænkning 1565/2017, s. 140, lægges tilsvarende til grund, at litra e, første led, vil dække behandling, der foretages som led i offentlige myndigheders faktiske forvaltningsvirksomhed. Tilsvarende Blume, Juristen, 2018, s. 156 og Wiese Schartum, Personvernforordningen, s. 131. Hos Korfits Nielsen & Lotterup, Databeskyttelsesforordningen og databeskyttelsesloven med kommentarer, s. 375, antages, at faktiske forvaltningsvirksomhed efter omstændighederne vil være omfattet af myndighedsudøvelse efter litra e, andet led. Det anføres dog videre, at ikke alt, hvad en forvaltningsmyndigheder foretager sig, vil falde ind under begrebet, og nævner som eksempler herpå service og rådgivning, der i stedet vil være omfattet af litra e, første led.

Også offentlige myndigheders behandling i deres egenskab af arbejdsgiver må antages at være behandling i “samfundets interesse”, jf. betænkning 1565/2017, s. 140. I det hele taget må det antages, at bestemmelsen kan anvendes på de fleste af de behandlinger, som offentlige myndigheder foretager uden for sin myndighedsudøvelse. Dette skyldes ikke mindst, at offentlige myndigheder ikke kan anvende afvejningsreglen i litra f, som tilfældet var under persondatadirektivet, hvorfor en række forskellige behandlingssituationer, der tidligere var hjemlet i afvejningsreglen, nu skal kunne rummes i litra e.

Se også om dette hensyn betænkning 1565/2017, s. 140 og Art. 29, udtalelse 6/2014, WP 217, s. 23 (“... would need to be interpreted in a way as to allow public authorities some degree of flexibility, at least to ensure their proper management and functioning ...”).

Det skal dog erindres, at litra e under alle omstændigheder forudsætter, at behandlingen er nødvendig, for at myndigheden kan udføre den pågældende opgave. Bestemmelsen er således ikke en *carte blanche* for offentlige myndigheder.

Se også en række yderligere mere konkrete eksempler hos Korfits Nielsen & Lotterup, Databeskyttelsesforordningen og databeskyttelsesloven med kommentarer, s. 362 ff., herunder offentlige myndigheders offentliggørelse af billeder og visning af direkte optagelser på internettet, kontrol med medarbejders brug af hjemmesider og mails, skolers logging af elevers hjemmesidebesøg, brug af sociale medier og offentliggørelse af kontrolresultater og afgørelser.

Udgangspunktet for litra e er den behandling, der foretages af offentlige myndigheder som led i deres myndighedsudøvelse og opgavevaretagelse i øvrigt. Bestemmelsen kan dog også anvendes af private dataansvarlige, men grænserne herfor må være snævre og er i øvrigt uklare.

Private data-
ansvarlige

Det må antages, at bestemmelsen kan anvendes af private virksomheder, når faktisk forvaltningsvirksomhed eller andre myndighedsopgaver, der i øvrigt er omfattet af litra e, første led, outsources til en virksomhed. Dette følger også af Datatilsynets praksis.

– på vegne af en
myndighed

Se således forudsætningsvist Datatilsynets afgørelse i sag nr. 2018-31-0455, hvor tilsynet pålagde virksomheden DK Hostmaster A/S at ophøre med at offentliggøre personoplysninger om fuldmægtige for domænenavnsregistrarer i WHOIS-databasen. Datatilsynet fandt ikke, at offentliggørelsen var nødvendig af hensyn til udførelse af en opgave i samfundets interesse og derfor ikke kunne ske i medfør af art. 6, stk. 1, litra e. Afgørelsen forudsætter, at DK Hostmasters behandling af oplysninger potentielt kan hjemles af bestemmelsen. DK Hostmaster er et helejet datterselskab af foreningen DIFO, der i henhold til domæne-loven er udpeget af Erhvervsministeren til at varetage administrationen af .dk-domænet på vegne af den danske stat.

Tilsvarende Wiese Schartum, Personvernforordningen, s. 132 men anderledes Kotschy i Kuner m.fl. (red.), The EU General Data Protection Regulation (GDPR), s. 335 f., der antager, at bestemmelsen ikke omfatter kontraktuel overdragelse af en opgave omfattet af litra e. ww

I hvilket omfang private dataansvarlige kan siges at udføre en opgave i samfundets interesse, når de ikke varetager en opgave på vegne af en myndighed, er mere tvivlsomt. I betænkning 1565/2017, s. 120, anføres, at det ikke er udelukket at anvende bestemmelsen, selvom behandlingen sker i kommercielt øjemed, ligesom større private foreningers og sammenslutningers registrering af oplysninger af interesse for en bredere kreds gives som et eksempel på en behandling, der kan være omfattet af bestemmelsen. Betænkningen nævner generelt behandling i statistisk, historisk eller videnskabeligt øjemed som eksempler på behandlinger omfattet af bestemmelsen.

– på egne vegne

Dette anføres i beskrivelsen af retstilstanden under den tilsvarende bestemmelser i den tidligere persondatalov, men betænkningen lægger til grund, at forordningen ikke indebærer ændringer i retstilstanden på dette punkt.

Datatilsynet har i en udtalelse fra 2011 (j.nr. 2009-321-0219) lagt til grund, at den tilsvarende bestemmelse i den tidligere persondatalov kunne anvendes af en interesseorganisation, der indsamlede oplysninger om internetbrugeres adfærd, da dette alene skete i statistisk øjemed. Tilsynet har endvidere fortolket begrebet “samfundsinteresser” i relation til privates behandling under DBL § 7, stk. 4, der giver hjemmel til behandling af følsomme oplysninger, når dette er nødvendigt at hensyn til væsentlige samfundsinteresser. I sag 2018-51-0300 gav tilsynet Center for Seksuelt Misbrug Øst tilladelse til at behandle personoplysninger i forbindelse med behandling og rådgivning af ofre for seksuelle overgreb. I sag 2018-51-0299 gav tilsynet tilladelse til Børns Vilkårs behandling af oplysninger i forbindelse med rådgivning af udsatte børn og unge. I sag 2018-51-0332 gav tilsynet tilladelse til, at fodboldklubben Brøndby behandlede biometriske data som led i brug af ansigtsgenkendelsesteknologi uden for stadion ved afvikling af fodboldkampe. Sådanne systemer skal hindre, at personer, der har forbud

mod at komme på stadion, alligevel får adgang og dermed medvirke til at undgå vold og uro på stadion.

Det er vanskeligt at forestille sig, at bestemmelsen kan anvendes af private virksomheder, når behandlingen foretages som led i en aktivitet, der har det som sit primære formål at generere profit til virksomheden. Klart er det, at det ikke bringer en behandling ind under bestemmelsen, blot fordi den sker som led i udvikling eller udbud af et produkt, som der er efterspørgsel efter (og som derfor er en interesse for i samfundet i bred forstand). Dette gælder også, selvom produkterne har en klar samfundsgavnlig effekt. En medicinalvirksomhed kan således ikke bruge bestemmelsen i forbindelse med sin produktudvikling, selvom det er til gavn for samfundet, at der udvikles ny medicin.

– profitformål

Art. 6, stk. 1, litra e, viderefører art. 7, stk. 1, litra e, fra det tidligere persondatadirektiv. Den tidligere bestemmelse indeholdt en sætning, der eksplicit gav hjemmel til, at oplysninger kunne videregives til den, der udførte en opgave i samfundets interesse eller forestod offentlig myndighedsudøvelse.

Videregivelse til den der udfører en opgave i samfundets interesse

Den tidligere bestemmelse havde følgende ordlyd, hvor den anførte sætning er markeret med kursiv: “[...] er nødvendig af hensyn til udførelsen af en opgave i samfundets interesse eller henhørende under offentlig myndighedsudøvelse, som den registeransvarlige *eller en tredjemand, til hvem oplysningerne videregives*, har fået pålagt”.

Såfremt en offentlig myndighed henvendte sig til en dataansvarlig og udbad sig udlevering af personoplysninger til brug for offentlig myndighedsudøvelse, ville den dataansvarlige således kunne videregive oplysningerne med hjemmel i bestemmelsen, selvom den dataansvarlige ikke selv udførte en opgave i samfundets interesse eller forestod myndighedsudøvelse.

Denne sætning blev imidlertid ikke medtaget i forordningens bestemmelse, som således alene omtaler behandling, der foretages af dataansvarlige, der selv udfører en opgave i samfundets interesse eller forestår myndighedsudøvelse. På den baggrund kan det næppe antages, at bestemmelsen giver hjemmel til en videregivelse til offentlige myndigheder eller andre, der udfører opgaver i samfundets interesse. En sådan videregivelse må i stedet hjemles i en af de andre behandlings-

grundlag, hvoraf navnlig litra om retlig forpligtelse eller afvejningsreglen i litra f vil kunne være relevante.

Tilsvarende Kotschy i Kuner m.fl. (red.), *The EU General Data Protection Regulation (GDPR)*, s. 335. I betænkning 1565/2017, s. 133, lægges til grund, at litra e også kan anvendes til videregivelse, idet videregivelsen vil være i samfundets interesse. Bestemmelsen forudsætter dog, at den dataansvarlige har fået “pålagt” at udføre en “opgave” i samfundets interesse, hvilket ikke synes at omfatte rene tilfælde af videregivelse. I Datatilsynets vejledning om udveksling af personoplysninger med politiet fra januar 2021, s. 4, anføres både art. 6, stk. 1, litra e og f som mulige hjemmelsgrundlag for videregivelse af oplysninger til politiet. Vejledningen synes således at lægge til grund, at litra e kan anvendes til videregivelse, idet der dog ikke redegøres nærmere for forholdet mellem litra e og f i denne henseende.

Det følger af forordningens art. 6, stk. 3, at grundlaget for en behandling efter litra e skal fremgå af enten EU-retten eller medlemsstaternes nationale ret, som den dataansvarlige er underlagt. Dette kan næppe indebære, at selve behandlingen skal have eksplicit hjemmel i en national lovbestemmelse, tilsvarende betænkning 1565/2017, s. 132. Derimod synes art. 6, stk. 3, at forudsætte, at den myndighedsudøvelse eller opgavevaretagelse i samfundets interesser, som begrundet behandlingen, er hjemlet i national ret. For offentlige myndigheder må dette krav antages generelt være opfyldt allerede i kraft af legalitetsprincippet. For private dataansvarlige forholder det sig anderledes, idet private ikke skal have hjemmel for at måtte foretage en handling. Art. 6, stk. 3, synes således at indebære, at private dataansvarlige kun kan anvende litra e, hvis den opgave, som ligger til grund for behandlingen, er eksplicit hjemlet. I modsat fald er det vanskeligt at se, at bestemmelsen har et reelt indhold. Resultatet understøttes også af ordlyden af litra e, der omfatter opgaver i samfundets interesse, som den dataansvarlige er blevet “pålagt”. Denne fortolkning indebærer, at private dataansvarlige ikke kan anvende litra e som hjemmelsgrundlag, hvis de af egen drift udfører en opgave, der kræver behandling af personoplysninger, selvom opgaven kan siges at være i samfundets interesse. En anden opfattelse lægges dog til grund i betænkning 1565/2017, s. 132, der anfører, at art. 6, stk. 3, skal læses i sammenhæng med art. 6, stk. 2, hvorefter medlemsstaterne kan opretholde eller indføre mere

Krav om særskilt lovgrundlag?

specifikke bestemmelser om behandling efter litra e (og litra c). Betænkningen antager, at art. 6, stk. 3, blot foreskriver, at *hvis* medlemsstaterne vælger at indføre specifikke bestemmelser efter stk. 2, skal der etableres et grundlag i national ret. Med denne fortolkning indebærer art. 6, stk. 3, ikke, at private dataansvarlige kun kan anvende litra e, hvis deres opgavevaretagelse er hjemlet i lovgivningen.

4. Interesseafvejningsreglen – art. 6, stk. 1, litra f

Som beskrevet er stort set enhver form for behandling af personoplysninger omfattet af forordningen og dermed af udgangspunktet om, at behandling kun kan finde sted, hvis et af forordningens behandlingsgrundlag dækker behandlingen. Da der i praksis ikke kan tages højde for og forudses alle de typer af behandlinger, som bør være lovlige, bl.a. som følge af den teknologiske udvikling, er det ikke muligt at dække hele området for lovlige behandlinger med behandlingsregler, der omhandler specifikke typer af behandlinger. Som en konsekvens heraf indeholder art. 6 en bred interesseafvejningsregel, der kan hjemle enhver behandling af personoplysninger, der “er nødvendig for, at den dataansvarlige eller en tredjemand kan forfølge en legitim interesse, medmindre den registreredes interesser, eller grundlæggende rettigheder og frihedsrettigheder, der kræver beskyttelse af personoplysninger, går forud herfor, navnlig hvis den registrerede er et barn”. Bestemmelsen indebærer, at der kan ske en behandling af personoplysninger, når 1) den dataansvarlige eller en tredjemand har en “legitim interesse” i behandlingen, 2) behandlingen er nødvendig for at forfølge denne interesse og 3) den legitime interesse overstiger i den konkrete situation den registreredes interesse i, at der ikke finder en behandling sted (den konkrete afvejning).

Den tidligere art. 29-gruppe har udgivet en længere udtalelse om den tilsvarende bestemmelse i det tidligere persondatadirektiv (udtalelse [6/2014](#) om den registeransvarliges legitime interesser som omhandlet i artikel 7 i direktiv 95/46/EF, WP 217), som stadig kan bidrage til fortolkning af bestemmelsen, selvom udtalelsen ikke er blevet tiltrådt af ED-PB. Ved læsningen skal man dog være opmærksom på, at interesseafvejningsreglen i forordningen eksplicit angiver, at den ikke kan anvendes

af offentlige myndigheder ved udførelsen af deres myndighedsopgaver, hvilket ikke var tilfældet under direktivet.

4.1. Den dataansvarlige eller tredjemands legitime interesser

Kravet om “legitim interesse” indebærer et reelt og aktuelt behov for at behandle oplysningerne. At en dataansvarlig på et senere tidspunkt muligvis kan få brug for at behandle oplysningerne er således ikke tilstrækkeligt.

I den tidligere art. 29-gruppens udtalelse 6/2014 udtrykkes det sådan, at interessen ikke må være spekulativ, s. 27.

I kravet ligger endvidere det åbenbare, at behandlingen skal forfølge lovlige interesser. Den legitime interesse vil som regel knytte sig til det formål med behandlingen, der skal identificeres efter art. 5, stk. 1, litra b.

Det følger eksplicit af bestemmelsen, at det ikke kun er den dataansvarliges legitime interesser men også tredjemands interesser, der kan begrunde en behandling. “Tredjemand” kan i denne sammenhæng også være den bredere offentlighed, der i nogle situationer bl.a. kan have en interesse i, at de pågældende personoplysninger gøres offentligt tilgængelige.

Se eksempelvis herved *Google Spain*-afgørelsen (C-131/12), hvor EU-Domstolen slog fast, at der ved vurderingen af, om behandling af oplysninger i Googles søgemaskine kunne hjemles i persondatadirektivets art. 7, litra f (svarende til forordningens art. 6, stk. 1, litra f), også skulle lægges vægt på internetbrugernes legitime interesse i at have adgang til oplysningerne.

Præambelbetragtning 47 angiver, at der kan foreligge legitime interesser, når der er et relevant og passende forhold mellem den registrerede og den dataansvarlige, f.eks. hvis den registrerede er kunde hos eller gør tjeneste under den dataansvarlige. Direkte markedsføring kan efter betragtningen også være en legitim interesse. Endelig anføres i betragtningen, at en behandling, der er strengt nødvendig for at forebygge svig (måske ikke overraskende) være en legitim interesse. Der er

dog kun tale om enkelte konkrete eksempler, og det ligger klart, at legitime interesser kan bestå i meget andet, og at det under alle omstændigheder må bero på en konkret vurdering, om der foreligger en legitim interesse.

EU-Domstolen har truffet enkelte afgørelser om, hvad der kan udgøre en legitim interesse for den dataansvarlige. I sag C-212/13 (*Ryneš*) udtalte Domstolen (præmis 34), at det indgik som en legitim interesse for den dataansvarlige at beskytte familiens ejendom, sundhed og liv (den dataansvarlige var en husejer, der havde opsat et overvågningskamera, der både filmede i familiens indkørsel og på offentlig vej, efter at familien flere gange var blevet udsat for angreb fra en ukendt person). I *Breyer-dommen* (C-582/14) udtalte Domstolen (præmis 62), at tyske myndigheder kunne have en legitim interesse i at sikre deres hjemmesiders funktionsdygtighed (sagen omhandlede logning af ip-adresser med henblik på at strafforfølge hackerangreb. Se også nærmere om sagen kap. 2.1.1).

Se også om Datatilsynets praksis hos Korfits Nielsen & Lotterup, Data-beskyttelsesforordningen og databeskyttelsesloven, s. 382 ff.

4.2. Nødvendighedskravet

Behandlingen skal være "nødvendig" for at den legitime interesse kan forfølges. Kravet er selvsagt opfyldt, hvis det er åbenbart, at interessen ikke kan forfølges uden den pågældende behandling af personoplysninger. Etablering af en søgemaskine på internettet, der også omfatter de personoplysninger, der er gjort tilgængelige på hjemmesider, forudsætter eksempelvis at disse oplysninger behandles. Tilsvarende åbenbart er behandlingen ikke nødvendig, hvis den er helt uden betydning for pågældende interesse. I mange situationer vil forholdet ikke være helt så åbenbart. Dette gælder, når behandlingen forfølger en legitim interesse, men denne interesse også kunne understøttes på anden måde. Vil en butiksejer eksempelvis anvende interesseafvejningsreglen til at foretage tv-overvågning med henblik på forebyggelse og opklaring af tyverier, må det overvejes, om andre og mindre privatlivsindgribende tiltag lige så effektivt kan varetage denne interesse.

I så skal det i øvrigt erindres, at forordningen suppleres af tv-overvågningsloven, når der foretages tv-overvågning.

Hvis andre og mindre privatlivsindgribende foranstaltninger lige så effektivt kan forfølge de legitime interesser, vil behandlingen som udgangspunkt ikke være nødvendig. Dette gælder dog ikke, hvis disse andre foranstaltninger vil være uforholdsmæssigt krævende at gennemføre, eksempelvis fordi de vil være prohibitivt dyre. Hvorvidt dette er tilfældet, vil bero på en konkret vurdering, men det er klart, at den dataansvarlige ikke kan afvise andre foranstaltninger blot fordi, det vil påføre den dataansvarlige omkostninger eller i øvrigt er mere besværligt end at foretage behandlingen af personoplysninger.

4.3. Den registreredes interesser og rettigheder

Mens den dataansvarlige skal vurdere, om der består en legitim interesse i at behandle personoplysningerne, kan den dataansvarlige uden videre lægge til grund, at den registrerede har en interesse i, at behandlingen ikke finder sted.

Bestemmelsen forudsætter som beskrevet, at behandlingen skal forfølge den dataansvarlige eller tredjemands "legitime" interesser. Et tilsvarende krav om at, at interessen skal være legitim, gælder ikke for den registreredes interesser. Dette indebærer, at selv når den registrerede begår noget ulovligt, vil den registreredes interesse i, at en behandling af oplysninger knyttet til den ulovlige handling ikke finder sted, være beskyttet af bestemmelsen. I den tidligere art. 29-gruppens udtalelse 6/2014, s. 32, gives som eksempel herpå, at en person, der begår butikstyveri vil være sikret, at hans interesser går forud for butiksejerens interesse i at offentliggøre hans billede og privatadresse.

Den dataansvarlige kan selv sagt søge at få den registreredes tilkendegivelse af, at den registrerede ikke har nogen indvendinger mod behandlingen. I så fald kunne man argumentere for, at behandlingen ikke vil stride mod den registreredes interesser. I praksis vil dette dog svare til, at den dataansvarlige søger at indhente samtykke til behandlingen, og i så fald må den dataansvarlige gå frem efter samtykkebestemmelsen i art. 6, stk. 1, litra a, og de krav, der følger af denne bestemmelse.

Efter bestemmelsens ordlyd skal den dataansvarlige eller tredjemands legitime interesser afvejes overfor den registreredes interesser *eller* de grundlæggende rettigheder og frihedsrettigheder, der kræver be-

Ikke krav om lovlighed

Den registreredes accept af behandlingen

Sondring mellem interesser og rettigheder?

skyttelse af personoplysninger. Bestemmelsen indeholdes således en principiel sondring mellem interesser og grundlæggende rettigheder. Dette kan muligvis indebærer, at selvom den konkrete registrerede ikke har nogen subjektiv interesse i, at behandlingen ikke foretages, vil behandlingen potentielt alligevel ikke kunne hjemles i bestemmelsen, fordi den legitime interesse i den konkrete situation ikke kan begrunde i et indgreb i de objektive grundlæggende rettigheder. I praksis vil sontringen dog næppe have betydning, og som anført af art. 29-gruppen i udtalelse 6/2014, s. 31, “er [budskabet] tydeligvis, at alle den registreredes relevante interesser skal tages i betragtning”.

4.4. Interesseafvejningen

Når den dataansvarlige har identificeret en legitim interesse, og det er nødvendigt at behandle personoplysninger for at forfølge denne interesse, skal den dataansvarlige foretage en konkret afvejning af den legitime interesse over for den registreredes interesser, dvs. de hensyn til den registrerede, som tilsiger, at behandlingen ikke bør finde sted.

Ved denne afvejning må det på den ene side vurderes, hvor tungtvæjende de legitime interesser er. Jo mere tyngde de har, jo mere taler for, at afvejningen falder ud til fordel for den dataansvarlige. På den anden side må det vurderes, hvilken indvirkning behandlingen vil have på den registrerede. Jo mere privatlivsindgribende behandlingen er, jo mere taler for, at afvejningen skal falde ud til fordel for den registrerede. Det er vanskeligt at fastsætte nærmere retningslinjer for disse vurderinger og for afvejningen i det hele taget. Art. 29-gruppen angav dog i udtalelse 6/2014 nogle kriterier, der kan inddrages.

De legitime interesser kan således tillægges stor vægt, hvis behandlingen er nødvendig for udøvelsen af grundlæggende rettigheder, eksempelvis ytrings- og informationsfrihed. Dette kan tilsvarende gælde, hvis behandlingen ikke kun varetager den dataansvarliges egne interesser men også varetager bredere samfundsinteresser. I udtalelsen formuleres det således, at “[Jo] vægtigere den offentlige interesse eller samfundsinteressen er, og jo mere det anerkendes og forventes i samfundet og af de registrerede, at den registeransvarlige kan handle og behandle oplysninger for at forfølge disse interesser, desto mere vejer denne legitime interesse i afvejningstesten”. Den kan endvidere tillæg-

Vægten af den dataansvarliges eller tredjemands legitime interesser

ges vægt, hvis behandlingen læner sig op ad et af de andre behandlingsgrundlag. Udtalelsen giver som eksempel herpå, at en behandling ikke er strengt nødvendig men stadig relevant for opfyldelsen af en kontrakt (art. 6, stk. 1, litra b) eller at behandling (eksplicit) er tilladt men ikke påkrævet efter loven (art. 6, stk. 1, litra c).

Se således også præambelbetragtning 47, hvor det anføres, at den dataansvarlige kan have en legitim interesse i at behandle oplysninger om sine kunder.

I forlængelse heraf peger udtalelsen endelig på, at jo mere det anerkendes i lovgivning, administrativ praksis og ikke-bindende retningslinjer fra officielle organer, at den dataansvarlige kan handle og behandle oplysninger for at forfølge en legitim interesse, jo tungere vejer den legitime interesser.

Ved vurderingen af, hvordan behandlingen vil indvirke på den registrerede, skal der både tages højde for positive og negative konsekvenser. Foretages behandlingen eksempelvis for at sikre den registreredes rettigheder, taler det for, at behandlingen kan foretages. Indvirkninger af negativ karakter trækker i den modsatte retning. Det vil vægte tungt, hvis der er en reel risiko for, at behandlingen påfører den registrerede en egentlig skade, f.eks. økonomiske tab, omdømmetab eller måske endog (omend sjældent) fysisk skade. I bredere forstand kan en skade også bestå i, at den registrerede oplever irritation eller angst i forbindelse med kompromittering eller misbrug af personoplysninger. Som anført af art. 29-gruppen i udtalelse 6/2014, s. 39, er hensynet til at den registreredes interesser efter art. 6, stk. 1, litra f, et langt bredere begreb end forordningens skadebegreb. Enhver negativ indvirkning på den registrerede skal derfor medtages i interesseafvejningsreglen. I udtalelsen, a.st., beskrives det således, at “det omfatter de forskellige måder, hvorpå en person kan blive berørt – positivt eller negativt – af behandlingen af vedkommendes personoplysninger”.

Vægten af den registreredes interesser

Ved vurderingen af, om behandlingen vil påvirke den registrerede negativt vil det ofte være relevant at foretage en risikovurdering, hvor der, i lighed med tilsvarende vurderinger under andre af forordningens bestemmelser, både ses på sandsynligheden for, at den negative indvirkning indtræder, og på effekten (omfanget) heraf. Eller med andre ord den velkendte risikoformel “sandsynlighed x effekt”. I udtalelse

6/2014 angiver art. 29-gruppen en række kriterier, der har relevans for denne vurdering. Dette gælder karakteren af personoplysningerne. Det fremgår eksplicit af bestemmelsen, at det skal tillægges vægt, hvis oplysningerne vedrører et barn. Behandlingen af følsomme oplysninger indebærer en større risiko for negativ indvirkning end behandlingen af almindelige oplysninger. Hvis oplysningerne allerede er offentligt tilgængelige kan det omvendt tale for en begrænset negativ indvirkning, jf. herved EU-Domstolens dom i de forenede sager C-468/10 og C-469/10 (ASNEF), præmis 44. Der kan også lægges vægt på, hvordan oplysningerne behandles. Gøres oplysningerne offentligt tilgængelige eller anvendes de til profilering eller anden form for mere indgribende behandling, er hensynet til den registrerede mere tungtvejende, end hvis der foretages mindre indgribende former for behandling. Den dataansvarlige kan i nogle situationer reducerer den potentielle negative indvirkning ved at iværksætte forskellige foranstaltninger, f.eks. begrænset antallet af behandlede oplysninger, etablere mere omfattende sikkerhedsprocedurer end i øvrigt krævet efter forordningen mv.

Når de relevante interesser hos både den dataansvarlige og den registrerede er identificeret og vurderet, skal den dataansvarlige foretage en afbalancering af disse interesser og på den baggrund vurdere, om den dataansvarliges interesse i behandlingen overstiger hensynet til den registrerede. På samme måde som vurderingerne af parternes interesser beror også afvejningen heraf på en konkret vurdering, der rummer et betydeligt element af skøn. Som det gælder for andre bestemmelser, der efterlader et stort rum for det konkrete skøn, giver bestemmelsen dermed på den ene side en fleksibilitet, der sikrer mod uhensigtsmæssige resultater og sikrer, at bestemmelsen kan tilpasses den teknologiske udvikling, men gør det på den anden side også vanskeligt at forudse retstilstanden. Det er i første omgang den dataansvarlige, der skal vurdere, om afvejningsreglen giver hjemmel til behandlingen, og som dermed må påtage sig standpunktsrisikoen ved at måtte fortolke bestemmelsen.

Det følger af præambelbetragtning 47, at det skal indgå i vurderingen, om den registrerede med rimelighed kunne forvente en behandling af oplysningerne, og at "den registreredes interesser og grundlæggende rettigheder navnlig kan gå forud for den dataansvarliges interesser, hvis personoplysninger behandles under omstændigheder, hvor re-

Afvejningen af
interesserne

– den
registreredes
forventninger

gistrerede ikke med rimelighed forventer viderebehandling”. Når det angives, at interesseafvejningen “navnlig” kan falde ud til fordel for den registrerede, hvis denne ikke kunne forvente en viderebehandling, kan det læses som en formodning for, at afvejningen vil falde ud til fordel for den dataansvarlige, når den registrerede kunne forvente en viderebehandling. Der er dog næppe grundlag for at opstille en så kategorisk formodningsregel, som heller ikke synes at have støtte i praksis. Den registreredes forventninger til en eventuel viderebehandling må således antages at være ét blandt flere kriterier, der kan inddrages i den samlede vurdering.

Herudover angiver forordningen ikke nærmere retningslinjer for afvejningen. Den eksisterende praksis kan give en vis vejledning, omend de konkrete forhold ofte vil afvige.

Interesseafvejningens konkrete natur indebærer, at præjudicielle afgørelser fra EU-Domstolen sjældent bidrager til at kaste lys over afvejningen, da den konkrete vurdering foretages af de nationale domstole. Enkelte begrænsede bidrag foreligger dog. I *Google Spain*-afgørelsen (C-131/12), fastslog Domstolen således (præmis 81), at offentlighedens interesse i adgang til personoplysninger i særlige tilfælde kan veje tungere end den registreredes interesser, bl.a. under hensyntagen til, hvilken rolle den registrerede har i det offentlige liv. I C-13/16 (*Valsts policijas Rīgas*) fastslog Domstolen, at en tredjemands legitime interesse i at få udleveret oplysninger om en skadevolder med henblik på at anlægge civil søgsmål om erstatning potentielt kunne overstige den registreredes interesse, selvom denne var et barn. Afgørelsen fortolker bestemmelsen i det tidligere persondatadirektiv. Selvom bestemmelsen i forordningen (i modsætning til det tidligere direktiv) eksplicit angiver, at der er et særligt hensyn at tage til børn, må det fortsat gælde, at afvejningen også i dette tilfælde kan falde ud til fordel for den dataansvarlige.

– praksis fra EU-Domstolen

Datatilsynet har truffet en række afgørelser om art. 6, stk. 1, litra f (og den tilsvarende bestemmelse i direktivet) og interesseafvejningen. Se nærmere hertil Korfits Nielsen & Lotterup, Databeskyttelsesforordningen og databeskyttelsesloven med kommentarer, s. 382 ff. med omtale af sager inden for forskellige områder.

– praksis fra Datatilsynet

Den behandlede praksis inddeles af forfatterne i følgende områder:

- offentliggørelse af medarbejderoplysninger
- videregivelse af medarbejderoplysninger til fagforeninger
- arbejdsgiveres videregivelse af oplysninger om ansattes løn
- foreningers videregivelse af medlemsoplysninger
- offentliggørelse af billeder og visning af direkte optagelser på internettet
- hensynet til informations- og ytringsfriheden samt kunstnerisk eller litterær virksomhed mv.,
- whistleblowerordninger
- diskotekers behandling af oplysninger om gæster, slægtsforskning, kontrol med medarbejders brug af hjemmesider og e-mail
- forsikringsselskabers observationsrapporter mv.
- arbejdsgiveres behandling af fratrådte medarbejders e-mailkonto
- overdragelse af kunderegistre
- due diligence og virksomhedsoverdragelse
- konkursboer
- samkøring i den private sektor
- videregivelse af oplysninger til kreditoplysningsbureauer, pengeinstitutters videregivelse af kreditoplysninger
- advarselsregistre, spærreliste og stillingsbesættende virksomheder.

4.5. Offentlige myndigheder

Det følger af art. 6, stk. 1, sidste afsnit, at interesseafvejningsreglen ikke kan anvendes af offentlige myndigheder, der behandler oplysninger som led i udførelsen af deres opgaver. I betragtning 47 angives som årsag hertil, at det er op til lovgiver ved lov at fastsætte retsgrundlaget for offentlige myndigheders behandling af personoplysninger. Umiddelbart kunne dette indikere, at offentlige myndigheder aldrig kan anvende art. 6, stk. 1, litra f, som behandlingsgrundlag. Datatilsynet lægger imidlertid sin praksis til grund, at bestemmelsen efterlader et snævert rum for offentlige myndigheders behandling, når dette ikke sker som led i udførelsen af deres myndighedsopgaver (og behandlingen dermed ikke kan hjemles i art. 6, stk. 1, litra e).

Se således Datatilsynets sag nr. 2021-212-2937, hvor tilsynet svarede på en forespørgsel fra Herning Kommune. Kommunen ønskede at registrere telefonnummer på de ansattes pårørende, så disse kunne kontaktes i tilfælde af akut behov herfor. Kommunen ønskede bl.a. svar på, hvilke

behandlingsgrundlag der kunne anvendes, idet kommunen fandt det formalistisk og praktisk vanskeligt at indhente samtykke fra de pårørende. Datatilsynet afviste, at behandlingen kunne hjemles i art. 6, stk. 1, litra e, da den ikke var nødvendig for kommunes varetagelse af sine opgaver som offentlighed myndighed. Derimod fandt tilsynet, at behandlingen kunne hjemles i afvejningsreglen og udtalte herved, at der er et snævert rum for offentlige myndigheders behandling af oplysninger efter litra f. Tilsynet anførte videre, at behandlingen kunne anses for nødvendig for, at kommunen på en hensigtsmæssig måde kunne fungere som offentlig myndighed, herunder med henblik på at varetage sine ansattes interesser.

5. Valg og skift af behandlingsgrundlag (konkurrerende behandlingsgrundlag) – uden for samtykke

Forordningens art. 6 indeholder ingen regulering af spørgsmålet om valg mellem behandlingsgrundlag, når flere af dem potentielt kan dække den samme behandling, og de tilhørende præambelbetragtninger omtaler, med en mindre undtagelse, heller ikke spørgsmålet. På tilsvarende vis indeholder forordningen ingen eksplicit regulering af, om den dataansvarlige kan skifte fra et behandlingsgrundlag til et andet under vejs i behandlingen.

Den følgende drøftelse af disse spørgsmål er baseret på min [artikel](#) “Konkurrerende behandlingsgrundlag – valg og skift af behandlingsgrundlag i databeskyttelsesretten med særlig fokus på samtykke” trykt i Juristen, 2022, s. 83 ff.

Det kunne på den baggrund være en nærliggende konklusion, at den dataansvarlig frit kan vælge og skifte mellem behandlingsgrundlagene, når flere kan finde anvendelse. En pligt for den dataansvarlige til at prioritere mellem flere anvendelige behandlingsgrundlag følger således hverken af forordningsteksten, der blot oplister de seks behandlingsgrundlag, eller præambelbetragtningerne.

Som allerede anført lægger både EDPB og Datatilsynet imidlertid til grund, at ét behandlingsgrundlag i den konkrete behandlingssituation kan være mere velegnet (eller “passende”) end et andet, og at den dataansvarlige derfor ikke nødvendigvis har fuld valgfrihed mellem konkurrerende behandlingsgrundlag. Spørgsmålet har sin væsentligste

og største praktisk betydning i situationer, hvor den registrerede har tilbagekaldt et samtykke. Af samme grund er netop dette spørgsmål særskilt behandlet i forbindelse med beskrivelsen af samtykket i afsnit 2 ovenfor (se afsnit 2.4 og 2.6). Det følgende omhandler valg og skift af behandlingsgrundlag, i de situationer hvor valget står mellem andre behandlingsgrundlag end samtykke.

Når samtykke kan være et problematisk valg i tilfælde af konkurrerende behandlingsgrundlag, skyldes det primært, at det kan give den registrerede en fejlagtig opfattelse af at være i kontrol med behandlingen. Dette gør sig kun gældende for samtykket. Adgangen til at foretage behandling efter de andre behandlingsgrundlag afgøres af forhold, som er uden for den registrerede kontrol. Hensynet til, at den registrerede ikke får en fejlagtig opfattelse af kontrol, kan derfor heller ikke begrunde, at den dataansvarlige ikke har valgfrihed mellem andre konkurrerende behandlingsgrundlag. Ikke desto mindre synes både EDPB og Datatilsynet at lægge til grund, at den dataansvarlige ikke kun i valget mellem samtykke og andre behandlingsgrundlag men generelt skal vurdere, hvad det er det mest passende blandt flere konkurrerende behandlingsgrundlag. I Rejsekort-sagen (sag nr. 2019-32-0709) fastslog Datatilsynet således, at “i forholdet til valget af behandlingsgrundlag skal en dataansvarlig altid forud for påbegyndelsen af behandling af personoplysninger gøre sig klart, hvilket behandlingsgrundlag i databeskyttelsesforordningens art. 6, der er det mest passende”. EDPB synes at være af en tilsvarende opfattelse.

Valg af behandlingsgrundlag

Se eksempelvis EDPB's retningslinjer 2/2019, pkt. 17, hvor det angives, at litra f i nogle tilfælde kan indeholde et “mere passende” grundlag for behandling end litra b.

Der foreligger dog ingen praksis eller vejledninger, der giver mere generelle retningslinjer for, hvornår et behandlingsgrundlag kan anses for mere passende end et andet (uden for samtykketilfældet), og i det hele taget er det vanskeligt at sige noget mere generelt herom.

Der er ét sted, hvor forordningen forholder sig til spørgsmålet. I præambelbetragtning 46 anføres, at litra d om beskyttelse af andre fysiske personers vitale interesser, kun finder anvendelse, hvis ingen af de andre behandlingsgrundlag finder anvendelse. Den tidligere art. 29-gruppe har i Retningslinjer om automatiske individuelle afgørelser og

profilering i henhold til forordning 2016/679, WP251rev.01, antaget, at dette tilsvarende gælder, når behandlingen er nødvendig for at beskytte den registreredes vitale interesser, og at litra d således altid vil være sekundær i konkurrence med de øvrige behandlingsgrundlag.

Selv hvis man følger tilsynsmyndighedernes opfattelse af, at dette kan være tilfældet, bør det derfor heller ikke føre til, at den dataansvarlige anses for at overtræde forordningen i de mange situationer, hvor det ikke er åbenbart, at et behandlingsgrundlag er mere passende end et andet. Forordningen er kompleks og efterlader mange ubesvarede spørgsmål. Der er ikke grund til at øge denne kompleksitet ved at pålægge dataansvarlige en vanskelig opgave med at vurdere, hvad der er det mest passende blandt flere i sig selv lovlige behandlingsgrundlag, medmindre det reelt giver den registrerede en klart bedre beskyttelse. Udgangspunktet må derfor være, at den dataansvarlige har valgfrihed mellem behandlingsgrundlagene, medmindre hensyn til den registrerede klart tilsiger, at ét behandlingsgrundlag vælges fremfor et andet. Det er vanskeligt at se, hvad der, i mangel af særskilt regulering herom i forordningen, skulle begrunde en indskrænkning i den dataansvarliges valgfrihed, hvis det er uden betydning for beskyttelsen af den registrerede, hvilket behandlingsgrundlag, der vælges. Det kan også udtrykkes således, at der i det hele taget kun eksisterer et "mest passende" behandlingsgrundlag, hvis ét af behandlingsgrundlagene giver den registrerede en klart bedre beskyttelse end de øvrige. Om dette er tilfældet må bero på en konkret vurdering, og den dataansvarlige må have et ikke ubetydeligt rum for denne vurdering. Dette understøttes også af Rejsekortsagen (selvom den omhandlede samtykke), hvor Datatilsynet i sin begrundelse bl.a. lagde vægt på, at de konkurrerende behandlingsgrundlag var "klart mere passende".

Skulle der (uden for samtykkesituationen) bestå en situation, hvor ét behandlingsgrundlag rent faktisk er mere passende end et andet, rejser det spørgsmålet, om den dataansvarlige kan skifte behandlingsgrundlag, hvis den dataansvarlige oprindeligt har startet behandlingen på baggrund af det "forkerte" grundlag. Spørgsmålet er behandlet i relation til samtykke i afsnit 2.4, hvor det blev konkluderet, at den dataansvarlige kan skifte behandlingsgrundlag, når behandlingen er nødvendig i de situationer, som er angivet i art. 17, stk. 3, dvs. når behand-

Skift af behandlingsgrundlag

lingen er omfattet af art. 6, stk. 1, litra c eller f eller er nødvendig for at fastlægge, forfølge eller forsvare et retskrav. Art. 17, stk. 3, er ikke begrænset til situationer, hvor den registrerede trækker et samtykke tilbage. Tværtimod taler endnu mere for at give den dataansvarlige mulighed for at skifte behandlingsgrundlag og fortsætte behandlingen, når det oprindelige behandlingsgrundlag ikke er samtykke. Som anført giver indhentning af samtykke den registrerede en berettiget forventning om at kunne bringe behandlingen til ophør ved at trække samtykket tilbage. En tilsvarende forventning etableres ikke, når det oprindelige behandlingsgrundlag er et andet end samtykke. Den dataansvarlige må derfor også som minimum kunne skifte behandlingsgrundlag i samme omfang, som når det oprindelige behandlingsgrundlag er samtykke.

Spørgsmålet er herefter, om det er muligt at foretage skift af behandlingsgrundlag i videre omfang, når det oprindelige behandlingsgrundlag ikke er samtykke, eftersom der ikke sker samme form for vildledning af den registrerede. Eller med andre ord, om den dataansvarlige fortsat kan opbevare og behandle oplysninger, når det er nødvendigt for at opfylde en kontrakt (litra b) eller efter interesseafvejningsreglen i litra f. Disse to situationer er ikke medtaget i art. 17, stk. 3, hvilket taler for, at den dataansvarlige ikke kan bibeholde oplysningerne og fortsætte behandlingen. Da art. 17, stk. 3, imidlertid ikke en bestemmelse, der eksplicit tager stilling til, hvornår der kan ske skift af behandlingsgrundlag, er resultatet ikke givet med bestemmelsen. Der kan og bør næppe opstilles en generel regel om, at den dataansvarlige skal slette oplysninger og dermed ikke kan skifte behandlingsgrundlag i disse situationer. Der er ingen væsentlige hensyn til den registrerede, der tilsiger, at behandlingen skal ophøre i denne situation. Et skift af behandlingsgrundlag vil typisk ikke indebære, at behandlingen fortsætter i længere tid, end den havde gjort efter det oprindeligt valgte (forkerte) behandlingsgrundlag, og den registrerede er heller ikke blevet stillet i udsigt selv at kunne afgøre, hvor længe behandlingen fortsætter. Mest taler derfor for, at den dataansvarlige i disse situationer kan skifte behandlingsgrundlag. Det må derfor antages, at den dataansvarlige altid kan skifte behandlingsgrundlag, når konkurrencen består mellem andre behandlingsgrundlag end samtykke.

6. Følsomme personoplysninger

6.1. Forbud mod behandling af følsomme oplysninger – art. 9, stk. 1

Forordningens art. 9 regulerer behandlingen af “særlige kategorier af oplysninger”. Denne type oplysninger benævnes sædvanligvis og også i det følgende “følsomme oplysninger”.

Begrebet “følsomme oplysninger” anvendes ikke i selve forordningsteksten, men er anvendt i præambelbetragtning 10 og anvendes også i databeskyttelsesloven, jf. dennes § 7. I den offentlige debat anvendes ofte det uhensigtsmæssige begreb “personfølsomme” oplysninger, der ikke er en databeskyttelsesretlig term, og som bør undgås, fordi det er uklart, om der hermed menes personoplysninger i bred forstand eller følsomme personoplysninger.

Bestemmelsen indeholder i stk. 1 som retsteknisk udgangspunkt et egentligt forbud mod behandling af følsomme oplysninger:

Behandling af personoplysninger om race eller etnisk oprindelse, politisk, religiøs eller filosofisk overbevisning eller fagforeningsmæssigt tilhørsforhold samt behandling af genetiske data, biometriske data med det formål entydigt at identificere en fysisk person, helbredsoplysninger eller oplysninger om en fysisk persons seksuelle forhold eller seksuelle orientering er forbudt.

Bestemmelsens angivelse af, hvilke oplysninger der er undergivet den stærkere beskyttelse i art. 9 (de følsomme oplysninger), er udtømmende.

Udtømmende

Begreberne “genetiske data” og “biometriske data” er defineret i forordningens art. 4, nr. 13 og 14.

I *Lindqvist-sagen* (C-101/01) lagde EU-Domstolen til grund, at der skulle anlægges en bred fortolkning af begrebet “oplysninger om helbredsforhold” i det tidligere persondatadirektivs art. 8 og nåede til, at begrebet også omfattede forholdsvis uskyldige oplysninger om, at en kollega havde beskadiget foden og var delvist sygemeldt. I sag C-

184/20 (*Vyriausioji tarnybinės etikos komisija*) har EU-Domstolen bekræftet, at dette også gælder efter forordningen.

Selvom oplysninger ikke direkte udtrykker nogle af de forhold, der angives i art. 9, kan oplysningerne være omfattet af art. 9, hvis det er muligt at udlede følsomme oplysninger af oplysningerne. Se således EU-Domstolens afgørelse i den netop nævnte C-184/20 (*Vyriausioji tarnybinės etikos komisija*), hvor Domstolen slog fast (præmis 127), at behandlingen af personoplysninger, der indirekte kan afsløre følsomme oplysninger, er omfattet af art. 9. Hvis der gennem "en intellektuel refleksion som består i sammenstilling eller deduktion" kan afsløres følsomme oplysninger om en person, har oplysningerne karakter af følsomme oplysninger, jf. dommens præmis 120. Sagens spørgsmål var, om navn på ægtefælle, samlever eller partner, kunne give oplysning om parternes seksuelle orientering. Domstolen anfører i præmis 100, at dette kan være tilfældet, men fastslår ikke, at det altid vil være det.

"Indirekte"
følsomme
personoplysninger

Sagens hovedspørgsmål var, om national lovgivning, hvorefter en offentlig tilsynsmyndighed på sin hjemmeside skulle offentliggøre oplysninger om bl.a. ledelsespersoner i offentligt finansierede organisationer, stred mod forordningen. Formålet med loven var at sikre offentlige beslutningstageres upartiskhed og forebygge interessekonflikter og korruption. Domstolen fandt, at den nationale lovs krav om offentliggørelse af en række af oplysningerne, herunder navnet på ægtefælle, var i strid med forordningen. Se også om det nationale råderum under forordningen kap. 1.5.2.

Hermed kan ganske mange oplysninger potentielt få karakter af følsomme oplysninger, ikke mindst i lyset af mulighederne for big data-analyser mv.

At en behandling af ikke-følsomme oplysninger, hvoraf der kan udledes følsomme oplysninger, kan udgøre en behandling af følsomme oplysninger er dog ikke et nybrud, se eksempelvis Art. 29-gruppens Advice paper on special categories of data ("sensitive data"): "The term 'data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, trade-union membership' is to be understood that not only data which by its nature contains sensitive information is covered by this provision, but also data from which sensitive information with regard to an individual can be concluded". EU-Domstolen har også selv i sin udtalelse 1/15 om PNR-aftalen mellem EU og Canada, pkt. 128, lagt

til grund, at aftalens anvendelse af begrebet følsomme oplysninger (der svarede til begrebsanvendelsen i persondatadirektivet), kunne omfatte oplysninger, der kunne udledes af ikke-følsomme oplysninger.

Det må dog omvendt være klart, at ikke enhver teoretisk sandsynlighed for, at en oplysning indirekte kan afsløre følsomme oplysninger, indebærer, at oplysningen omfattes af art. 9. Det vil bero på en konkret vurdering, hvornår dette er tilfældet. EU-Domstolen angiver ikke nærmere retningslinjer i sin dom for denne vurdering, som kan give anledning til vanskelige grænsedragninger. Vil et flyselskabs registrering af passagerers ønske om ikke at få serveret svinekød eksempelvis være en oplysning om religiøs overbevisning? Fravalget kan være religiøst betinget men behøver ikke være det. Vil tv-overvågning foran en bar for homoseksuelle være oplysninger om seksuel orientering, når baren også har heteroseksuelle gæster?

– afgrænsningskriterier

Ved den konkrete vurdering må der lægges vægt på sandsynligheden for, at forholdet rent faktisk har karakter af en følsom oplysning. Når en bar, der har mange homoseksuelle gæster, også har heteroseksuelle gæster, kan oplysninger om, hvem der besøger baren, næppe udgøre en følsom oplysning. Omvendt vil en oplysning om, at to personer af samme køn er gift, med meget stor sandsynlighed sige noget om deres seksuelle orientering, hvilket taler for, at der er tale om følsomme oplysninger. (selvom muligheden for et proformaægteskab ikke kan udelukkes).

– sandsynligheds-vurdering

Hvis afsløringen af følsomme oplysninger forudsætter, at de oplysninger, den dataansvarlige er i besiddelse af, sammenstilles med andre oplysninger, må det kunne tillægges vægt, hvor vanskeligt det er for den dataansvarlige at foretage denne sammenstilling. Kræver sammenstillingen eksempelvis adgang til oplysninger hos en tredjepart, må det vurderes, hvor sandsynligt det er, at den dataansvarlige kan få en sådan adgang, og hvor vanskeligt det i det hele taget vil være at foretage sammenstillingen. Denne vurdering har lighedstræk med vurderingen af, om en oplysning indirekte kan identificere en person (se herom kap. 2.1.1 ovenfor).

– den påkrævede indsats

I sit forslag til afgørelse i C-184/20, pkt. 87, peger generaladvokaten også på lighederne mellem vurderingen af, om oplysninger indirekte kan identificere en fysisk person og vurderingen af, om oplysninger kan

afsløre følsomme oplysninger. Generaladvokaten anvender det dog kun til at fastslå, at lovgiver har taget højde for den mulighed, at en oplysning kan rekonstrueres ved at sammenstille eller sammensætte forskellige oplysninger.

Om vurderingen af, hvorvidt en oplysning indirekte kan identificere en person anføres følgende i præambelbetragtning 26:

[...] For at afgøre, om en fysisk person er identificerbar, bør alle midler tages i betragtning, der med rimelighed kan tænkes bragt i anvendelse af den dataansvarlige eller en anden person til direkte eller indirekte at identificere, herunder udpege, den pågældende. For at fastslå, om midler med rimelighed kan tænkes bragt i anvendelse til at identificere en fysisk person, bør alle objektive forhold tages i betragtning, såsom omkostninger ved og tid der er nødvendig til identifikation, under hensyntagen til den tilgængelige teknologi på behandlingstidspunktet og den teknologiske udvikling [...]

Det er muligt, at disse betragtninger også kan tillægges vægt ved vurderingen af, om oplysninger kan afsløre følsomme oplysninger.

Det må endvidere antages, at der kan lægges vægt på formålet med behandlingen. Når et flyselskab registrerer passagerernes madønsker, har det ikke til formål at behandle oplysninger om religiøs overbevisning. Hvis andre anvender oplysningerne til eksempelvis at føre statistik over passagerers mulige religiøse overbevisning, er det mere nærliggende, at der sker en behandling af følsomme oplysninger. Formålskriteriet er også lagt til grund af både Datatilsynet og EDPB. Datatilsynet har således i en udtalelse fra september 2021 (sag nr. 2020-212-2099) fastslået, at Familieretshusets oplysninger om, at to personer af samme køn har ansøgt om at indgå ægteskab i Danmark, som udgangspunkt ikke skal anses for at være følsomme personoplysninger, men at der altid skal foretages en konkret vurdering. I udtalelsen anføres som begrundelse for resultatet, at "Datatilsynet herved bl.a. [har] lagt vægt på, at formålet med behandlingen af oplysningerne ikke er at behandle oplysninger om ansøgernes seksuelle forhold mv., ligesom oplysningerne om køn alene anvendes til at verificere, hvorvidt der er overensstemmelse mellem oplysningerne i ansøgningen og oplysningen i ansøgernes pas".

– formål

Udtalelsen er i overensstemmelse med fast praksis, hvorefter oplysning om, at en person lever i registreret partnerskab, som udgangspunkt anses for oplysning om civilstand og ikke oplysning om seksuel orientering, jf. Kortfits Nielsen og Lotterup, Databeskyttelsesforordningen og databeskyttelsesloven, s. 423. Datatilsynet har ikke meldt ud, at EU-Domstolens dom i C-184/20 giver anledning til en praksisændring. Det kan dog ikke udelukkes, at dommen indebærer, at oplysninger om ægteskab eller samliv mellem to personer af samme køn skal anses for følsomme oplysninger, også i situationer, hvor det ikke er formålet med behandlingen at behandle oplysninger om seksuel orientering.

Også EDPB har anvendt formålsbetragtninger i afgrænsningen af, hvornår en oplysning har karakter af en indirekte følsom oplysning. I retningslinjer 3/2019 om brug af videoudstyr til behandling af personoplysninger, pkt. 62 og 64 anfører rådet således: “[V]ideoovervågning anses imidlertid ikke altid for at være behandling af særlige kategorier af personoplysninger ... Hvis videooptagelserne derimod behandles *for at udlede* særlige kategorier af oplysninger, finder artikel 9 anvendelse” (fremhævet her).

I sit forslag til afgørelse i C-184/20, pkt. 87, afviste generaladvokaten, at der kunne anvendes et formålskriterium. EU-Domstolen tager imidlertid ikke stilling til dette i sin dom. Når Domstolen anfører, at der foreligger indirekte følsomme oplysninger, hvis oplysningerne gennem “en intellektuel refleksion som består i sammenstilling eller deduktion” kan afsløre følsomme oplysninger, lægger det ikke op til at inddrage formålet med behandlingen. I mangel af en eksplicit stillingtagen kan dommen dog næppe tages til indtægt for, at det er udelukket at inddrage formålet med behandlingen.

I en længere og ganske læseværdig artikel om begrebet følsomme oplysninger, foreslår Quinn & Malgieri en to-trins-test i vurderingen af, om der foreligger indirekte følsomme oplysninger. Efter testen skal det først vurderes, om formålet er at behandle følsomme oplysninger. I så fald foreligger der altid en behandling af følsomme oplysninger. Er formålet ikke at behandle følsomme oplysninger, skal det herefter vurderes, om “it is reasonably foreseeable that in certain contexts the data in question could reveal sensitive aspects of data subjects or allow them to be inferred”. Der er næppe tvivl om, at formålskriteriet er og bør være centralt, men dommen i C-184/20 synes ikke at efterlade mulighed

for, at det gøres til det primære kriterium. Artiklen er skrevet før dommens afsigelse.

Muligvis kan det også tillægges vægt, hvor privatlivsindgribende behandlingen vil være for den registrerede – eller med andre ord den potentielle skadeeffekt. Hvis en oplysning om, at to personer af samme køn er gift, er en oplysning om seksuel orientering, vil det samme i princippet gælde en oplysning om, at en kvinde og mand er gift. Beskyttelsesbehovet og oplevelsen af, hvor privatlivsindgribende behandlingen er, vil dog ikke nødvendigvis være identisk. Art. 9 rummer således et element af minoritetsbeskyttelse, der må kunne tillægges vægt ved vurderingen af, om en oplysning skal behandles som en følsom oplysning.

– potentiel
skadevirkning

I Lindqvist-sagen (C-101/01) lagde EU-Domstolen ikke til grund, at oplysninger om, at navngivne personer arbejdede som frivillige i en lokal folkekirke, udgjorde følsomme oplysninger, selvom disse oplysninger, i hvert fald indirekte, måtte siges at give informationer om de pågældendes religiøse overbevisning. Både et formålskriterium og et skadekriterium kan bidrage til at forklare resultatet. Da dommen ikke drøfter kvalifikationen af disse oplysninger nærmere, er det dog ikke muligt at udlede, hvad Domstolen har lagt vægt på.

Selv i situationer, hvor en behandling angår “direkte” følsomme oplysninger, og uanset at der med EU-Domstolens praksis skal anlægges en bred fortolkning af de oplysningstyper, der er angivet i art. 9, er det nødvendigt at indfortolke en form for bagatelgrænse i bestemmelsen. Det er således ikke enhver oplysning, der i en eller anden forstand informerer om de forhold, som er angivet i art. 9, der vil have karakter af en følsom oplysning. Det har eksempelvis altid været antaget i Danmark, at et almindeligt portrætbillede ikke omfattes af art. 9, selvom billedet oplyser om den portrætteredes race.

Bagatelgrænse

Det er nu også fastslået i forordningens betragtning 51, at behandling af fotografier ikke systematisk skal anses for behandling af følsomme oplysninger.

På tilsvarende vis vil oplysninger om, at en person er syg uden angivelse af, hvori sygdommen består, næppe udgøre helbredsoplysninger, jf. Korfits Nielsen & Lotterup, Databeskyttelsesforordningen og data-

beskyttelsesloven med kommentarer, s. 421 f. EU-Domstolens kvalifikation af oplysninger om frivilligt arbejde i en folkekirke som ikke-følsomme oplysninger, jf. lige ovenfor om *Lindqvist*-sagen (C-101/01), kan eventuelt også ses som udtryk for sådanne bredere betragtninger om en bagatelgrænse. Det samme kan muligvis EDPB's angivelse af, at videooptagelser, der viser en registreret, som bruger briller eller kørestol, ikke i sig selv skal anses for at være behandling af følsomme oplysninger, jf. retningslinjer 3/2019, pkt. 63.

Når art. 9 nogle gange undergives en indskrænkende ordlydsfortolkning, skyldes det navnlig, at bestemmelsen ikke rummer samme fleksible afvejningsregel for behandling, som gælder efter art. 6. Der vil derfor kunne opstå situationer, hvor det er vanskeligt at finde en hjemmel til behandlingen efter art. 9, men hvor behandlingen omvendt har så "uskyldig" karakter (en meget lav grad af integritetskrænkelse), og hvor det praktiske behov for at kunne foretage behandlingen er så stort, at det vil blive oplevet som unødigt formalistisk at forbyde behandlingen.

Se også Udsen, *De informationsretlige grundsætninger*, s. 401 ff.

Sådanne betragtninger må dog omvendt ikke tillægges for stor vægt, og det klare udgangspunkt er, at oplysninger, der kan henregnes til de oplysningstyper, som angives i art. 9, beskyttes som følsomme oplysninger, også selvom deres behandling kun indebærer en begrænset skaderisiko for den registrerede.

6.2. Undtagelser – adgang til behandling af følsomme oplysninger efter art. 9, stk. 2

Der vil i mange situationer være behov for, at myndigheder og virksomheder kan behandle følsomme oplysninger. Art. 9, stk. 2, indeholder derfor også en række undtagelser fra forbuddet mod behandling af følsomme oplysninger i stk. 1.

6.2.1. Samtykke

Efter art. 9, stk. 2, litra a, kan der ske behandling af følsomme oplysninger, når den registrerede har givet sit samtykke.

Forordningens definition af samtykkebegrebet i art. 4, nr. 11, gælder på tværs af lovens regler, og kravene til samtykket er således som udgangspunkt identiske for behandling af almindelige og følsomme oplysninger. Om begrebet henvises derfor til afsnit 2 ovenfor. I den konkrete fortolkning af, om samtykket er “frivilligt”, “specifikt” og “informeret” kan det dog tillægges betydning, om samtykket vedrører følsomme oplysninger. Herudover skal samtykket efter art. 9 være “udtrykkeligt”, mens det efter art. 6 kun skal være “utvetydigt”. Det er vanskeligt at fastlægge den mere præcise forskel på “udtrykkeligt” og “utvetydigt”, men overordnet skærper udtrykkelighedsbetingelsen kravene til, hvor tydeligt den registrerede skal udtrykke sin vilje til at acceptere behandlingen af personoplysninger. Brug af en ydelse kan således næppe udgøre et udtrykkeligt samtykke, jf. om denne problemstilling i relation til utvetydighedskravet afsnit 2.3.

6.2.2. Arbejds-, sundheds- og socialretlige forpligtelser

Efter art. 9, stk. 2, litra b, kan behandlingen ske, når det er nødvendigt for at overholde den dataansvarliges eller den registreredes arbejds-, sundheds- og socialretlige forpligtelser efter EU-retten, national ret eller kollektive overenskomster. I overensstemmelse hermed fastslår DBL § 7, stk. 2, at behandlingen kan ske, når det er nødvendigt af hensyn til den dataansvarliges eller den registreredes arbejdsretlige forpligtelser.

6.2.3. Fysiske personers vitale interesser

Efter art. 9, stk. 2, litra c, kan behandlingen ske, når det er nødvendigt for at beskytte den registreredes eller andres vitale interesser, og det ikke er muligt at indhente samtykke fra den registrerede. Bestemmelsen vil kunne finde anvendelse, når den registrerede f.eks. på grund af sygdom ikke er i stand til at give samtykke, eller når den registrerede er blevet umyndiggjort. Begrebet “vitale interesser” skal forstås på samme måde som i art. 6, stk. 1, litra d.

6.2.4. Visse typer af organisationer

Efter art. 9, stk. 2, litra d, kan non-profit organisationer, der har et politisk, religiøst, filosofisk eller fagforeningsmæssigt sigte, under visse

betingelser behandle oplysninger om medlemmer og samarbejdspartnere.

6.2.5. Oplysninger offentliggjort af den registrerede selv

Efter art. 9, stk. 2, litra e, kan behandlingen ske, når de pågældende oplysninger er blevet offentliggjort af den registrerede selv. Bestemmelsen hviler på den antagelse, at der ikke længere består noget beskyttelsesbehov, når den registrerede selv har valgt at gøre oplysningerne tilgængelige for offentligheden. Bestemmelsen hidrører fra det tidligere persondatadirektiv og tog oprindeligt primært sigte på offentliggørelse gennem de traditionelle massemedier. Med udbredelsen af internettet og sociale medier har bestemmelsen fået en anden og større betydning, idet mange oplysninger gøres tilgængelige af den registrerede selv via Facebook og andre sociale medier. Dette rejser spørgsmålet, om en sådan tilgængeliggørelse indebærer, at oplysningerne er "offentliggjort" i § 7, stk. 2, nr. 3's forstand. At en Facebook-bruger deler oplysninger om sig selv med sine Facebook-venner indebærer som udgangspunkt ikke en offentliggørelse i bestemmelsens forstand, heller ikke selvom den pågældende har nogle hundrede Facebook-venner. Gøres oplysninger omvendt tilgængelige på en åben Facebook-profil, hvortil alle har adgang, vil der være tale om en offentliggørelse. Tilsvarende hvis oplysningerne i øvrigt lægges ud på en åben hjemmeside.

Se nærmere til emnet, Udsen i Henrichsen m.fl. (red.), Ret, informatik og samfund, s. 321 ff.

6.2.6. Retskrav

Efter art. 9, stk. 2, litra f, kan behandlingen ske, når den er nødvendig for at kunne fastlægge eller forfølge et retskrav. Dette gælder både retskrav, der tilkommer den registrerede, den dataansvarlige og tredjeparter. Bestemmelsen fortolkes således, at den hjemler offentlige myndigheders behandling af følsomme oplysninger som led i myndighedsudøvelse, idet myndighedsudøvelsen fastlægger borgernes retskrav over for staten og omvendt. Hermed får bestemmelsen et betydeligt og praktisk væsentligt anvendelsesområde. Bestemmelsen kan også anvendes af private parter og giver eksempelvis forsikringsselskaber

hjemmel til at behandle følsomme oplysninger, når det er nødvendigt for at fastslå, om forsikringstagere har krav på erstatning.

6.2.7. Øvrige undtagelser

Art. 9, Stk. 2, giver i litra g-j hjemmel til behandling i en række andre situationer, der primært tager sigte på bredere samfundsinteresser, herunder folkesundhedsformål og arkivformål.

6.3. Forholdet mellem art. 6 og 9

Der har siden det tidligere persondatadirektiv (der indeholdt tilsvarende bestemmelser) været usikkerhed om forholdet mellem art. 6 og 9. Man kan opfatte forholdet sådan, at art. 9 afgør, hvornår der må behandles følsomme oplysninger, mens art. 6 afgør, hvornår der må behandles oplysninger, der ikke er følsomme ("almindelige personoplysninger"). Man kan også opfatte det sådan, at behandlingen af alle personoplysninger, også de følsomme, skal have hjemmel i art. 6, men at de følsomme herudover også skal være hjemlet i art. 9.

Til støtte for den førstnævnte opfattelse taler, at en række af undtagelserne i art. 9, stk. 2, synes formuleret som selvstændige behandlingsgrundlag mere end som bestemmelser, der skal supplere behandlingsgrundlagene i art. 6. Det kan således forekomme en smule kunstigt, at et samtykke til behandling af følsomme oplysninger på en gang kræver et udtrykkeligt samtykke efter art. 9 og et utvetydigt samtykke efter art. 6. Der kan også peges på formuleringen i art. 17, stk. 1, litra c, hvorefter den dataansvarlige er forpligtet til at slette oplysninger, når "den registrerede trækker det samtykke, der er grundlaget for behandlingen, jf. artikel 6, stk. 1, litra a, *eller* artikel 9, stk. 2, litra a [...] tilbage" (fremhævet her). Denne formulering synes at forudsætte, at art. 9 kan udgøre et selvstændigt hjemmelsgrundlag.

Omvendt kan peges på, at art. 6 ikke efter sin ordlyd er begrænset til almindelige oplysninger. Teoretisk kan man endvidere forestille sig, at en behandling er dækket af en af undtagelserne i art. 9, stk. 2, uden samtidig at være dækket af et behandlingsgrundlag i art. 6. Hvis behandlingen af følsomme oplysninger alene skulle have hjemmel i art. 9, ville det kunne indebære, at en behandling ville være lovlig, hvis der var tale om følsomme oplysninger, men ikke hvis der var tale om al-

Skal behandling af følsomme oplysninger også have hjemmel i art. 6?

mindelige oplysninger. Præambelbetragtning 51 synes også at understøtte dette resultat. I betragtningen anføres således, at ved behandling af følsomme oplysninger, bør udover de specifikke krav efter art. 9, stk. 2, "de generelle principper og andre regler i denne forordning finde anvendelse, navnlig for så vidt angår betingelserne for lovlig behandling". Hermed må sigtes til art. 6, der har overskriften "lovlig behandling". Det er også blevet fremhævet, at den registreredes indsigelsesret efter art. 21, stk. 1, kun gælder behandling efter art. 6, stk. 1, litra e og f. Det ville være besynderligt, hvis der kun var ret til indsigelse overfor (visse) behandlinger af almindelige men ikke følsomme oplysninger.

EU-Domstolen har berørt men ikke endeligt afklaret spørgsmålet i sagen C-136/17 (*Google*) om søgemaskiners pligt til at foretage deindeksering af følsomme oplysninger. Domstolen nåede frem til, at søgemaskinens behandling af følsomme oplysninger kunne være lovlig efter art. 9 i forordningen, "forudsat at udbyderen tillige opfylder de øvrige lovlighedsbetingelser i bl.a. [...] forordningens artikel 5" (dommens præmis 64). Det er ikke tvivl om, at "de øvrige lovlighedsbetingelser" omfatter de grundlæggende behandlingsprincipper i art 5, som der direkte henvises til. Spørgsmålet er imidlertid, om domstolen med "øvrige lovlighedsbetingelser" også sigter til art. 6. I så fald forudsætter domstolen, at en behandling af følsomme oplysninger både skal have et behandlingsgrundlag efter art. 6 og være omfattet af en af undtagelserne i art. 9, stk. 2. Omfatter "øvrige lovlighedsbetingelser" omvendt ikke art. 6, forudsætter domstolen, at behandlingen af følsomme oplysninger alene skal have hjemmel i art. 9. Det fremgår ikke klart, hvilken af disse to fortolkninger, domstolen har baseret sin afgørelse på. Når domstolen anfører, at de øvrige lovlighedsbetingelser "bl.a." omfatter art. 5, indebærer det, at der er flere lovlighedsbetingelser. Eftersom art. 6 har overskriften "lovlig behandling", er det nærliggende at antage, at det er denne bestemmelse, domstolen sigter til. Omvendt havde det været oplagt, at domstolen havde henvist udtrykkeligt til art. 6, hvis henvisningen til "øvrige lovlighedsbetingelser" også sigtede til denne bestemmelse, på samme måde, som domstolen udtrykkeligt henviste til art. 5. I den citerede domspræmis henvises til præmis 72 i *Google Spain*-dommen (C-131/12). Denne henvisning gør ikke resultatet klarere. Præmis 72 skal læses i sammenhæng med præmis 70, 71 og 73.

C-136/17

I præmis 70 fastslås, at den registrerede havde ret til at kræve sletning efter art. 12 i det tidligere persondatadirektiv, både i de situationer, der eksplicit var angivet i bestemmelsen (ufuldstændige eller urigtige oplysninger) og ved manglende overholdelse af andre "lovlighedsbetingelser". I præmis 71, der indledes med ordene "[I] denne forbindelse [...]", fastslås herefter, at enhver behandling skal ske i overensstemmelse med principperne i direktivets art. 6 (forordningens art. 5) og i overensstemmelse med et af behandlingsgrundlagene efter direktivets art. 7 (forordningens art. 6). Præmis 72 omtaler de grundlæggende behandlingsprincipper, mens præmis 73 fastslår det relevante behandlingsgrundlag. Google Spain-dommen må på denne baggrund læses således, at begrebet "lovlighedsbetingelser" både omfatter behandlingsprincipperne efter forordningens art. 5 og behandlingsgrundlaget efter art. 6. Da den nye *Google*-dom ([C-136/17](#)) også anvender begrebet "lovlighedsbetingelser" og i den forbindelse henviser til *Google Spain*-dommen taler meget for, at begrebet også må omfatte art. 6 i den nye dom. Hvis det var ønsket fra EU-Domstolen at signalere dette med henvisningen til *Google Spain*-dommen, er det imidlertid forunderligt, at EU-Domstolen alene henviser til præmis 72, der omhandler behandlingsprincipperne efter art. 5, men ikke præmis 73, der omhandler behandlingsgrundlagene efter art. 6. Samlet set forekommer dommen i [C-136/17](#) så uklar på dette punkt, at den ikke kan tages til indtægt for nogen af de to resultater.

EDPB har i sine vejledninger lagt til grund, at behandlingen af følsomme oplysninger både kræver, at behandlingen er omfattet af en af undtagelserne i 9, stk. 2, og at der er et hjemmelsgrundlag i art. 6.

EDPB

Se således EDPB's retningslinjer [3/2019](#) om brug af videoudstyr til behandling af personoplysninger, pkt. 68: "Hvis et videoovervågningssystem anvendes til at behandle særlige kategorier af oplysninger, skal den dataansvarlige identificere både en undtagelse for behandling af særlige kategorier af oplysninger i henhold til artikel 9 (dvs. en undtagelse fra den generelle regel om, at man ikke bør behandle særlige kategorier af oplysninger) og et retsgrundlag i henhold til artikel 6". Tilsvarende rådets udtalelse [3/2019](#) vedrørende kliniske forsøg, pkt. 28.

I Danmark har det traditionelt været opfattelsen, at behandlingen af følsomme oplysninger alene skulle have hjemmel i art. 9, og Datatil-

Datatilsynet

synet har haft lagt den opfattelse til grund for sin praksis. Den er også lagt til grund i betænkning 1565/2017 (s. 113). Ved et opslag på sin hjemmeside den 7. november 2019 med tilhørende baggrundsnotat (j.nr. 2019-20-0004, dok.nr. 148511) meddelte Datatilsynet imidlertid, at det fremover ville være tilsynets opfattelse, at også behandlingen af følsomme oplysninger skal have hjemmel i art. 6. Tilsynet henviste herved til formuleringen af art. 21, præambelbetragtning 51 og *Google-dommen* (C-136/17) (der som anført ovenfor dog næppe i sig selv kan tages til indtægt for resultatet). Tilsynet henviste endvidere til, at EDPB også lægger denne opfattelse til grund og påpegede bl.a., at rådet kan træffe afgørelser, der også binder Datatilsynet. Hermed illustrerer tilsynets praksisændring også, hvordan EDPB og det mere bindende samarbejde mellem tilsynsmyndighederne i forordningen vil føre til en højere grad af harmonisering af tilsynsmyndighedernes praksis.

Samlet set må det på baggrund af ovenstående lægges til grund, at en behandling af følsomme oplysninger både skal være omfattet af en undtagelse efter art. 9, stk. 2, og af et af behandlingsgrundlagene i art. 6. Når dette både er opfattelsen hos EDPB og Datatilsynet, bliver dette i praksis den retstilstand, som dataansvarlige må indrette sig efter. Det kan næppe hellere forventes, at EU-Domstolen vil nå et modsat resultat, uanset at domstolens nuværende praksis ikke udelukker det.

Konklusion

I praksis har det næppe stor betydning, at en behandling af følsomme oplysninger skal have hjemmel i begge bestemmelser. Det vil være sjældent, at en behandling har hjemmel i en af undtagelserne i art. 9, stk. 2, uden samtidig at have hjemmel i et behandlingsgrundlag efter art. 6. Situationen kan dog tænkes, særligt når den registrerede offentliggør oplysninger om sig selv. Dette er omfattet af undtagelsen i art. 9, stk. 2, litra e, men der findes ikke en tilsvarende bestemmelse i art. 6.

Den praktiske betydning

Datatilsynet nævner i den ovennævnte omtale af sin praksisændring som eksempel herpå, at en virksomhed med henblik på målrettet markedsføring opretter et register over personer med en bestemt sygdom eller et bestemt politisk tilhørsforhold, som de pågældende personer har omtalt på de sociale medier. Behandlingen vil være omfattet af undtagelsen i art. 9, stk. 2, litra e, men der vil normalt ikke være et lovligt grundlag for behandlingen efter art. 6. Som også påpeget af Datatilsynet, vil en behandling af offentliggjorte oplysninger, som ikke har

hjemme i art. 6, normalt være i strid med de grundlæggende principper i art. 5. I praksis vil behandlingen derfor også være ulovlig, selvom der ikke kræves hjemmel i art. 6.

Som nævnt har det dog en betydning i relation til den registreredes indsigelsesret efter art. 21, stk. 1, da denne kun gælder for behandlinger omfattet af art. 6, stk. 1, litra e og f. Når artikel 6 også omfatter følsomme oplysninger, vil indsigelsesretten også gælde for disse oplysninger.

Som anført ovenfor i afsnit 2.5 har det endvidere en betydning i relation til børns mulighed for at give samtykke efter art. 8. Denne mulighed gælder efter bestemmelsen kun for samtykke efter art. 6, stk. 1, litra a. Når art. 6 også omfatter følsomme oplysninger betyder det, at børn kan give samtykke til behandling af følsomme oplysninger efter art. 8. Dette ville ikke være muligt, hvis art. 6 alene omfattede almindelige personoplysninger.

Endelig kan spørgsmålet have betydning for nogle af den dataansvarliges compliancerettede aktiviteter. I de tilfælde, hvor den dataansvarlige skal dokumentere eller oplyse om behandlingsgrundlaget, vil der således både skulle angives hjemmelsgrundlag efter art. 6 og 9, når der behandles følsomme oplysninger.

7. Danske særregler

Databeskyttelsesloven indeholder en række særregler om behandlingsgrundlaget for særlige typer af personoplysninger. Disse regler, der indskrænker behandlingsgrundlagene i forhold til forordningens art. 6, er i det væsentlige en videreførelse af tilsvarende regler fra den tidligere persondatalov. Videreførelsen må primært ses som et politisk ønske om i videst muligt omfang at opretholde den eksisterende retstilstand efter forordningen.

I det følgende omtales kort reglerne om videregivelse af personoplysninger i markedsføringsøjemed, behandling af straffeoplysninger og af CPR-numre.

7.1. Videregivelse af personoplysninger i markedsføringsøjemed – DBL § 13

Videregivelse af personoplysninger med henblik på markedsføring eller brug af personoplysninger på vegne af en tredjepart i markedsføringsøjemed kræver samtykke fra den registrerede, jf. DBL § 13, stk. 1:

Krav om
samtykke ved
videregivelse med
henblik på
markedsføring

En virksomhed må ikke videregive oplysninger om en forbruger til en anden virksomhed til brug ved direkte markedsføring eller anvende oplysningerne på vegne af en anden virksomhed i dette øjemed, medmindre forbrugeren har givet sit udtrykkelige samtykke hertil. Et samtykke skal indhentes i overensstemmelse med reglerne i markedsføringslovens § 10.

Bestemmelsen indebærer, at videregivelsen til en anden virksomhed med henblik på dennes direkte markedsføring forudsætter samtykke fra den registrerede. De øvrige hjemmelsgrundlag efter forordningens art. 6, stk. 1, kan således ikke anvendes. Det følger af sidste sætning, at samtykket skal indhentes i overensstemmelse med reglerne i MFL § 10, hvilket indebærer, at samtykket ikke må forsøges indhentet ved hjælp af elektronisk post uden forudgående anmodning fra den registrerede, jf. nærmere om kravene efter MFL § 10 afsnit 10.5. Det må i øvrigt antages, at de ovenfor beskrevne krav til samtykket i forordningen ligeledes skal iagttages.

Bestemmelsen gælder kun videregivelse af oplysninger om forbrugere. Videregivelse af oplysninger om enkeltpersoner, der ikke optræder som forbrugere, f.eks. kontaktpersoner i en virksomhed, er ikke omfattet af bestemmelsen.

Bestemmelsen gælder endvidere kun den dataansvarliges videregivelse af oplysninger til en tredjepart eller anvendelse af oplysningerne på vegne af en tredjepart. Den dataansvarliges egen forudgående indsamling af oplysningerne er ikke omfattet af § 13. Hvorvidt den dataansvarlige er berettiget til at indsamle oplysningerne og selv bruge dem, afgøres derfor af forordningens art. 6, stk. 1, mens den efterfølgende videregivelse til tredjepart med henblik på dennes markedsføring afgøres efter DBL § 13.

Datatilsynet har i en udtalelse lagt til grund, at den tilsvarende regel i den tidligere persondatalov ikke fandt anvendelse, hvis et kunde-

kartotek blev overdraget som led i en samlet virksomhedsoverdragelse, hvor alle virksomhedens aktiver sælges til en anden virksomhed, jf. sag nr. 2000-210-0057. I stedet skulle forholdet behandles efter den tidligere lovs § 6, stk. 1 (nu art. 6, stk. 1). Dette må antages fortsat at være gældende.

Det følger af § 13, stk. 2, at når overdragelsen alene omfatter generelle kundeoplysninger, der danner grundlag for inddeling i kundekategorier, kan behandlingen finde sted uden samtykke, forudsat at overdragelsen har hjemmel i interesseafvejningsreglen i art. 6, stk. 1, litra f. Generelle kundeoplysninger er f.eks. oplysninger om navn, adresse, alder, køn og generelle oplysninger om, at den registrerede bor i eget hus, har en bil mv. Nærmere oplysninger om, hvilke varer den registrerede har købt, oplysninger om kreditforhold mv. kan derimod ikke videregives efter stk. 2, men kræver samtykke efter stk. 1.

Generelle
kundeoplysninger

Det følger endvidere af stk. 3, at følsomme oplysninger og oplysninger om strafbare forhold ikke kan videregives uden samtykke, uanset om disse (undtagelsesvist) måtte have karakter af generelle kundeoplysninger.

Følsomme
oplysninger og
oplysninger om
strafbare forhold

Kravet om samtykke i § 13, stk. 1, ved videregivelse af personoplysninger med henblik på markedsføring, indebærer, at ingen af de andre behandlingsgrundlag i forordningens art. 6 kan anvendes. Det kan imidlertid ikke antages, at en sådan indskrænkning er i overensstemmelse med forordningen og medlemsstaternes nationale råderum. Det følger af art. 6, stk. 2, at medlemsstaterne kan opretholde eller indføre nationale regler, der tilpasser bestemmelserne om behandlingsgrundlag i art. 6, stk. 1, litra c (retlig forpligtelse) eller litra e (offentlig myndighedsudøvelse og opgaver i samfundets interesse). Derimod rummer bestemmelsen ingen mulighed for at tilpasse eller begrænse de øvrige behandlingsgrundlag. Hvis videregivelse af markedsføringsoplysninger er nødvendig for at overholde en kontrakt, som den registrerede er part i (litra b) eller kan hjemles i interesseafvejningsreglen (litra f), kan den derfor ikke forbydes efter en national regel som DBL § 13, stk. 1. I praksis vil det dog nok være sjældent, at en interesseafvejning falder ud til den dataansvarliges fordel i denne situation.

I strid med
forordningen?

Se i samme retning Datatilsynets afgørelse i sag nr. 2020-431-0075, hvor tilsynet fandt det tvivlsomt, om DBL § 13 ligger inden for det nationale råderum og i stedet anvendte forordningens art. 6, stk. 1, litra f, til at af-

gøre, om en virksomhed kunne videregive oplysninger med henblik på markedsføring til samarbejdspartnere.

Forbuddet mod videregivelse af følsomme oplysninger uden samtykke i § 13, stk. 3, vil potentielt også kunne være i strid med forordningen. Nogle af undtagelserne i art. 9, stk. 2, forudsætter national hjemmel og andre kan medlemsstaterne vælge at begrænse efter art. 9, stk. 3. Dette gælder dog ikke for alle undtagelserne i art. 9, stk. 2. I praksis vil det nok kun være bestemmelsen i art. 9, stk. 2, litra e, om behandling af oplysninger, der tydeligvis er offentliggjort af den registrerede selv, som kan være relevant. Art. 9 giver ikke mulighed for at begrænse denne bestemmelse i national ret, og der kan derfor heller ikke indføres en national bestemmelse, der kun tillader behandling ved indhentelse samtykke for denne type oplysninger. Det skal dog erindres, at behandlingen også skal have hjemmel i art. 6, hvad den i praksis sjældent vil have. Man kan således dårligt forestille sig, at en interesseafvejning falder ud til den dataansvarliges fordel, når denne vil videregive følsomme oplysninger i markedsføringsøjemed.

Se også om det nationale råderum kap. 1.5.3.

7.2. Oplysninger om strafbare forhold

DBL § 8 rummer særlige regler om behandling af oplysninger om strafbare forhold. Bestemmelsen er udstedt med hjemmel i forordningens art. 10 om behandling af personoplysninger vedrørende strafdomme og lovovertrædelser.

Offentlige myndigheder må efter § 8, stk. 1, behandle oplysninger om strafbare forhold, når det er nødvendigt for at varetage myndighedens opgaver. Myndigheden må kun videregive oplysningerne i de situationer, der er angivet i stk. 2, herunder med den registreredes udtrykkelige samtykke, eller hvis videregivelsen sker til varetagelse af private eller offentlige interesser, der klart overstiger hensynet til de interesser, der begrunder hemmeligholdelsen, herunder hensynet til den, oplysningen angår.

Private må efter stk. 3 tilsvarende behandle oplysninger om strafbare forhold, hvis den registrerede har givet sit udtrykkelige samtykke, eller hvis behandlingen er nødvendig for at varetage en berettiget

interesse, der klart overstiger hensynet til den registrerede. I lighed med art. 6 (almindelige oplysninger), men i modsætning til art. 9 (følsomme oplysninger), indeholder § 8 således en interesseafvejningsregel, der dog er skærpet i forhold til reglen i art. 6, da den berettigede interesse “klart” skal overstige hensynet til den registrerede.

7.3. Personnummer (CPR-nummer)

Personnumre anses for en særlig beskyttelsesværdig type information, da personnummeret anvendes som identifikator i en række forskellige sammenhænge. Databeskyttelseslovens § 11 indeholder derfor skærpede regler for, hvornår personnumre må behandles.

Efter DBL § 11, stk. 1, må offentlige myndigheder behandle personnumre med henblik på entydig identifikation eller som journalnummer. Private må behandle personnumre, når det følger af lovgivningen, når den registrerede har givet samtykke til behandlingen, når behandlingen alene finder sted til videnskabelige eller statistiske formål, eller når der er tale om videregivelse som et naturligt led i den normale drift af virksomheden, og videregivelsen er af afgørende betydning for at sikre en entydig identifikation af den registrerede, eller videregivelsen kræves af en offentlig myndighed.

Kapitel 6

Den registreredes rettigheder

1. Generelt om reglerne om registreredes rettigheder

Forordningens kap. III indeholder en række bestemmelser om den registreredes rettigheder, når der sker behandling af personoplysninger. I det følgende omtales disse rettigheder i den rækkefølge, de fremgår af forordningen:

Reglerne om registreredes rettigheder

- Retten til oplysning ved indsamling (art. 13 og 14)
- Retten til indsigt (art. 15)
- Retten til berigtigelse (art. 16)
- Retten til sletning (art. 17)
- Retten til begrænsning af behandling (art. 18)
- Retten til dataportabilitet (art. 20)
- Retten til indsigelse (art. 21)
- Retten til ikke at være genstand for automatiske individuelle afgørelser (art. 22).

Det er alene den dataansvarlige, der er pligtsubjekt for reglerne om registreredes rettigheder. Reglerne forpligter ikke databehandlere, og registrerede kan således ikke rejse krav direkte overfor databehandlere om f.eks. at give indsigt i oplysninger eller foretage sletning.

Den dataansvarlige er pligtsubjekt

Når en dataansvarlig bruger en databehandler, vil den dataansvarliges overholdelse af sine forpligtelser efter reglerne om registreredes rettigheder ofte forudsætte medvirken fra databehandleren, f.eks. i forbindelse med ekstern drift af it-systemer. Det følger af art. 28, stk. 3, li-

– brug af databehandlere

tra e, at databehandlertaften skal pålægge databehandleren under hensyntagen til behandlingens karakter, så vidt muligt og ved hjælp af passende tekniske og organisatoriske foranstaltninger at bistå den dataansvarlige med at opfylde dennes forpligtelse til at besvare anmodninger om udøvelse af de registreredes rettigheder. Parterne kan også aftale, at databehandleren varetager den dataansvarliges forpligtelser direkte overfor de registrerede. En sådan forpligtelse følger dog ikke af art. 28, og den dataansvarlige vil under alle omstændigheder fortsat være ansvarlig overfor de registrerede for en manglende overholdelse af reglerne. Se også om parternes ansvar og forpligtelser ved den dataansvarliges brug af en databehandler kap. 3.5.3.

Den dataansvarliges forpligtelser under reglerne om registreredes rettigheder kan enten være proaktive eller reaktive. En proaktiv pligt indebærer, at den dataansvarlige af egen drift skal foretage den handling, som skal sikre den registrerede rettigheder. Dette betegnes undertiden som “forbudsret”. En reaktiv pligt indebærer, at handlingen kun skal foretages efter anmodning fra den registrerede. Dette betegnes også som en “indsigelsesret” (der ikke må forveksles med indsigelsesretten efter art. 18). Eksempler på proaktive regler er art. 13 og 14, der forpligter den dataansvarlige til at informere den registrerede i forbindelse med indsamling af oplysninger. Art. 15 om indsigtsret er omvendt en reaktiv regel, der kun forpligter den dataansvarlige til at give nærmere oplysninger ved henvendelse fra den registrerede. For nogle af reglerne, herunder art. 17 om sletning og art. 22 om automatiserede afgørelser, er det mindre klart, om de har proaktiv eller reaktiv karakter. Dette drøftes i forbindelse med gennemgangen af de enkelte regler.

Proaktive og reaktive forpligtelser

Inden gennemgangen af de materielle regler om registreredes rettigheder omtales i det følgende en række generelle proceskrav i art. 12, der gælder for alle rettighedsbestemmelserne.

2. Processuelle krav – art. 12

Efter art. 12, stk. 1, skal enhver oplysning gives “i en kortfattet, gennemsigtig, letforståelig og lettilgængelig form og i et klart og enkelt sprog”. Dette gælder navnlig (men altså ikke udelukkende), når oplysninger specifikt er rettet mod et barn. Oplysningerne skal som udgangspunkt gives skriftligt eller elektronisk. Oplysningerne kan gives

Formkrav

mundtligt, når den registrerede anmoder om det og er i stand til at identificere sig.

I sag 2019-32-0639 fandt Datatilsynet, at en dataansvarlig havde for-
sømt pligten til at give oplysninger i en gennemsigtig, letforståelig og
tilgængelig form, og dermed havde overtrådt art. 12, stk. 1, da oplysnin-
gerne blev givet til den registrerede trinvis undervejs i sagsbehand-
lingen frem for i en samlet meddelelse.

Den dataansvarlige skal efter art. 12, stk. 3, uden unødigt ophold
og senest inden for en måned oplyse den registrerede om de foranstalt-
ninger, der er iværksat på baggrund af den registreredes anmodning.
Såfremt den dataansvarlige ikke vil imødekomme anmodningen (og
f.eks. afviser at give indsigt eller at slette en oplysning), skal dette
meddeles den registrerede straks og senest inden for en måned, jf.
art. 12, stk. 4.

Frister

Den dataansvarlige kan efter art. 12, stk. 5, som udgangspunkt ikke
kræve betaling for at stille oplysninger til rådighed for den registrerede
eller i øvrigt iværksætte de foranstaltninger, som den registrerede kan
kræve efter art. 15-22. Bestemmelsen har følgende ordlyd:

“Åbenbart
grundløse eller
overdrevne” –
krav på betaling
eller afvisning af
anmodning –

Oplysninger, der gives i henhold til artikel 13 og 14, og enhver meddel-
else og enhver foranstaltning, der træffes i henhold til artikel 15-22 og
34, er gratis. Hvis anmodninger fra en registreret er åbenbart grundløse
eller overdrevne, især fordi de gentages, kan den dataansvarlige enten:

- a) opkræve et rimeligt gebyr under hensyntagen til de administra-
tive omkostninger ved at give oplysninger eller meddelelser el-
ler træffe den ønskede foranstaltning, eller
- b) afvise at efterkomme anmodningen.

Bevisbyrden for, at anmodningen er åbenbart grundløs eller over-
dreven, påhviler den dataansvarlige.

Den dataansvarlige er dog efter bestemmelsen berettiget til at kræ-
ve et rimeligt gebyr, hvis anmodninger fra den registrerede er åbenbart
grundløse eller overdrevne (f.eks. fordi den registrerede afgiver et me-
get stort antal anmodninger). I denne situation kan den dataansvarlige
også vælge at afvise anmodningen. EDPB antager i Guidelines
01/2022 om indsigtsret, at den dataansvarlige ikke nødvendigvis har
valgfrihed mellem at kræve betaling eller afvise anmodningen. I vej-
lednings pkt. 190 anføres således, at man vanskeligt kan forestille

sig, at krav på betaling er en passende foranstaltning, hvis anmodningen er grundløs, mens det i overensstemmelse med transparensprincippet ofte vil være mest passende at kræve betaling frem for afvisning i tilfælde af overdrevne (gentagende) anmodninger.

Bestemmelsen skal navnlig sikre den dataansvarlige mod chikanøse henvendelser og finder således også kun anvendelse ved den registreredes anmodninger til den dataansvarlige. Derimod kan bestemmelsen ikke anvendes til at undlade at opfylde de proaktive forpligtelser, som den dataansvarlige af egen drift skal iværksætte, f.eks. til at give oplysninger efter art. 13 og 14.

I Datatilsynets vejledning om de registreredes rettigheder angives (s. 9) som et eksempel på en åbenbar grundløs anmodning den situation, hvor en borger kræver berigtigelse af urigtige oplysninger uden at ville præcisere, hvilke oplysninger der er urigtige. Som et eksempel på en overdreven anmodning angives en situation, hvor en kunde med kort mellemrum tre gange anmoder et teleselskab om indsigt i, hvilke oplysninger selskabet behandler om den pågældende.

Den dataansvarlige må sikre, at en henvendelse fra den registrerede rent faktisk hidrører fra denne. Anmoder den registrerede eksempelvis om indsigt i, hvilke oplysninger den dataansvarlige behandler om den pågældende, må den dataansvarlige ikke udlevere disse oplysninger uden at have fornøden sikkerhed for den registreredes identitet. Efter art. 12, stk. 2, kan den dataansvarlige undlade at efterkomme forpligtelserne efter art. 15-22, hvis den dataansvarlige kan påvise, at det ikke er muligt at identificere den registrerede.

Hvis der hersker "rimelig tvivl" om den registreredes identitet, kan den dataansvarlige anmode om yderligere oplysninger, der er nødvendige for at bekræfte identiteten, jf. art. 12, stk. 6. Eftersom der ikke findes et globalt eller europæisk fælles ID-system, som vi på nationalt plan har MitID, kan det være vanskeligt for dataansvarlige at sikre entydig identitet af den registrerede.

EU arbejder på en fælles europæisk identitetsløsning, men den har endnu ikke en udbredelse eller praktiske anvendelse, som gør den til et reelt alternativ til MitID og tilsvarende nationale identitetsløsninger.

Identifikation af den registrerede

– anmodning om yderligere oplysninger ved tvivl om identitet

Omvendt kan den dataansvarlige selvsagt ikke smygge sine forpligtelser af sig blot ved at henvise til, at det er vanskeligt at identificere den registrerede. Kravene til identifikation vil variere afhængigt af den konkrete situation, hvor der bl.a. kan lægges vægt på karakteren af oplysninger, der udleveres til den registrerede, konsekvenserne af den handling, som den registrerede ønsker iværksat mv. Efter præambelbetragtning 64 bør den dataansvarlige træffe alle rimelige foranstaltninger for at bekræfte identiteten af en registreret, som anmoder om indsigt, navnlig i forbindelse med onlinetjenester og onlineidentifikatorer.

Se også om disse krav Datatilsynets vejledning om de registreredes rettigheder, s. 10 f., hvor det bl.a. anføres, at den registreredes identitet kan sikres ved forevisning af legitimationspapirer som pas, kørekort eller andet ID, men at dette dog ikke er et krav, hvis identiteten kan sikres på anden måde. Som eksempler herpå angives henvendelse via Digital Post eller fra en person, som den dataansvarlige kender i forvejen (angiveligt i forbindelse med fysisk fremmøde).

Mens den dataansvarlige således på den ene side er forpligtet til at udøve rimelige bestræbelser for at sikre identiteten af den registrerede, må den dataansvarlige på den anden side ikke gøre identifikationsproceduren så byrdefuld eller vanskelig, at det risikerer at afholde registrerede fra at udnytte deres rettigheder. Heri ligger også, at den dataansvarlige ikke må kræve dokumentation eller identifikationsoplysninger udover, hvad der er nødvendigt for at opnå tilstrækkelig sikkerhed for den registreredes identitet. Der gælder med andre ord et krav om, at identifikationskravene skal være proportionale.

– krav om
proportionalitet

I Guidelines 01/2022 anfører EDPB, at ID-kort generelt ikke kan anses for en hensigtsmæssig identifikationsform, idet fremsendelse af kopi af et ID-kort øger risikoen for identitetstyveri og anden form for misbrug af kortet. Det anføres dog også, at ID-kort kan bruges i særlige situationer, herunder når den dataansvarlige behandler følsomme oplysninger om den registrerede. Det vil ikke være alle oplysninger på et ID-kort, der vil være nødvendige for at sikre behørig identificering af den registrerede. I vejledningen anføres, at den dataansvarlige skal informere den registrerede om, hvilke oplysninger, der ikke behøves, og om muligheden for at overstrege eller på anden måde fjerne disse oplysninger. Fremsendes kortet uden overstregning anfører EDPB, at det vil være

“good practice”, at den dataansvarlige gør det, hvis det er muligt. Se nærmere vejledningens pkt. 74-77.

Er der med formuleringen i art. 12, stk. 6, ikke “rimelig tvivl” om den registreredes identitet, skal den dataansvarlige således undlade at kræve yderligere dokumentation. Den dataansvarlige må foretage en konkret vurdering af, om der er rimelig tvivl, og hvad der vil være et proportionalt krav til identifikation.

Se herved Datatilsynets afgørelse i j.nr. 2018-7320-0166 (Pandora), hvor tilsynet udtalte kritik af, at den registrerede skulle indsende pas, kørekort eller nationalt identitetskort, før den dataansvarlige ville tage stilling til en anmodning om sletning. Tilsynet anførte, at den dataansvarlige har pligt til at foretage en konkret vurdering af, om der hersker rimelig tvivl om identiteten på den fysiske person. Det var derfor i strid med art. 12, stk. 6, at stille et generelt krav om ID-validering for alle kunder. Tilsynet anførte endvidere, at det var i strid med proportionalitetskravet i art. 5, stk. 1, litra c, at kræve flere oplysninger end nødvendigt for at kunne identificere den registrerede.

Se også om identifikationskravene EDPB’s Guidelines 01/2022, pkt. 58 ff.

Det følger af art. 11, stk. 1, at den dataansvarlige ikke er forpligtet til at opbevare eller i øvrigt behandle personoplysninger alene for at kunne reagere på mulige anmodninger. Bestemmelsen har følgende ordlyd:

– ikke krav om opbevaring af identitetsoplysninger efter afsluttet behandling

Hvis formålene med en dataansvarligs behandling af personoplysninger ikke kræver eller ikke længere kræver, at den registre rede kan identificeres af den dataansvarlige, er den dataansvarlige ikke forpligtet til at beholde, indhente eller behandle yderligere oplysninger for at kunne identificere den registrerede alene med det formål at overholde denne forordning

Art. 11 forbyder ikke den dataansvarlige at opbevare oplysninger alene med henblik på at kunne identificere den registrerede, men i mange situationer vil en sådan opbevaring være uproportionel og dermed kunne stride mod de generelle principper i art. 5 om bl.a. rimelighed og mangle hjemmel i art. 6. I præambelbetragtning 64 anføres så-

ledes også, at en dataansvarlig ikke bør opbevare oplysninger alene for at kunne reagere på mulige anmodninger fra registrerede.

I de situationer, hvor den dataansvarlige har slettet identifikationsoplysningerne, fordi der i øvrigt ikke behandles oplysninger om den registrerede, vil den dataansvarlige om muligt være forpligtet til at orientere den registrerede om den manglende mulighed for at imødekomme en anmodning, jf. art. 11, stk. 2. I så fald vil den dataansvarlige ikke være forpligtet til at imødekomme en anmodning efter art. 15-20 fra den registrerede, medmindre den registrerede herefter giver den dataansvarlige oplysninger, der muliggør en identifikation.

3. Den registreredes ret til oplysning om indsamling (den dataansvarliges oplysningspligt)

Forordningen indeholder i art. 13 og 14 regler om den dataansvarliges pligt til at afgive nærmere oplysninger til den registrerede i forbindelse med indsamling af oplysninger. Art. 13 omhandler indsamling af oplysninger hos den registrerede selv, mens art. 14 omhandler indsamling fra andre kilder.

Formålet med reglerne er at give den registrerede et sådant indblik i, hvilke oplysninger der behandles, at den registrerede kan varetage sine interesser, herunder kontrollere, om behandlingen overholder lovens regler, fremsætte indsigelser mod behandlingen og klage til tilsynsmyndigheden, såfremt den registrerede mener, at behandlingen strider mod forordningen. Uden kendskab til at oplysningerne behandles, vil den registrerede ikke kunne varetage sine interesser. Formålet med art. 13 er endvidere at sikre, at den registreredes beslutning om at afgive personoplysninger sker på et fyldestgørende grundlag med viden om, hvad oplysningerne vil blive brugt til (dette gælder ikke for art. 14, da denne bestemmelse omhandler videregivelse fra andre end den registrerede).

Reglernes
formål

3.1. Indsamling fra den registrerede

Bestemmelsen i art. 13 forpligter den dataansvarlige til at give den registrerede en række oplysninger, når den dataansvarlige indsamler oplysninger hos den registrerede selv, jf. stk. 1, 1. pkt.:

Hvis personoplysninger om en registreret indsamles hos den registrerede, giver den dataansvarlige på det tidspunkt, hvor personoplysningerne indsamles, den registrerede alle følgende oplysninger: [...]

Oplysningspligten gælder i forbindelse med indsamlingen hos den registrerede. Begrebet “indsamling” dækker alle de situationer, hvor den dataansvarlige registrerer personoplysninger, uanset om den dataansvarlige har kontaktet den registrerede, eller den registrerede på eget initiativ har kontaktet den dataansvarlige. At oplysningspligten kun udløses ved indsamling, indebærer, at den dataansvarlige ikke er forpligtet til at informere den registrerede, hver gang der efterfølgende sker behandling af de indsamlede oplysninger.

“Indsamling”

Den dataansvarlige skal oplyse den registrerede af egen drift og kan således ikke nøjes med at afgive oplysningerne på den registreredes forespørgsel. Det følger af bestemmelsen, at oplysningerne skal “gives” til den registrerede. Dette indebærer, at oplysningerne skal præsenteres umiddelbart for den registrerede. Det er derfor eksempelvis ikke tilstrækkeligt at lægge oplysningerne på en hjemmeside, som den registrerede selv skal finde.

Oplysninger skal gives af egen drift og umiddelbart til den registrerede

Det følger af art. 13, stk. 1, at oplysningerne skal gives på det tidspunkt, hvor personoplysningerne indsamles. Som udgangspunkt skal oplysningerne derfor gives samtidig med, at personoplysningerne indhentes hos den registrerede. Dette er dog ikke muligt, hvis den registrerede uopfordret henvender sig og afgiver personoplysninger. I det tilfælde skal den dataansvarlige afgive oplysningerne snarest muligt herefter, jf. Datatilsynets vejledning om de registreredes rettigheder, s. 14.

Oplysningstidspunktet

Ved indsamlingen skal den dataansvarlige efter art. 13, stk. 1, altid oplyse om følgende forhold:

Indholdet af oplysningerne – minimums-kravene

- *Identitet på og kontaktoplysninger* for den dataansvarlige og dennes eventuelle repræsentant.
- *Kontaktoplysninger* for en eventuel databeskyttelsesrådgiver.
- *Formålene* med den behandling, som personoplysningerne skal bruges til, og retsgrundlaget for behandlingen.
- *De legitime interesser*, som forfølges af den dataansvarlige eller en tredjemand, hvis behandlingen er baseret på artikel 6, stk. 1, litra f).

- Eventuelle *modtagere* eller kategorier af modtagere af personoplysningerne.
- Hvor det er relevant, at den dataansvarlige agter at *overføre* personoplysninger til et *tredjeland* eller en international organisation, og om hvorvidt Kommissionen har truffet afgørelse om tilstrækkeligheden af beskyttelsesniveauet, eller i tilfælde af overførsler i henhold til artikel 46 eller 47 eller artikel 49, stk. 1, andet afsnit, litra h), henvisning til de fornødne eller passende garantier, og hvordan der kan fås en kopi heraf, eller hvor de er blevet gjort tilgængelige.

Med kendskab til den dataansvarliges identitet ved den registrerede, hvem der behandler oplysningerne, og hvortil den dataansvarlige skal rette henvendelse, hvis den registrerede eksempelvis ønsker indsigt i behandlingen, jf. om indsigtsretten nedenfor. Med kendskab til formålet ved den registrerede, hvilken behandling den dataansvarlige påtænker, og vil (i hvert fald i teorien) løbende kunne kontrollere, om der sker behandling i strid med det angivne formål.

Efter art. 13, stk. 2, skal den dataansvarlige afgive en række yderligere oplysninger, når dette er nødvendigt for at sikre en rimelig og gennemsigtig behandling. Dette omfatter efter bestemmelsen følgende oplysninger:

– yderligere oplysninger - art. 13, stk. 2

- Det *tidsrum*, hvor personoplysningerne vil blive opbevaret, eller hvis dette ikke er muligt, de kriterier, der anvendes til at fastlægge dette tidsrum.
- *Den registreredes rettigheder* til at anmode den dataansvarlige om indsigt i og berigtigelse eller sletning af personoplysninger eller begrænsning af behandling vedrørende den registrerede eller til at gøre indsigelse mod behandling samt retten til dataportabilitet.
- Når behandling er baseret på artikel 6, stk. 1, litra a, eller artikel 9, stk. 2, litra a, retten til at *trække samtykke tilbage* på ethvert tidspunkt, uden at dette berører lovligheden af behandling, der er baseret på samtykke, inden tilbagetrækning heraf
- Retten til at indgive en *klage* til en *tilsynsmyndighed*.

- Om meddelelse af personoplysninger er *lovpligtigt* eller et *krav i henhold til en kontrakt* eller et krav, der skal være opfyldt for at indgå en kontrakt, samt om den registrerede har pligt til at give personoplysningerne og de eventuelle konsekvenser af ikke at give sådanne oplysninger.
- Forekomsten af *automatiske afgørelser*, herunder profilering, som omhandlet i artikel 22, stk. 1 og 4, og i disse tilfælde som minimum meningsfulde oplysninger om logikken heri samt betydningen og de forventede konsekvenser af en sådan behandling for den registrerede.

Det er ikke et ubetinget krav, at disse oplysninger gives, men beror på en konkret vurdering af, om det er nødvendigt for at sikre en "rimelig og gennemsigtig" behandling. Denne brede standard kan gøre det vanskeligt for den dataansvarlige at vurdere, om der er en pligt til at give oplysningerne. Er den dataansvarlige i tvivl, vil det i mange tilfælde være tilrådeligt at give oplysningerne for en sikkerheds skyld.

I sin vejledning om samtykke anfører Datatilsynet (s. 17), at den konkrete vurdering "ofte" vil føre til, at den dataansvarlige er forpligtet til at give oplysningerne.

I en række situationer gælder oplysningspligten ikke, og den dataansvarlige kan så indsamle personoplysninger hos den registrerede uden at afgive de oplysninger, der er angivet i art. 13, stk. 1 og 2.

Det følger af art. 13, stk. 4, at oplysningspligten ikke gælder, hvis den registrerede allerede er bekendt med oplysningerne. Når den registrerede selv afgiver oplysningerne til den dataansvarlige, vil den registrerede i de fleste tilfælde allerede kende den dataansvarliges identitet og ofte også formålet med behandlingen. Indsamler en webshop eksempelvis en købers fysiske adresse, vil det fremgå af omstændighederne, at dette sker med henblik på at kunne sende en fysisk vare til køberen, og webshoppen behøver ikke informere om dette formål. Påtænker webshoppen omvendt at bruge adresseoplysningerne på en måde, der ikke umiddelbart følger af købsituationen, skal der oplyses herom.

Det følger endvidere af forordningens art. 23, at medlemsstaterne kan fastsætte begrænsninger i de registreredes rettigheder, når en så-

Undtagelser

– den registreredes kendskab til oplysningerne – art. 13, stk. 4

– nationale undtagelser efter art. 23

dan begrænsning respekterer det væsentlige indhold af de grundlæggende rettigheder og frihedsrettigheder og er en nødvendig og forholdsmæssig foranstaltning i et demokratisk samfund for at forfølge en række nærmere angivne hensyn. Disse er oplistet i art 23, stk. 1 og omfatter hensyn til:

- a. statens sikkerhed
- b. forsvaret
- c. den offentlige sikkerhed
- d. forebyggelse, efterforskning, afsløring eller retsforfølgning af strafbare handlinger eller fuldbyrdelse af strafferetlige sanktioner, herunder beskyttelse mod og forebyggelse af trusler mod den offentlige sikkerhed
- e. andre vigtige målsætninger i forbindelse med beskyttelse af Unionens eller en medlemsstats generelle samfundsinteresser, navnlig Unionens eller en medlemsstats væsentlige økonomiske eller finansielle interesser, herunder valuta-, budget- og skatteanliggender, folkesundhed og social sikkerhed
- f. beskyttelse af retsvæsenets uafhængighed og retssager
- g. forebyggelse, efterforskning, afsløring og retsforfølgelse i forbindelse med brud på etiske regler for lovregulerede erhverv
- h. kontrol-, tilsyns- eller reguleringsfunktioner, herunder opgaver af midlertidig karakter, der er forbundet med offentlig myndighedsudøvelse i de tilfælde, der er omhandlet i litra a-e og g
- i. beskyttelse af den registrerede eller andres rettigheder og frihedsrettigheder
- j. håndhævelse af civilretlige krav

Denne hjemmel er udnyttet i DBL § 22, der sonderer mellem private og offentlige interesser.

– DBL § 22

Efter DBL § 22, stk. 1, gælder oplysningspligten ikke, hvis den registreredes interesse i oplysningerne findes at burde vige for “afgørende hensyn til private interesser”.

– stk. 1 –
afgørende
hensyn til
private
interesser

Som anført oplister art. 23 en række hensyn, der kan begrunde nationale indskrænkninger i de registreredes rettigheder. Bestemmelsen i DBL § 22, stk. 1, ligger ifølge betænkning 1565/2017, s. 398, inden for rammerne af art. 23, stk. 1, litra i, der giver mulighed for nationale ind-

skrænkninger for at varetage hensynet til beskyttelsen af “den registreredes eller andres rettigheder og frihedsrettigheder”.

Bestemmelsen har følgende ordlyd:

Bestemmelserne i databeskyttelsesforordningens artikel 13, stk. 1-3, artikel 14, stk. 1-4, artikel 15 og artikel 34 gælder ikke, hvis den registreredes interesse i oplysningerne findes at burde vige for afgørende hensyn til private interesser, herunder hensynet til den pågældende selv.

De hensyn, der tilsiger, at oplysningspligten ikke gælder, kan både være hensyn til at den registrerede selv, til den dataansvarlige og til tredjeparter. Som eksempler herpå nævnes i forarbejderne hensynet til beskyttelsen af forretningshemmeligheder eller en situation, hvor formålet med behandlingen ville være forspildt, hvis den registrerede blev oplyst om behandlingen.

Efter DBL § 22, stk. 2, gælder oplysningspligten endvidere ikke, hvis den registreredes interesse i oplysningerne findes at burde vige for “afgørende hensyn til offentlige interesser”. Bestemmelsen indeholder en ordret gengivelse af de hensyn, der er oplistet i art. 23, stk. 1, litra a-j og angiver, at det “navnlig” er i disse situationer, at oplysningspligten kan fraviges. DBL § 22, stk. 2, synes hermed at forudsætte, at også andre hensyn end de oplistede i art. 23 potentielt kan begrunde en fravigelse af oplysningspligten. Opregningen af hensyn i art. 23 synes dog at være udtømmende, hvorfor der ikke kan antages at være rum for at fritage en dataansvarlig for oplysningspligten i situationer, der ikke omfattes af ét af hensynene i art. 23. Oplistingen af hensyn er imidlertid så bred, herunder med hensynet til registreredes eller andres rettigheder og frihedsrettigheder i litra i, at dette næppe har større praktisk betydning.

Det vil være en konkret vurdering, hvornår afgørende hensyn til private eller offentlige interesser indebærer, at den dataansvarlige kan undlade at oplyse den registrerede. Vurderingen skal foretages for hver af de forskellige typer af oplysninger, der skal gives efter art. 13.

Det har næppe været intentionen med art. 23 at efterlade medlemsstaterne et meget stort rum for at indskrænke de registreredes rettigheder, jf. også bestemmelsens indledende krav om, at indskrænkningen skal respektere det væsentlige indhold af de grundlæggende rettighe-

– Stk. 2 –
afgørende
hensyn til
offentlige
interesser

der og frihedsrettigheder og være en nødvendig og forholdsmæssig foranstaltning i et demokratisk samfund for at forfølge de angivne hensyn. DBL § 22 må læses i dette lys, og det følger da også af bestemmelsen, at undtagelsen kun gælder, når “afgørende” hensyn til private interesser nødvendiggør indskrænkningen. Efter forarbejderne til bestemmelsen indebærer brugen af ordet “afgørende”, at undtagelsen fra oplysningspligten kun kan gøres, når der er “nærliggende fare” for, at private eller offentlige interesser vil lide “skade af væsentlig betydning”.

Se også betænkning 1565/2017, s. 401, hvor det anføres, at der efter art. 23 er “strengt krav” til, hvornår rækkevidden af den registreredes rettigheder kan begrænses.

I nogle tilfælde vil det være lovligt for den dataansvarlige at behandle personoplysninger til et andet formål, end de oprindeligt er indsamlet til. Som nævnt ovenfor kræver princippet om formålsbegrænsning i art. 5, stk. 1, litra b, kun, at viderebehandling ikke må være uforeneligt med det oprindelige formål. Der er således et rum til at foretage en viderebehandling af indsamlede personoplysninger til et andet formål, når dette ikke er uforeneligt med det oprindelige formål. I denne situation er den dataansvarlige forpligtet til oplyse den registrerede om det nye formål, jf. art. 13, stk. 3.

Viderebehandling
med andet formål

Denne forpligtelse gælder dog efter DBL § 23 ikke, når offentlige myndigheder behandler oplysningerne til nye formål efter DBL § 5, stk. 3, medmindre formålet er sammenstilling eller samkøring af personoplysninger i kontroløjemed (f.eks. med henblik på at kontrollere socialt bedrageri).

3.2. Indsamling fra andre kilder

Bestemmelsen om oplysningspligt ved indsamling fra andre kilder i art. 14 svarer i vidt omfang til bestemmelsen i art. 13. Det er således i det væsentlige de samme oplysninger, der skal gives til den registrerede efter de to bestemmelser. Dog skal den dataansvarlige efter art. 14 også oplyse om, hvilken kilde personoplysningerne hidrører fra, jf. stk. 2, litra f.

Forholdet mellem
art. 13 og 14

Der består en mindre forskel i, hvornår oplysningerne skal afgives. Hvor de efter art. 13 skal gives på indsamlingstidspunktet, skal de efter art. 14, stk. 3, gives inden for en rimelig frist og senest en måned efter indsamlingstidspunktet. Hvis personoplysningerne bruges til at kommunikere med den registrerede, indtræder oplysningspligten på kommunikationstidspunktet. Videregives personoplysningerne til en anden modtager, indtræder oplysningspligten ved videregivelsen.

Oplysningstids-
punkt

Af størst praktisk betydning er forskellene i reglerne om undtagelser til oplysningspligten. Art. 14, stk. 5, litra a, indeholder samme undtagelse, som gælder efter art. 13 i relation til oplysninger, som den registrerede allerede er bekendt med, men da indsamlingen efter art. 14 ikke sker fra den registrerede, vil denne undtagelse sjældnere finde anvendelse. Også de særlige nationale undtagelsesregler i DBL § 22, stk. 1 og 2, som beskrevet ovenfor, gælder for oplysningspligten efter art. 14.

Undtagelser
– den registreredes kendskab til oplysningerne
– den registreredes kendskab til oplysningerne
– DBL § 22

Til gengæld rummer art. 14 en række undtagelser til oplysningspligten, som ikke følger af art. 13.

For det første gælder oplysningspligten ikke, hvis underretningen af den registrerede er umulig eller vil kræve en uforholdsmæssigt stor indsats, jf. art. 14, stk. 5, litra b. Bestemmelsen angiver, at dette navnlig gælder i forbindelse med behandling til arkivformål i samfundets interesse, til videnskabelige eller historiske forskningsformål eller til statistiske formål. Brugen af ordet "navnlig" indebærer dog, at undtagelsen også vil gælde i andre situationer, hvor det vil være umuligt eller kræve en uforholdsmæssigt stor indsats at underrette den registrerede. Angivelsen af de specifikke formål kan dog påvirke den konkrete vurdering og sender et signal om, at der skal ganske meget til, før en dataansvarlig kan bruge undtagelsen i andre situationer end de angivne. Undtagelsen afspejler, at det kan være vanskeligt at finde frem til den registrerede eller indebære et arbejde, der ikke står mål med behovet for at oplyse den registrerede. Det vil bero på en konkret vurdering, om det vil være uforholdsmæssigt vanskeligt at iagttage oplysningspligten. Ved denne vurdering må der bl.a. lægges vægt på, hvor indgribende behandlingen må antages at være for den registrerede, og hvor mange personer behandlingssituationen omhandler. Omfatter indsamlingen flere tusinde personer, kan det være mere byrde-

– umulig eller uforholdsmæssigt stor indsats

fuldt at skulle give individuel information, end når indsamlingen kun omfatter en enkelt person.

At der ikke kun skal lægges vægt på, hvor byrdefuldt det vil være for den dataansvarlige at give oplysningerne men også på, hvor indgribende behandlingen er for den registrerede, illustreres af Datatilsynets sag nr. 2021-212-2937, hvor tilsynet svarede på en forespørgsel fra Herning Kommune. Kommunen ønskede at registre telefonnummer på de ansattes pårørende, så disse kunne kontaktes i tilfælde af akut behov herfor. Kommunen ønskedes bl.a. svar på, om de pårørende skulle orienteres om registrering af telefonnummer efter art. 14. Hertil svarede Datatilsynet, at kommunen henset til formålet med behandlingen og den begrænsede mængde oplysninger, der blev behandlet, kunne overveje, om undtagelsen om uforholdsmæssig stor indsats kunne anvendes.

For det andet gælder oplysningspligten ikke, hvis underretningen ville gøre det umuligt eller i alvorlig grad vil hindre opfyldelse af formålene med behandlingen af personoplysningerne. Også denne undtagelse følger af art. 14, stk. 5, litra b. Som nævnt ovenfor antages i forarbejderne til DBL § 22, stk. 1, at denne bestemmelse også undtager underretningspligten, når formålet med behandlingen ville blive forspildt ved underretning.

– formål forspildt

For det tredje gælder oplysningspligten ikke, når indsamlingen eller videregivelsen af oplysningerne udtrykkeligt er fastsat i EU-ret eller national ret, jf. art. 14, stk. 5, litra c. Dette vil eksempelvis gælde for visse regler om videregivelse af oplysninger til skattemyndighederne og for offentliggørelse af whois-data efter domænelovens § 18. Efter som behandlingen skal finde sted, er det begrænset, hvilket hensyn der er at tage til den registrerede.

– lovbestemt
indsamling eller
videregivelse

For det fjerde gælder oplysningspligten ikke, når en underretning ville krænke en tavshedspligt, som den dataansvarlige er underlagt i henhold til EU-retten eller national ret, jf. art. 14, stk. 5, litra d.

– tavshedspligt

Som nævnt gælder art. 13 og 14 kun for indsamling af personoplysninger, men ikke for den videre behandling, herunder videregivelse af oplysninger. Den dataansvarlige er således ikke forpligtet til at oplyse den registrerede om en videregivelse af personoplysninger. For den, som personoplysningerne videregives til, har videregivelsen imidlertid karakter af en indsamling, og denne nye dataansvarlige har derfor som udgangspunkt pligt til at oplyse den registrerede herom.

Videre behandling

4. Den registreredes indsigtret

Den registrerede kan på ethvert tidspunkt anmode om indsigt i, om og hvordan en dataansvarlig behandler oplysninger om den pågældende. Indsigtsretten følger af forordningens art. 15.

Indsigtsretten adskiller sig fra oplysningsretten efter art. 13 og 14 ved, at den registrerede aktivt skal udbede sig oplysningerne fra den dataansvarlige. Til gengæld kan den registrerede løbende (og ikke kun i forbindelse med indsamling) anmode om indsigt i, hvilke oplysninger der behandles og til hvilke formål. I princippet udgør indsigtsretten derfor en væsentlig forudsætning for, at den registrerede kan håndhæve sine rettigheder efter forordningen og kontrollere, at der ikke finder misbrug sted. Den praktiske anvendelse af indsigtsretten har bl.a. været begrænset af, at det kan være svært overskueligt for registrerede, hvem der behandler deres oplysninger og vanskeligt at få dataansvarlige til at give oplysninger herom på en overskuelig måde. Med den større fokus på databeskyttelse generelt og muligheden for indsigt mere specifikt, må det forventes, at dette vil ændre sig.

Den grundlæggende ret til at kræve indsigt følger af art. 15, stk. 1, første led, der har følgende ordlyd:

Den registrerede har ret til at få den dataansvarliges bekræftelse på, om personoplysninger vedrørende den pågældende behandles, og i givet fald adgang til personoplysningerne og følgende information:

[...]

Den dataansvarlige er således forpligtet til *for det første* at bekræfte, at der sker behandling af den registreredes personoplysninger, *for det andet* at informere om, hvilke personoplysninger der behandles, og *for det tredje* give den registrerede en række yderligere oplysninger.

Ved modtagelse af en indsigtsanmodning skal den dataansvarlige først afklare, om der sker en behandling af den registreredes personoplysninger og i givet fald omfanget heraf. Dette kan i sig selv være en omfattende og ressourcekrævende opgave, særligt hvis den dataansvarliges it-systemer ikke fuldt ud understøtter et automatisk udtræk. At imødekomme af en indsigtret kan være ressourcekrævende fritager imidlertid ikke den dataansvarlige for pligten.

Det kan være hensigtsmæssigt for en dataansvarlig at opsætte sine it-systemer, så de understøtter en nem adgang til at opfylde pligten til at give indsigt, og det vil også være i god overensstemmelse med princippet om databeskyttelses gennem design i art. 25, men det er ikke et krav, at indsigtsretten systemunderstøttes. Selv dataansvarlige, der behandler store mængder personoplysninger, kan vælge at understøtte indsigtsretten gennem manuelle procedurer, jf. EDPB's Guidelines 01/2022 om indsigtsret, pkt. 134.

Som nærmere beskrevet i kapitel 2 er personoplysningsbegrebet og behandlingsbegrebet brede begreber, og anvendelsesområdet for at kræve indsigt efter art. 15, er derfor tilsvarende bredt.

Det kan i nogle tilfælde være vanskeligt at vurdere, om oplysninger i et dokument, der omhandler den registrerede, kan siges at være oplysninger "vedrørende" den pågældende og dermed personoplysninger, herunder når sagsbehandlingsdokumentet indeholder vurderinger af den registreredes færdigheder, juridiske stilling mv. Da personoplysningsbegrebet som nævnt også omfatter subjektive holdninger til og vurderinger af en person, vil denne type oplysninger ofte have karakter af personoplysninger, mens dette kun gælder for de objektive oplysninger, som vurderingen hviler på, hvis oplysningerne relaterer sig til den pågældende person. Vurderer en rapport eksempelvis, at en forsikringstager har krav på erstatning, fordi personen lider af en sygdom, vil både oplysningerne om, at personen har krav på erstatning, den medicinske vurdering, der ligger til grund for den juridiske konklusion, og selve oplysningen om, at personen lider af sygdommen, være personoplysninger. Indeholder rapporten generelle oplysninger om sygdommen, f.eks. om almindelige symptomer, hyppighed mv., vil dette ikke have karakter af personoplysninger.

Indsigt i
sagsbehandlings-
dokumenter -
personoplysnings-
begrebet

EU-Domstolen har i to afgørelser, de forenede sager C-141/12 og C-372/12 (YS) og C-434/16 (Nowak) forholdt sig til disse spørgsmål. Afgørelserne illustrerer, at der kan være tale om vanskelige grænsedragninger.

- YS- og Nowak-
dommene

I YS-sagen havde hollandske myndigheder afslået at give asylansøgere indsigt i de juridiske vurderinger, der lå til grund for afgørelser om midlertidig opholdstilladelse. EU-Domstolen fastslog, at de personoplysninger, der var indeholdt i den juridiske redegørelse, var omfattet af indsigtsretten, hvorimod selve den juridiske analyse ikke var.

EU-Domstolen lagde herved vægt på, at indsichtsretten skulle give den registrerede mulighed for at kontrollere, at behandlingen af personoplysninger var lovlig og rette op på en eventuel ulovlighed ved at kræve berigtigelse eller sletning af oplysningerne. Dette formål nødvendigjorde ikke indsigt i selve den juridiske analyse. EU-Domstolen anførte endvidere, at formålet med de databeskyttelsesretlige regler ikke var at sikre indsigt i administrative dokumenter.

I *Nowak*-sagen ønskede en eksamensdeltager, der var dumpet, indsigt i sin eksamensbesvarelse, som var påført bedømmerens håndskrevne noter. EU-Domstolen fandt, at eksamensbesvarelsen i sin helhed og bedømmerens rettelsesnoter var personoplysninger om eksamensdeltageren og dermed omfattet af indsichtsretten. EU-domstolen lagde bl.a. vægt på, at eksamensbesvarelsen i modsat fald ikke nød nogen beskyttelse og dermed i princippet kunne gøres frit tilgængelig af uddannelsesinstitutionen og heller ikke ville være underlagt andre af persondatadirektivets krav om f.eks. sletning eller passende sikkerhedsforanstaltninger. EU-Domstolen lagde endvidere vægt på, at eksamensdeltageren havde en berettiget interesse i at kunne kontrollere eventuelle fejl i eksamensbedømmelsen, f.eks. ombytning af eksamensbesvarelser men også situationer, hvor “eksaminators rettelser og kommentarer ikke korrekt dokumenterer dennes evaluering”. Endelig lagde EU-Domstolen vægt på, at eksamensbedømmelsen havde indvirkning på den registrerede, bl.a. fordi den kunne påvirke hans chancer for at få adgang til det erhverv, han ønskede at arbejde inden for (eksamen indgik som en del af en revisoruddannelse).

Det kan umiddelbart være vanskeligt at forene de to afgørelser. I *YS*-sagen lagde Domstolen vægt på, at de databeskyttelsesretlige regler ikke skal sikre indsigt i administrative dokumenter. I *Nowak*-sagen synes det imidlertid netop at være ønsket om at kunne kontrollere bedømmerens vurdering af eksamensopgaven, der var bærende for den registreredes ønske om indsigt. Betragtningen i *Nowak*-sagen om, at dokumentet ville være helt uden beskyttelse, hvis det ikke blev behandlet som en personoplysning, kunne tilsvarende anføres for dokumenterne i *YS*-sagen. Også synspunktet om, at eksamensbedømmelsen havde indvirkning på den registrerede, gælder tilsvarende (og i endnu højere grad) for vurderingen om opholdstilladelse i *YS*-sagen. Skal man søge en konsistens i de to afgørelser, kan forskellen muligvis for-

klares med, at *IS*-sagen primært var en objektiv vurdering af, om juridiske krav var opfyldt, mens *Nowak*-sagen var en subjektiv vurdering af den registreredes egenskaber, hvormed selve bedømmelsen i højere grad kan siges at udgøre en personoplysning. Selv med denne forklaring er afgørelserne vanskelige at forene fuldt ud. *Nowak*-afgørelsen går langt, og måske også for langt, i sin fortolkning af indsigtsretten, hvis man vil fastholde, at den databeskyttelsesretlige indsigtsret ikke skal give registrerede mulighed for at kontrollere sagsbehandlingsaktiviteter men alene at kontrollere behandlingen af personoplysninger. Ikke desto mindre er den udtryk for gældende ret, særligt fordi den er den nyeste af de to domme.

Udover at bekræfte behandlingen af personoplysninger og give den registrerede adgang til personoplysningerne, skal den dataansvarlige give den registrerede følgende yderligere oplysninger efter art. 15, stk. 1 (fremhævelser foretaget her):

Hvilke oplysninger skal gives?

- a. *formålene* med behandlingen
- b. de berørte *kategorier af personoplysninger*
- c. de *modtagere* eller kategorier af modtagere, som personoplysningerne er eller vil blive videregivet til, navnlig modtagere i tredjelande eller internationale organisationer
- d. om muligt det påtænkte *tidsrum*, hvor *personoplysningerne vil blive opbevaret*, eller hvis dette ikke er muligt, de kriterier, der anvendes til fastlæggelse af dette tidsrum
- e. *retten til* at anmode den dataansvarlige om *berigtigelse* eller *sletning* af personoplysninger eller *begrænsning* af behandling af personoplysninger vedrørende den registrerede eller til at gøre *indsigelse* mod en sådan behandling
- f. retten til at indgive en *klage til en tilsynsmyndighed*
- g. enhver tilgængelig information om, *hvorfra personoplysningerne stammer*, hvis de ikke indsamles hos den registrerede
- h. forekomsten af *automatiske afgørelser*, herunder profilering, som omhandlet i artikel 22, stk. 1 og 4, og som minimum meningsfulde oplysninger om logikken heri samt betydningen og de forventede konsekvenser af en sådan behandling for den registrerede.

Hvor det er relevant, skal oplysningerne være “skræddersyet” til den konkrete indsigtsanmodning. Den dataansvarlige kan eksempelvis ikke blot henvise til de behandlingsformål, der er angivet i den generelle databeskyttelsespolitik, hvis det kun er nogle af disse formål, som er relevante for de behandlinger, der er omfattet af indsigtsanmodningen.

I princippet om, at oplysningerne skal være “skræddersyet”, ligger også, at de skal være så specifikke som muligt. Når det i litra c eksempelvis angives, at der skal oplyses om modtagere eller kategorier af modtagere, antager EDPB, at den dataansvarlige som udgangspunkt skal oplyse om de enkelte modtagere, medmindre det udelukkende er muligt at oplyse om kategorien af modtagere, jf. Guidelines 01/2022, pkt. 115.

Art. 15 pålægger ikke den dataansvarlige en pligt til at oplyse om behandlingsgrundlaget efter art. 6, således som art. 13 og 14 gør. Dette kan forekommende overraskende, da oplysning om behandlingsgrundlag vil være et element i den registreredes mulighed for at undersøge, om behandlingen er lovlig. EDPB anbefaler i Guidelines 01/2022, pkt. 112, at den dataansvarlige altid informerer den registrerede om det anvendte behandlingsgrundlag. Det er uklart, om EDPB forudsætter, at der er en egentlig pligt til oplyse om behandlingsgrundlaget. En sådan pligt kan dog ikke antages at eksisterer henset til, at opregningen i art. 15, der i øvrigt er meget sammenfaldende med de oplysninger, der skal gives efter art. 13 og 14, netop ikke, og i modsætning til disse to bestemmelser, nævner behandlingsgrundlaget.

– oplysning om behandlingsgrundlag

EDPB’s vejledning giver anledning til tvivl, fordi den efter at have angivet, at den dataansvarlige “anbefales” at oplyse om behandlingsgrundlaget, tilføjer, at “[i]n any event, the principle of transparent processing requires that the information on the legal bases of the processing be made available to the data subject in an accessible way (e.g. in a privacy notice)”.

Udover oplysningerne i art. 15, stk. 1, følger det af stk. 2, at den dataansvarlige også som led i indsigtsretten skal oplyse om de fornødne garantier efter art. 46, hvis behandlingen indbefatter overførsel til usikre tredjelande.

– oplysning om fornødne garantier ved tredjelandsoverførsler

Art. 15 indeholder ikke nærmere krav til, hvordan oplysninger skal gives. Det følger som anført ovenfor af art. 12, stk. 1, at alle oplysninger og meddelelser efter reglerne om registreredes rettigheder i art. 13-22 skal gives i en kortfattet, gennemsigtig, letforståelig og lettilgængelig form. Det heri indeholdte princip om transparens er ikke mindst vigtigt i relation til den registreredes ret til at få adgang til de personoplysninger, den dataansvarlige behandler om den pågældende. Når den dataansvarlige behandler meget store mængder oplysninger om en registreret, kan en rå systemudskrift heraf formelt give den registrerede indsigt, men reelt give den registrerede meget begrænset mulighed for at overskue behandlingsens omfang. Informationen skal give den registrerede en reel indsigt i behandlingen, og den dataansvarlige skal derfor tage databehandlingsens omfang og kompleksitet i betragtning ved vurderingen af, hvordan oplysningerne skal stilles rådighed for den registrerede.

Krav til, hvordan oplysningerne gives

Se nærmere hertil EDPB's Guidelines 01/2022, pkt. 125 ff., hvor det bl.a. anføres, at det kan være nødvendigt for den dataansvarlige at forsyne den registrerede med yderligere oplysninger, der forklarer, hvordan de udleverede data skal forstås. Vejledningen peger også på muligheden for at anvende lagdelt information ("layered approach"), når der er tale om meget store mængder oplysninger. Det følger videre af vejledningen (pkt. 140), at oplysningerne skal gives på den registreredes sprog, hvis den dataansvarlige tilbyder sine tjenester i det pågældende land.

Den dataansvarlige er endvidere efter art. 15, stk. 3, forpligtet til at udlevere en kopi af de personoplysninger, der behandles. Bestemmelsen har følgende ordlyd:

Udlevering af kopi af personoplysningerne – art. 15, stk. 3

Den dataansvarlige udleverer en kopi af de personoplysninger, der behandles. For yderligere kopier, som den registrerede anmoder om, kan den dataansvarlige opkræve et rimeligt gebyr baseret på de administrative omkostninger. Hvis den registrerede indgiver anmodningen elektronisk, og medmindre den registrerede anmoder om andet, udleveres oplysningerne i en almindeligt anvendt elektronisk form

Bestemmelsen giver alene den registrerede ret til at få udleveret en kopi af selve personoplysningerne, ikke de dokumenter, som personoplysningerne indgår i. Den dataansvarlige er med andre berettiget

til at ekstrahere personoplysningerne fra de dokumenter, oplysningerne hidrører fra, jf. også EDPB's Guidelines 01/2022, pkt. 150.

Den dataansvarlige skal dog være opmærksom på, at personoplysningsbegrebet fortolkes bredt, jf. eksempelvis den ovennævnte Nowak-dom fra EU-Domstolen, hvor den registrerede havde krav på at få udleveret en eksaminators noter, da disse havde karakter af oplysninger om den registrerede. Se eksempelvis også EDPB's Guidelines 01/2022, pkt. 153, hvor det bl.a. angives, at den registrerede har krav på at få udleveret lydoptagelser med den pågældende, og ikke kun en udskrift af optagelserne, da stemmen i sig selv udgør en personoplysning.

Såfremt den registrerede anmoder om kopier i flere tilfælde, kan den dataansvarlige kræve et omkostningsbestemt gebyr for udlevering af de yderligere kopier.

Efter art. 15, stk. 4, må retten til at modtage en kopi af oplysningerne efter stk. 3 ikke krænke andres rettigheder og frihedsrettigheder. I præambelbetragtning 63 nævnes som eksempler herpå forretningshemmeligheder og intellektuelle ejendomsrettigheder (immaterialrettigheder), herunder ophavsretten til software. Dette er dog ikke en udtømmende opregning og andre former for rettigheder kan også omfattes, eksempelvis databeskyttelsesrettigheder for andre end den registrerede. En virksomheds bredere økonomiske interesse i ikke at udlevere oplysningerne vil derimod ikke være omfattet, jf. EDPB's Guidelines 01/2022, pkt. 168. Det er således i særlig grad informationsrettigheder, bestemmelsen tager sigte på. Vurderer den dataansvarlige, at en udlevering af oplysningerne til den registrerede potentielt krænker andres rettigheder (herunder den dataansvarliges egne rettigheder), må den dataansvarlige foretage en konkret vurdering heraf. At en udlevering af oplysninger vil indeholde forretningshemmeligheder indebærer eksempelvis ikke, at den dataansvarlige kan afvise udleveringen, hvis der ikke er nogen reel risiko for, at udleveringen vil skade forretningshemmelighedsindehaverens økonomiske interesser. Der må med andre foretages en konkret afbalancering af den registrerede interesse i at få udleveret oplysningerne overfor andre berørte rettigheder og frihedsrettigheder. I præambelbetragtning 63 anføres, at art. 15, stk. 4, ikke bør føre til en afvisning af at give nogen form for oplysninger til den registrerede. Vurderer den dataansvarlige, at en udlevering af oplysning-

Indsigt må ikke krænke andres rettigheder og frihedsrettigheder
– art. 15, stk. 4

gerne vil krænke andres rettigheder, skal den dataansvarlige derfor så vidt muligt fjerne de oplysninger, der indebærer en krænkelse, og udlevere de øvrige oplysninger til den registrerede.

Efter sin ordlyd gælder art. 15, stk. 4, kun pligten til at udlevere en kopi. Potentielt kan den registrerede anmode om adgang til sine personoplysninger på anden måde end gennem udlevering af en kopi af oplysningerne, f.eks. gennem en systemadgang, gennemlæsning af papirdokumenter hos den dataansvarlige eller ved en mundtlig orientering. En sådan form for indsigt kan også krænke andres rettigheder og frihedsrettigheder, og det forekommer ulogisk, at udleveringsformen skulle være afgørende for, om den registrerede kan kræve indsigt i oplysningerne. Er en forretningshemmelighed eller følsomme oplysninger om andre blevet afsløret, er skaden sket, ligegyldigt hvordan den registrerede har fået adgang til oplysningerne. Uanset ordlyden af art. 15, stk. 4, må det derfor også antages, at den dataansvarlige kan afvise anmodningen, ikke kun om at udlevere en kopi efter stk. 3, men også i det hele taget til at give adgang til de behandlede personoplysninger (efter stk. 1), hvor dette vil krænke andres rettigheder og frihedsrettigheder.

Dette er også lagt til grund af EDPB i Guidelines 01/2022, pkt. 167.

Forpligtelsen efter art. 15 gælder de personoplysninger, som den dataansvarlige behandler på indsigts tidspunktet. Den registrerede har således ikke krav på at få informationer om tidligere behandlinger af personoplysninger, som den dataansvarlige ikke længere er i besiddelse af. Omvendt kan den dataansvarlige ikke afslå en indsigtsanmodning med den begrundelse, at behandlingen ligger langt tilbage, hvis den dataansvarlige fortsat opbevarer oplysninger om behandlingen. I praksis betyder det, at indsigtsretten gælder, indtil de pågældende oplysninger bliver slettet efter reglerne om sletning. Den dataansvarlige kan dog ikke undslippe pligten til at give indsigt ved at slette oplysninger, når den registrerede anmoder om indsigt. Bliver den dataansvarlige i forbindelse med anmodningen opmærksom på, at behandlingen er uberettiget og oplysningerne skal slettes, kan den dataansvarlige derfor ikke først slette oplysningerne og derefter informere den registrerede om, at der ikke sker nogen behandling. Indsigtsretten skal som nævnt give den registrerede mulighed for at undersøge, om der sker en uberettiget

Indsigtsrettens
tidsmæssige
udstrækning

behandling og i så fald forfølge sine rettigheder. Dette forudsætter, at den dataansvarlige gør den registrerede opmærksom på, at der er sket en ulovlig behandling. Den dataansvarlige vil næppe hellere kunne slette personoplysningerne, efter den registrerede er blevet informeret om den ulovlige behandling. Den registrerede kan have en interesse i, at oplysningerne fortsat opbevares af den dataansvarlige, indtil et eventuelt krav fra den registrerede er blevet afgjort. Den dataansvarlige må derfor formentlig give den registrerede mulighed for at vælge mellem sletning eller begrænsning af behandling efter art. 18, jf. bestemmelsens stk. 1, litra b, hvorefter den registrerede kan modsætte sig sletning og i stedet anmode om begrænsning af behandling (dvs. alene fortsat opbevaring af oplysninger), når behandlingen er ulovlig.

Se også om den tidsmæssige udstrækning af indsigt retten, EDPB's Guidelines 01/2022, pkt. 37-39.

Den registreredes anmodning er ikke underlagt formkrav, og den dataansvarlige kan derfor ikke afvise en anmodning med henvisning til, at den registrerede ikke har brugt et prædefineret format, en særlig formular fra den dataansvarlig e.lign. Omvendt er den dataansvarlige ikke forpligtet til at besvare en anmodning, der sendes til en e-mailadresse eller en anden kommunikationskanal, som åbenbart ikke er tænkt brugt til indsigtsanmodninger, hvis den dataansvarlige har stillet en kanal til rådighed til brug herfor.

Ingen formkrav til den registreredes anmodning

Se også EDPB's Guidelines 01/2022, pkt. 53-56, hvor det bl.a. anføres, at den dataansvarlige ikke kan undlade at besvare en anmodning, hvis den sendes til en medarbejder, der har daglig kontakt med den registrerede, selvom en anden kanal er etableret til afgivelse af anmodninger. EDPB anbefaler endvidere som god praksis, at dataansvarlige etablerer procedurer, der sikre intern kommunikation mellem medarbejdere, så indsigtsanmodninger videresendes til det relevante sted hos den dataansvarlige.

Den dataansvarlige kan heller ikke kræve, at den registrerede skal præcisere det retlige grundlag for anmodningen eller i øvrigt begrunde anmodningen. Den registreredes motiv for at søge indsigt er uden betydning for retten efter art. 15 (medmindre motivet er chikane, jf. ovenfor om grundløse eller overdrevne anmodninger), og selv hvis indsig-

ten kan skade den dataansvarlige, f.eks. fordi den registrerede vil bruge oplysningerne i en verserende retssag mellem parterne, har den registrerede krav på indsigt. Ofte vil indsigtsretten netop være relevant i den registreredes bestræbelser på at dokumentere, at den dataansvarlige ikke har overholdt forordningen.

Den registrerede har krav på at få udleveret alle oplysninger men kan også begrænse anmodningen til dele af oplysningerne, f.eks. en bestemt type af oplysninger eller oplysninger behandlet i et bestemt tidsinterval. Er den dataansvarlige i tvivl om omfanget af anmodningen, må den dataansvarlige afklare dette ved en henvendelse til den registrerede.

Indsigtsretten kan endvidere være undtaget efter DBL § 22, stk. 1 og 2, når afgørende hensyn til private eller offentlige interesser taler herfor, jf. nærmere om disse bestemmelser afsnit 3.1 ovenfor. Indsigtsretten kan endvidere undtages i samme omfang som gælder efter reglerne i offentlighedsloven, jf. § 22, stk. 3. Indsigtsretten gælder ikke, hvis oplysningerne udelukkende behandles i videnskabeligt eller statistisk, jf. § 22, stk. 5.

Undtagelser til
indsigtsretten
efter DBL § 22

5. Den registreredes ret til berigtigelse

Den registrerede har i henhold til forordningens art. 16 ret til at få urigtige personoplysninger om sig selv berigtiget af den dataansvarlige uden unødigt forsinkelse. Er oplysningerne ufuldstændige, kan den registrerede kræve dem suppleret. Bestemmelsen har følgende ordlyd:

Den registrerede har ret til at få urigtige personoplysninger om sig selv berigtiget af den dataansvarlige uden unødigt forsinkelse. Den registrerede har under hensyntagen til formålene med behandlingen ret til få fuldstændiggjort ufuldstændige personoplysninger, bl.a. ved at fremlægge en supplerende erklæring.

Bestemmelsen hænger tæt sammen med det grundlæggende princip om "rigtighed", som er udtrykt i art. 5, stk. 1, litra d. Princippet om personoplysningernes rigtighed og den tilhørende ret til at kræve berigtigelse og suppleret afspejler, at myndigheder og virksomheders afgørelser af betydning for den registrerede på baggrund af dennes personoplysninger skal være baseret på et faktuel korrekt grundlag. End-

videre hviler bestemmelsen på det grundlæggende personlighedshensyn, at den registrerede har krav på, at der bliver præsenteret et retvisende billede af den pågældendes personlighed, hvilket forudsætter, at behandlede personoplysninger er korrekte og retvisende.

Som nærmere anført i kap. 4.4 om art. 5, stk. 1, litra d, kan en “berigtigelse” både ske ved at urigtige oplysninger slettes og erstattes af de korrekte oplysninger og i nogle tilfælde blot ved, at det angives, at oplysningerne er ukorrekte. Som nærmere hertil kap. 4.4.

Såfremt den dataansvarlige har videregivet de urigtige oplysninger, skal den dataansvarlige underrette modtagerne om berigtigelsen, jf. forordningens art. 19.

Retten til berigtigelse gælder ikke, hvis oplysningerne udelukkende behandles i videnskabeligt eller statistisk øjemed, jf. DBL § 22, stk. 5.

6. Retten til sletning (“retten til at blive glemt”)

Den digitale teknologi gør det nemt at kopiere og videresprede information. Det gælder også de enorme mængder af personoplysninger, der deles gennem sociale netværkstjenester og hjemmesider. Mange har måttet konstatere, at de billeder og oplysninger, man har haft lyst til at dele med andre i én periode af sit liv, vil man gerne have unddraget offentligheden senere hen.

I forbindelse med udarbejdelsen af forordningen ønskede Kommissionen derfor at udstyre borgerne med en “ret til at blive glemt”. Denne ret følger nu af forordningens art. 17, der indeholder en generelt til at kræve sletning i en række situationer.

Allerede inden forordningen blev vedtaget, fik EU-Domstolen ved en dom af 13. maj 2014 (*C-131/12, Google Spain*) lejlighed til at vurdere, hvorvidt der under det tidligere persondatadirektiv gjaldt en “ret til at blive glemt”, uagtet direktivet ikke indeholdt en særskilt regulering af en sådan ret. Sagen rummer en række væsentlige principielle spørgsmål og har haft stor betydning for adgangen til at kræve de-indeksering fra søgemaskiner (i realiteten navnlig Google). Den praksis, der blev etableret på baggrund af dommen, har fortsat relevans. Dommen omtales nærmere i det følgende inden forordningens art. 17 gennemgås.

6.1. Google Spain-dommen

Sagen udsprang af en klage fra en spansk statsborger, hvis ejendom i 1998 blev solgt på tvangsauktion i forbindelse med gæld til den sociale sikringsordning. Ifølge spansk lov skulle tvangsauktionen annonceres offentligt. Tvangsauktionsannoncen blev bragt i en spansk avis og kunne tilgås fra avisens elektroniske artikelarkiv på avisens hjemmeside. Som en konsekvens heraf dukkede artiklen op, når man søgte på mandens navn i Googles søgemaskine. I 2010 klagede manden herover til den spanske tilsynsmyndighed og gjorde gældende, at gældsforholdet for længst var bragt ud af verden, og at oplysningerne derfor ikke længere var relevante. Det spanske tilsyn afviste, at manden kunne kræve artiklerne fjernet fra avisens elektroniske arkiv, idet offentliggørelsen fulgte af et lovkrav. Derimod fandt tilsynet, at Google var forpligtet til at fjerne linket til den pågældende side. Denne afgørelse indbragte Google for den spanske domstol, Audiencia Nacional, der herefter forelagde en række præjudicielle spørgsmål for EU-Domstolen.

Sagens faktum og præjudicielle spørgsmål

Under sagen anførte Google, at en søgemaskine alene indekserede oplysninger, som allerede var tilgængelige på internettet, og at det således ikke var Google, som besluttede, hvilke oplysninger der blev offentliggjort. Ud fra denne tanke om, at søgemaskineudbyderen alene er en passiv mellemmand, gjorde Google gældende, at der ikke kunne bestå en pligt til at slette oplysninger, der fortsat ville være tilgængelige på den hjemmeside, der blev linket til, og at dette særligt måtte gælde, når oplysningerne lovligt lå på hjemmesiden. Disse betragtninger blev imidlertid afvist af EU-Domstolen, der fastslog, at den søgbarhed af oplysningerne, som Googles søgemaskine tilvejebringer, kan være mere indgribende end selve offentliggørelsen af oplysninger på hjemmesiden. Googles påstand om, at man ikke kan tvinge en søgemaskineudbyder til at slette links, allerede fordi oplysningerne fortsat vil være tilgængelige på de hjemmesider, der linkes til, blev derfor afvist af EU-Domstolen.

Passiv mellemmand?

Hermed blev spørgsmålet, om en slettepligt for søgemaskineudbydere kunne udledes af direktivet. Omdrejningspunktet var direktivets art. 12, litra b, der gav den registrerede ret til at få "oplysninger, som ikke er blevet behandlet i overensstemmelse med dette direktiv, berigtiget, slettet eller blokeret, navnlig hvis de er ufuldstændige eller urig-

Pligt til at slette irrelevante oplysninger

tige”. EU-Domstolen fastslog, at bestemmelsens angivelse af oplysninger, der er “ufuldstændige” eller “urigtige”, alene er eksemplificeringer, og at bestemmelsen indebærer, at enhver behandling i strid med direktivet kunne kræves berigtiget, slettet eller blokeret af den registrerede. Herefter henviste domstolen til de generelle behandlingskrav, der fulgte af direktivets art. 6 (nu forordningens art. 5), herunder kravene om formålsbestemthed, relevans og tidsbegrænsning. Såfremt ét eller flere af disse krav ikke var opfyldt, ville den registrerede kunne kræve berigtigelse, sletning eller blokering efter art. 12, litra b. På baggrund heraf konkluderede domstolen, at enhver person kunne kræve, at en søgemaskine slettede links til oplysninger om den pågældende, hvis oplysningerne ikke længere var relevante, uanset om de var relevante på tidspunktet, hvor de blev offentliggjort på hjemmesiden. EU-Domstolen fastslog endvidere, at det ikke var et krav, at offentliggørelsen af oplysningerne skadede den pågældende person. Det var således tilstrækkeligt, at oplysningerne ikke længere var relevante.

Domstolen opstiller dog en undtagelse, såfremt det af særlige grunde fremgår, at indgrebet i personens grundlæggende rettigheder er begrundet i offentlighedens vægtige interesse i at have adgang til de pågældende oplysninger, jf. dommens præmis 97. Domstolen nævner som et kriterium for denne vurdering, hvilken rolle personen har i det offentlige liv.

Vægtige offentlige
interesser i
adgang til
information

Med dommen skal Google og andre søgemaskineudbydere vurdere, hvorvidt oplysningerne om en person ikke længere er relevante, og om vægtige offentlige interesser i så fald undtagelsesvis kan begrunde, at der alligevel linkes til oplysningerne. Denne vurdering skal foretages konkret for hver henvendelse, søgemaskineudbyderen modtager. Den konkrete vurdering kan tage udgangspunkt i nogle mere generelle kriterier (oplysningernes alder, karakteren af oplysningerne, personens offentlige status mv.), hvilket dog ikke ændrer på, at der stadig må foretages en individuel vurdering. Det er en vanskelig og omfattende opgave, dommen pålægger søgemaskineudbyderen.

Den konkrete
vurdering

Artikel 29-gruppen udarbejdede i 2014 retningslinjer for implementeringen af dommen (WP 225), herunder med en liste over kriterier, som de nationale datatilsyn vil lægge vægt på ved den konkrete vurdering af, om et link kan kræves slettet.

Dommen har givet anledning til betydelig debat. Det er bl.a. blevet drøftet, om dommen rammer den rigtige balance mellem privatlivshensyn og informationsfrihedshensyn ved end ikke at kræve et element af skadevirkning, før der kan kræves sletning. I forlængelse heraf er der en risiko for, at søgemaskineudbydere vil slette flere links end påkrævet, da udbyderen ikke løber nogen risiko ved at slette links, hvorimod en manglende sletning kan være et lovbrud. Dommen blev dog også støttet af fortalere for en stærk privatlivsbeskyttelse. Kommissionen udtrykte også markant opbakning til dommen, hvilket heller ikke er overraskende, idet dommen understøttede den "ret til at blive glemt", som Kommissionen introducerede i sit oprindelige forordningsudkast, og som har udmøntet sig i art. 17 i den endelige udgave af forordningen.

6.2. Forordningens art. 17

Lige siden Kommissionen startede sit arbejde med at udarbejde en ny databeskyttelsesforordning, stod ønsket om at give de europæiske borgere en mulighed for at blive glemt på internettet højt på den politiske dagsorden. I den endelige udgave af forordningen er denne "ret til at blive glemt" reguleret på følgende måde i art. 17, stk. 1:

Slettepligt, art. 17, stk. 1

Den registrerede har ret til at få personoplysninger om sig selv slettet af den dataansvarlige uden unødigt forsinkelse, og den dataansvarlige har pligt til at slette personoplysninger uden unødigt forsinkelse, hvis et af følgende forhold gør sig gældende:

- a) Personoplysningerne er ikke længere nødvendige til at opfylde de formål, hvortil de blev indsamlet eller på anden vis behandlet.
- b) Den registrerede trækker det samtykke, der er grundlaget for behandlingen, jf. artikel 6, stk. 1, litra a), eller artikel 9, stk. 2, litra a), tilbage, og der ikke er et andet retsgrundlag for behandlingen.
- c) Den registrerede gør indsigelse mod behandlingen i henhold til artikel 21, stk. 1, og der foreligger ikke legitime grunde til behandlingen, som går forud for indsigelsen, eller den registrerede gør indsigelse mod behandlingen i medfør af artikel 21, stk. 2.
- d) Personoplysningerne er blevet behandlet ulovligt.

- e) Personoplysningerne skal slettes for at overholde en retlig forpligtelse i EU-retten eller medlemsstaternes nationale ret, som den dataansvarlige er underlagt.
- f) Personoplysningerne er blevet indsamlet i forbindelse med udbud af informationssamfundstjenester som omhandlet i artikel 8, stk. 1.

Bestemmelsen gælder ikke kun oplysninger, der er gjort tilgængelige på internettet. Også oplysninger, der udelukkende er lagret i den dataansvarliges eget system, er omfattet af denne ret. Bestemmelsen har derfor karakter af en generel bestemmelse om ret til at kræve sletning.

Undervejs i arbejdet med forordningen ændredes bestemmelsens overskrift da også fra "Retten til at blive glemt" til "Retten til sletning" (med "retten til at blive glemt" i parentes).

For hovedparten af de situationer, hvor der kan kræves sletning efter art. 17, stk. 1, vil pligten til sletning også følge af andre regler, særligt art. 5, stk. 1, om de grundlæggende principper, herunder principperne om lovlighed (litra a), formålsbegrænsning (litra b) og datamining (litra c). Dette gælder dog ikke art. 17, stk. 1, litra f, om slettepligt i relation til personoplysninger, der er indsamlet i forbindelse med udbud af informationssamfundstjenester som omhandlet i art. 8, stk. 1 (se nærmere om denne bestemmelse kap. 5.2.5 ovenfor). Det betyder, at oplysninger om børn indsamlet i forbindelse med informationssamfundstjenester, som f.eks. Facebook, altid kan kræves slettet, uanset om indsamlingen og den efterfølgende behandling i øvrigt er lovlig. Hermed har man bl.a. forsøgt at beskytte børn og unge mod, at (kompromitterende) billeder mv., der lægges ud tidligt i livet på sociale medier, skal forfølge den pågældende senere i voksenlivet.

Som beskrevet i afsnit 6.1 fastslog EU-Domstolen i *Google Spain-dommen* (C-131/12), at det tidligere persondatadirektiv hjemlede en ret til i visse situationer at kræve de-indeksering i søgemaskiner. En tilsvarende ret gælder efter art. 17. Hjemlen vil navnlig kunne findes i art. 17, stk. 1, litra a (behandlingen ikke længere nødvendig for at opfylde formålet), litra c om indsigelsesret og litra d om ulovlig behandling (en søgemaskineudbyders behandling af personoplysninger, der ikke længere er relevante, vil sjældent kunne hjemles i nogle af behandlings-

– særlig pligt for informations-samfundstjenester til at slette oplysninger om børn

– de-indeksering i søgemaskiner

grundlagene i art. 6 og vil som regel også være i strid med dataminimeringsprincippet i art. 5, stk. 1, litra c. Det må forventes, at den praksis, der er udviklet om relevanskravet på baggrund af *Google Spain*-afgørelsen, også vil kunne tillægges vægt ved fortolkningen af relevansbegrebet under forordningen.

Se også om retten til at kræve de-indeksering fra søgemaskiner efter forordningens art. 17, EDPB's retningslinjer [5/2019 \(del 1\)](#).

En dataansvarlig, der er forpligtet til at slette oplysninger efter art. 17, stk. 1, er ligeledes forpligtet til at underrette andre, som den dataansvarlige har videregivet oplysningerne til, om sletningen, jf. forordningens art. 19.

Underretningspligt – art. 19

Skal beskyttelsen være effektiv i relation til billeder og andre oplysninger, der ligger på internettet, forudsætter det, at alle kopier af de pågældende billeder og oplysninger slettes. Art. 17, stk. 2, indeholder derfor en udvidet underretningspligt for dataansvarlige, der har offentliggjort personoplysninger (f.eks. ved at gøre dem tilgængelige på internettet). Bestemmelsen har følgende ordlyd:

– art. 17, stk. 2

Hvis den dataansvarlige har offentliggjort personoplysningerne og i henhold til stk. 1 er forpligtet til at slette personoplysningerne, træffer den dataansvarlige under hensyntagen til den teknologi, der er tilgængelig, og omkostningerne ved implementeringen, rimelige foranstaltninger, herunder tekniske foranstaltninger, for at underrette de dataansvarlige, som behandler personoplysningerne, om, at den registrerede har anmodet disse dataansvarlige om at slette alle link til eller kopier eller gengivelser af de pågældende personoplysninger

I modsætning til art. 19 gælder denne bestemmelse ikke kun i forhold til de modtagere, den dataansvarlige har videregivet oplysningerne til, men i forhold til alle, der behandler oplysningerne. Dette kan være en vanskelig og i mange tilfælde praktisk umulig opgave. Derfor gælder forpligtelsen kun, hvis underretningen kan ske ved at træffe "rimelige foranstaltninger", som skal fastsættes under hensyntagen til tilgængelig teknologi og omkostningerne ved implementeringen. Uanset de gode intentioner er udsagnet om, at "nettets aldrig glemmer", i mange tilfælde sandt, og det er nok tvivlsomt, hvor stor effekt underret-

ningspligten vil have, når først oplysningerne er blevet spredt på nettet.

Dataansvarlige, der modtager underretning efter art. 17, stk. 2, og art. 19, skal foretage en vurdering af, om de tilsvarende er forpligtet til at slette oplysningerne efter stk. 1, eller om de fortsat lovligt kan behandle oplysningerne. Den omstændighed, at den første dataansvarlige er forpligtet til at slette oplysningerne, er med andre ord ikke ensbetydende med, at de øvrige dataansvarlige, der modtager underretning efter art. 17, stk. 2, eller art. 19, automatisk forpligtes til at slette oplysningerne.

– de underrettedes eventuelle slettepligt

Pligten til sletning og underretning efter stk. 1 og 2 er undergivet en række undtagelser i art. 17, stk. 3, der har følgende ordlyd:

Undtagelser, art. 17, stk. 3

Stk. 1 og 2 finder ikke anvendelse, i det omfang denne behandling er nødvendig:

- a) for at udøve retten til ytrings- og informationsfrihed
- b) for at overholde en retlig forpligtelse, der kræver behandling i henhold til EU-retten eller medlemsstaternes nationale ret, og som den dataansvarlige er underlagt, eller for at udføre en opgave i samfundets interesse eller som henhører under offentlig myndighedsudøvelse, som den dataansvarlige har fået pålagt
- c) af hensyn til samfundsinteresser på folkesundhedsområdet i overensstemmelse med artikel 9, stk. 2, litra h) og i), samt artikel 9, stk. 3
- d) til arkivformål i samfundets interesse, til videnskabelige eller historiske forskningsformål eller til statistiske formål i overensstemmelse med artikel 89, stk. 1, i det omfang den rettighed, der er omhandlet i stk. 1, sandsynligvis vil gøre det umuligt eller i alvorlig grad hindre opfyldelse af denne behandling, eller
- e) for, at retskrav kan fastlægges, gøres gældende eller forsvares.

Efter stk. 3, litra a, gælder pligten ikke, når en behandling af oplysningerne er nødvendig for at udøve retten til ytrings- og informationsfrihed. Det vil bero på en konkret vurdering, om ytringsfrihedshensynet er så tungtvejende, at slettepligten ikke gælder. Dette vil kun undtagelsesvist være tilfældet.

– ytrings- og informationsfrihed

Pligten gælder endvidere ikke, når behandlingen er nødvendig for at overholde en retlig forpligtelse for den dataansvarlige eller er nødvendig for at udføre en opgave i samfundets interesse, eller som henhører under offentlig myndighedsudøvelse, jf. stk. 3, litra b. Disse undtagelser viser tilbage til behandlingsreglerne i art. 6, stk. 1, litra c og e, der er omtalt i kap. 5.3.2 og 5.3.4. Hvis den dataansvarlige har en forpligtelse til på et senere tidspunkt at videregive oplysningerne, gælder slettepligten således ikke. Tilsvarende hvis oplysningerne er nødvendige for en offentlig myndigheds sagsbehandling.

– retlig forpligtelse, samfundsopgave og myndighedsudøvelse

Efter stk. 3, litra e, gælder pligten ikke, hvis behandlingen er nødvendig for, at et retskrav kan fastlægges, gøres gældende eller forsvares. Den registrerede kan således ikke kræve sletning, hvis oplysningerne eksempelvis skal bruges i forbindelse med en retssag.

– retskrav

Pligten til at slette personoplysninger er vanskelig at efterleve, når personoplysninger lagres i en blockchain. Det er et af de væsentlige karakteristika ved blockchainteknologien, at indholdet af en blockchain ikke kan ændres og dermed heller ikke slettes. I nogle tilfælde men langt fra altid vil undtagelserne i art. 17, stk. 3, kunne finde anvendelse på oplysninger opbevaret i en blockchain. Se nærmere om disse udfordringer og andre vanskeligheder ved at få indpasset blockchainteknologien i databeskyttelsesretten, Finck, Blockchain and Data Protection in the European Union.

– blockchain

Som anført kan reglerne om de registreredes rettigheder både være proaktive, således at den dataansvarlige skal handle af egen drift, og reaktive, således at den dataansvarlige kun skal handle på anmodning fra den registrerede. Det er ikke klart, om art. 17 har karakter af en proaktiv eller reaktiv bestemmelse. Den omstændighed, at retten til sletning netop betegnes som en "ret" for den registrerede, kan tale i retning af, at bestemmelsen har reaktiv karakter og således kun finder anvendelse, hvis den registrerede udøver rettigheden gennem en henvendelse til den dataansvarlige. I art. 17, stk. 1, fastslås ganske vist også, at "den dataansvarlige har pligt til at slette personoplysningerne uden unødigt forsinkelse". Dette kan dog ikke nødvendigvis tages til indtægt for, at den dataansvarlige har en proaktiv pligt til sletning. Betydningen kan lige så vel være, at når den registrerede har anmodet om

Proaktiv eller reaktiv bestemmelse?

sletning, skal den dataansvarlige sørge for, at der sker uden unødigt forsinkelse.

Spørgsmålet er behandlet af EDPB i Opinion 39/2021, hvor rådet anfører, at retten til sletning efter art. 17, stk. 1, omfatter en række situationer, som det i praksis vil være meget vanskeligt for den registrerede at tage stilling til, og som beror på vurderinger, der skal foretages af den dataansvarlige. Dette vil f.eks. gælde vurderingen af, om oplysningerne ikke længere er nødvendige for at opfylde formålet (litra a), om behandlingen er ulovlig (litra d), og om sletning er nødvendig for at overholde en retlig forpligtelse (litra e). Dette understøtter efter EDPB's opfattelse, at den dataansvarlige er underlagt en proaktiv slettepligt efter art. 17. EDPB peger endvidere på, at tilsynsmyndighederne ikke vil have mulighed for af egen drift at pålægge dataansvarlige at slette oplysninger efter art. 58, stk. 2, litra g, hvis art. 17 forudsætter en anmodning fra den registrerede. Art. 58, stk. 2, litra g, giver tilsynsmyndighederne mulighed for at påbyde dataansvarlige at slette oplysninger "i henhold til" art. 17. EDPB's synspunkt er således, at hvis art. 17 forudsætter, at den registrerede har anmodet om sletning, og den registrerede ikke har gjort dette, vil art. 58, stk. 2, litra g, ikke give tilsynsmyndigheden hjemmel til at påbyde sletning, da det forudsætter, at betingelserne i art. 17 er opfyldt. På denne baggrund konkluderer EDPB i opinion 39/2021, at den dataansvarlige har en proaktiv pligt til at slette efter art. 17, også selvom den registrerede ikke har anmodet om sletning.

EDPB's konklusion og argumentation kan dog anfægtes. De grundlæggende krav til den dataansvarliges behandling er placeret i art. 5 (de grundlæggende principper) og art. 6 (krav om behandlingsgrundlag). Disse bestemmelser vil i sig selv pålægge den dataansvarlige en pligt til at slette oplysninger i de situationer, der er angivet af EDPB (oplysninger ikke nødvendige for at forfølge formål, ulovlig behandling og sletning nødvendig for at overholde retlig forpligtelse). Der er derfor ikke noget behov for, at en bestemmelse om de registreredes rettigheder skulle pålægge den dataansvarlige samme forpligtelse, som allerede fremgår af art. 5 og 6. Systematisk forekommer det mere logisk, at den dataansvarliges selvstændige pligt efter art. 5 og 6 suppleres af en ret for den dataansvarlige til at kræve sletning efter art. 17. Illustrativt er også, at den formentlig eneste situation, hvor der kan kræ-

ves sletning efter art. 17, uden at en sådan pligt allerede ville gælde for den dataansvarlige efter art. 5 og 6, er art. 17, stk. 1, litra f, om indsamling af oplysninger om børn på sociale medier og andre informations-samfundstjenester. Den pligt gælder utvivlsomt kun, når den registrerede selv har anmodet om sletning, da det i modsat slet ikke ville være muligt at behandle oplysninger om børn og unge på sociale medier. Heller ikke behovet for, at tilsynsmyndigheden af egen drift skal kunne pålægge den dataansvarlige at slette oplysninger efter art. 58, stk. 2, litra g, taler nødvendigvis for EDPB's fortolkning. Denne mulighed vil tilsynsmyndighederne under alle omstændigheder have efter andre af bestemmelserne i art. 58, stk. 2, særlig litra d om at bringe en behandling i overensstemmelse med forordningen og litra f om at begrænse, herunder forbyde, en behandling. Det er endvidere ikke sikkert, at litra g skal læses sådan, at den kun gælder, hvis den registrerede har anmodet om sletning efter art. 17. Det følger af litra c, at tilsynsmyndigheden kan give den dataansvarlige påbud om at imødekomme den registreredes anmodninger om at udøve sine rettigheder. Tilsynsmyndighedernes mulighed for at påbyde den dataansvarlige at slette oplysninger, når den registrerede har anmodet om det efter art. 17, følger således allerede af litra c. Det er derfor også muligt, at art. 58, stk. 2, litra g, skal forstås sådan, at tilsynsmyndigheden kan påbyde den dataansvarlige at slette oplysninger, uanset om den registrerede ikke har anmodet om det, når betingelserne for sletning efter art. 17 i øvrigt er opfyldt.

Samlet set taler mest for, at art. 17 ikke pålægge den dataansvarlige en proaktiv pligt til at slette oplysninger, men alene er en bestemmelse, som giver den registrerede ret til at kræve sletning. I praksis har det dog ikke stor betydning, da den dataansvarlige i langt de fleste tilfælde som anført allerede vil have en selvstændig pligt til at slette oplysninger efter art. 5 og 6.

7. Ret til begrænsning af behandling

Forordningens art. 18 giver den registrerede ret til at kræve "begrænsning af behandling". Dette indebærer, at den dataansvarlige i en række situationer alene må opbevare personoplysningerne, men i øvrigt som udgangspunkt ikke må behandle dem uden den registreredes

samtykke. Konsekvensen er, at den dataansvarlige forbydes at foretage en behandling, selvom den ellers ville have hjemmel i en af behandlingsreglerne i art. 6 (og art. 9 såfremt der er tale om følsomme oplysninger).

Begrebet “begrænsning af behandling” er defineret i art. 4, nr. 3, som “mærkning af opbevarede personoplysninger med den hensigt at begrænse fremtidig behandling af disse oplysninger”.

Begreb

Om metoder til begrænsning af behandling angives følgende i præambelbetragtning 67: “Metoder til at begrænse behandlingen af personoplysninger kan bl.a. omfatte, at udvalgte oplysninger midlertidig flyttes til et andet behandlingssystem, at udvalgte personoplysninger gøres utilgængelige for brugere, eller at offentliggjorte oplysninger midlertidig fjernes fra et websted. I automatiske registre bør begrænsning af behandling i princippet sikres ved hjælp af tekniske midler på en sådan måde, at personoplysningerne ikke kan viderebehandles og ikke kan ændres. Det forhold, at behandling af personoplysninger er begrænset, bør angives tydeligt i systemet”.

Den registreredes ret til at kræve begrænsning af behandling gælder i fire tilfælde, jf. art. 18, stk. 1, der har følgende ordlyd:

Tilfælde hvor der kan kræves begrænsning af behandling

Den registrerede har ret til fra den dataansvarlige at opnå begrænsning af behandling, hvis et af følgende forhold gør sig gældende:

- a) rigtigheden af personoplysningerne bestrides af den registrerede, i perioden indtil den dataansvarlige har haft mulighed for at fastslå, om personoplysningerne er korrekte
- b) behandlingen er ulovlig, og den registrerede modsætter sig sletning af personoplysningerne og i stedet anmoder om, at anvendelse heraf begrænses
- c) den dataansvarlige ikke længere har brug for personoplysningerne til behandlingen, men de er nødvendige for, at et retskrav kan fastlægges, gøres gældende eller forsvares
- d) den registrerede har gjort indsigelse mod behandlingen i medfør af artikel 21, stk. 1, i perioden mens det kontrolleres, om den dataansvarliges legitime interesser går forud for den registreredes legitime interesser.

Hvis rigtigheden af personoplysningerne bestrides af den registrerede, kan denne kræve begrænsning af behandling, indtil den dataansvarlige har haft mulighed for at fastslå, om personoplysningerne er

– rigtigheden bestrides –
litra a

korrekte. Den dataansvarlige skal med andre ord standse behandlingen af oplysningerne, indtil den dataansvarlige har vurderet, om oplysningerne er korrekte.

Hvis behandlingen er ulovlig, kan den registrerede anmode om, at der sker begrænsning af behandling i stedet for sletning af oplysningerne. Konsekvensen heraf er, at den dataansvarlige fortsat kan opbevare oplysningerne, men ikke i øvrigt behandle dem, så længe behandlingen vil være ulovlig. Det kan eksempelvis være i den registreredes interesse, at den dataansvarlige fortsat kan opbevare oplysningerne, mens behandlingen lovliggøres, i stedet for, at den registrerede skal indsende oplysningerne igen. Dette kan også være tilfældet, hvis den registrerede ønsker at bruge oplysninger som bevis i en retssag, hvor den registrerede eksempelvis vil søge erstatning efter art. 82 af den dataansvarlige. Bestemmelsen må formentlig forstås således, at den dataansvarlige pålægges en pligt til at opbevare personoplysninger, når den registrerede anmoder herom, jf. betænkning 1565/2017, s. 341.

– ulovlig
behandling -
litra b

Den registrerede kan endvidere kræve begrænsning af behandling, hvis den dataansvarlige ikke længere har brug for personoplysningerne til behandlingen, men de er nødvendige for, at et retskrav kan fastlægges, gøres gældende eller forsvares.

– Retskrav –
litra c

Endelig kan den registrerede kræve begrænsning af behandling, hvis den registrerede har gjort indsigelse mod behandlingen efter indsigelsesretten i art. 21 (omtalt nedenfor), mens det kontrolleres, om indsigelsen skal tages til følge.

– indsigelse efter
art. 21 – litra d

Konsekvensen af, at den registrerede kan kræve begrænsning er efter art. 18, stk. 2, at den dataansvarlige som udgangspunkt kun må fortage opbevaring men ikke yderligere behandling af oplysningerne, medmindre en af de angivne undtagelser gælder. Bestemmelsen har følgende ordlyd:

Forbud mod
anden behandling
end opbevaring

Hvis behandling er blevet begrænset i medfør af stk. 1, må sådanne personoplysninger, bortset fra opbevaring, kun behandles med den registreredes samtykke eller med henblik på, at et retskrav kan fastlægges, gøres gældende eller forsvares eller for at beskytte en anden fysisk eller juridisk person eller af hensyn til Unionens eller en medlemsstats vigtige samfundsinteresser.

Den registrerede kan således ikke gøre begrænsningsretten gældende, hvis en behandling af oplysningerne er nødvendig for behandlingen af et retskrav, for at beskytte en anden fysisk eller juridisk person eller af hensyn til vigtige samfundsinteresser. Dette indebærer bl.a., at den dataansvarlige kan behandle oplysningerne, når det sker som led i en retlig tvist med den registrerede. Korfits Nielsen & Lotterup, antages, at retskravsundtagelsen også omfatter den situation, hvor behandlingen er nødvendig for at den dataansvarlige kan opfylde en oplysningspligt efter anden lovgivning, Databeskyttelsesforordningen og databeskyttelsesloven, s. 556. Dette indebærer bl.a., at offentlige myndigheder kan give tredjemand aktindsigt efter reglerne i forvaltningsloven og offentlighedsloven, selvom oplysningerne i øvrigt af omfattet af begrænsningsretten efter art. 18. Det synes ikke givet, at retskravsundtagelsen efter sin ordlyd kan omfatte alle situationer, hvor den dataansvarlige er underlagt en oplysningspligt efter lovgivningen, herunder i situationer, hvor tredjemand ikke skal bruge oplysningerne til at forfølge et retskrav. Såfremt den lovgivning, der forpligter den dataansvarlige til at udlevere oplysningerne, i øvrigt ligger inden for det nationale råderum efter forordningen, tilsiger reale grunde dog, at den dataansvarlige må kunne udlevere oplysningerne. Dette kan tale for at lade retskravsundtagelsen finde anvendelse eller lade situationen være omfattet af en af de andre undtagelser (beskyttelse af fysiske og juridiske personer eller vigtige samfundsinteresser).

Undtagelser

Retten til begrænsning gælder ikke, hvis oplysningerne udelukkende behandles i videnskabeligt eller statistisk øjemed, jf. DBL § 22, stk. 5.

Den dataansvarlige er efter art. 18, stk. 3, forpligtet til at underrette den registrerede om begrænsningen. Dette skal ske inden en eventuel ophævelse af begrænsningen. Den dataansvarlige er efter art. 19 ligeledes forpligtet til at underrette andre, som den dataansvarlige har videregivet oplysningerne til, om begrænsningen.

Underretningspligt

Det må antages, at art. 18 er en reaktiv bestemmelse, der kun pålægger den dataansvarlige at begrænse behandlingen, når den registrerede anmoder om det.

Reaktiv bestemmelse

8. Ret til dataportabilitet

Forordningens art. 20 giver den registrerede en adgang til at kræve sine personoplysninger udleveret i et format, som muliggør, at en anden dataansvarlig overtager oplysningerne som led i sin tjeneste. Bestemmelsen har navnlig til formål at give forbrugere en let adgang til at skifte til en konkurrerende tjeneste. Hermed har retten til dataportabilitet i realiteten mere karakter af en forbrugerrettigheder end en databeskyttelsesrettighed.

Art. 20, stk. 1, fastslår den registreredes ret til selv at modtage personoplysningerne:

Den registreredes ret til at modtage oplysninger

Den registrerede har ret til i et struktureret, almindeligt anvendt og maskinlæsbart format at modtage personoplysninger om sig selv, som vedkommende har givet til en dataansvarlig, og har ret til at transmittere disse oplysninger til en anden dataansvarlig uden hindring fra den dataansvarlige, som personoplysningerne er blevet givet til, når:

- a) behandlingen er baseret på samtykke, jf. artikel 6, stk. 1, litra a), eller artikel 9, stk. 2, litra a), eller på en kontrakt, jf. artikel 6, stk. 1, litra b), og
- b) behandlingen foretages automatisk.

Bestemmelsen kan siges at supplere den almindelige indsigtsret i art. 15, men har navnlig selvstændig relevans gennem kravet om, at oplysningerne skal udleveres i et struktureret, almindeligt anvendt og maskinlæsbart format. Indsigtsretten efter art. 15 indeholder ikke et tilsvarende formatkrav. Det vil bero på en konkret vurdering, om et format kan siges at være "almindeligt anvendt". Den dataansvarlige kan selv vælge formatet, så længe det opfylder kravet om at være almindeligt anvendt. Den registrerede kan således ikke kræve udlevering i et specifikt format.

Krav til format

Retten til dataportabilitet gælder kun oplysninger, som den registrerede har givet til den dataansvarlige. Oplysninger, som den dataansvarlige selv har indsamlet, er således ikke omfattet. Art. 29-gruppens retningslinjer vedrørende retten til dataportabilitet, WP 242/2016 (tiltrådt af EDPB ved Endorsement 1/2018), angiver, at oplysninger, der er genereret ved brug af en ydelse, også skal anses for "givet" af den registrerede, jf. retningslinjernes s. 10, der angiver søge-

Oplysninger givet af den registrerede

historik, trafikdata og data fra intelligente målere (f.eks. elmålere) som eksempler herpå. Også en oversigt over, hvilke film og serier brugeren har set på en streamingtjeneste, vil være oplysninger omfattet af art. 20. Derimod vil oplysninger, som den dataansvarlige selv analyser sig frem til ved hjælp af de personoplysninger, den registrerede har givet, ikke være omfattet. Dette kan f.eks. være en profilering, der angiver den registreredes købsinteresser.

Retten gælder endvidere kun, når den dataansvarliges behandling er baseret på et samtykke eller på en kontrakt og foretages automatisk. Sker behandlingen med hjemmel i et andet behandlingsgrundlag, gælder retten til dataportabilitet ikke. Denne begrænsning afspejler, at bestemmelsen har som et væsentligt formål at give den registrerede nem adgang til at skifte tjenesteudbydere, der normalt behandler oplysningerne med hjemmel i et samtykke eller for at opfylde en kontrakt.

Bestemmelsen giver den registrerede ret til at videretransmittere de modtagne oplysninger til en anden tjenesteudbyder uden hindringer. Det betyder bl.a., at den dataansvarlige ikke kan kræve et gebyr for, at oplysningerne videregives til en konkurrerende tjenesteudbyder.

Efter art. 20, stk. 2, kan den registrerede kræve, at den dataansvarlige selv transmitterer oplysningerne til en anden dataansvarlig (dvs. en anden tjenesteudbyder), hvis det er teknisk muligt. Hvis den overførende og den modtagende dataansvarlige ikke anvender systemer, som er teknisk kompatible, vil det ikke være teknisk muligt at overføre oplysningerne. Det fremgår udtrykkeligt af forordningens præambelbetragtning 68, at art. 20 ikke skaber en pligt for dataansvarlige til at indføre systemer, der er teknisk kompatible. Dataansvarlige kan således ikke tvinges til at anvende et bestemt format for at kunne overføre oplysninger mellem hinanden. Eksisterer der et anerkendt brancheformat, vil en manglende anvendelse af dette dog kunne være en overtrædelse af pligten til at anvende et "almindeligt anvendt" format efter art. 20, stk. 1.

Retten til dataportabilitet gælder efter art. 20, stk. 3, ikke for behandling, der er nødvendig for udførelse af en opgave i samfundets interesse, eller som henhører under offentlig myndighedsudøvelse. Man kan derfor normalt ikke bede om udlevering eller overførsel af oplysninger efter art. 20 fra offentlige myndigheder. Retten gælder efter art. 20, stk. 4, endvidere ikke, hvis den vil krænke andres rettighe-

Behandling baseret på samtykke eller kontrakt

Videretransmission uden hindringer

Den dataansvarliges pligt til videretransmission

Undtagelser

der eller frihedsrettigheder. Ofte vil de oplysninger, der omfattes af art. 20, også indeholde oplysninger om andre personer end den registrerede, f.eks. en liste over kontaktpersoner fra en mailtjeneste eller en kontooversigt fra en bank med angivelse af, hvem der har indbetalt penge til den registrerede. I disse tilfælde kan retten til dataportabilitet kun udøves, hvis det ikke vil krænke andre registreredes rettigheder. Det forudsætter, at overførslen af disse andres personoplysninger kan ske lovligt efter forordningen, f.eks. med hjemmel i interesseafvejningsreglen.

9. Ret til indsigelse

Registrerede har efter forordningens art. 21 i visse situationer en ret til at gøre indsigelse mod en behandling. Art. 21, stk. 1, har følgende ordlyd:

Den registrerede har til enhver tid ret til af grunde, der vedrører den pågældendes særlige situation, at gøre indsigelse mod behandling af sine personoplysninger baseret på artikel 6, stk. 1, litra e) eller f), herunder profilering baseret på disse bestemmelser. Den dataansvarlige må ikke længere behandle personoplysningerne, medmindre den dataansvarlige påviser vægtige legitime grunde til behandlingen, der går forud for registreredes interesser, rettigheder og frihedsrettigheder, eller behandlingen er nødvendig for, at retskrav kan fastlægges, gøres gældende eller forsvares.

Det følger af bestemmelsen, at den dataansvarlige på anmodning skal ophøre med behandlingen af oplysningerne, når dette tilsiges af den registreredes "særlige situation", medmindre den dataansvarlige har vægtige legitime grunde til behandlingen, der går forud for den registreredes interesser, eller behandlingen er nødvendig for at håndhæve et retskrav.

"Særlig situation"

Det er åbenbart, at en registeret altid kan gøre indsigelse mod en ulovlig behandling. Dette vil også gælde uden den særskilte indsigelsesret i art. 21. Det selvstændige anvendelsesområde for bestemmelsen er således de situationer, hvor den registrerede kan kræve ophør af en behandling, som ellers var lovlig efter forordningen.

Den registrerede kan ikke kræve en behandling bragt til ophør, blot fordi den registrerede helst vil være fri for, at behandlingen finder sted. I så fald ville det være muligt at hindre en lang række behandlinger der er nødvendige, for at myndigheder og virksomheder kan fungere, jf. også kap. 1.3 om hensynene, der tilsiger begrænsninger i persondatabeskyttelsen. Der skal derfor særlige grunde til, for at den dataansvarlige er forpligtet til at efterkomme en indsigelse, når behandlingen i øvrigt er lovlig, jf. ordene “den pågældendes særlige situation” i art. 21, stk. 1. Der kan dog være situationer, hvor det ud fra en samlet afvejning vil være rimeligt, at den registrerede kan anmode om, at behandlingen ophører, og derfor kan bruge indsigelsesretten efter art. 21.

I sin vejledning om registreredes rettigheder, s. 45, giver Datatilsynet som et eksempel herpå en situation, hvor en slægtsforsker har lagt et stort stamtræ ud på sin hjemmeside. Som udgangspunkt kan oplysninger om familiemedlemmerne offentliggøres med hjemmel i interesseafvejningsreglen. Et familiemedlem med et meget karakteristisk efternavn ønsker at blive fjernet fra stamtræet, da han arbejder i politiets bande-enhed, og da oplysninger om familiemæssige tilhørsforhold kan bruges af banderne til afpresning. Dette ønske skal imødekommes i henhold til indsigelsesretten.

Indsigelsesretten gælder kun for behandlinger, der er nødvendige af hensyn til udførelse af en opgave i samfundets interesse, eller som henhører under offentlig myndighedsudøvelse – art. 6, stk. 1, litra e – eller som har hjemmel i interesseafvejningsreglen – art. 6, stk. 1, litra f.

Kun behandlinger efter art. 6, stk. 1, litra e og f

Det følger af art. 21, stk. 2 og 3, at den registrerede altid kan gøre indsigelse mod en behandling, der sker med henblik på direkte markedsføring, herunder profilering, og at behandlingen herefter ikke længere må foretages med dette formål. I dette tilfælde er indsigelsesretten ikke begrænset til tilfælde, hvor der foreligger en “særlig situation” for den registrerede. Den registrerede kan således altid og ubetinget gøre indsigelse mod behandling med henblik på direkte markedsføring.

Direkte markedsføring

Efter forordningens art. 20, stk. 4, skal den dataansvarlige klart og adskilt fra andre oplysninger gøre den registrerede opmærksom på retten til at gøre indsigelse ved den første kommunikation mellem parterne.

Oplysningspligt

10. Ret til ikke at være genstand for automatiserede individuelle afgørelser

Forordningens art. 22 indeholder en bestemmelse, der giver den registrerede ret til ikke at være genstand for automatiserede individuelle afgørelser. Bestemmelsen er ikke ny, men fandtes også i persondatadirektivet og den tidligere persondatalov. I takt med udbredelsen af kunstig intelligens og algoritmebaseret afgørelsesvirksomhed har den imidlertid fået en større praktisk betydning og dermed også opmærksomhed. Formålet med bestemmelsen er at sætte grænser for, hvornår der kan træffes væsentlige afgørelser uden nogen form for menneskelig indblanding og dermed uden en menneskelig vurdering af afgørelsens rigtighed. Dette formål er strengt taget ikke et databeskyttelsesformål, selvom brugen af personoplysninger er en forudsætning for de automatiserede afgørelser. Bestemmelsen illustrerer imidlertid, at forordningen ikke kun er baseret på et ønske om at beskytte privatlivet, men også tager sigte på de dispositioner, der bliver udøvet med brug af personoplysninger, jf. også princippet om oplysningernes rigtighed i art. 5 og retten til berigtigelse i art. 16.

Udgangspunktet følger af art. 22, stk. 1:

Den registrerede har ret til ikke at være genstand for en afgørelse, der alene er baseret på automatisk behandling, herunder profilering, som har retsvirkning eller på tilsvarende vis betydeligt påvirker den pågældende.

Bestemmelsen gælder afgørelser, der “alene er baseret på automatisk behandling”. En behandling må generelt antages at være “automatisk”, når afgørelsen træffes uden nogen form for menneskelig involvering. Kravet om, at afgørelsen “alene” skal være baseret på automatisk behandling, indebærer, at en afgørelse, der foretages i et samspil mellem menneskelig involvering og et automatiseret afgørelsessystem ikke omfattes af bestemmelsen. Det vil f.eks. gælde, hvis et automatiseret afgørelsessystem fremkommer med et forslag til afgørelse, som vurderes af en sagsbehandler, inden den endelige afgørelse træffes.

Bestemmelsen omfatter afgørelser, der er baseret på profilering. Profilering er i art. 4, nr. 4, defineret som “enhver form for automatisk behandling af personoplysninger, der består i at anvende personop-

Art. 22, stk. 1 –
forbud mod visse
former for
automatiserede
afgørelser

– alene baseret på
automatisk
behandling

– profilering

lysninger til at evaluere bestemte personlige forhold vedrørende en fysisk person, navnlig for at analysere eller forudsige forhold vedrørende den fysiske persons arbejdsindsats, økonomiske situation, helbred, personlige præferencer, interesser, pålidelighed, adfærd, geografisk position eller bevægelser”. Det er dog ikke et krav, at der foreligger profilering, for at bestemmelsen finder anvendelse, jf. ordet “herunder”.

Bestemmelsen gælder kun afgørelser, der har “retsvirkning” eller på tilsvarende vis “betydeligt påvirker den registrerede”. En afgørelse vil eksempelvis have retsvirkning, hvis den indebærer opsigelse af en kontrakt eller afviser et krav under en kontrakt (f.eks. et forsikringselskabs afvisning af et krav på erstatning til en forsikringstager) eller afviser ret til en social ydelse. En afgørelse om, at den dataansvarlige ikke vil indgå en kontrakt med den registrerede, f.eks. en aftale om forsikring eller ansættelse, vil ikke være en afgørelse, der har retsvirkning, eftersom den registrerede ikke har retskrav på at indgå aftalen. En sådan afgørelse kan dog være en afgørelse, der “betydeligt påvirker den registrerede” og dermed også omfattes af bestemmelsen. Forordningens præambelbetragtning 71 anfører således et automatisk afslag på en onlineansøgning om kredit eller afslag i forbindelse med en e-rekrutteringsprocedure som eksempler på afgørelser, der betydeligt kan påvirke den registrerede. I betænkning 1565/2017, s. 377, nævnes som eksempel, at et forsikringselskab automatisk giver en 18-årig mand afslag på at tegne en bilforsikring.

– retsvirkning eller anden betydelig påvirkning af den registrerede

I forordningens præambelbetragtning 71 angives, at automatiserede afgørelser efter art. 22 ikke bør omfatte børn. Denne betragtning er dog ikke anført i selve bestemmelsen, og art. 22 indeholder derfor ikke et egentligt forbud mod at træffe automatiserede afgørelser over for børn. Betragtning 71 må dog indebære, at der skal udvises stor tilbageholdenhed med dette, og at det vil skulle tillægges vægt ved fortolkningen af bestemmelsen, herunder hvornår en afgørelse “betydeligt” vil påvirke den registrerede, hvis denne er et barn.

– børn

Det er uklart, om art. 22 forudsætter en evaluering af den registreredes personlige forhold. Et sådant krav kan ikke udledes af bestemmelsens ordlyd. Tværtimod følger det udtrykkeligt af ordlyden, at det ikke er et krav, at der foretages profilering, for at art. 22 finder anvendelse. Og som det følger af den ovenfor angivne definition af “profilering”, er denne netop kendetegnet ved, at der sker en evaluering af

– krav om evaluering af den registreredes personlige forhold?

personlige forhold. Omvendt indledes forordningens præambelbetragtning 71 med følgende ord: “Den registrerede bør have ret til ikke at blive gjort til genstand for en afgørelse, der kan omfatte en foranstaltning, *som evaluerer personlige forhold vedrørende vedkommende*, og som alene bygger på automatisk behandling [...]” (fremhævet her). Dette indikerer, at det er evalueringen af personlige forhold, som omfattes af art. 22. I betænkning 1565/2017, s. 377, lægges til grund, at art. 22 kun finder anvendelse, hvis der sker evaluering af personlige forhold: “Det er vigtigt at holde sig for øje, at den behandling, som omtales i artikel 22, er den automatiske behandling, hvor netop personlige forhold evalueres. Der vil således ikke være tale om en afgørelse i artikel 22’s forstand, såfremt den afgørelse, der træffes, sker ved en rent matematisk udregning ud fra de givne faktuelle forudsætninger, uden at der dermed sker en evaluering af personlige forhold vedrørende vedkommende. Den omstændighed, at en person f.eks. ikke kan hæve et beløb i en pengeautomat, fordi der ikke er dækning for beløbet, falder eksempelvis uden for bestemmelsen”. I sin vejledning om registreredes rettigheder anfører Datatilsynet tilsvarende, s. 48: “At afgørelsen skal lægge vægt på en evaluering af personlige forhold betyder omvendt, at et system, der udelukkende evaluerer “hårde” værdier – som det indestående beløb på en bankkonto – og dermed ikke “bløde” værdier – som en persons interesser – ikke vil være omfattet af rettigheden”. Med støtte i præambelbetragtning 71 kan det ikke udelukkes, at visse aktiviteter ikke omfattes af art. 22, fordi de helt mangler et element af personlig evaluering. Spørgsmålet må dog anses for uafklaret.

I Art. 29-gruppens vejledning om art. 22 (WP 251 rev.01) er spørgsmålet uomtalt.

Det er uklart, om art. 22, stk. 1, opstiller et egentligt forbud mod de pågældende former for automatiserede afgørelse, eller om bestemmelsen giver den registrerede ret til at gøre indsigelse mod denne form for afgørelsesvirksomhed. Eller med andre ord, om bestemmelsen er proaktiv eller reaktiv. Er der tale om et forbud, betyder det, at det vil være ulovligt at påbegynde den automatiserede afgørelsesvirksomhed, og den dataansvarlige må selv vurdere, om en behandling er omfattet af forbuddet. Er der tale om en indsigelsesret, betyder det, at den data-

– forbud eller indsigelsesret (proaktiv eller reaktiv bestemmelse)?

ansvarlige lovligt kan træffe automatiserede afgørelser over for den registrerede, indtil denne gør indsigelse herimod. I art. 29-gruppens WP 251 rev.01, angives s. 19 f., at bestemmelsen har karakter af en forbudsbestemmelse og henviser bl.a. til ordlyden af præambelbetragtning 71, hvorefter automatiserede afgørelser “bør være tilladt”, når en af undtagelserne i art. 22, stk. 2, (omtalt nedenfor) finder anvendelse. Dette støtter, at den automatiserede behandling efter art. 22, stk. 1, ikke generelt er tilladt. Fortolkningen støttes også af, at en af undtagelserne efter art. 22, stk. 2, er den registreredes udtrykkelige samtykke. Hvis den automatiserede afgørelsesvirksomhed kunne udøves, indtil den registrerede gør indsigelse, var der næppe behov for en undtagelse i tilfælde af den registreredes samtykke. På den baggrund må det lægges til grund, at art. 22 har karakter af en forbudsbestemmelse.

I betænkning 1565/2017, s. 375, lægges til grund, at art. 22 har karakter af en bestemmelse om indsigelsesret.

Forbuddet i stk. 1 er undergivet tre undtagelser i stk. 2:

Art. 22, stk. 2 –
undtagelser

Stk. 2. Stk. 1 finder ikke anvendelse, hvis afgørelsen:

- a) er nødvendig for indgåelse eller opfyldelse af en kontrakt mellem den registrerede og en dataansvarlig
- b) er hjemlet i EU-ret eller medlemsstaternes nationale ret, som den dataansvarlige er underlagt, og som også fastsætter passende foranstaltninger til beskyttelse af den registreredes rettigheder og frihedsrettigheder samt legitime interesser eller
- c) er baseret på den registreredes udtrykkelige samtykke.

Automatiserede afgørelser kan i praksis være nødvendige at bruge for den dataansvarlige, når en menneskelig (manuel) behandling ville blive uforholdsmæssigt tidskrævende, f.eks. som følge af det samlede omfang af afgørelsesvirksomheden. Modtager en dataansvarlig eksempelvis et meget stort antal jobansøgninger til en stilling, kan det være nødvendigt at foretage en første automatisk sortering på baggrund af udvalgte kriterier (karaktergennemsnit, sprogkundskaber mv.). Det vil bero på en konkret vurdering, om ressourceforbruget ved en manuel behandling har et sådant omfang, at undtagelsen finder anvendelse. Det følger af art. 22, stk. 3, at den dataansvarlige skal indføre passende

– nødvendigt for
at indgå eller
opfylde en
kontrakt

foranstaltninger til at beskytte den registreredes rettigheder og frihedsrettigheder og legitime interesser, når der træffes automatiserede afgørelser efter stk. 2. Det skal som minimum give den registrerede ret til menneskelig indgriben fra den dataansvarliges side og retten til at bestride afgørelsen.

Forbuddet mod automatiserede afgørelser gælder endvidere ikke, når EU-retten eller national ret giver hjemmel til at træffe en sådan afgørelse. Det antages i betænkning 1565/2017, s. 380, at det ikke behøver fremgå udtrykkeligt af den nationale regel, at afgørelsen kan træffes automatisk. Det er således tilstrækkeligt, at det i øvrigt af national ret følger, at en afgørelse kan træffes automatisk. Det følger dog af stk. 2, litra b, at den nationale lovgivning skal fastsætte passende foranstaltninger til beskyttelse af den registreredes rettigheder og frihedsrettigheder og legitime interesser. Det kan f.eks. indebære en forpligtelse til at kunne bestride afgørelsen og få den prøvet manuelt.

Den dataansvarlige kan yderligere træffe automatiserede afgørelser omfattet af stk. 1, hvis den registrerede har givet sit udtrykkelige samtykke til det. Om begreberne "samtykke" og "udtrykkelig", se ovenfor kap. 5.2 og 5.6.2.1. Den dataansvarlige skal i denne situation indføre passende beskyttelsesforanstaltninger som f.eks. ret til at protestere mod afgørelsen og til menneskelig indgriben, jf. art. 22, stk. 3.

Endelig gælder forbuddet mod automatiserede afgørelser ikke, når behandlingen udelukkende sker i videnskabeligt eller statistisk øje-med, jf. DBL § 22, stk. 5.

Afgørelser truffet med hjemmel i art. 22, stk. 2, må kun være baseret på følsomme oplysninger, hvis den registrerede har givet udtrykkeligt samtykke hertil, eller behandlingen er nødvendig af hensyn til væsentlige samfundsinteresser på grundlag af EU-retten eller national ret. Dette betyder bl.a., at der ikke kan træffes en automatiseret afgørelse på grundlag af følsomme oplysninger, når afgørelsen er nødvendig for indgåelse eller opfyldelse af en kontrakt, som den registrerede er part i (art. 22, stk. 2, litra a). En arbejdsgiver, der modtager mange jobansøgninger, kan således ikke foretage en første automatiseret udvælgelse af ansøgere på baggrund af sundhedsoplysninger.

Det følger af bestemmelserne om oplysningspligt og om indsigtsret, at den dataansvarlige eksplicit skal oplyse den registrerede om en eventuel brug af automatiserede afgørelser, jf. art. 13, stk. 3, litra f, art. 14,

– hjemmel i national ret – offentlige myndigheder

– udtrykkeligt samtykke

– Videnskabeligt eller statistisk øje-med

Følsomme oplysninger

Informationspligt

stk. 2, litra g, og art. 15, stk. 1, litra h. Som led heri skal den dataansvarlige som minimum oplyse om den anvendte logik og betydningen og de forventede konsekvenser for den registrerede. Disse krav udtrykker et ønske om at skabe transparens og give den registrerede en reel mulighed for at få indsigt i grundlaget for afgørelsen og konsekvenserne af den. Det er et anerkendelsesværdigt formål i lyset af en udvikling, hvor det kan blive stadigt sværere at gennemskue, hvordan beslutninger træffes i en algoritmebaseret digital tidsalder. Det må dog også erkendes, at det i praksis kan blive vanskeligt at oplyse den registrerede på en måde, der skabe en reel indsigt for den pågældende.

Kapitel 7

Behandlingssikkerhed

Det er et væsentligt element i beskyttelsen af de registreredes personoplysninger, at dataansvarlige og databehandlere etablerer beskyttelsesforanstaltninger, der sikrer mod, at oplysningerne kompromitteres og således kommer til uvedkommendes kendskab. Den beskyttelse, som forordningen skal give de registrerede bliver illusorisk, hvis dataansvarlige og databehandlere overholder alle de grundlæggende behandlingsprincipper, sørger for at have det fornødne behandlingsgrundlag og iagttager de registreredes rettigheder til indsigt, indsigelse mv., men omvendt ikke beskytter oplysningerne mod tredjeparters uautoriseret og efterfølgende ulovlige behandling. Forordningen indeholder derfor i art. 32 en bestemmelse, som forpligter dataansvarlige og databehandlere til at beskytte de behandlede personoplysninger gennem tekniske og organisatoriske sikkerhedsforanstaltninger.

I tilknytning til bestemmelsen i art. 32 indeholder forordningen i art. 33 og 34 to bestemmelser, der forpligter den dataansvarlige til at orientere tilsynsmyndigheden og eventuelt de registrerede om sikkerhedsbrud. Mens art. 32, med en række justeringer, er en videreførelse fra det tidligere persondatadirektiv er pligten til at underrette om sikkerhedsbrud nyskabelser i forordningen.

1. Behandlingssikkerhed (krav om sikkerhedsforanstaltninger) – art. 32

1.1. Indledning

Forordningen indeholder i art. 32 en bestemmelse om behandlingssikkerhed, som har stor praktisk betydning. Bestemmelsens stk. 1 har følgende ordlyd:

Under hensyntagen til det aktuelle tekniske niveau, implementeringsomkostningerne og den pågældende behandlings karakter, omfang, sammenhæng og formål samt risiciene af varierende sandsynlighed og alvor for fysiske personers rettigheder og frihedsrettigheder gennemfører den dataansvarlige og databehandleren passende tekniske og organisatoriske foranstaltninger for at sikre et sikkerhedsniveau, der passer til disse risici, herunder bl.a. alt efter hvad der er relevant:

- a) pseudonymisering og kryptering af personoplysninger
- b) evne til at sikre vedvarende fortrolighed, integritet, tilgængelighed og robusthed af behandlingssystemer og -tjenester
- c) evne til rettidigt at genoprette tilgængeligheden af og adgangen til personoplysninger i tilfælde af en fysisk eller teknisk hændelse
- d) en procedure for regelmæssig afprøvning, vurdering og evaluering af effektiviteten af de tekniske og organisatoriske foranstaltninger til sikring af behandlingssikkerhed.

Bestemmelsen pålægger den dataansvarlige, og også en eventuel databehandler, at etablere sikkerhedsforanstaltninger til imødegåelse af identificerede risici.

Krav om sikkerhedsforanstaltninger

Informationssikkerhedsvurderinger vil normalt tage udgangspunkt i de tre parametre fortrolighed, integritet og tilgængelighed. Fortrolighed indebærer sikkerhed for, at informationen ikke kommer til uvedkommendes kendskab. Integritet indebærer sikkerhed for, at informationen ikke uautoriseret ændres eller tilintetgøres. Tilgængelighed indebærer sikkerhed for, at informationen er tilgængelig for de personer, der har retmæssig adgang til den. Er der ikke sikkerhed for personoplysningernes fortrolighed, tilgængelighed og integritet, kan det potentielt skade de registrerede.

Fortrolighed, integritet og tilgængelighed

Sikkerhedsforanstaltningerne efter art. 32 skal navnlig beskytte de behandlede personoplysninger mod tab af fortrolighed, integritet og tilgængelighed.

Sikkerhed er ikke et absolut begreb, og spørgsmålet er derfor ikke "om" der skal etableres sikkerhed, men "hvor meget" sikkerhed, der skal etableres. Heri ligger på den ene side, at sikkerheden altid kan øges gennem yderligere sikkerhedsforanstaltninger, men på den anden side også, at de ressourcer, der er forbundet med at øge sikkerheden ikke altid står mål med effekten. Dette afspejles i de krav til sikkerhedsforanstaltninger, som pålægges den dataansvarlige. Det følger således af art. 32, stk. 1, at den dataansvarlige skal gennemføre "passende" sikkerhedsforanstaltninger. Ved vurderingen af, hvad der udgør passende foranstaltninger, skal der tages udgangspunkt i risikoen for de registrerede. Art. 32 forudsætter hermed, at den dataansvarlige skal foretage en risikovurdering, hvilket også udtrykkes således, at bestemmelsen, i lighed med en række andre af forordningens bestemmelser, anvender en risikobaseret tilgang.

Se også mere generelt om den risikobaserede tilgang, art. 29-gruppens WP 218, Statement on the role of a risk-based approach in data protection legal frameworks.

1.2. Risikovurderingen

Det følger af art. 32, at der både skal lægges vægt på "sandsynlighed" og "alvor", når risikoen vurderes. Hermed sigtes til de klassiske parametre, når der foretages risikovurderinger: Hvad er sandsynligheden for, at begivenheden indtræder, og hvilken konsekvens vil det have? Er sandsynligheden lav og konsekvenserne begrænsede, er risikoen lav. Er sandsynligheden høj og konsekvenserne omfattende, er risikoen høj.

1.2.1. Sandsynlighedsvurderingen

Det første skridt i risikovurderingen er derfor at fastlægge sandsynligheden for et tab af fortrolighed, integritet eller tilgængelighed af de behandlede personoplysninger. Ved vurderingen heraf kan den dataansvarlige bl.a. inddrage tidligere erfaringer. Sker det eksempelvis hyppigt, at medarbejdere får sendt mails med personoplysninger til

forkerte adressater (hvilket er den største enkeltstående årsag til de risikobrud, der anmeldes til Datatilsynet), må det i risikovurderingen lægges til grund, at dette med stor sandsynlighed også vil finde sted for den planlagte behandlingsaktivitet (indtil der etableres sikkerhedsforanstaltninger til at imødegå denne risiko). Den dataansvarlige kan også inddrage generelle trusselsvurderinger fra relevante myndigheder og private aktører, statistikker for forskellige typer af trusler mv.

1.2.2. Konsekvensvurderingen

Det andet skridt i risikovurderingen er at fastlægge de potentielle konsekvenser ved den vurderede begivenhed. Det følger af art. 32, at risikovurderingen skal tage udgangspunkt i "risikoen for fysiske personers rettigheder og frihedsrettigheder". Det er således konsekvenserne for *de registrerede* ved et tab af behandlingssikkerhed, der skal vurderes, ikke risikoen for de dataansvarlige.

"Fysiske personers
rettigheder og
frihedsrettigheder"

Hermed adskiller risikovurderingerne i databeskyttelsesretten sig fra de klassiske vurderinger af risikoen for brud på informationssikkerhed, hvor det er risikoen for organisationen, der vurderes. I sidstnævnte type af risikovurderinger vil man eksempelvis lægge vægt på de økonomiske tab for virksomheden ved et brud på informationssikkerheden. Sådanne konsekvenser skal ikke inddrages i den databeskyttelsesretlige risikovurdering.

Når man læser art. 32 er det ikke helt klart, hvad det er en for en risiko for de registrerede, der skal inddrages i risikovurderingen.

Bestemmelsen fastslår, at de passende sikkerhedsforanstaltninger skal fastsættes under hensyntagen til "den pågældende behandlings karakter, omfang, sammenhæng og formål samt risiciene af varierende sandsynlighed og alvor for fysiske personers rettigheder og frihedsrettigheder". Ordlyden af bestemmelsen giver det indtryk, at behandlingens karakter, omfang, sammenhæng og formål på den ene side og risiciene for fysiske personers rettigheder og frihedsrettigheder på den anden side er to separate elementer, der skal vurderes hver for sig. I realiteten må det dog antages, at der er tale om en samlet vurdering, hvor man skal vurdere risikoen for den registrerede *under hensyntagen* til behandlingens karakter, omfang, sammenhæng og formål. Af præambelbetragtning 76 fremgår således: "Risikoens sandsynlighed og

alvor for så vidt angår den registreredes rettigheder og frihedsrettigheder bør bestemmes *med henvisning til* behandlingens karakter, omfang, sammenhæng og formål”, ligesom betragtning 89 omtaler behandlinger, der sandsynligvis vil indebære en høj risiko for fysiske personers rettigheder og frihedsrettigheder *i medfør af* deres karakter, omfang, sammenhæng og formål” (fremhævet her).

Det er med andre ord risikoen for fysiske personers rettigheder og frihedsrettigheder, som skal vurderes. Sprogligt giver det ikke så god mening at tale om en “risiko for en rettighed” men meningen er givetvis, at der skal foretages en vurdering af risikoen for, at der sker en *krænkelse* af de registreredes rettigheder. Begrebet “fysiske personers rettigheder og frihedsrettigheder” anvendes adskillige steder i forordningen uden dog nogen steder at være defineret. Begrebet sigter til de grundlæggende rettigheder, herunder særligt men ikke udelukkende til beskyttelsen af personoplysninger, som den er kommet til udtryk i charterets art. 8 og nærmere udtrykt i forordningen.

Ved at fokusere på en krænkelse af rettigheder, synes konsekvensvurderingen i højere grad af være en overordnet og retlig vurdering end at være en mere konkret og faktisk vurdering af den potentielle skadevirkning for den registrerede. Den konkrete skadevirkning er dog central i vurderingen af, hvilke risici behandlingen påfører den registrerede, og det må derfor også lægges til grund, at skadevirkningen skal inddrages i konsekvensvurderingen og formentlig er et centralt element i denne vurdering. Dette har også støtte i præambelbetragtningerne. I betragtning 74, sidste punktum, anføres, at foranstaltningerne, der skal sikre behandlingens lovlighed, bør tage højde for behandlingens karakter, omfang, sammenhæng og formål og risikoen for fysiske personers rettigheder og frihedsrettigheder. Herefter fortsætter betragtning 75 med at fastslå, at “[R]isiciene for fysiske personers rettigheder og frihedsrettigheder, af varierende sandsynlighed og alvor, kan opstå som følge af behandling af personoplysninger, der kan føre til fysisk, materiel eller immateriel skade, navnlig hvis behandlingen kan give anledning til forskelsbehandling, identitetstyveri eller -svig, finansielle tab, skade på omdømme, tab af fortrolighed for personoplysninger, der er omfattet af tavshedspligt, uautoriseret ophævelse af pseudonymisering eller andre betydelige økonomiske eller sociale konsekvenser”. Forordningen lægger således entydigt til grund, at skade-

Den konkrete
skadevirkning

virksomheden skal inddrages i risikovurderingen. I overensstemmelse hermed har Datatilsynet i sin praksis lagt vægt på den potentielle konkrete skadevirkning for den registrerede.

Se eksempelvis sag [2019-441-3399](#), hvor Datatilsynet udtalte alvorlig kritik af, at BroBizz A/S ikke havde foretaget en tilstrækkelig risikovurdering efter art. 32. Datatilsynet nævnte som mulige risici (der ikke var identificeret af den dataansvarlige) identitetstyveri, chikane og stalking.

De potentielle konkrete skader for den registrerede forårsaget af manglende behandlingssikkerhed kan antage forskellige karakter. Overordnet kan behandlingen føre til fysisk skade, økonomisk skade eller ideel skade (hvilket formentlig svarer til sondringen mellem fysisk, materiel og immateriel skade i præambelbetragtning 75 – se også om sondringen mellem materiel og immateriel skade kap. 11.2 nedenfor under gennemgangen af erstatningsbestemmelsen i art. 82, hvor sondringen også anvendes). Alle disse typer af skader kan forvoldes ved de forskellige former for brud på behandlingssikkerheden – tab af fortrolighed, integritet og tilgængelighed.

Det er sjældent, at behandling af personoplysninger fører til fysiske skader. Et eksempel herpå vil være fejlagtig videregivelse af en hemmelig adresse (tab af fortrolighed) til en voldelig eksmand, der overfalder ekskonen eller ødelægger genstande i hendes hjem.

– fysiske skader

Fysiske skader vil ofte også medføre økonomiske skader, f.eks. i form af tabt arbejdsfortjeneste eller omkostninger til reparation eller genanskaffelse af genstande. Økonomisk skade behøver dog ikke være knyttet til fysisk skade, og der vil eksempelvis foreligge en økonomisk skade, hvis personoplysninger anvendes til at skaffe sig adgang til den registreredes bankkonti (tab af fortrolighed) og trække penge fra disse. Et andet eksempel er brug af ukorrekte personoplysninger (tab af integritet), der fører til en forkert sagsbehandling med økonomiske konsekvenser for den registrerede, f.eks. afslag på låneansøgning, jobansøgning eller ansøgning om offentligt tilskud. Tilsvarende konsekvenser kan være forårsager af manglende adgang til oplysninger (tab af tilgængelighed).

– økonomiske skader

Ideelle skader vil nok være den mest udbredte skadetype og kan opfattes som et residualbegreb, der dækker alle former for negative påvirkning af den registrerede, som ikke har fysisk eller økonomisk ka-

– ideelle skader

rakter. Hermed bliver det potentielt et meget bredt begreb, der navnlig kan dække over den registreredes psykiske ubehag, bekymringer mv. forårsaget af den manglende behandlingssikkerhed og det heraf følgende potentielle misbrug af personoplysningerne. Det psykiske ubehag kan igen antage mange former, som f.eks. bekymring for misbrug i forbindelse med et identitetstyveri eller stigmatisering på en arbejdsplads eller i en anden social gruppe ved kompromittering af oplysninger (i begge tilfælde tab af fortrolighed).

Selvom den potentielle konkrete skadevirkning således må tillægges betydelig vægt ved konsekvensvurderingen, synes forordningen at forudsætte, at der også skal lægges vægt på, hvor intensivt et indgreb i de registreredes rettigheder et tab af behandlingssikkerhed vil være i bredere forstand. Dette synes som nævnt allerede at følge af, at risikovurderingen skal tage udgangspunkt i en eventuel krænkelse af de registreredes grundlæggende rettigheder til databeskyttelse. Det understøttes også af, at der efter bestemmelsens ordlyd skal lægges vægt på behandlingens karakter, omfang og sammenhæng, som er mere generelle kriterier, der ikke nødvendigvis vil føre til en konkret skade for den registrerede. Endvidere opregner den nævnte betragtning 75 ikke kun eksempler på risici for de registreredes rettigheder, der har karakter af konkrete skader, men bl.a. også generelle former for "skader", som f.eks. at de registrerede berøves deres rettigheder eller frihedsrettigheder, at der sker behandling af følsomme oplysninger eller oplysninger om sårbare personer eller foretages profilering.

Rettighedskrænkel
se i bredere
forstand (den
abstrakte
skadevirkning)

Der er en række typer af behandlinger og behandlingsaktiviteter, der sædvanligvis opfattes som særligt indgribende for de registrerede. Dette omfatter bl.a. de forhold, der er angivet i art. 75 (behandling af oplysninger om børn og andre sårbare personer, følsomme oplysninger, oplysninger om mange registrerede, profilering mv.). Et bidrag til, hvad der udgør særligt indgribende typer af behandlinger og behandlingsaktiviteter foreligger også med afgrænsningen af de situationer, hvor der skal foretages en konsekvensanalyse efter art. 35, når behandlingen indebærer en høj risiko for de registrerede, jf. nærmere herom kap. 8.4 nedenfor. I den generelle konsekvensvurdering må det indgå med vægt, om behandlingssituationen omfatter denne typer af aktiviteter.

Når en behandling indebærer en særligt indgribende rettighedskrænkelse, vil den som regel også være mere egnet til at påføre den registrerede en egentlig skade af fysisk, økonomisk eller ideel karakter. Der er med andre ord en sammenhæng (men ikke nødvendigvis et sammenfald) mellem rettighedskrænkelsens karakter og sandsynligheden for, at den påfører den registrerede en konkret skade. Rettighedskrænkelsen kan derfor også betegnes som den *abstrakte skadevirkning*.

Sammenfattende må det lægges til grund, at både behandlingens potentielle konkrete skadevirkning og dens indgreb i de registreredes rettigheder i bredere forstand (den abstrakte skadevirkning) skal indtages i konsekvensvurderingen.

Når det lægges til grund, at konsekvensvurderingen både skal indtage den potentielle konkrete skadevirkning og dens indgreb i de registreredes rettigheder i bredere forstand (den abstrakte skadevirkning), rejser det spørgsmålet om samspillet mellem disse to forskellige måder at opgøre konsekvenserne på. Selvom der som anført vil være et overlap mellem de to typer af skadevirkning, vil de ikke altid føre til samme konsekvensvurdering. Omhandler tabet af behandlingssikkerhed eksempelvis oplysninger om børn, vil det veje tungt i den generelle vurdering, selvom tabet ikke nødvendigvis indebærer nogen væsentlig konkret skadevirkning.

Forholdet mellem den konkrete og den abstrakte skadevirkning

Forordningen indeholder ingen angivelse af, hvordan den konkrete og den abstrakte skadevirkning skal vægtes overfor hinanden, når de leder konsekvensvurderingen i hver sin retning. En mulighed er at indtage begge typer af skadevirkning i den samlede vurdering, således, at konsekvensen vurderes højere, når begge typer skadevirkning fører til en høj risiko, end når de peger i hver sin retning. En anden mulighed er at vægte den type skadevirkning, der giver den højeste risiko under henvisning til, at forordningen skal yde de registrerede en høj grad af beskyttelse. En tredje mulighed er, at den ene af de to typer af skadevirkning altid skal vægtes højest. Den sidstnævnte mulighed må formentlig afvises, da den vil indebære, at det i praksis altid vil være den ene type af skadevirkning, der bliver afgørende, mens den anden ikke får betydning. Dette vil harmonerer dårligt med, at forordningen synes at forudsætte, at begge typer af skadevirkning er relevante og skal inddrages. Hvis konsekvensvurderingen viser, at et tab af behandlingssikkerhed potentielt kan påføre den registrerede alvorlige konkrete

te skadevirkninger, f.eks. i form af fysisk personskade eller omfattende økonomiske tab, bør konsekvensscoren være høj, uanset om den abstrakte skadevirkning ikke giver en høj konsekvensscore. Er situationen den omvendte, forekommer svaret mindre sikkert. På den ene side tilsiger hensynet til beskyttelsen af de registrerede, at konsekvensscoren også i denne situation sættes til høj. Dette harmonerer også med art. 35, hvorefter risikoen for de registreredes rettigheder kan være høj alene baseret på kriterier, der afgør den abstrakt skadevirkning (profilering baseret på automatisk behandling, behandling af et stort antal følsomme oplysninger mv.). På den anden side forudsætter art. 32 en konkret risikovurdering, og i den situation er det ikke nærliggende at se bort fra den konkrete skadevirkning og alene baserer risikovurderingen på abstrakte kriterier, hvis disse i realiteten tegner et forkert billede af den konkrete skadevirkning. Registreringen af medlemmer i en fagforenings medlemsdatabase vil eksempelvis udgøre en behandling, der indebærer en høj risiko for de registreredes rettigheder efter art. 35, stk. 3, litra b, da der behandles et stort antal følsomme oplysninger. Den potentielle konkrete skadevirkning vil imidlertid i de fleste tilfælde være meget begrænset ved et tab af tilgængeligheden af oplysningerne i medlemsdatabase, og muligvis også selvom der sker en kompromittering (tab af fortrolighed) af databasen. En konkret risikovurdering som den, der skal foretages efter art. 32, bør næppe se helt bort fra den konkrete skadevirkning, og i den situation, hvor den abstrakte skadevirkning giver en højere konsekvensscore end den konkrete skadevirkning, bør begge typer af skadevirkning derfor indgå i konsekvensvurderingen. Hermed bliver vægtningen af de to typer skadevirkninger i realiteten en hybrid mellem de ovenfor anførte mulighed 1 og 2, eftersom der alene skal lægges vægt på den konkrete skadevirkning, når den giver den højeste konsekvensscore, mens der i øvrigt skal lægges vægt på begge typer af skadevirkning.

1.3. Valg af sikkerhedsforanstaltninger

Når den dataansvarlige har identificeret de aktuelle risici, dvs. sandsynligheden for tab af behandlingssikkerhed og de potentielle konsekvenser for den registrerede, skal den dataansvarlige vurdere og vælge, hvilke foranstaltninger, som skal etableres for at imødegå disse risici.

Valget af foranstaltninger skal afspejle de identificerede risici. Jo højere disse risici er, jo større krav stilles til foranstaltningerne.

Den identificerede risiko

Udover omfanget af risici, skal den dataansvarlige efter art. 32, stk. 1, tage hensyn til det aktuelle sikkerhedsniveau og implementeringsomkostningerne ved fastlæggelsen af foranstaltningerne.

Henvisningen til det aktuelle sikkerhedsniveau indebærer, at det i højere grad kan forventes, at den dataansvarlige anvender tekniske sikkerhedsløsninger (navnlig i form af software), der er udbredte og anerkendte, end nye og avancerede løsninger, som endnu ikke er udbredte på markedet men omvendt også, at den dataansvarlige ikke anvender forældet teknologi, der ikke yder den beskyttelse, som kan forventes af dagens standarder. I sidstnævnte ligger også, at den dataansvarlige løbende skal inddrage den teknologiske udvikling i sin vurdering.

Det aktuelle sikkerhedsniveau

Henvisningen til implementeringsomkostningerne betyder, at den dataansvarlige kan inddrage udgifterne til de eventuelle foranstaltninger. Det betyder selvsagt ikke, at den dataansvarlige kan undlade at reducere risici, blot fordi det er forbundet med udgifter, men hvis udgifterne til en foranstaltning langt overstiger de sikkerhedsmæssige gevinster (en dyr foranstaltning, der kun vil indebære en ubetydelig reduktion af risikoen), kan den dataansvarlige undlade at iværksætte foranstaltningen. Den dataansvarlige må da overveje andre mulige foranstaltninger, som måske ikke tilvejebringer samme sikkerhed, men hvor sikkerheden og omkostningerne står i et rimeligt forhold.

Implementeringsomkostninger

Art. 32 indeholder i stk. 1, litra a-d, fire eksempler på foranstaltninger, der kan anvendes af den dataansvarlige. Udover foranstaltningen i litra a, pseudonymisering og kryptering, er der dog tale om meget generiske angivelser mere end konkrete foranstaltninger. Litra b angiver således som en mulig foranstaltning evnen til at sikre vedvarende fortrolighed, integritet, tilgængelighed og robusthed af behandlingssystemer og -tjenester, mens litra c angiver evnen til rettidigt at genoprette tilgængeligheden af og adgangen til personoplysninger i tilfælde af fysiske eller tekniske hændelser. Litra d angiver en procedure for regelmæssig afprøvning, vurdering og evaluering af effektiviteten af de tekniske og organisatoriske foranstaltninger til sikring af behandlingssikkerhed, hvilket i realiteten er en anden måde at skrive på, at risikovurderingen og vurderingen af passende foranstaltninger skal foretages løbende.

Foranstaltninger i art. 32, stk. 1, litra a-d

Det følger af art. 32, stk. 1, at foranstaltningerne både kan være “tekniske” og “organisatoriske”.

“Tekniske og organisatoriske sikkerhedsforanstaltninger”

Tekniske foranstaltninger omfatter it-sikkerhedsforanstaltninger som f.eks. brug af adgangskoder, firewalls, kryptering mv. Den omstændighed at art. 32, stk. 1, litra a, eksplicit nævner pseudonymisering og kryptering kan gøre det nærliggende at anvende disse foranstaltninger, når det er relevant, men et egentligt krav herom følger ikke af bestemmelsen. Også fysiske foranstaltninger kan have karakter af tekniske foranstaltninger. Dette kan f.eks. omfatte fysisk aflåsning af skabe med manuelle (papirbaserede) registre og aflåsning og anden form for indbrudssikring eller adgangskontrol til fysiske lokaler, hvor der opbevares personoplysninger.

Organisatoriske foranstaltninger kan være uddannelse af personale og udarbejdelse af processer i organisationen, der fastlægger nærmere retningslinjer og procedurer for behandling af personoplysninger. Det kan eksempelvis være retningslinjer, der fastlægger, at kun bestemte medarbejdere eller grupper af medarbejdere kan få adgang til bestemte typer af personoplysninger.

I sidste ende vil det bero på en samlet og konkret vurdering, om de anvendte foranstaltninger etablerer et sikkerhedsniveau, der passer til de identificerede risici, hvor der altså som nævnt skal lægges vægt på sandsynlighed og konsekvenser, mulige foranstaltninger og omkostningerne herved. Hermed anlægger art. 32 som nævnt, i lighed med en række andre af forordningens bestemmelser, hvad der ofte benævnes en risikobaseret tilgang. Dette indebærer accept af en vis (rest)risiko, selv efter der er iværksat sikkerhedsforanstaltninger.

Den samlede vurdering - risikobaseret tilgang

1.4. Krav om løbende vurdering

Som allerede anført angiver art. 32, stk. 1, litra d, som en potentiel foranstaltning en procedure for “regelmæssig” afprøvning, vurdering og evaluering af effektiviteten af de valgte foranstaltninger. Selvom bestemmelsen ikke er formuleret som et egentligt krav om løbende at foretage risikovurdering og om nødvendigt justere de valgte foranstaltninger, er det klart, at denne intention ligger i art. 32 og særligt i stk. 1, litra d, og at den dataansvarlige derfor er forpligtet til med mellemrum at foretage en revurdering af risici og foranstaltninger. Hvornår og

hvor ofte dette skal ske, vil bero på en konkret vurdering. Ved denne vurdering kan den dataansvarlige lægge vægt på, hvor mange og hvor omfattende ændringer, der er foretaget, og deres mulige påvirkning af risikobilledet. Er eksempelvis antallet af behandlede oplysninger øget betydeligt, eller har karakteren af oplysningerne ændret sig, så der i højere grad behandles følsomme oplysninger, kan det indebære, at der skal foretages en fornyet vurdering. Små justeringer, der ikke i selv ændrer væsentligt ved risikobilledet, kan alligevel have denne effekt over tid, når effekten af justeringerne kumuleres. Derfor skal den dataansvarlig under alle omstændigheder foretage en fornyet risikovurdering med passende interval. Dette vil også gælde, selvom den dataansvarlige ikke har ændret noget i sine egne behandlingsprocesser, da eksterne forhold kan medføre et ændret risikobillede.

1.5. Risikovurderingen i praksis

At foretage den beskrevne form for risikovurderinger med tilhørende sikkerhedsforanstaltninger kan være en omfattende og vanskelig øvelse. Forordningen indeholder ingen form- eller proceskrav, og det er således op til den dataansvarlige, hvordan vurderingen skal gennemføres. Til brug herfor kan eventuelt bruges nogle af de eksisterende standarder på området. Det kan dog være et omfattende arbejde at implementere sådanne standarder, og særligt for mindre dataansvarlige vil det ikke nødvendigvis være en farbar vej. Også i disse tilfælde kan standarderne dog tjene til inspiration for arbejdet med risikovurdering.

En udbredt standard er ISO 27000, der indeholder en række standarder for informationssikkerhed. ISO 27005 indeholder en model for risikovurdering. ISO 27701 beskriver arbejdsgange og foranstaltninger, som en organisation bør etablere for et opnå passende beskyttelse af personoplysninger.

Datatilsynet, Justitsministeriet og Digitaliseringsstyrelsen har udarbejdet en vejledning om behandlingssikkerhed og databeskyttelses gennem design og standardindstillinger fra juni 2018, der på et overordnet plan kan bidrage til arbejdet.

Dataansvarlige skal endvidere være opmærksom på, at Datatilsynet i sin praksis har opstillet krav til foranstaltninger under art. 32 i forskellige typer af behandlingssituationer. Det vil dog ikke nødvendigvis indebære, at bestemte typer af foranstaltninger altid skal anvendes, da vurderingen efter art. 32 som beskrevet er en samlet og konkret vurdering.

Datatilsynet har truffet adskillige afgørelser om behandlingssikkerhed efter art. 32. En række af disse er omtalt hos Korfits Nielsen & Lotterup, Databeskyttelsesforordningen og databeskyttelsesloven, s. 636 ff.

1.6. Ansvar efter art. 32

En overtrædelse af art. 32 kan medføre bødeansvar efter DBL § 41, ligesom Datatilsynet efter forordningens art. 58 bl.a. kan forbyde en behandling, der er i strid med art. 32 og pålægge en lovliggørelse af behandlingen.

Selvom art. 32 har til formål at forhindre sikkerhedsbrud, er det ikke ethvert sikkerhedsbrud, der indebærer en overtrædelse af art. 32. Det afgørende er, om den dataansvarlige har overholdt forpligtelsen til at gennemføre en risikovurdering og træffe de fornødne sikkerhedsforanstaltninger. Er dette tilfældet ifalder den dataansvarlige ikke ansvar for et eventuelt sikkerhedsbrud, der har været muligt på trods af de truffe sikkerhedsforanstaltninger.

Det følger eksplicit af art. 32, at bestemmelsen gælder for både dataansvarlige og databehandlere. Art. 32 er således en af de bestemmelser i forordningen, der gør databehandleren til selvstændigt pligtsubjekt. Om den dataansvarliges erstatningsansvar for databehandlerens manglende overholdelse af art. 32 henvises til kap. 11.1.

2. Oplysning om brud på persondatasikkerheden – art. 33 og 34

Forordningen forpligter den dataansvarlige (og databehandleren) til at oplyse om brud på persondatasikkerheden til tilsynsmyndigheden og i visse tilfælde også de registrerede. Oplysningspligten tjener flere formål. For det første tvinger den den dataansvarlige til at forholde sig til

sikkerhedsbruddet, og hvordan det skal håndteres. Den dataansvarlige kan med andre ord ikke “lukke øjnene” og håbe, at sikkerhedsbruddet ikke har haft konsekvenser. For det andet har pligten en præventiv effekt. De færreste virksomheder og myndigheder ønsker at få blotlagt, at de har haft et sikkerhedsbrud, og alene risikoen for at skulle oplyse tilsynsmyndigheder og registrerede herom kan give et incitament til at undgå sikkerhedsbrud. For det tredje giver oplysningspligten tilsynsmyndigheden mulighed for at kontrollere, om sikkerhedsbruddet håndteres korrekt og i øvrigt have en særlig opmærksomhed på dataansvarlige, der har mange sikkerhedsbrud. For det fjerde giver det de registrerede mulighed for at træffe egne forholdsregler, hvis bruddet nødvendiggør dette (f.eks. udskiftning af passwords, betalingskort mv.).

Forpligtelsen til at anmelde sikkerhedsbrud til tilsynsmyndigheden følger af art. 33, mens art. 34 regulerer pligten til at underrette den registrerede om bruddet.

2.1. Anmeldelsespligt til tilsynsmyndigheden – art. 33

Pligten til at anmelde sikkerhedsbrud til tilsynsmyndigheden følger af art. 33, stk. 1, der har følgende ordlyd:

Ved brud på persondatasikkerheden anmelder den dataansvarlige uden unødigt forsinkelse og om muligt senest 72 timer, efter at denne er blevet bekendt med det, bruddet på persondatasikkerheden til den tilsynsmyndighed, som er kompetent i overensstemmelse med artikel 55, medmindre at det er usandsynligt, at bruddet på persondatasikkerheden indebærer en risiko for fysiske personers rettigheder eller frihedsrettigheder. Foretages anmeldelsen til tilsynsmyndigheden ikke inden for 72 timer, ledsages den af en begrundelse for forsinkelsen.

Anmeldelsespligten indtræder således, når der er sket “et brud på persondatasikkerheden”, medmindre det er “usandsynligt”, at bruddet “indebærer en risiko for fysiske personers rettigheder eller frihedsrettigheder”.

Begrebet “brud på persondatasikkerheden” er defineret i art. 4, nr. 12, som “et brud på sikkerheden, der fører til hændelig eller ulovlig tilintetgørelse, tab, ændring, uautoriseret videregivelse af eller adgang

“Brud på persondatasikkerheden”

til personoplysninger, der er transmitteret, opbevaret eller på anden måde behandlet”. Der er således tale om en ganske bred definition, der ikke kun omfatter kompromittering af personoplysninger, men også eksempelvis en fejlagtig sletning af oplysninger eller manglende adgang til oplysninger (f.eks. som følge af et it-nedbrud).

I disse situationer skal den dataansvarlige foretage en anmeldelse til tilsynsmyndigheden, medmindre det er usandsynligt, at sikkerhedsbruddet har indebåret en risiko for fysiske personers rettigheder eller frihedsrettigheder. Efter præambelbetragtning 75 kan risikoen for fysiske personers rettigheder og frihedsrettigheder opstå som følge af behandling af personoplysninger, der kan føre til fysisk, materiel eller immateriel skade, navnlig hvis

“Risiko for fysiske personers rettigheder og frihedsrettigheder”

- behandlingen kan give anledning til forskelsbehandling, identitetstyveri eller -svig, finansielle tab, skade på omdømme, tab af fortrolighed for personoplysninger, der er omfattet af tavshedspligt, uautoriseret ophævelse af pseudonymisering eller andre betydelige økonomiske eller sociale konsekvenser
- de registrerede kan blive berøvet deres rettigheder og frihedsrettigheder eller forhindret i at udøve kontrol med deres personoplysninger
- der behandles følsomme personoplysninger eller oplysninger om straffedomme og lovovertrædelser
- der foretages profilering
- der behandles personoplysninger om sårbare fysiske personer, navnlig børn
- behandlingen omfatter en stor mængde personoplysninger og berører et stort antal registrerede.

Det følger af betragtningen, at der “kan” opstå en risiko. De angivne situationer indebærer således ikke automatisk, at der består en risiko. Omvendt indebærer brugen af ordet “navnlig”, at der også kan opstå en risiko uden for de oplistede forhold.

Den dataansvarlige skal foretage en konkret vurdering af, om det er usandsynligt, at sikkerhedsbruddet har medført en risiko for fysiske personers rettigheder og frihedsrettigheder. Kan det ikke udelukkes, at uvedkommende har fået adgang til personoplysninger, vil dette altid

“Usandsynligt”

være tilfældet. Tilsvarende hvis det eksempelvis ikke kan udelukkes, at en afgørelsesvirksomhed har været påvirket af, at der som følge af et sikkerhedsbrud ikke har været adgang til oplysninger, eller disse ikke er korrekte. Kan det omvendt med meget stor sandsynlighed udelukkes, at sikkerhedsbruddet har givet uvedkommende adgang til data (og der heller ikke aktualiseres andre risici), vil der ikke gælde en anmeldelsespligt.

Datatilsynets vejledning om håndtering af brud på persondatasikkerheden indeholder to eksempler herpå (s. 14 f.):

Eksempel 1: Personalechefen i en virksomhed får på togturen hjem fra arbejde stjålet sin taske, hvori der bl.a. ligger en ekstern harddisk indeholdende oplysninger om ansøgere til en opslået stilling i virksomheden. Virksomheden har sikret sig, at de harddiske, der udleveres til medarbejderne, er beskyttet med en stærk kryptering, der ikke umiddelbart vil være mulig for uvedkommende at dekryptere.

Eksempel 2: En medarbejder hos en kommune kommer ved en fejl til at uploade en fil på kommunens hjemmeside, der indeholder personnumre på flere borgere i kommunen. Medarbejderen bliver straks opmærksom på fejlen og fjerner filen fra hjemmesiden. Kommunens it-afdeling kan ved en undersøgelse af hjemmesidens logoplysninger konstatere, at der ikke har været besøgende på hjemmesiden i den tid, hvor filen har været tilgængelig. Kommunen konkluderer samtidig, at der ikke er noget der tyder på, at filen er blevet kopieret af søgemaskiner, som f.eks. Google, Bing og lign. På den baggrund vurderer kommunen, at sandsynligheden for at filen er eller kan komme til uvedkommendes kendskab er så lille, at der ikke skal ske anmeldelse til Datatilsynet.

Se også EDPB's retningslinjer 01/2021, der indeholder en række eksempler på sikkerhedsbrud med angivelse af, om bruddet i det enkelte eksempel skal anmeldes. Eksemplerne omfatter områderne ransomware, uautoriseret adgang (data exfiltration), interne risici fra ansatte mv., mistede eller stjålne enheder eller papirdokumenter, afsendelse til forkert modtager og social engineering.

Såfremt den dataansvarlige er forpligtet til at anmelde sikkerhedsbruddet til tilsynsmyndigheden, skal dette ske "uden unødigt forsinkelse" og så vidt muligt inden for 72 timer, efter den dataansvarlige er ble-

Frist for
anmeldelse

vet bekendt med bruddet. En mistanke om et sikkerhedsbrud er således ikke tilstrækkelig til at udløse anmeldelsespligten, men kan give den dataansvarlige en forpligtelse til at undersøge forholdet nærmere. I art 29-gruppens retningslinjer om anmeldelse af brud på persondatasikkerheden i henhold til forordning 2016/679, WP250rev.01, der er tiltrådt af EDPB, s. 11, anføres, at den dataansvarlige er “bekendt” med sikkerhedsbruddet, når denne har en rimelig grad af vished for, at der er opstået en sikkerhedshændelse, som kompromitterer personoplysninger. I tilfælde af hackerangreb og andre mere komplekse former for sikkerhedsbrud er det ikke altid muligt at skaffe et fuldt overblik over sikkerhedsbruddet inden for 72 timer. Det betyder dog ikke, at den dataansvarlige kan undlade at overholde fristen. I stedet må den dataansvarlige anmelde sikkerhedsbruddet og herefter trinvist give tilsynsmyndigheden yderligere oplysninger, efterhånden som der opnås kendskab hertil. Kun i den situation, hvor det slet ikke er muligt inden for fristen at skaffe oplysninger til at vurdere, om der foreligger et anmeldelsespligtigt sikkerhedsbrud, kan den dataansvarlige vente med anmeldelsen til et senere tidspunkt, jf. formuleringen om, at anmeldelsen “så vidt muligt” skal ske inden for 72 timer. Det følger i øvrigt af præambelbetragtning 87, at vurderingen af, om anmeldelsen er fandt sted uden unødigt forsinkelse bør ske under særlig hensyntagen til karakteren og alvoren af bruddet og dets konsekvenser og skadevirkninger for den registrerede.

Såfremt den dataansvarlige gør brug af en databehandler, skal denne uden unødigt forsinkelse underrette den dataansvarlige om sikkerhedsbrud, der opstår hos databehandleren. Denne forpligtelse påhviler databehandleren, uanset om det er usandsynligt, at sikkerhedsbruddet har medført en risiko for fysiske personers rettigheder og frihedsrettigheder. Den dataansvarlige skal under alle omstændigheder gøres bekendt med bruddet og kan herefter vurdere, om det skal anmeldes til tilsynsmyndigheden.

Art. 33, stk. 2, angiver, hvilke oplysninger den dataansvarlige skal give til tilsynsmyndigheden i sin anmeldelse:

Stk. 2. Den i stk. 1 omhandlede anmeldelse skal mindst:

- a) beskrive karakteren af bruddet på persondatasikkerheden, herunder, hvis det er muligt, kategorierne og det omtrentlige

Underretningspligt for databehandlere

Anmeldelsens indhold

- antal berørte registrerede samt kategorierne og det omtrentlige antal berørte registreringer af personoplysninger
- b) angive navn på og kontaktoplysninger for databeskyttelsesrådgiveren eller et andet kontaktpunkt, hvor yderligere oplysninger kan indhentes
 - c) beskrive de sandsynlige konsekvenser af bruddet på persondatasikkerheden
 - d) beskrive de foranstaltninger, som den dataansvarlige har truffet eller foreslår truffet for at håndtere bruddet på persondatasikkerheden, herunder, hvis det er relevant, foranstaltninger for at begrænse dets mulige skadevirkninger.

Anmeldelsen skal således beskrive omfanget af bruddet, dets sandsynlige konsekvenser og imødegåelsesforanstaltninger.

Efter art. 33, stk. 5, er den dataansvarlige forpligtet til at dokumentere alle brud på persondatasikkerheden. Dette gælder også brud, som efter den dataansvarliges vurdering ikke indebærer risiko for fysiske personers rettigheder og frihedsrettigheder og derfor ikke skal anmeldes til tilsynsmyndigheden. Dokumentationspligten sikrer bl.a., at tilsynsmyndigheden, hvis ønsket, kan efterprøve den dataansvarliges vurdering af, at sikkerhedsbruddet ikke var anmeldelsespligtigt. Henset til den meget brede definition af sikkerhedsbrud indebærer dette potentielt en meget omfattende dokumentationsaktivitet.

Krav om
dokumentation

2.2. Pligt til at underrette den registrerede – art. 34

Efter art. 34 har den dataansvarlige i nogle situationer også pligt til at underrette den registrerede om sikkerhedsbruddet. Forpligtelsen hertil fremgår af art. 34, stk. 1:

Når et brud på persondatasikkerheden sandsynligvis vil indebære en høj risiko for fysiske personers rettigheder og frihedsrettigheder, underretter den dataansvarlige uden unødigt forsinkelse den registrerede om bruddet på persondatasikkerheden.

Underretningspligten gælder således kun, når sikkerhedsbruddet medfører en "høj" risiko for fysiske personers rettigheder og frihedsrettigheder. Der vil derfor være mange situationer, hvor den dataansvarlige er forpligtet til at anmelde et sikkerhedsbrud til tilsynsmyndigheden.

digheden (dette gælder som beskrevet ovenfor, medmindre det er usandsynligt, at bruddet medfører en risiko for fysiske personers rettigheder og frihedsrettigheder) uden at skulle underrette den registrerede.

I sin risikovurdering skal den dataansvarlige således både vurdere, om det er usandsynligt, at der ikke består en risiko, og hvis dette ikke kan afvises, om risikoen da er "høj". Forordningen indeholder ingen angivelse af, hvornår en risiko skal anses for høj. Generelt vil det gælde, at jo større de potentielle negative konsekvenser bruddet har for den registrerede, og jo større sandsynlighed der er for, at konsekvenserne indtræder, jo mere taler for, at der foreligger en høj risiko. Ved vurderingen må det også tillægges vægt, om den registrerede har behov for kendskab til sikkerhedsbruddet for at kunne træffe fornødne foranstaltninger. Et sikkerhedsbrud, der indebærer kompromittering af passwords, vil eksempelvis nødvendiggøre en udskiftning af password, både på den pågældende tjeneste, men muligvis også på andre tjenester, da de fleste personer genanvender passwords. Dette nødvendiggør, at den registrerede gøres bekendt med sikkerhedsbruddet. Der kan dog ikke nødvendigvis sluttet modsætningsvist, således at risikoen kun kan være høj, hvis der er brug for, at den registrerede træffer konkrete afværgeforanstaltninger.

"Høj risiko for fysiske personers rettigheder og frihedsrettigheder"

Art. 29-gruppens retningslinjer om anmeldelse af brud på persondatasikkerheden i henhold til forordning 2016/679, WP250rev.01, der er tiltrådt af EDPB, indeholder i bilag B eksempler på forskellige typer af sikkerhedsbrud med angivelse af, om de registrerede skal underrettes i de enkelte situationer.

Underretning skal ske "uden unødigt forsinkelse". Det følger af forordningens præambelbetragtning 86, at underretningen bør gives, så snart det med rimelighed er muligt. Er der behov for, at den registrerede reagerer meget hurtigt på sikkerhedsbruddet, kan det påvirke vurderingen af, hvor hurtigt den dataansvarlige skal give underretningen.

Frist for underretning

Efter DBL § 22, stk. 6, gælder underretningspligten efter art. 34 ikke, så længe underretningen af registrerede konkret må antages at vanskeliggøre efterforskningen af strafbare forhold. Beslutning herom kan alene foretages af politiet. Den dataansvarlige kan således ikke på egen hånd anvende § 22, stk. 6, til at udskyde underretningen, men må fore-

DBL § 22, stk. 6 – udskydelse af underretning ved efterforskning

tage en anmeldelse af det potentielt strafbare forhold til politiet, som herefter kan pålægge den dataansvarlige at vente med at foretage underretningen. Det følger af forarbejderne til bestemmelsen, at den er tiltænkt et snævert anvendelsesområde, og at det forventes, at det normalt ikke vil være nødvendigt at udsætte underretningen i mere end nogle få dage eller uger. Bestemmelsen ændrer således ikke på, at der skal gives en underretning eller på kriterierne herfor, men indebærer alene en udskydelse af underretningstidspunktet.

Underretningen til de registrerede skal efter art. 34, stk. 2, ske i et klart og forståeligt sprog og som et minimum oplyse om de sandsynlige konsekvenser af sikkerhedsbruddet, hvad den dataansvarlige har gjort for at håndtere bruddet og opgive en kontaktperson hos den dataansvarlige. Underretningen skal som udgangspunkt ske direkte til de registrerede på en måde, der skaber størst sandsynlighed for, at de modtager den. Dette kan være via e-mail, sms eller fysisk brev, men vil bero på en konkret vurdering.

Underretningens
form

Art. 34, stk. 3, indeholder tre undtagelser fra underretningspligten, dvs. situationer hvor der foreligger en høj risiko for fysiske personers rettigheder eller frihedsrettigheder, men hvor den dataansvarlige alligevel ikke er forpligtet til at underrette de registrerede om sikkerhedsbruddet.

Undtagelser

Efter litra a gælder underretningspligten ikke, hvis "den dataansvarlige har gennemført passende tekniske og organisatoriske beskyttelsesforanstaltninger, og disse foranstaltninger er blevet anvendt på de personoplysninger, som er berørt af bruddet på persondatasikkerheden, navnlig foranstaltninger, der gør personoplysningerne uforståelige for enhver, der ikke har autoriseret adgang hertil, som f.eks. kryptering". Efter bestemmelsens ordlyd vil en virksomhed eksempelvis ikke være forpligtet til at underrette de registrerede, hvis en hacker skaffer sig adgang til virksomhedens it-systemer og de heri lagrede personoplysninger, såfremt oplysningerne er effektivt krypteret. At der ikke skal ske underretning til de registrerede i denne situation, stemmer godt overens med, at der heller ikke skal ske anmeldelse til tilsynsmyndigheden, når kompromitterede personoplysninger er effektivt krypteret, jf. herom afsnittet ovenfor og eksemplerne fra Datatilsynets vejledning. Der er imidlertid ikke overensstemmelse mellem begrundelsen for resultatet for de to bestemmelser. I forhold til art. 33 indebærer

– passende
tekniske og
organisatoriske
foranstaltninger

krypteringen, at der ikke foreligger nogen risiko for fysiske personers rettigheder og frihedsrettigheder.

Denne fortolkning er som nævnt lagt til grund af Datatilsynet og også af EDPB, jf. WP 250 rev.01, s. 18.

I forhold til art. 34 indebærer krypteringen, at undtagelsen i stk. 3 finder anvendelse. Denne undtagelse bliver imidlertid kun relevant, hvis der foreligger en høj risiko for fysiske personers rettigheder og frihedsrettigheder. Uanset denne tilsyneladende manglende konsistens, forekommer resultatet fornuftigt og rigtigt. Der er ikke noget behov for at foretage en anmeldelse eller underretning, hvis det i praksis er utænkeligt, at uvedkommende har kunnet skaffe sig adgang til oplysninger om de registrerede.

Efter litra b gælder underretningspligten ikke, når den dataansvarlige har truffet efterfølgende foranstaltninger, der sikrer, at den høje risiko ikke længere er reel. I Datatilsynets vejledning nævnes som eksempel herpå en situation, hvor en sikkerhedsbrist har givet åben adgang til personoplysninger på en hjemmeside, men hvor det kan dokumenteres, at adgangen blev lukket igen, inden uvedkommende udnyttede den. Der synes her at være samme inkonsistens mellem art. 33 og 34 som netop beskrevet i relation til undtagelsen i litra a, men også i dette tilfælde er resultatet ikke desto mindre fornuftigt.

– efterfølgende
foranstaltninger

Efter litra c gælder underretningspligten ikke, når underretningen ville kræve en uforholdsmæssigt stor indsats af den dataansvarlige. Den omstændighed, at det kræver ressourcer at informere potentielt mange berørte af et sikkerhedsbrud, indebærer ikke i sig selv, at den dataansvarlige kan anvende denne undtagelse. Bestemmelsen vil derimod eksempelvis kunne anvendes, hvor et hackerangreb har bevirket, at hele den dataansvarliges kundedatabase er blevet slettet, og den dataansvarlige derfor ikke længere har kontaktoplysninger om kunderne tilgængelige. Når underretningen af de enkelte registrerede kræver en uforholdsmæssigt stor indsats, skal den dataansvarlige foretage en offentlig meddelelse eller en anden tilsvarende foranstaltning, hvorved de registrerede underrettes på en tilsvarende effektiv måde. Bestemmelsen fritager således ikke fuldstændigt den dataansvarlige for underretningsforpligtelsen, men kun for den individuelle underretning.

– uforholdsmæs-
sig stor indsats

Det følger af art. 34, stk. 4, at tilsynsmyndigheden kan pålægge den dataansvarlige at underrette de registrerede, hvis tilsynet ikke er enig i den dataansvarliges vurdering af, at sikkerhedsbruddet ikke er omfattet af underretningspligten.

Pålæg fra
tilsynsmyndig-
heden

Kapitel 8

Ansvarlighed

1. Generelt om ansvarlighed

En dataansvarlig, der vælger at behandle personoplysninger, skal iagttage kravene til behandlingen som beskrevet i de foregående kapitler. Den dataansvarlige skal således sikre sig at have det fornødne hjemmelsgrundlag til behandlingen, foretage behandlingen i overensstemmelse med de grundlæggende principper i art. 5, iagttage de registreredes rettigheder som led i behandlingen, foretage behandlingen i overensstemmelse med sikkerhedskravene i art. 32 og iagttage kravene til tredjelandsoverførsler efter forordningens kap. V. Dette er de materielle krav, som den dataansvarlige skal overholde. I tillæg hertil pålægger forordningen den dataansvarlige en række yderligere forpligtelser, der først og fremmest skal bidrage til at sikre, at den dataansvarlige efterlever forordningens materielle regler og kan dokumentere dette.

At de dataansvarlige skal pålægges sådanne yderligere forpligtelser for at sikre overholdelsen af forordningens materielle krav og dokumentation heraf, benævnes også princippet om "ansvarlighed" (eller på engelsk "accountability"), der er et bærende princip i forordningen.

Begrebet anvendes et enkelt sted i forordningen, se art. 5, stk. 2, der har følgende ordlyd:

Den dataansvarlige er ansvarlig for og skal kunne påvise, at stk. 1 overholdes (»ansvarlighed«).

I denne kontekst fastlægger indebærer princippet, at den data-ansvarlige skal sikre og kunne påvise overholdelsen af de generelle principper i art. 5, stk. 1. Selvom begrebet kun eksplicit anvendes i art. 5, er princippet ikke begrænset til denne bestemmelse men gælder generelt for overholdelsen af forordningens materielle bestemmelser.

Den danske oversættelse af begrebet, “ansvarlighed”, skaber ikke helt så stærke associationer som det engelske begreb “accountability”. I det følgende anvendes dog det dansksprogede begreb.

Den Europæiske Databeskyttelsesrådgiver (EDPS) har på sin hjemmeside følgende definition af “accountability”: “Principle intended to ensure that controllers are more generally in control and in the position to ensure and demonstrate compliance with data protection principles in practice. Accountability requires that controllers put in place internal mechanisms and control systems that ensure compliance and provide evidence – such as audit reports – to demonstrate compliance to external stakeholders, including supervisory authorities”.

Forordningens “ansvarlighedsregler” er nyskabelser og tilsvarende bestemmelser fandtes ikke i det tidligere persondatadirektiv.

I Opinion 3/2010 “On the principle of accountability” (WP 173) behandlede art. 29-gruppen begrebet og anbefalede, at arbejdet med en revision af persondatadirektivet (der i sidste ende førte til forordningen) blev baseret på et princip om ansvarlighed. Se også om princippet baggrund og historik, Motzfeldt, Grundlæggende databeskyttelsesret, s. 218 ff.

Udover den omtalte bestemmelse i art. 5, stk. 2, omfatter dette regler, der på forskellig vis forpligter den dataansvarlige til at gennemføre risikovurderinger og etablere foranstaltninger for at sikre behandlingens lovlighed. Denne type af ansvarlighedsregler udgøres af den generelle regel om den dataansvarliges pligt til at kunne påvise overholdelse af forordningen (art. 24), reglerne om databeskyttelse gennem design og standardindstillinger (art. 25) og om konsekvensanalyse (art. 35-36). Herudover indeholder forordningen regler om fortegnelser over behandlingsaktiviteter (art. 30) og om brugen af databeskyttelsesrådgiver (art. 37-39). Også reglerne om oplysning om brud på persondatasikkerheden i art. 33 og 34 kan kategoriseres som ansvar-

lighedsregler. Disse regler er dog af fremstillingstekniske grunde beskrevet i foregående kapitel sammen med reglerne om sikkerhedskrav efter art. 32.

I det følgende gennemgås disse ansvarlighedsregler, der som nævnt alle har som overordnet formål at sikre overholdelsen af forordningens materielle regler.

Ansvarlighedsreglerne har derfor karakter af det, der ofte benævnes for compliance-regler. Se således også den engelsksprogede version af art. 5, stk. 2: “The controller shall be responsible for, and be able to demonstrate compliance with, paragraph 1 (‘accountability’)”.

2. Den dataansvarliges pligt til at gennemføre risikobaserede lovlighedsvurderinger og etablere tekniske og organisatoriske foranstaltninger for at sikre behandlingens lovlighed

2.1. Indledning

Med overgangen fra persondatadirektivet til databeskyttelsesforordningen introduceredes en række bestemmelser med en såkaldt risikobaseret tilgang. Fælles for en række af disse bestemmelser er, at de pålægger den dataansvarlige at foretage en vurdering af, hvilken risiko for de registrerede, som en behandlingsaktivitet indebærer, og herefter iværksætte foranstaltninger, der kan reducere denne risiko. Forordningens art. 32 om behandlingssikkerhed, der er gennemgået ovenfor, er et eksempel herpå. Mens art. 32 skal imødegå risikoen for tab af personoplysningernes fortrolighed, integritet og tilgængelighed, indeholder forordningen en række andre bestemmelser, der ligeledes pålægger den dataansvarlige at gennemføre risikovurderinger men med det formål at sikre, at behandlingen er lovlig. Der er med andre ord risikoen for de registrerede forbundet med en ulovlig behandling, der skal håndteres i disse bestemmelser. Da disse bestemmelser har til formål at sikre lovligheden af behandlingen og dermed i sidste ende, at forordningens øvrige materielle bestemmelser overholdes, har de karakter af

ansvarlighedsbestemmelser. Dette drejer sig om art. 24 og 25 (særligt stk. 1), der behandles i det følgende.

Også art. 35 om konsekvensanalyse har til formål at nedbringe risikoen for ulovlig behandling i de situationer, hvor der er en høj risiko for de registrerede. Hermed har art. 35 også karakter af en ansvarlighedsbestemmelse. Da bestemmelsen imidlertid også omfatter høj risiko for de registrerede, når dette ikke er forårsaget af ulovlig behandling men af tab af behandlingssikkerheden, er art. 35 ikke en “ren” ansvarlighedsbestemmelse. Dens karakter af delvis ansvarlighedsbestemmelse indebærer, at den er medtaget i dette afsnit.

Afsnittet afsluttes med en oversigt over samspillet mellem de forskellige bestemmelser, der pålægger den dataansvarlige at gennemføre risikovurderinger: art. 24, art. 25, stk. 1, art. 32 og art. 35.

2.2. Generalklausulen – art. 24

Forordningens art. 24 indeholder en generel forpligtelse for den dataansvarlige til at etablere foranstaltninger, der sikrer overholdelse af forordningens krav og muligheden for at påvise dette. Bestemmelsens stk. 1, der kan betegnes som en form for “ansvarligheds-generalklausul”, har følgende ordlyd:

Under hensyntagen til den pågældende behandlings karakter, omfang, sammenhæng og formål samt risiciene af varierende sandsynlighed og alvor for fysiske personers rettigheder og frihedsrettigheder gennemfører den dataansvarlige passende tekniske og organisatoriske foranstaltninger for at sikre og for at være i stand til at påvise, at behandling er i overensstemmelse med denne forordning. Disse foranstaltninger skal om nødvendigt revideres og ajourføres.

Den dataansvarliges pligt til at gennemføre foranstaltninger, der sikrer, at den påtænkte behandling overholder forordningens krav vil i praksis indebære, at den dataansvarlige skal foretage en indledende vurdering af behandlingens overensstemmelse med forordningens krav. Viser denne vurdering, at behandlingen vil være ulovlig, må den dataansvarlige ændre den på en måde, så den bliver lovlig. Dette skal ifølge bestemmelsen ske gennem “passende tekniske og organisatori-

ske foranstaltninger”. I yderste konsekvens må behandlingen opgives, hvis det ikke er muligt at lovliggøre den.

Det følger af bestemmelsen, at fastlæggelsen af, hvad der er passende tekniske og organisatoriske foranstaltninger, skal ske under hensyntagen til den pågældende behandlings karakter, omfang, sammenhæng og formål samt risiciene af varierende sandsynlighed og alvor for fysiske personers rettigheder og frihedsrettigheder. Dette indebærer, at den dataansvarlige skal foretage en risikovurdering, og art 24 dermed, på samme måde som en række af forordningens øvrige bestemmelser, herunder art. 25, 32 og 35, hviler på en risikobaseret tilgang. Umiddelbart kan det forekomme overraskende, at forpligtelsen til at sikre lovlig behandling kan være risikobaseret. Selvom den risikobaserede tilgang indebærer, at der skal lægges vægt på de potentielle negative konsekvenser ved en begivenheds indtræden, medfører denne tilgang imidlertid ikke, at den dataansvarlige kan vælge at acceptere en mindre ulovlighed under henvisning til, at dette kun har ubetydelige konsekvenser for de registrerede. Den risikobaserede tilgang kan kun anvendes til at håndtere risikoen for en *utilsigtet* ulovlig behandling. Eller med andre situationer, hvor behandlingen vil være lovlig, hvis den gennemføres som planlagt, men hvor det ikke kan udelukkes, at menneskelige fejl eller andre utilsigtede hændelser medfører en ulovlig behandling. Dette kan f.eks. være medarbejderes udlevering af oplysninger til de forkerte personer eller manglende overholdelse af sletningsprocedurer. Hvis derimod de planlagte behandlingsaktiviteter uundgåeligt indebærer en ulovlig behandling, f.eks. fordi der ikke er et behandlingsgrundlag eller den planlagte procedure indebærer indsamling af flere oplysninger, end formålet med behandlingen tilsiger, vil der være tale om *tilsigtet* ulovlig behandling. I denne situation kan den risikobaserede tilgang ikke anvendes, og behandlingen vil være ulovlig, uanset hvor beskedne konsekvenserne vil være for den registrerede.

Risikoen for
utilsigtet ulovlig
behandling

Se også Datatilsynets afgørelse af 18. august 2022 i Helsingør/Chromebook-sagen (sag nr. 2020-431-0061), hvor tilsynet udtalte, at det er en “forudsætning for at vurdere eventuelle risici ved en behandlingsaktivitet, at aktiviteten er lovlig, som den er tiltænkt og designet”.

Finder den dataansvarlige, at behandlingsaktiviteterne indebærer en risiko for utilsigtet ulovlig behandling, skal den dataansvarlige foretage en nærmere vurdering af denne risiko. Risikovurderingen skal tage udgangspunkt i de klassiske parametre for en risikovurdering: sandsynligheden for at en begivenhed indtræder (ofte også omtalt som sandsynligheden for at en trussel materialiserer sig) og konsekvenserne heraf.

Risikovurderingen

Eftersom art. 24 har til formål at begrænse risikoen for en (utilsigtet) ulovlig behandling, er det sandsynligheden herfor, som skal indgå i risikovurderingen. Ved vurderingen heraf kan den dataansvarlige bl.a. inddrage tidligere erfaringer. Sker det eksempelvis hyppigt, at medarbejdere får sendt mails med personoplysninger til forkerte adressater (hvilket er den største enkeltstående årsag til de risikobrud, der anmeldes til Datatilsynet), må det i risikovurderingen lægges til grund, at dette med stor sandsynlighed også vil finde sted for den planlagte behandlingsaktivitet (indtil der etableres foranstaltninger til at imødegå denne risiko).

– sandsynlighed

Dernæst skal risikovurderingen inddrage de mulige konsekvenser ved en utilsigtet ulovlig behandling. I bestemmelsen er det udtrykt således, at foranstaltningerne skal fastsættes under hensyntagen til “den pågældende behandlings karakter, omfang, sammenhæng og formål samt risiciene af varierende sandsynlighed og alvor for fysiske personers rettigheder og frihedsrettigheder”. Denne formulering er identisk med formuleringen i art. 32 (og art. 25), og selvom art. 32 vedrører behandlingssikkerhed, mens art. 24 vedrører sikkerhed for behandlingens lovlighed, må formuleringen antages at have samme meningsindhold i de to bestemmelser. Hvad der ovenfor er anført om formuleringen i kap. 7.1.2.2 under gennemgangen af art. 32 vil derfor tilsvarende gælde for art. 24. Heraf følger, at konsekvensvurderingen både skal inddrage den konkrete skadevirkning, i form af fysiske skader, økonomiske skader og ideelle skader, og rettighedskrænkelser intensitet i bredere forstand (den abstrakte skadevirkning), jf. i det hele herom og om forholdet mellem den konkrete og den abstrakte skadevirkning ovenfor a.st.

– konsekvenser

Når den dataansvarlige har identificeret de aktuelle risici, dvs. sandsynligheden for en utilsigtet ulovlig behandling og de potentielle konsekvenser for den registrerede, skal den dataansvarlige vurdere og væl-

Tekniske og organisatoriske foranstaltninger

ge, hvilke foranstaltninger, som skal etableres for at imødegå disse risici. Det følger af bestemmelsen, at foranstaltningerne både kan være "tekniske" og "organisatoriske". Der er dermed samme typer af foranstaltninger, som dem, der anvendes til at nedbringe risikoen for brud på behandlingssikkerheden efter art. 32, som f.eks. adgangskoder, firewalls, kryptering (tekniske) og uddannelse, etablering af processer, retningslinjer mv. (organisatoriske).

Hvis den indledende risikovurdering viser, at den begivenhed, der risikovurderes (f.eks. at ansatte glemmer at slette oplysninger eller får sendt oplysninger til forkerte modtagere), sandsynligvis vil indebære en høj risiko for de registreredes rettigheder og frihedsrettigheder, skal den dataansvarlige før iværksættelse af foranstaltninger gennemføre en konsekvensanalyse efter art. 35 (en form for udvidet risikoanalyse), jf. herom afsnit 2.4 nedenfor.

Krav om
konsekvens-
analyse ved høj
risiko

I sidste ende vil det bero på en samlet og konkret vurdering, om de anvendte foranstaltninger etablerer et sikkerhedsniveau, der passer til de identificerede risici. Dette indebærer accept af en vis (rest)risiko, selv efter der er iværksat sikkerhedsforanstaltninger. Den dataansvarlige kan med andre acceptere en vis risiko for, at der vil ske en utilsigtet ulovlig behandling. Derimod må den dataansvarlige som anført ikke iværksætte en behandling, hvis det ligger fast, at behandlingen vil være ulovlig, sådan som den er planlagt. I denne situation må den dataansvarlige ændre i den planlagte behandling, så den bliver lovlig, eller undlade at iværksætte behandlingen.

Restrisiko

Det kan være en kompleks og vanskelig opgave at gennemføre en risikovurdering, både fordi forordningen ikke indeholder nærmere retningslinjer herfor, og fordi vurderingen under alle omstændigheder beror på en konkret afvejning af faktorer, der vanskeligt lader sig måle. Det følger af art. 24, stk. 3, at adfærdskodekser efter art. 40 og certificeringsmekanismer efter art. 42 kan bruges som elementer i overholdelsen af art. 24. Dette forudsætter dog, at der eksisterer relevante kodekser eller certificeringsmekanismer for behandlingen. Herudover kan der også søges inspiration i nogle af de risikovurderingsmatricer og standarder, der er udarbejdet af forskellige organisationer.

Efter art. 24, stk. 1, sidste pkt., skal de gennemførte foranstaltninger om nødvendigt revideres og ajourføres. Heri ligger en pligt til løbende at vurdere, om de valgte foranstaltninger fortsat er tilstrækkelige til at

Fornyet vurdering

sikre behandlingens lovlighed. Hvor hyppigt dette skal ske fremgår ikke af forordningen og vil også bero på en konkret vurdering. Forudsætningerne for den oprindelige vurdering kan løbende ændre sig i takt med, at der sker ændringer i de it-systemer, der varetager behandlingen, justering af arbejdsprocesser, organisationsændringer mv. Jo mere omfattende disse ændringer er, jo mere taler for, at der skal foretages en fornyet vurdering.

Det følger af art. 24, at den dataansvarlige ikke kun skal sikre overholdelsen af forordningen men også kunne påvise dette, jf. også afsnit 3 nedenfor. Dette indebærer bl.a., at den dataansvarlige må dokumentere sine overvejelser og vurderinger i forbindelse med lovlighedsvurderingen på en måde, så disse kan påvises ved en eventuel kontrol fra tilsynsmyndigheden.

Krav om påvisning af overholdelse

2.3. Databeskyttelse gennem design og standardindstillinger – art. 25

2.3.1. Databeskyttelse gennem design

Forordningens art. 25, stk. 1, introducerer princippet om databeskyttelse gennem design (“data protection by design”). Bestemmelsen har følgende (ganske svært tilgængelige) ordlyd:

Under hensyntagen til det aktuelle tekniske niveau, implementeringsomkostningerne og den pågældende behandlings karakter, omfang, sammenhæng og formål samt risiciene af varierende sandsynlighed og alvor for fysiske personers rettigheder og frihedsrettigheder, som behandlingen indebærer, gennemfører den dataansvarlige både på tidspunktet for fastlæggelse af midlerne til behandling og på tidspunktet for selve behandlingen passende tekniske og organisatoriske foranstaltninger, såsom pseudonymisering, som er designet med henblik på effektiv implementering af databeskyttelsesprincipper, såsom dataminimering, og med henblik på integrering af de fornødne garantier i behandlingen for at opfylde kravene i denne forordning og beskytte de registreredes rettigheder.

Den bærende tanke i princippet er, at databeskyttelsen skal tænkes ind i systemdesignet fra starten. Der er mange tidligere eksempler på, at it-systemer er blevet udviklet uden blik for de databeskyttelsesretli-

ge regler. Det har i nogle tilfælde medført, at systemet ikke var lovligt og måtte ændres med både forsinkelser og omkostninger til følge. I andre tilfælde har konsekvensen været, at systemet ikke har understøttet databeskyttelsen så effektivt, som det kunne være sket, hvis databeskyttelsen var tænkt ind i løsningen fra starten.

Princippet om databeskyttelse gennem design tager navnlig sigte på udvikling af it-systemer, men art. 25 er ikke begrænset til systemudvikling. Udvikling af eksempelvis forretningsgange og procedurer i en organisation kan også være underlagt kravet om databeskyttelse gennem design, således at databeskyttelsen skal tænkes ind fra start, når udarbejdelsen af sådanne procedurer mv. påbegyndes.

Omfatter alle former for systemer, forretningsgange og procedurer

Se som et eksempel på, at den dataansvarlige ikke havde tænkt databeskyttelsen ind i designfasen af en proces, der indebar behandling af personoplysninger, Datatilsynets afgørelse i sag [2021-31-4751](#). I sagen havde TV 2 i samarbejde med sit advokatfirma iværksat en metoo-undersøgelse for at afdække mulige krænkende handlinger. Datatilsynet fandt, at TV 2 og advokatfirmaet ikke havde tilrettelagt undersøgelsen på en sådan måde, at der var den fornødne sikkerhed for, at behandlingen af følsomme oplysninger havde hjemmel i art. 9. Datatilsynet bemærkede herved, at undersøgelsen var indrettet på en sådan måde, at der kunne indberettes bl.a. følsomme oplysninger om personer, der ikke længere var ansat eller tilknyttet TV 2. På den baggrund nåede tilsynet frem til, at den planlagt fremgangsmåde var i strid med art. 25 (samt en række andre bestemmelser).

Ordlyden af art. 25, stk. 1, er delvist sammenfaldende med ordlyden af art. 24, og der består et overlap mellem de to bestemmelser (se herom afsnit 2.5 nedenfor).

Bestemmelsen forudsætter, at den dataansvarlige skal gennemføre passende tekniske og organisatoriske foranstaltninger. Disse foranstaltninger skal tilvejebringe "effektiv implementering af databeskyttelsesprincipper, såsom dataminimering, og med henblik på integrering af de fornødne garantier i behandlingen for at opfylde kravene i denne forordning og beskytte de registreredes rettigheder". Formuleringen "implementering af databeskyttelsesprincipper" må antages at henvise til de grundlæggende principper i art. 5, mens formuleringen "for at opfylde kravene i denne forordning" indeholder en bred henvisning til alle forordningens krav, herunder kravet om behandlingsgrundlag i

Etablering af passende tekniske og organisatoriske foranstaltninger

– med henblik på at undgå ulovlig behandling

art. 6. Bestemmelsen slutter af med en eksplicit henvisning til de registreredes rettigheder. Hermed fokuserer også art. 25, stk. 1, på risikoen for ulovlig behandling, og det er denne risiko, som foranstaltningerne skal imødegå. Trods de forskellige formuleringer synes det med andre ord at være den samme risiko (risikoen for ulovlig behandling), som art. 24 og 25 fokuserer på.

Når den dataansvarlige skal vurdere, hvilke foranstaltninger, der skal etableres for at imødegå risikoen for ulovlig behandling efter art. 25, stk. 1, skal dette ske under hensyntagen til behandlingens karakter, omfang, sammenhæng og formål samt risiciene af varierende sandsynlighed og alvor for de registreredes rettigheder på samme måde som krævet efter både art. 24 og 32. Art. 25, stk. 1, forudsætter endvidere, i modsætning til art. 24, at der ved fastsættelsen af de passende foranstaltninger skal tages hensyn til det aktuelle tekniske sikkerhedsniveau og implementeringsomkostningerne. Forskellen skyldes formentlig, at systemudvikling ligger i kernen af art. 25, mens art. 24 i højere grad er tænkt som en bestemmelse, der mere generelt fastslår, at den dataansvarlige skal sikre og dokumentere overholdelsen af forordningen. Inddragelsen af det aktuelle sikkerhedsniveau og implementeringsomkostninger findes til gengæld tilsvarende i art. 32. Det må antages, at formuleringen "behandlingens karakter, omfang, sammenhæng og formål samt risiciene af varierende sandsynlighed og alvor for de registreredes rettigheder" generelt skal tillægges samme forståelse i art. 24, 25 og 32, og at dette også gælder begreberne "det aktuelle tekniske sikkerhedsniveau" og "implementeringsomkostningerne" for art. 25 og 32. Herom henvises derfor til behandlingen af art. 24 (afsnit 2.2) og art. 32 (kap. 7.1.2.2).

Ved risikovurderingen efter art. 25, stk. 1, skal den dataansvarlige - på samme måde som under art. 24 - vurdere sandsynligheden for, at en begivenhed fører til en utilsigtet ulovlig behandling og konsekvensen for den registrerede herved. Den dataansvarlige skal på den baggrund foretage en vurdering af, hvilke foranstaltninger der i den konkrete situation vil være passende for at imødegå den identificerede risiko. Henset til de meget brede formuleringer i art. 25 må den dataansvarlige tillægges en stor grad af frihed i valget af foranstaltninger, jf. tilsvarende betænkning 1565/2017, s. 417. Pseudonymisering er den eneste

Under hensyntagen til behandlingens karakter, omfang, sammenhæng og formål samt risiciene af varierende sandsynlighed og alvor for de registreredes rettigheder

Risikovurderingen og valg af foranstaltninger

konkrete foranstaltning, der nævnes i art. 25, hvilket dog ikke indebærer en forpligtelse til at vælge lige præcis denne foranstaltning.

I retningslinjer 4/2019 har EDPB angivet en lang række tænkte scenarier med angivelse af eksempler på mulige foranstaltninger i de enkelte scenarier. Eksempelvis kan en boghandler, der vil sælge bøger online, indrette købsprocessen sådan, at der kun efterspørges fysisk adresse, hvis der købes fysiske bøger, der skal sendes, men ikke ved køb af e-bøger. Eksemplerne er knyttet til overholdelse af behandlingsprincipperne i art. 5 og dermed af ganske generel karakter.

Tilsvarende indeholder Datatilsynets, Justitsministeriets og Digitaliseringsstyrelsens vejledning om behandlingssikkerhed og databeskyttelse gennem design og standardindstillinger fra juni 2018 følgende meget generelle eksempler på foranstaltninger efter art. 25 (s. 25):

- Minimeringen af persondatabehandlingen (artikel 5, stk. 1, litra c),
- Pseudonymisering af personoplysninger så hurtigt som muligt (artikel 4, nr. 5, jfr. artikel 5, stk. 1, litra e),
- Transparens hvad angår personoplysningernes funktion og behandling (artikel 5, stk. 1, litra a),
- Kryptering af data i transit eller hvile (artikel 5, stk.1, litra f jfr. artikel 32, stk. 1, litra b),
- Sikring af infrastrukturen mod uautoriseret indtrængen (artikel 5, stk.1, litra f jfr. artikel 32, stk. 1, litra b),
- Effektive organisatoriske kontroller til autorisation og styring af adgangsrettigheder (artikel 5, stk.1, litra f jfr. artikel 32, stk. 1, litra b) og
- Udeladelse af visning af oplysninger i brugergrænseflader, når disse ikke er nødvendige for en given behandling (artikel 5, stk. 1, litra f).

Vejledningen indeholder også (s. 30) enkelte mere konkrete eksempler på foranstaltninger, herunder automatisk scanning for CPR-nummer ved upload af dokumenter og automatisk sletning efter en vis periode, f.eks. 5 år i et økonomisystem.

Da art. 25, stk. 1, har til formål at imødegå risikoen for ulovlig behandling, er det alene kravene i forordningen øvrige materielle bestemmelser, der sætter rammerne for, hvilke krav der kan stilles til den dataansvarlige under art. 25, stk. 1. Dette indebærer, at den dataansvarlige ikke kan pålægges at indføre en bestemt designforanstaltning, hvis den

ikke er nødvendig for at mitigere risikoen for en ulovlig behandling. Er risikoen således allerede på et acceptabelt niveau, forpligtes den dataansvarlige ikke til at indføre en designforanstaltning, uanset hvor effektiv den måtte være, og hvor meget den (yderligere) ville kunne øge privatlivsbeskyttelsen. Heri ligger også, at den dataansvarlige selv kan vælge, hvilke foranstaltninger, der skal iværksættes, så længe de valgte foranstaltninger nedbringer risikoen til et acceptabelt niveau. Vurderer den dataansvarlige eksempelvis (baseret på hidtidige erfaringer), at der er en risiko for, at der med mellemrum utilsigtet og i strid med reglerne vil blive udsendt dokumenter indeholdende CPR-nummer, kan den dataansvarlige vælge at implementere en teknisk designforanstaltning, der blokerer for denne mulighed. Den dataansvarlige kan imidlertid også vælge at etablere en organisatorisk foranstaltning, hvor medarbejdere uddannes i at undgå denne fejl, hvis den dataansvarlige vurderer, at dette kan nedbringe risikoen til et acceptabelt niveau.

Den dataansvarlige skal dog samtidig være opmærksom på, at det acceptable niveau bl.a. skal fastsættes under hensyntagen til det aktuelle tekniske niveau. Er der teknologiske løsninger tilgængelige, som markant kan reducere en risiko, er det ikke sikkert, at en mindre effektiv organisatorisk foranstaltning (længere) er tilstrækkeligt.

Pligten efter art. 25, stk. 1, gælder ikke kun i forbindelse med udviklingen af et nyt system eller etableringen af en ny procedure men skal iagttages løbende, jf. bestemmelsens ordlyd, hvorefter pligten ikke kun skal iagttages “på tidspunktet for fastlæggelsen af midlerne” men også på “tidspunktet for selve behandlingen” og EDPB’s retningslinjer 4/2019 om art. 25, v.2, pkt. 37. Den dataansvarlige er således forpligtet til løbende at overveje, om de iværksatte foranstaltninger i tilstrækkelig grad sikrer overholdelsen af forordningen. Dette vil i særlig grad gælde, når ændrede forhold gør dette tvivlsomt, f.eks. fordi der har været markante teknologiske udviklinger, eller behandlingen omfatter flere eller nye typer af personoplysninger.

Pligten til at iagttage databeskyttelse gennem design gælder kun for den dataansvarlige. Hverken databehandlere eller eksempelvis producenter af it-systemer, hvor der behandles personoplysninger, er omfattet af art. 25. Den dataansvarlige er dog efter art. 28, stk. 1, forpligtet til kun at vælge databehandlere, der opfylder forordningens

Løbende
forpligtelse

Art. 25 gælder
kun for den
dataansvarlige

krav og har derfor et ansvar for at sikre og løbende kontrollere, at databehandleren etablerer de nødvendige foranstaltninger efter art. 25, jf. også EDPB's retningslinjer 4/2019, pkt. 39. Den dataansvarlige vil også være forpligtet til at vurdere, hvordan behandling af personoplysninger sker i indkøbte it-systemer, inden systemet tages i brug.

Det følger af præambelbetragtning 78, at producenter af produkter, tjenester og applikationer (software), hvori der behandles personoplysninger, bør tilskyndes til at tage højde for retten til databeskyttelse i forbindelse med udviklingen, og at der også bør tages hensyn til principperne om databeskyttelse gennem design og standardindstillinger i forbindelse med offentlige udbud.

Art. 25 er en nyskabelse i forordningen. Det tidligere persondatadirektiv indeholdt ikke en tilsvarende bestemmelse, hvilket rejser spørgsmålet, om bestemmelsen også gælder systemer, der var i brug før forordningen fik virkning. Spørgsmålet får selvsagt mindre betydning, som tiden går, men der anvendes fortsat mange systemer, der blev udviklet og taget i brug før maj 2018. I retningslinjer 4/2019, pkt. 38, anfører EDPB, at sådanne systemer også omfattes af art. 25, og at den dataansvarlige har en pligt til at vurdere, om systemet overholder kravene efter art. 25. Dette er for så vidt en naturlig følge af, at art. 25 ikke kun gælder i designfasen men løbende i hele den periode, hvor behandlingen finder sted. Det kan dog være ganske ressourcekrævende at skulle re-designe et eksisterende system. Formentlig henset hertil anføres i Datatilsynets, Justitsministeriets og Digitaliseringsstyrelsens vejledning om behandlingssikkerhed og databeskyttelse gennem design og standardindstillinger fra juni 2018, at forordningen ikke kræver, at allerede eksisterende systemer skal re-designes, jf. s. 23. Giver systemet ikke i sig selv tilstrækkelig sikkerhed for, at forordningens materielle regler overholdes, peger vejledningen på, at dette potentielt kan sikres gennem organisatoriske foranstaltninger som f.eks. interne procedurer eller undervisning af medarbejdere. I sidste ende kan det selvsagt ikke udelukkes, at et system er designet på en sådan måde, at organisatoriske foranstaltninger ikke kan afbøde systemets manglende evne til at overholde forordningen (eksempelvis at det ikke er muligt at slette oplysninger i systemet). I så fald vil den dataansvarlige være forpligtet til at ændre i systemdesignet. I praksis må dette dog antages at være sjæl-

Systemer udviklet
før forordningen

dent forekommende, eftersom forordningens materielle bestemmelser i art. 5 og 6 og om de registrerede rettigheder i det væsentlige er identiske med bestemmelserne i det tidligere persondatadirektiv. Er systemet designet til at overholde bestemmelserne i det tidligere direktiv, er det derfor sandsynligt, at det også overholder bestemmelserne i forordningen.

Princippet om databeskyttelse gennem design og art. 25, stk. 1, er blevet omtalt som en af de vigtigste nyskabelser i forordningen, og det kan heller ikke udelukkes, at bestemmelsen vil få stor betydning navnlig i forbindelse med design af it-systemer og processerne for behandling af personoplysninger i sådanne systemer. På trods af dette, og måske en smule paradoksalt, må bestemmelsen antages at få begrænset retlig betydning, hvilket også illustreres også af, at der så vidt ses ikke foreligger tilsynsafgørelser, der alene omhandler en overtrædelse af art. 25. I praksis synes overtrædelse af art. 25 således altid at ske i tilknytning til overtrædelse af en eller flere af forordningens materielle bestemmelser om behandling, særligt art. 5 og 6 og bestemmelserne om de registrerede rettigheder. I disse situationer kan man med nogen rette sige, at overtrædelsen af art. 25 bliver af sekundær karakter.

At der tillige sker en overtrædelse af art. 25 kan dog potentielt tillægges betydning ved sanktioneringen. Overtrædelse af art. 25 er således nævnt som et af de forhold, der kan tillægges vægt ved vurderingen af, om der skal pålægges en administrativ bøde og størrelsen heraf, jf. art. 83, stk. 2, litra d. Den dataansvarlige, der ikke har gjort sig nogen overvejelser om, hvordan det sikres, at behandlingen sker inden for forordningens rammer og ikke har iværksat nogen designtiltag for at sikre dette, risikerer givetvis en større bøde, når der sker en overtrædelse af forordningen, end den dataansvarlige der (forgæves) har bestræbt sig på at overholde forordningen. Har den dataansvarlige omvendt udfoldet sådanne bestræbelser, har det næppe væsentlig betydning for bødens størrelse, at der ikke kun foreligger en overtrædelse af forordningens materielle bestemmelser, men ligeledes af art. 25, fordi foranstaltningerne ikke lever op til denne bestemmelse.

Det kan dog ikke udelukkes, at art. 25 i nogle situationer vil være den eneste bestemmelse, der er overtrådt, og dermed i sig selv være afgørende for, om den dataansvarlige kan sanktioneres. Anvender den dataansvarlige eksempelvis et it-system, der er designet sådan, at det

Selvstændig retlig betydning – konsekvenser ved overtrædelse?

– overtrædelse af art. 25 samtidig med overtrædelse af andre bestemmelser

– kun overtrædelse af art. 25

ikke er muligt at give registrerede indsigt efter art. 15, vil dette udgøre en overtrædelse af art. 25, også selvom der endnu ikke er nogen registrerede, der har anmodet om indsigt. Konsekvensen heraf er bl.a., at tilsynsmyndigheden efter art. 58, stk. 2, litra d og f, kan give den dataansvarlige et påbud om at ændre systemet eller nedlægge forbud mod dets brug. Derimod bør den dataansvarlige næppe pålægges en bøde i en sådan situation, hvor der endnu ikke foreligger en aktuel overtrædelse af forordningens materielle bestemmelser.

Det kan endvidere overvejes, om der kan ske overtrædelse af art. 25, selvom den dataansvarlige endnu ikke er begyndt at behandle personoplysninger. Problemstillingen kan illustreres ved at ændre det netop anførte eksempel, så den dataansvarlige har fået udviklet et it-system, der ikke gør det muligt at give den registrerede indsigtsret, men som endnu ikke er taget i brug af den dataansvarlige. Spørgsmålet er, om den dataansvarlige i denne situation overtræder art. 25. På den ene side er forordningens materielle anvendelsesområde "behandling af personoplysninger", jf. art. 2, stk. 1. Eftersom der i det angivne eksempel endnu ikke er sket nogen behandling af personoplysninger, taler det for, at der ikke kan være sket en overtrædelse af forordningen, herunder art. 25. På den anden side angives eksplicit i art. 25, stk. 1, at princippet om databeskyttelse gennem design både gælder på tidspunktet for fastlæggelse af midlerne til behandling og på tidspunktet for selve behandlingen. Bestemmelsen angiver med andre ord eksplicit, at princippet ikke kun skal gælde i forbindelse med behandlingen men også forudgående. Isoleret set taler dette for, at den dataansvarlige kan overtræde art. 25 allerede på tidspunktet, hvor systemet designes. Det vil også indebære, at tilsynsmyndighedernes beføjelser til at påbyde en lovliggørelse mv. gælder allerede fra designtidspunktet, hvilket synes at være i overensstemmelse med tanken bag bestemmelsen. Det ville være uhensigtsmæssigt, hvis tilsynsmyndigheden konstaterede, at systemet var designet i strid med art. 25, stk. 1, men først kunne reagere herpå, når systemet blev taget i brug. Det må derfor også lægges til grund, at den dataansvarlige allerede kan overtræde art. 25, stk. 1, i designfasen, selvom der på dette tidspunkt endnu ikke ske behandling af personoplysninger. I lyset af, at der ikke er sket en behandling af personoplysninger, og dermed selvsagt heller ikke en ulovlig behandling, bør forholdet ikke kunne udløse bøde. I det hele taget har situationen

nok begrænset praktisk betydning, da det vil være sjældent, at tilsynsmyndighederne allerede på designtidspunktet bliver bekendt med, at et system eller en proces ikke overholder art. 25, stk. 1. Det vil nok særligt være ved udvikling af store offentlige løsninger, at dette kan forekomme (som eksempelvis udvikling af den nationale corona smittestopporing-app, der blev fulgt tæt af Datatilsynet).

Selvom art. 25, stk. 1, ikke nødvendigvis vil få stor retlig betydning, forstået således, at en handling udelukkende eller primært sanktioneres efter denne bestemmelse, kan den alligevel være væsentlig. Alene det forhold, at den dataansvarlige pålægges en retlig forpligtelse til at tænke databeskyttelse ind i designfasen, kan medføre et øget fokus på, at dette rent faktisk sker. Det kan heller ikke udelukkes, at bestemmelsen over tid vil udvikle sig sådan, at den anvendes til at pålægge dataansvarlige mere konkrete former for designforanstaltninger. Tilsynsmyndighederne bør dog udvise tilbageholdenhed med at indfortolke pligt til brug af konkrete designforanstaltninger, både fordi bestemmelsen er meget bredt formuleret og således lægger op til en høj grad af valgfrihed hos de dataansvarlige, og fordi bestemmelsen under alle omstændigheder alene har til formål at sikre behandlingens lovlighed.

2.3.2. Databeskyttelse gennem standardindstillinger

Tæt beslægtet med princippet om databeskyttelse gennem design er princippet om databeskyttelse gennem standardindstillinger ("data protection by default"). Princippet følger af art. 25, stk. 2, der har følgende ordlyd:

Den dataansvarlige gennemfører passende tekniske og organisatoriske foranstaltninger med henblik på gennem standardindstillinger at sikre, at kun personoplysninger, der er nødvendige til hvert specifikt formål med behandlingen, behandles. Denne forpligtelse gælder den mængde personoplysninger, der indsamles, og omfanget af deres behandling samt deres opbevaringsperiode og tilgængelighed. Sådanne foranstaltninger skal navnlig gennem standardindstillinger sikre, at personoplysninger ikke uden den pågældende fysiske persons indgriben stilles til rådighed for et ubegrænset antal fysiske personer.

På samme måde som art. 25, stk. 1, omfatter bestemmelsen både tekniske og organisatoriske foranstaltninger. Princippet om databeskyttelse gennem standardindstillinger omfatter således ikke kun it-systemer men også de organisatoriske processer for behandlingen af personoplysninger. Bestemmelsen vil dog formentlig have sin største praktiske betydning ved valg af standardindstillinger i it-systemer.

Tekniske og organisatoriske foranstaltninger

Bestemmelsens fastslår, at foranstaltningerne skal sikre, at der kun sker behandling af personoplysninger, der er nødvendige for det specifikke formål med behandlingen, hvilket særligt knytter sig til det grundlæggende princip om dataminimering i art. 5, stk. 1, litra c. Angivelsen af, at pligten gælder mængden af personoplysninger, behandlingens omfang, opbevaringsperiode og tilgængelighed viser, at bestemmelsen har et bredere fokus end kun princippet om formålsbegrænsning. Omvendt synes bestemmelsens sidste sætning, hvorefter foranstaltningerne navnlig skal sikre, at personoplysninger ikke gøres tilgængelige for et ubegrænset antal personer uden den registreredes indgriben, at indikere, at foranstaltningerne ikke generelt skal sikre behandlingens lovlighed som tilfældet er for art. 25, stk. 1 og art. 24.

Formålet med foranstaltningerne

I retningslinjer 4/2019, pkt. 48, anfører EDPB, at art. 25, stk. 2's angivelse af mængden af oplysninger, omfanget af behandlingen, opbevaringsperioden og tilgængeliggørelsen for et ubegrænset antal personer, udgør "dimensionerne" af pligten til dataminimering. Hvad der nærmere ligger heri forekommer uklart, men det er næppe EDPB's tanke, at art. 25, stk. 2, alene forpligter den dataansvarlige til at anvende standardindstillinger for at sikre overholdelsen af dataminimeringsprincippet. I retningslinjernes efterfølgende eksempler på, hvordan (alle) principperne i art. 5 kan implementeres (pkt. 60 ff.), sondres der således heller ikke mellem databeskyttelse gennem design (art. 25, stk. 1) og databeskyttelses gennem standardindstillinger (art. 25, stk. 2). Det anføres endvidere (pkt. 63), at forpligtelsen også gælder overholdelsen for iagttagelsen af de registreredes rettigheder.

Henset til bestemmelsens ordlyd kan den dog næppe strækkes til at pålægge den dataansvarlige en pligt til generelt at sikre lovlig behandling ved brug af standardindstillinger. Den må først og fremmest forpligte den dataansvarlige til at sætte standardindstillingerne således, at opbevaring, brug og tilgængeliggørelse af personoplysninger begrænses til det minimale henset til formålet med behandlingen. Når den da-

taansvarlige anvender tredjepartssoftware til behandlingen af personoplysninger, kan dette både indebære en pligt til at aktivere standardindstillinger, der sikrer en begrænsning i behandlingen, når sådanne standardindstillinger ikke er slået til som default, og omvendt til at deaktivere standardindstillinger, der indebærer en behandling udover det nødvendige, når sådanne indstillinger er aktiveret som default. EDPB formulerer det således, at den dataansvarlige er forpligtet til at foretage en risikovurdering af tredjepartsproduktet og som led heri vurdere behovet for deaktivering (og aktivering) af standardfunktioner, retningslinjer 4/2019, pkt. 44.

Art. 25, stk. 2, forudsætter ikke, som art. 25 stk. 1 og art. 24, at foranstaltningerne fastsættes under hensyntagen til risikoen for den registrerede. Bestemmelsen har dermed ikke den samme risikobaserede tilgang som de to andre bestemmelser. Dette skyldes muligvis, at art. 25, stk. 2, efterlader den dataansvarlige med et langt mere afgrænset udfaldsrum, der i princippet består i en beslutning om, hvorvidt givne standardindstillinger skal aktiveres eller deaktiveres. Henset til, at foranstaltningerne også efter art. 25, stk. 2, skal være "passende", efterlade bestemmelsen i praksis imidlertid også et rum for konkret vurdering, der i nogle situationer vil gøre det muligt at inddrage risikovurderingselementer.

Ikke en
risikobaseret
tilgang

De ovenstående overvejelser om den selvstændige retlige betydning af art. 25, stk. 1, gælder tilsvarende for art. 25, stk. 2. Det må således forventes, at en overtrædelse af art. 25, stk. 2, som regel vil indebære en overtrædelse af andre af forordningens materielle bestemmelser. Er den dataansvarliges mailsystem eksempelvis ikke sat til at slette mails efter en vis periode som standard, vil en fortsat opbevaring af mails indeholdende personoplysninger, efter der ikke længere er behov for at behandle oplysningerne, være i strid med art. 5, stk. 1, litra c, om data-minimering. Der kan dog forekomme situationer, hvor kun art. 25, stk. 2, er overtrådt, når den dataansvarlige anvender et system eller en proces, som ikke overholder kravet om databaseskyttelse gennem standardindstillinger, men hvor dette endnu ikke har resulteret i en ulovlig behandling. Dette kunne eksempelvis være tilfældet, hvis den dataansvarlige anvender et mailsystem uden automatisk sletning, og der heller ikke er etableret andre procedurer, der sikrer løbende sletning, men hvor der endnu ikke foreligger mails, som burde være slettet.

Overtrædelse af
art. 25, stk. 2

2.4. Konsekvensanalyse – art. 35 og 36

Efter forordningens art. 35 skal den dataansvarlige foretage en såkaldt konsekvensanalyse, inden en behandling af personoplysninger igangsættes, hvis behandlingen sandsynligvis vil udgøre en høj risiko for den registrerede.

Betegnelsen “DPIA” anvendes af og til som synonym for konsekvensanalyse. Betegnelsen er en forkortelse af den engelsksprogede betegnelse for konsekvensanalyse, “Data Protection Impact Assessment”.

Konsekvensanalysen er en særlig form for risikovurdering og dermed beslægtet med risikovurderingerne efter art. 24, 25 og 32 (se også afsnit 2.5 nedenfor om forholdet mellem disse bestemmelser). Når den dataansvarlige vurderer, at behandlingen sandsynligvis indebærer en høj risiko for de registrerede, skal risikovurderingen følge den særlige proces og de krav, der fremgår af art. 35. Overordnet består processen af fire trin: 1) en indledende vurdering af, om der sandsynligvis består en høj risiko for de registrerede, særligt på baggrund af de kriterier, der er lagt fast i art. 35 og af tilsynsmyndighederne, 2) en konkret vurdering af risikoen for de registrerede, 3) valg af foranstaltninger for at nedbringe den identificerede risiko og 4) høring af tilsynsmyndigheden, hvis den dataansvarlige vil gennemføre en behandling, der fortsat indebærer en høj risiko for de registrerede, efter der er etableret foranstaltninger.

2.4.1. Pligt til at gennemføre en konsekvensanalyse

Pligten til at udarbejde en konsekvensanalyse og de nærmere kriterier for, hvornår en sådan pligt gælder, følger af art. 35, stk. 1:

Hvis en type behandling, navnlig ved brug af nye teknologier og i medfør af sin karakter, omfang, sammenhæng og formål, sandsynligvis vil indebære en høj risiko for fysiske personers rettigheder og frihedsrettigheder, foretager den dataansvarlige forud for behandlingen en analyse af de påtænkte behandlingsaktiviteters konsekvenser for beskyttelse af personoplysninger. En enkelt analyse kan omfatte flere lignende behandlingsaktiviteter, der indebærer lignende høje risici.

Pligten til at udarbejde en konsekvensanalyse indtræder således, når en påtænkt behandling sandsynligvis vil indebære en høj risiko for fysiske personers rettigheder og frihedsrettigheder. Samme kriterie anvendes ved vurderingen af, om den dataansvarlige skal underrette den registrerede om et sikkerhedsbrud.

“Høj risiko for fysiske personers rettigheder og frihedsrettigheder”

Det følger af bestemmelsen, at pligten navnlig gælder ved brug af nye teknologier. Tanken er, at brugen af nye teknologier potentielt kan medføre behandling af personoplysninger på nye måder, hvis omfang og intensitet kan være vanskelige at gennemskue på forhånd. Det er derfor særligt i disse situationer, det kan være relevant at foretage en forudgående konsekvensanalyse. Eksempler på nye teknologier kan være kunstig intelligens, anvendelse af ansigtsgenkendelse, iris-scanning og andre biometriske teknologier, eventuelt anvendt i nye kombinationer. At det “navnlig” er ved brug af nye teknologier, hvor der kan indtræde en pligt til at gennemføre en konsekvensanalyse, viser dog, at det ikke er udelukket, at en sådan pligt kan indtræde også uden anvendelsen af nye teknologier.

– nye teknologier

I art. 35, stk. 3, angives tre situationer, hvor det navnlig er påkrævet at gennemføre en konsekvensanalyse. Brug af ordet “navnlig” indebærer også her, at bestemmelsen ikke er udtømmende.

Efter litra a gælder det ved “en systematisk og omfattende vurdering af personlige forhold vedrørende fysiske personer, der er baseret på automatisk behandling, herunder profilering, og som er grundlag for afgørelser, der har retsvirkning for den fysiske person eller på tilsvarende vis betydeligt påvirker den fysiske person”.

– systematisk og omfattende vurdering af personlige forhold

Datatilsynet giver i sin vejledning om konsekvensanalyse som eksempel, at en privat arrangør af en større rockkoncert samkører navnene på de 35.000 personer, der har købt en billet til koncerten op imod offentligt tilgængelige oplysninger (f.eks. medieomtale, blogs mv.), med henblik på at afdække, om de pågældende tidligere har optrådt farligt eller forstyrrende ved offentlige arrangementer og derfor skal udelukkes fra koncerten.

Efter litra b gælder det endvidere ved behandling i stort omfang af følsomme oplysninger eller oplysninger om straffedomme og lovovertrædelser.

– følsomme oplysninger

Efter litra c gælder det endelig, når der sker systematisk overvågning af offentligt tilgængeligt område i stort omfang. Kommuners brug af tv-overvågning kan være et eksempel herpå.

– offentlig overvågning

Det kan være en vanskelig opgave at vurdere, hvornår en behandling har en sådan karakter, at der indtræder pligt til at udarbejde en konsekvensanalyse. Forordningen forudsætter, at tilsynsmyndighederne skal udarbejde og offentliggøre en liste over typer af behandlingsaktiviteter, der er underlagt krav om en konsekvensanalyse, jf. art. 35, stk. 4. Til brug herfor har Art. 29-gruppen udarbejdet retningslinjer for konsekvensanalyse (WP 248 rev. 01, tiltrådt af EDPB), der identificerer ni kriterier, som de nationale tilsynsmyndigheder bør tage hensyn til ved udarbejdelsen af lister over omfattede behandlingsaktiviteter. Disse ni kriterier omfatter:

– EDPB's ni kriterier og Datatilsynets liste over omfattede behandlingsaktiviteter

- Evaluering eller analyse, herunder profilering og forudsigelse
- Automatiseret beslutningstagning med juridisk eller tilsvarende betydelig indvirkning
- Systematisk overvågningen
- Følsomme oplysninger (art. 9) eller oplysninger om straffedomme og lovovertrædelser (art. 10)
- Oplysninger, der gøres til genstand for omfattende behandling
- Matching eller kombination af datasæt
- Oplysninger om sårbare registrerede
- Innovativ brug eller anvendelse af ny teknologi eller nye organisatoriske løsninger
- Behandlinger, der hindrer den registrerede i at udøve en rettighed eller gøre brug af en tjeneste eller en kontrakt.

I vejledningen angives, at jo flere kriterier en behandling opfylder, jo mere sandsynligt er det, at den udgør en høj risiko. Det anføres endvidere, at en dataansvarlig kan antage, at der i de fleste tilfælde skal udarbejdes en konsekvensanalyse, hvis to af kriterierne er opfyldt.

I Danmark har Datatilsynet med udgangspunkt i WP 248 rev. 01 udarbejdet en liste, der opregner otte behandlingsaktiviteter, hvor der altid skal udføres en konsekvensanalyse:

– Datatilsynets liste

- Behandling af biometriske data med det formål entydigt at identificere en fysisk person i sammenhæng med mindst et yderligere kriterie fra Artikel 29-gruppens retningslinjer (WP248 rev. 01)
- Behandling af genetiske data i sammenhæng med mindst et yderligere kriterie fra Artikel 29- gruppens retningslinjer (WP248 rev. 01)
- Behandling af lokationsdata i sammenhæng med mindst et yderligere kriterie fra Artikel 29- gruppens retningslinjer (WP248 rev. 01)
- Behandling ved brug af nye teknologier i sammenhæng med mindst et yderligere kriterie fra Artikel 29-gruppens retningslinjer (WP248 rev. 01)
- Behandling der fører til afgørelser om en fysisk persons rettigheder til et produkt, en service, en potentiel mulighed eller begunstigelse, der er baseret på en hvilken som helst form for automatiseret afgørelse (herunder profilering)
- Behandling der omfatter profilering af fysiske personer i stor skala, sådan som dette er defineret i Artikel 29-gruppens retningslinjer (WP248 rev. 01)
- Behandling af personoplysninger om sårbare personer eller hvor der er tale om behandling af følsomme oplysninger (særlige kategorier) og hvor, der benyttes profilering eller andre former for automatiserede afgørelser
- Behandlinger hvor et brud på persondatasikkerheden kan have en direkte effekt på en persons fysiske helbred eller på sikkerheden for en fysisk person.

Datatilsynets liste er ikke udtømmende, og dataansvarlige skal derfor fortsat vurdere, om en behandling kan være omfattet af kravet om konsekvensanalyse, selvom behandlingen ikke er omfattet af listen. Vurderer den dataansvarlige derfor, at der sandsynligvis er en høj risiko for de registrerede, selvom behandlingsaktiviteten ikke omfattes af Datatilsynets liste, skal der foretage en konsekvensanalyse. Som nærmere udviklet i kap. 7.1.2.2 må det antages, at begrebet “risikoen for fysiske personers rettigheder og frihedsrettigheder” både omfatter risikoen for konkrete skadevirkninger i form af fysisk, økonomisk og ideel skade og risikoen for krænkelse af de registreredes rettigheder i bre-

– situationer uden for Datatilsynets liste

dere forstand (den abstrakte skadevirkning). Begrebet må tillægges samme forståelse i art. 35. Både den konkrete og den abstrakte skadevirkning kan således føre til, at der foreligger en høj risiko for de registrerede.

I overensstemmelse hermed har Datatilsynet i sin vejledning om konsekvensanalyse (afsnit 3.2) anført begge typer af skader i opregningen af forhold, der kan medføre en høj risiko for de registrerede

Det følger af art. 35, stk. 10, at kravet om, at den dataansvarlige skal gennemføre en konsekvensanalyse, kan fraviges, når den dataansvarlige foretager behandling med hjemmel i art. 6, stk. 1, litra c (retlig forpligtelse) eller litra e (offentlig myndighedsudøvelse eller opgave i samfundets interesse) på baggrund af en national lov, når der allerede i forbindelse med vedtagelsen af denne lov er udarbejdet en generel konsekvensanalyse.

Undtagelse til kravet om konsekvensanalyse

2.4.2. Indholdet af konsekvensanalysen

Kravene til indholdet af konsekvensanalysen følger af art. 35, stk. 7. Det fremgår heraf, at analysen som minimum skal indeholde

- a. en systematisk beskrivelse af de planlagte behandlingsaktiviteter og formålene med behandlingen, herunder i givet fald de legitime interesser, der forfølges af den dataansvarlige
- b. en vurdering af, om behandlingsaktiviteterne er nødvendige og står i rimeligt forhold til formålene
- c. en vurdering af risiciene for de registreredes rettigheder og frihedsrettigheder som omhandlet i stk. 1, og
- d. de foranstaltninger, der påtænkes for at imødegå disse risici, herunder garantier, sikkerhedsforanstaltninger og mekanismer, som kan sikre beskyttelse af personoplysninger og påvise overholdelse af forordningen, under hensyntagen til de registreredes og andre berørte personers rettigheder og legitime interesser.

Kravene om, at der skal foretages en systematisk beskrivelse af behandlingsaktiviteterne og formålene (litra a) og en vurdering af behandlingsaktiviteternes nødvendighed og proportionalitet (litra b) er isoleret set ikke aktiviteter, der er en del af en risikovurdering. De kan

Beskrivelse af behandlingsaktiviteter og formål og vurdering af nødvendighed og proportionalitet

dog give den dataansvarlige anledning til at (gen)overveje, om behandlingen er nødvendig i dens planlagt udformning i lyset af den høje risiko for de registrerede. Inden den dataansvarlige overvejer, hvordan risikoen kan reduceres, kan den dataansvarlige eventuelt overveje, om behandlingen kan foretages på en anden og mindre indgribende måde.

Såfremt den dataansvarlige finder, at behandlingen er nødvendig og proportional, skal der herefter foretages en vurdering af de risici, behandlingen påfører de registrerede (litra c) og fastlæggelse af foranstaltningerne for at reducere disse risici (litra d).

Vurderingen af risikoen for de registreredes rettigheder efter litra c svarer til den tilsvarende vurdering, der foretages efter art. 24, 25 og 32 og indbefatter både en vurdering af sandsynligheden for begivenhedens indtræden og dens potentielle skadevirkning (konsekvens). Det dataansvarlige skal således vurdere de potentielle konkrete skadevirkninger af fysisk, økonomisk og ideel karakter og den abstrakte skadevirkning i form af risikoen for krænkelse af de registreredes rettigheder i bredere forstand, se nærmere hertil under gennemgangen af de nævnte bestemmelser.

Efter litra d skal konsekvensanalysen angive de foranstaltninger, den dataansvarlige vil gennemføre for at imødegå de identificerede risici. På samme måde som det gælder efter art. 24, 25 og 32 kan disse foranstaltninger både være tekniske og organisatoriske.

Det fremgår ikke klart af litra c og d hvilke typer af begivenheder, der omfattes af risikovurderingen. Som anført ovenfor omfatter risikovurderingen efter art. 32 risikoen for de registrerede som følge af brud på behandlingssikkerheden (tab af fortrolighed, integritet og tilgængelighed), mens risikovurderingen efter art. 24 og 25 omfatter risikoen for utilsigtet ulovlig behandling. I litra d angives som foranstaltninger under art. 35 "garantier, sikkerhedsforanstaltninger og mekanismer, som kan sikre beskyttelse af personoplysninger og påvise overholdelse af denne forordning". Med henvisningen til sikkerhedsforanstaltninger og mekanismer, som kan sikre beskyttelse af personoplysninger, står det klart, at risikovurderingen efter art. 35 omfatter brud på behandlingssikkerheden. Litra d henviser endvidere til foranstaltninger, der kan *påvise* overholdelsen af forordningen. I modsætning til art. 24 og 25 omtaler litra d imidlertid ikke foranstaltninger, der kan *sikre*

Risikovurderingen

Foranstaltninger

Art. 35 omfatter både risikoen ved tab af behandlingssikkerhed og ved utilsigtet ulovlig behandling

overholdelsen af forordningen. På trods af dette må det lægges til grund, at art. 35 også omfatter den situation, hvor en høj risiko for de registrerede er udløst af en utilsigtet ulovlig behandling, således at konsekvensanalysen også må forholde sig til risikoen ved utilsigtet ulovlig behandling. Et sådant krav gælder som anført for de "almindelige" risikovurderinger efter art. 24 og 25, og kravene kan næppe være mere lempelige til risikovurderingerne efter art. 35.

Dette er også lagt til grund af Datatilsynet i afgørelse af 18. august 2022 i Helsingør/Chromebook-sagen (sag nr. 2020-431-0061), hvor tilsynet udtalte, at "... de faktiske forhold vedrørende behandlingsaktiviteten og dennes lovlighed er en forudsætning for at vurdere eventuelle risici i form af fravigelser fra den tilsigtede, lovlige behandlingsaktivitet, jf. stk. 7, litra c ... Derudover skal den dataansvarlige vurdere, om der findes risikoscenarier, der kan indebære, at der sker ulovlig behandling af personoplysninger. Ved sådanne risikoscenarier forstår Datatilsynets mulige situationer, der kan opstå *utilsigtet*, og som indebærer en afvigelse af den tiltænkte, lovlige behandlingsaktivitet".

Fordi konsekvensanalysen anvendes, når der er en høj risiko for de registrerede, vil det typisk indebære, at der stilles større krav til de foranstaltninger, der skal nedbringe risici, end efter en almindelig risikovurdering, og at der i det hele taget skal foretages en mere omfattende analyse. Det vil dog altid bero på de konkrete omstændigheder, hvilke krav der stilles til konsekvensanalysen i den enkelte situation, og dens nærmere indhold fastlægges af den dataansvarlige. Til brug herfor kan eventuelt søges inspiration i nogle af de eksisterende standarder og rammeværktøjer, som f.eks. ISO/IEC 29134-standarden om privacy impact assessments.

Den risikobaserede tilgang indebærer, at den dataansvarlige skal identificere og mitigere risikoen for, at behandlingen påfører de registrerede skade (risiciene for de registreredes rettigheder og frihedsrettigheder). Dette skal føre til, at risikoen nedbringes til et acceptabelt niveau. Det er således ikke et krav, at risikoen helt elimineres. Hvis residualrisikoen fortsat er høj selv efter anvendelse af de mitigerende foranstaltninger, kan den dataansvarlige dog ikke uden videre påbegynde behandlingen men skal i stedet indlede en dialog med tilsyns-

Restrisiko

myndigheden efter proceduren i art. 36, jf. herom afsnit 2.4.6 nedenfor.

2.4.3. Krav til form og proces

Udover kravene til indholdet og enkelte yderligere krav i art. 35 og 36, er den dataansvarliges gennemførelse af konsekvensanalysen ikke underlagt nærmere formkrav. Den dataansvarlige vælger således selv processen og den nærmere dokumentation for konsekvensanalysens gennemførelse. Eftersom konsekvensanalysen skal kunne udledes til tilsynsmyndighederne skal den i praksis foreligge i skriftlig form.

Som udgangspunkt ingen krav til proces

I art. 29-gruppens retningslinjer for konsekvensanalyse (WP 248 rev. 01) oplistes i bilag 1 en række på daværende tidspunkt eksisterende rammer for konsekvensanalyser, bl.a. udarbejdet af en række af de europæiske tilsynsmyndigheder.

Art. 35 indeholder enkelte krav til konsekvensanalysens gennemførelse. Det følger for det første af stk. 2, at den dataansvarlige skal rådføre sig med sin databeskyttelsesrådgiver, hvis en sådan er udpeget, når der gennemføres en konsekvensanalyse. Bestemmelsen indeholder ikke nærmere krav til, hvordan databeskyttelsesrådgiveren skal involveres, og rådgiveren har ikke en egentlig "vetoret" i forhold til konsekvensanalysens konklusioner, men omvendt ligger det klart, at der skal ske en reel inddragelse af rådgiveren, som skal have mulighed for at forholde sig til konsekvensanalysen.

Rådførelse med databeskyttelsesrådgiver

Se også Datatilsynets afgørelse af 18. august 2022 i Helsingør/Chromebook-sagen (sag nr. 2020-431-0061), hvor Helsingør Kommune havde indsendt en omfattende konsekvensanalyse, der ikke indeholdt nogen bemærkninger fra kommunens eksterne databeskyttelsesrådgiver. Dette gav Datatilsynet anledning til at henstille til, "at Helsingør Kommune inkluderer eventuelle bidrag fra kommunens databeskyttelsesrådgiver i fremtidige konsekvensanalyser. Bemærkningerne fra databeskyttelsesrådgiveren om den rådgivning, der er en pligt efter databeskyttelsesforordningens artikel 35, stk. 2, er af væsentlig betydning med henblik på at dokumentere, at databeskyttelsesrådgiveren har haft lejlighed og rum til at udføre de opgaver, der påhviler denne efter databeskyttelsesforordningens artikel 39".

Efter art. 35, stk. 9, skal den dataansvarlige, når det er relevant, indhente de registreredes eller disses repræsentanternes synspunkter vedrørende den planlagt behandling. Dette skal dog ske “uden at det berører beskyttelse af kommercielle eller samfundsmæssige interesser eller behandlingsaktiviteternes sikkerhed”. Det vil bero på en konkret vurdering fra den dataansvarlige, om det vil være relevant at indhente synspunkter fra de registrerede eller deres repræsentanter, eller om en sådan indhentelse vil være i strid med de nævnte interesser. I relevanskravet ligger bl.a. en forudsætning om, at indhentelsen kan undlades, hvis det vil være uforholdsmæssigt byrdefuldt for den dataansvarlige. Det gælder her som andre steder, at dette krav ikke er opfyldt, blot fordi den dataansvarlige skal bruge tid eller penge på at indhente de registreredes synspunkter. Generelt må bestemmelsen dog forventes at efterlade et vist rum for at undlade høring af de registrerede, jf. også betænkning 1565/2017, s. 531, hvor det forventes, at bestemmelsen vil få begrænset praktisk betydning. I art. 29-gruppens retningslinjer for konsekvensanalyse (WP 248 rev. 01) anføres, at indhentelsen af synspunkter kan ske ved hjælp af forskellige midler afhængigt af situationen. Som eksempler angives spørgsmål til medarbejderrepræsentanter og almindelige undersøgelser, der sendes til den dataansvarliges fremtidige kunder. Den dataansvarlige er ikke forpligtet til at følge de registreredes synspunkter herunder et ønske om, at behandlingen ikke finder sted. Det anføres dog i retningslinjerne, at den dataansvarlige skal dokumentere sin begrundelse for ikke at følge de registrerede synspunkter. Tilsvarende bør den dataansvarlige ifølge retningslinjerne dokumentere sin begrundelse for ikke at høre de registrerede.

Høring af de registrerede

Det er alene den dataansvarlige, der er forpligtet til at udarbejde en konsekvensanalyse efter art. 35. Anvender den dataansvarlige en databehandler, vil det dog ofte være en forudsætning for at kunne gennemføre en konsekvensanalyse, at databehandleren bistår den dataansvarlige. Det følger af art. 28, stk. 3, litra f, at databehandleraftalen skal pålægge databehandleren en sådan pligt. Selv uden et eksplicit angivelse af en sådan forpligtelse i databehandleraftalen må det antages, at databehandlere vil være forpligtet til at bistå den dataansvarlige.

Konsekvensanalysen skal udarbejdes af den dataansvarlige

I præambelbetragtning 95 anføres, at databehandleren efter anmodning “bør” bistå den dataansvarlige, når det er nødvendigt for at den data-

ansvarlige kan overholde sine forpligtelser til at gennemføre en konsekvensanalyse.

I forbindelse med implementering af et nyt it-system, kan den dataansvarlige også tage udgangspunkt i de oplysninger og analyser, som producenten af programmet fremlægger. Det er dog under alle omstændigheder den dataansvarlige, der har ansvaret for, at konsekvensanalysen overholder kravene i art. 35.

2.4.4. Fornyet konsekvensanalyse

Hvis risikobilledet ændrer sig, skal den dataansvarlige foretage en fornyet konsekvensanalyse, jf. art. 35, stk. 11. Det kan være flere årsager til, at risikobilledet ændrer sig, herunder at behandlingens omfang udvides, at nye typer af personoplysninger behandles (hvilket er særlig relevant, hvis behandlingen fremadrettet omfatter følsomme oplysninger), eller at behandlingen gennemføres på nye måder, der f.eks. omfatter ny teknologi. I sin vejledning om konsekvensanalyse anfører Datatilsynet, at den dataansvarlige også skal vurdere behovet for en ny konsekvensanalyse, hvis formålet med behandlingen ændres. Når behandlingen sker via tredjepartstjenester, herunder cloudtjenester, kan ændringer i tredjepartstjenesten eller i vilkårene for at bruge den også medføre en pligt til gennemføre en ny konsekvensanalyse, når anvendelsen af tjenesten oprindeligt har krævet en konsekvensanalyse. I sin afgørelse af 18. august 2022 i Helsingør/Chromebook-sagen (sag nr. 2020-431-0061) udtalte Datatilsynet således, at det generelt er tilsynets opfattelse, at væsentlige ændringer i vilkår, software og applikationer almindeligvis udgør en væsentlig ændring af risikoen, som behandlingsaktiviteten udgør.

2.4.5. Retsvirkning af manglende overholdelse af art. 35

Iværksætter den dataansvarlige en behandling af personoplysninger uden at gennemføre en påkrævet konsekvensanalyse i overensstemmelse med art. 35, kan dette potentielt medfører en behandling i strid med forordningens materielle regler, f.eks. fordi den dataansvarlige ikke får implementeret sikkerhedsforanstaltninger, der er påkrævet efter art. 32 eller behandler oplysningerne i strid med de generelle principper i art. 5. I denne situation vil der forligge en overtrædelse af både

Bøde

art. 35 og den pågældende materielle bestemmelse. Ved fastlæggelsen af en eventuel bøde kan det tillægges betydning, at en ulovlig behandling er indledt uden den påkrævede konsekvensanalyse.

Potentielt er det dog muligt, at behandlingsaktiviteterne indrettes på en sådan måde, at behandlingen er lovlig, også selvom den dataansvarlige ikke har gennemført den forudgående påkrævede konsekvensanalyse. I denne situation vil den dataansvarlige kunne sanktioneres alene for overtrædelsen af art. 35. Det følger således af art. 83, stk. 4, litra a, at en overtrædelse af (bl.a.) art. 35 kan straffe med en administrativ bøde på op til 2 % af den samlede globale omsætning. Det følger ligeledes af DBL § 41, stk. 1, nr. 1, at en overtrædelse af art. 35 kan straffes med bøde eller fængsel indtil 6 måneder. I praksis må det dog nok forventes at være sjældent, at en dataansvarlig ifalder bødestraf for en manglende konsekvensanalyse, hvis behandlingsaktiviteten er lovlig.

Som drøfte ovenfor er det tvivlsomt, om den dataansvarlige kan sanktioneres for en manglende overholdelse af pligten til at sikre databeskyttelse gennem design efter art. 25, stk. 1, i situationer, hvor der endnu ikke påbegyndt en behandling af personoplysninger. Denne situation kan ikke opstå i relation til art. 35, da pligten til at gennemføre en konsekvensanalyse gælder "forud" for behandlingen af personoplysninger. Først på det tidspunkt, hvor behandlingen af personoplysninger indledes, er den dataansvarlige således forpligtet til at have gennemført konsekvensanalysen. Det indebærer, at den dataansvarlige ikke kan overtræde art. 35, før behandlingen indledes.

I praksis er den væsentligste konsekvens ved manglende overholdelse af art. 35 nok oftere end bødesanktionen, at tilsynsmyndigheden kan pålægge den dataansvarlige at ophøre med behandlingen, indtil der er gennemført en konsekvensanalyse, der indebærer en tilstrækkelig reduktion af risikoen. Tilsynsmyndighederne har således efter art. 58, stk. 2, litra e og f både mulighed for at påbyde den dataansvarlige at lovliggøre behandlingen og forbyde behandlingen.

Påbud og forbud

2.4.6. Mulighed for at foretage behandling, når der er høj risiko for de registrerede

Konsekvensanalysen skal gerne føre til, at den dataansvarlige får etableret foranstaltninger, der indebærer, at den påtænkte behandling ikke medfører en høj risiko for de registrerede. Der kan dog være situationer, hvor den dataansvarlige efter en gennemført konsekvensanalyse må konstatere, at det ikke er muligt at nedbringe risikoen så meget, at der ikke længere er høj risiko for de registrerede. Disse situationer er reguleret i art. 36, der forpligter den dataansvarlige til at tage kontakt til tilsynsmyndigheden, inden behandlingen igangsættes. Art. 36, stk. 1, har følgende ordlyd:

Pligt til at høre
tilsynsmyndig-
heden

Den dataansvarlige hører tilsynsmyndigheden inden behandling, såfremt en konsekvensanalyse vedrørende databeskyttelse foretaget i henhold til artikel 35 viser, at behandlingen vil føre til høj risiko i mangel af foranstaltninger truffet af den dataansvarlige for at begrænse risikoen.

Ordlyden synes umiddelbart at pålægge den dataansvarlige at høre tilsynsmyndigheden i alle situationer, hvor behandlingen ville føre til en høj risiko uden afværgeforanstaltninger, dvs. også i situationer, hvor den dataansvarlige er i stand til at reducere risikoen, så den ikke længere er høj. Det er dog formentlig hensigten med bestemmelsen, at den alene skal finde anvendelse, når den dataansvarlige ikke er i stand til at nedbringe risikoen. Viser konsekvensanalysen, at der er en høj risiko for de registrerede, men at denne risiko gennem foranstaltninger kan nedbringes, så den ikke længere er høj, skal den dataansvarlige således ikke kontakte tilsynsmyndigheden, inden behandlingen påbegyndes.

Dette følger også af præambelbetragtning 94, 1. pkt.: "Såfremt en konsekvensanalyse vedrørende databeskyttelse viser, at en behandling uden garantier, sikkerhedsforanstaltninger og mekanismer til at begrænse risikoen vil føre til en høj risiko for fysiske personers rettigheder og frihedsrettigheder, og den dataansvarlige mener, at risikoen ikke kan begrænses gennem rimelige midler for så vidt angår tilgængelig teknologi og gennemførelsesomkostninger, bør tilsynsmyndigheden høres inden indledning af behandlingsaktiviteterne".

I forbindelse med høringen skal den dataansvarlige sende tilsynsmyndigheden konsekvensanalysen og en række andre oplysninger, jf. art. 36, stk. 1 og 3.

Finder tilsynsmyndigheden på denne baggrund, at den planlagte behandling vil overtræde forordningen, navnlig den dataansvarlige ikke tilstrækkeligt har identificeret eller begrænset risikoen, skal myndigheden rådgive den dataansvarlige om, hvordan behandlingen eventuelt kan gøres lovlig. Tilsynsmyndighedens rådgivning skal foreligge inden for otte uger, der dog kan forlænges med yderligere seks uger. I modsat fald kan den dataansvarlige iværksætte behandlingen, idet tilsynsmyndigheden dog ikke herved er afskåret fra efterfølgende at erklære behandlingen ulovlig.

Tilsynsmyndighedens rådgivning til den dataansvarlige

Hvis tilsynsmyndigheden i sin rådgivning kan anvise en måde at nedbringe risikoen på, så den ikke længere er høj, vil den dataansvarlige herefter kunne påbegynde behandlingen. Hvis heller ikke tilsynsmyndigheden kan anvise en sådan mulighed, skal det afgøres, om dataansvarlige i denne situation må iværksætte behandlingen. Forordningen indeholder således ikke et ubetinget forbud mod behandling, når der er en høj risiko for de registrerede, som det ikke er muligt at nedbringe. Tilsynsmyndighedernes beføjelser i denne situation følger af art. 36, stk. 2, 1. pkt.:

Behandling hvor der består en høj risiko

Hvis tilsynsmyndigheden finder, at den planlagte behandling omhandlet i stk. 1 overtræder denne forordning, navnlig hvis den dataansvarlige ikke tilstrækkeligt har identificeret eller begrænset risikoen, skal tilsynsmyndigheden inden for en periode på op til otte uger efter modtagelse af anmodningen om høring give den dataansvarlige og, hvor det er relevant, databehandleren skriftlig rådgivning og kan i den forbindelse anvende enhver af sine beføjelser, jf. artikel 58.

Det er ikke helt klart, om formuleringen "hvis tilsynsmyndigheden finder, at den planlagte behandling omhandlet i stk. 1 overtræder denne forordning navnlig hvis den dataansvarlige ikke tilstrækkeligt har identificeret eller begrænset risikoen...", indebærer, at bestemmelsen giver tilsynsmyndighederne hjemmel til at forbyde en behandling alene af den grund, at behandlingen indebærer en risiko, der efter tilsynsmyndighedens vurdering er uacceptabel høj, også efter den dataansvarlige har foretaget de mulige mitigerende foranstaltninger, eller

om tilsynsmyndighedens mulighed for at nedlægge forbud forudsætter, at behandlingen strider mod andre af forordningens bestemmelser. Det må nok antages, at bestemmelsen giver tilsynsmyndighederne mulighed for at forbyde en behandling, som tilsynsmyndigheden finder indebærer en uacceptabel høj risiko. I samme retning Rigaudias og Spina i Kuner m.fl. (red.), *The EU General Data Protection Regulation (GDPR)*, s. 684, der anfører, at tilsynsmyndighedernes vurdering bør tage udgangspunkt i, om behandlingen er nødvendig og proportional.

Formentlig tilsvarende Art. 29-gruppens retningslinjer for konsekvensanalyse (WP 248 rev. 01), s. 22, hvor der gives eksempler på en “uacceptabel høj residualrisiko”, hvilket dels må indebære, at der er en høj residualrisiko også kan være acceptabel og formentlig, at det er tilsynsmyndigheden, som vurderer dette. De konkrete eksempler, der nævnes i retningslinjerne, giver kun begrænset vejledning: “tilfælde, hvor de registrerede kan udsættes for betydelige eller endog uoprettelige konsekvenser, som de muligvis ikke kan overvinde (f.eks.: uretmæssig adgang til data, som kan føre til en trussel mod de registreredes liv, afskedigelse, økonomisk tab), og/eller når det virker indlysende, at risikoen vil indtræffe (f.eks.: når det ikke er muligt at begrænse antallet af personer, der har adgang til dataene på grund af de anvendte metoder til udveksling, anvendelse eller distribution, eller når en velkendt sårbarhed ikke afhjælpes)”.

2.5. Forholdet mellem art. 24, 25, stk. 1, 32 og 35

Som det er fremgået pålægger bestemmelserne i art. 24, 25, stk. 1, 32 og 35 alle den dataansvarlige at gennemføre en risikovurdering. Risikovurderingerne af bestemmelserne har forskellige udgangspunkter men er også delvist overlappende, og det kan være vanskeligt at gennemskue og overskue samspillet mellem bestemmelserne. I det følgende gives et kort overblik over dette samspil.

Man kan indledningsvist sonde mellem på den ene side de tre bestemmelser i art. 24, 25, stk. 1 og 32, der pålægger den dataansvarlige at gennemføre en “almindelig” risikovurdering, dvs. en risikovurdering, hvor der ikke er en høj risiko for de registrerede og på den anden side bestemmelsen i art. 35, der pålægger den dataansvarlige at foretage en risikovurdering, når der er en høj risiko.

Ser man herefter på de tre bestemmelser i art. 24, 25, stk. 1 og 32 tager de udgangspunkt i den samme type risikovurdering og ordlyden i bestemmelserne er også delvist sammenfaldende i deres regulering af risikovurderingen. Deres forskellige udgangspunkter er dog klare nok: Art. 24 indeholder den brede forpligtelse for dataansvarlige til at sikre og kunne påvise, at forordningen overholdes. Art. 25, stk. 1, forpligter den dataansvarlige til at tænke databeskyttelse ind allerede fra start af, når der designes og udvikles systemer og forretningsgange. Art. 32 forpligter den dataansvarlige til at etablere sikkerhedsforanstaltninger mod kompromittering af personoplysningernes fortrolighed, integritet og tilgængelighed. Både art. 24 og 25, stk. 1, fokuserer på overholdelse af forordningens *retlige* krav, mens art. 32 fokuserer på overholdelse af *sikkerhedskrav*. Lidt forenklet sagt handler art. 24 og 25, stk. 1, om juridisk sikkerhed (eller compliance), mens art. 32 handler om informationssikkerhed (ofte dog i den databeskyttelsesretlige kontekst benævnt "behandlingssikkerhed" for at markere forskellen til den generelle informationssikkerhedsdisciplin, der omhandler beskyttelse af al form for information, og som tager sigte på at beskytte organisationen og ikke den registrerede). Hermed består der en helt grundlæggende forskel på art. 24 og 25, stk. 1 på den ene side og art. 32 på den anden side. Denne forskel kan sløres af, at det for alle tre bestemmelser er den samme risiko, der skal håndteres (risikoen for de registreredes rettigheder), og den samme type foranstaltninger, der potentielt kan anvendes for at reducere risikoen (tekniske og organisatoriske foranstaltninger). Hertil kommer, at et brud på behandlingssikkerheden ofte også vil udgøre en ulovlig behandling, hvorved der foreligger en situation, der både omfattes af art. 24/25, stk. 1 og art. 32.

Forholdet mellem art. 24, 25, stk. 1, og 32

Da art. 32 er *lex specialis*-bestemmelsen om sikkerhedsforanstaltninger, kan det ikke antages, at art. 24 eller 25, stk. 1, kan indebære andre krav til sikkerhedsforanstaltninger, end dem der følger af art. 32, tilsvarende Korfits Nielsen og Lotterup, Databeskyttelsesloven og databeskyttelsesforordningen, 2020, s. 595.

Art. 24 og 25, stk. 1, har begge til formål at reducere risikoen for en utilsigtet ulovlig behandling, og begge bestemmelser forpligter den dataansvarlige til at gennemføre passende tekniske og organisatoriske

Forholdet mellem art. 24 og art. 25, stk. 1

foranstaltninger med henblik på at sikre overholdelse af forordningens krav og løbende foretage vurdering heraf.

Den primære forskel på de to bestemmelser er, at art. 24 på et helt generelt plan pålægger den dataansvarlige at etablere foranstaltninger for at sikre behandlingens lovlighed og kunne dokumentere dette, mens art. 25, stk. 1, udelukkende omhandler foranstaltninger, der integreres i designet af systemer og processer ("designforanstaltninger"). Dette har bl.a. betydning for, hvornår forpligtelsen indtræder. Det indledende design af et it-system vil ofte ske måneder eller år før, systemet er færdigudviklet og taget i brug, og den dataansvarlige vil allerede på dette tidspunkt blive forpligtet efter art. 25, stk. 1. Dette vil ikke gælde efter art. 24, der alene forudsætter, at foranstaltningerne er etableret på det tidspunkt, hvor behandlingen påbegyndes.

Art. 25, stk. 1, forudsætter endvidere, i modsætning til art. 24, at der ved fastsættelsen af de passende foranstaltninger skal tages hensyn til det aktuelle tekniske sikkerhedsniveau og implementeringsomkostningerne. Forskellen skyldes formentlig, at systemudvikling ligger i kernen af art. 25, mens art. 24 i højere grad er tænkt som en bestemmelse, der mere generelt fastslår, at den dataansvarlige skal sikre og dokumentere overholdelsen af forordningen. Inddragelsen af det aktuelle sikkerhedsniveau og implementeringsomkostninger findes til gengæld tilsvarende i art. 32.

Det må antages, at en overtrædelse af art. 25, stk. 1, i mange situationer også vil være en overtrædelse af art. 24, hvilket er en naturlig følge af, at art. 24 har karakter af generalklausul. Ud fra *lex specialis*-betragtninger vil det i disse situationer være mest nærliggende at behandle forholdet efter art. 25, stk. 1, hvilket dog næppe har stor praktisk betydning.

Art. 35 forpligter i lighed med de øvrige tre bestemmelser den dataansvarlige til at foretage en risikovurdering med udgangspunkt i de registreredes rettigheder. Bestemmelsen forpligter ligeledes den dataansvarlige til at etablere foranstaltninger for at reducere den identificerede risiko. Selvom bestemmelsen ikke udtrykkeligt anvender begrebet "tekniske og organisatoriske foranstaltninger", som de øvrige bestemmelser gør, er dette næppe udtryk for en realitetsforskel i de foranstaltninger, der kan bringes i anvendelse. Art. 35 (med den tilhørende art. 36) adskiller sig på tre punkter væsentligt fra de øvrige bestemmelser.

Forholdet mellem art. 35 og de tre øvrige bestemmelser

For det første finder den kun anvendelse, når behandlingsaktiviteten indebærer en høj risiko for de registrerede. For det andet omfatter den både håndtering af risici ved brud på behandlingssikkerheden og ved utilsigtet ulovlig behandling, hvor de øvrige bestemmelser enten omfatter ulovlig behandling (art. 24 og 25, stk. 1) eller brud på behandlingssikkerheden (art. 32). For det tredje indebærer art. 35 sammen med art. 36, at tilsynsmyndighederne har hjemmel til at forbyde en behandling alene af den grund, at behandlingen indebærer en uacceptabel høj risiko. En tilsvarende hjemmel har tilsynsmyndighederne ikke efter de tre andre bestemmelser.

3. Den dataansvarligs pligt til at kunne påvise behandlingens lovlighed

Efter forordningens art. 24 skal den dataansvarlige ”sikre” og ”være i stand til at påvise”, at behandlingen er i overensstemmelse med forordningen. Kravet om, at den dataansvarlig skal sikre behandlingens lovlighed indebærer som beskrevet ovenfor, at den dataansvarlige må foretage en indledende lovlighedsvurdering. Kravet om, at den dataansvarlig skulle kunne påvise, at behandlingen er lovlig, udgør et selvstændigt krav, der er sideordnet kravet om at sikre lovlighed. Det følger tilsvarende af art. 5, stk. 2, at den dataansvarlige er ansvarlig for og skal kunne påvise, at de generelle behandlingsprincipper i art. 5, stk. 1, overholdes.

Forordningen indeholder ikke nærmere krav til, hvordan den dataansvarlige skal kunne påvise lovligheden. I mange tilfælde vil kravet nok indebære, at den dataansvarlige udarbejder skriftlig dokumentation, herunder eksempelvis for at kunne påvise, at der er gennemført den fornødne lovlighedsvurdering efter art. 24. Forordningens manglende angivelse af nærmere krav indebærer dog, at den dataansvarlige må have ganske stor frihed til at selv at fastlægge, hvordan påviseligheden sikres. Kravene må antages at afhænge af behandlingssituationen, således at der er højere krav til, hvordan lovlighed skal kunne påvises, når en behandling indebærer en høj risiko for de registrerede, end når der er lav risiko. Dette er i overensstemmelse med den risikobaserede tilgang i art. 24.

4. Fortegnelse over behandlingsaktiviteter – art. 30

Efter det tidligere persondatadirektiv skulle dataansvarlige i visse situationer anmelde behandlingen af personoplysninger til den nationale tilsynsmyndighed. Anmeldelsen skulle indeholde en fortegnelse over de anmeldte behandlingsaktiviteter. Det var imidlertid en udbredt opfattelse, at anmeldelsesordningen ikke fungerede hensigtsmæssigt og ikke gav den beskyttelse, som var dens formål.

Med forordningen er derfor indført en anden ordning, hvorefter dataansvarlige (og databehandlere) skal føre en intern fortegnelse over deres behandlingsaktiviteter. Forpligtelsen hertil fremgår af art. 30, der i stk. 1 fastlægger, hvilke typer af oplysninger fortegnelsen skal indeholde:

Pligt til at føre fortegnelse for dataansvarlige

- a. navn på og kontaktoplysninger for den dataansvarlige og, hvis det er relevant, den fælles dataansvarlige, den dataansvarliges repræsentant og databeskyttelsesrådgiveren
- b. formålene med behandlingen
- c. en beskrivelse af kategorierne af registrerede og kategorierne af personoplysninger
- d. de kategorier af modtagere, som personoplysningerne er eller vil blive videregivet til, herunder modtagere i tredjelande eller internationale organisationer
- e. hvor det er relevant, overførsler af personoplysninger til et tredjeland eller en international organisation, herunder angivelse af dette tredjeland eller denne internationale organisation og i tilfælde af overførsler i henhold til artikel 49, stk. 1, andet afsnit, dokumentation for passende garantier
- f. hvis det er muligt, de forventede tidsfrister for sletning af de forskellige kategorier af oplysninger
- g. hvis det er muligt, en generel beskrivelse af de tekniske og organisatoriske sikkerhedsforanstaltninger omhandlet i artikel 32, stk. 1.

Fortegnelsen skal både anvendes til at sikre den dataansvarliges overholdelse af forordningens regler og som dokumentation herfor, hvis tilsynsmyndigheden ønsker at føre kontrol med den dataansvarlige. Det følger således også af art. 30, stk. 4, at den dataansvarlige har

Tilsynsmyndighedens adgang til fortegnelsen

pligt til at stille fortegnelsen til rådighed for tilsynsmyndigheden. Dette forudsætter i praksis, at fortegnelsen foreligger i et fysisk format, og efter art. 30, stk. 3, skal fortegnelsen foreligge skriftligt, herunder elektronisk.

Pligten til at føre en fortegnelse gælder ligeledes for databehandlere (med enkelte justeringer i kravene til indholdet), jf. art. 30, stk. 2.

Databehandlere

Det kan være ressourcekrævende at føre og løbende opdatere en fortegnelse, og dette ressourceforbrug vil ikke altid stå mål med effekten, hvis den dataansvarlige (eller databehandleren) er en mindre organisation, der ikke i øvrigt foretager nogen væsentlig behandling af personoplysninger. Foretagender og organisationer med mindre end 250 ansatte er derfor som udgangspunkt undtaget fra kravet om at føre en fortegnelse, jf. art. 30, stk. 5. Begreberne “foretagender” og “organisationer” omfatter private virksomheder og formentlig også alle andre former for private parter. Derimod gælder undtagelsen ikke for offentlige myndigheder, som derfor altid er undergivet kravet om at føre en fortegnelse. Undtagelsen gælder ikke, hvis behandlingen indebærer en sandsynlig risiko for den registreredes rettigheder og frihedsrettigheder, behandlingen ikke er lejlighedsvis, eller behandlingen omfatter følsomme oplysninger eller oplysninger vedrørende straffedomme og lovovertrædelser. I disse situationer skal organisationen således føre en fortegnelse, selvom den har mindre end 250 ansatte. I praksis betyder det, at en virksomhed kan være forpligtet til at føre fortegnelse over nogle typer af behandlinger, men kan undlade at gøre det for andre typer af behandlinger. Behandling af oplysninger om medarbejdere vil eksempelvis næppe være “lejlighedsvis”, da denne behandling må antages at ske løbende og hyppigt. En virksomhed med under 250 ansatte vil derfor være forpligtet til at føre fortegnelse over denne form for behandling, men muligvis være undtaget fra kravet for andre typer af behandling.

Undtagelse

Datatilsynet har udarbejdet en vejledning om fortegnelser efter art. 30. Art. 29-gruppen har udarbejdet et kort papir om undtagelserne efter art. 30, stk. 5, der er tiltrådt af EDPB.

5. Pligten til brug af en databeskyttelsesrådgiver – art. 37-39

Forordningen pålægger offentlige myndigheder og nogle typer af private virksomheder at udpege og bruge en databeskyttelsesrådgiver, der skal fungere som en intern rådgiver om databeskyttelsesspørgsmål i organisationen og dermed bistå organisationen med at efterleve forordningens krav. Databeskyttelsesrådgiverfunktionen er dermed et led i forordningens bestræbelser på at skabe “ansvarlighed”.

Betegnelsen “DPO” anvendes ofte synonymt med databeskyttelsesrådgiver. Betegnelsen er en forkortelse af den engelsksprogede betegnelse for databeskyttelsesrådgiveren, “Data Protection Officer”.

5.1. Pligten til udpegning – art. 37

Pligten til at udpege en databeskyttelsesrådgiver følger af forordningens art. 37, stk. 1:

Den dataansvarlige og databehandleren udpeger altid en databeskyttelsesrådgiver, når:

- a) behandling foretages af en offentlig myndighed eller et offentligt organ, undtagen domstole, der handler i deres egenskab af domstol
- b) den dataansvarliges eller databehandlerens kerneaktiviteter består af behandlingsaktiviteter, der i medfør af deres karakter, omfang og/eller formål kræver regelmæssig og systematisk overvågning af registrerede i stort omfang, eller
- c) den dataansvarliges eller databehandlerens kerneaktiviteter består af behandling i stort omfang af særlige kategorier af oplysninger, jf. artikel 9, og personoplysninger vedrørende strafdomme og lovovertrædelser, jf. artikel 10.

Litra a fastslår, at offentlige myndigheder, med undtagelse af domstolene, altid har pligt til at udpege en databeskyttelsesrådgiver. Dette gælder således for alle statslige institutioner, regioner og kommuner. Også nogle typer af selvejende institutioner vil være omfattet, herunder universiteter og gymnasier. Den omstændighed, at en offentlig myndighed har outsourcet størstedelen af sin persondatabehandling til

Offentlige
myndigheder

en privat leverandør, ændrer ikke på forpligtelsen til at udpege en databeskyttelsesrådgiver for myndigheden.

Private virksomheder er kun forpligtet til at udpege en databeskyttelsesrådgiver, når betingelserne efter litra b eller c er opfyldt. I praksis betyder det, at de fleste virksomheder ikke er forpligtet til at udpege en databeskyttelsesrådgiver.

Private
virksomheder

Virksomheder, der ikke er underlagt denne pligt, kan vælge frivilligt at udpege en databeskyttelsesrådgiver. I så fald gælder alle forordningens krav til databeskyttelsesrådgivere for den pågældende. Ønsker en virksomhed at have tilknyttet en tilsvarende funktion i virksomheden uden at være underlagt forordningens krav til databeskyttelsesrådgivere, må virksomheden derfor give den pågældende medarbejder en anden titel.

Det følger af de to bestemmelser, at den dataansvarliges “kerneaktivitet” skal bestå af enten (a) behandlingsaktiviteter, der i medfør af deres karakter, omfang og/eller formål kræver regelmæssig og systematisk overvågning af registrerede i stort omfang, eller (b) af behandling i stort omfang af følsomme oplysninger eller oplysninger vedrørende straffedomme og lovovertrædelser. Begrebet “kerneaktivitet” omfatter ikke den gængse behandling af medarbejderoplysninger o.lign., som alle private virksomheder foretager, eller behandling af almindelige kundeoplysninger. Behandling af denne type oplysninger anses for en biaktivitet for virksomheden. Derimod vil det udgøre en kerneaktivitet, hvis virksomhedens egentlige produkt består i behandling af personoplysninger, f.eks. virksomheder der udbyder marketingundersøgelser. Behandlingen af personoplysninger vil også udgøre en kerneaktivitet, hvis virksomhedens produkt i øvrigt hænger uløseligt sammen med behandlingen. Dette vil eksempelvis være tilfældet for forsikrings-selskaber og privathospitaler, hvor behandling af oplysninger om forsikringstagere og patienter godt nok ikke er selve produktet, men dog tæt integreret med produktet.

– “kerneaktivitet”

Begrebet “regelmæssig systematisk overvågning” omfatter eksempelvis adfærdsbaseret annoncering og drift af telenet med logning af brugeres opkald mv. Et skadesforsikringsselskab eller et privathospital er eksempler på virksomheder, der behandler følsomme oplysninger. Eftersom behandlingen af de følsomme oplysninger skal udgøre virksomhedens kerneaktivitet, vil det langt fra være enhver behandling af

– “regelmæssig
systematisk
overvågning”
eller behandling
af følsomme
oplysninger

følsomme oplysninger, der medfører en forpligtelse til at udpege en databeskyttelsesrådgiver.

Det er endvidere et fælleskrav for bestemmelserne i litra b og c, at den pågældende behandling af personoplysninger sker i stort omfang. Art. 29-gruppen har i WP 243 rev. 01, Retninglinjer for databeskyttelsesrådgivere (tiltrådt af EDPB ved Endorsement 1/2018), s. 8 anført følgende fire kriterier i vurderingen af, om behandlingen sker "i stort omfang": (1) antallet af registrerede, (2) antallet af personoplysninger, (3) hvor lang tid oplysningerne behandles og (4) den geografiske udstrækning af behandlingen. Datatilsynet antager i sin vejledning om databeskyttelsesrådgivere, s. 9, at eksempelvis et mindre regionalt forsikringsselskab ikke behandler oplysninger i stort omfang, hvorimod et landsdækkende forsikringsselskab gør.

Databeskyttelsesrådgiveren kan både være en intern ansat og en ekstern part, der udfylder funktionen på konsulentbasis, jf. art. 37, stk. 6. Både private virksomheder og offentlige myndigheder kan i et vist omfang dele en databeskyttelsesrådgiver med andre virksomheder henholdsvis offentlige myndigheder, jf. art. 37, stk. 2 og 3.

Pligten til at udpege en databeskyttelsesrådgiver gælder også for databehandlere, der opfylder de anførte kriterier i art. 37.

– "i stort omfang"

Intern eller ekstern og mulighed for at dele databeskyttelsesrådgiver

Databehandlere

5.2. Databeskyttelsesrådgiverens rolle, stilling og opgaver – art. 38 og 39

Det følger af art. 38, stk. 1 og 2, at den dataansvarlige skal sikre, at databeskyttelsesrådgiveren inddrages tilstrækkeligt og rettidigt i alle spørgsmål vedrørende beskyttelse af personoplysninger og gives de ressourcer, adgang til oplysninger mv., der er nødvendige for at databeskyttelsesrådgiveren kan udføre sine opgaver. Det følger endvidere af art. 38, stk. 3, at databeskyttelsesrådgiveren ikke handler efter instruks og ikke må afskediges eller i øvrigt sanktioneres for at udføre sine opgaver. Databeskyttelsesrådgiveren rapporterer direkte til det øverste ledelsesniveau hos den dataansvarlige. Efter art. 38, stk. 6, må databeskyttelsesrådgiveren kun udføre andre opgaver, når dette ikke medfører en interessekonflikt med arbejdet som databeskyttelsesrådgiver.

Databeskyttelsesrådgiverens særlige rolle

Disse krav afspejler databeskyttelsesrådgiverens særlige rolle i organisationen. På den ene side skal den pågældende fungere som en ressource i organisationen, der skal bistå med rådgivning om databeskyttelsesspørgsmål. På den anden side indeholder rollen også et kontrolelement og en pligt til at indskærpe eventuelle ulovligheder for den øverste ledelse og i øvrigt fungere som kontaktperson for tilsynsmyndigheden og de registrerede, som efter art. 38, stk. 4, kan kontakte databeskyttelsesrådgiveren vedrørende alle spørgsmål om behandling af deres oplysninger og om udøvelse af deres rettigheder. Dette forudsætter en særlig beskyttelse og sikring af, at der ikke lægges hindringer i vejen for en "besværlig" databeskyttelsesrådgiver. Databeskyttelsesrådgiverens særlige rolle sætter også grænser for, hvem i organisationen der kan varetage funktionen. EDPB antager således, at kravet om uafhængighed indebærer, at funktionen ikke kan varetages af seniorledelsen (for eksempel administrerende direktør, teknisk direktør, økonomidirektør, marketingchef, personalechef eller ledere af it-afdelinger), og at det samme gælder andre stillinger, der indebærer beslutninger om databehandlingens formål og hjælpemidler, WP 243 rev. 01, s. 17.

Databeskyttelsesrådgiverens opgaver følger af art. 39. Det følger heraf, at databeskyttelsesrådgiveren skal underrette og rådgive den dataansvarlige og de ansatte, der behandler personoplysninger, om deres forpligtelser i henhold til forordningen og nationale databeskyttelsesregler og anden EU-ret eller national ret i medlemsstaterne om databeskyttelse. Databeskyttelsesrådgiveren skal endvidere overvåge den dataansvarliges overholdelse af forordningen, nationale databeskyttelsesregler og den dataansvarliges interne databeskyttelsespolitikker. Endvidere skal databeskyttelsesrådgiveren involveres i udarbejdelsen af konsekvensanalyser og samarbejde med tilsynsmyndigheden.

Databeskyttelses-
rådgiverens
opgaver

Kapitel 9

Overførsel til tredjelande

Når en behandling af personoplysninger omfattes af databeskyttelsesforordningen, opnår den registrerede den beskyttelse, der følger af forordningens regler. Såfremt behandlingen omfattes af reglerne i et land uden for EU, vil beskyttelsen følge reglerne i dette land. Det beskyttelsesniveau, der gælder efter forordningen, ville derfor kunne undermineres, hvis dataansvarlige frit kunne overføre personoplysninger om EU-borgere til andre lande med et lavere beskyttelsesniveau. For at undgå dette indeholder forordningen særlige regler, der skal være opfyldt, før oplysninger må overføres til tredjelande (dataeksport).

Disse regler gælder ikke overførsel inden for EU. Med forordningen sikres et ensartet beskyttelsesniveau i medlemslandene, således at der frit kan udveksles personoplysninger inden for EU. Denne mulighed er sammen med beskyttelsen af personoplysninger hovedformålet med forordningen (der illustrativt har den officielle titel “forordning om beskyttelse af fysiske personer i forbindelse med behandling af personoplysninger og om fri udveksling af sådanne oplysninger [...]”). Selvom forordningen som beskrevet giver medlemsstaterne et vist nationalt råderum, og selvom der blandt medlemsstaterne er forskellige fortolkninger af en række af forordningens bestemmelser, er forskellene ikke større, end at beskyttelsesniveauet i alt væsentligt er identisk i medlemsstaterne.

Selvom videregivelse af oplysninger inden for EU ikke omfattes af de særlige regler om overførsel til tredjelande, vil en sådan videregivelse

stadig udgøre en behandling, der skal overholde de almindelige behandlingsregler.

Reglerne om overførsel til tredjelande følger af forordningens kapitel V, art. 44-50.

Forordningens art. 44 fastlægger det overordnede generelle princip for overførsel af personoplysninger til tredjelande:

Enhver overførsel af personoplysninger, som underkastes behandling eller planlægges behandlet efter overførsel til et tredjeland eller en international organisation, må kun finde sted, hvis betingelserne i dette kapitel med forbehold af de øvrige bestemmelser i denne forordning opfyldes af den dataansvarlige og databehandleren, herunder ved videreoverførsel af personoplysninger fra det pågældende tredjeland eller den pågældende internationale organisation til et andet tredjeland eller en anden international organisation. Alle bestemmelserne i dette kapitel anvendes for at sikre, at det beskyttelsesniveau, som fysiske personer garanteres i medfør af denne forordning, ikke undermineres.

Det følger af bestemmelsens sidste sætning, at alle bestemmelserne om tredjelandsoverførsler i kap. V anvendes for at sikre, at forordningens beskyttelsesniveau ikke undermineres. Dette er den helt overordnede standard, som tredjelandsbestemmelserne skal overholde og forstås i lyset af.

Se således også EU-Domstolen i *Schrems II*, C-311/18, præmis 92: "Selv om databeskyttelsesforordningens artikel 46 ikke nærmere angiver karakteren af de krav, der følger af denne henvisning til 'fornødne garantier', til 'rettigheder, som kan håndhæves', og til 'effektive retsmidler', skal det bemærkes, at denne artikel findes i forordningens kapitel V og derfor skal læses i sammenhæng med artikel 44, der har overskriften 'Generelt princip for overførsler', og som bestemmer, at '[a]lle bestemmelserne i dette kapitel anvendes for at sikre, at det beskyttelsesniveau, som fysiske personer garanteres i medfør af denne forordning, ikke undermineres'. Dette beskyttelsesniveau skal derfor være garanteret, uanset hvilken bestemmelse i det nævnte kapitel en overførsel af personoplysninger til et tredjeland er baseret på".

Kravet om, at overførslen skal opfylde betingelserne i forordningens kap. V, indebærer i praksis, at der skal findes hjemmel til overførslen i enten art. 45 (overførsler baseret på en afgørelse om tilstrækkeligt

beskyttelsesniveau), art. 46 (overførsler omfattet af fornødne garantier) eller art. 49 (undtagelser i særlige situationer). Disse tre hjemmelsgrundlag behandles i det følgende. Indledningsvist beskrives først de to centrale begreber “overførsel” og “tredjeland”.

Reglerne gælder både for overførsler til tredjelande og til internationale organisationer. Overførsler til tredjelande har langt den største praktiske betydning og den type overførsler, der fokuseres på i det følgende.

1. Begreberne “overførsel” og “tredjeland”

Forordningens kap. V har overskriften “Overførsler til personoplysninger til tredjelande eller internationale organisationer”. Allerede heraf fremgår, at begreberne “overførsel” og “tredjeland” er centrale og sætter rammen for, hvornår kapitlets regler om eksport af personoplysninger finder anvendelse.

1.1. Overførsel

På trods af sin centrale betydning, er overførselsbegrebet ikke defineret i forordningen, og der foreligger kun en enkelt ældre afgørelse fra EU-Domstolen, *Lindqvist*-sagen, C-101/01, der fortolker begrebet under det tidligere persondatadirektiv. Dommen er afsagt i en tid (2003), hvor forholdene var så forskellige fra dem, der gælder i dag, at den ikke kan tillægges præjudikatsværdi uden for sit helt konkrete sagsområde (offentliggørelse af oplysninger på en hjemmeside, der omtales nedenfor).

EDPB har i Guidelines 05/2021 (høringsversion) givet sit bud på forståelsen af overførselsbegrebet. Det er langt fra alle de spørgsmål, som overførselsbegrebet giver anledning til, der behandles i vejledningen, men den etablerer dog et udgangspunkt for fastlæggelsen af begrebet og en række bidrag til fortolkningen heraf. Som det fremgår af det følgende, fokuseres i vejledningen navnlig på betydningen af de forskellige aktørers roller i forbindelse med en tredjelandsoverførsel og kun i begrænset omfang på, hvilke former for tilrådgivelsesstilling, der udgør en overførsel. Om sidstnævnte findes fortolkningsbidrag i Datatilsynets vejledning om tredjelandsoverførsler, der også nævnes i det følgende.

I sin vejledning opstiller EDPB følgende tre kumulative betingelser for, at der foreligger en overførsel i forordningens forstand (angivet her på engelsk, da vejledningen endnu kun foreligger i en høringsversion og dermed kun på engelsk):

1. A controller or a processor is subject to the GDPR for the given processing.
2. This controller or processor (“exporter”) discloses by transmission or otherwise makes personal data, subject to this processing, available to another controller, joint controller or processor (“importer”).
3. The importer is in a third country or is an international organisation, irrespective of whether or not this importer is subject to the GDPR in respect of the given processing in accordance with Article 3.

En overførsel forudsætter således, at en dataansvarlig eller databehandler (ofte også benævnt “dataeksportør”) foretager en behandling af personoplysninger omfattet af forordningen ved gennem transmission eller på anden måde at gøre oplysningerne tilgængelige for en anden dataansvarlig, fælles dataansvarlig eller databehandler (ofte også benævnt “dataimportør”), der befinder sig i et tredjeland, uanset om importørens behandling af de overførte oplysninger omfattes af forordningen.

I sin vejledning om overførsel af personoplysninger til tredjelande formulerer Datatilsynet det således, at der “som udgangspunkt vil være tale om en overførsel til et tredjeland, når de personoplysninger, du som dataansvarlig eller databehandler behandler, forlader EU/EØS eller gøres tilgængelige uden for EU/EØS”.

At dataeksportørens behandling i form af transmission mv. skal være omfattet af forordningen indebærer i praksis, at behandlingen skal være omfattet af forordningens territoriale anvendelsesområde i art. 3. Dette krav vil være opfyldt efter art. 3, stk. 1, når eksportøren er etableret inden for EU. Behandlinger, der er foretaget af dataansvarlige og databehandlere, som ikke er etableret i EU, vil efter art. 3, stk. 2, være omfattet af forordningen, når behandlingen vedrører udbud af varer

Dataeksportøren skal være omfattet af forordningen

eller tjenester til registrerede i EU eller overvågning af registreredes adfærd, som finder sted inden for EU (i praksis navnlig overvågning af adfærd på internettet). I sin vejledning nævner EDPB eksplicit behandlinger omfattet af art. 3, stk. 2, og markerer hermed, at virksomheder, der ikke er etableret inden for EU, potentielt kan foretage en overførsel omfattet af forordningens regler om tredjelandsoverførsler. I princippet betyder det, at eksempelvis en internetjeneste, der udelukkende er etableret i USA og som udbyder sine tjenester til EU-borgere, vil kunne foretage en tredjelandsoverførsel efter forordningen, hvis virksomheden videregiver oplysninger til en anden amerikansk virksomhed. Det skal dog understreges, at art. 3, stk. 2, kun gælder, hvis behandlingen "vedrører" udbud af varer eller tjenester eller overvågning af adfærd. Den behandling, der består i videregivelse (i eksemplet fra den amerikanske internetjeneste til en anden amerikansk virksomhed) vil derfor kun være omfattet af forordningen, og dermed kun udgøre en overførsel, hvis behandlingen vedrører udbud af varer eller tjenester eller overvågning af adfærd i art. 3, stk. 2's forstand.

At transmissionen mv. af oplysningerne skal foretages af en dataansvarlig eller en databehandler, før der foreligger en overførsel, indebærer endvidere, at der ikke foreligger en overførsel, når den registrerede selv overgiver oplysninger til en part, der er placeret i et tredjeland, eftersom den registrerede ikke har karakter af dataansvarlig for behandling af egne personoplysninger, jf. EDPB's Guidelines 05/2021, pkt. 12. Hvis en dansk kunde eksempelvis afgiver oplysninger om adresse mv. til en webshop, der drives af en virksomhed, som ikke er etableret i EU, vil dette ikke udgøre en overførsel i forordningens forstand (men virksomheden vil stadig kunne være omfattet af forordningen efter art. 3, stk. 2).

Det er endvidere et krav, at dataeksportøren og dataimportøren er to forskellige enheder. Dette har navnlig betydning, når medarbejdere tilgår oplysninger fra tredjelande. Hvis en medarbejder fra en europæisk virksomhed eksempelvis henter oplysninger fra virksomhedens system (placeret inden for EU) under et arbejdsophold i et tredjeland, foreligger ikke en overførsel, uagtet der teknisk set sker en transmission fra virksomhedens server i EU til medarbejderens computer i et tredjeland, idet medarbejderen identificeres med virksomheden, jf. EDPB's Guidelines 05/2021.

Overdragelse af oplysninger fra den registrerede selv

Medarbejdere

I vejledningen (pkt.17) peger EDPB på, at den dataansvarlige (virksomheden) i denne situation fortsat skal være opmærksom på at opfylde forordningens øvrige krav, herunder sikkerhedskravene i art. 32. Det har særlig relevans, fordi en medarbejders tilgang til oplysninger i et tredjeland kan give anledning til samme type af problemer, hvis tredjelandets lovgivning ikke yder tilstrækkelige beskyttelse af grundlæggende rettigheder, som ved tredjelandsoverførsler, jf. herom afsnit 3.3 nedenfor. I vejledningen anfører EDPB, at risikovurderingen efter art. 32 i yderste konsekvens kan føre til, at behandlingen ikke kan finde sted, og at ansatte må forbydes at medbringe bærbare computere mv. til visse tredjelande.

Mens en ansat identificeres med virksomheden, gælder det ikke for koncernforbundne selskaber. Når et europæisk moderselskab transmitterer oplysninger til et datterselskab i et tredjeland (eller omvendt), udgør de to selskaber selvstændige enheder i databeskyttelsesretlig forstand, og der vil derfor foreligge en overførsel.

Koncern-
forbundne
selskaber

Dataeksportørens og dataimportørens status af enten dataansvarlige, delt dataansvarlig, databehandler eller underdatabehandler er uden betydning for, om der foreligger en overførsel. Alle kombinationer (fra dataansvarlig til databehandler, fra databehandler til underdatabehandler osv.) omfattes af overførselsbegrebet, hvis betingelser i øvrigt er opfyldt.

Et lidt besynderligt resultat af dette er, at der formentlig også foreligger en overførsel, når en dataansvarlig uden for EU overgiver oplysninger til en databehandler inden for EU (der alene behandler oplysningerne på vegne af den dataansvarlige), som herefter sender dem tilbage til den dataansvarlige. Overgivelsen af oplysningerne fra den dataansvarlige til databehandleren udgør ikke en overførsel, da den dataansvarlige ikke er omfattet af forordningen (der er ikke tale om eksport men import af personoplysninger). Tilbageleveringen af oplysninger fra den europæiske databehandler til den dataansvarlige i tredjelandet vil til gengæld nok udgøre en overførsel. Man kan overveje, om det har været hensigten at udstrække forordningens beskyttelse til denne situation. Hvis en amerikansk virksomhed eksempelvis behandler oplysninger om sine amerikanske kunder (og derfor ikke er i nærheden af forordningens anvendelsesområde), vil virksomheden blive underlagt de krav til beskyttelsesniveau, der følger af forordningens

Re-eksport

bestemmelser om tredjelandsoverførsler, alene fordi virksomheden under vejs har anvendt en europæisk databehandler til at bistå med behandlingen af oplysningerne. Man kan derfor også argumentere for, at der i denne situation ikke foreligger en overførsel. Omvendt vil en sådanne sondring formentlig kunne føre til ganske vanskelige grænsedragninger, hvor den retlige kvalificering af oplysninger i (potentielt store) datasæt afgøres af, hvor oplysningerne hidrører fra. EDPB lægger i Guidelines 05/2021 (pkt. 13) til grund, at situationen udgør en overførsel. Kommissionens standardkontraktbestemmelser for tredjelandsoverførsler (omtalt i afsnit 3.1 nedenfor) omfatter også overførsler fra databehandler til dataansvarlig og lægger dermed ligeledes til grund, at der foreligger en overførsel. I denne situation pålægger standardkontraktbestemmelserne imidlertid ikke den dataansvarlige (dataimportøren) forpligtelser svarende til forordningens. Standardkontraktbestemmelsernes bestemmelse om de registreredes rettigheder og mulighed for at indgive klage ved dataimportørens manglende overholdelse heraf gælder eksempelvis ikke i denne situation. Kommissionen synes dermed at have håndteret udfordringen ved at fortolke begrebet "fornødne garantier" i art. 46, stk. 1, således, at det ikke indbefatter krav om, at dataimportøren skal behandle oplysningerne i overensstemmelse med forordningens krav i denne særegne situation.

En overførsel forudsætter, at dataimportøren er placeret i et tredjeland. Derimod er det ikke en forudsætning, at dataimportøren ikke er omfattet af forordningen. Som anført kan virksomheder, der er etableret uden for EU, blive omfattet af forordningen efter art. 3, stk. 2, når deres behandlingsaktiviteter vedrører udbud af varer eller tjenester til EU-borgere eller overvågning af (internet)adfærd inden for EU. Selvom der overføres oplysninger til en dataimportør, der omfattes af art. 3, stk. 2, og som derfor skal overholde forordningen, foreligger i denne situation en tredjelandsoverførsel, jf. EDPB's Guidelines 05/2021, pkt. 18. Dette kan umiddelbart forekommer overraskende, da formålet med at opstille særlige krav til tredjelandsoverførsler netop er at sikre, at de registrerede opnår en beskyttelse, der nogenlunde svarer til forordningens. Som beskrevet nedenfor indeholder forordningens regulering af tredjelandsoverførsler imidlertid også en beskyttelse mod, at der sker overførsler til tredjelande, hvis lovgivning ikke yder de registrerede tilstrækkelig beskyttelse af deres grundlæggende rettig-

Dataimportøren
omfattet af
forordningen

heder i forbindelse med efterretningstjenesters og andre myndigheder adgang til oplysninger. Denne beskyttelse vil ikke nødvendigvis være tilstrækkelig sikret alene fordi, dataimportøren er forpligtet til at overholde forordningen efter art. 3, stk. 2.

Kommissionens standardkontraktbestemmelser for tredjelandsoverførsler forudsætter også, at der foreligger en overførsel i denne situation, dog således at mange af de forpligtelser, dataimportøren i øvrigt underlægges efter bestemmelserne, ikke finder anvendelse, da dataimportørens forpligtelser følger direkte af forordningen.

Udover, at der skal være en dataansvarlig eller databehandler, hvis behandling omfattes af forordningen (dataeksportøren) og en dataansvarlig eller databehandler i et tredjeland, der modtager oplysningerne (dataimportøren), er det centrale kriterium i overførselsbegrebet, som det opstilles af EDPB med de tre ovennævnte kumulative betingelser, at oplysningerne gennem transmission eller på anden måde gøres tilgængelige for dataimportøren (“discloses by transmission or otherwise makes [...] available”). Vejledningen forholder sig imidlertid ikke til, hvad der nærmere ligger i disse formuleringer.

Karakterens af
tilrådgivelsesstil-
lelsen

Det er oplagt, at der foreligger en overførsel, hvis oplysningerne fysisk videregives til dataimportøren, enten ved at et fysisk medium med oplysningerne overgives til importøren i tredjelandet eller ved at oplysningerne sendes af dataeksportøren via internettet og lagres digitalt på enheder, der befinder sig hos importøren i tredjelandet.

– fysisk
overgivelse

En overførsel forudsætter imidlertid ikke, at dataeksportøren sender eller på anden måde overgiver oplysningerne til dataimportøren. Hvis dataeksportøren blot giver dataimportøren en systemadgang til eksportørens servere inden for EU, hvorfra importøren selv kan hente oplysningerne, foreligger også en overførsel.

– fjernadgang

Se således også eksempel 4 fra Datatilsynets vejledning om tredjelandsoverførsler, hvor det fastslås, at der foreligger en overførsel i en situation, hvor en cloududbyder har oplysninger lagret på et datacenter i Tyskland men foretager fejlrrettelse og vedligeholdelse fra en afdeling i Ukraine, når medarbejderne har adgang til personoplysninger i forbindelse med denne fejlrrettelse og vedligeholdelse.

EDPB har tilsvarende i henstilling 01/2020 om supplerende foranstaltninger, pkt. 13, fastslået, at fjernadgang fra et tredjeland også betragtes som en overførsel.

Det er ikke klart, om den blotte fjernadgang indebærer, at der foreligger en overførsel, eller om der i denne situation først foreligger en overførsel, når dataimportøren udnytter muligheden og rent faktisk henter oplysningerne. Spørgsmålet er ikke adresseret af Datatilsynet eller EDPB i de to ovenstående dokumenter. I en situation, hvor ingen personer i tredjelandet rent faktisk har tilgået oplysningerne, og hvor der heller ikke i øvrigt foreligger nogen behandling af oplysningerne i tredjelandet i form af opbevaring eller andet, kan der ikke antages at foreligge en overførsel. Dette må antages først at være tilfældet, når dataimportøren udnytter muligheden for at tilgå oplysningerne.

Tilsvarende Wuermeling og Oldani i Millard (red.), Cloud Computing Law, s. 358.

Det kan imidlertid ikke udelukkes, at den dataansvarlige vil have bevisbyrden for, at dataimportøren ikke har udnyttet muligheden, henset til ansvarlighedsprincippet i art. 5, stk. 2, og det gennemgående krav om, at den dataansvarlige skal kunne dokumentere overholdelse af forordningen. Hvis en cloududbyder eksempelvis kan få adgang til personoplysninger som led i vedligeholdelsen af cloudmiljøet, må det har formodningen for sig, at dette rent faktisk også er sket, og den dataansvarlige må da løfte bevisbyrden for, at det ikke er tilfældet, eventuelt ved erklæringer fra cloududbyderen.

Det er heller ikke klart, om overførselsbegrebet også rummer den situation, hvor fjernadgangen kun giver personer i tredjelandet adgang til at se oplysningerne men ikke mulighed for at lagre dem eller printe dem (dvs. uden mulighed for at foretage permanent kopiering til medier, der fysisk befinder sig i tredjelandet). Datatilsynet har i en ældre sag fra 2007 lagt til grund, at den blotte "se-adgang" udgjorde en overførsel under den tidligere persondatalov.

– "se-adgang"

Se sag nr. 2007-214-0004, hvor Datatilsynet besvarede en henvendelse fra ATP, der bl.a. ønskede at outsource drift og vedligehold af it-systemer til it-virksomheder beliggende i Indien og Sydafrika. ATP pegede som en mulighed på, at dette kunne tilrettelægges således, at medar-

bejderne hos de indiske og sydafrikanske virksomheder udelukkende kunne se oplysninger på deres skærm uden teknisk adgang til at lagre eller printe dem. Datatilsynet fandt, at dette udgjorde en tredjelandsoverførsel efter den dagældende persondatalovs § 27.

Da overførselsbegrebet som anført må tillægges samme forståelse under forordningen som under det tidligere direktiv, har afgørelsen fortsat relevans, og fortolkningen er også fastholdt af Datatilsynet under forordningen. I sin vejledning om tredjelandsoverførsler anfører tilsynet således under vejledningens eksempel 2, at der foreligger overførsel, når en dansk virksomhed anvender en virksomhed i et tredjeland (i eksemplet Indien) til it-support, hvis supportmedarbejderne har mulighed for at se personoplysninger, når de yder support, uanset at medarbejderne ikke har teknisk adgang til at lagre eller printe oplysningerne. Hermed anlægger Datatilsynet en ganske bred fortolkning af overførselsbegrebet, hvilket der kan være gode grunde til. For det første kan beskyttelsen efter forordningen blive undermineret, hvis det er muligt at give omfattende “se-adgange” ind i systemer med personoplysninger fra alle dele af verden uden den beskyttelse, der ligger i forordningen. For det andet vil det at gøre sig bekendt med en oplysning via en computerskærm, og eventuelt agere på baggrund af denne oplysning, i sig selv udgøre en behandling af personoplysninger, og det vil være en besynderlige situation, hvis der kan ske en behandling af oplysninger i et tredjeland, uden at der er sket en overførsel af disse oplysninger. Dette ræsonnement synes også at være bærende for Datatilsynet. I det angivne eksempel 2 anføres således eksplicit, at it-supporternes adgang indebærer en behandling af personoplysninger.

Se også under Datatilsynets “Spørgsmål og svar om cloud”: “Enhver behandling i tredjeland udgør en overførsel. En se-adgang er også en behandling – og dermed overførsel – i databeskyttelsesforordningens forstand”.

Denne brede fortolkning giver dog praktiske udfordringer med at anvende fleksible supportløsninger fra forskellige lande, bl.a. i cloud-miljøer, og man kan indvende, at der er ganske stor forskel på den situation, hvor oplysningerne fysisk placeres i et tredjeland og den situa-

tion, hvor der alene etableres en begrænset se-adgang med henblik på at kunne supportere systemer. På trods heraf må det af de ovennævnte grunde nok fastholdes, at se-adgang udgør overførsel som også lagt til grund af Datatilsynet. Dette gælder dog her som så mange andre steder i databeskyttelsesretten, at et endeligt og sikkert svar forudsætter en afgørelse fra EU-Domstolen.

Blandt andet som følge af EU-Domstolens afgørelser i *Schrems I* og *II*, der behandles nedenfor, og den heraf følgende usikkerhed om lovligheden af at bruge amerikanske cloudløsninger, der indebærer overførsel af oplysninger til USA, har en række amerikanske cloudleverandører givet europæiske kunder mulighed for at få deres cloudtjenester leveret fra datacentre beliggende inden for EU/EØS. Hermed vil de personoplysninger, der behandles i løsningerne, som udgangspunkt også forblive inden for EU's grænser (med forbehold for bl.a. den net-op beskrevne supportproblematik). I nogle tilfælde vil amerikansk lovgivning (i form af den amerikanske CLOUD Act) imidlertid pålægge amerikanske virksomheder at udlevere oplysninger til amerikanske myndigheder i efterforskningsøjemed, selvom oplysningerne befinder sig uden for USA. Hermed risikerer et europæisk datterselskab potentielt at blive pålagt af sit amerikanske moderselskab at udlevere personoplysninger til moderselskabet. En sådan udlevering vil udgøre en tredjelandsoverførsel, da overførselsbegrebet som nævnt også omfatter koncerninterne overførsler. Derimod vil den europæiske kundes (den dataansvarliges) overlevering af oplysningerne til det europæiske cloud datterselskab (databehandleren) ikke udgøre en tredjelandsoverførsel. Dette gælder også, selvom databehandleraftalen mellem kunden og det europæiske datterselskab giver sidstnævnte ret til at udlevere oplysningerne til det amerikanske moderselskab. Første på det tidspunkt, hvor det europæiske datterselskaber rent faktisk overfører oplysningerne til moderselskabet foreligger en tredjelandsoverførsel.

Se således også Datatilsynets besvarelse af forespørgsel fra KOMBIT vedrørende tilsigtede eller utilsigtede overførsler til tredjelande. Spørgsmålet var, om der forelå en tilsigtet tredjelandsoverførsel som kunden/den dataansvarlige havde ansvaret for, når en europæisk cloudleverandør (databehandleren) i sine vilkår forbeholder sig ret til at udlevere personoplysninger til sit amerikanske moderselskab. Dette bekræftede Datatilsynet og anførte herved, at "kommunerne efter Datatilsynets op-

Europæisk
databehandlers
pligt til at
udlevere
oplysninger til
moderselskab i
tredjeland

fattelse [skal] sikre sig, at reglerne i databeskyttelsesforordningens kapitel V iagttages, *hvis eller når* AWS i henhold til instruksen foretager sådanne overførsler” (fremhævet her).

Et særligt spørgsmål er, om der foreligger en overførsel, når personoplysninger gøres tilgængelige via hjemmesider, som kan tilgås af brugere uden for EU. På den ene side gøres oplysningerne utvivlsomt tilgængelige for tredjeparter i tredjelande og eksponeres dermed for en behandling i disse lande. På den anden side ville de praktiske vanskeligheder ved at lade hjemmesider være omfattet af kravene til internationale overførsler være ganske betydelige. I overensstemmelse hermed har EU-Domstolen i *Lindqvist*-dommen (C-101/01) fastslået, at oplysninger på en åben hjemmeside, der var lagret hos en udbyder etableret i en medlemsstat, ikke udgjorde en overførsel (videregivelse) efter de tilsvarende regler i det tidligere persondatadirektiv. EU-Domstolen lagde bl.a. vægt på, at det modsatte resultat ville indebære, at der ikke kunne ske offentliggørelse via hjemmesider, hvis blot ét land, hvorfra hjemmesiden kunne tilgås, ikke havde et tilstrækkeligt beskyttelsesniveau, se dommens præmis 69.

Særligt om
hjemmesider

Man kan have forståelse og sympati for resultatet, men det må erkendes, at det kan forekomme vanskeligt at forene med, hvad der i øvrigt antages at indebære en overførsel, herunder overførsel ved at personer fra lande uden for EU får en adgang til oplysninger, der befinder sig på servere inden for EU. Dommen kan dog muligvis forenes med de ovenfor anførte antagelser om, hvad der udgør tredjelandsoverførsler, hvis man lægger til grund, at der sker en tredjelandsoverførsel, når en hjemmesidebruger i et tredjeland læser oplysningerne på hjemmesiden og eventuelt foretager yderligere behandling af dem. Dommen forholder sig ikke til dette men kun til, om hjemmesideindehaveren foretager en tredjelandsoverførsel ved selve tilgængeliggørelsen af oplysningerne på hjemmesiden. En sådan retstilstand vil imidlertid være vanskelig at håndtere i praksis, da hjemmesideindehaveren i så fald foretager tredjelandsoverførsler til de lande, hvor brugere læser oplysningerne, uden at hjemmesideindehaveren nødvendigvis vil vide, hvilke lande det drejer sig om. Dette ville stemme dårligt overens med de realhensyn Domstolen tillagde afgørende vægt og kan derfor næppe hellere gælde. Det indebærer til gengæld, at retstilstanden ikke er

forenelig med Datatilsynets (logiske) betragtning om, at der nødvendigvis må ske en tredjelandsoverførsel, hvis der sker en behandling af oplysninger i tredjelandet. EU-Domstolen synes i dag at anlægge en mere beskyttelsesorienterede og mindre pragmatiske fortolkning af databeskyttelsesreglerne, end hvad der er udtrykt i *Lindqvist*-afgørelsen, og det kan ikke udelukkes, at Domstolen vil korrigere retstilstanden, hvis den skal forholde sig til spørgsmålet i en ny sag. Indtil da må det imidlertid nok fastholdes, at offentliggørelse af personoplysninger på hjemmesider ikke i sig selv udgør en tredjelandsoverførsel.

Såfremt hjemmesiden er placeret på en server, der fysisk er placeret uden for EU, vil der dog foreligge en overførsel. Dette skyldes imidlertid ikke selve tilgængeliggørelsen af oplysningerne på hjemmesiden, men transmissionen af oplysningerne til en fysisk server i et land uden for EU.

Der kan herved også lægges vægt på, at EU-lovgiver ikke fandt anledning til at regulere spørgsmålet eller omtale det i præambelbetragtningerne, da man overgik fra direktivet til forordningen. Havde lovgiver ønsket en anden retstilstand, kunne man have sikret det i forbindelse med overgangen til forordningen.

Bl.a. med henvisning til *Schrems I*, C-362/14, finder Kuner det sandsynligt, at EU-Domstolen vil nå et andet resultat, hvis den i dag blev spurgt, om offentliggørelse via hjemmesider udgør en tredjelandsoverførsel, Kuner m.fl. (red.), *The EU General Data Protection Regulation (GDPR)*, s. 763.

Da *Lindqvist*-sagen blev afgjort, blev indholdet på en hjemmeside lagt op af hjemmesideindehaveren selv. Dommen forholder sig derfor heller ikke til den situation, hvor oplysninger gøres tilgængelige af brugerne, således som det i dag ofte sker via sociale medier og andre tjenester med brugergenereret indhold. Dommens resultat vil formentlig også gælde for denne typer af tjenester, uanset om oplysningerne gøres tilgængelige og tilgås af brugerne via hjemmesider eller apps.

– brugergeneret
indhold

1.2. Tredjelande

På samme måde som det er tilfældet for overførselsbegrebet, er tredjelandsbegrebet ikke defineret i forordningen. Dette giver dog ikke anledning til samme fortolkningsvanskeligheder, da tredjelande omfatter alle lande, som ikke er medlem af EU eller omfattet af EØS-aftalen (udover medlemsstaterne er dette Norge, Island og Liechtenstein, som alle tre har implementeret forordningen i deres nationale lovgivning). Da databeskyttelsesforordningen ikke gælder for Grønland og Færøerne, der ikke er medlem af EU, har disse karakter af tredjelande. Efter sin udtræden af EU har Storbritannien (bestående af England, Skotland, Wales og Nordirland) ligeledes status af tredjelande.

2. Tilstrækkeligt beskyttelsesniveau – art. 45 (overførsel til sikre tredjelande)

Efter forordningens art. 45, stk. 1, kan der ske overførsel af personoplysninger til et tredjeland, når Kommissionen har truffet afgørelse om, at landet har et tilstrækkeligt sikkerhedsniveau. Bestemmelsen har følgende ordlyd:

Overførsel af personoplysninger til et tredjeland eller en international organisation kan finde sted, hvis Kommissionen har fastslået, at tredjelandet, et område eller en eller flere specifikke sektorer i dette tredjeland, eller den pågældende internationale organisation har et tilstrækkeligt beskyttelsesniveau. En sådan overførsel kræver ikke specifik godkendelse.

EU-Domstolen har i C-362/14, *Schrems I*, fortolket begrebet “tilstrækkeligt beskyttelsesniveau” således, at tredjelande skal have et beskyttelsesniveau, der “i det væsentlige” svarer til beskyttelsesniveauet efter det tidligere persondatadirektiv (præmis 73). Domstolen fastslog endvidere, at bedømmelsen både skulle inddrage tredjelandets regler, og hvordan det sikredes, at reglerne i praksis blev overholdt (præmis 75). Denne formulering er efterfølgende gentaget i forordningens betragtning 104, hvor det anføres, at tredjelandet “bør give garantier, der sikrer et passende beskyttelsesniveau, som i det væsentlige svarer til det, der sikres i Unionen”. Som anført af EU-Domstolen i *Schrems*

“Tilstrækkeligt beskyttelsesniveau”

II, C-311/18, præmis 94, er det således ikke et krav, at tredjelandet garanterer et beskyttelsesniveau, som er identisk med niveauet efter forordningen.

Forordningens art. 45, stk. 2, indeholder en opregning af de elementer, som Kommissionen navnlig skal tage i betragtning ved sin vurdering. Elementerne, der til dels er fastsat på baggrund af *Schrems I*-afgørelsen, omfatter bl.a.

- Retssikkerhed og respekt for menneskerettigheder og de grundlæggende frihedsrettigheder
- Databeskyttelsesregler, herunder regler om videreoverførsel til et andet tredjeland
- Effektive rettigheder for registrerede, som kan håndhæves
- Adgang til effektiv administrativ og retlig prøvelse for de registrerede
- Velfungerende og uafhængig tilsynsmyndighed
- De internationale forpligtelser landet har påtaget sig, navnlig vedrørende beskyttelse af personoplysninger

Såfremt Kommissionen vurderer, at lovgivningen i tredjelandet yder et tilstrækkeligt beskyttelsesniveau, kan Kommissionen efter art. 45, stk. 3, udstede en gennemførelsesretsakt, der fastslår dette. Landet har herefter status af et "sikkert tredjeland" i databeskyttelsesretlig forstand, og den dataansvarlige kan i henhold til art. 45, stk. 1, uden forudgående godkendelse overføre oplysninger til det pågældende tredjeland. Det følger dog af *Schrems I*-dommen, at de nationale tilsynsmyndigheder har både ret og pligt til at efterprøve Kommissionens beslutninger, såfremt der indgives en klage herover.

Sikre tredjelande

På nuværende tidspunkt er følgende lande godkendt: Andorra, Argentina, Canada (begrænset anvendelsesområde), Færøerne, Guernsey, Isle of Man, Israel, Japan (begrænset anvendelsesområde), Jersey, New Zealand, Schweiz, Storbritannien, Sydkorea og Uruguay.

Af stor praktisk betydning er hverken USA eller nogle af de store outsourcinglande som Kina og Indien godkendt.

Da persondatadirektivet blev vedtaget i 1995, stod det klart, at USA ikke havde en persondataregulering, der kunne siges at yde et tilstræk-

Særligt om overførsler til USA

keligt beskyttelsesniveau i direktivets forstand, eftersom USA ikke havde (og fortsat ikke har) en føderal generel lovgivning om beskyttelse af personoplysninger. Det stod dog også klart, at man relativt hurtigt måtte finde en for begge parter acceptabel løsning, der gjorde det muligt for amerikanske virksomheder at udveksle personoplysninger med bl.a. sine europæiske datterselskaber.

Løsningen på denne problemstilling blev den såkaldte “Safe Harbor”-ordningen. Amerikanske virksomheder kunne frivilligt tilmelde sig ordningen og dermed forpligte sig til at iagttage de krav til behandlingen af personoplysninger, der fulgte af ordningen. Disse virksomheder havde herefter et “tilstrækkeligt beskyttelsesniveau” efter det tidligere direktivs art. 25 (nu forordningens art. 45), idet Kommissionen havde truffet beslutning herom ved en beslutning af 26. juli 2000 (beslutning 2000/520).

– Safe Harbor-ordningen

EU-Domstolen fastslog imidlertid ved *Schrems I*-dommen, C-362/14, at denne beslutning var ugyldig, da Safe Harbor-ordningen ikke ydede et tilstrækkeligt beskyttelsesniveau.

– Schrems I-dommen

Dommen var anlagt af databeskyttelsesaktivisten Max Schrems som et led i dennes tvist med Facebook (nu Meta) om Facebooks (efter Schrems opfattelse manglende) overholdelse af de europæiske databeskyttelsesregler. Facebook brugte bl.a. Safe Harbor-ordningen som hjemmelsgrundlag for at overføre personoplysninger fra sit irske datterselskab til det amerikanske moderselskab.

Dommen er præget af Snowden-afsløringerne og deres afdækning af den amerikanske efterretningstjenestes vidtgående adgang til personoplysninger, herunder om europæiske borgere. I to af dommens centrale præmisser anfører EU-Domstolen således:

En lovgivning, der på generel vis tillader opbevaring af samtlige personoplysninger fra samtlige de personer, hvis oplysninger er blevet videregivet fra Unionen til USA, uden at der bliver foretaget nogen form for differentiering, begrænsning eller undtagelse under hensyn til det forfulgte mål, og uden at der bliver fastsat noget objektivt kriterium, som gør det muligt at afgrænse de offentlige myndigheders adgang til oplysningerne og deres senere anvendelse heraf med henblik på veldefinerede formål, der er strengt begrænsede, og som kan begrunde det indgreb, som såvel adgangen til disse oplysninger som anvendelsen heraf

indebærer, er således ikke begrænset til det strengt nødvendige [...] (præmis 93).

Navnlig skal en lovgivning, der gør det muligt for de offentlige myndigheder på generel vis at få adgang til indholdet af elektronisk kommunikation, anses for at udgøre et indgreb i det væsentligste indhold af den grundlæggende ret til respekt for privatlivet, således som denne er sikret ved chartrets artikel 7 [...] (præmis 94).

Domstolen lægger endvidere vægt på, at europæiske borgere ikke har adgang til en effektiv domstolsbeskyttelse mod en uberettiget brug af personoplysninger:

Tilsvarende opfylder en lovgivning, der ikke fastsætter nogen mulighed for retssubjektet til at gøre brug af retsmidler med henblik på at få adgang til personoplysninger, som vedrører den pågældende, eller til at få sådanne oplysninger berigtiget eller slettet, ikke det væsentligste indhold af den grundlæggende ret til en effektiv domstolsbeskyttelse, således som denne er sikret ved chartrets artikel 47 [...] (præmis 95).

Disse præmisser har væsentlig betydning for dommens resultat, hvorefter Kommissionens afgørelse om, at Safe Harbor-ordningen sikrede et tilstrækkeligt beskyttelsesniveau, var i strid med direktivets art. 25, stk. 6, sammenholdt med chartret om grundlæggende rettigheder.

På baggrund af dommen udarbejdede EU og USA en ny rammeaftale til afløsning af Safe Harbor-ordningen, kaldet Privacy Shield. Denne ordning skulle håndtere de mangler i Safe Harbor-ordningen, som fik EU-Domstolen til at erklære den for ugyldig under direktivet og chartret om grundlæggende rettigheder. Kommissionen traf i juli 2016 afgørelse om, at Privacy Shield-ordningen sikrede et tilstrækkeligt beskyttelsesniveau og dermed kunne bruges som grundlag for overførsel til amerikanske virksomheder, der tilsluttede sig ordningen (gennemførelsesafgørelse 2016/1250). Denne ordning blev dog også anfægtet i den fortsatte sag mellem Max Schrems og Facebook og også denne gang førte det til en præjudiciel forelæggelse for EU-Domstolen. Hovedspørgsmålet i sagen var, om der gyldigt kunne ske en overførsel med hjemmel i Kommissionens standardkontraktbestemmelser i art. 46, men Domstolen forholdt sig også til gyldigheden af Kommis-

– Privacy Shield
Agreement

sionens afgørelse om, at Privacy Shield sikrede et tilstrækkeligt beskyttelsesniveau efter art. 45. I sin dom af 16. juli 2020, *Schrems II*, C-311/18, fastslog EU-Domstolen, at heller ikke Privacy Shield ordningen sikrede de fornødne garantier under charterets art. 7, 8 og 47, og at Kommissionens tilstrækkelighedsafgørelse herom derfor var i strid med art. 45 og dermed ugyldig. Domstolen fastslog i forlængelse af *Schrems I*-afgørelsen, at videregivelse af personoplysninger til offentlige myndigheder og opbevaring af oplysninger og offentlige myndigheds adgang hertil udgør et indgreb i de grundlæggende rettigheder til privatlivsbeskyttelse og beskyttelse af personoplysninger efter charterets art. 7 og 8 (præmis 171). Efter charterets art. 52, stk. 1, 2. pkt., kan et sådant indgreb i de grundlæggende rettigheder under iagttagelse af proportionalitetsprincippet kun ske, hvis begrænsningerne er nødvendige og forfølger mål af almen interesse. Heri ligger bl.a., at begrænsningen i de grundlæggende rettigheder skal være fastsat ved lov, og at lovgivningen skal angive under hvilke omstændigheder og på hvilke betingelser, der kan vedtages en foranstaltning om behandling af personoplysninger, således at indgrebet begrænses til det strengt nødvendige (præmis 176). Domstolen fandt i sin analyse af de amerikanske regler (FISA 702, E.O. 12333 og PPD-28), at disse ikke begrænsede de amerikanske efterretningsmyndigheders indsamling til det strengt nødvendige og dermed ikke levede op til kravet i charterets art. 52 sammenholdt med art. 7 og 8 (præmis 185). Domstolen fandt endvidere ikke, at de amerikanske regler gav europæiske borgere mulighed for ved en domstol at kræve udlevering, berigtigelse eller sletning af personoplysninger. Domstolen afviste, at den ombudsmandsinstitution, der var etableret med Privacy Shield-ordningen, kunne sidestilles med en uafhængig domstol, bl.a. fordi den udgjorde en del af det amerikanske udenrigsministerium og ikke var beskyttet mod nedlæggelse (præmis 197). Hermed levede reglerne heller ikke op til kravet i charterets art. 47 om krav på adgang til effektive retsmidler ved en domstol.

Schrems II-dommen har givet anledning til betydelige vanskeligheder, fordi den både fastslog, at Privacy Shield-ordningen ikke kunne anvendes som overførselsgrundlag efter art. 45, og samtidig indebar, at overførsler i mange tilfælde (i realiteten nok de fleste) til USA heller ikke kunne ske efter art. 46 som beskrevet nedenfor. Kommissionen og den amerikanske regering indledte derfor efter *Schrems II*-dommen

– Data Privacy Framework (DPF)

intense forhandlinger om en afløser for Privacy Shield-ordningen og den 7. oktober 2022 udstedte den amerikanske præsident et dekret (Executive Order 14086 On Enhancing Safeguards For United States Signals Intelligence Activities), der skal højne beskyttelsen af udenlandske borgere, når amerikanske efterretningstjenester behandler oplysninger om dem i forbindelse med signalindhentning behandling af personoplysninger. Dekretet har til formål at afhjælpe de forhold, EU-Domstolen påpegede i *Schrems II*-dommen. Dekretet fastslår bl.a., at efterretningstjenesternes indsamling af oplysninger skal være proportional og nødvendig med henblik på beskyttelsen af national sikkerhed. Dette skal imødegå Domstolens vurdering af, at amerikansk lovgivning ikke begrænsede indhentningsmulighederne til det proportionale og nødvendige. Dekretet indeholder endvidere en ny klageinstans (the Data Protection Review Court), som har kompetence til at behandle klager over ulovlig behandling og pålægge efterretningstjenesterne at indstille en ulovlig behandling. Dette skal imødegå EU-Domstolens vurdering af, at klagemulighederne efter amerikansk ret ikke levede op til kravet om adgang til effektive retsmidler for en domstol efter charterets art. 47. Det er nu op til Kommissionen at vurdere, om den nye ordning (benævnt Data Privacy Framework eller blot DPF) lever op til kravene under charteret og forordningen som opstillet af EU-Domstolen. Som led heri skal Kommissionen bl.a. høre EDPB men er ikke forpligtet til at følge en indstilling fra EDPB. Det må forventes, at Kommissionen vil nå frem til, at ordningen lever op til kravene i europæisk ret og herefter træffer en tilstrækkelighedsafgørelse efter art. 45, bl.a. fordi Kommissionen allerede har meldt ud, at man ikke forventer, at EU-Domstolen vil erklære den nye ordning ugyldig. Herefter vil overførsler til amerikanske virksomheder, der er tilsluttet ordningen, kunne ske efter art. 45. Det må imidlertid også forventes, at den nye ordning igen vil blive anfægtet, og EU-Domstolen igen skal forholde sig til gyldigheden. Udfaldet af en sådan sag er vanskeligt at spå om. Ordningen vil under alle omstændigheder kunne anvendes, indtil en eventuel afgørelse om ugyldig måtte blive afsagt af EU-Domstolen.

3. Overførsler omfattet af fornødne garantier – art. 46 (overførsel til usikre tredjelande)

Da lovgivningen i de fleste af verdens lande ikke sikrer et tilstrækkeligt beskyttelsesniveau målt med databeskyttelsesforordningens standarder (og dermed har karakter af “usikre tredjelande” i databeskyttelsesretlig forstand), vil mange internationale overførsler ikke kunne foretages med hjemmel i art. 45. Både globaliseringen og digitaliseringen medfører imidlertid et stort behov for at kunne foretage internationale persondataoverførsler, og forordningen rummer derfor i art. 46 en række yderligere hjemmelsgrundlag for lovlige overførsler til tredjelande af stor praktisk betydning. Udgangspunktet efter art. 46, stk. 1, er, at overførsel kun kan finde sted, hvis den dataansvarlige eller databehandleren, der overfører oplysningerne, udsteder de fornødne garantier. Bestemmelsen har følgende ordlyd:

Hvis der ikke er vedtaget en afgørelse i henhold til artikel 45, stk. 3, må en dataansvarlig eller databehandler kun overføre personoplysninger til et tredjeland eller en international organisation, hvis vedkommende har givet de fornødne garantier, og på betingelse af at rettigheder, som kan håndhæves, og effektive retsmidler for registrerede er tilgængelige.

EU-Domstolens har i *Schrems II*, C-311/18, anført, at de fornødne garantier efter art. 46, stk. 1, skal være af en sådan karakter, at de yder et beskyttelsesniveau, der i det væsentlige svarer til det niveau, der er sikret inden for EU. Udtalelsen sigter til standardkontraktbestemmelserne efter art. 46, stk. 2, litra c, men vil gælde alle overførsler efter art. 46.

Art. 46, stk. 2, opregner en række instrumenter, der kan sikre de fornødne garantier. I disse situationer kan der ske overførsel uden specifik godkendelse fra den nationale tilsynsmyndighed (såfremt kravene til lovgivningen i tredjelandet endvidere er opfyldt, jf. nærmere nedenfor). Disse instrumenter omfatter 1) retligt bindende instrumenter mellem offentlige myndigheder (eksempelvis en dobbeltbeskatningsaftale mellem Skatteministeriet og skattemyndighederne i et usikkert tredjeland, der indeholder bindende regler om, hvornår der kan ske udveksling af skatteoplysninger), 2) bindende virksomhedsregler, 3)

standardkontraktbestemmelser og 4) godkendte adfærdscodekser og certificeringsmekanismer.

Efter art. 46, stk. 3, kan de fornødne garantier også sikres gennem individuelle kontraktbestemmelser. Dette forudsætter, at kontraktbestemmelserne pålægger modtagerne af oplysningerne forpligtelser, som i det væsentlige svarer til, hvad der gælder efter forordningen. Brugen af individuelle kontraktbestemmelser forudsætter forudgående godkendelse af den nationale tilsynsmyndighed.

Som nærmere beskrevet nedenfor forudsætter en lovlig overførsel efter art. 46 ikke kun, at der anvendes et af de anførte overførselsinstrumenter. Der forudsætter endvidere, at lovgivningen i tredjelandet sikrer et beskyttelsesniveau som i det væsentlige svarer til det niveau, der er sikret i EU i medfør af forordningen sammenholdt med chartret.

I det følgende omtales først de to overførselsinstrumenter med størst praktisk relevans, standardkontraktbestemmelser og bindende virksomhedsregler og dernæst kravene til lovgivningen i tredjelandet.

3.1. Standardkontraktbestemmelser

Det følger af art. 46, stk. 2, litra c og d, at de fornødne garantier omtalt i art. 46, stk. 1, kan sikres ved brug af såkaldte standardbestemmelser om databeskyttelse (som regel benævnt “standardkontraktbestemmelser” eller “SCC”, som er forkortelsen for den engelsksproget betegnelse “Standard Contractual Clauses”). Litra c giver hjemmel til Kommissionens udarbejdelse af standardkontraktbestemmelser, mens litra d giver hjemmel til, at de nationale tilsynsmyndigheder kan udarbejde deres egne standardkontraktbestemmelser. Såfremt Kommissionen godkender disse, vil de tilsvarende kunne bruges som hjemmelsgrundlag for overførslen. Hverken det danske datatilsyn eller andre tilsynsmyndigheder har udarbejdet sådanne bestemmelser, og i praksis er det således Kommissionens standardkontraktbestemmelser, der anvendes og dem, der omtales i det følgende.

Kommissionen har gennem tiden udarbejdet flere sæt standardkontraktbestemmelser. Den nyeste udgave blev offentliggjort den 4. juli 2021. Dokumentet består (som de tidligere) dels af en gennemførelsesafgørelse, der fastslår, at en dataeksportør og en dataimportør, der

anvender standardkontraktbestemmelserne angivet i dokumentets bilag hermed etablerer de fornødne garantier efter art. 46, dels af et bilag med selve standardkontraktbestemmelserne.

3.1.1. Gennemførelsesafgørelsen

Gennemførelsesafgørelsen er kortfattet og består udover nogle indledende betragtninger af fire artikler, hvoraf art. 1, stk. 1, fastslår standardkontraktbestemmelsernes gyldighed som overførselsgrundlag efter art. 46:

Standardkontraktbestemmelserne, som fastsat i bilaget, anses for at give de fornødne garantier, jf. artikel 46, stk. 1, og artikel 46, stk. 2, litra c), i forordning (EU) 2016/679, for en dataansvarligs eller databehandlers overførsel af personoplysninger, der behandles i henhold til den nævnte forordning (dataeksportør), til en dataansvarlig eller (under) databehandler, hvis behandling af oplysningerne ikke er omfattet af den nævnte forordning (dataimportør).

Art. 1, stk. 2, fastslår, at standardkontraktbestemmelserne også fastsætter de dataansvarliges og databehandlernes rettigheder og forpligtelser med hensyn til de forhold, der er omhandlet i art. 28, stk. 3 og 4, når overførslen sker fra en dataansvarlig til en databehandler eller fra en databehandler til en underdatabehandler. Dette betyder med andre ord, at standardkontraktbestemmelserne opfylder kravene til en databehandlersaftale i art. 28, således at parterne ikke behøver indgå en separat databehandlersaftale, når de anvender standardkontraktbestemmelserne.

Standardkontraktbestemmelserne kan anvendes som databehandlersaftale

Art. 2 pålægger en tilsynsmyndighed at underrette Kommissionen, hvis tilsynsmyndigheden forbyder eller suspenderer en overførsel, fordi lovgivningen i tredjelandet har forhindret en dataimportør i at overholde sine forpligtelser under standardkontraktbestemmelserne. Kommissionen underretter herefter de øvrige tilsynsmyndighederne. Bestemmelsen skal sikre, at alle tilsynsmyndighederne bliver bekendt med det, hvis en tilsynsmyndighed vurderer, at lovgivningen i et tredjeland forhindrer overførsler til det pågældende land, således at tilsynsmyndighederne kan koordinere dette. Er tilsynsmyndighederne uenige om vurderingen af lovgivningen i tredjelandet, må uenigheden afgøres i EDPB efter sammenhængsmekanismen, jf. herom kap. 10.2.

Tilsynsmyndighedernes underretningspligt

Art. 3 fastslår, at Kommissionen skal evaluere den praktiske anvendelse af standardkontraktbestemmelserne som led i den regelmæssige evaluering af forordningen, Kommissionen skal foretage hver fjerde år efter art. 97.

Art. 4 fastslår ikrafttrædelsestidspunktet for afgørelsen, den 27. juni 2021. Bestemmelsen fastslår endvidere, at kontrakter indgået før 27. september 2021 kan baseres på de tidligere standardkontraktbestemmelser indtil den 27. december 2022. Herefter vil sådanne kontrakter ikke længere udgøre et gyldigt overførselsgrundlag efter art. 46, og parterne må derfor sørge for at have indgået en ny kontrakt baseret på de nye standardkontraktbestemmelser inden denne dato.

Brug af tidligere standardkontraktbestemmelser

3.1.2. Standardkontraktbestemmelserne

3.1.2.1. Generelt om standardkontraktbestemmelserne

Standardkontraktbestemmelserne består af 18 bestemmelser inddelt i fire afsnit: Afsnit I (uden titel) med forskellige indledende bestemmelser, afsnit II om dataeksportørens og dataimportørens forpligtelser, afsnit III om tredjelandsløvgivning og afsnit IV med afsluttende bestemmelser om overtrædelse, lovvalg og værneting.

Som beskrevet under gennemgangen af overførselsbegrebet i afsnit 1.1 kan både dataeksportøren og dataimportøren være enten dataansvarlig eller databehandler, hvilket giver fire kombinationsmuligheder: overførsel fra (1) dataansvarlig til dataansvarlig, (2) dataansvarlig til databehandler, (3) databehandler til databehandler (underdatabehandler) og (4) databehandler til dataansvarlig. Standardkontraktbestemmelserne er modulært opbygget, således at de omfatter alle fire situationer. De enkelte bestemmelser indeholder alternative formuleringer for de fire forskellige situationer i de tilfælde, hvor reguleringen adskiller sig afhængigt af, hvilken situation, der foreligger. Det indebærer i realiteten, at der er fire forskellige sæt standardkontraktbestemmelser, som er samlet i ét dokument.

Modulær opbygning

3.1.2.2. Dataimportørens forpligtelser

Da standardkontraktbestemmelserne skal sikre, at dataimportørens behandling af personoplysninger sker med et beskyttelsesniveau for de registrerede, der i det væsentlige svarer til forordningens, udgøres en

central del af standardkontraktbestemmelserne af de bestemmelser, der pålægger dataimportøren forpligtelser, der minder om forordningens. Disse forpligtelser fremgår af afsnit II og omfatter bl.a. (med variationer afhængigt af, hvilken af de fire konstellationer, der foreligger) pligt til kun at behandle oplysningerne til det konkrete formål, som overførslen vedrører, oplysningspligt, slettepligt (opbevaringsbegrænsning), iagttagelse af sikkerhedsforanstaltninger, underretningspligt ved sikkerhedsbrud og dokumentationspligt. Bestemmelse 10 udstyrer de registrerede med rettigheder, som i en mindre omfangsrig udgave afspejler forordningens bestemmelser herom. Dette gælder retten til indsigt, sletning, berigtigelse og forbuddet mod afgørelse udelukkende på grundlag af automatisk behandling.

3.1.2.3. Lovgivningen i tredjelandet

Bestemmelsernes afsnit III forholder sig til den situation, hvor lovgivningen i tredjelandet påvirker dataimportørens muligheder for at overholde bestemmelserne. I princippet kan dette omfatte al præceptiv lovgivning, som forpligter dataimportøren til at foretage handlinger, der strider mod standardkontraktbestemmelserne. I realiteten er det navnlig *Schrems II*-problematikken, der søges adresseret her, og dermed den situation, hvor tredjelandslovgivningen giver myndigheder en adgang til oplysningerne, der ikke sikrer de registrerede den minimumsbeskyttelse, som følger af charteret sammenholdt med forordningen.

Bestemmelse 14, litra a pålæggende indledningsvist en garanti for god tro om lovgivningen i tredjelandet:

God tro om
lovlighed

Parterne garanterer, at de ikke har grund til at tro, at den lovgivning og praksis i bestemmelsestredjelandet, der gælder for dataimportørens behandling af personoplysninger, herunder krav om videregivelse af personoplysninger eller foranstaltninger, der tillader offentlige myndigheders adgang, forhindrer dataimportøren i at opfylde sine forpligtelser i henhold til disse bestemmelser. Dette baseres på, at lovgivning og praksis, der respekterer kernen i de grundlæggende rettigheder og frihedsrettigheder og ikke går videre, end hvad der er nødvendigt og rimeligt i et demokratisk samfund for at sikre et af de mål, der er anført i artikel 23, stk. 1, i forordning (EU) 2016/679, ikke anses for at være i modstrid med disse bestemmelser.

Parterne skal dokumentere den vurdering af tredjelandsgivningen, der ligger til grund for garantien og efter anmodning stille den til rådighed for den kompetente tilsynsmyndighed, jf. bestemmelse 14, litra d. Parterne kan med andre ord ikke blot “lukke øjnene” og gå ud fra, at lovgivningen er uproblematisk (en sådan forpligtelse gælder for dataeksportøren allerede efter forordningen, jf. nærmere afsnit 3.3 nedenfor).

Bestemmelse 14, litra b, opregner de elementer, der skal indgå i vurderingen af tredjelandsgivningen:

1. De særlige omstændigheder ved overførslen, herunder behandlingskædens længde, antallet af involverede aktører og de anvendte transmissionskanaler, påtænkte videreoverførsler, modtagertype, formålet med behandlingen, kategorierne og formatet af de overførte personoplysninger, den økonomiske sektor, inden for hvilken overførslen finder sted, og opbevaringsstedet for de overførte oplysninger
2. Lovgivning og praksis i bestemmelsestredjelandet — herunder dem, der kræver videregivelse af oplysninger til offentlige myndigheder eller tillader sådanne myndigheder adgang — som er relevante på grund af de konkrete forhold ved overførslen samt de gældende begrænsninger og garantier
3. Alle relevante kontraktmæssige, tekniske eller organisatoriske sikkerhedsforanstaltninger, der er indført for at supplere garantierne i henhold til disse bestemmelser, herunder foranstaltninger, der anvendes under videregivelsen og behandlingen af personoplysninger i bestemmelseslandet

Som også omtalt i afsnit 3.3 nedenfor, har det siden *Schrems II*-dommen været en løbende diskussion, om sandsynligheden for, at efterretningstjenester eller andre offentlige myndigheder vil have interesse i de overførte oplysninger, kan indgå i vurderingen af tredjelandsgivningen. Eller med andre ord: Hvis lovgivningen i tredjelandet ikke yder den tilstrækkelige beskyttelse af de grundlæggende rettigheder, kan overførslen da alligevel finde sted, hvis det i praksis er usandsynligt, at efterretningstjenester m.fl. vil interesse sig for den konkrete type af oplysninger, der overføres? Det følger af den ovenstående bestemmelse

14, litra b, pkt. 2, at det ikke kun er “lovgivning” men også “praksis”, der skal vurderes. Til dette punkt 2 er der indsat en note (note 12), der indledes med følgende sætninger: “For så vidt angår sådanne loves og praksissers betydning for overholdelsen af disse bestemmelser kan forskellige elementer indgå som en del af en samlet vurdering. Disse elementer kan omfatte relevant og dokumenteret praktisk erfaring med tidligere anmodninger om videregivelse af oplysninger fra offentlige myndigheder, *eller manglen på samme*, i en passende og tilstrækkeligt repræsentativ periode” (fremhævet her). Hermed gives mulighed for, at det kan indgå i vurderingen, at myndigheder *ikke* tidligere har udbedt sig den type af oplysninger, der overføres, og at der dermed er en begrænset sandsynlighed for, at det vil ske fremadrettet. Dokumentationen herfor kan ifølge note 12 navnlig bestå af interne registre eller anden dokumentation, der løbende udarbejdes i overensstemmelse med due diligence og er certificeret på øverste ledelsesniveau, forudsat at disse oplysninger lovligt kan deles med tredjeparter. Hermed lægges op til, at dokumentationen kan bestå af dataimportørens egne interne opgørelser af udleveringsanmodninger (hvilket særligt kan være relevante for nogle af de store cloudtjenester og andre techvirksomheder). Det følger imidlertid videre af note 12, at der ikke udelukkende kan lægges vægt på internt materiale, men at konklusionen om den manglende sandsynlighed skal understøttes af objektive elementer, herunder “offentligt tilgængelige eller på anden måde tilgængelige, pålidelige oplysninger om eksistensen eller fraværet af anmodninger inden for samme sektor og/eller anvendelsen af lovgivningen i praksis, såsom retspraksis og rapporter fra uafhængige tilsynsorganer”.

Den noget komplekse tekst i note 12 (og formentlig også tekstens placering i en note) afspejler en uenighed mellem Kommissionen og EDPB ved udarbejdelsen af standardkontraktbestemmelserne. I Kommissionens oprindelige udkast fremgik muligheden for at inddrage sandsynligheden for, om myndighederne i tredjelandet ville anmode om oplysningerne direkte i bestemmelserne. I et fælles høringssvar til dette udkast afviste EDPB sammen med EDPS, at *Schrems II*-dommen efterlod rum for en sandsynlighedsvurdering og anbefalede derfor, at denne formulering blev slettet i udkastet. Dette blev dog afvist af Kommissionen, og note 12 i den endelige udgave af standardkontraktbestemmelserne synes at udgøre et kompromis.

Efter litra e skal dataimportøren underrette dataeksportøren, hvis importøren i kontraktens løbetid har grund til at tro, at importøren er underlagt lovgivning, der ikke gør det muligt for importøren at overholde sine forpligtelser efter kontrakten – eller med andre ord, at dataimportøren ikke længere kan overholde garantien i litra a. I denne situation skal dataeksportøren efter litra f enten etablere supplerende foranstaltninger (jf. herom i afsnit 3.3 nedenfor), eller, hvis supplerende foranstaltninger ikke kan afhjælpe forholdet, suspendere overførslen. I sidstnævnte tilfælde følger det af bestemmelsen, at dataeksportøren har ret til at opsig kontrakten for så vidt den vedrører behandling af personoplysninger i henhold til standardkontraktbestemmelserne.

Dataimportørens underretningspligt ved ulovlig behandling

Efter bestemmelse 15, stk. 1, skal dataimportøren underrette dataeksportøren og om muligt den registrerede, hvis importøren modtager en retligt bindende anmodning fra en offentlig myndighed om videregivelse af de overførte personoplysninger. Det gælder tilsvarende, hvis dataimportøren får kendskab til, at en offentlig myndighed har en direkte adgang til oplysningerne. Såfremt dataimportøren i henhold til tredjelandsløvgivningen ikke må oplyses om udleveringen, skal importøren gøre sit bedste for at få hævet forbuddet. Dataimportøren skal under alle omstændigheder oplyse dataeksportøren, hvis importøren ikke er i stand til at overholde sine forpligtelser under standardkontraktbestemmelserne, uanset om importøren ikke kan oplyse om en konkret udlevering.

Underretning om videregivelses-anmodning

Når en offentlig myndighed anmoder om videregivelse af oplysningerne, skal dataimportøren efter bestemmelse 15, stk. 2, vurdere lovligheden af anmodningen og anfægte den, hvis importøren finder rimelig grund til at antage, at anmodningen ikke er lovlig.

Pligt til at anfægte

3.1.2.4. Ansvar og håndhævelse

Det er en et bærende princip i standardkontraktbestemmelserne, at dataimportøren ikke kun skal påtage sig forpligtelser, der svarer til forordningens, men også skal stå til ansvar for overholdelsen heraf, således at en misligholdelse af bestemmelserne kan udløse ansvar, der kan håndhæves overfor dataimportøren. Dette sikres gennem forskellige tiltage i bestemmelserne.

Efter bestemmelse 3 tildeles de registrerede status som begunstigede tredjemænd overfor dataeksportøren og dataimportøren i relation

Registreredes status som begunstigede tredjemænd

til bl.a. dataimportørens forpligtelser ved behandling og overholdelse af de registreredes rettigheder efter bestemmelse 11 kan indgive en klage over dataimportøren til tilsynsmyndigheden i sit eget hjemland eller den tilsynsmyndighed, der fungerer som tilsynsmyndighed for dataimportøren i henhold til bestemmelse 13. Den registrerede kan endvidere anlægge en sag mod dataimportøren ved domstolene i sit eget hjemland eller ved den domstol, der efter bestemmelse 18 af dataeksportøren og dataimportøren er valgt som kompetent domstol til at afgøre tvister under standardkontraktbestemmelserne. Det følger af bestemmelse 11, litra e, at dataimportøren er forpligtet til at rette sig efter en afgørelse, der er bindende i henhold til EU-retten eller lovgivningen i en medlemsstat.

Efter bestemmelse 12 kan de registrerede rejse erstatningskrav mod dataimportøren for materiel eller immateriel skade forårsaget af importørens overtrædelse af bestemmelserne. Bestemmelsen er modelleret over erstatningsbestemmelsen i forordningens art. 82 og indebærer bl.a., at dataeksportøren og dataimportøren hæfter solidarisk overfor den registrerede.

Erstatningskrav fra registrerede

Bestemmelse 13 fastslår, hvilken af de europæiske tilsynsmyndigheder, der fungerer som tilsynsmyndigheden for dataimportøren. Som udgangspunkt er det tilsynsmyndigheden i den medlemsstat, hvor dataeksportøren er etableret. Dataimportøren er efter bestemmelsen forpligtet til at samarbejde med tilsynsmyndigheden og til at overholde de foranstaltninger, som tilsynsmyndigheden vedtager, herunder afhjælpende og kompenserende foranstaltninger. Derimod har tilsynsmyndigheden ikke kompetence til at pålægge dataimportøren administrative bøder.

Tilsynsmyndighed

Da standardkontraktbestemmelserne udgør en kontrakt mellem dataeksportøren og dataimportøren indeholder de også en regulering af inter partes ansvaret mellem disse to parter og regler om tvistløsning. Ansvarsbestemmelsen i bestemmelse 12 regulerer således ikke kun dataeksportøren og dataimportørens erstatningsansvar overfor de registrerede men også deres ansvar overfor hinden. Af litra a fremgår, at "[p]arterne er ansvarlige over for den eller de andre parter for eventuel skade, som en part påfører den eller de andre parter ved overtrædelse af disse bestemmelser".

Inter partes ansvaret

Efter bestemmelse 16 suspenderer dataeksportøren overførslen, hvis dataimportøren overtræder bestemmelserne eller i øvrigt ikke er i stand til at overholde dem, indtil forholdet er udbedret. Dataeksportøren har ret til at opsige kontrakten, hvis dette ikke sker inden for en rimelig frist og senest inden for 30 dage. Dette gælder tilsvarende, hvis dataimportøren på alvorlig eller vedvarende vis tilsidesætter bestemmelserne eller ikke efterkommer en bindende afgørelse fra en domstol eller tilsynsmyndighed vedrørende forpligtelserne under bestemmelserne. Ved opsigelse er dataimportøren forpligtet til at tilbagelevere eller slette de overførte oplysninger.

Opsigelse

Kontrakten skal efter bestemmelse 17 være underlagt lovgivningen i den EU-medlemsstat, som parterne vælger. Parterne skal endvidere efter bestemmelse 18 angive, hvilken medlemsstats domstole, der skal afgøre tvister mellem dem.

Lovvalg og værning

3.2. Bindende virksomhedsregler

Selvom virksomheder er en del af samme koncern (og dermed udgør moderselskaber, datterselskaber eller søsterselskaber), har de i databeskyttelsesretlig forstand status som selvstændige juridiske enheder. Det betyder, at der gælder samme regler og krav, når der overføres personoplysninger mellem koncernforbundne selskaber, som når overførslen sker mellem ikke-koncernforbundne selskaber. En overførsel fra et selskab i EU til et koncernforbundet selskab i et usikkert tredjeland skal derfor overholde forordningens regler om tredjelandsoverførsler. Dette giver særlige udfordringer for multinationale virksomheder, der har et praktisk behov for at kunne flytte oplysninger mellem koncernforbundne selskaber, uden at der skal iværksættes omfattende administrative foranstaltninger. Disse behov har ikke fuldt ud kunnet imødekommes ved Kommissionens ovennævnte standardkontraktbestemmelser, da det opleves som administrativt byrdefuldt at skulle indgå en lang række standardkontrakter mellem de forskellige koncernforbundne selskaber. Der vil skulle vedtages et sæt standardkontraktbestemmelser mellem alle de koncernforbundne selskaber, der hver især overfører oplysninger til hinanden. I en større multinational virksomhed kan dette resultere i flere hundrede standardkontrakter. I stedet er det blevet accepteret, at virksomheder kan fastsætte interne bindende

regler, der forpligter alle virksomhedens selskaber til at behandle personoplysninger i overensstemmelse med de krav, der følger af reglerne. Sådanne bindende virksomhedsregler (på engelsk “Binding Corporate Rules” eller blot “BCR”) har fået stor udbredelse blandt store globale virksomheder, da de gør det muligt frit at overføre personoplysninger internt i koncernen, når blot de bindende virksomhedsregler én gang er blevet godkendt af den relevante tilsynsmyndighed.

Forordningens art. 47 rummer en ganske omfattende regulering af kravene til et sæt bindende virksomhedsregler. Det følger af art. 47, stk. 1, at de bindende virksomhedsregler skal 1) være retligt bindende for og håndhæves af alle berørte medlemmer af koncernen, herunder deres medarbejdere, 2) udtrykkeligt tillægge registrerede rettigheder, som kan håndhæves, for så vidt angår behandling af deres personoplysninger og 3) opfylde de indholdsmæssige krav, der følger af art. 47 stk. 2.

Efter stk. 2 skal de bindende virksomhedsregler angive strukturen og kontaktoplysningerne for koncernen og dens medlemmer og information om de foretagne overførsler, herunder kategorierne af personoplysninger, behandlingstype og -formål, typen af berørte registrerede og angivelse af de pågældende tredjelande. Reglerne skal endvidere angive, at de har retligt bindende karakter både internt og eksternt.

Den materielle beskyttelse af de registrerede sikres gennem stk. 2, litra d og e. Efter litra d skal reglerne forpligte de omfattede virksomheder til at efterleve de generelle behandlingsprincipper (art. 5), sikre et retsgrundlag for behandlingen (art. 6), iagttage kravene ved behandling af følsomme oplysninger (art. 9), etablere sikkerhedsforanstaltninger (art. 32) og fastlægge krav til videreoverførsel til organer, der ikke er underlagt de bindende virksomhedsregler. Efter litra e skal de omfattede virksomheder sikre overholdelse af de registreredes rettigheder (art. 12-22), respektere de registreredes ret til at indgive en klage til tilsynsmyndighederne eller anlægge sag ved domstolene (art. 79) og til at kræve erstatning for brud på de bindende virksomhedsregler (art. 82).

For at sikre overholdelsen af de bindende virksomhedsregler, skal det angives, hvordan de registrerede informeres om reglerne, herunder særligt om deres rettigheder og mulighed for at indgive en klage og kræve erstatning. Reglerne skal endvidere indeholde mekanismer for

kontrol, registrering af ændringer, samarbejde med og indberetning til tilsynsmyndighederne og for relevant uddannelse af personale.

EDPB har med Recommendations 1/2022 offentliggjort et ansøgnings-skema, der kan anvendes, når en virksomhed vil søge en tilsynsmyndighed om godkendelse af bindende virksomhedsregler. Med ansøgnings-skemaet specificeres indholdet af disse regler.

3.3. Kravene til lovgivningen i tredjelandet

Som beskrevet ovenfor fastslog EU-Domstolen i *Schrems I*, C-362/14, at det kan være i strid med forordningen og chartret om grundlæggende rettigheder, hvis lovgivningen i et tredjeland gør det muligt for offentlige myndigheder på generel vis at få adgang til indholdet af elektronisk kommunikation, herunder personoplysninger, eller hvis lovgivningen ikke indeholder retsmidler, der gør det muligt at få adgang til egne oplysninger eller få oplysninger berigtiget eller slettet. På den baggrund fastslog dommen, at Safe Harbor-ordningen ikke ydede et "tilstrækkeligt beskyttelsesniveau" efter det tidligere persondatadirektivs art. 26 (nu forordningens art. 45). Selvom dommen angik overførsler under bestemmelsen om sikre tredjelande (forordningens art. 45), var dens præmisser formuleret så bredt, at den også måtte antages at have betydning for overførsler til usikre tredjelande efter art. 46. Risikoen for, at en manglende beskyttelse i tredjelandets lovgivning er i strid med chartret, er således den samme uanset overførselsgrundlaget.

Denne antagelse blev bekræftet med *Schrems II*, C-311/18. Som omtalt ovenfor fastslog dommen, at Privacy Shield-ordningen (afløseren for Safe Harbor-ordningen) ikke levede op til kravene om et tilstrækkeligt beskyttelsesniveau efter forordningens art. 45. Hovedspørgsmålet i sagen var imidlertid, om der lovligt kunne ske overførsler til USA på baggrund af standardkontraktbestemmelser efter art. 46. Domstolen fastslog, at de af Kommissionen vedtagne standardkontraktbestemmelser var gyldige og således kunne anvendes som overførselsgrundlag. Domstolen fastslog imidlertid også, at en lovlig overførsel til et tredjeland forudsætter, at lovgivningen i tredjelandet sikrer et beskyttelsesniveau for de grundlæggende rettigheder, som i det væsentlige svarer til det niveau, der er sikret i EU i medfør af forordningen sam-

Krav om
tilstrækkeligt
beskyttelsesniveau

menholdt med charteret. Med andre ord kan der ikke ske en lovlig overførsel, selvom dataeksportøren og dataimportøren aftaler at bruge Kommissionens standardkontraktbestemmelser, hvis lovgivningen i tredjelandet indebærer, at der trods anvendelsen af standardkontraktbestemmelserne ikke ydes en tilstrækkelig beskyttelse af de registreredes grundlæggende rettigheder.

EDPB betegner sådan lovgivning for “problematisk lovgivning”, der i henstilling 01/2020 note 50 defineres som lovgivning, der “1) pålægger modtageren af personoplysninger fra Den Europæiske Union forpligtelser og/eller påvirker de overførte oplysninger på en måde, der kan bringe overførselsværktøjets kontraktlige garanti for et i det væsentlige tilsvarende beskyttelsesniveau i fare, og 2) ikke respekterer kernen i de grundlæggende rettigheder og frihedsrettighederne, der er anerkendt i EU’s charter om grundlæggende rettigheder, eller går videre, end hvad der er nødvendigt og forholdsmæssigt i et demokratisk samfund for at sikre et af de vigtige mål, som det ligeledes er anerkendt i EU-retten eller EU-medlemsstaternes lovgivning, såsom de mål, der er anført i artikel 23, stk. 1, i GDPR”.

I praksis kan dette navnlig forekomme, hvis lovgivningen i tredjelandet giver landets offentlige myndigheder adgang til at indhente personoplysninger om registrerede fra EU uden den beskyttelse, der følger af charterets art. 7, 8 og 47. De standardkontraktbestemmelser, der er indgået mellem dataeksportøren og dataimportøren binder selvsagt ikke tredjelandets offentlige myndigheder, og disse bestemmelser kan derfor heller ikke begrænse den (efter charteret eventuelt for vidtgående) adgang til de overførte personoplysninger, som tredje-landslovgivningen udstyrer de offentlige myndigheder med. Det vil ofte være lovgivning, der giver efterretningstjenester adgang til at indhente personoplysninger, som volder problemer, da efterretningstjenester som følge af deres virke har en vidtgående og mindre transparent adgang til at indsamle oplysninger. I *Schrems*-dommene var det således også lovgivning, der gav de amerikanske efterretningstjenester adgang til at indsamle personoplysninger, som EU-Domstolen fandt i strid med forordningen og charteret.

Schrems II-dommen indebærer, at en dataeksportør, som ønsker at overføre oplysninger til en dataimportør i et usikkert tredjeland efter art. 46, både skal finde hjemmel i et af de overførselsgrundlag, der er

anført i art. 46 (standardkontraktbestemmelser, bindende virksomhedsregler mv.) og sikre sig, at lovgivningen i tredjelandet om efterretningstjenesters og andre offentlige myndigheders adgang til de overførte personoplysninger ikke krænker de registreredes rettigheder efter charteret og forordningen (eller med EDPB's formulering og definition ikke er "problematiske"). EU-Domstolen anfører således i dommens præmis 134, at det "først og fremmest [tilkommer] den dataansvarlige eller dennes databehandler i hvert enkelt tilfælde, og hvor det er relevant, i samarbejde med modtageren af overførslen at undersøge, om lovgivningen i bestemmelsestredjelandet sikrer den fornødne beskyttelse ...".

Den tredjelandsvurdering, som dataeksportøren forpligtes til at foretage, betegnes også for en "transfer impact assessment" eller blot "TIA".

3.3.1. Vurderingen af tredjelandslvgivningen

Det er en kompleks opgave at vurdere, om lovgivningen i tredjelandet lever op til kravene efter charteret og forordningen. Det følger af *Schrems II*-dommens præmis 104, at der skal tages udgangspunkt i de forhold, der er angivet i forordningens art. 45, stk. 2 (som angiver, hvad Kommissionen skal lægge vægt på ved vurderingen af, om et tredjeland kan opnå status af sikkert tredjeland).

I vurderingen kan dataeksportøren endvidere inddrage de fire såkaldte "europæiske essentielle garantier", der er identificeret af EDPB.

De fire europæiske essentielle garantier

Garantierne blev første gang offentliggjort af den daværende art. 29-gruppe i april 2016 på baggrund af *Schrems I*-dommen og en række andre domme fra EU-Domstolen og Den Europæiske Menneskerettighedsdomstol. En opdateret udgave af dokumentet blev offentliggjort af EDPB efter *Schrems II*-dommen (anbefalinger 02/2020 om de europæiske væsentlige garantier for overvågningsforanstaltninger).

De fire garantier har følgende indhold:

1. Behandling skal være baseret på klare, præcise og tilgængelige regler.
2. Nødvendighed og proportionalitet hvad angår de legitime mål, der forfølges, skal godtgøres.
3. Der skal findes en uafhængig tilsynsmekanisme.

4. Der skal være effektive retsmidler til rådighed for de enkelte personer.

Garantierne er så bredt formuleret, at de ikke i sig selv giver svaret på, om lovgivningen i et tredjeland lever op til de europæiske krav, men de kan dog tjene som et udgangspunkt for vurderingen.

Det følger af *Schrems II*-dommen, at der både skal foretages en vurdering af selve lovgivningen og af praksis. At vurderingen skal omfatte "praksis" indebærer, at det ikke er tilstrækkeligt at forholde sig, hvad loven siger, hvis lovgivningen ikke bliver fulgt af myndighederne i praksis. Indsamler myndighederne i praksis oplysninger på en måde, der krænker grundlæggende rettigheder, kan dataeksportøren altså ikke overføre oplysningerne med henvisning til, at lovgivningen "på papiret" yder tilstrækkelig beskyttelse. Som udgangspunkt må dataeksportøren dog kunne forvente, at myndighederne overholder lovgivningen. I henstilling 01/2020, pkt. 43.1, anfører EDPB, at der kan være tilfælde, hvor myndighedernes praksis "klart" kan være udtryk for, at de normalt ikke overholder den lovgivning, der i princippet regulerer deres aktiviteter. Dette understreger, at der skal foreligge ganske klare indikationer af, at myndighederne ikke overholder lovgivningen, før dataeksportøren ikke uden videre kan lægge dette til grund.

Praksis
– praksis i strid
med lovgivning

Praksis kan også få betydning, hvis der ikke eksisterer lovgivning i tredjelandet, der dækker myndighedernes indsamling af oplysninger, eller hvor en sådan lovgivning er mangelfuld. I så fald skærpes kravene til dataeksportørens vurdering af praksis. EDPB formulerer det således, at den manglende eller mangelfulde lovgivning ikke giver eksportøren mulighed for automatisk at konkludere, at overførslen er undergivet fornødne garantier, men at eksportøren skal kontrollere, om der er indikationer af, at den anvendte praksis ikke giver et tilstrækkeligt beskyttelsesniveau, henstilling 01/2020, pkt. 43.2. Uden sådanne indikationer kan eksportøren lægge til grund, at der består et tilstrækkeligt beskyttelsesniveau.

– praksis i tilfælde
af manglende
eller mangelfuld
lovgivning

Der er omdiskuteret, i hvilket omfang inddragelsen af praksis ligeledes indebærer, at lovgivningen muliggør en overførsel, selvom den ikke yder en tilstrækkelig beskyttelse, hvis det er usandsynligt, at myndighederne i praksis vil kræve udlevering af de oplysninger, der omfattes af overførslen. EDPB's oprindelige udkast til henstilling 01/2020

– problematisk
lovgivning
anvendes ikke i
praksis

gav ikke mulighed herfor, men det blev indføjet i den endelige version. I afsnit 43.3 anføres således, at dataeksportøren i denne situation kan “beslutte at gå videre med overførslen uden at skulle gennemføre supplerende foranstaltninger, hvis I [dataeksportørerne] ikke har nogen grund til at tro, at den relevante og problematiske lovgivning i praksis vil blive anvendt på jeres overførte oplysninger og/eller importør”. Henstillingen opstiller dog strenge krav til dokumentationen for, at lovgivningen ikke vil blive anvendt i praksis. Dataeksportøren skal således kunne vurdere dette gennem relevante, objektive, pålidelige, verificerbare og offentligt tilgængelige kilder. I henstillingens bilag 3 er angivet en ikke-udtømmende liste over kilder, der kan inddrages i vurderingen. Det følger endvidere af henstillingen, pkt. 47, at dataeksportøren kan inddrage dataimportørens dokumenterede praktiske erfaringer med relevante tidligere tilfælde af anmodninger om adgang modtaget fra offentlige myndigheder i tredjelandet i sin vurdering. Dette forudsætter dog, at tredjelandslvgivningen ikke forbyder importøren at oplyse om udleveringsanmodninger fra offentlige myndigheder. Det anføres endvidere, at det ikke i sig selv kan være afgørende for vurderingen, at dataimportøren ikke tidligere er blevet anmodet om udlevering, men at dette kan indgå som del af den samlede vurdering, der skal tage udgangspunkt i de objektive kilder. Dataeksportørens vurdering skal foreligge i form af en skriftlig rapport og indeholde “omfattende oplysninger om den juridiske vurdering af lovgivningen og praksis og anvendelsen heraf på de konkrete overførsler, den interne procedure til udarbejdelse af vurderingen (herunder oplysninger om aktører involveret i vurderingen, f.eks. advokatfirmaer, konsulenter eller interne afdelinger) og datoer for kontrollen” (henstillingens note 54). Rapporten skal endvidere være godkendt af dataeksportørens retlige repræsentant.

De meget strenge dokumentationskrav afspejler formentlig en generel skepsis hos EDPB mod at anvende en risikobaseret tilgang, hvor der lægges vægt på den faktiske sandsynlighed for, at de overførte oplysninger gøres til genstand for udlevering. Som nævnt i afsnit 3.1.2 afviste EDPB denne mulighed i sit høringssvar til Kommissionens udkast til standardkontraktbestemmelser og havde heller ikke medtaget den i det oprindelige udkast til henstilling 01/2020. Muligheden for at tillade en overførsel, når dataeksportøren ikke har nogen grund til at

tro, at den problematiske lovgivning vil blive anvendt i praksis i forhold til de konkrete oplysninger, sådan som det nu er skrevet ind i henstilling 01/2020 og Kommissionens standardkontraktbestemmelser, har således karakter af et kompromis mellem Kommissionen og EDPB.

Uenigheden er ikke helt elimineret med formuleringerne i de to dokumenter. Mens henstilling 01/2020 angiver, at vurderingen skal tage udgangspunkt i objektive kilder og i bilag 3 oplister dataimportørens tidligere erfaringer som det kriterium, der kan tillægges mindst vægt, lægger standardkontraktbestemmelserne op til, at vurderingen skal tage udgangspunkt i dataimportørens praktiske erfaringer, som dog skal understøttes af de objektive kilder.

Denne skepsis synes også afspejlet i nogle af de afgørelser, som de nationale tilsynsmyndigheder efterfølgende har truffet om tredjelandsoverførsler. Særligt markant er en afgørelse fra den østrigske tilsynsmyndighed fra 22. april 2022, hvor tilsynet slog fast, at overførsel af personoplysninger (ip-adresser) til Google i USA som led i brugen af Google Analytics var en ulovlig tredjelandsoverførsel. Tilsynet afviste, at det havde betydning for vurderingen, om de amerikanske efterretningstjenester havde interesse i oplysningerne (uautoriseret oversættelse fra tysk til engelsk): Finally, as far as the second respondent argues that US intelligence services have no interest in the data processed in this case - for example, by stating that the information on the 'screen resolution is an industry standard' - it must be countered that it is not a question of a possible interest of US intelligence services, but of their access possibilities". Sagen var én af en række sager om tredjelandsoverførsler ved brug af Google Analytics, som foreningen NOYB (ledet af Max Screms) havde indbragt for forskellige tilsynsmyndigheder. Sagerne har været koordineret mellem tilsynsmyndighederne gennem EDPB, og den østrigske afgørelse udtrykker derfor den generelle opfattelse hos EDPB. Dette blev bekræftet i en udtalelse fra Datatilsynet fra 21. september 2022, hvor tilsynet anførte, at tilsynet ville afgøre sager på tilsvarende måde, og at "[S]elvom de enkelte sager er blevet afgjort individuelt af de respektive tilsynsmyndigheder, som har modtaget den oprindelige klage, er afgørelserne udtryk for en fælleseuropæisk holdning blandt tilsynsmyndighederne".

Det må erkendes, at det er vanskeligt at forene den meget kategoriske afvisning af at lægge vægt på, om de konkrete oplysninger kunne have interesse for efterretningstjenesterne (eller andre offentlige myndigheder) i den østrigske afgørelse med både retningslinjer 01/2020's og Kommissionens standardkontraktbestemmelser angivelse af, at lovgivningen i et tredjeland ikke hindrer en overførsel, hvis det er usandsynligt, at myndighederne i praksis vil kræve udlevering af de oplysninger, der omfattes af overførslen. Med den linje, der hermed er lagt af de europæiske tilsynsmyndigheder, er rummet for at anvende denne mulighed meget snævert, og måske nærmest ikke-eksisterende. *Schrems II*-dommen forholder sig ikke direkte til, om der kan lægges vægt på sandsynligheden for, at lovgivningen vil blive anvendt i praksis. Det er derfor også vanskeligt at vurdere, om Domstolen vil være enig med EDPB og Kommissionen i, at dette er tilfældet, og om Domstolen i givet fald vil være enig i den meget restriktive fortolkning af, hvor stort rummet herfor er, som EDPB synes at lægge til grund. Det er under alle omstændigheder problematisk, at EDPB melder en retstilstand ud, som man synes ikke selv at ville følge.

3.3.2. Supplerende foranstaltninger

I de situationer, hvor den dataansvarlige gennem sin vurdering af tredjefjeldslovgivningen når frem til, at denne tillader offentlige myndighedernes adgang til oplysninger i et omfang, der ikke er foreneligt med charteret og forordningen, vil der som udgangspunkt ikke kunne ske en overførsel. EU-Domstolen efterlader dog i *Schrems II*-dommen en vis mulighed for, at der forsat kan overføres oplysninger til usikre tredjefjeldslande, selvom lovgivningen ikke sikrer de registreredes grundlæggende rettigheder. Det følger således af dommens præmis 133, at den manglende beskyttelse efter tredjefjeldslovgivningen i nogle tilfælde kan opvejes gennem supplerende foranstaltninger, som sikrer, at der samlet set opnås det fornødne beskyttelsesniveau, jf. præmissens 2. pkt.:

For så vidt som disse standardbestemmelser om databeskyttelse, henset til deres karakter, ikke kan give garantier, der rækker videre end en kontraktlig forpligtelse til at sikre, at det beskyttelsesniveau, der kræves efter EU-retten, er overholdt, kan der i forhold til disse, afhængigt af situationen i tredjefjeldet eller tredjefjeldene, være behov for, at den data-

ansvarlige vedtager supplerende foranstaltninger for at sikre, at dette beskyttelsesniveau er overholdt.

Dommen indeholder ikke nærmere angivelser af, hvad sådanne supplerende foranstaltninger kan bestå i. Det har EDPB til gengæld givet et bud på i henstilling 01/2020. I henstillingen, pkt. 53, fastslås, at kontraktretlige og organisatoriske foranstaltninger alene generelt ikke kan overvinde tredjelandets offentlige myndigheders adgang til personoplysningerne på grundlag af problematisk lovgivning. Dette er også korrekt, da kontraktretlige foranstaltninger ikke vil binde myndighederne i tredjelandet (dette er grunden til, at standardkontraktbestemmelser ikke i sig selv kan sikre de fornødne garantier i denne situation), og da organisatoriske foranstaltninger heller ikke hverken juridisk eller praktisk kan hindre myndighedernes adgang. Tilbage står derfor kun de tekniske foranstaltninger. I sin vejledning har EDPB med udgangspunkt i en række eksempler overvejet, hvilke tekniske foranstaltninger, der kan sikre et tilstrækkeligt beskyttelsesniveau, og kun været i stand til at pege på kryptering og pseudonymisering som effektive tekniske supplerende foranstaltninger. Vejledningen anfører således, at kryptering af personoplysninger kan udgøre en effektiv supplerende foranstaltning, hvis krypteringsnøglen ikke overlades til dataimportøren (eller andre i det usikre tredjeland). Det vil med andre ord være lovligt at overføre krypterede personoplysninger til tredjelande, hvis lovgivning ikke yder tilstrækkelig beskyttelse af grundlæggende rettigheder, når krypteringsnøglen forbliver hos dataeksportøren (den dataansvarlige). Dette gælder tilsvarende ved pseudonymisering af oplysninger, der ikke gør det muligt for dataimportøren (eller andre i det usikre tredjeland) at føre oplysningerne tilbage til en bestemt fysisk person. Derimod følger det af vejledningen og dets eksempel 6, at EDPB ikke er i stand til at anvise supplerende foranstaltninger, som kan lovliggøre en overførsel af personoplysninger i klartekst til et tredjeland, hvis lovgivning ikke yder tilstrækkelig beskyttelse af de grundlæggende rettigheder.

3.3.3. En risikobaseret tilgang?

Siden *Schrems II*-dommen har der pågået en omfattende debat om de begrænsede muligheder for at foretage tredjelandsoverførsler efter for-

ordningen. Særligt EDPB's fortolkning reglerne og *Schrems II*-dommen er blevet kritiseret for ikke i tilstrækkelig grad at lægge vægt på den reelle risiko forbundet med en overførsel. Som led i denne kritik er det blevet anført, at forordningens regler om tredjelandsoverførsler er risikobaserede, og at der derfor skal anvendes en risikobaseret tilgang, når det afgøres, om en tredjelandsoverførsel kan finde sted. Til støtte herfor er blevet anført, at forordningens art. 24 er en horisontal bestemmelse, der indebærer en risikobaseret tilgang til alle de forpligtelser, den dataansvarlige er underlagt efter forordningen, herunder forpligtelserne i forbindelse med tredjelandsoverførsler.

Se således Lokke Moerel, What happened to the Risk Based Approach to Data Transfers? og i samme retning Paul Breithbarth, A Risk-Based Approach to International Data Transfers, *European Data Protection Law Review*, 2021/4, s. 539 ff.

Det vil indebære, at dataeksportøren forud for en tredjelandsoverførsel skal foretage en risikovurdering, der omfatter sandsynligheden for, at offentlige myndigheder i tredjelandet vil kræve oplysningerne udleveret og de potentielle konsekvenser (skadevirkning) for de registrerede, hvis der sker. Fører denne risikovurdering til, at der kun er en lav risiko for de registrerede ved overførslen, kan den lovligt foretages.

EDPB kan siges i et vist omfang at inddrage risici, når henstilling 01/2020 lægger til grund, at der kan foretages en tredjelandsoverførsel, hvis dataeksportøren ikke har nogen grund til at tro, at den problematisk lovgivning i praksis vil blive anvendt – eller med andre ord sandsynligheden for, at offentlige myndigheder vil anmode om udlevering af oplysningerne. Dette er dog ikke en risikovurdering som det kendes fra andre af forordningens bestemmelser, da konsekvenserne for de registrerede ikke skal inddrages, og da sandsynligheden tilsyneladende skal nærme sig nul i den vurdering, som skal foretages. EDPB har således ikke anerkendt, at reglerne om tredjelandsoverførsler er risikobaserede og at muligheden for overførsler skal tage udgangspunkt i en risikovurdering. Tværtimod har den østrigske tilsynsmyndighed i den ovenfor omtalte afgørelse fra 22. april 2022 eksplicit anført, at dette ikke er tilfældet (uautoriseret oversættelse fra tysk til engelsk):

“Such a ‘risk-based approach’ cannot be derived from the wording of Art. 44 GDPR [...]”

On the contrary, it can be deduced from the wording of Art. 44 GDPR that for *every* data transfer to a third country (or to an international organisation), it must be ensured that the level of protection guaranteed by the GDPR is not undermined.

The success of a complaint of a violation of Art. 44 GDPR therefore does *not* depend on whether a certain “minimum risk” is present or whether US intelligence services have actually accessed data. According to the wording of this provision, a violation of Art. 44 GDPR already exists if personal data are transferred to a third country without an adequate level of protection”.

Da afgørelsen som nævnt er et del af et sagskompleks, der er koordineret i EDPB, må det antages, at den udtrykker EDPB’s holdning.

Det kan tiltrædes, at art. 24 ikke gælder for tredjelandsoverførsler, og at der således ikke lovligt kan foretages tredjelandsoverførsler på baggrund af den type risikovurdering, som skal foretages efter art. 24. Som anført i kap. 8.2.2 pålægger art. 24 den dataansvarlige en pligt til at vurdere risikoen for en utilsigtet ulovlig behandling. Bestemmelsen kan derimod ikke tages til indtægt for at skulle regulere, hvornår en behandling, herunder en tredjelandsoverførsel, *er* lovlig. Dette kan også udtrykkes således, at art. 24 ikke har til formål at påvirke indholdet af forordningens materielle bestemmelser. Det er endvidere værd at bemærke, at EU-Domstolen ikke nævner art. 24 i *Schrems II*-dommen. Havde udgangspunktet for lovligheden af en tredjelandsoverførsel vidterligt været en risikovurdering efter art. 24, må det forventes, at EU-Domstolen havde nævnt det i en så omfattende dom, der handler om risikoen forbundet med tredjelandsoverførsler.

3.3.4. Fortsatte udfordringer

Den retstilstand, der etableres med *Schrems II* og EDPB’s fortolkning, gør det meget vanskeligt at overføre personoplysninger (i klartekst) til mange lande i verden. I en globaliseret og digitaliseret verden giver dette betydelige udfordringer. Med det ovenfor omtalte Data Privacy Framework er det forventningen, at Kommissionen vil træffe en tilstrækkelighedsafgørelse i første halvdel af 2023, der gør det muligt at overføre oplysninger til amerikanske virksomheder efter art. 45. Her-

med vil en del af de praktiske problemer blive løst bl.a. i forbindelse med brug af amerikanske cloudtjenester. Der vil dog fortsat bestå mange udfordringer, da der selvsagt også foretages mange overførsler til andre usikre tredjelande end USA. Også brugen af de amerikanske cloudtjenester kan fortsat være udfordret, da de i mange tilfælde supporteres af medarbejdere, der er placeret i forskellige lande. Sådanne medarbejders adgang til personoplysninger i de cloudbaserede systemer kan som beskrevet ovenfor i sig selv udgøre tredjelandsoverførsler. Hertil kommer muligheden for, at EU-Domstolen vurderer, at Data Privacy Framework ikke yder en tilstrækkelig beskyttelse og dermed erklærer en eventuel tilstrækkelighedsafgørelse fra Kommissionen ugyldig endnu en gang. Det er således forventningen, at den nye ordning også vil blive anfægtet og dermed i sidste ende skal vurderes af EU-Domstolen.

Det er må nuværende tidspunkt uklart, hvordan disse udfordringer skal løses. De fortsatte udfordringer ved brug af cloudtjenester kan muligvis reduceres ved, at cloududbydere justerer deres tjenester, således at der kan vælges europæiske løsninger, hvor oplysningerne forbliver i Europa. Nogle af de store cloududbydere er begyndt på dette. Det kan heller ikke udelukkes, at den fortolkning af reglerne om tredjelandsoverførsler og *Schrems II*-afgørelsen, som ligger til grund for tilsynsmyndighedernes praksis, vil blive anfægtet og prøvet ved domstolene. Dette kan både omfatte tilsynsmyndighedernes afvisning af, at reglerne om tredjelandsoverførsler hviler på en risikobaseret tilgang (selvom denne afvisning som anført ovenfor må anses for korrekt), tilsynsmyndighedernes meget restriktive tilgang til at tillade overførsler, når dataeksportøren ikke har grund til at tro, at offentlige myndigheder i praksis vil have en interesse i oplysningerne og påberåbelse af en proportionalitetsvurdering, der i højere grad (også) lægger vægt på andre grundlæggende rettigheder, herunder retten til at drive virksomhed efter charterets art. 15. Hvordan domstolene og i sidste ende EU-Domstolen vil se på disse spørgsmål, må fremtidige sager vise.

4. Undtagelser i særlige situationer – art. 49

Forordningens art. 49 opregner en række forskellige specifikke hjemmelsgrundlag for overførsel af personoplysninger i situationer, hvor

tredjelandet ikke yder et tilstrækkeligt beskyttelsesniveau (art. 45), og der heller ikke er sikret fornødne garantier efter art. 46.

4.1. Generelt om anvendelsesområdet

Da overførsel efter art. 49 finder sted i en situation, hvor de registrerede ikke ydes en beskyttelse, der gælder efter art. 45 og 46 (der begge kræver, at de eksporterede oplysninger beskyttes på et niveau, der er i det væsentlige svarer til forordningens), har bestemmelsen karakter af en undtagelsesbestemmelse med et snævert anvendelsesområde, jf. herved også EDPB's retningslinjer 02/2018 om art. 49, s. 4. Til gengæld vil bestemmelsen kunne finde anvendelse selv i situationer, hvor lovgivningen i tredjelandet indebærer en potentiel krænkelse af de registreredes grundlæggende rettigheder (*Schrems II*-situationen). Det kan forekomme en smule paradoksalt, at registrerede potentielt skal tåle krænkelse af grundlæggende rettigheder, når en overførsel finder sted med hjemmel i art. 49, men der ikke tvivl om, at bestemmelsen kan finde anvendelse uanset en eventuel problematisk lovgivning i tredjelandet. Dette er også udtrykkeligt lagt til grund af EU-Domstolen i *Schrems II*, C-311/18, hvor Domstolen nævner art. 49 som et muligt overførselsgrundlag i de situationer, hvor art. 45 og 46 ikke kan anvendes som følge af problematisk tredjelandslovgivning, jf. dommens præmis 202. Se også EDBP vejledning 02/2018, s. 4: "Undtagelserne i artikel 49 er således undtagelser fra det generelle princip om, at personoplysninger kun kan overføres til tredjelande, hvis der er et tilstrækkeligt beskyttelsesniveau i tredjelandet, eller hvis der er indført fornødne garantier, og de registrerede har effektive rettigheder, som kan håndhæves, så de fortsat vil nyde godt af deres grundlæggende rettigheder og garantier".

Anvendelsen af art. 49 som hjemmelsgrundlag for en overførsel til et tredjeland, hvis lovgivning ikke yder en tilstrækkelig beskyttelse, forudsætter dog, at overførslen ikke er i strid med charteret, idet den sekundære EU-ret (forordningen) ikke kan give hjemmel hertil. I *Schrems II* fastslog EU-Domstolen, at den amerikanske lovgivning ikke ydede en tilstrækkelig beskyttelse efter forordningen "fortolket i lyset af charteret". EU-Domstolen fastslog således ikke, at overførslen var i strid med selve charteret men "kun", at den var i strid med forordningen (fortol-

ket i lyset af charteret). Se også EDPB's vejledning 02/2018, s. 3, hvor det angives, at anvendelsen af undtagelserne i art. 49 "aldrig bør føre til en situation, hvor de grundlæggende rettigheder kan blive tilsidesat".

4.2. De enkelte undtagelser

Efter art. 49, stk. 1, 1. pkt., litra a, kan en overførsel finde sted, når den registrerede har givet sit udtrykkelige samtykke. På samme måde som den registrerede kan give samtykke til en behandling af oplysninger efter art. 6-9, kan den registrerede således give samtykke til en overførsel af oplysninger til tredjelande. Om samtykkebegrebet henvises til kap. 5.2 ovenfor. Det er en forudsætning, at den registrerede er blevet informeret om de mulige risici ved overførslen til et usikkert tredjeland, uden at garantierne efter art. 46 er sikret.

Samtykke

Efter litra b kan overførsel finde sted, når den er nødvendig af hensyn til opfyldelse af en kontrakt mellem den registrerede og den dataansvarlige eller af hensyn til gennemførelse af foranstaltninger, der træffes på den registreredes anmodning forud for indgåelsen af en sådan kontrakt. Efter litra c gælder det endvidere, hvis overførslen er nødvendig af hensyn til indgåelse eller opfyldelse af en kontrakt, der i den registreredes interesse indgås mellem den dataansvarlige og en anden fysisk person. Det vil eksempelvis kunne være tilfældet, når en dansk virksomhed på vegne af en dansk kunde bestiller varer eller tjenesteydelser hos en udenlandsk virksomhed, der skal kende kundens adresse mv. Det følger ikke af selve bestemmelsen, men efter præambelbetragtning 111 kan litra b og c kun bruges, hvis overførslen er lejlighedsvis og nødvendig i forbindelse med kontrakten. I EDPB's vejledning 02/2018, s. 9, anføres, at regelmæssige overførsler af personoplysninger inden for rammerne af faste forbindelser betragtes som systematiske og gentagne og dermed ikke "lejlighedsvis", og at mange overførsler inden for rammerne af forretningsforbindelser derfor ikke kan baseres på litra b og c.

Opfyldelse
af aftaler

I vejledningen angives som et eksempel på en lejlighedsvis overførsel, at personoplysninger om en salgschef, der som led i opfyldelsen af sin ansættelseskontrakt besøger forskellige kunder i tredjelande, sendes til disse kunder for at tilrettelægge møder. Som et andet eksempel angives at en bank i EU overfører personoplysninger til en bank i et tredjeland

for at opfylde en kundes anmodning om at foretage en betaling, så længe denne overførsel ikke finder sted inden for rammerne af et fast samarbejde mellem de to banker. Som et eksempel på en overførsel, der ikke er lejlighedsvis angives, at et multinationalt selskab tilrettelægger kurser i et uddannelsescenter i et tredjeland og systematisk overfører personoplysninger om de ansatte, der deltager i et kursus (f.eks. oplysninger om navn og stillingsbetegnelse, men potentielt også om kostbehov eller mobilitetsrestriktioner).

Efter litra d kan overførslen ske, hvis den er nødvendig af hensyn til vigtige samfundsinteresser. Det følger af art. 49, stk. 4, at sådanne samfundsinteresser skal være anerkendt i EU-retten eller i retten i den medlemsstat, som den dataansvarlige er underlagt.

Vigtige samfundsinteresser

Efter litra e kan overførslen ske, hvis den er nødvendig for at et retskrav kan fastlægges, gøres gældende eller forsvares. Se om det tilsvarende begreb under art. 9 i kap. 5.6.2.6 ovenfor. Det følger ikke af bestemmelsen men fremgår af præambelbetragtning 111, at bestemmelsen kun kan anvendes, hvis overførslen er lejlighedsvis og nødvendig på samme måde, som det gælder for overførsler i forbindelse med opfyldelse af en aftale.

Retskrav

Efter litra f kan overførslen ske, hvis den er nødvendig for at beskytte den registreredes vitale interesser. Se om det tilsvarende begreb under art. 6 i kap. 5.3.3 ovenfor.

Vitale interesser

Art. 49, stk. 1, 2. pkt., rummer en snæver afvejningsregel, der kun kan anvendes, hvis ingen af undtagelserne i stk. 1, 1. pkt. litra a-g, finder anvendelse, og hvis overførslen heller ikke kan hjemles i art. 45 eller 46. I denne situation kan der foretages en overførsel, hvis overførslen

Snæver afvejningsregel

- ikke gentages
- kun vedrører et begrænset antal registrerede
- er nødvendig af hensyn til vægtige legitime interesser, som følges af den dataansvarlige
- den registreredes interesser eller rettigheder og frihedsrettigheder ikke går forud for disse interesser
- den dataansvarlige har vurderet alle omstændigheder i forbindelse med overførslen og på grundlag af denne vurdering giver passende garantier for beskyttelse af personoplysningerne.

Det følger af art. 49, stk. 3, at undtagelserne i stk. 1, første afsnit, littera a (samtykke), b og c (overholdelse af aftale) og andet afsnit (interesseafvejningsregel) ikke finder anvendelse på aktiviteter, der gennemføres af offentlige myndigheder som led i deres myndighedsudøvelse.

Offentlig
myndigheds-
udøvelse

5. Det nationale lokationskrav – DBL § 3, stk. 9

Da registerlovene blev vedtaget i 1978 under den kolde krig, var der en reel bekymring for, at Danmark kunne blive udsat for en invasion fra Sovjetunionen. Samtidig lå oplevelserne fra 2. verdenskrig ikke langt væk. Loven om offentlige registre indeholdt derfor en bestemmelse, hvorefter der skulle træffes særlige foranstaltninger, som i tilfælde af krig muliggjorde bortskaffelse eller tilintetgørelse af oplysninger som behandledes for den offentlige forvaltning, og som kunne være af særlig interesse for fremmede magter. Hermed ønskede man at hindre, at en besættelsesmagt fik adgang til vitale data, der bl.a. kunne sætte besættelsesmagten i stand til at overtage det administrative apparat eller på anden måde ramme vitale funktioner i tilfælde af krig. Reglen, der omtales som “kriksreglen”, blev videreført i persondataloven fra 2000, og blev bl.a. fortolket sådan, at visse it-systemer ikke fysisk måtte placeres i andre lande end Danmark. Datatilsynet traf således i 2007 en afgørelse (sag nr. 2007-214-0004) om, at ATP’s centrale systemer var omfattet af reglen og derfor ikke måtte driftes fra andre lande.

Den tidligere
kriksregel

Med databeskyttelsesloven er indført en ny regel, der afløser den tidligere kriksregel. Bestemmelsen, der fremgår af § 3, stk. 9, har følgende ordlyd:

DBL § 3, stk. 9

Justitsministeren kan efter forhandling med vedkommende minister fastsætte regler om, at personoplysninger, der behandles i nærmere bestemte IT-systemer, og som føres for den offentlige forvaltning, helt eller delvist alene må opbevares her i landet.

Formålet er fortsat at minimere risikoen for, at fremmede magter eller andre, der vil skade danske interesser, får adgang til systemer med store samlinger af vitale oplysninger. Er sådanne systemer fysisk placeret i andre lande, vil lovgivningen i det pågældende land kunne pålæg-

ge den, der driver systemerne, at udlevere oplysningerne. Formålet er endvidere at sikre, at danske myndigheder altid har adgang til disse samlinger af vitale oplysninger. Det følger af forarbejderne, at bestemmelsen alene finder anvendelse, hvis hensyn til statens sikkerhed kan begrunde et krav om fysisk placering i Danmark. Mere generelle hensyn til it-sikkerheden kan ikke begrunde brug af reglen, da disse hensyn varetages gennem de krav til behandlingssikkerhed, der følger af forordningens art. 32.

Reglen omfatter kun personoplysninger, ikke andre typer af oplysninger, uanset om disse måtte have betydning for statens sikkerhed. Restriktioner i omgangen med andre typer af oplysninger kan følge af anden lovgivning.

– kun personoplysninger

Reglen gælder kun for systemer, der føres for den offentlige forvaltning. Private virksomheders systemer er ikke omfattet (medmindre virksomheden varetager en opgave på vegne af en offentlig myndighed).

– den offentlige forvaltnings systemer

Reglen forbyder ikke kun overførsel af oplysninger til tredjelande men også til andre EU-lande. Reglen strider ikke mod EU-retten, fordi den omhandler national sikkerhed, og dermed vedrører aktiviteter, som falder uden for EU-retten. Denne type aktiviteter er eksplicit undtaget forordningen efter art. 2, stk. 2, litra a.

– forbud mod overførsel til andre EU-lande

Den tidligere krigsregel pålagde den enkelte dataansvarlig selv at vurdere, om et system var omfattet af krigsreglen. Dette førte til, at ganske mange offentlige it-systemer blev omfattet af krigsreglen, og også flere end reglen reelt påkrævede. Med den nuværende regel træffer Justitsministeren (efter forhandling med den pågældende myndighed) afgørelse om, hvorvidt et system omfattes af reglen. I så fald optages systemet på en liste over systemer omfattet af reglen. Dette skal ske, før systemet tages i brug. Listen, der fremgår som bilag til bekendtgørelse 220/2022, indeholder på nuværende tidspunkt otte systemer (forsvarssystemet DeMars, Digital Post, MitID, NemLog-in3, Statens Lønløsning, Rigspolitiets centrale system portefølje (samling af en række systemer, herunder Det Centrale Kriminalregister), Den fællesoffentlige Datafordeler og CPR-systemet).

– omfattede systemer

Justitsministeriet har udsendt en vejledning til reglen (vejledning 9557/2020). I vejledningen anføres, at en myndighed bør overveje følgende to punkter i vurderingen af, om et system omfattes af reglen:

1. Hvad er konsekvenserne ved, at personoplysninger kommer i et fremmed lands varetægt? Det skal i den forbindelse overvejes, hvilke alvorlige konsekvenser det vil have, hvis det fremmede land anvender oplysningerne mod Danmark, f.eks. offentliggør eller ændrer dem.
2. Hvad er konsekvenserne ved, at der ikke er adgang til personoplysningerne i it-systemet? Det skal i den forbindelse overvejes, hvor lang tid det vil tage at genskabe adgangen til personoplysningerne i it-systemet, herunder om dette kan ske, inden et kritisk tidspunkt indtræder.

Det følger endvidere af vejledningen, at reglen kun gælder for systemer, der udvikles efter reglens ikrafttræden (25. maj 2018) og ved genudbud af driften af systemer efter dette tidspunkt.

– ældre systemer

6. Forpligtelse til at udlevere oplysninger efter lovgivningen i tredjelande

I nogle tilfælde kan lovgivningen i et tredjeland forpligte en virksomhed til at udlevere personoplysninger, der fysisk er placeret hos europæiske virksomheder. Dette har bl.a. været aktuelt i forbindelse med amerikansk lovgivning, der har pålagt amerikanske virksomheder med europæiske datterselskaber at udlevere personoplysninger lagret hos det europæiske datterselskab til brug for kriminalitetsbekæmpelse i USA. Udlevering af sådanne oplysninger kan ske gennem traktater, hvor staterne gensidigt forpligtes til at bistå hinanden med håndhævelse af udenlandske afgørelser. Procedurene efter disse traktater kan dog være langvarige, og i nogle tilfælde har amerikanske myndigheder ikke ønsket at afvente disse procedurer, men har i stedet pålagt det amerikanske moderselskab at udlevere oplysningerne fra det europæiske datterselskab. Da en sådan udlevering vil være en overførsel efter databeskyttelsesforordningen, skal reglerne om overførsel til tredjelande iagttages. Den amerikanske virksomhed placeres hermed i den vanskelige situation, at det europæiske datterselskabs udlevering potentielt kan være i strid med den europæiske databeskyttelsesforordning, mens det amerikanske moderselskabs afvisning af udlevering kan være i strid med de amerikanske regler. I praksis kan denne problemstilling

kun løses gennem internationale aftaler. I mangel af sådanne aftaler må det konstateres, at de involverede virksomheder kan blive bragt i en vanskelig og for så vidt urimelig situation.

Problemstillingen er adresseret i forordningens art. 48, der dog blot fastslår, at en dom mv. fra et tredjeland ikke i sig selv udgør et hjemmelsgrundlag for overførsel efter forordningen. Bestemmelsen, der således ikke indeholder nogen løsning af problemstillingen (men i realiteten blot cementerer den), har følgende ordlyd:

Enhver dom afsagt af en domstol eller ret og enhver afgørelse truffet af en administrativ myndighed i et tredjeland, der kræver, at en dataansvarlig eller en databehandler overfører eller videregiver personoplysninger, kan kun anerkendes eller håndhæves på nogen måde, hvis den bygger på en international aftale, såsom en traktat om gensidig retshjælp mellem det anmodende tredjeland og Unionen eller en medlemsstat, uden at det berører andre grunde til overførsel i henhold til dette kapitel.

I hvilket omfang stater kan udbrede den territoriale anvendelse af deres nationale lovgivning, vil i sidste ende bero på folkeretten.

Der verserede i flere år en retssag mellem den amerikanske regering og Microsoft, der nægtede at udlevere personoplysninger fra Microsofts irske datterselskab og afviste, at der var hjemmel hertil. Sagen blev bragt for den amerikanske højesteret, men afsluttet i foråret 2018, inden der blev afsagt dom, da der i mellemtiden blev vedtaget amerikansk lovgivning (CLOUD ACT), som indeholdt en klar hjemmel til at pålægge Microsoft at udlevere de pågældende oplysninger.

Hvis en dataansvarlig overlader personoplysninger til en europæisk databehandler, f.eks. en cloudleverandør, der er sine vilkår forbeholder sig retten til at overføre oplysninger til sit moderselskab i et tredjeland, hvis tredjelandslvgivningen forpligter moderselskabet til at udlevere oplysningerne til myndigheden i dette land, foreligger en tilsigtet overførsel, som den dataansvarlige har ansvaret for, jf. afsnit 1.1 ovenfor om overførselsbegrebet.

Kapitel 10

Tilsyn

Databeskyttelsesretten beskytter individet mod integritetskrænkende behandlinger af den pågældendes personoplysninger. Da den potentielt krænkede part i databeskyttelsesretten er individet, er der grund til at overveje, hvordan det sikres, at reglerne håndhæves. Det er både kosteligt og tidkrævende at føre retssager, og enkeltpersoner vil sjældent tage et sådant skridt, selvom der er sket en ulovlig behandling af den pågældendes personoplysninger. Hertil kommer, at det ofte vil være umuligt for den enkelte at konstatere og dokumentere, hvorvidt der er sket en krænkelse. Bl.a. med henblik på at sikre en effektiv håndhævelse af databeskyttelsesreglerne foreskriver forordningen, at der skal føres tilsyn med overholdelse af reglerne af en national tilsynsmyndighed. Kravet om uafhængig kontrol følger ligeledes af EU's charter om grundlæggende rettigheder, art. 8, stk. 3. Forordningen indeholder en ganske omfattende regulering af kravene til tilsynsmyndighederne og deres opgaver, beføjelser mv., som suppleres af nationale regler. I Danmark indeholder databeskyttelsesloven således regler om Datatilsynet. Disse regler beskrives nedenfor i afsnit 1.

Globaliseringen og den teknologiske udvikling har betydet, at mange tjenester, der behandler personoplysninger, udbydes på tværs af landegrænser. Den samme tjeneste kan derfor indebære behandling af personoplysninger i en lang række lande bedst illustreret ved de store techvirksomheder som Meta/Facebook, Google, Amazon m.fl. Dette skaber et behov for koordinering mellem de nationale tilsynsmyndigheder, ikke mindst fordi tilsynsmyndighederne med forordningen skal

håndhæve et regelsæt, der er identisk i hele EU, og som derfor også bør fortolkes ens i alle medlemsstaterne. Den grundlæggende tanke om regelharmonisering i EU ville være alvorligt svækket, hvis de enkelte tilsynsmyndigheder etablerede deres egen og meget forskelligartede praksis. Udover dette harmoniseringsønske har de senere år vist, at der ikke mindst i forhold til de store techvirksomheder er behov for en fælleseuropæisk indsats i bestræbelserne på at sikre overholdelsen af de europæiske databeskyttelsesregler. Forordningen indeholder derfor en række bestemmelser om samarbejde mellem tilsynsmyndighederne og særligt vigtigt etableres med forordningen Det Europæiske Databeskyttelsesråd (EDPB), der består af ledende repræsentanter for alle de nationale tilsynsmyndigheder. EDPB beskrives nedenfor i afsnit 2.1.

I forbindelse med forordningens vedtagelse var det fra de multinationale virksomheders side et ønske, at man kun var underlagt én tilsynsmyndighed frem for at være underlagt tilsynsmyndigheden i hvert af de lande, hvor virksomheden opererede, hvorved virksomheden potentielt skulle være i dialog med 28 forskellige tilsynsmyndigheder, hvis den var repræsenteret i alle medlemslandene (på daværende tidspunkt inklusive Storbritannien). Med forordningen blev derfor vedtaget en såkaldt “one-stop-shop” ordning, hvorefter alle virksomheder i udgangspunktet kun er underlagt én tilsynsmyndighed, uanset om virksomheden opererer i flere medlemsstater. Forordningen indeholder en ganske kompleks regulering af denne ordning, der bl.a. skal sikre, at en registreret fortsat kan få bistand fra tilsynsmyndigheden i sit eget land, uanset at det er tilsynsmyndigheden i et andet land, som er tilsynsmyndighed for den dataansvarlige. One-stop-shop ordningen beskrives nedenfor i afsnit 3.

1. Den nationale tilsynsmyndighed - Datatilsynet

Det følger af forordningens art. 51, at medlemsstaterne skal sikre, at en offentlig myndighed er ansvarlig for at føre tilsyn med forordningen. Tilsynsmyndigheden skal efter art. 52 fungere i fuld uafhængighed. Efter art. 54 skal hver medlemsstat fastsætte lovregler om oprettelse af tilsynsmyndigheden og tilsynets nærmere sammensætning.

Krav om en
national
tilsynsmyndighed

I Danmark er denne forpligtelse opfyldt gennem databeskyttelseslovens bestemmelser om Datatilsynet. Det følger således af DBL § 27, at Datatilsynet fører et uafhængigt tilsyn med enhver behandling, der omfattes af databeskyttelsesloven, forordningen og særregler om behandling af personoplysninger. Bestemmelsen fastslår endvidere, at Datatilsynet består af et råd og et sekretariat. Rådet består af otte medlemmer og forholder sig til principielle spørgsmål. Det daglige arbejde varetages af sekretariatet, der ledes af en direktør.

Datatilsynet

Forordningens art. 57, stk. 1, indeholder en ganske omfattende opregning af tilsynsmyndighedens opgaver. Den første af disse opgaver indrammer kernefunktionen, idet det i litra a angives, at tilsynsmyndigheden skal føre tilsyn med og håndhæve anvendelsen af forordningen. Som led heri skal tilsynsmyndigheden behandle klager, der indgives af registrerede, jf. litra e. Håndhævelsen sker således både på grundlag af tilsynsmyndighedens undersøgelser af egen drift og på grundlag af konkrete klager eller andre former for henvendelser. Herudover pålægger art. 57 tilsynsmyndigheden en række andre typer af opgaver inden for områder som information, certificering og akkreditering, vedtagelse og godkendelse af standarddokumenter og – som der sluttes af med – “enhver anden opgave i forbindelse med beskyttelse af personoplysninger”. Tilsynsmyndighederne er således tiltænkt en ganske omfattende rolle efter forordningen.

Tilsynsmyndighedens opgaver

Dette illustreres af antallet af bestemmelser om tilsynsfunktionen i forordningen. Hvor persondatadirektivet indeholdt én bestemmelse om tilsynsmyndighederne og to bestemmelser om art. 29-gruppen, indeholder forordningen 26 bestemmelser om tilsynsfunktionen og EDPB, der strækker sig over 14 sider!

Tilsynsmyndighedernes beføjelser opregnes i forordningens art. 58, der sonderer mellem undersøgelsesbeføjelser (stk. 1), korrigerende beføjelser (stk. 2) og godkendelses- og rådgivningsbeføjelser (stk. 3). Tilsynets mulighed for at udøve kontrol med og sikre håndhævelse af reglerne knytter sig til de to førstnævnte typer af beføjelser. En første forudsætning for en effektiv kontrol er således, at tilsynet har mulighed for at undersøge, om der er sket krænkelse. Ofte vil borgerne i praksis ikke selv have mulighed for at undersøge, om deres rettigheder er blevet krænket.

Tilsynsmyndighedens beføjelser

Art. 58, stk. 1, udstyrer tilsynsmyndigheden med en række undersøgelsesbeføjelser. Tilsynsmyndigheden kan bl.a. give dataansvarlige og databehandlere påbud om at give alle oplysninger, der kræves til udførelsen af tilsynsopgaven, ligesom tilsynsmyndigheden kan kræve adgang til alle lokaler og alt udstyr hos dataansvarlige og databehandlere i overensstemmelse med nationale retsplejeregler.

– undersøgelsesbeføjelser

Forordningens art. 58, stk. 2, udstyrer tilsynsmyndighederne med en række såkaldte korrigerende beføjelser, når der er sket en ulovlig behandling af personoplysninger. Disse beføjelser indbefatter bl.a.:

– korrigerende beføjelser

- At udstede en advarsel til en dataansvarlig eller en databehandler om, at planlagte behandlingsaktiviteter sandsynligvis vil være i strid med forordningen
- At udtale kritik af en dataansvarlig eller en databehandler, hvis behandlingsaktiviteter har været i strid med forordningen
- At give den dataansvarlige eller databehandleren påbud om at imødekomme den registreredes anmodning om udøve sine rettigheder (f.eks. anmodning om indsigt)
- At give den dataansvarlige eller databehandleren påbud om at lovliggøre en ulovlig behandling
- At give den dataansvarlige påbud om at underrette den registrerede om et brud på persondatasikkerheden
- Midlertidigt eller definitivt at begrænse eller forbyde en behandling
- At give påbud om berigtigelse eller sletning af personoplysninger
- At pålægge den dataansvarlige eller databehandleren en administrativ bøde
- At påbyde suspension af overførsel af oplysninger til et tredjeland.

Disse beføjelser kan grundlæggende opdeles i beføjelser, der skal hindre en overtrædelse af reglerne (proaktive beføjelser), beføjelser der skal standse en overtrædelse af reglerne (reaktive beføjelser) og beføjelser, der skal sanktionere en overtrædelse af reglerne (sanktionerende beføjelser).

Den eneste egentlige proaktive beføjelse består i muligheden for at udstede en advarsel om, at en planlagt behandlingsaktivitet sandsynligvis vil være i strid med forordningen.

De fleste af de korrigerende beføjelser i art. 58, stk. 2, har reaktiv karakter og giver tilsynsmyndigheden mulighed for at påbyde den dataansvarlige eller databehandleren at standse en ulovlig behandling og eventuelt ændre behandlingen, så den bliver lovlig.

Som nærmere beskrevet i kap. 8, kan tilsynsmyndigheden i enkelte tilfælde forpligte den dataansvarlige til at indstille eller justere aktiviteter, som ikke udgør ulovlig behandling af personoplysninger, f.eks. hvor et systemdesign ikke overholder art. 25, men hvor brugen af systemet endnu ikke har medført behandlinger i strid med forordningen. I disse situationer kan påbudsbeføjelsen siges at have en proaktiv karakter.

Det er selvsagt væsentligt, at tilsynsmyndigheden har muligheden for at få bragt en ulovlig behandling til ophør, men disse beføjelser giver dog ikke i sig selv dataansvarlige og databehandlere noget incitament til at undgå ulovlige behandlinger. Det er derfor væsentligt, at tilsynsmyndighederne kan sanktionere en ulovlig behandling. Art. 58, stk. 2, giver tilsynsmyndighederne to former for sanktionsbeføjelser: Muligheden for at udtale kritik og adgangen til at pålægge administrative bøder.

– sanktionsbeføjelser

I Danmark opererer Datatilsynet med to grader af kritik: "kritik" og "alvorlig kritik". Muligheden for at udtale (alvorlig) kritik er en mild sanktion, der for mange dataansvarliges vedkommende næppe giver noget stærkt incitament til at overholde reglerne. Som et supplement til selve muligheden for at udtale kritik, har Datatilsynet gennem mange år offentliggjort afgørelser om ulovlig behandling med den tilhørende kritik på tilsynets hjemmeside. Tanken er, at hverken virksomheder eller myndigheder ønsker at blive hængt ud for ikke at respektere borgernes privatliv, hvorfor en offentliggørelse af persondatakrænkelser kan skabe incitament til at overholde reglerne. En eksplicit hjemmel til denne praksis findes nu i DBL § 33. Det må dog nok konstateres, at den afskrækkende effekt af denne "gabestok" har været begrænset og primært har været et forsøg på at skabe et vist incitament i mangel af mere effektive instrumenter.

Hermed samler interessen sig om bødesanktionen. Det er i høj grad et effektivt bødesystem, der skaber incitament til at overholde de databeskyttelsesretlige regler. Dette illustreres meget tydeligt af den fokus på at overholde reglerne, som blev skabt med de markant højere bødeniveauer i forordningen. Tilsynsmyndighedernes mulighed for at udstede administrative bøder fremgår af forordningens art. 83. Denne adgang til at udstede administrative bøder gælder dog ikke for det danske datatilsyn, jf. herved art. 83, stk. 9. I Danmark må Datatilsynet i stedet anmelde sagerne til politiet, idet bøder skal pådømmes af domstolene, bortset fra de tilfælde, hvor Datatilsynet efter DBL§ 42 har hjemmel til at udstede et bødeforlæg, der accepteres af den dataansvarlige. Bødesystemet og de særlige danske regler behandles nærmere nedenfor i kapitel 11.

Forordningens art. 58, stk. 3, udstyrer tilsynsmyndigheden med en række godkendelses- og rådgivningsbeføjelser på specifikke områder som eksempelvis konsekvensanalyser, standardbestemmelser, bindende virksomhedsregler, adfærdskodekser, certificeringer mv. Af stk. 3, litra b, følger, at tilsynsmyndigheden kan afgive udtalelser om ethvert spørgsmål om beskyttelse af personoplysninger. Det er således en vigtig del af tilsynsmyndighedernes rådgivnings- og informationsfunktion at udarbejde vejledninger, der kan bistå dataansvarlige og databehandlere med at overholde forordningen. På Datatilsynets hjemmeside er offentliggjort en lang række vejledninger udarbejdet af Datatilsynet og af EDPB (og den tidligere art. 29-gruppe).

– godkendelses- og rådgivningsbeføjelser

2. Koordination og harmonisering af tilsynsmyndighedernes arbejde

Som nævnt er det væsentligt, at der sker en harmonisering af tilsynsmyndighedernes praksis og fortolkning af forordningen, og at tilsynsmyndighederne i relevant omfang samarbejder om de grænseoverskridende ulovlige behandlinger af personoplysninger. Forordningen indeholder en række elementer, der skal understøtte disse harmoniserings- og samarbejdsbestræbelser. Dette gælder særligt etableringen af EDPB, reglerne om gensidig bistand og fælles aktiviteter for tilsynsmyndighederne og den såkaldte sammenhængsmekanisme.

2.1. Det Europæiske Databeskyttelsesråd (EDPB)

Med forordningen etableredes Det Europæiske Databeskyttelsesråd, der som anført oftest blot benævnes EDPB. EDPB er oprettet med hjemmel i art. 68 og afløser den tidligere art. 29-gruppe, der fungerede under persondatadirektivet. EDPB består ligesom den tidligere art. 29-gruppe af chefen for hver af de nationale tilsynsmyndigheder. Forordningen udstyrer imidlertid EDPB med flere kompetencer, end den tidligere art. 29-gruppe havde under direktivet.

Forordningens art. 70 indeholder en lang opregning af EDPB's opgaver. En væsentlig opgave er den rolle, som rådet har i forbindelse med den nedenfor beskrevne sammenhængsmekanisme, der giver rådet vidtgående muligheder for at afgive udtalelser og træffe afgørelser om forståelse af forordningen. Det følger endvidere af art. 70, stk. 1, litra b, at rådet kan "rådgive Kommissionen om ethvert spørgsmål vedrørende beskyttelse af personoplysninger i Unionen, herunder om ethvert forslag til ændring af denne forordning". Rådet har således også en væsentlig retspolitisk funktion. Fremhæves skal endvidere art. 70, stk. 1, litra e, hvorefter rådet har mulighed for og efter omstændighederne pligt til "på eget initiativ, efter anmodning fra et af sine medlemmer eller efter anmodning fra Kommissionen at undersøge ethvert spørgsmål vedrørende anvendelsen af denne forordning og udstede retningslinjer, henstillinger og bedste praksis for at fremme ensartet anvendelse af denne forordning". EDPB (og den tidligere art. 29-gruppe) har udarbejdet en lang række vejledninger, der bidrager til at skabe en ensartet forståelse af forordningens regler.

Vejledninger fra EDPB er, på samme måde som det gælder vejledninger fra de nationale tilsynsmyndigheder, ikke en autoritativ retskilde, der binder domstolene. Ved læsningen af dem skal man derfor også have sig for øje, at det "blot" er EDPB's og tilsynsmyndighedernes bud på, hvordan reglerne skal fortolkes. Ikke desto mindre har vejledningerne i praksis en betydelig vægt, fordi de dataansvarlige ofte indretter sig efter dem. Det kan også med stor sikkerhed forventes, at en afgørelse fra tilsynsmyndighederne vil blive truffet i overensstemmelse med vejledningerne, og at en anfægtelse i denne situation derfor vil kræve, at sagen indbringes for domstolene. Se også mere generelt om databeskyttelsesrettens retskilder kap. 1.5.

2.2. Gensidig bistand og fælles aktiviteter

Forordningens art. 61 og 62 indeholder to bestemmelser om tilsynsmyndighedernes gensidige bistand og fælles aktiviteter.

Efter art. 61 skal tilsynsmyndighederne yde hinanden gensidig bistand. Forpligtelsen hertil fremgår af stk. 1:

Gensidig bistand
– art. 61

Tilsynsmyndighederne udveksler relevante oplysninger og yder hinanden gensidig bistand med henblik på at gennemføre og anvende denne forordning på en ensartet måde og træffer foranstaltninger med henblik på et effektivt samarbejde med hinanden. Gensidig bistand omfatter navnlig anmodninger om oplysninger og tilsynsforanstaltninger, som f.eks. anmodninger om gennemførelse af forudgående godkendelser og høringer, inspektioner og undersøgelser.

Den øvrige del af art. 61 fastlægger den nærmere procedure for den gensidige bistand, herunder frister for besvarelse, tilfælde hvor en tilsynsmyndighed kan afvise at yde bistand og betaling for bistand (som udgangspunkt skal bistand ydes gratis).

Art. 62 regulerer tilsynsmyndighedernes fælles aktiviteter. Dette gælder særligt fælles undersøgelses- og håndhævelsesforanstaltninger, hvor medarbejdere fra flere tilsynsmyndigheder deltager sammen. Ikke mindst, når de globale internettjenester oplever sikkerhedsbrud eller handler i strid med forordningen, vil det ramme borgere i mange medlemsstater og derfor gøre en fælles undersøgelse relevant.

Art. 62 – fælles
aktiviteter

2.3. Sammenhængsmekanismen

Ønsket om at skabe en harmonisering af tilsynsmyndighedernes praksis er også søgt understøttet gennem en såkaldt sammenhængsmekanisme, der giver EDPB mulighed for i visse tilfælde at afgive udtalelser og træffe bindende afgørelser. Harmoniseringsønsket udtrykkes i indledningsbestemmelsen til sammenhængsmekanismen i art. 63:

Med henblik på at bidrage til en ensartet anvendelse af denne forordning i hele Unionen samarbejder tilsynsmyndighederne med hinanden og, hvis det er relevant, med Kommissionen gennem den sammenhængsmekanisme, der er omhandlet i denne afdeling.

Efter forordningens art. 64, stk. 1, afgiver EDPB udtalelse, når en national tilsynsmyndighed har til hensigt at træffe afgørelse i en række nærmere angivne situationer, f.eks. når tilsynsmyndigheden vil vedtage standardbestemmelser eller godkende bindende virksomhedsregler til brug for dataeksport. Formålet med bestemmelsen er at sikre en ensartet linje, når tilsynsmyndighederne træffer denne type afgørelser, eftersom afgørelsen ikke vedrører en konkret sag, men vil have en bredere anvendelse.

Udtalelse fra
EDPB – art. 64

I tillæg hertil indeholder art. 64, stk. 2, en bestemmelse om EDPB's mulighed for at afgive udtalelse i andre tilfælde. Bestemmelsen er formuleret på en måde, så den i princippet giver EDPB mulighed for at afgive en udtalelse om alle forhold under forordningen:

En tilsynsmyndighed, formanden for Databeskyttelsesrådet eller Kommissionen kan kræve, at ethvert almengyldigt spørgsmål eller ethvert spørgsmål, der har virkninger i mere end én medlemsstat, drøftes af Databeskyttelsesrådet med henblik på en udtalelse, navnlig hvis en kompetent tilsynsmyndighed ikke opfylder forpligtelserne vedrørende gensidig bistand, jf. artikel 61, eller vedrørende fælles aktiviteter, jf. artikel 62.

Bestemmelsen giver således EDPB mulighed for at afgive udtalelse om ethvert "almengyldigt" spørgsmål eller spørgsmål, der har virkning i mere end én medlemsstat. Dette vil omfatte ethvert principielt spørgsmål om forståelsen af forordningen. Bestemmelsen angiver, at dette navnlig er i situationer, hvor en tilsynsmyndighed ikke opfylder sine forpligtelser efter bestemmelserne om gensidig bistand og fælles aktiviteter, men brugen af ordet "navnlig" indebærer, at bestemmelsen ikke er begrænset til disse tilfælde.

Se som et eksempel på anvendelse af bestemmelsen EDPB's Opinion 39/2021, der forholder sig til, om en tilsynsmyndighed efter art. 58, stk. 2, litra g, kan pålægge en dataansvarlig ex officio at slette oplysninger uden en forudgående anmodning fra den registrerede. Udtalelsen blev afgivet på baggrund af en henvendelse fra det ungarske tilsyn, der var i tvivl om spørgsmålet.

Sammenhængsmekanismen indeholder i art. 65 en hjemmel for EDPB til at træffe bindende afgørelser i nærmere angivne situationer. Det-

Bindende
afgørelse fra
Databeskyttelses-
rådet – art. 65

te gælder efter art. 65, stk. 1, litra a og b, når der er uenighed mellem tilsynsmyndighederne i forbindelse med en sag, der behandles af flere tilsynsmyndigheder under one-stop-shop ordningen (der omtales straks nedenfor). Det gælder endvidere efter litra c bl.a., “hvis en kompetent tilsynsmyndighed [...] ikke følger Databeskyttelsesrådets udtalelse udstedt i henhold til artikel 64”. Art. 64 giver EDPB mulighed for at udtale sig, hvis en tilsynsmyndighed påtænker at træffe en afgørelse i en række konkrete situationer, eller hvis tilsynsmyndigheder er uenige om deres forpligtelser under reglerne om gensidig bistand eller fælles aktiviteter. Det er åbenbart, at art. 65 i disse situationer giver EDPB mulighed for at træffe en afgørelse, som tilsynsmyndighederne skal følge. Som beskrevet giver art. 64 imidlertid EDPB en langt bredere mulighed for at udtale sig om alle principielle spørgsmål under forordningen. Når art. 65 giver rådet hjemmel til at træffe afgørelse, hvis en tilsynsmyndighed ikke følger rådets udtalelser “udstedt i henhold til art. 64”, synes konsekvensen at være, at rådet gennem en bindende afgørelse kan forpligte en tilsynsmyndighed til at følge enhver udtalelse om ethvert forhold, som rådet har afgivet efter art. 64. Dette ville være en meget vidtgående kompetence, og det følger ikke af de tilhørende præambelbetragtninger, at dette har været hensigten. Det kan derfor ikke udelukkes, at intentionen kun har været, at EDPB skal kunne træffe afgørelser i konkrete tvister mellem tilsynsmyndighederne og i de specifikke situationer angivet i art. 64, stk. 1, og at bestemmelsens anvendelsesområde skal afgrænses på denne vis. Selv med en sådan begrænsning, er bestemmelsen et væsentligt element i harmoniseringsbestræbelserne.

3. One-stop-shop ordningen

Under persondatadirektivet var virksomheder underlagt tilsynsmyndigheden i hver af de medlemsstater, som de opererede i. For virksomheder med aktiviteter i mange lande var dette administrativt byrdefuldt og vanskeliggjorde også ensartede processer, fordi de forskellige tilsynsmyndigheder ikke nødvendigvis fungerede på samme måde og stillede samme krav, uagtet de var underlagt samme regelsæt. Med forordningen blev derfor indført en model, hvor virksomheder kun er underlagt én tilsynsmyndighed, uanset om de har behandlingsaktiviteter

i flere medlemsstater. En sådan ordning kan dog udfordre retssikkerheden for den registrerede, hvis denne udelukkende kan få behandlet sin sag og skal føre dialogen med en tilsynsmyndighed i et andet land. Blandt andet af denne grund indeholder forordningen mulighed for, at andre tilsynsmyndigheder kan blive involveret i sager, der behandles af den tilsynsmyndighed, som den dataansvarlige er underlagt. Resultatet er blevet en ganske kompleks ordning, der beskrives i det følgende.

Det følger af forordningens art. 56, stk. 1, at en dataansvarlig, der foretager grænseoverskridende behandling af personoplysninger, som udgangspunkt er underlagt tilsynsmyndigheden i den medlemsstat, hvor den dataansvarlige er etableret, eller hvor den dataansvarlige har sin hovedvirksomhed, hvis den dataansvarlige er etableret i flere medlemsstater. Det følger af art. 4, nr. 16, litra a, at den dataansvarliges "hovedvirksomhed" er "stedet for dennes centrale administration i Unionen, medmindre beslutninger vedrørende formål og hjælpemidler i forbindelse med behandling af personoplysninger træffes i en anden af den dataansvarliges etableringer i Unionen, og sidstnævnte etablering har beføjelse til få sådanne beslutninger gennemført; i så fald anses den etablering, der har truffet sådanne beslutninger, for hovedvirksomheden". Dette kan også udtrykkes således, at den dataansvarlige normalt vil være underlagt tilsynsmyndigheden i det land, hvor den dataansvarlige har sit hovedsæde, medmindre en anden enhed i virksomheden selvstændigt træffer beslutningerne om behandlingen af personoplysninger.

Den kompetente
tilsynsmyndighed

I EDPB's Guidelines 8/2022 (høringsversion), pkt. 22, gives følgende eksempel på det sidstnævnte: "En bank har hovedsæde i Frankfurt am Main, og alle dens behandlingsaktiviteter organiseres herfra, men dens forsikringsafdeling er beliggende i Wien. Hvis etableringen i Wien har beføjelse til at træffe beslutninger om alle former for databehandlingsaktiviteter vedrørende forsikringer og at gennemføre disse beslutninger for hele EU, er den østrigske tilsynsmyndighed i overensstemmelse med artikel 4, stk. 16, i databeskyttelsesforordningen den ledende tilsynsmyndighed i forbindelse med grænseoverskridende behandling af persondata i forsikringsøjemed, og de tyske myndigheder (Hessens tilsynsmyndighed) vil overvåge behandlingen af personoplysninger for bankforretninger, uanset hvor kunderne befinder sig".

Forordningen behandler ikke spørgsmålet om tilsynskompetence, når flere dataansvarlige er fælles dataansvarlige. I Guidelines 8/2022 (høringsversion), pkt. 34 anfører EDPB, at fælles dataansvarlige ikke kan udpege én af de dataansvarlige som hovedvirksomhed for den behandling, de fælles dataansvarlige udfører, og at one-stop-shop ordningen sledes ikke kan anvendes af fælles dataansvarlige. De fælles dataansvarlige er derfor hver underlagt deres respektive tilsynsmyndigheder.

– fælles
dataansvarlige

Guidelines 8/2022 afløser WP 244 rev. 01 (tiltrådt af EDPB ved endorsement 1/2018). Efter disse tidligere retningslinjer kunne de fælles dataansvarlige udpege hvem af dem, der skulle have beføjelse til at gennemføre beslutninger om behandling i forhold til alle de fælles dataansvarlige. Denne udpegede ville herefter blive anset for hovedvirksomheden for den behandling, de fælles dataansvarlige udfører. De fælles dataansvarlige kunne således efter disse retningslinjer nøjes med at være underlagt én tilsynsmyndighed for den fælles databehandling. Guidelines 8/2022 udtrykker derfor en ændret opfattelse fra EDPB's side.

Konsekvensen af one-stop-shop ordningen er, at den tilsynsmyndighed, der er tilsynsmyndighed for den dataansvarlige efter art. 56, som udgangspunkt varetager alle sager, der omhandler den pågældende dataansvarlige. One-stop-shop ordningen giver dog andre tilsynsmyndigheder mulighed for at deltage i grænseoverskridende sager, der omfatter behandling af oplysninger om registrerede, der er bosat i den pågældende tilsynsmyndigheds land.

Det følger således af art. 60, at i grænseoverskridende sager skal den tilsynsmyndighed, der er tilsynsmyndighed for den dataansvarlige (benævnt "den ledende tilsynsmyndighed"), samarbejde med andre "berørte" tilsynsmyndigheder. En "berørt tilsynsmyndighed" er efter art. 4, nr. 22, en tilsynsmyndighed, der er berørt af en behandling, fordi (a) den dataansvarlige eller databehandleren er etableret på tilsynsmyndighedens medlemsstats område, (b) de registrerede, der har bopæl i tilsynsmyndighedens medlemsstat, i væsentlig grad er påvirket af eller sandsynligvis i væsentlig grad vil kunne blive påvirket af behandlingen, eller (c) en klage er blevet indgivet til tilsynsmyndigheden. Har en europæisk virksomhed eksempelvis sit hovedsæde i Irland, vil den irske tilsynsmyndighed som udgangspunkt være ledende tilsynsmy-

Samarbejds-
mekanismen i art.
60 – ledende og
berørte
tilsynsmyndig-
heder

dighed. Hvis virksomheden har en filial i Danmark, eller virksomhedens behandling af personoplysninger i væsentlig grad påvirker registrerede i Danmark, f.eks. fordi behandlingen i væsentligt omfang har vedrørt danskere, eller en registreret klager til Datatilsynet, vil Datatilsynet være en “berørt tilsynsmyndighed” omfattet af art. 60.

Hvis en dataansvarlig eller databehandler ikke er etableret i en medlemsstat, og tilsynsmyndigheden i den pågældende medlemsstat heller ikke modtager klager fra egne borgere, kan tilsynsmyndigheden kun involvere sig i en grænseoverskridende sag, hvis kravet om “væsentlig påvirkning” af borgerne er opfyldt. I praksis kan dette derfor være et væsentligt kriterium for tilsynsmyndighedernes mulighed for involvering i de grænseoverskridende sager. I art. 29-gruppens retningslinjer for udpegelse af en ledende tilsynsmyndighed for en dataansvarlig eller databehandler, WP 244 rev. 01 (tiltrådt af EDPB ved Endorsement 1/2018), s. 4, opregnes kriterier, der kan anvendes i vurderingen af, om der foreligger en væsentlig påvirkning. Dette omfatter en række nærmere angivne negative konsekvenser for den registrerede, behandling af følsomme oplysninger og behandling af en bred vifte af personoplysninger.

Den nærmere procedure for samarbejdet mellem den ledende tilsynsmyndighed og de berørte tilsynsmyndigheder fremgår af art. 60. Det følger bl.a. heraf, at den ledende tilsynsmyndighed udarbejder et udkast til afgørelse til de berørte tilsynsmyndigheders kommentering. Såfremt de berørte tilsynsmyndigheder er enige i udkastet eller fremsætter ændringsforslag, som accepteres af den ledende tilsynsmyndighed, afsiger denne herefter endelig afgørelse.

EDPB har på sin hjemmeside en samling over afgørelser truffet under medvirken af flere tilsynsmyndigheder efter one-stop-shop ordningen. På nuværende tidspunkt (november 2022), er der omkring 250 afgørelser.

Hvis tilsynsmyndighederne ikke kan nå til enighed, skal den ledende tilsynsmyndighed indbringe sagen for EDPB efter den ovenfor beskrevne sammenhængsmekanisme, hvorefter EDPB træffer bindende afgørelse. Det betyder i praksis, at afgørelsen træffes af samtlige de nationale tilsynsmyndigheder. Forpligtelsen til at indbringe sagen for EDPB gælder efter art. 60, stk. 4, hvis den ledende tilsynsmyndighed ikke vil følge en berørt tilsynsmyndigheds relevante og begrundede

– uenighed mellem tilsynsmyndighederne
– bindende afgørelse fra EDPB

indsigelse mod den ledende tilsynsmyndigheds udkast til afgørelse, eller hvis den ledende tilsynsmyndighed ikke finder indsigelsen relevant og begrundet.

En “relevant og begrundet indsigelse” defineres i art. 4, nr. 24, som “en indsigelse mod et udkast til afgørelse om, hvorvidt der foreligger en overtrædelse af denne forordning, eller hvorvidt en planlagt foranstaltning i forbindelse med den dataansvarlige eller databehandleren overholder denne forordning, og som klart påviser betydningen af de risici, som udkastet til afgørelse udgør for registreredes grundlæggende rettigheder og frihedsrettigheder og, hvis det er relevant, for den frie udveksling af personoplysninger i Unionen”. EDPB har i retningslinjer 09/2020 nærmere behandlet kravene om “relevant” og “begrundet”.

Den nærmere procedure for tvistbilæggelse gennem en bindende afgørelse fra EDPB fremgår af art. 65.

EDPB’s Guidelines 03/2021 (høringsversion) indeholder en nærmere behandling af disse procedureregler.

EDPB har indtil videre (november 2022) afsagt fem bindende afgørelser i sager, hvor tilsynsmyndighederne var uenige om resultatet.

En samling af alle bindende afgørelser kan findes på EDPB’s hjemmeside.

Hovedparten af sagerne udspringer af en uenighed mellem den irske tilsynsmyndighed som ledende tilsynsmyndighed og en række andre tilsynsmyndigheder som berørte tilsynsmyndigheder. Det irske tilsyn er ledende tilsynsmyndighed for mange af de store techvirksomheder, herunder Meta/Facebook og Google, fordi disse virksomheder af skattemæssige årsager har placeret deres europæiske hovedkontor i Irland. Det er særligt sager, der omhandler disse aktører, som giver anledning til uenighed mellem tilsynsmyndighederne, jf. også straks nedenfor om kritik af one-stop-shop ordningen. Afgørelsen omhandler forskellige af forordningens bestemmelser men som et gennemgående træk, er der uenighed om størrelsen af den administrative bøde, som den ledende tilsynsmyndighed vil pålægge den dataansvarlige, og i alle sagerne således, at EDPB pålægger den ledende tilsynsmyndighed at forhøje bøden.

I afgørelse 1/2021 pålagde EDPB det irske tilsyn at ændre sin afgørelse på en række punkter, herunder bl.a. ved at anlægge en anden fortolkning af art. 83 og forhøje den administrative bøde. I den endelige afgørelse blev WhatsApp herefter pålagt en bøde på 225 mio. euro, hvor det oprindelige udkast havde lagt op til en bøde på mellem 30 og 50 mio. euro. Afgørelsens behandling af art. 83 er nærmere omtalt nedenfor i kapitel 11.

Art. 56, stk. 2, giver mulighed for, at en sag behandles af en anden tilsynsmyndighed end den ledende tilsynsmyndighed. Dette gælder, når sagen vedrører behandlingsaktiviteter, der udelukkende er foretaget af et datterselskab eller anden enhed, der er etableret i en anden medlemsstat, end der hvor virksomheden har sit hovedsæde, eller hvis sagen alene i væsentlig grad påvirker registrerede i en anden medlemsstat. Såfremt en fransk virksomhed underlagt den franske tilsynsmyndighed eksempelvis har et dansk datterselskab, der gennemfører en markedsføringskampagne i Danmark, vil Datatilsynet potentielt kunne behandle en klage over denne kampagne. Datatilsynet skal i første omgang underrette den franske tilsynsmyndighed om klagen, hvorefter den franske tilsynsmyndighed skal beslutte, om den ønsker at behandle sagen. I så fald anvendes samarbejdsproceduren i art. 60. Ønsker den franske tilsynsmyndighed ikke at behandle sagen, varetager Datatilsynet behandlingen af sagen. Den franske tilsynsmyndighed vil dog fortsat være eneste kontaktpunkt for den franske virksomhed (der har status af dataansvarlig).

Sager der alene behandles af en berørt tilsynsmyndighed

Efter art. 66, stk. 1, kan en berørt tilsynsmyndighed i særlige situationer træffe foreløbige foranstaltninger med retsvirkning for sit eget område uden at afvente en afgørelse fra den ledende tilsynsmyndighed. Dette kræver efter bestemmelsen "ekstraordinære omstændigheder", der gør det nødvendigt at handle omgående for at beskytte registreredes rettigheder og frihedsrettigheder. Foranstaltningerne skal have midlertidig karakter og må ikke være gældende i mere end tre måneder. Hvis tilsynsmyndigheden finder, at der er behov for at træffe endelige (ikke-midlertidige) beslutninger under hasteproceduren, kan tilsynsmyndigheden følge beslutningen om foreløbige foranstaltninger op med en anmodning til EDPB om at afgive en hastedtalelse eller træffe en hurtig bindende afgørelse, jf. art. 66, stk. 2. Tilsynsmyndigheder kan endvidere anmode EDPB om en hastedtalelse eller en hur-

Behandling efter hasteprocedure

tig bindende afgørelse, hvis en kompetent tilsynsmyndighed ikke har truffet de fornødne foranstaltninger efter stk. 1, jf. art. 66, stk. 3.

EDPB har indtil videre (november 2022) truffet én afgørelse efter hasteproceduren i art. 66 (hurtige bindende afgørelse 01/2021). I sagen havde tilsynsmyndigheden i Hamborg truffet en afgørelse efter art. 66, stk. 1, der forbød Facebook og WhatsApp at dele oplysninger om tjenernes brugere, da tilsynet mente, at dette skete i strid med forordningen. Tilsynet anmodede herefter EDPB træffe en endelig afgørelse herom. Dette afviste EDPB både med henvisning til, at rådet ikke havde tilstrækkelig information til at konkludere, at der forelå en overtrædelse af forordningen og med henvisning til, at der ikke var et presserende behov ("urgency") for at træffe afgørelse. Anmodningen fra tilsynet i Hamborg var udtryk for en utilfredshed med, at det irske tilsyn som ledende tilsynsmyndighed ikke gjort tilstrækkeligt og handlede hurtigt nok for at hindre en ulovlig udveksling af personoplysninger mellem Facebook og WhatsApp. Tilsynsmyndighedens anvendelse af hasteproceduren må derfor også ses i konteksten af den utilfredshed med dele af one-stop-shop ordningen, der beskrives straks nedenfor.

Uanset one-stop-shop ordningen kan en registreret altid klage til tilsynsmyndigheden i sit eget bopælsland, og denne tilsynsmyndighed skal da holde den registrerede underrettet om sagen og om klagens udfald, jf. art. 77. Den registrerede behøver således ikke at føre en dialog med en udenlandsk tilsynsmyndighed, uanset om en behandling, der omfatter den registrerede, er underlagt den udenlandske tilsynsmyndigheds kompetence.

Adgang for registrerede til at klage til egen tilsynsmyndighed

One-stop-shop ordningen indebærer som nævnt, at den irske tilsynsmyndighed er tilsynsmyndighed for mange af techgiganterne. Det irske tilsyn er blevet kritiseret for ikke at håndhæve forordningen tilstrækkelig effektivt overfor techgiganterne. Repræsentanter fra andre tilsynsmyndigheder har således udtrykt frustration over, at de må afvente lange sagsbehandlingstider fra det irske tilsyn uden selv at kunne foretage sig noget i sager, der også omhandler deres borgere. EU-Domstolen har i C-645/19 (*Facebook Ireland*) forholdt sig til kompetencen mellem den ledende tilsynsmyndighed og andre berørte tilsynsmyndigheder. I sagen ønskede den belgiske tilsynsmyndighed at anlægge sag mod Facebook i Belgien. Facebook bestred, at det belgiske tilsyn havde kompetence hertil og anførte med henvisning til one-stop-

Kritik af one-stop-shop ordningen

shop ordningen, at sagen skulle behandles af den irske tilsynsmyndighed. I dommen fastholder EU-Domstolen, at det som det klare udgangspunkt er den ledende tilsynsmyndighed, der skal behandle sager, der omfatter grænseoverskridende behandling af personoplysninger. Domstolen fremhæver de undtagelser, der følger af forordningen, herunder den berørte tilsynsmyndigheds mulighed for at træffe foreløbige foranstaltninger efter den ovenfor beskrevne hasteprocedure i art. 66, når ekstraordinære omstændigheder gør det nødvendigt at handle omgående. Domstolen forholder sig ikke til, om disse krav var opfyldt i den konkrete sag. Dette er næppe tilfældet, men det er muligt, at Domstolen ved at fremhæve bestemmelsen vil sende et signal om, at det potentielt er muligt at gå uden om one-stop-shop ordningen, hvis den ledende tilsynsmyndighed (i praksis det irske tilsyn) ikke sørger for en effektiv håndhævelse af forordningen.

Kapitel 11

Straf og erstatning

Det gælder på det databeskyttelsesretlige område som på andre retsområder, at effektive sanktioner er et væsentligt element i at sikre overholdelsen af reglerne. Dette blev meget tydeligt illustreret med den fokus, der kom på overholdelse af reglerne med forordningens indførelse af markante bøderammer og forventningerne om en væsentlig forøgelse af bødeniveauet. Udover et potentielt bødeansvar pålægger forordningen i nogle situationer den dataansvarlige og databehandleren at betale erstatning til de registrerede. Både strafansvar og erstatningsansvar kan potentielt også følge af nationale regler. I det følgende omtales først de registreredes mulighed for at kræve erstatning og godtgørelse og dernæst de strafferetlige sanktioner.

1. Erstatning

Forordningen indeholder i art. 82 en regulering af dataansvarlige og databehandleres erstatningsansvar for overtrædelse af forordningen. Retten til at kræve erstatning følger af art. 82, stk. 1:

Ret til erstatning
– art. 82, stk. 1

Enhver, som har lidt materiel eller immateriel skade som følge af en overtrædelse af denne forordning, har ret til erstatning for den forvoldte skade fra den dataansvarlige eller databehandleren.

Det følger af art. 82, stk. 2, at den dataansvarlige er erstatningsansvarlig for enhver overtrædelse, hvorimod databehandleren kun er ansvarlig for tilsidesættelse af de forpligtelser efter forordningen, der

Art. 82, stk. 2

særligt gælder for databehandlere, og for tilsidesættelse af de lovlige instrukser, der er givet af den dataansvarlige:

Enhver dataansvarlig, der er involveret i behandling, hæfter for den skade, der er forvoldt af behandling, der overtræder denne forordning. En databehandler hæfter kun for den skade, der er forvoldt af behandling, hvis pågældende ikke har opfyldt forpligtelser i denne forordning, der er rettet specifikt mod databehandlere, eller hvis pågældende har undladt at følge eller handlet i strid med den dataansvarliges lovlige instrukser.

Bestemmelsen i stk. 2 må læses i sammenhæng med stk. 3, der har følgende ordlyd:

Ansvarsgrundlag
– art. 82, stk. 3

En dataansvarlig eller databehandler er fritaget for erstatningsansvar i henhold til stk. 2, hvis det bevises, at den pågældende ikke er skyld i den begivenhed, der medførte skaden.

Bestemmelsen, der er en videreførelse fra det tidligere persondatadirektiv, er ikke klar og efterlader tvivl om ansvarsgrundlaget for et eventuelt erstatningsansvar. Brugen af ordet “skyld” synes at forudsætte en culpøs handling fra den dataansvarlige eller databehandleren. Denne fortolkning lå også til grund for den tidligere persondatalov og er endvidere antaget i betænkning 1565/2017, s. 915.

Præambelbetragtning 55 i det tidligere persondatadirektiv anførte, at den dataansvarlige “navnlig” kunne fritages for erstatningsansvar i tilfælde af fejl fra den registreredes side eller i tilfælde af force majeure. Betragtningen, der kan læses således, at den dataansvarlige var underlagt et objektivi ansvar under direktivet, er ikke gentaget i forordningen, men bidrager til uklarheden om ansvarsgrundlaget.

Brugen af ordet skyld kan dog også mene, at den dataansvarlige ikke må have forårsaget handling. I litteraturen synes den overvejende opfattelse at være, at art. 82 pålægger den dataansvarlige og databehandleren et objektivi ansvar, således at det ikke er et krav, at den handling, der medfører en overtrædelse af forordningen og skaden, kan bebrejdes den dataansvarlige eller databehandleren.

Se eksempelvis Van Alsenoy, Liability under EU Data Protection Law, JIPITEC, 2016, s. 282 og Zafir-Fortuna i Kuner m.fl. (red.), The EU General Data Protection Regulation (GDPR), s. 1176.

Dette resultat kan også siges at harmonere med ønsket om at yde de registrerede en stærk beskyttelse og at pålægge de dataansvarlige sikkerhed for, at deres behandlinger overholder forordningen (ansvarlighedsprincippet).

Uanset disse betragtninger synes brugen af ordet “skyld” at pege i retning af et culpaansvar. I så fald vil der være tale om et præsumptionsansvar, idet den dataansvarlige eller databehandleren har bevisbyrden for, at den pågældende ikke er skyld i den skadesudløsende begivenhed. Ret beset må spørgsmålet om ansvarsgrundlag betegnes som uafklaret, indtil EU-Domstolen har forholdt sig til det. Henset til den beskyttelsesorienterede tilgang, Domstolen har anvendt i mange sager om fortolkning af forordningen, forekommer det ikke utænkeligt, at Domstolen vil nå frem til, at art. 82 pålægger dataansvarlige og databehandlere et objektivt ansvar.

Der verserende i skrivende stund (november 2022) en række præjudicielle sager for EU-Domstolen om fortolkningen af art. 82, hvor Domstolen bl.a. er blevet spurgt om ansvarsgrundlaget. Der må derfor forventes en afklaring af dette spørgsmål inden for den kommende tid.

Når man frem til, at ansvaret efter art. 82 er et culpaansvar (med omvendt bevisbyrde), bliver det et praktisk vigtigt spørgsmål, om art. 82 pålægger den dataansvarlige et objektivt hæftelsesansvar for krænkelse, der begås af databehandleren (når man frem til, at art. 82 pålægger den dataansvarlige et objektivt ansvar, vil den dataansvarlige allerede af denne grund under alle omstændigheder blive ansvar for databehandlerens overtrædelser af forordningen). Brugen af ordet “hæftelse” i stk. 2 kunne indikere et sådant objektivt ansvar, men kan dog næppe tages til indtægt herfor. I den engelske sprogversion af bestemmelsen bruges begrebet “shall be liable”, hvilket ikke indikerer et objektivt hæftelsesansvar. At begrebet “hæftelse” i den danske oversættelse af forordningen tilsyneladende er brugt synonymt med “ansvar”, understøttes ligeledes af, at bestemmelsens andet led også taler om “hæftelse” for databehandleren. Det kan ikke have været tanken, at da-

Objektivt
hæftelsesansvar
for den
dataansvarlige?

tabehandleren (der handler på vegne af den dataansvarlige og efter dennes instruks) skal pålægges et objektivi hæftelsesansvar for den dataansvarliges krænkelse. Til støtte for et objektivi hæftelsesansvar for den dataansvarlige kan til gengæld anføres, at forordningen generelt søger at give de registrerede et højt beskyttelsesniveau, og at den dataansvarlige potentielt ville have mulighed for at skærme sig mod økonomiske krav fra registrerede ved at bruge en databehandler, hvis den dataansvarlige ikke er underlagt et hæftelsesansvar. Det kan endvidere anføres, at meningen med stk. 2 netop er, at den dataansvarlige skal hæfte for enhver overtrædelse af forordningen (herunder overtrædelser begået af databehandleren), mens databehandleren kun bliver ansvarlig i de situationer, hvor denne har et selvstændigt ansvar.

Der er dog også argumenter, som taler mod at pålægge den dataansvarlige et objektivi hæftelsesansvar, hvis det lægges til grund, at et ansvar efter stk. 3 forudsætter, at den dataansvarlige har handlet culpøst, jf. ovenfor. Det følger i så fald af stk. 3, at den dataansvarlige er fritaget for ansvar efter stk. 2, hvis denne betingelse ikke er opfyldt. Læst i sammenhæng synes ordlyden af stk. 2 og 3 således at forudsætte en culpøs handling, før den dataansvarlige kan blive erstatningsansvarlig. Var det tanken, at dette udgangspunkt skulle fraviges ved databehandlerens overtrædelse af forordningen, havde det været nærliggende at angive det i bestemmelsen. Der er imidlertid ikke noget i forordningens erstatningsregulering eller præambelbetragtningerne, som eksplicit understøtter, at art. 82, stk. 3, ikke gælder denne situation, og at den dataansvarlige derfor skulle være underlagt et sådant objektivi ansvar.

Præambelbetragtning 146 synes nærmest at understøtte, at den dataansvarlige ikke hæfter på objektivi grundlag. Betragtningen indledes med følgende sætning: “Den dataansvarlige eller databehandleren bør yde erstatning for enhver skade, som en person måtte lide som følge af behandling, der overtræder denne forordning”. Ordet “eller” synes at indebære, at der kan være situationer, hvor det kun er databehandleren, der bliver erstatningsansvarlig. Dette ville ikke kunne forekomme, hvis den dataansvarlige var underlagt et objektivi hæftelsesansvar for databehandlerens fejl.

Uanset disse betragtninger tilsiger forordningens stærke fokus på beskyttelsen af de registrerede og tilsvarende stærke fokus på, at den dataansvarlige holdes ansvarlig for manglende overholdelse af forordningen, nok, at den dataansvarlige pålægges et objektivi t hæftelsesansvar for databehandlerens overtrædelse af forordningen. Også en endelig afklaring af dette spørgsmål må afvente en afgørelse fra EU-Domstolen, der som nævnt i sin praksis generelt yder de registrerede en stærk beskyttelse.

Forordningens art. 28, stk. 1, forudsætter under alle omstændigheder, at den dataansvarlige kun må bruge databehandlere, der kan gennemføre passende tekniske og organisatoriske foranstaltninger på en sådan måde, at behandlingen opfylder forordningens krav og sikrer beskyttelsen af den registreredes rettigheder. Dette indebærer, den dataansvarliges valg af en databehandler potentielt i sig selv kan være culpøst. Det kan endvidere indebære, at den dataansvarlige ikke kan vælge en økonomisk svagt funderet databehandler, som ikke vil være i stand til at honorere de økonomiske krav, de registrerede måtte kunne rejse.

Art. 82, stk. 4, fastslår, at alle dataansvarlige og databehandlere, der er erstatningsansvarlige, hæfter solidarisk over for den registrerede:

Solidarisk ansvar for dataansvarlig og databehandler – art. 82, stk. 4

Hvis mere end én dataansvarlig eller databehandler eller både en dataansvarlig og en databehandler er involveret i den samme behandling, og hvis de i henhold til stk. 2 og 3 er ansvarlige for skader, der er forvoldt af behandling, hæfter de solidarisk for hele skaden for at sikre fuld erstatning til den registrerede.

Det solidariske ansvar forudsætter, at begge parter er ansvarlige efter art. 82.

Som en naturlig konsekvens af, at art. 82 indeholder en bestemmelse om solidarisk ansvar, indeholder den også, i stk. 5, en regresbestemmelse om den endelige ansvarsfordeling mellem de solidarisk hæftende:

Regres – art. 82, stk. 5

Hvis en dataansvarlig eller en databehandler i overensstemmelse med stk. 4 har betalt fuld erstatning for den forvoldte skade, har den pågældende dataansvarlige eller databehandler ret til at kræve den del af erstatningen, der svarer til andres del af ansvaret for skaden, tilbage fra de

andre dataansvarlige eller databehandlere, der er involveret i den samme behandling, i overensstemmelse med betingelserne i stk. 2.

Bestemmelsen indebærer, at den endelige fordeling af erstatningsansvaret afgøres af skyldgraden. Hermed er bestemmelsen ikke fuldt sammenfaldende med den baggrundsretlige regresregulering i dansk ret. Efter erstatningsansvarslovens § 25 sker den indbyrdes fordeling af erstatningsansvaret mellem flere solidarisk hæftende erstatningsansvarlige efter, hvad der “under hensyn til ansvarets beskaffenhed og omstændighederne i øvrigt må anses for rimeligt”. Efter bestemmelsens stk. 2 kan der endvidere tages hensyn til forsikringsforhold ved den indbyrdes fordeling.

Udgangspunktet for ansvarsfordelingen ved persondatakrænkelser vil være art. 82, og erstatningsansvarslovens § 25 vil derfor ikke finde anvendelse. Spørgsmålet er dog, om det er muligt at fravige den ansvarsfordeling, der følger af art. 82, og i stedet anvende § 25 eller en anden aftalt ansvarsfordeling. Spørgsmålet har ikke mindst praktisk betydning i aftaler om it-drift, hvor driftsleverandøren vil være databehandler, og den kunde, der får driftet sine it-systemer hos driftsleverandøren, vil være dataansvarlig. I sådanne driftsaftaler er det helt sædvanligt, at driftsleverandørens erstatningsansvar er begrænset til et nærmere angivet beløb. Såfremt der sker en kompromittering eller anden ulovlig behandling af de personoplysninger, kunden er dataansvarlig for, og både kunden og driftsleverandøren ifalder ansvar efter art. 82, vil de efter art. 82, stk. 4, hæfte solidarisk over for registrerede, som har lidt tab. Driftsaftalens ansvarsbegrænsningsbestemmelse kan imidlertid indebære en anden indbyrdes ansvarsfordeling end den, der følger af art. 82, stk. 5. Eftersom den registrerede er sikret ved at kunne kræve det fulde beløb erstattet af både den dataansvarlige og databehandleren, er der næppe afgørende grunde, som taler mod, at to professionelle parter skulle kunne aftale en anden indbyrdes ansvarsfordeling end den, der fremgår af art. 82, og det har næppe været hensigten, at bestemmelsen skulle afskære parterne denne mulighed.

– mulighed for at fravige art. 82, stk. 5?

Tilsvarende betænkning 1565/2017, s. 916.

Databeskyttelsesloven indeholder i § 40 en henvisningsbestemmelse til art. 82:

DBL § 40

Enhver person, som har lidt materiel eller immateriel skade som følge af en ulovlig behandlingsaktivitet eller enhver anden behandling i strid med denne lov og databeskyttelsesforordningen, har ret til erstatning efter databeskyttelsesforordningens artikel 82.

Bestemmelsen har ikke noget selvstændigt indhold; og hjemlen til at kræve erstatning for overtrædelse af forordningen vil være art. 82.

Den registreredes erstatningskrav forudsætter i øvrigt, at de almindelige erstatningsretlige betingelser er opfyldt; det vil navnlig sige, at der skal kunne dokumenteres et kausalt og adækvat økonomisk tab. I de fleste tilfælde vil en ulovlig behandling af personoplysninger ikke påføre den registrerede et økonomisk tab, og i praksis vil det derfor være sjældent, at en overtrædelse af forordningen fører til erstatningskrav.

De almindelige
erstatningsbetin-
gelser

Der er ingen danske trykte domme, der tildeler erstatning for persondatakrænkelser. I *U.2011.2343H* fandtes en kommunes videregivelse af oplysninger om mistanke om et alkoholmisbrug til en potentiel arbejdsgiver at være i strid med persondataloven. Både landsret og Højesteret afviste dog at tildele erstatning til den forurettede (som ikke fik stillingen), da det ikke ansås for bevist, at den pågældende ville have fået stillingen, hvis ikke oplysningerne var blevet videregivet. Den forurettede fik i stedet en godtgørelse på 25.000 kr.

Man kunne derfor hævde, at den praktiske betydning af art. 82, er ganske begrænset. Dette afhænger dog helt af, om bestemmelsen også giver hjemmel til at kræve godtgørelse, jf. herom i det følgende.

2. Godtgørelse

Mens en persondatakrænkelse sjældent vil påføre den registrerede et økonomisk tab og dermed krav på erstatning, vil krænkelsen ofte kunne påføre den registrerede et psykisk ubehag, der efter omstændighederne kan berettige til en godtgørelse. Adgangen til at kræve godtgørelse følger i dansk ret af erstatningsansvarslovens § 26, hvorefter "den, der er ansvarlig for en retsstridig krænkelse af en andens frihed, fred, ære eller person, skal betale den forurettede godtgørelse for tort". Der findes således en række domme, hvor den forurettede er blevet tildelt tortgodtgørelse for en persondatakrænkelse efter § 26.

Se udover den ovennævnte *U.2011.2343H* eksempelvis *U.2008. 727/2S*, hvor en butiksansat blev tildelt en tortgodtgørelse på 25.000 kr. for en arbejdsgivers tv-overvågning af butikken i strid med persondataloven.

Det er ikke enhver persondatakrænkelse, der giver ret til tortgodtgørelse. Krænkelsen skal have en vis grovhed og dermed potentielt føre til en vis psykisk gene, før der kan kræves godtgørelse efter § 26. Illustrativ er *U.2017.98H*, hvor tre tjenestemænd i BaneDanmark blev afskediget efter længere tids sygefravær. Som led i sagsbehandlingen blev der indhentet lægeerklæringer, som BaneDanmark i strid med persondataloven gjorde sig bekendt med, inden erklæringerne blev videresendt til Helbredsnavnet. Både landsret og Højesteret afviste imidlertid, at denne persondatakrænkelse udgjorde en sådan retsstridig krænkelse af de tre tjenestemænd, at de havde krav på tortgodtgørelse. Højesteret tilsluttede sig landsrettens begrundelse, hvorefter der blev lagt vægt på, at det kun var et begrænset antal personer, der havde haft adgang til lægeerklæringerne, og at overtrædelsen af persondataloven ikke havde påvirket den materielle rigtighed af personalesagerens udfald.

Det er i Danmark omdiskuteret, om forordningens art. 82 også omfatter krav på godtgørelse eller alene omfatter erstatningskrav. Spørgsmålet er, om begrebet "immateriel skade" i art. 82, stk. 1, også omfatter ikke-økonomisk skade (dvs. godtgørelse).

Omfatter art. 82 godtgørelse?

Art. 82 anvender begrebet "erstatning". I en dansk kontekst bruges erstatningsbegrebet normalt om situationer, hvor der er lidt et økonomisk tab. Sprogbrugen i den danske oversættelse af forordningen skal man dog nok ikke lægge for meget i. I den engelsksprogede version anvendes "compensation", der potentielt også kan dække ikke-økonomiske tab.

Sondringen mellem materiel og immateriel skade vil normalt gå på, om skaden er af fysisk karakter. Der er ikke sammenfald mellem sondringen materiel/immateriel og økonomisk/ikke-økonomisk, og en immateriel skade kan godt være en økonomisk skade (det praktisk væsentligste eksempel er et økonomisk tab forårsaget af en immaterialretskrænkelse). Ordlyden af bestemmelsen giver derfor ikke noget svar på, om den også omfatter krav på godtgørelse. Heller ikke forordningens præambelbetragtninger giver et svar.

Det fremgår af betragtning 75, at “[R]isiciene for fysiske personers rettigheder og frihedsrettigheder, af varierende sandsynlighed og alvor, kan opstå som følge af behandling af personoplysninger, der kan føre til fysisk, materiel eller immateriel skade, navnlig hvis behandlingen kan give anledning til forskelsbehandling, identitetstyveri eller -svig, finansielle tab, skade på omdømme, tab af fortrolighed for personoplysninger, der er omfattet af tavshedspligt, uautoriseret ophævelse af pseudonymisering eller andre betydelige økonomiske eller sociale konsekvenser”. Af de afsluttende ord kan udledes, at skadesbegrebet ikke kun omfatter økonomiske konsekvenser. Dette taler for, at en (immateriel) skade også kan være ikke-økonomisk. Betragtning 75 retter sig dog ikke mod art. 82 og kan næppe tages til indtægt for, at der kan kræves ikke-økonomisk skade efter art. 82.

EU-Domstolen har i en række afgørelser fortolket skadesbegrebet i andre EU-retsakter, men denne praksis giver ikke noget entydigt svar på, om begrebet også omfatter ikke-økonomisk skade. Ved besvarelsen af spørgsmålet må det formentlig tillægges betydelig vægt, at den form for skade, der kan opstå ved persondatakrænkelser, primært vil være ikke-økonomisk skade. Det har formodningen mod sig, at man i en omfattende retsakt som forordningen kun har valgt at medtage en civilretlig sanktion af begrænset betydning (erstatning for økonomisk skade), men ikke den civilretlige sanktion, som i praksis er den, der har betydning (godtgørelse for ikke-økonomisk skade). Dette ville ikke give de registrerede en reel civilretlig beskyttelse og heller ikke være i overensstemmelse med princippet om, at forordningen skal sikre de registrerede effektive retsmidler, jf. herved art. 79 om den registreredes adgang til effektive retsmidler over for dataansvarlige og databehandlere.

Det følger af præambelbetragtning 108, at effektive retsmidler bl.a. indbefatter retten til at kræve erstatning.

På den baggrund må det lægges til grund, at art. 82 også omfatter retten til at kræve godtgørelse for ikke-økonomisk skade.

I alle de verserende sager for EU-Domstolen, hvor der er rejst præjudicielle spørgsmål om fortolkningen af art. 82, synes det også uden videre lagt til grund, at bestemmelsen også gælder ikke-økonomisk skade. Alle sagerne omhandler således ikke-økonomisk skade, og i ingen sagerne er

der stillet præjudicielle spørgsmål om, hvorvidt sådanne krav i det hele taget er omfattet af forordningen. Dette lægger med andre ord til grund.

Konsekvensen heraf er, at hjemlen til at kræve godtgørelse for persondatakrænkelser ikke som under persondatadirektivet er erstatningsansvarslovens § 26, men forordningens art. 82. Hvilken betydning dette vil få, afhænger af den praksis, der udvikler sig under art. 82, herunder i relation til godtgørelsesniveauet, der under § 26 har været relativt lavt (de højeste godtgørelsesbeløb har været på 25.000 kr.).

Se også om spørgsmålet *Udsen*, U.2020B.215 ff. I betænkning [1565/2017](#) konkluderes bl.a. med henvisning til praksis om skadesbegrebet fra EU-Domstolen, at der ikke er tilstrækkeligt grundlag for at fastslå, at godtgørelse for ikke-økonomisk skade er omfattet af retten til erstatning for materiel eller immateriel skade efter art. 82. Denne konklusion kan af de ovennævnte grunde ikke tiltrædes.

Der er kun få danske domme, der har tildelt godtgørelse for persondatakrænkelser. Det kan dog ikke udelukkes, at dette vil ændre sig i takt med den betydelige fokus, der er kommet på databeskyttelse, ikke kun hos virksomheder og myndigheder, men også hos borgerne. Der verserer således også sager for de danske domstole, hvor der er rejst krav på godtgørelse efter art. 82.

Der eksisterer efterhånden en ganske omfattende praksis fra domstole i andre medlemslande. Særligt i Tyskland har art. 82 givet anledning til en række sager. Hjemmesiden GDPRhub inderholder en (ikke-fuldstændig) [samling](#) af nationale domme om art. 82.

Som det allerede er fremgår giver art. 82 anledning til en række vanskelige fortolkningsspørgsmål, og den nærmere rækkevidde af bestemmelsen vil først være klarlagt, når EU-Domstolen har besvaret en række af de præjudicielle spørgsmål om art. 82, som pt. verserer.

EDPB bidrager til afklaring af forordningens bestemmelser gennem sine vejledninger. Da tilsynsmyndighederne ikke har kompetence til at pålægge dataansvarlige og databehandlere erstatningsansvar efter art. 82, kan det imidlertid ikke forventes, at EDPB vil udarbejde en vejledning om art. 82. Den nærmere forståelse af bestemmelsen kan derfor

kun fastlægges gennem praksis fra de nationale domstole og EU-Domstolen.

Blandt de meste centrale spørgsmål er, om der gælder en bagatelgrænse under art. 82, hvordan denne i givet fald skal fastlægges, og hvordan godtgørelsesbeløbene skal udmåles.

Det må lægges til grund, at der gælder en bagatelgrænse under art. 82, og at ikke enhver overtrædelse af forordningen giver den registrerede krav på godtgørelse. Den omstændighed, at en registreredes oplysninger behandles i strid med forordningen kan med andre ord ikke automatisk sidestilles med, at den registrerede har lidt en "skade" efter art. 82, stk. 1. Et modsat resultat ville potentielt medføre en syndflod af krav og sager ved domstolene.

Bagatelgrænse

Se således også generaladvokatens forslag til afgørelse i C-300/21 (*Österreichische Post*).

Lægger man til grund, at der gælder en bagatelgrænse, bliver næste spørgsmål, hvor denne grænse går. Dette er et vanskeligt spørgsmål, som forordningen ikke giver svar på. Præambelbetragtning 85 indeholder en længere opregning af, hvad der kan udgøre en "immateriel skade". Opregningen er dog så generel, at den kun har begrænset brugbarhed, når der skal foretages en konkret vurdering. Det er muligt, at EU-Domstolen i nogle af de verserende sager vil udstikke retningslinjer for fastlæggelsen af bagatelgrænsen, men da Domstolen ikke skal forholde sig til den konkrete sag, og da det under alle omstændigheder er vanskeligt at fastsætte generelle retningslinjer, er det ikke sikkert, at dette vil ske. I så fald bliver det op til de nationale domstole at fastlægge denne grænse.

Se således også generaladvokatens forslag til afgørelse i C-300/21 (*Österreichische Post*), pkt. 116: "Jeg er ikke i tvivl om, at grænsen mellem simpel utilfredshed (som ikke er erstatningsberettiget) og reel immateriel skade (som er erstatningsberettiget) er vag, og jeg ser ikke bort fra, at det er vanskeligt at foretage en teoretisk afgrænsning af de to kategorier og anvende dem i praksis på en sag. Denne vanskelige opgave er tillagt medlemsstaternes retter, som i deres domme sandsynligvis ikke kan unddrage sig den opfattelse, der til enhver tid hersker i samfundet om den accepterede tolerance, når de subjektive konsekvenser af overtræ-

delsen af en bestemmelse på dette område ikke overstiger en minimumsgrænse”.

På tilsvarende vis må det forventes, at godtgørelsesniveauet vil blive fastlagt af de nationale domstole. Art. 82 giver ingen nærmere retningslinjer for. Efter art. 79 skal den registreredes retsmidler over for den dataansvarlige og databehandlere være “effektive”, hvilket dog heller ikke giver meget vejledning for den konkrete vurdering.

Godtgørelses-
niveau

I en af de verserende sager for EU-Domstolen, har den forelæggende ret spurgt, om kriterierne efter art. 83 for fastsættelsen af bødeniveauet tilsvarende kan anvendes ved fastlæggelsen af godtgørelsesniveauet efter art. 82. Umiddelbart synes forordningen ikke at give hjemmel hertil, men det kan ikke udelukkes, at EU-Domstolen i bestræbelserne på at harmonisere retstilstanden og undgå store nationale forskelle i godtgørelsesniveauerne gennem art. 83 eller på anden måde vil søge at opstille harmoniserende kriterier under art. 82. I sit forslag til afgørelse i C-300/21 (*Österreichische Post*), pkt. 116 note 87, anfører generaladvokaten, at det vil være op til domstolen i medlemsstaterne at fastlægge godtgørelsesniveauet.

Sager om krav på godtgørelse kan ikke mindst få betydning, hvis der anlægges gruppesøgsmål i tilfælde, hvor et stort antal personers oplysninger er blevet kompromitteret eller i øvrigt behandlet ulovligt, f.eks. i forbindelse med et større sikkerhedsbrud. Forordningen etablerer i art. 80 mulighed for, at visse typer af organer kan rejse kollektive sager på vegne af registrerede, herunder også rejse krav på erstatning, hvis national ret rummer denne mulighed. En sådan ordning findes i Danmark med reglerne om gruppesøgsmål i retsplejelovens §§ 254 a ff. Såfremt mange tusinde registrerede samler sig i et gruppesøgsmål, kan den dataansvarlige potentielt blive mødt med enorme krav, uanset om godtgørelsesbeløbet til den enkelte er af mindre omfang. Der findes endnu ingen dansk retspraksis om krav på godtgørelse ved større sikkerhedsbrud og heraf følgende kompromittering af personoplysninger. Henset til de potentielt meget store beløb, en anerkendelse af godtgørelse kan føre til, må det nok forventes, at domstolene vil udvise en vis tilbageholdenhed med at tildele godtgørelse i denne type sager.

Mulighed for
gruppesøgsmål

3. Bøder

Under persondataloven blev der i enkelte sager givet bøder. Bødeniveauet var dog beskedent, og de højeste bøder lå på 25.000 kr. Bødesanktionen havde derfor ikke den afskrækkende effekt, som var dens primære formål. Dette er ændret med forordningen, der har medført væsentligt flere og højere bøder. Da forordningens bødebestemmelse om administrative bøder i art. 83 ikke gælder i Danmark, er dataansvarlige og databehandlere efter dansk ret alene underlagt bødeansvar efter databeskyttelsesloven. Dette indebærer dog ikke, at art. 83 er uden betydning i Danmark. I det følgende beskrives art. 83, bødebestemmelsen i DBL § 41, tilsynsmyndighedernes bødevejledninger og praksis efter de nævnte regler.

3.1. Administrative bøder efter art. 83

Forordningens art. 83 indeholder således en bestemmelse om administrative bøder, der indeholder meget høje bøderammer. Bestemmelsen giver tilsynsmyndighederne hjemmel til at udstede administrative bøder, jf. § 83, stk. 1:

Hver tilsynsmyndighed sikrer, at pålæggelse af administrative bøder i henhold til denne artikel for overtrædelse af denne forordning som omhandlet i stk. 4, 5 og 6 i hver enkelt sag er effektiv, står i rimeligt forhold til overtrædelsen og har afskrækkende virkning.

Art. 83, stk. 2, opregner elementer, der skal indgå i tilsynsmyndighedens vurdering af, om der skal udstedes en bøde, og hvilken størrelse den i givet fald skal have. Dette omfatter overtrædelsens karakter, alvor og varighed, skyldgraden, typer af personoplysninger omfattet af overtrædelsen, om der er tale om gentagelsestilfælde og en række andre elementer.

Art. 83, stk. 4 og 5, angiver de meget omtalte og meget høje bøderammer, hvorefter det maksimale bødeniveau udgør 10 mio. euro eller 2 % af et selskabs samlede globale årlige omsætning for nogle typer af overtrædelser og 20 mio. euro eller 4 % af den samlede globale årlige omsætning for andre typer af overtrædelser.

– bøderammer

De nationale tilsynsmyndigheders mulighed for at udstede administrative bøder er et effektivt middel i håndhævelsen af forordningen. Danmark er imidlertid ikke omfattet af forordningens administrative bødesystem. Det er anført i bemærkningerne til databeskyttelsesloven, at indførelsen af administrative bøder giver betænkeligheder i forhold til grundloven. Betænkeligheden går på, at bøder bør idømmes af domstolene (den dømmende magt), ikke af administrative organer. Denne opfattelse kan man være enig eller uenig i. Det kan konstateres, at det udover Danmark kun er Estland, som ikke er omfattet af det administrative bødesystem, og at ingen af de øvrige medlemsstater således finder, at den forfatningsmæssige tredeling af magten hindrer, at den nationale tilsynsmyndighed får hjemmel til at udstede administrative bøder. Under alle omstændigheder giver forordningen udtrykkeligt adgang til ikke at indføre et administrativt bødesystem. Dette følger af forordningens art. 83, stk. 9:

Hvis en medlemsstats retssystem ikke giver mulighed for at pålægge administrative bøder, kan denne artikel anvendes på en sådan måde, at den kompetente tilsynsmyndighed tager skridt til bøder, og de kompetente nationale domstole pålægger dem, idet det sikres, at disse retsmidler er effektive, og at deres virkning svarer til virkningen af administrative bøder, som pålægges af tilsynsmyndighederne. Bøder skal under alle omstændigheder være effektive, stå i rimeligt forhold til overtrædelsen og have afskrækkende virkning [...]

Denne undtagelse indebærer dog ikke, at Danmark har frie rammer for fastlæggelsen og anvendelsen af bødereger. Det følger således af art. 83, stk. 9, at virkningen af det danske bødesystem skal svare til virkningen af forordningens administrative bødesystem, og at bøderne skal være effektive og have afskrækkende virkning. Bestemmelsen rummer endvidere det formelle krav, at Datatilsynet skal tage det første skridt til bøden. I forordningens præambelbetragtning 151 anføres i tilknytning hertil, at de danske domstole bør tage hensyn til en anbefaling fra Datatilsynet, hvormed formentlig sigtes til en anbefaling vedrørende bødeniveauet.

Det administrative bødesystem gælder ikke i Danmark

3.2. Bøder efter DBL § 41

Med DBL § 41 er der indført en bødebestemmelse, som skal opfylde Danmarks forpligtelse til at indføre et bødesystem, der er lige så effektivt som forordningens administrative bødesystem. I § 41, stk. 1 og 2, opregnes hovedparten af de materielle bestemmelser fra forordningen og databeskyttelsesloven, og det fastslås, at en overtrædelse af disse bestemmelser kan medføre bødestraf eller fængsel i op til 6 måneder, medmindre højere straf er forskyldt efter anden lovgivning. Bøder efter § 41 skal pådømmes af domstolene.

Det følger af § 41, stk. 3, at forordningens art. 83, stk. 2, skal følges ved pålæggelse af straf. De kriterier, som efter forordningen skal indtages ved vurderingen af, om der skal tildeles en administrativ bøde og størrelsen heraf, skal således også inddrages ved bødenvurderingen under § 41. Bestræbelserne på at skabe et bødesystem, der er lige så effektivt som forordningens, afspejles også i forarbejderne til § 41, hvorefter det forudsættes, at Datatilsynet indgiver politianmeldelse sammen med en redegørelse for sagen, når tilsynet vurderer, at der kan idømmes en bøde. Redegørelsen skal indeholde tilsynets vurdering af bødeniveauet, herunder også bødeniveauet i andre EU-lande. På denne vis er det formentlig lovgivers håb, at det bødeniveau, der bliver etableret under art. 83, afspejles i det af domstolene fastlagte bødeniveau under databeskyttelsesloven. Med henvisning til de betydelige bøderammer i forordningen og kravet om, at bøderne skal være effektive og have afskrækkende virkning, anføres endvidere i lovbemærkningerne, at der "bør lægges op til en væsentlig forøgelse af bødeniveauet", der efter de tidligere regler har ligget på 5.000-25.000 kr.

Det følger af forordningens art. 83, stk. 7, at medlemsstaterne selv fastsætter, om offentlige myndigheder skal kunne ifalde bødeansvar og i givet fald omfanget heraf. I forbindelse med databeskyttelseslovens forhandling var det meget omdiskuteret, om offentlige myndigheder skulle kunne idømmes bøder for persondatakrænkelser (det forekommer jævnligt, at offentlige myndigheder ikke lever op til databeskyttelsesreglerne, bl.a. som følge af sikkerhedsbrud). På den ene side kan det hævdes, at den bøde, som myndigheden skal betale, kommer fra den samme kasse, som der betales til, og at en bøde kan indebære serviceforringelser for borgerne (f.eks. for patienter på et hospital, der må

Krav om samme
virkning

Offentlige
myndigheder

betale en større bøde for persondatakrænkelser). På den anden side vil risikoen for at blive pålagt en (større) bøde kunne have samme afskrækkende effekt for offentlige myndigheder som for private virksomheder og dermed skabe et større incitament til, at reglerne overholdes (hvorved myndigheden slet ikke skal betale en bøde). Det sidstnævnte argument endte med at blive tillagt størst vægt, og DBL § 41, stk. 6, fastslår således, at offentlige myndigheder kan ifalde strafansvar.

Dette er en fravigelse af det generelle princip efter straffelovens § 27, stk. 2, hvorefter statslige myndigheder, regioner og kommuner ikke kan ifalde strafansvar for deres myndighedsudøvelse. Lovbemærkningerne forudsætter dog, at bødelofterne for offentlige myndigheder bliver lavere end for private virksomheder (2 % af driftsbevillingen eller 8 mio. kr. for nogle typer af krænkelser og 4 % af driftsbevillingen eller 16 mio. kr. for andre typer af krænkelser) bl.a. under hensyn til, at offentlige myndigheder er sat til at varetage lovbestemte opgaver under nogle rammevilkår.

Det er ikke enhver overtrædelse af databeskyttelsesloven og forordningen, som skal straffes med bøde. Det fremgår således af lovbemærkningerne, at der ikke forudsættes bøder ved alle overtrædelser af databeskyttelsesforordningen og loven. I forordningens præambelbetragtning 148 er tilsvarende anført, at “mindre overtrædelser” kan udløse en irettesættelse i stedet for en administrativ bøde.

Ikke bøder for alle overtrædelser

DBL § 42, stk. 1, giver Datatilsynet mulighed for i nogle situationer at udstede et bødeforlæg:

Bødeforlæg – DBL § 42

Skønnes en overtrædelse af denne lov eller databeskyttelsesforordningen eller regler, der er udstedt i medfør af loven, ikke at ville medføre højere straf end bøde, kan Datatilsynet i et bødeforelæg tilkendegive, at sagen kan afgøres uden retssag, hvis den, der har begået overtrædelsen, erklærer sig skyldig i overtrædelsen og erklærer sig rede til inden en nærmere angivet frist, der efter begæring kan forlænges, at betale en i bødeforelægget angivet bøde.

Med bødeforlægget kan den, der har begået overtrædelsen, vælge frivilligt at betale bøden og dermed undgå, at sagen indbringes for domstolene af anklagemyndigheden. Betales ikke frivilligt, må sagen indbringes for domstolene. Det følger af bemærkningerne til bestemmelsen, at Datatilsynet kun kan udstede bødeforlæg i ukomplicerede

sager, hvor der ikke er bevismæssige tvivlsspørgsmål. Det er endvidere en forudsætning, at der i retspraksis er fastlagt et tilstrækkeligt præcist bødeniveau for den pågældende overtrædelse. I andre sager og i sager, hvor der ikke betales frivilligt, må Datatilsynet indgive politianmeldelse, hvorefter politi og anklagemyndigheden overtager sagen og om nødvendigt fører den for domstolene.

3.3. Bødemodeller

For dataansvarlige kan usikkerhed om, hvilket bødeniveau man kan forvente for en overtrædelse af forordningen være frustrerende, ligesom en meget uens bødepraksis blandt tilsynsmyndighederne vil være uhensigtsmæssig. For at imødegå dette har EDPB udarbejdet retningslinjer for udmålingen af administrative bøder under art. 83 (guidelines [04/2022](#)). Datatilsynet har tilsvarende – og forud for EDPB – udarbejdet en vejledning om udmåling af bøder til virksomheder og en vejledning om udmåling af bøder for fysiske personer.

Datatilsynet har endvidere varslet en vejledning om udmåling af bøder til offentlige myndigheder, men den er endnu ikke udgivet.

Da fysiske personer kun sjældent idømmes bøder for persondatakrænkelser, er det bøder til virksomheder og vejledningen herom, der har praktisk betydning.

Vejledningen om udmåling af bøder til fysiske personer angiver et beløb på mellem 10.000 og 25.000 kr. for forskellige typer af såkaldte “standardsager”. Der lægges således op til relativt begrænsede bøder til fysiske personer ved en overtrædelse af forordningen.

Bødevejledningen for virksomheder fastsætter en model for bødeudmålingen. Efter modellen skal der fastsættes et grundbeløb på baggrund af det bødemaksimum, der gælder for overtrædelsen. Modellen forudsætter således, at det indledningsvist klarlægger, hvad det maksimale bødebeløb vil være efter art. 83, stk. 3 og 4. Grundbeløbet fastsættes herefter til en procentdel af maksimumbeløbet inddelt efter en række kategorier af overtrædelser (betegnet henholdsvis “alvorlige”, “mere alvorlige” og “meste alvorlige” overtrædelser). Kategoriseringen tager udgangspunkt i, hvilken bestemmelse i forordningen, der er

overtrådt. Standardgrundbeløbet fastsættes til 5, 10 hhv. 20 % af maksimumbeløbet for hver af de tre kategorier af overtrædelser. Dette beløb kan yderligere justeres efter virksomhedens størrelse (målt på omsætning og markedsandel). Når grundbeløbet af fundet, kan det justeres på baggrund af en konkret vurdering af overtrædelsens karakter, alvor og varighed og efter de øvrige skærpende og formildende omstændigheder, der følger af art. 83, stk. 2. Vejledningen indeholder en række eksempler herpå og præciserer samtidig, at de angivne vurderingskriterier ikke er udtømmende. Det beløb, der fremkommer efter justeringen, vil som udgangspunkt være det beløb, som Datatilsynet vil indstille bøden til. Dog vil beløbet blive nedsat, hvis det (undtagelsesvist) skulle overstige bødemaksimum efter art. 83, stk. 3 og 4. Vejledningen angiver endvidere, at der med udgangspunkt i proportionalitetsprincippet kan tages hensyn til virksomhedens manglende betalingssevne. Dette kræver dog ifølge vejledningen, at virksomheden selv anmoder herom, og at der foreligger objektive beviser for, at den pålagte bøde med sikkerhed vil bringe den pågældende virksomheds økonomiske levedygtighed i fare og få dens aktiver til at miste al værdi.

EDPB's bødevejledning indeholder en model for bødeudmålingen, der i det væsentlige svarer til modellen i Datatilsynets vejledning (der således synes at have været forlæg for EDPB-vejledningen).

Det er væsentligt at understrege, at bødevejledningerne ikke kan erstatte den konkrete vurdering med inddragelse af alle relevante forhold i den enkelte sag.

Se også EDPB's Guidelines 04/2022, pkt. 145: "The above Chapters outline a general method for the calculation of fines and shall facilitate further harmonization and transparency on the fining practice of supervisory authorities. However, this general method should not be misunderstood as a form of automatic or arithmetical calculation. The individual setting of a fine must always be based on a human assessment of all relevant circumstances of the case and must be effective, proportionate and deterrent with regard to that specific case."

Dette ligger for så vidt indbygget i modellens adgang til at inddrage konkrete forhold i justeringen af et grundbeløb. Heri ligger også, at modellen kun i et begrænset omfang kan give indikationer af,

hvordan bøden vil ende i en konkret sag. Det er ligeledes vigtigt at understrege, at bødevejledningerne ikke binder domstolene.

3.4. Praksis

Som anført fik bødebestemmelsen en betydelig opmærksomhed, da forordningen fik virkning, fordi den indvarslede langt højere bøder, end man havde været vant til under persondatadirektivet. Det er dog værd at være opmærksom på, at de meget høje bøderammer netop er rammer, dvs. et øvre loft for bødestørrelserne. Bøderammerne giver en forventning om et højere bødeniveau, men siger ikke i selv noget om, bødestørrelsen i den konkrete sag. Hvilke bødeniveauer, der udmønter sig under forordningen afgøres derfor af den bødepraksis, som tilsynsmyndighederne og domstolene fastlægger. Det er denne praksis, der tegner billedet af, hvilke bødeniveauer, de dataansvarlige kan forvente, og dermed følges denne praksis også med betydelig interesse, særligt indtil praksis har "sat sig" og bødeniveauerne ligger nogenlunde fast. Dette vil tage lang tid, både fordi bødesagerne omhandler mange forskellige typer af overtrædelser, og fordi de nationale tilsynsmyndigheder kan have forskellige opfattelser af bødeniveauet. Endvidere, hvad der af og til overses men er meget væsentligt, kan tilsynsmyndighedernes afgørelser altid indbringes for domstolene, hvilket også sker i mange sager. I sidste ende er det derfor de nationale domstole, der kan komme til at afgøre bødeniveauerne for de forskellige typer af overtrædelser af forordningen.

I Danmark består sondringen mellem bødepraksis fra tilsynsmyndighederne og fra domstolene ikke, da Datatilsynet som anført ikke har kompetence til at udstede administrative bøder. Bl.a. som følge heraf er antallet af afgjorte bødesager i Danmark begrænset sammenlignet med antallet i mange andre medlemsstater. Der er således kun afsagt enkelte sager ved byretterne. Dette indebærer, at der endnu ikke kan tegnes noget klart billede af bødeniveauerne i Danmark.

I de hidtidige sager er der tildelt bøder til både virksomheder og myndigheder. Der er endnu ikke tildelt bøde på mere end 100.000 kr. Det dog forventes, at kommende sager vil resultere i højere bøder.

I andre medlemsstater har tilsynsmyndigheder udstedt mange administrative bøder, herunder også mange bøder af en betydelig størrelse. Udover at bødeniveauet i tilsynspraksis generelt forekommer højere end efter den beskudne danske retspraksis og Datatilsynets indstillingspraksis, er det vanskeligt at sige noget mere generelt om bødeniveauet fra de forskellige tilsynsmyndigheder under art. 83. Praksis er under alle omstændigheder nok heller ikke ensartet i de forskellige lande.

En oversigt over bødesager fra de forskellige medlemsstater kan findes på <https://www.enforcementtracker.com>.

4. Fængsel

Forordningen indeholder ingen regler om fængselsstraf. Det er således op til medlemsstaterne selv, om en overtrædelse af reglerne skal kunne give fængselsstraf.

Medlemsstaternes mulighed for selv at fastsætte andre sanktioner end civilretlige sanktioner efter art. 82 og administrative bøder efter art. 83 følger af art. 84: "Medlemsstaterne fastsætter regler om andre sanktioner, der skal anvendes i tilfælde af overtrædelser af denne forordning, navnlig overtrædelser, som ikke er underlagt administrative bøder i henhold til artikel 83, og træffer alle nødvendige foranstaltninger for at sikre, at de anvendes. Sanktionerne skal være effektive, stå i et rimeligt forhold til overtrædelsen og have afskrækkende virkning".

Denne mulighed er udnyttet i Danmark. Efter DBL § 41 kan den type overtrædelser, som kan straffes med bøde, også straffes med fængsel i op til 6 måneder. Det forudsætter selvsagt, at forholdet har en grovere beskaffenhed, før der kan idømmes fængselsstraf. Forarbejderne nævner, at fængselsstraf eksempelvis kan anvendes, hvor der sker en forsætlig offentliggørelse af særligt beskyttelsesværdige oplysninger, såsom følsomme oplysninger, i et meget betydeligt omfang. Hermed understreges, at fængselsstraf kun undtagelsesvist skal anvendes ved overtrædelse af de databeskyttelsesretlige regler. Der er endnu ikke dømt fængselsstraf for persondatakrænkelser i Danmark.

5. Koordination og harmonisering af tilsynsmyndighedernes arbejde

Som nævnt er det væsentligt, at der sker en harmonisering af tilsynsmyndighedernes praksis og fortolkning af forordningen, og at tilsynsmyndighederne i relevant omfang samarbejder om de grænseoverskridende ulovlige behandlinger af personoplysninger. Forordningen indeholder en række elementer, der skal understøtte disse harmoniserings- og samarbejdsbestræbelser. Dette gælder særligt etableringen af EDPB, reglerne om gensidig bistand og fælles aktiviteter for tilsynsmyndighederne og den såkaldte sammenhængsmekanisme.

5.1. Det Europæiske Databeskyttelsesråd (EDPB)

Med forordningen etableres Det Europæiske Databeskyttelsesråd, der som anført oftest blot benævnes EDPB. EDPB er oprettet med hjemmel i art. 68 og afløser den tidligere art. 29-gruppe, der fungerede under persondatadirektivet. Databeskyttelsesrådet består ligesom den tidligere art. 29-gruppe af chefen for hver af de nationale tilsynsmyndigheder. Forordningen udstyrer imidlertid Databeskyttelsesrådet med flere kompetencer, end den tidligere art. 29-gruppe havde under direktivet.

Forordningens art. 70 indeholder en lang opregning af EDPB's opgaver. En væsentlig opgave er den rolle, som rådet har i forbindelse med den nedenfor beskrevne sammenhængsmekanisme, der giver rådet vidtgående muligheder for at afgive udtalelser og træffe afgørelser om forståelse af forordningen. Det følger endvidere af art. 70, stk. 1, litra b, at rådet kan "rådgive Kommissionen om ethvert spørgsmål vedrørende beskyttelse af personoplysninger i Unionen, herunder om ethvert forslag til ændring af denne forordning". Rådet har således også en væsentlig retspolitisk funktion. Fremhæves skal endvidere art. 70, stk. 1, litra e, hvorefter rådet har mulighed for og efter omstændighederne pligt til "på eget initiativ, efter anmodning fra et af sine medlemmer eller efter anmodning fra Kommissionen undersøge ethvert spørgsmål vedrørende anvendelsen af denne forordning og udstede retningslinjer, henstillinger og bedste praksis for at fremme ensartet anvendelse af denne forordning". EDPB (og den tidligere art. 29-grup-

pe) har udarbejdet en lang række vejledninger, der bidrager til at skabe en ensartet forståelse af forordningens regler.

Vejledninger fra EDPB er, på samme måde som det gælder vejledninger fra de nationale tilsynsmyndigheder, ikke en autoritativ retskilde, der binder domstolene. Ved læsningen af dem skal man derfor også have sig for øje, at det "blot" er EDPB's og tilsynsmyndighedernes bud på, hvordan reglerne skal fortolkes. Ikke desto mindre har vejledningerne i praksis en betydelig vægt, fordi de dataansvarlige ofte indretter sig efter dem. Det kan også med stor sikkerhed forventes, at en afgørelse fra tilsynsmyndighederne vil blive truffet i overensstemmelse med vejledningerne, og at en anfægtelse i denne situation derfor vil kræve, at sagen indbringes for domstolene. Se også mere generelt om databeskyttelsesrettens retskilder kap. 1.5.

5.2. Gensidig bistand og fælles aktiviteter

Forordningens art. 61 og 62 indeholder to bestemmelser om tilsynsmyndighedernes gensidige bistand og fælles aktiviteter.

Efter art. 61 skal tilsynsmyndighederne yde hinanden gensidig bistand. Forpligtelsen hertil fremgår af stk. 1:

Gensidig bistand
– art. 61

Tilsynsmyndighederne udveksler relevante oplysninger og yder hinanden gensidig bistand med henblik på at gennemføre og anvende denne forordning på en ensartet måde og træffer foranstaltninger med henblik på et effektivt samarbejde med hinanden. Gensidig bistand omfatter navnlig anmodninger om oplysninger og tilsynsforanstaltninger, som f.eks. anmodninger om gennemførelse af forudgående godkendelser og høringer, inspektioner og undersøgelser.

Den øvrige del af art. 61 fastlægger den nærmere procedure for den gensidige bistand, herunder frister for besvarelse, tilfælde hvor en tilsynsmyndighed kan afvise at yde bistand og betaling for bistand (som udgangspunkt skal bistand ydes gratis).

Art. 62 regulerer tilsynsmyndighedernes fælles aktiviteter. Dette gælder særligt fælles undersøgelses- og håndhævelsesforanstaltninger, hvor medarbejdere fra flere tilsynsmyndigheder deltager sammen. Ikke mindst, når de globale internettjenester oplever sikkerhedsbrud eller

Art. 62 – fælles
aktiviteter

handler i strid med forordningen, vil det ramme borgere i mange medlemsstater og derfor gøre en fælles undersøgelse relevant.

5.3. Sammenhængsmekanismen

Ønsket om at skabe en harmonisering af tilsynsmyndighedernes praksis er også søgt understøttet gennem en såkaldt sammenhængsmekanisme, der giver EDPB mulighed for i visse tilfælde at afgive udtalelser og træffe bindende afgørelser. Harmoniseringsønsket udtrykkes i indledningsbestemmelsen til sammenhængsmekanismen i art. 63:

Med henblik på at bidrage til en ensartet anvendelse af denne forordning i hele Unionen samarbejder tilsynsmyndighederne med hinanden og, hvis det er relevant, med Kommissionen gennem den sammenhængsmekanisme, der er omhandlet i denne afdeling.

Efter forordningens art. 64, stk. 1, afgiver Databeskyttelsesrådet udtalelse, når en national tilsynsmyndighed har til hensigt at træffe afgørelse i en række nærmere angivne situationer, f.eks. når tilsynsmyndigheden vil vedtage standardbestemmelser eller godkende bindende virksomhedsregler til brug for dataeksport. Formålet med bestemmelsen er at sikre en ensartet linje, når tilsynsmyndighederne træffer denne type afgørelser, eftersom afgørelsen ikke vedrører en konkret sag, men vil have en bredere anvendelse.

Udtalelse fra
EDPB – art. 64

I tillæg hertil indeholder art. 64, stk. 2, en bestemmelse om EDPB's mulighed for at afgive udtalelse i andre tilfælde. Bestemmelsen er formuleret på en måde, så den i princippet giver EDPB mulighed for at afgive en udtalelse om alle forhold under forordningen:

En tilsynsmyndighed, formanden for Databeskyttelsesrådet eller Kommissionen kan kræve, at ethvert almengyldigt spørgsmål eller ethvert spørgsmål, der har virkninger i mere end én medlemsstat, drøftes af Databeskyttelsesrådet med henblik på en udtalelse, navnlig hvis en kompetent tilsynsmyndighed ikke opfylder forpligtelserne vedrørende gensidig bistand, jf. artikel 61, eller vedrørende fælles aktiviteter, jf. artikel 62.

Bestemmelsen giver således EDPB mulighed for at afgive udtalelse om ethvert "almengyldigt" spørgsmål eller spørgsmål, der har virkning

i mere end én medlemsstat. Dette vil omfatte ethvert principielt spørgsmål om forståelsen af forordningen. Bestemmelsen angiver, at dette navnlig er i situationer, hvor en tilsynsmyndighed ikke opfylder sine forpligtelser efter bestemmelserne om gensidig bistand og fælles aktiviteter, men brugen af ordet “navnlig” indebærer, at bestemmelsen ikke er begrænset til disse tilfælde.

Se som et eksempel på anvendelse af bestemmelsen EDPB's Opinion 39/2021, der forholder sig til, om en tilsynsmyndighed efter art. 58, stk. 2, litra g, kan pålægge en dataansvarlig ex officio at slette oplysninger uden en forudgående anmodning fra den registrerede. Udtalelsen blev afgivet på baggrund af en henvendelse fra det ungarske tilsyn, der var i tvivl om spørgsmålet.

Sammenhængsmekanismen indeholder i art. 65 en hjemmel for EDPB til at træffe bindende afgørelser i nærmere angivne situationer. Dette gælder efter art. 65, stk. 1, litra a og b, når der er uenighed mellem tilsynsmyndighederne i forbindelse med en sag, der behandles af flere tilsynsmyndigheder under one-stop-shop ordningen (der omtales straks nedenfor). Det gælder endvidere efter litra c bl.a., “hvis en kompetent tilsynsmyndighed [...] ikke følger Databeskyttelsesrådets udtalelse udstedt i henhold til artikel 64”. Art. 64 giver Databeskyttelsesrådet mulighed for at udtale sig, hvis en tilsynsmyndighed påtænker at træffe en afgørelse i en række konkrete situationer, eller hvis tilsynsmyndigheder er uenige om deres forpligtelser under reglerne om gensidig bistand eller fælles aktiviteter. Det er åbenbart, at art. 65 i disse situationer giver Databeskyttelsesrådet mulighed for at træffe en afgørelse, som tilsynsmyndighederne skal følge. Som beskrevet giver art. 64 imidlertid Databeskyttelsesrådet en langt bredere mulighed for at udtale sig om alle principielle spørgsmål under forordningen. Når art. 65 giver rådet hjemmel til at træffe afgørelse, hvis en tilsynsmyndighed ikke følger rådets udtalelser “udstedt i henhold til art. 64”, synes konsekvensen at være, at rådet gennem en bindende afgørelse kan forpligte en tilsynsmyndighed til at følge enhver udtalelse om ethvert forhold, som rådet har afgivet efter art. 64. Dette ville være en meget vidtgående kompetence, og det følger ikke af de tilhørende præambelbetragtninger, at dette har været hensigten. Det kan derfor ikke udelukkes, at intentionen kun har været, at EDPB skal kunne træffe afgø-

Bindende
afgørelse fra
Databeskyttelsesr
ådet – art. 65

relser i konkrete tvister mellem tilsynsmyndighederne og i de specifikke situationer angivet i art. 64, stk. 1, og at bestemmelsens anvendelsesområde skal afgrænses på denne vis. Selv med en sådan begrænsning, er bestemmelsen et væsentligt element i harmoniseringsbestræbelserne.

Vejledninger mv.

Vejledninger knyttet til forordningens enkelte bestemmelser

Art 3. - anvendelsesområde		
EDPB	Retningslinjer 3/2018 om det territoriale anvendelsesområde for databeskyttelsesforordningen (artikel 3)	Version 2.1 12. November 2019
EDPB	Guidelines 05/2021 on the Interplay between the application of Article 3 and the provisions on international transfers as per Chapter V of the GDPR	Høringsversion 18. november 2021
Art. 4 - definitioner		
Nr. 7 og 8 – dataansvarlig og databehandler		
EDPB	Retningslinjer 07/2020 for begreberne dataansvarlig og databehandler i den generelle forordning om databeskyttelse	Version 2.0 7. juli 2021
Datatilsynet	Vejledning om dataansvarlige og databehandlere	Version af november 2017
Datatilsynet	Vejledende principper om dataansvar for vikarer og konsulenter	Udateret version
Datatilsynet	Vejledende tekst om rollefordelingen, når private er leverandører til det offentlige	Version af november 2021
Nr. 24 – relevant og begrundet indsigelse		
EDPB	Retningslinjer 09/2020 vedrørende relevant og begrundet indsigelse i henhold til forordning 2016/679	Version 2.0 9. marts 2021

Art. 6 - behandlingsgrundlag		
Litra a - samtykke		
EDPB	Retningslinjer 5/2020 vedrørende samtykke i henhold til forordning 2016/679	Version 1.1 4. maj 2020
Datatilsynet	Vejledning. Samtykke	Version af maj 2021
Litra b - kontrakt		
EDPB	Retningslinjer 2/2019 for behandling af personoplysninger i henhold til artikel 6, stk. 1, litra b), i GDPR i forbindelse med leveringen af onlinetjenester til registrerede	Version 2.0 8. oktober 2019
Kap. III – de registreredes rettigheder		
Datatilsynet	Vejledning om de registreredes rettigheder	Version af juli 2018
Art. 13 + 14 – oplysningspligt		
Art. 29-gruppen	Retningslinjer for gennemsigtighed i henhold til forordning 2016/679	WP 260 rev. 01 11. april 2018
EDPB har tilsluttet sig retningslinjerne ved Endorsement 1/2018		
Datatilsynet	Skabeloner til iagttagelse af oplysningspligten og indsigtsretten	
Art. 15 - indsigtsret		
EDPB	Guidelines 01/2022 on data subject rights - Right of access	Version 1.0 18. januar 2022
Datatilsynet	Skabeloner til iagttagelse af oplysningspligten og indsigtsretten	
Art. 17 – retten til sletning		
EDPB	Retningslinjer 5/2019 for kriterierne for retten til at blive glemt i søgemaskinesagerne under GDPR (del 1)	Version 2.0 7. juli 2020
Art. 20 - dataportabilitet		

Art. 29-gruppen	Retningslinjer vedrørende retten til dataportabilitet	WP 242 rev. 01 5. april 2017
EDPB har tilsluttet sig retningslinjerne ved Endorsement 1/2018		
Art. 22 – automatiske afgørelser		
Art. 29-gruppen	Retningslinjer om automatiske individuelle afgørelser og profilering i henhold til forordning 2016/679	WP 251 rev.01 6. februar 2018
EDPB har tilsluttet sig retningslinjerne ved Endorsement 1/2018		
Art. 23 – begrænsninger i registreredes rettigheder		
EDPB	Guidelines 10/2020 on restrictions under Article 23 GDPR	Version 2.0 13. oktober 2021
Art. 25 – databeskyttelse gennem design og standardindstillinger		
EDPB	Retningslinjer 4/2019 om artikel 25 Databeskyttelse gennem design og databeskyttelse gennem standardindstillinger	Version 2.0 20. oktober 2020
Datatilsynet, Justitsministeriet og Digitaliseringsstyrelsen	Behandlingssikkerhed. Databeskyttelse gennem design og standardindstillinger	Version af juni 2018
Art. 26 – fælles dataansvar		
Datatilsynet	Skabelon til aftale om fælles dataansvar	Version af 12. april 2018
Art. 28 - databehandlere		
Kommissionen	Gennemførelsesafgørelse 2021/915 om standardkontraktbestemmelser mellem dataansvarlige og databehandlere	Version af 4. juni 2021

EDPB	Retningslinjer 07/2020 for begreberne dataansvarlig og databehandler i den generelle forordning om databeskyttelse	Version 2.0 7. juli 2021
Datatilsynet	Vejledning om dataansvarlige og databehandlere	Version af november 2017
Datatilsynet	Vejledende principper om dataansvar for vikarer og konsulenter	Udateret version
Datatilsynet	Vejledende tekst om rollefordelingen, når private er leverandører til det offentlige	Version af november 2021
Datatilsynet	Vejledning om tilsyn med databehandlere	Version af oktober 2021
Art. 30 - fortegnelse		
Art. 29-gruppen EDPB har tilsluttet sig retningslinjerne ved Endorsement 1/2018	Working party 29 position paper on the derogations from the obligation to maintain records of processing activities pursuant to Article 30(5) GDPR	Version af 19. april 2018
Datatilsynet	Fortegnelse	Version af august 2020
Art. 33 + 34 – orientering om sikkerhedsbrud		
Art. 29-gruppen EDPB har tilsluttet sig retningslinjerne ved Endorsement 1/2018	Retningslinjer om anmeldelse af brud på persondatasikkerheden i henhold til forordning 2016/679	WP 250 rev.01 6. februar 2018
EDPB	Guidelines 9/2022 on personal data breach notification under GDPR (opdatering af WP 250)	Høringsversion af 10. oktober 2022

EDPB	Guidelines 01/2021 on Examples regarding Personal Data Breach Notification	Version 2.0 14. december 2021
Datatilsynet	Vejledning om håndtering af brud på persondatasikkerheden	Version af februar 2018
Art. 35 + 36 - konsekvensanalyse		
Art. 29-gruppen EDPB har tilsluttet sig retningslinjerne ved Endorsement 1/2018	Retningslinjer for konsekvensanalyse vedrørende databeskyttelse (DPIA) og bestemmelse af, om behandlingen "sandsynligvis indebærer en høj risiko" i henhold til forordning (EU) 2016/679	WP 248 rev.01 4. oktober 2017
Datatilsynet	Konsekvensanalyse	Version af marts 2018
Datatilsynet	Datatilsynets liste over de typer af behandlingsaktiviteter, der er underlagt kravet om en konsekvensanalyse vedrørende databeskyttelse jf. databeskyttelsesforordningens artikel 35, stk. 4.	Udateret version
Art. 37 + 38 - databeskyttelsesrådgiver		
Art. 29-gruppen EDPB har tilsluttet sig retningslinjerne ved Endorsement 1/2018	Retningslinjer for databeskyttelsesrådgivere	WP 243 rev.01 5. april 2017
Datatilsynet, Justitsministeriet, Digitaliseringsstyrelsen, Erhvervsstyrelsen	Vejledning om databeskyttelsesrådgivere	Version af december 2017
Art. 40 + 41 - adfærdskodekser		

EDPB	Retningslinjer 1/2019 for adfærdskodekser og kontrolorganer i henhold til forordning 2016/679	Version 2.0 4. juni 2019
Datatilsynet	Akkrediteringskrav for kontrolorganer til adfærdskodekser	Version af november 2020
Datatilsynet og Justitsministeriet	Vejledning om adfærdskodekser og certificeringsordninger	Version af december 2018
Art. 42 + 43 - certificering		
EDPB	Guidance on certification criteria assessment (Addendum to Guidelines 1/2018 on certification and identifying certification criteria in accordance with Articles 42 and 43 of the Regulation)	Høringsversion 6. april 2021
EDPB	Guidelines 1/2018 on certification and identifying certification criteria in accordance with Articles 42 and 43 of the Regulation 2016/679	Version af 25. maj 2018
EDPB	Annex 2 on the review and assessment of certification criteria pursuant to Article 42(5) to the Guidelines 1/2018 on certification and identifying certification criteria in accordance with Articles 42 and 43 of the Regulation 2016/679	Høringsversion 23. januar 2019
EDPB	Vejledning 4/2018 om akkreditering af certificeringsorganer i henhold til artikel 43 i den generelle forordning om databeskyttelse (2016/679)	Version 3.0 4. juni 2019
Datatilsynet	Datatilsynets supplerende akkrediteringskrav for certificeringsorganer	Version af marts 2021
Datatilsynet	Certificeringsordninger	Version af april 2021
Datatilsynet og Justitsministeriet	Vejledning om adfærdskodekser og certificeringsordninger	Version af december 2018
Art. 44 – generelle krav til tredjelandsoverførsler		

EDPB	Guidelines 05/2021 on the Interplay between the application of Article 3 and the provisions on international transfers as per Chapter V of the GDPR	Høringsversion 18. november 2021
Art. 46 – tredjelandsoverførsler til usikre tredjelande		
Art. 29-gruppen EDPB har tilsluttet sig retningslinjerne ved Endorsement 1/2018	Reference vedrørende et tilstrækkeligt beskyttelsesniveau	WP 254 rev.01 6. februar 2018
Art. 29-gruppen EDPB har tilsluttet sig retningslinjerne ved Endorsement 1/2018	Arbejdsdokument om en tjekliste over de elementer og principper, der skal være indeholdt i et sæt bindende virksomhedsregler	WP 256 rev.01 6. februar 2018
Art. 29-gruppen EDPB har tilsluttet sig retningslinjerne ved Endorsement 1/2018	Arbejdsdokument om en tjekliste over de elementer og principper, der skal være indeholdt i et sæt bindende virksomhedsregler for databehandlere	WP 257 rev.01 6. februar 2018

Art. 29-gruppen EDPB har tilsluttet sig retningslinjerne ved Endorsement 1/2018	Working Document Setting Forth a Co-Operation Procedure for the approval of “Binding Corporate Rules” for controllers and processors under the GDPR	WP 263 rev.01 11. april 2018
Art. 29-gruppen EDPB har tilsluttet sig retningslinjerne ved Endorsement 1/2018	Recommendation on the Standard Application for Approval of Controller Binding Corporate Rules for the Transfer of Personal Data	WP 264 11. april 2018
Art. 29-gruppen EDPB har tilsluttet sig retningslinjerne ved Endorsement 1/2018	Standard Application for Approval of Binding Corporate Rules for Processors	WP 265
EDPB	Retningslinjer 2/2020 om artikel 46, stk. 2, litra a), og artikel 46, stk. 3, litra b), i forordning (EF) nr. 2016/679 om overførsel af personoplysninger mellem myndigheder i EØS og offentlige myndigheder og organer uden for EØS	Version 2.0 15. december 2020
EDPB	Henstilling nr. 01/2020 om foranstaltninger, der supplerer overførselsværktøjer for at sikre overholdelse af EU-niveauet for beskyttelse af personoplysninger	Version 2.0 18. juni 2021

EDPB	Anbefalinger 02/2020 om de europæiske væsentlige garantier for overvågningsforanstaltninger	Version af 10. november 2020
EDPB	Guidelines 04/2021 on codes of conduct as tools for transfers	Høringsversion 7. juli 2021
EDPB	Guidelines 05/2021 on the Interplay between the application of Article 3 and the provisions on international transfers as per Chapter V of the GDPR	Høringsversion 18. november 2021
EDPB	Guidelines 07/2022 on certification as a tool for transfers	Version 1.0 14. juni 2022
Datatilsynet	Vejledning. Overførsel af personoplysninger til tredjelande	Version af juni 2022 (4. udgave)
Art. 47 – bindende virksomhedsregler		
EDPB	Recommendations 1/2022 on the Application for Approval and on the elements and principles to be found in Controller Binding Corporate Rules (art. 47 GDPR)	Høringsversion af 14. november 2022
Art. 49 – tredjelandsoverførsler - undtagelsesbestemmelse		
EDPB	Retningslinjer 2/2018 vedrørende undtagelser i artikel 49 i forordning 2016/679	Version af 25. maj 2018
Art. 57 – tilsynsmyndighedernes opgaver		
EDPB	Guidelines 06/2022 on the practical implementation of amicable settlements	Version 2.0 12. maj 2022
Art. 60 – Samarbejde mellem ledende og berørte tilsynsmyndigheder		
EDPB	Guidelines 8/2022 on identifying a controller or processor's lead supervisory authority	Version 1.0 10. oktober 2022
EDPB	Retningslinjer 02/2022 om anvendelse af artikel 60 i den generelle forordning om databeskyttelse	Version 1.1 14. marts 2022
Art. 65 (+ 60) – relevant og begrundet indsigelse		
EDPB	Retningslinjer 09/2020 vedrørende relevant og begrundet indsigelse i henhold til forordning 2016/679	Version 2.0 9. marts 2021

Art. 65 (1)(a) – bindende afgørelser fra EDPB		
EDPB	Guidelines 03/2021 on the application of Article 65(1)(a) GDPR	Høringsversion 13. april 2021
Art. 83 – bøder		
Art. 29-gruppen EDPB har tilsluttet sig retningslinjerne ved Endorsement 1/2018	Retningslinjer vedrørende anvendelse og fastsættelse af administrative bøder i overensstemmelse med forordning (EU) 2016/679	WP 253 3. oktober 2017
Datatilsynet	Bødevejledning. Udmåling af bøder til fysiske personer	Version af februar 2022
Datatilsynet	Bødevejledning. Udmåling af bøder til virksomheder	Version af januar 2021

Tematiske vejledninger

EDPB	Guidelines 05/2022 on the use of facial recognition technology in the area of law enforcement	Version 1.0 12. maj 2022
EDPB	Guidelines 3/2022 on dark patterns in social media platform interfaces: How to recognise and avoid them	Version 1.0 14. marts 2022
EDPB	Retningslinjer 02/2021 vedrørende digitale stemmestyrede assistenter	Version 2.0 7. juli 2021
EDPB	Henstilling 02/2021 om retsgrundlaget for opbevaring af kreditkortoplysninger med det ene formål at lette yderligere onlinetransaktioner	Version af 19. maj 2021

EDPB	Retningslinjer 8/2020 vedrørende målretning mod brugere af sociale medier	Version 2.0 13. april 2021
EDPB	Retningslinjer 1/2020 om behandling af personoplysninger i forbindelse med opkoblede køretøjer og mobilitetsrelaterede anvendelser	Version 2.0 9. marts 2021
EDPB	Retningslinjer 06/2020 om samspillet mellem andet betalingstjenestedirektiv og databeskyttelsesforordningen	Version 2.0 15. december 2020
EDPB	Retningslinjer 04/2020 om brug af lokaliseringsdata og kontaktopsporingsredskaber i forbindelse med covid-19- udbruddet	Version 1.1 5. maj 2020
EDPB	Retningslinjer 03/2020 om behandling af helbredsoplysninger med henblik på videnskabelig forskning i forbindelse med covid-19- udbruddet	Version 1.1 30. april 2020
EDPB	Retningslinjer 3/2019 om brug af videoudstyr til behandling af personoplysninger	Version 2.0 29. januar 2020
Art. 29-gruppen EDPB har tilsluttet sig retningslinjerne ved Endorsement 1/2018	Retningslinjer for gennemsigtighed i henhold til forordning 2016/679	WP 260 rev. 01 11. april 2018
Datatilsynet	Vejledning om cloud	Version af marts 2022
Datatilsynet	Udveksling af personoplysninger med politiet	Version af januar 2021
Datatilsynet	Databeskyttelse i forbindelse med ansættelsesforhold	Version af december 2020

Datatilsynet	Optagelser af telefonsamtaler	Version af november 2020
Datatilsynet	Behandling af personoplysninger om hjemmesidebesøgende	Version af februar 2020
Datatilsynet	Vejledning om spærrelistes	Version af november 2019
Datatilsynet	Kreditoplysningsbureauer	Version af oktober 2019

Litteraturfortegnelse

- Blume Peter, Persondatarettens omfang og grænser, Juristen nr. 5/6, 2018, s. 155 ff.
- Blume Peter, Databeskyttelsesret, 5. udgave, Djøf Forlag, 2018.
- Blume, Peter, Den nye persondatarets aktører, Djøf Forlag, 2018.
- Blume, Peter, Den nye persondataret, 2. udgave, Djøf Forlag, 2020.
- Boberg, Vibeke, Kapitel 8. Personlighedsret i Udsen (red.), Lærebog i informationsret.
- Breithbarth, Paul, A Risk-Based Approach to International Data Transfers, European Data Protection Law Review, 2021/4, s. 539 ff.
- Chen, Jiachong, How the best-laid plans go awry: the (unsolved) issues of applicable law in the General Data Protection Regulation, International Data Privacy Law, 2016, s. 310 ff.
- De Terwangne, Cécile, Article 5. Principles relating to processing of personal data i Kuner m.fl. (red.), The EU General Data Protection Regulation (GDPR).
- Finck Michéle, Blockchains and Data Protection in the European Union, European Data Protection Law, 2018, s. 17 ff.
- Henrichsen, Carsten, Jens Elo Rytter & Steen Rønsholdt (red.), Ret, informatik og samfund, Jurist- og Økonomforbundets Forlag, 2010.
- Jakobsen, Søren Sandfeld & Sten Schaumburg-Müller, Persondatabehandling i journalistisk øjemed, Juristen, 2017, s. 53 ff.
- Korfits Nielsen, Kristian & Anders Lotterup, Databeskyttelsesforordningen og databeskyttelsesloven, Jurist- og Økonomforbundets Forlag, 2020.
- Kotschy, Waltraut, Article 6. Lawfulness of processing i Kuner m.fl. (red.), The EU General Data Protection Regulation (GDPR).

- Kuner, Christopher, Lee A. Bygrave, Christopher Docksey & assistant editor Laura Drechsler, *The EU General Data Protection Regulation (GDPR). A Commentary*, Oxford University Press, 2020.
- Millard, Christopher (red.), *Cloud Computing Law*, 2. udgave, Oxford University Press, 2021.
- Mortensen, Bent Ole Gram (red.), *Dansk Persondataret*, 2020.
- Motzfeldt, Hanne Marie, *Grundlæggende databeskyttelsesret*, Djøfs Forlag, 2022.
- Quiin, Paul & Gianclaudio Malgieri, *The Difficulty of Defining Sensitive Data – The Concept of Sensitive Data in the EU Data Protection Framework*, *German Law Journal*, Vol. 22, Issue 8, 2021, s. 1583 ff.
- Svantesson, Dan B., *Article 4(1)(a) ‘establishment of the controller’ in EU data privacy law – time to rein in this expanding concept?*, *International Data Privacy Law*, 2016, vol. 6, issue 3, s. 210 ff.
- Udsen, Henrik, *De informationsretlige grundsætninger – studier i informationsretten*, Djøf Forlag, 2009.
- Udsen, Henrik, *Behandling af offentliggjorte personoplysninger – særligt om sociale netværkstjenester i Henrichsen m.fl. (red.)*, *Ret, informatik og samfund*, s. 321 ff.
- Udsen, Henrik, *Digitale freds- og ærekrænkelser i Udsen m.fl. (red.)*, *Festskrift til Mads Bryde Andersen*, s. 121 ff.
- Udsen, Henrik, Jan Schans Christensen, Jesper Lau Hansen, Torsten Iversen & Linda Nielsen (red.), *Festskrift til Mads Bryde Andersen*, *Jurist- og Økonomforbundets Forlag*, 2018.
- Udsen, Henrik, *Lærebog i informationsret*, 2. udgave, Djøf Forlag, 202.
- Udsen, Henrik, *Konkurrerende behandlingsgrundlag – valg og skift af behandlingsgrundlag i databeskyttelsesretten med særlig fokus på samtykke*, *Juristen*, nr. 2, 2022, s. 83 ff.
- Ullits, Jøren, *Journalistbegrebet i retlig belysning*, Karnov Group, 2019.
- Van Alsenoy, Brendan, *Liability under the EU Data Protection Law: From Directive 95/46 to the General Data Protection Regulation*, 7 (2016), *JIPITEC* 271, para 1.

Warren, Samuel D. & Louis D. Brandis, The Right to Privacy, Harward Law Review, vol. 4, no. 5, 1890.

Wiese Schartum, Dag, Personvernforordningen – en lærebok, Fagbokforlaget, 2020.

Wuermeling, Ulrich & Isabella Oldani, Chapter 10. Regulation of International Data Transfers in Clouds i Millard (red.), Cloud Computing Law.

Zanfir-Fortuna, Gabriela, Article 82, Right to compensation and liability, i Kuner m.fl. (red.), The EU General Data Protection Regulation (GDPR).